European Digital Identity Wallet

Architecture and Reference Framework



v3.0.0 20260723.191048

Contents

Architecture and Reference Framework **6**
1 Introduction . . . 6
1.1 EUDI Wallet ecosystem . . . 6
1.2 Legal context . . . 7
1.3 Purpose, scope and audience . . . 8
1.4 Relation to the Large-Scale Pilots (LSP) . . . 9
1.5 Definitions . . . 10
1.6 Change Log . . . 10
1.7 Further refinement of the ARF . . . 10
1.8 Drafting Process and Discussion Papers . . . 11
2 EUDI Wallet functionalities . . . 12
2.1 Introduction . . . 12
2.2 Identification and authentication . . . 12
2.3 Attribute exchange mechanism using attestations . . . 14
2.4 Qualified electronic signatures . . . 14
2.5 Pseudonyms . . . 14
2.6 The role of Use Cases . . . 17
3 Roles within the EUDI Wallet ecosystem . . . 22
3.1 Introduction . . . 22
3.2 Users of Wallet Units . . . 25
3.3 Wallet Providers . . . 26
3.4 Person Identification Data (PID) Providers . . . 26
3.5 Trusted List Provider or LoTE Provider . . . 27
3.6 Qualified Electronic Attestation of Attributes (QEAA) Providers . . . 28
3.7 EAA issued by or on behalf of a public sector body responsible for an authentic source (PuB-EAA) Providers . . . 29
3.8 Non-Qualified Electronic Attestation of Attributes (EAA) Providers . . . 29
3.9 Qualified Electronic Signature Remote Creation (QESRC) Providers . . . 30
3.10 Authentic Sources . . . 30
3.11 Relying Parties, Relying Party Services, Relying Party Instances, and intermediaries . . . 31
3.12 Conformity Assessment Bodies (CAB) . . . 34
3.13 Supervisory Bodies . . . 34

3.14 Device Manufacturers and Related Subsystems Providers 34
3.15 Attestation Scheme Providers for QEAAs, PuB-EAAs and EAAs 34
3.16 National Accreditation Bodies 35
3.17 Registrars 35
3.18 Access Certificate Authorities 36
3.19 Providers of registration certificates 37
4 High-level architecture 39
4.1 Introduction 39
4.2 Design principles 39
4.3 Reference architecture 41
4.4 Data presentation flows 48
4.5 WSCD architecture types 58
4.6 State diagrams 61
4.7 Possible implementations of pseudonyms 68
5 Data model and data exchange protocols 74
5.1 Attestation elements 74
5.2 Attestation categories 75
5.3 Logical versus technical PIDs and attestations 77
5.4 Technical attestation formats and proof mechanisms 78
5.5 Attestation Rulebooks and Attestation schemes 82
5.6 Catalogue of attributes and catalogue of attestation schemes 83
5.7 Protocols and transmission mechanisms for attestation presentation . . . 85
5.8 Protocols and transmission mechanisms for attestation issuance 88
6 Trust model 89
6.1 Scope 89
6.2 Trust throughout a Wallet Provider lifecycle 92
6.3 Trust throughout a PID Provider or an Attestation Provider lifecycle 93
6.4 Trust throughout a Relying Party lifecycle 98
6.5 Trust throughout a Wallet Unit lifecycle 99
6.6 Trust throughout a PID or an attestation lifecycle 117
7 Wallet Solution Certification and Risk Management 161
7.1 Introduction 161
7.2 Certification of Wallet Solutions against national certification schemes . . 162
7.3 Certification of Wallet Solutions against a dedicated CSA-based scheme . 164
7.4 Risk-based approach and risk register 164

7.5 Functional conformance (FCAF) . . . 172
8 Accessibility . . . 174
8.1 Introduction . . . 174
8.2 Legal instruments and standards . . . 174
8.3 Wallet Units and other User-facing components . . . 175
9 Document development . . . 176
9.1 Publication and Lifecycle . . . 176
9.2 Contributing and Community Engagement . . . 176
9.3 Document Versioning . . . 176
10 References . . . 177
10.1 Commission Regulations and Decisions . . . 177
10.2 International and European standards and technical specifications . . . 185
10.3 Topics from Annex 2 . . . 192
10.4 Technical Specifications published by the Commission . . . 193
11 Annexes . . . 195

ANNEX 1 - Definitions **196**
A.1 Introduction . . . 196
A.2 Definitions from the European Digital Identity Regulation . . . 196
A.3 Definitions from the adopted Commission Implementing Regulations . . . 200
A.4 Additional definitions used in the ARF . . . 203

ANNEX 2.01 - High-Level Requirements **212**

ANNEX 2.02 - High-Level Requirements by topic **213**
A.2 High-level requirements by topic . . . 213
A.2.1 Introduction . . . 213
A.2.2 Structure and order of presentation of the HLRs . . . 214
A.2.3 High-Level Requirements . . . 214

ANNEX 2.03 - High-Level Requirements by category **348**
A.2 High-level requirements by category . . . 348
A.2.1 Introduction . . . 348
Part 1: Actor-Specific Requirements . . . 349
1. Wallet Providers . . . 349
2. Member States & Registrars . . . 413

3. Attestation & PID Providers . . . 429
4. Relying Parties . . . 466
Part 2: Ecosystem-Wide Rules . . . 471
5. Protocols & Interoperability . . . 471
6. Data Models & Attestation Rules . . . 480
A.2.2 Backward Reference: Original Topics . . . 506

ANNEX 3.01 - PID Rulebook **509**

ANNEX 3.02 - mDL Rulebook **509**

EUDI Wallet - Design Guide **509**
1 Introduction . . . 510
1.1 Purpose of the design guide . . . 510
1.2 Boundaries of the design guide . . . 510
1.3 Importance of design consistency . . . 510
1.4 Overview of design criteria . . . 511
2 Design criteria . . . 512
2.1 Visibility of system status . . . 512
2.2 Match between system and the real world . . . 513
2.3 User control and freedom . . . 515
2.4 Consistency and standards . . . 516
2.5 Error prevention . . . 516
2.6 Recognition rather than recall . . . 518
2.7 Flexibility and efficiency of use . . . 518
2.8 Aesthetic and minimalist design . . . 519
2.9 Help users recognize, diagnose, and recover from errors . . . 519
2.10 Help and documentation . . . 520
2.11 Accessibility . . . 521
2.12 Writing . . . 524
3 EUDI Wallet - Design Considerations . . . 527
3.1 User authentication . . . 527
3.2 Browsing credentials/documents . . . 527
3.3 QR code presentation . . . 527
3.4 Confirmation/Summary/Authentication results . . . 527
3.5 Error Messages . . . 528

3.6 Privacy/Security by Design . . . 528
3.7 Trust Mark . . . 528
3.8 Notification guidelines . . . 528
4 Conclusion . . . 529

EUDI WALLET DESIGN GUIDE - DATA SHARING SCENARIOS 529
1 Situations for Identification/Authorization . . . 529
2 Identifications . . . 533
2.1 Identification Points . . . 533
2.2 Identification Methods . . . 534
Authentication Methods Comparison . . . 536
3 Receiving & Configuring Data Request (by the User) . . . 537
4 Authorization . . . 541
4.1 Remote (Online) Authorization and Authentication . . . 541
4.2 Proximity-Based Authorization . . . 541
5 Error Cases . . . 542

Architecture and Reference Framework

The Architecture and Reference Framework is organised into the following chapters.

- 1 Introduction
- 2 EUDI Wallet functionalities
- 3 Roles within the EUDI Wallet ecosystem
- 4 High-level architecture
- 5 Data model and data exchange protocols
- 6 Trust model
- 7 Wallet Solution Certification and Risk Management
- 8 Accessibility
- 9 Document development
- 10 References
- 11 Annexes

1 Introduction

1.1 EUDI Wallet ecosystem

The European Digital Identity (EUDI) Wallet is a secure, user-controlled digital application that empowers citizens to manage their official identity and other personal data. It allows Users to request verified digital information (known as “attestations”) from trusted issuers (known as PID Providers and Attestation Providers), store that information, and present it to trusted parties (called Relying Parties) in a way that prioritizes privacy and security.

This Architecture and Reference Framework defines the following aspects of the EUDI Wallet ecosystem:

- Chapter 2 describes the main functionalities of a Wallet Unit, from the perspective of the User.
- Chapter 3 describes the main roles and components within the EUDI Wallet ecosystem, with their associated responsibilities.
- Chapter 4 describes the architecture of EUDI Wallet ecosystem, including its design principles, the components that make up a Wallet Unit and the interfaces between a Wallet Unit and other entities, the proximity and remote attestation presentation flows, the different architectures that may be used for implementing a WSCD, the lifecycles of

the main entities and components, and the implementation of pseudonym generation and presentation.
- Chapter 5 describes the elements that make up an attestation, the different (legal) attestation categories that will be used in the EUDI Wallet ecosystem, the different attestation formats, the role of attestation rulebooks and associated catalogues, and the different attestation presentation protocols.
- Chapter 6 contains the trust model for the EUDI Wallet ecosystem. For each of the main entities and components in the ecosystem, this chapter describes the mechanisms used to ensure it can be trusted by the entities it interfaces with, throughout its lifetime. These mechanisms may include registration, revocation, authentication, and authorisation.
- Chapter 7 discusses Wallet Solution certification and risk management.
- Chapter 8 discusses the accessibility of all User-facing components of the EUDI Wallet ecosystem.
- Chapter 9 describes how this document is and will be developed.
- Chapter 10 contains a list of references.
- Chapter 11 lists the Annexes to this document.

1.2 Legal context

The European Digital Identity Framework is established by Regulation (EU) No 910/2014, as amended by Regulation (EU) 2024/1183 (the European Digital Identity Regulation). This ARF is developed as part of the Common Union Toolbox to support the implementation of that Regulation, as described below.

On 3 June 2021, the European Commission adopted COMMISSION RECOMMENDATION (EU) 2021/946 of 3 June 2021 on a Common Union Toolbox for a coordinated approach towards a European Digital Identity Framework, calling on Member States to work closely together with the Commission towards the development of a Toolbox including a technical Architecture and Reference Framework (hereinafter the ARF), a set of common standards and technical specifications and a set of common guidelines and best practices.

The Recommendation specifies that these outcomes will serve as a basis for the implementation of the European Digital Identity Regulation, without the process of developing the Toolbox interfering with, or prejudging the legislative process.

The Recommendation establishes a structured framework for cooperation between Member States, the Commission, and, where relevant, private sector operators to develop the Toolbox.

The European Digital Identity Cooperation Group (EDICG), formerly known as the eIDAS Expert Group, is responsible for:

- exchanging best practices and cooperating with the Commission on emerging policy initiatives in the field of digital identity wallets, electronic identification means and trust services;
- advising the Commission in the preparation of draft implementing and delegated acts;
- supporting Supervisory Bodies in the implementation of the European Digital Identity Regulation;
- organising peer reviews of electronic identification schemes;
- engaging with the Commission and other relevant stakeholders to develop a Common Union Toolbox;

The European Digital Identity Cooperation Group's page can be found at the official page.

The European Digital Identity Cooperation Group has since further developed the concepts and specifications for the European Digital Identity Framework. The current ARF version is based on the legal text adopted by the co-legislators, including the Commission Implementing Regulations adopted under it. The complete list of these implementing acts, with their official titles and links, is provided in Section 10.1.

To harmonise the conformity assessment of the functional requirements that Wallet Solutions must support under CIR 2024/2981, the European Commission and the Member States are establishing the Functional Conformance Assessment Framework (FCAF), which complements the cybersecurity certification of Wallet Solutions. The FCAF is described in Section 7.5.

1.3 Purpose, scope and audience

This **EUDI Wallet Architecture and Reference Framework (ARF)** defines the architecture, components, and interactions of the EUDI Wallet ecosystem. It provides the technical foundation for ensuring ecosystem-wide **interoperability, security, and privacy**.

Specifically, this document serves three primary purposes:

- **Explains the architecture:** It details the system components and their interactions, serving as background information for the High-Level Requirements (HLRs) found in Annex 2.
- **Guides implementation:** It acts as a common reference for the harmonised implementation of the European Digital Identity Regulation, guiding the development of technical specifications, standards, and operational procedures.

- **Supports development of reference implementation:** It is used to develop the Wallet Solution reference implementation and will serve as a foundation for future updates to Implementing Acts based on technological advancements.

This ARF is **informative** and intended to support implementation; it **does not replace** the legally binding European Digital Identity Regulation or its adopted implementing and delegated acts, which are the only mandatory requirements.

This document applies exclusively to EUDI Wallet ecosystems compliant with the Regulation. It represents the current state-of-play of the European Digital Identity Cooperation Group and will be updated over time.

The audience of the ARF consists of:

- Entities acting as PID Providers, QEAA Providers, PuB-EAA Providers, or EAA Providers,
- Wallet Providers,
- Relying Parties,
- Conformity Assessment Bodies (CABs), and
- Supervisory Bodies.

1.4 Relation to the Large-Scale Pilots (LSP)

To support the development of a reference implementation of a Wallet Solution and to pilot its usage across different priority use cases, the Commission launched a call for proposals on 22 February 2022 under the Digital Europe Programme to pilot use cases for the EUDI Wallet ecosystem at a large scale.

The objective of the Large-Scale Pilots (LSP) call is to support the piloting of the EUDI Wallet ecosystem around a range of use cases involving both public and private sector stakeholders. The LSPs will test the EUDI Wallet ecosystem in both national and cross-borders contexts and integrate with the iterative development of the reference application.

The works of the LSPs will be aligned with the ARF, which will guide pilot system design and architecture development together with the release of the reference implementation.

The LSPs are expected to provide feedback on the ARF as they develop and interact with Relying Party services, Qualified or non-qualified Electronic Attestations of Attributes (Q)EAA Providers, Person Identification Data (PID) Providers, Qualified and non-qualified Trust Service Providers and Users in meaningful interactions under the proposed use cases.

1.5 Definitions

The definitions used in this document can be found in Annex 1 of this document.

1.6 Change Log

In this version of the ARF, the following changes were made:

- Changes due to the CIRs amending CIR 2025/848,
- Changes due to the CIRs amending CIR 2024/2977, CIR 2024/2979, CIR 2024/2980, and CIR 2024/2982,
- Changes due to the revision round discussion paper for Topic J (Wallet-to-wallet interactions).
- Changes due to the revision round discussion paper for Topic X (Relying Party registration), which introduced the concept of Relying Party Services, especially in Section 3.11.2 and in Topic 44.
- Several issues raised via Confluence and GitHub have been resolved.

Apart from these changes, a number of editorial mistakes were corrected.

1.7 Further refinement of the ARF

The **Architecture and Reference Framework (ARF)** will be further refined and maintained according to the ARF work plan, which addresses the work to:

- Refine and stabilize high-level requirements (HLRs) for core EUDI Wallet functionalities.
- Maintain alignment with relevant standards and technical specifications.
- Maintain alignment with certification requirements.

The work will be progressed through discussions with Member States, the European Digital Identity Cooperation Group, civil society, industry representatives, and professionals, ensuring broad and comprehensive feedback from all relevant stakeholders.

The outcomes of these discussions will be incorporated into future versions of the ARF. The document will continue to evolve iteratively, improving its content and addressing new topics as they emerge. The process for providing feedback and details on how updates are managed is described in Chapter 9.

The topics to further refine and stabilise the ARF are available on GitHub, including progress updates.

Please note the ARF and its supporting materials remain open to continuous feedback via the internal and public channels, and stakeholders can propose new or revised topics at any time. Updates to the ARF are implemented through the ARF work plan: topics are prioritized, scheduled, and progressed via the agreed process, and the work plan is updated accordingly as implementation needs evolve.

1.8 Drafting Process and Discussion Papers

The development of the **Architecture and Reference Framework (ARF)** is guided by discussions with Member States and experts from the European Digital Identity Cooperation Group, as well as by feedback from industry and the wider community through GitHub.

For each discussion topic, a **Discussion Paper** is created and iteratively refined until consensus is reached. Once finalised, the paper is integrated into the next release of the ARF. An overview of all Discussion Papers and the ARF versions into which they were integrated can be found in the corresponding README file.

Once a Discussion Paper has been integrated into the ARF, it is **no longer updated**. Over time, its content may therefore become outdated, for example, when high-level requirements are modified in later ARF versions. This can happen for several reasons:

- **Adjustments at integration**
  Requirements or descriptions may already be slightly modified when a Discussion Paper is integrated into the ARF, to ensure consistency of language and style across the ARF. Sometimes further refinements are made in collaboration between the ARF editors and the authors of the paper, for example to solve contradictions between high-level requirements proposed in the discussion paper and existing requirements in other parts of the ARF.
- **Interdependence of topics**
  Discussion topics are not entirely separate. The introduction of new Discussion Papers may lead to adjustments of existing requirements or descriptions in the ARF.
- **Continuous feedback**
  The Commission receives feedback via Confluence, GitHub, and internal reviews. When accepted, these comments lead to further changes in the ARF.

Although the ARF may reference Discussion Papers as background information, **historic Discussion Papers (including their proposed high-level requirements) should not be used**. The final requirements are those in the latest version of the Annex 2 of the ARF. In addition, as said in Section 1.3, the ARF itself is informative and not legally binding.

2 EUDI Wallet functionalities

2.1 Introduction

The EUDI Wallet ecosystem is designed as a secure, User-controlled digital environment that enables Users to use their Wallet Unit to manage and present their person identification data (PID) and attestations across both public and private services in the EU. Its functionalities are built around security, privacy, and User control, ensuring seamless interactions with Relying Parties and other entities, while adhering to data protection principles.

This chapter outlines the core functionalities of the Wallet, as defined by the European Digital Identity Regulation, and examines how the requirements for its implementation align with real-world use cases where Users will use their Wallet Unit.

The functionalities of a Wallet can be grouped into the following categories:

- **Secure identification and authentication**, ensuring that Users can present person identification data in a trusted environment.
- **Exchanging qualified and non-qualified User attributes** through secure and verifiable electronic attestations of attributes.
- **Electronic signing of documents or data**, allowing Users to create legally recognised qualified electronic signatures and seals.
- **Generate and use pseudonyms** for authentication, to enhance privacy and prevent tracking.

These functionalities are discussed in the next four sections.

2.2 Identification and authentication

Using their Wallet, Users are able to:

- **Identify and authenticate** to online and offline services, while using **selective disclosure** of attributes as well as **User approval**. This ensures that only necessary and

User-approved attributes are presented to Relying Parties, which minimises exposure of personal information.

- **Securely authenticate Relying Parties or other Wallet Units**, making sure that attributes are only presented to trusted entities.
- **Onboard seamlessly with PID Providers or attestation Providers** by leveraging existing electronic identification schemes, for a smooth and secure registration process.
- **Be informed** whether a Relying Party is registered to receive the attributes it requests.
- **Access a transaction log via a dashboard**, allowing Users to:
  - **Review past interactions** with Relying Parties and other Wallets.
  - **Request data erasure** under Regulation (EU) 2016/679, Article 17 (right to erasure), to maintain privacy.
  - **Report suspicious Relying Parties** to the relevant national data protection authority.

These identification and authentication functions are closely linked to the concept of the Wallet as an **electronic identity (eID) means**. Article 3(42) of the European Digital Identity Regulation defines the European Digital Identity Wallet as an electronic identification means. As explained in this ARF, a Wallet Provider provides a Wallet Unit (a unique technical configuration of its generic Wallet Solution) to a User. The Wallet Unit, together with the PID issued to it and operated under the relevant eID scheme, implements the functionality of the European Digital Identity Wallet as the eID means.

Article 5a(5), point (d), requires that the European Digital Identity Wallet, provided under the relevant eID scheme, meets the requirements for Level of Assurance high. In this ARF, this is implemented through a Wallet Provider providing a Wallet Unit to which a PID is issued by a PID Provider. The Wallet Unit is operated under an eID scheme at Level of Assurance high.

The concept of Level of Assurance (LoA) is defined for electronic identification means (and the corresponding eID scheme). In the context of the EUDI Wallet ecosystem, this means that the LoA concept only applies to PID. For other attestations held and managed in the Wallet Unit, assurance and trust are expressed through other mechanisms (e.g., the security controls required for issuance and lifecycle management) and the European Digital Identity Regulation does not prescribe any specific level to be reached.

To reflect this, the ARF uses the term ‘level of security’ for non-PID attestations, to indicate that different attestations may be subject to different security requirements. Each Attestation Provider specifies the required level of security for its attestations (including, where applicable, requirements on issuance, storage, presentation, and lifecycle management).

2.3 Attribute exchange mechanism using attestations

Using their Wallet Unit, Users are able to:

- **Request, store, and present** personal identification data and electronic attestations of attributes under their sole control, ensuring secure usage in both online and offline scenarios.
- **Backup a list of their attributes, attestations, and configurations**, guaranteeing compliance with data portability rights.
- **Prevent tracking by Relying Parties** when using attestations, ensuring privacy-preserving interactions.

2.4 Qualified electronic signatures

Using their Wallet Unit, Users are able to:

- **Create qualified electronic signatures and seals** for legally binding digital transactions.
- **Sign documents using qualified electronic signatures**, which are provided by default and free of charge to natural persons using the Wallet (Regulation (EU) No 910/2014, Article 5a(5), point (g)). Member States may provide for proportionate measures to limit the free-of-charge use to non-professional purposes.

These functionalities are implemented by using the authentication and signing capabilities of the Wallet as part of a local QSCD, or by involving a remote QSCD managed by a QTSP (called a Qualified Electronic Signature Remote Creation (QESRC) Provider). Local QSCDs are discussed in Section 4.3.2. QESRC Providers are discussed in Section 3.9.

For high-level requirements regarding the creation of qualified electronic signatures, see Topic 16.

2.5 Pseudonyms

2.5.1 Overview

Using the Wallet, Users are able to present a pseudonym to a Relying Party to authenticate in situations where it is not necessary for the Relying Party to learn the User's identity. A pseudonym enables the Relying Party to recognise the same User across sessions within a

defined scope, while avoiding unnecessary identification. This aligns with the general principle in European Digital Identity Regulation, Article 5, that the use of user-chosen pseudonyms shall not be prohibited.

In the European Digital Identity Wallet context, Wallet Units must support the generation of pseudonyms and store them encrypted and locally (European Digital Identity Regulation, Article 5a(4)(b)). In addition, Relying Parties must not refuse the use of pseudonyms where identification of the user is not required by Union or national law (European Digital Identity Regulation, Article 5b(9)).

The Discussion Paper for Topic E introduced four possible use cases for pseudonyms within the EUDI Wallet ecosystem:

- A. Pseudonymous authentication,
- B. Attribute registration with subsequent authentication using a pseudonym,
- C. Rate-limited participation and
- D. Linkable pseudonymous authentication.

These use cases are described in the next sections. Section 4.7 provides further information on how pseudonyms can be implemented to support these use cases.

For high-level requirements, see Topic 11 in Annex 2.

2.5.2 Use case A: Pseudonymous authentication

A User authenticates to a Relying Party using a pseudonym when the Relying Party does not need to know the User's identity. The Relying Party typically links the pseudonym to an account and afterwards grants access to that account when the User can successfully authenticate using that pseudonym. To be reliable for account access, pseudonyms must be unique within the relevant scope (i.e., no collisions between different Users for the same Relying Party scope). A User may hold multiple pseudonyms at the same Relying Party (e.g., multiple accounts).

2.5.3 Use case B: Attribute registration with subsequent authentication using a pseudonym

This use case builds on use case A. In addition to pseudonymous authentication, the User may wish to register verifiable attributes (e.g., by presenting a PID or attestation) in the account. The Relying Party receives evidence that the attributes provided are associated with the same

User who controls the pseudonym. Where available, a cryptographic binding mechanism, as discussed in Section 6.6.3.10.2, can be used to strengthen the assurance of that association while avoiding unnecessary disclosure.

2.5.4 Use case C: Rate-limited participation

This use case builds on use case A or B, but adds the guarantee that a User can register only a limited number of distinct pseudonyms (called the 'rate') for a given scope, as defined by the Relying Party. This supports scenarios such as limiting spam or bot registrations or enforcing "one participation per person" patterns, while still avoiding disclosure of the User's identity.

2.5.5 Use case D: Linkable pseudonymous authentication across multiple actors

In this use case, a single pseudonym is used to authenticate towards multiple actors, so that these actors can recognise the User and (where intended) exchange information based on that pseudonym for a specific purpose. A typical example is an e-commerce flow where a User uses one pseudonym with a merchant and later authenticates with the same pseudonym to a carrier for delivery or pick-up. Because this introduces cross-party linkability, it should be supported only where necessary for the use case and with appropriate safeguards and User choice.

2.5.6 Use case support

Commission Implementing Regulation (EU) 2024/2979 sets the baseline obligations for pseudonyms: Wallet Units must support pseudonym generation and, upon request of a wallet-relying party, generate a pseudonym that is specific and unique to that wallet-relying party, and provide it to the wallet-relying party either stand-alone or in combination with a requested PID or attestation (CIR 2024/2979, Article 14 (2)).

With regard to the use cases identified above, this implies the following:

- Wallet Units support use case A (Pseudonymous authentication), since this is required in the CIR. The technical specifications in W3C WebAuthn can be used to implement this use case, although other mechanisms can be used as well.
- Use case B (Attribute registration with subsequent authentication using a pseudonym) is partially supported, insofar as Article 14(2) enables Wallet Units to provide the pseudonym in combination with a PID or attestation, but additional technical

specification work is needed to specify a common cryptographic binding mechanism to bind the PID or attestation to the pseudonym.
- Use case C (Rate-limited participation) requires the specification of an additional mechanism to ensure interoperability. Section E in Topic 11 contains a set of expectations for such a mechanism.
- Use case D (Linkable pseudonymous authentication) can be supported by issuing pseudonyms in the form of an attestation, see Section 4.7.3. However, no common specification of pseudonym attestations is available currently.

Future ARF iterations will therefore develop and/or reference additional technical specifications to support the use cases B - D in a harmonised way (including conformance expectations), building on the baseline established by CIR 2024/2979.

2.6 The role of Use Cases

2.6.1 Overview

The development of the Architecture and Reference Framework (ARF) is strategically driven by real-world use cases, ensuring that the User experience, value proposition, and requirements of the EUDI Wallet ecosystem are effectively addressed. To achieve this, the European Digital Identity Cooperation Group initially created service blueprints for each use case, which detail service touch points, components, and processes.

These blueprints serve a dual purpose: they play a crucial role in service design, enhancing both User experience and operational efficiency, while also identifying areas for improvement. As a foundational element, these blueprints shape the development of common specifications, providing comprehensive yet flexible solutions that can accommodate alternative approaches and optional steps.

User journeys may vary based on the specific implementation approach, influencing aspects such as data retrieval and User approval processes. The Annexes contain detailed descriptions of these blueprints, ensuring transparency and adaptability.

The European Digital Identity Cooperation Group has outlined service blueprints for the following main use cases:

- Identification and authentication to access online services, see Section 2.6.2,
- Qualified Electronic Signature, see Section 2.4,
- Mobile Driving Licence, see Section 2.6.3,

- Strong User Authentication for electronic payments, see Section 2.6.4
- A natural person representing another natural person, see Section 2.6.5.
- Additional use cases that will be introduced in the future, see Section 2.6.6.

These blueprints, along with all relevant information on use cases implementation, will be compiled in a standardised format within a dedicated document titled the “Use Cases Manual”, and distributed together with this document.

2.6.2 Identification and authentication to access online services using PID

One of the main use cases of the EUDI Wallet ecosystem is secure User identification and authentication. In this context, ‘User identification’ means that a User presents data from their PID, which is issued and managed at Level of Assurance High, to various online services, both public and private. ‘Authentication’ means that these services verify that the presented attributes originated from a trusted PID Provider and have not been changed. This capability is crucial, as it allows Relying Parties to confidently verify the identity of Users they interact with.

In this use case, a User utilises their Wallet Unit to present specific attributes from a PID to a Relying Party in order to access online services. Before doing so, the Wallet Unit first authenticates the User. The User is particularly mindful of the privacy and security implications of presenting data when accessing online services. Their primary objective is to securely and reliably access online services that require PID attributes, while maintaining full control over how their personal data is presented.

2.6.3 Mobile Driving Licence

A significant use case for the Wallet Unit involves allowing Users to request, store, and present a mobile Driving Licence (mDL) as an attestation in their Wallet Unit, allowing them mainly to prove their driving privileges. In this use case, the User employs a Wallet Unit to present an mDL to a Relying Party, for instance a police officer.

Like any other attestation type, an mDL can be presented in proximity as well as online, over the internet.

For more details and high-level requirements for this use case, please see Topic 4.

2.6.4 Strong User Authentication for electronic payments

Users would like to be able to authenticate themselves and their electronic payments securely and conveniently using their Wallet Units, so that they can enjoy a seamless and protected shopping and payment experience.

A Wallet Unit facilitates complying with strong customer authentication (SCA) requirements for electronic payments, ensuring a high level of security and compliance with Article 97 of the PSD2 (and with the future PSD3/PSR).

Note: Whereas the PSD2 speaks about 'strong *customer* authentication', the European Digital Identity Regulation, Article 5f(2), uses the term 'strong *user* authentication'. The ARF assumes that this means that Wallet Units must comply with the requirements for SCA in the PSD2.

Commission Delegated Regulation (EU) 2018/389 lays down the requirements for strong customer authentication (SCA), which needs to be complied with when accessing a payment account online and for initiating electronic payments, or carrying out any action through a remote channel which may imply a risk of payment fraud or other abuses. The use of a Wallet Unit for SCA will be in full compliance with those requirements. This implies that the Wallet Unit must enable the User to authenticate payment information, such as amount and payee, originating from a Relying Party, and to return the authenticated data to the Relying Party.

In general, the life cycle of a Wallet Unit in the role of an authenticator for Strong User Authentication comprises the following phases:

- **Registration**: The User registers the Wallet Unit as an authenticator for a service. This process includes:
  - User identification and authentication, for example by presenting a PID,
  - User consent for the registration,
  - Linking a Wallet Unit with the service and a User account in that service. This happens by issuing a dedicated SUA attestation to the Wallet Unit, containing User attributes relevant for the service. The issuance process for this SUA attestation complies with all requirements for attestation issuance in this ARF. The SUA attestation is device-bound, which means it contains a public key and the associated private key is stored in a WSCA/WSCD or in a keystore.
- **Strong User Authentication**: A Relying Party sends a presentation request to the Wallet Unit to request relevant attributes from the SUA attestation. This presentation request includes transactional data. In the context of electronic payments, the transactional data will include at least the payment amount and the payee. After presenting the data

to the User and obtaining the User's approval, the Wallet Unit signs the transactional data. It does so by including (a representation of) the transactional data in the signature creation process used for device binding. Note that the syntax and semantics of the transactional data, as well as rules for how the data must be presented to the User and how the data will be prepared for inclusion in the device binding signature, will be defined in the Attestation Rulebook (or a Technical Specification) for the SUA attestation.

- **De-registration**: Unlinking the Wallet Unit from the service and/or the User's account in that service. This will involve deletion or revocation of the SUA attestation.

For more information, please refer to Sections 5.7.5 and 6.6.3.8. For high-level requirements, see Topic 20.

2.6.5 Natural person representing another natural person

The European Digital Identity Regulation considers the representation of one natural person by another.

One common use case is the legal representation of minors or individuals with diminished legal capacity. For example, parents or legal guardians must be empowered to make decisions and act on behalf of their children and represent them when accessing educational platforms, healthcare services, government benefits, or other services. The EUDI Wallet ecosystem must therefore accommodate such representation in a secure, verifiable manner.

Another significant use case is the management of affairs for elderly or incapacitated individuals. In these cases, individuals can be assigned as legal representatives to manage healthcare, financial, and personal matters. For instance, a caregiver or relative could hold a delegation to access health records or submit applications for social care services on behalf of the person they represent.

Power of attorney is another use case of a natural person (the agent) acting on behalf of another natural person (the principal).

It should therefore be possible to issue a dedicated representation attestation for a natural person to a representative, in accordance with applicable national and European legislation. For certain use cases (e.g., parent-child relationships), the Attestation Provider of such attestations will be able to retrieve the relevant information from Authentic Sources at the national level. In other cases (e.g., power of attorney), the represented natural person may be required to explicitly authorize the representative.

Representation attestations for a natural person issued to a representative have a distinct attestation type. The Attestation Rulebook describing this attestation type specifies the nature of the representation and clearly defines the operations that the representative is authorized to perform, thereby restricting the scope of their authority.

Furthermore, representation attestations (like any other attestations) are either short-lived or revocable. In the case of revocable representation attestations, all entities that, according to applicable law, are entitled to revoke them have the capability to request the Attestation Provider to do so. It is emphasized that the high-level requirements concerning attestation revocation, as defined in Topic 7, also apply to this attestation type.

A User holding a representation attestation is able to represent another natural person when interacting with a Relying Party. The Relying Party is always aware that it is interacting with a legal representative or agent. This is ensured by the fact that the corresponding Wallet Unit presents an attestation having a distinct type, specifically for representation attestations.

For more details and high-level requirements for this use case, please see Topic 29.

2.6.6 Examples of other use cases

2.6.6.1 Health data

Easy access to health data is crucial in both national and cross-border contexts. A Wallet Unit may enable access to patient summary, ePrescriptions, etc.

2.6.6.2 Educational attestations and professional qualifications

Providing credentials for qualification recognition procedures can be costly and time-consuming for Users, Relying Parties (such as companies and employers), and Attestation Providers (such as education and training providers or academic institutions). A Wallet Unit may be a repository for educational credentials and a means for presenting them by the User to relevant Relying Parties.

2.6.6.3 Digital Travel Credential

Digital Travel Credential (DTC) Providers may issue DTCs to Wallet Units in a supported format, to enable Relying Parties to identify Users, thus facilitating a smooth travel experience and

User journey. Relying Parties for a DTC may include governments, transportation providers, hospitality agents, or any other actors operating in a regulated environment which requires the use of a DTC.

2.6.6.4 Central Bank Digital Currencies

In the future, a Wallet Unit could also be used for payments with Central Bank Digital Currencies.

2.6.6.5 Social Security

Documents related to social security are important for many EU citizens to prove their rights and obligations under social security legislation in the EU. Examples include:

- **Portable Document ("PDA1")** This is a statement of applicable legislation which is useful to prove that a person pays social contributions in another EU country, for example if they are a posted worker or work in several countries at the same time.
- **Electronic Health Insurance Card ("EHIC")** This is a free card that provides every citizen with access to medically necessary government-provided healthcare during a temporary stay in one of the 27 EU countries, Iceland, Liechtenstein, Norway, and Switzerland, under the same conditions and at the same cost (free in some countries) as persons insured in that country. This includes, for example, services related to chronic or existing illnesses, as well as in connection with pregnancy and childbirth.

3 Roles within the EUDI Wallet ecosystem

3.1 Introduction

This chapter describes the EUDI Wallet ecosystem as it is foreseen in the European Digital Identity Regulation. The main roles and components in the EUDI Wallet ecosystem are depicted in Figure 1 and described in the following sections.

Note that a single entity may combine multiple of the roles depicted in the figure, as long as that entity complies with all requirements, both legal and technical, for each of the roles. In addition, potential conflicts of interest are to be avoided, but this issue is outside the scope of this ARF.

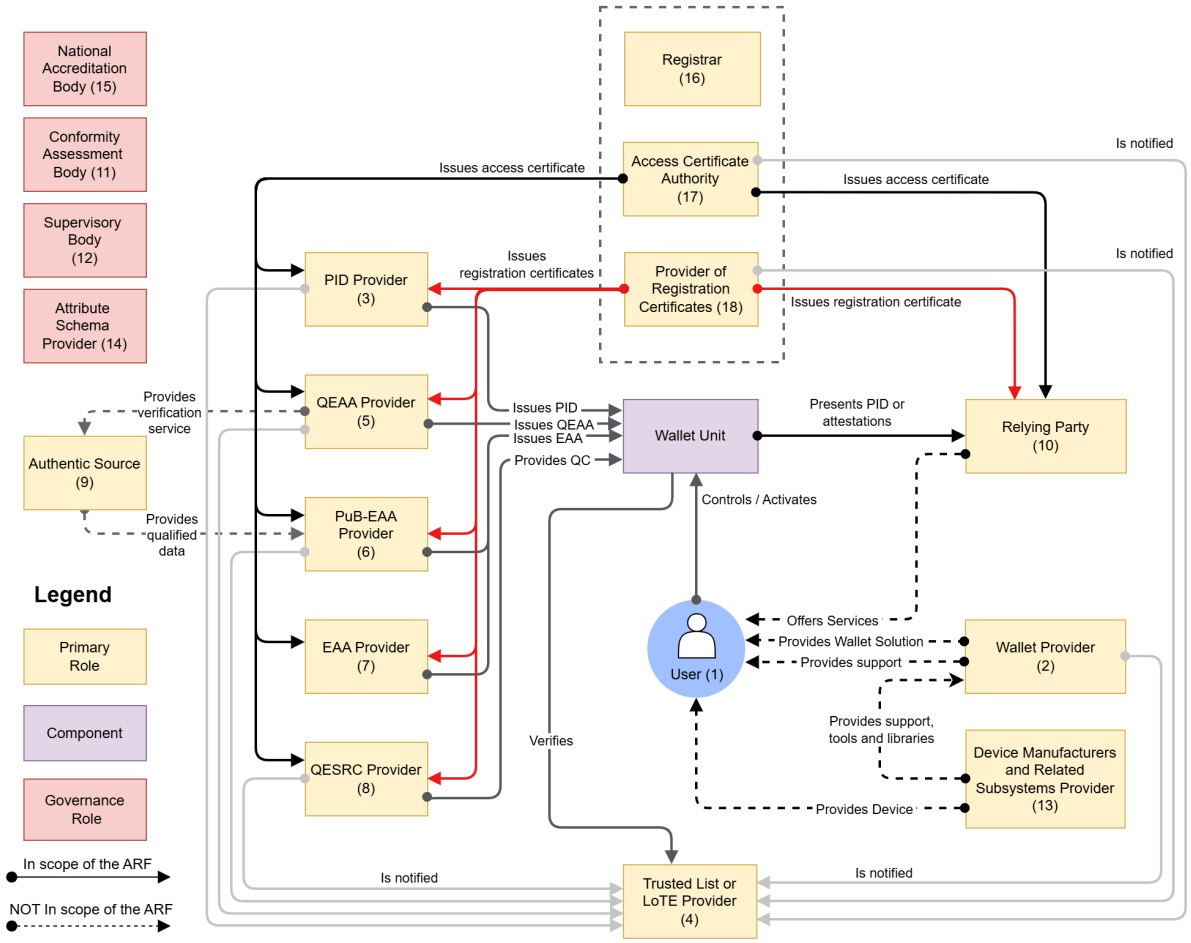


Figure 1: Overview of the EUDI Wallet ecosystem roles and components

The table below summarizes the main roles in the EUDI Wallet ecosystem, as shown in Figure 1. Each role is detailed in the corresponding referenced section.

Role	Primary Responsibility	Section
User of Wallet Unit	Manage, store, and present PIDs/attestations.	Section 3.2
Wallet Provider	Make the certified Wallet Solution available to Users.	Section 3.3
PID Provider	Issue Person Identification Data (PID) to Users.	Section 3.4

Role	Primary Responsibility	Section
Trusted List Provider or LoTE Provider	Maintain, manage, and publish Trusted Lists or Lists of Trusted Entities (LoTE).	Section 3.5
QEAA Provider	Issue Qualified Electronic Attestations of Attributes (QEAAs).	Section 3.6
PuB-EAA Provider	Issue EAAs on behalf of a public sector body.	Section 3.7
EAA Provider	Issue Non-Qualified Electronic Attestations of Attributes (EAAs).	Section 3.8
Qualified Electronic Signature Remote Creation (QESRC) Provider	Provide Qualified Electronic Signature Remote Creation services.	Section 3.9
Authentic Source	Act as the definitive repository for specific attributes.	Section 3.10
Relying Party (RP) / Intermediary	Request and receive attributes from a Wallet Unit.	Section 3.11
Conformity Assessment Body (CAB)	Certify Wallet Solutions and audit Trust Service Providers.	Section 3.12
Supervisory Body	Review the proper functioning of ecosystem actors.	Section 3.13
Device Manufacturers / Subsystems	Provide the underlying platform (hardware, OS, secure elements).	Section 3.14
Attestation Scheme Provider	Define and publish the Attestation Rulebooks and schemes.	Section 3.15
National Accreditation Body (NAB)	Accredit CABs according to EU regulations.	Section 3.16
Registrar	Manages the registration of Providers and Relying Parties.	Section 3.17

Role	Primary Responsibility	Section
Access Certificate Authority (Access CA)	Issue access certificates for authentication.	Section 3.18
Provider of Registration Certificates	Issue certificates detailing registration status and scope.	Section 3.19

3.2 Users of Wallet Units

Users of Wallet Units use the Wallet Unit to receive, store, and present PIDs, QEAAs, PuB-EAAs, or non-qualified EAAs to Relying Parties. Users can also create qualified electronic signatures and seals (QES) and create and present pseudonyms.

CIR 2024/2982 (among others) defines 'wallet user' as 'a user who is in control of the wallet unit'. Being in control of the Wallet Unit implies being able to present a PID or attestation to a Relying Party. Within the use cases described in the current version of the ARF, the User is the subject of the PID(s) in the Wallet Unit. The User is also the subject of most of the attestations in the Wallet Unit, but there could be attestations related to objects owned or used by the User, such as a vehicle registration card. Additionally, the Wallet Unit could contain attestations that have no subject, such as vouchers. Such attestations will be valid for any User that can present it to a Relying Party.

Please note that:

- the topic of Wallet Units for legal persons, possibly containing a legal-person PID, has been removed from this ARF in view of the development of a separate business wallet.
- this ARF assumes that a User device is a personal device, meaning that the User will not share it with other people, and that only the User can access and control the Wallet Unit. This also implies that all PIDs and attestations on the Wallet Unit pertain to that User (or to entities represented by, or objects owned by or linked to, that User).

The use of a Wallet Unit by citizens is not mandatory under the European Digital Identity Regulation. However, each Member State will provide at least one European Digital Identity Wallet within 24 months after the entry into force of the Implementing Acts referred to in the European Digital Identity Regulation.

3.3 Wallet Providers

Wallet Providers are Member States or organisations either mandated or recognised by Member States making a Wallet Solution available to Users. All Wallet Solutions must be certified as described in Chapter 7.

A Wallet Provider makes a combination of several products and Trust Services available to a User, which give the User sole control over the use of their Person Identification Data (PID) and Electronic Attestations of Attributes (QEAA, PuB-EAA or EAA), and any other personal data within their Wallet Unit. This also implies guaranteeing a User sole control over sensitive cryptographic material (e.g., private keys) related to their Wallet Unit.

Wallet Providers are responsible for ensuring compliance with the requirements for Wallet Solutions.

From the viewpoint of the other actors in the EUDI Wallet ecosystem, the Wallet Provider is responsible for all components of the Wallet Unit. These components are described in Section 4.3.2. In particular, the Wallet Provider is responsible for ensuring that the Wallet Instance can access a Wallet Secure Cryptographic Device (WSCD) that has a level of security sufficient to ensure that the Wallet Unit can achieve Level of Assurance High, as required in the European Digital Identity Regulation for the PID. This is true even if the WSCD is not delivered by the Wallet Provider but is integrated into the User device. For more information, see Section 4.5. Other actors in the ecosystem do not need to interact with or explicitly trust a WSCA or WSCD supplier. As explained in Section 6.5.3.4, Wallet Providers sign Wallet Instance Attestations (WIA) and Key Attestations (KA), and issue them to the Wallet Unit:

- A Key Attestation (KA) attests that a WSCA/WSCD or keystore used by the Wallet Unit complies with the relevant requirements. A Key Attestation contains public keys whose corresponding private keys are managed by that WSCA/WSCD or keystore. Finally, it carries a revocation reference for that WSCA/WSCD or keystore.
- A Wallet Instance Attestation (WIA) attests the integrity and authenticity of the Wallet Instance (i.e., the app installed on the User device), and carries a revocation reference for the Wallet Instance.

3.4 Person Identification Data (PID) Providers

PID Providers are trusted entities responsible for:

- verifying the identity of the User in compliance with LoA high requirements,

- issuing a PID to the Wallet Unit, and
- making available, in a privacy-preserving way, information for Relying Parties to verify the validity of the PID.

The terms and conditions of these services are for each Member State to determine.

PID Providers may be the same organisations that today issue official identity documents, electronic identity means, etc. PID Providers may be the same organisations as Wallet Providers. In case an organisation acts as both a PID Provider and a Wallet Provider, it complies with all requirements for both PID Providers and Wallet Providers.

3.5 Trusted List Provider or LoTE Provider

A Trusted List Provider is a body responsible for maintaining, managing, and publishing Trusted Lists. Similarly, a LoTE Provider is responsible for maintaining, managing, and publishing Lists of Trusted Entities (LoTE). An entity's status as a trusted entity can be verified by checking whether they are present on the relevant Trusted List or LoTE.

Within the EUDI Wallet ecosystem, Trusted Lists exist only for QEAA Providers, see Section 3.6, since these are QTSPs in the sense of Art. 22 of the European Digital Identity Regulation. This Article requires Member States to list QTSPs and the qualified trust service they provide in national Trusted Lists. Each Member States signs and publishes its Trusted Lists and makes the URL of the Trusted Lists available to a common trust infrastructure ("List of Trusted Lists", LOTL) maintained by the Commission. Using the common infrastructure, any entity in the EUDI Wallet ecosystem will be able to find all Trusted Lists in the ecosystem.

On the other hand, Lists of Trusted Entities exist within the EUDI Wallet ecosystem for:

- Wallet Providers, see Section 3.3,
- PID Providers, see Section 3.4,
- PuB-EAA Providers, see Section 3.7.
- Access Certificate Authorities, see Section 3.18,
- Providers of registration certificates, see Section 3.19.

These LoTEs are signed and published by the Commission. In order to be put on a LoTE, relevant entities must be notified to the Commission by a Member State. For all mentioned entities except Wallet Providers, this happens after the entity has been registered by a Registrar in the Member State, see Section 3.17. The Commission publishes the locations of the LoTEs in the Official Journal of the EU (OJEU).

Notes:

- Trusted Lists comply with ETSI TS 119 612; LoTEs comply with ETSI TS 119 602;
- There is no Trusted List or LoTE for Relying Parties. The expected number of Relying Parties in the Union would make this infeasible. Instead, a Relying Party receives one or more access certificate(s) from an Access Certificate Authority (see Section 3.18), and these certificates allow a Wallet Unit to authenticate the Relying Party.
- Wallet Providers, PID Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates are not trust service providers in the sense of the European Digital Identity Regulation. For that reason, they are included in a LoTE, not in a Trusted List in the sense of Article 22.
- Non-qualified EAA Providers are trust service providers in the sense of the European Digital Identity Regulation. Therefore, Trusted Lists and Trusted List Providers may also exist for non-qualified EAA Providers. However, this is out of scope of the ARF.
- If an entity is put on a Trusted List or LoTE, it is never removed from it. However, its status can be set to Invalid to indicate that the entity is no longer trusted.

The use of Trusted Lists and LoTEs is described in more detail in Section 6.2.2 for Wallet Providers, Section 6.3.2 for PID Providers and Attestation Providers and Section 6.4.2 for Access Certificate Authorities and Providers of registration certificates.

For more information and high-level requirements, please refer to Topic 27 and to Topic 31.

3.6 Qualified Electronic Attestation of Attributes (QEAA) Providers

Qualified EAAs are provided by Qualified Trust Service Providers (QTSPs). The general trust framework for QTSPs (see Chapter III, Section 3 of the European Digital Identity Regulation applies also to QEAA Providers, but specific rules for the Trust Service of issuing QEAAs may be defined as well.

QEAA Providers maintain an interface to Wallet Units to provide QEAAs upon request. Potentially, they also maintain an interface towards Authentic Sources to verify the value of User attributes, as specified in Topic 42.

It is likely that for most QEAAs, a QEAA Provider will need to verify the identity of a User when issuing a QEAA. The reference standards and procedures for this verification are laid down in CIR 2025/1566. Within those constraints, it is up to each QEAA Provider to implement the necessary User authentication processes, in compliance with all applicable national and

Union legislation. Note that, when User identity verification is necessary, it is likely that the User requesting a QEAA already possesses a PID. This would enable the QEAA Provider to carry out User identification and authentication at LoA high, by requesting and verifying User attributes from the PID in the Wallet Unit. See also Section 6.6.2.1.

The terms and conditions of these services are for each QEAA Provider to determine, beyond what is specified in the European Digital Identity Regulation.

3.7 EAA issued by or on behalf of a public sector body responsible for an authentic source (PuB-EAA) Providers

As specified in the European Digital Identity Regulation, an attestation may be issued by or on behalf of a public sector body responsible for an Authentic Source. This ARF calls such an attestation a PuB-EAA. For a description of Authentic Sources, see Section 3.10. A public sector body is a state, regional or local authority, or a body governed by public law.

A PuB-EAA Provider, meaning a public sector body issuing PuB-EAAs, is not a QTSP. Rather, a PuB-EAA Provider is notified to the Commission by a Member State, in a manner similar to the notification of PID Providers. A Relying Party verifies a PuB-EAA by verifying the signature over the PuB-EAA using a trust anchor from the PuB-EAA Provider LoTE. For more details, refer to Section 6.6.3.6. The European Digital Identity Regulation stipulates that PuB-EAAs, like QEAAs, have the same legal effect as attestations in paper form. It is up to the Member States to define terms and conditions for the provisioning of PuB-EAAs, but PuB-EAA Providers will comply with the same technical specifications and standards as Providers of PIDs and other attestations.

For the precise and legally binding definitions and obligations regarding the issuance of PuB-EAAs, please refer to the European Digital Identity Regulation and to CIR 2025/1569, particularly Article 5 and 6.

3.8 Non-Qualified Electronic Attestation of Attributes (EAA) Providers

Non-qualified EAAs can be provided by any (non-qualified) Trust Service Provider. While they will be supervised under the European Digital Identity Regulation, it can be assumed that other legal or contractual frameworks will mostly govern the rules for provision, use and recognition of EAAs. Those other frameworks may cover policy areas such as educational credentials, digital payments, although they may also rely on Qualified Electronic Attestation

of Attributes Providers. For non-qualified EAAs to be used, EAA Providers offer Users a way to request and obtain these EAAs. This implies that these non-qualified EAA Providers comply with the Wallet Unit interface specifications. The terms and conditions of issuing EAAs and related services are subject to sectoral rules.

3.9 Qualified Electronic Signature Remote Creation (QESRC) Providers

The Wallet Unit will allow the User to create qualified electronic signatures or seals over any data. This will also enhance the use of the Wallet Unit for signing, in a natural and convenient way. The creation of a qualified electronic signature or seal by the Wallet Unit can be achieved by means of a local QSCD, as discussed in Section 4.3.2.

However, the Wallet Unit can also connect to a remote QSCD, managed by a QTSP called a Qualified Electronic Signature Remote Creation (QESRC) Provider. As part of the EUDI Wallet ecosystem, the use of common interfaces and protocols for provisioning qualified electronic signatures and seals will create a unified European market for QESRC Providers.

Besides providers for the remote creation of qualified electronic signatures and seals, also providers for the remote creation of non-qualified electronic signatures or seals may exist. However, such providers are out of scope of this ARF.

3.10 Authentic Sources

Authentic Sources are public or private repositories or systems, recognised or required by law, containing attributes about natural or legal persons. Authentic Sources are sources for attributes on, for instance, address, age, gender, civil status, family composition, nationality, education and training qualifications titles and licences, professional qualifications titles and licences, public permits and licences, or financial and company data.

Authentic Sources are required to provide an interface to QEAA Providers to verify the authenticity of the above attributes, either directly or via designated intermediaries recognised at national level. Authentic Sources may act as PuB-EAA Providers if they meet the requirements of the European Digital Identity Regulation, see Section 3.7. In Figure 1 this is indicated by the arrow ‘provides qualified data’.

3.11 Relying Parties, Relying Party Services, Relying Party Instances, and intermediaries

3.11.1 Relying Parties

A Relying Party is a service provider requesting User attributes contained within a PID, QEAA, PuB-EAA, or EAA from the Wallet Unit, subject to the approval of the User and within the limits of applicable legislation and rules.

> Note: As specified in the European Digital Identity Regulation, legally speaking, the term 'wallet-relying party' includes Attestation Providers (i.e., QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers), as well as service providers. However, technically speaking the responsibilities of Attestation Providers are quite different from those of service providers, as is the way they interact with Wallet Units. Therefore, for clarity the term 'Relying Party' is used in all parts of the ARF exclusively to mean a service provider interacting with a Wallet Unit to request and receive User attributes.

The reason for a Relying Party to rely on the Wallet Unit may be a legal requirement, a contractual agreement, or their own decision. In particular, the European Digital Identity Regulation, Article 5f(3), requires that providers of very large online platforms accept the EUDI Wallet for user authentication only upon the voluntary request of the User and in respect of the minimum data necessary for the specific online service.

To rely on Wallet Units for the purpose of providing a service, Relying Parties register at a Registrar in the Member State where they are established. During registration, the Registrar assigns an EU-wide unique Relying Party identifier to each Relying Party. This identifier could, for example, be a concatenated list of one or more registered official Relying Party identifiers listed in Annex I(3) of the CIR 2025/848 regarding registration of Wallet Relying Parties, expressed in the semantic form defined in [ETSI EN 319 412-1] sections 5.1.4 or 5.1.5. The Relying Party provides a user-friendly trade name and Service trade name, which will be used by a Wallet Unit to identify the Relying Party towards its User during a presentation of attributes.

During registration, a Relying Party receives one or more access certificates and one or more registration certificates. Its Relying Party identifier and trade name, as well as its Service identifier and trade name, are included in both types of certificate. See Section 6.4.2 and Technical Specification 5 for more information on Relying Party registration, access certificates, and registration certificates.

3.11.2 Relying Party Services

A Relying Party may be a big organisation that offers multiple services that have (partly or wholly) different intended uses, and therefore will request different sets of attributes from a Wallet Unit. Moreover, the Relying Party may want to ensure that its different services cannot access each other's data, or use each other's access certificates or registration certificates towards Wallet Units. To enable such a separation of concerns between Relying Party services, Technical Specification 5 introduces the concept of a Relying Party Service. During registration, a Relying Party registers at least one Service. For every Service, it specifies a Relying Party Service identifier. This identifier can be freely chosen by the Relying Party, as long as it is unique for the given Relying Party. It could, for example, be an existing OAuth `client_id` for the given service. Note that if the Relying Party registers only one service (for example because it is a small business), the Service identifier could be an empty string, or "N/A", or similar. It is up to each Registrar to set applicable rules if needed.

As specified in [Technical Specification 5], the Relying Party also registers one or more intended uses. The identifiers of these intended uses are generated by the Registrar, not the Relying Party. The Relying Party also indicates which of its Service(s) has which intended use(s), and it provides a user-friendly trade name and description of the Service, as well as a user-friendly description of the intended use(s).

EXAMPLE: If a Relying Party registers Services A, B, and C, and also registers intended uses 1, 2, 3, 4, and 5, it may subsequently register that

- Service A has intended uses 1 and 2,
- Service B has intended uses 2, 3, 4, and 5,
- Service C has intended use 4.

In this example the Registrar would issue seven registration certificates to this Relying Party, two for service A, four for service B, and one for service C. Each registration certificate contains precisely one intended use, as well as the (Registrar-assigned, EU-wide unique) Relying Party identifier and the (Relying Party-chosen, Relying Party-unique) Relying Party Service identifier.

3.11.3 Relying Party Instances

A Relying Party uses a system consisting of software and hardware to interact with Wallet Units. The ARF calls such a system a Relying Party Instance. A Relying Party Instance maintains an interface with Wallet Units to request PIDs and attestations. It implements Relying Party

authentication, using an access certificate obtained by the Relying Party, as described in Section 6.6.3.2. Note that a Relying Party can operate multiple Relying Party Instances.

To bind a Relying Party Instance to a Relying Party Service (as introduced in the previous section), the Registrar includes the Relying Party Service identifier also in the access certificate, next to the Relying Party identifier. Note that an access certificate is bound to a specific Relying Party Instance, because the public key in the certificate corresponds to a private key that is securely stored in the hardware of the Relying Party Instance.

To obtain an access certificate for a given Relying Party Instance, a Relying Party requests that Relying Party Instance to generate a key pair. The Relying Party Instance securely stores the private key, and returns the public key to the Relying Party. The Relying Party then sends the public key to the Access CA (see Section 3.18) in a certificate signing request, together with a Relying Party identifier and a Relying Party Service identifier. The Access CA returns a signed access certificate that includes (and thus binds together) the public key and both identifiers.

Note that if a single Relying Party Instance is used by multiple Services of the same Relying Party, the Relying Party can request multiple access certificates for that Relying Party Instance, each bearing a different Service identifier. Of course, to prevent misuse, the Relying Party should carefully control access to its certificate-requesting functions.

3.11.4 Intermediaries

So-called intermediaries form a special class of Relying Party. Article 5b (10) of the European Digital Identity Regulation states “Intermediaries acting on behalf of relying parties shall be deemed to be relying parties and shall not store data about the content of the transaction”. Such an intermediary is a party that offers services to Relying Parties to, on their behalf, connect to Wallet Units and request the User attributes that these Relying Parties need. The intermediary then sends the presented attributes to the intermediated Relying Party. This implies that an intermediary performs all tasks assigned to a Relying Party in this ARF on behalf of the intermediated Relying Party.

For a more detailed description of the interactions between an intermediated Relying Party, an intermediary, and a Wallet Unit, see Section 6.6.5.

3.12 Conformity Assessment Bodies (CAB)

Conformity Assessment Bodies (CAB) are public or private bodies that are accredited by a national accreditation body, which itself is designated by a Member State according to Regulation 765/2008 Article 4. In particular, CABs are accredited to carry out assessments on which Member States will rely before issuing a Wallet Solution or providing the 'qualified' status to a Trust Service Provider.

Wallet Solutions will be certified by CABs. QTSPs will be audited regularly by CABs.

The standards and schemes used by CABs to fulfil their tasks to certify Wallet Solutions are discussed in Chapter 7.

3.13 Supervisory Bodies

Supervisory Bodies review the proper functioning of Wallet Providers and other actors in the EUDI Wallet ecosystem. Supervisory Bodies will be created and appointed by the Member States. The Supervisory Bodies will be notified to the Commission by the Member States.

3.14 Device Manufacturers and Related Subsystems Providers

In the EUDI Wallet ecosystem, commercial actors such as device manufacturers and related subsystems providers fulfil an important role to enable a Wallet Unit to work smoothly and securely. Device manufacturers and related subsystem providers provide a platform on which a Wallet Unit can be built. Wallet Providers ensure that their Wallet Units use that platform to ensure usability, security, stability and connectivity. The components provided by device manufacturers and providers of related subsystems may include, among others, hardware, operating systems, secure cryptographic hardware, libraries, and app stores.

3.15 Attestation Scheme Providers for QEAAs, PuB-EAAs and EAAs

An Attestation Scheme Provider defines a specific attestation type (e.g., QEAA, PuB-EAA, or EAA) and publishes two complementary artefacts:

1. A human-readable Attestation Rulebook; see Section 5.5, the authoritative documentation that explains what the attestation represents and how it works, detailing identifiers, semantics, encodings, constraints, and processing rules, trust model;

2. A machine-readable attestation scheme that mirrors the Rulebook so software can build requests to Wallet Units and validate responses at runtime.

Relying Parties use the Rulebook to decide whether and how to adopt an attestation and to prepare their systems, while their Relying Party Instances rely on the attestation scheme in production.

For PID, the European Commission publishes the applicable Rulebook.

Moreover, the Commission operates a catalogue of schemes and Rulebooks, setting the related technical specifications, standards, and procedures, so ecosystem participants can discover available attestations and understand how to request and verify their attributes; A broad array of attestation schemes, including sector-specific ones, is critical for interoperability and uptake. For more information see Section 5.6.

3.16 National Accreditation Bodies

National Accreditation Bodies (NAB), under Regulation (EC) No 765/2008, are the bodies in Member States that perform accreditation with authority derived from the Member State. NABs accredit CABs (Section 3.12) as competent, independent, and supervised professional entities in charge of certifying Wallet Solutions against normative document(s) establishing the relevant requirements. NABs monitor the CABs to which they have issued an accreditation certificate.

3.17 Registrars

All PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers, and Relying Parties in the EUDI Wallet ecosystem are registered by a Registrar in the Member State where they reside under CIR 2025/848. As a result of registering an entity,

- Data about the entity is registered by the Registrar and made available online in human-readable and machine-readable format to any interested party. In particular,
  - For a Relying Party, the Registrar mainly registers which attributes the Relying Party intends to request from Wallet Units, and for what purpose. The Registrar also registers if the Relying Party intends to use the services of an intermediary (see Section 3.11.4) to interact with Wallet Units, and if so, which one. Conversely, if the Relying Party is an intermediary, the Registrar registers which Relying Parties use its services to connect to Wallet Units.

  - For a PID Provider, QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider, the Registrar registers the attestation type(s) this entity wants to issue to Wallet Units, for example, diplomas, driving licences, or vehicle registration cards.

- Registered entities receive one or more access certificate(s) from an Access Certificate Authority, as described in Section 3.18.
- Registered entities also receive a registration certificate, as discussed in Section 3.19.

The process and terms and conditions for registering will be determined by each Member State.

Note: PID and Attestation Providers are, in addition to registration at their applicable Registrar, subject to notification under CIR 2024/2980. This is a separate legal flow which is not to be mixed with registration by a Registrar.

3.18 Access Certificate Authorities

Access Certificate Authorities issue an access certificate to all PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers in the EUDI Wallet ecosystem. In addition, each Relying Party in the ecosystem also receives one or more access certificates, one for each of its Relying Party Instances. When these entities interact with a Wallet Unit to issue or request a PID or attestation, they will present an access certificate to prove their authenticity and validity. In order to receive an access certificate, an entity must be registered by a Registrar as described in Section 3.17.

> Note: In the Implementing Acts, the term 'wallet-relying party access certificate' refers to the certificate used by Relying Parties to authenticate towards Wallet Units. The ARF further clarifies that a Relying Party may operate multiple technical systems ('Relying Party Instances', see Section 3.11.3) to interact with Wallet Units, and that each of these needs at least one separate access certificate to do so. However, the legal subject of all of these access certificates is the wallet-relying party.

An access certificate is a public key certificate, complying with RFC 5280 and ETSI TS 119 411-8.

Access Certificate Authorities are notified by a Member State to the Commission. As part of the notification process, the trust anchors of the Access CA are included in a List of Trusted Entities

(LoTE) by the Commission. A trust anchor is the combination of a public key and an identifier for the associated entity. Wallet Units need these trust anchors to verify the signatures over the access certificates presented to them when a new PID or attestation is issued or when they receive an attribute presentation request from a Relying Party.

The Commission signs and publishes the Access CA LoTE and publishes the URL of the LoTE in the OJEU. Any entity in the EUDI Wallet ecosystem will be able to find the LoTE.

In order to enable detection of any event in which an access certificate was issued erroneously or fraudulently, an Access Certificate Authority logs all access certificates in a Certificate Transparency log, once such a log is available for access certificates. For more information, see the Discussion Paper for Topic S. For high-level requirements on Certificate Transparency, see Topic 55.

An Access Certificate Authority operates a root CA, whose public keys act as the Authority's trust anchors in the LoTE. Moreover, it operates at least one signing CA, whose private keys are used to sign access certificates. In addition, it may operate one or more intermediate CAs, for example to achieve a separation of concerns between access certificates for PID Providers and Attestations Providers on the one hand and Relying Parties on the other hand. It is up to each Access Certificate Authority to decide on the number and nature of intermediate CAs.

3.19 Providers of registration certificates

A Registrar has one or more associated Provider(s) of registration certificates. Such a Provider issues one or more registration certificates to each registered Relying Party, PID Provider, QEAA Provider, PuB-EAA Provider, and non-qualified EAA Provider. Each registration certificate contains (a subset of) the data registered for that entity, as described in Section 3.17.

A registration certificate is signed by the Provider of registration certificates that issued it. A registration certificate is a JSON Web Token (JWT) complying with RFC 7519, not a X.509 public key certificate complying with RFC 5280. However, it is bound to the X.509-compliant access certificates issued to the same entity by an Access CA (see Section 3.18): both the access certificates and the registration certificate contain that entity's unique identifier and Service identifier. This enables a Wallet Unit to verify that a registration certificate it receives during attestation issuance (see Section 6.6.2.3) or attestation presentation (see Section 6.6.3.3) belongs to the same entity as the access certificate that the Wallet Unit used to authenticate that entity.

Note: The concept of a Service identifier is explained in Section 3.11.2 in the context of Relying Parties. However, exactly the same logic can be applied to PID Providers and Attestation Providers, which can similarly have multiple services and service supply points. For example, a single entity within a Member State may issue both PIDs and photoIDs, and may wish to prevent that a service supply point used for issuing photoIDs can present a registration certificate showing an entitlement to issue PIDs.

Commission Implementing Regulation 2024/2982 requires a Wallet Unit to verify and validate the registration certificate. This enables Users:

- for a Relying Party they are interacting with, to verify that the attributes being requested by the Relying Party are within the scope of their registered attributes. This provides assurance that the request is legitimate and trustworthy.
- for a PID Provider or Attestation Provider they are interacting with, to verify that the issued attestation is within the scope of their registered attestations. This provides assurance that the attestation is legitimate and trustworthy.

  Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

Like Access Certificate Authorities (see previous section), Providers of registration certificates are notified by a Member State to the Commission. Their trust anchors are put on a List of Trusted Entities, such that they can be found by Wallet Units and used to verify a registration certificate received from a Relying Party.

A Provider of registration certificates operates a root CA, whose public keys act as the Provider's trust anchors in the LoTE. Moreover, it operates at least one signing CA, whose private keys are used to sign registration certificates. In addition, it may operate one or more intermediate CAs, for example to achieve a separation of concerns between registration certificates for PID Providers and Attestations Providers on the one hand and Relying Parties on the other hand. It is up to each Provider of registration certificates to decide on the number and nature of intermediate CAs.

4 High-level architecture

4.1 Introduction

This chapter provides a broad overview of the EUDI Wallet ecosystem's core components, their interfaces, and the overall design principles. This chapter is structured as follows:

- Section 4.2 discusses the design principles that guided the design of the EUDI Wallet ecosystem, as described in this ARF.
- Section 4.3 presents an overview of the ecosystem's architecture, focussing on the components that make up a Wallet Unit and on the interfaces between a Wallet Unit and other entities, as well as the protocols used on these interfaces.
- Section 4.4 discusses the different attestation presentation flows enabled by this architecture, and in particular the mechanisms foreseen to enable and secure remote presentation flows in which the Wallet Unit and the Relying Party interact over the internet.
- Section 4.5 briefly discusses the different architecture types a Wallet Providers may use for implementing a Wallet Secure Cryptographic Device into their Wallet Solutions.
- Section 4.6 presents state diagrams for all of the main entities and components in the EUDI Wallet ecosystem, discussing all of the states a particular component can be in, as well as the conditions triggering state transitions.
- Section 4.7 discusses how pseudonyms can be implemented and used within a Wallet Unit.

4.2 Design principles

To effectively translate the European Digital Identity Regulation into a User-friendly, privacy-focused, and secure technical architecture, establishing design principles is crucial. These principles, rooted in the regulatory framework and enriched by industry best practices, will serve as fundamental guidelines. This approach ensures compliance with requirements emphasising User-centricity, accessibility, privacy, security, and cross-border interoperability. It demonstrates a commitment to both regulatory alignment and excellence in the EUDI Wallet architecture's design.

4.2.1 User-centricity

The EUDI Wallet ecosystem prioritises User-centricity as a core design principle. This means placing User needs and experience at the forefront of every design decision. The Wallet Unit should be intuitive and easy to use, with seamless integration into existing use cases. Wallet Units make it easy for Users to exercise their legal rights to full control over their attributes and privacy, with transparent information about what attributes are being presented and to whom. Additionally, the Wallet Unit should be accessible and inclusive, catering to Users with varying technical backgrounds and abilities. By prioritising User-centricity, the EUDI Wallet ecosystem fosters trust and encourages widespread adoption, ultimately achieving its goal of empowering Users with secure and convenient digital identity management.

4.2.2 Accessibility

Regarding the accessibility of Wallet Units for Users, it is essential to ensure that Wallet Units are inclusive by design and fully aligned with the applicable European legal and technical frameworks on accessibility. The same applies to any other User-facing component of the EUDI Wallet ecosystem, such as websites and User authentication methods of PID Providers and Attestation Providers, registries (see Section 3.17), et cetera. This is not only a matter of legal compliance but also a fundamental component of ensuring equal access, User trust, and widespread adoption across all segments of the population, including persons with disabilities.

For more information, please refer to Chapter 8.

4.2.3 Interoperability

The EUDI Wallet ecosystem prioritises interoperability as a core design principle. This ensures a Wallet Unit functions seamlessly across borders within the EU. Users can travel freely and confidently utilise their digital identity wallets for various services, from e-government platforms to private online interactions. Interoperability fosters secure data exchange through standardised protocols, allowing trusted entities to verify credentials effortlessly. This not only simplifies the User experience but also strengthens overall security within the system. Moreover, interoperability prevents market fragmentation by creating a level playing field for different Wallet Solutions. It fosters competition and collaboration, ultimately driving innovation in the EUDI Wallet ecosystem. By prioritising interoperability, the EUDI Wallet architecture lays the foundation for a trusted and universally accepted EUDI Wallet ecosystem across the EU.

4.2.4 Privacy by design

The EUDI Wallet architecture embodies the principle of privacy by design. This means that the protection of User data is a fundamental pillar of the architecture's design. The principle of data minimisation guides the collection of personal information, ensuring that Relying Parties gather only the attributes they need and have registered for. By enabling selective disclosure of attributes, the Wallet Unit empowers Users with granular control over what data is presented and to whom. Transparency is built into the system, with clear explanations of how data is used and protected. By making privacy a cornerstone from the beginning, the EUDI Wallet ecosystem aims to foster trust and protect the fundamental rights of its Users. Finally, measures are taken to prevent Users from being tracked by Relying Parties, PID Providers, or Attestation Providers.

For more information, please refer to Sections 7.4.3.4 and 7.4.3.5.

4.2.5 Security by design

The EUDI Wallet architecture embraces the principle of security by design. This means security considerations are woven into the very fabric of the architecture's design. Throughout the design process, potential vulnerabilities are identified and mitigated. Secure coding practices are mandated, and the architecture itself minimises attack surfaces by compartmentalising sensitive data and access controls. By prioritising security from the outset, the EUDI Wallet architecture aims to be inherently resistant to cyberattacks and data breaches, fostering trust and User confidence in this EUDI Wallet ecosystem.

For more information, please refer to Sections 7.4.3.2 and 7.4.3.3.

4.3 Reference architecture

4.3.1 Overview

The figure below gives an overview of the architecture of the EUDI Wallet ecosystem and its components. In comparison to Figure 1, this figure presents more detail on the composition of a Wallet Unit and its interfaces to other entities. The depicted components of a Wallet Unit are described in Section 4.3.2, while the interfaces are described in Section 4.3.3. The other entities shown in the figure were already described in Chapter 3.

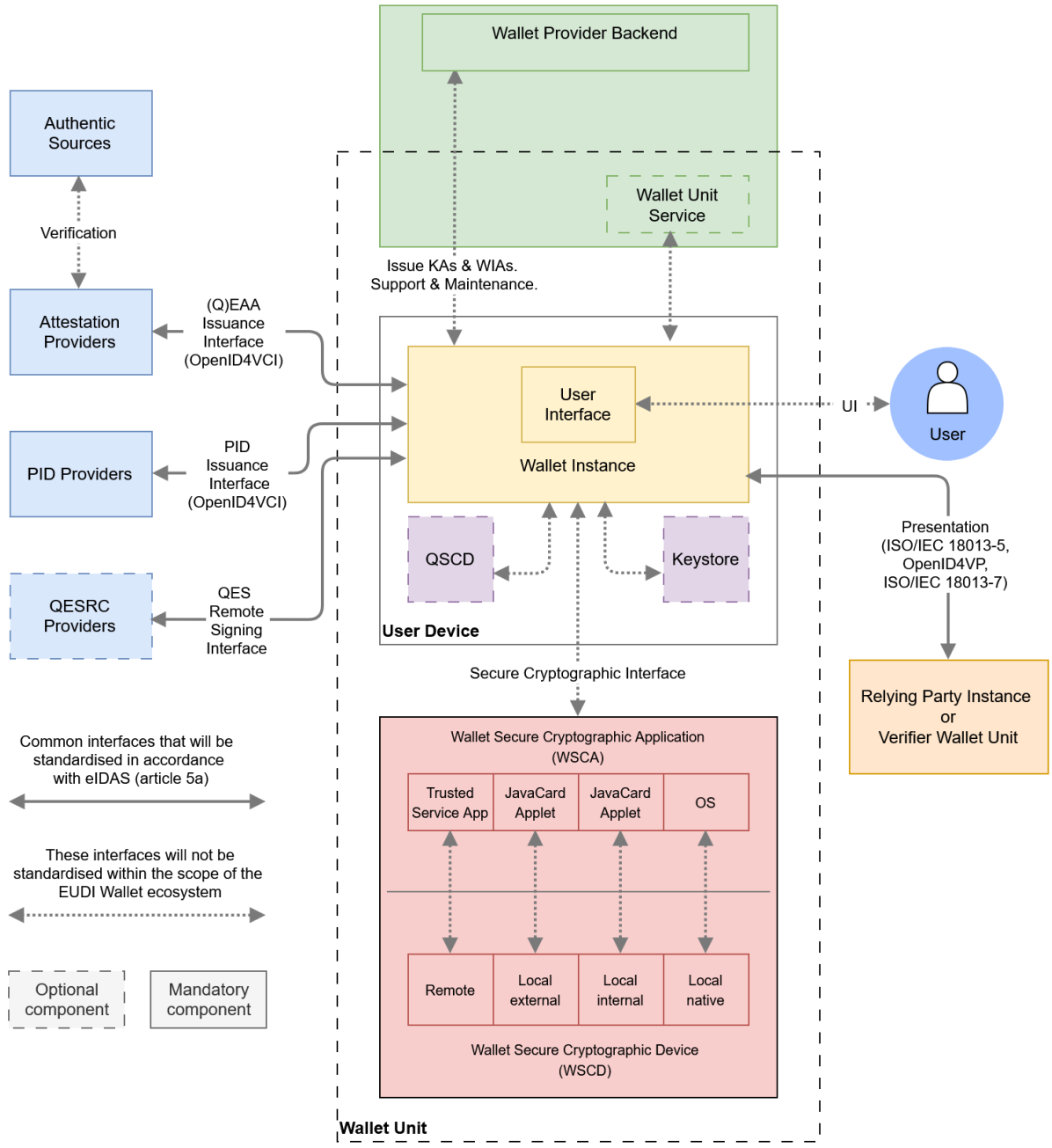


Figure 2: EUDI Wallet ecosystem reference architecture

Figure 2 shows the high-level components and interfaces of the EUDI Wallet ecosystem. The **Wallet Unit** is shown interacting with external entities through standardized protocols for its entire lifecycle. The components of the Wallet Unit are detailed in Section 4.3.2.

4.3.2 Components of a Wallet Unit

The following have been identified as the core components of a Wallet Unit:

- **User device**: A User Device comprises the hardware, operating system, and software environment required to host and execute the Wallet Instance. The minimum hardware and software requirements for the User device will be determined by the Wallet Provider.
- **Wallet Instance**: The app or application installed on a User device, which is an instance of the corresponding software that is part of the Wallet Solution and belongs to and is controlled by a User. This component implements the core business logic and interfaces as depicted in Figure 2. It directly interacts with the WSCA (which is interacting with the WSCD, see bullets hereafter) to securely manage critical assets and execute cryptographic functions. It optionally interfaces with one or more keystores for the management of non-critical cryptographic assets. Regarding the possible implementations of a Wallet Instance, please note the following:
  - The wordings used above and in the remainder of this and the following sections assume that a Wallet Instance is an app installed on a User device. However, a Wallet Instance can also be a web application. If this is the case, instead of opening the app, the User would log in to their web wallet using the browser on their User device. In such an architecture, typically no data is stored locally. Apart from UI aspects and short-range interfaces, all functions of the Wallet Unit are executed by the Wallet Unit Service running on the Wallet Provider backend depicted in Figure 2 and briefly discussed in the next section. Also, this implies that the WSCD will be a remote HSM, as discussed in Section 4.5.2. All requirements in the ARF are applicable regardless of whether the Wallet Instance is a mobile app or a web app, except where explicitly indicated.
  - Similarly, the European Digital Identity Regulation does not exclude the possibility that a Wallet Instance may be installed on a non-mobile device, for example a server. The requirements in this ARF also apply for the installation of a Wallet Unit on a User device that is not a mobile device.
  - A User device can host more than one Wallet Instance, either provided by multiple Wallet Providers or by the same one, if supported by that Wallet Provider. If a User device hosts multiple Wallet Instances, it is part of multiple Wallet Units. In such a case, all requirements in this ARF for a single Wallet Unit and its components apply to each one independently.
  - The exact functionalities of the Wallet Instance depend on whether the Wallet Provider chooses to use a Wallet Unit Service (running on the Wallet Provider

backend) as part of the Wallet Unit, see below. If a Wallet Unit Service is present, some tasks and responsibilities will be divided between the Wallet Instance and the Wallet Unit Service.

- **Wallet Secure Cryptographic Device (WSCD)**: A tamper-resistant device that provides an environment that is linked to and used by the Wallet Secure Cryptographic Application (WSCA) to protect critical assets and to securely execute cryptographic functions. This includes a hardware-backed repository for storing and managing cryptographic keys and other critical assets, but also the environment where related security-critical functions are executed. The WSCD is tamper-proof and duplication-proof. In fact, CIR 2024/2981, Annex IV, section 2 (3) states "As a prerequisite to the certification under national certification schemes, the WSCD shall be assessed against the requirements of assurance level high as set out in Implementing Regulation (EU) 2015/1502". Therefore, a WSCD by legal definition complies with requirements of LoA High. One WSCD may be a part of multiple Wallet Units, e.g. in case of a remote HSM. The WSCD consists of two parts: the WSCD hardware covers the hardware issued by the WSCD vendor and the WSCD firmware covers security-related software, such as an operating system and cryptographic libraries provided by the WSCD vendor. Figure 2 shows four different possible security architectures for the WSCD (for more details see Section 4.5):
  - a remote WSCD, which is a remote device, such as a Hardware Security Module (HSM), accessed over a network.
  - a local external WSCD, which is an external device, such as a smart card issued to the User specifically for this purpose,
  - a local internal WSCD, which is a component within the User device, such as a SIM, e-SIM, or embedded Secure Element,
  - a local native WSCD, which is a component embedded in the User device and accessed via an API provided by the operating system.
- **Wallet Secure Cryptographic Application (WSCA)**: an application that manages critical assets by being linked to and using the cryptographic and non-cryptographic functions provided by the Wallet Secure Cryptographic Device. Different types of WSCD generally use different types of WSCA. For example, if the WSCD is a remote HSM, the WSCA may be (but does not have to be) a dedicated firmware module. If the WSCD is a external smartcard or an internal e-SIM or embedded Secure Element, the WSCA takes the form of a dedicated Java Card applet running on the smart card, e-SIM, or SE. If the WSCD is a local native WSCD, the WSCA is integrated into the OS of the User device. In all cases, the

WSCA interfaces directly with the Wallet Instance. For more details see Section 4.5. Note that the WSCA is dedicated firmware and/or software implementing specific functions needed within the EUDI Wallet ecosystem. A WSCD may offer additional functionalities through native firmware or software, for generic purposes. A good example of this is that some WSCDs will offer functionalities for synchronising (backing up and restoring) private keys, for instance to enable the creation of fallback or load balancing systems. However, within the scope of the EUDI Wallet ecosystem, private key export is not necessary and therefore it is not supported by a WSCA.

- **Keystore**: In addition to a WSCA/WSCD, a Wallet Unit may also have available one or more other keystores. A keystore is a hardware-backed repository and service in which non-critical cryptographic assets are generated, stored, and used exclusively inside a dedicated hardware security boundary. Examples of a keystore include a Secure Element, a TPM, TEE, or secure enclave, or a remote HSM. Depending on its implementation, a keystore is associated with a certain level of security, classified, for example, according to [ISO/IEC 18045]; see also OpenID4VCI Appendix D.2. A keystore cannot be used for PID private keys, since these must be managed on Level of Assurance High, which can only be done using a WSCA/WSCD. See Section 2.2 for the distinction between 'Level of Assurance' and 'level of security'.
- **Local QSCD**: The Wallet Unit may contain a local QSCD. In principle, a local QSCD can be the same component as the WSCD. Or, to put it differently, a single component can implement both the QSCD and the WSCD functionality. However, in such case that component must be certified both as QSCD and as WSCD. Alternatively, a local QSCD can also be a separate component, for example a dedicated smart card, that is connected to the Wallet Unit. If a local QSCD is available to the Wallet Unit, it is provided by the Wallet Provider, and the Wallet Provider is responsible for ensuring the correct functioning of the Wallet Instance and the local QSCD when creating a signature.
- **Wallet Provider backend**: The Wallet Provider backend offers Users support with their Wallet Units, performs essential maintenance, and issues Wallet Unit Attestations and Wallet Instance Attestations to the Wallet Unit. Maintenance provided by the Wallet Provider is discussed in more detail in the discussion paper for Topic T and in Section 6.5.3.2. High-level requirements are in included in Topic 56 in Annex 2.
- **Wallet Unit Service**: Depending on the implementation chosen by the Wallet Provider, some parts of a Wallet Unit may run on the Wallet Provider backend rather than being part of the Wallet Instance. These parts are called the Wallet Unit Service. If a Wallet

Unit Service is present, some tasks and responsibilities will be divided between the Wallet Instance and the Wallet Unit Service.

4.3.3 Wallet Unit interfaces and protocols

Figure 2 shows the following interfaces between components of a Wallet Unit, or between the Wallet Unit and other entities in the EUDI Wallet ecosystem:

- The **Wallet Provider Interface** is used by the Wallet Instance to communicate with the Wallet Provider to request and issue Wallet Unit Attestations and Wallet Instance Attestations, as well as to provide support to the User and collect aggregated and User-consented information in a privacy-preserving manner to provision the Wallet Unit, in compliance with applicable legislation. Because the Wallet Provider is responsible for both sides of this interface, it will not be standardised in the scope of the EUDI Wallet ecosystem. Moreover, the exact location of this interface may depend on the implementation of the Wallet Unit. If management of KAs and WIAs by the Wallet Unit is implemented within a Wallet Unit Service, then part of the Wallet Provider Interface will be internal to the Wallet Provider backend. This is depicted in Figure 2.
- The **User Interface** is the point of interaction and communication between the User and the Wallet Instance. This interface will not be standardised in the scope of the EUDI Wallet ecosystem.
- The **Presentation Interface** enables Relying Party Instances to securely request and receive PIDs, QEAAs, PuB-EAAs, and EAAs from Wallet Units. This interface accommodates both remote and proximity interactions.

  For proximity presentation flows to a Relying Party Instance, the Wallet Instance implements the the protocol specified in ISO/IEC 18013-5, see Section 5.7.2. This interface can, with some extensions, also be used by a Wallet Unit to request User attributes from another Wallet Unit, see Section 6.6.4.

  For remote presentation flows to a Relying Party Instance, the Wallet Instance implements the following (see Sections 5.7.3 and 5.7.4):

  - the protocol specified in OpenID4VP in combination with a custom URI scheme,
  - the OpenID4VP protocol in combination with the W3C Digital Credentials API,
  - the protocol specified in ISO/IEC 18013-7, in combination with the W3C Digital Credentials API,

  - optionally, the ISO/IEC 18013-7 protocol in combination with a custom URI scheme.

  Proximity presentation flows are discussed in Section 4.4.2. Remote presentation flows, including the role of URI schemes and the W3C Digital Credentials API, are discussed in Section 4.4.3.

- The **Secure Cryptographic Interface** enables the Wallet Unit to communicate with the Wallet Secure Cryptographic Application (WSCA). This interface is specifically designed for managing cryptographic assets and executing cryptographic functions. In case the WSCA is delivered by the Wallet Provider, the Wallet Provider is responsible for both sides of this interface, and hence standardisation is not needed within the scope of the EUDI Wallet ecosystem. In case the WSCA is delivered by the provider of the WSCD, this interface will comply with an existing specification that is not specifically designed for the EUDI Wallet ecosystem. Rather, each type of WSCA/WSCD will expose a provider-defined interface to the Wallet Units. For example, in case the WSCD is a secure element, CIR 2024/2979 requires support for the GP OMAPI interface specification (or an equivalent one). To be able to support different types of WSCA/WSCD, Wallet Units may therefore need to be able to handle multiple flavours of this interface.
- The **WSCA - WSCD Interface** enables the WSCA to communicate with the WSCD. This interface is not specifically designed for the EUDI Wallet ecosystem. Rather, each type of WSCD will expose a manufacturer-defined interface to the WSCA making use of it, for example syscalls of the operating system. In case the WSCA is delivered by the Wallet Provider, the Wallet Provider is responsible for correctly implementing this interface.
- The **PID Issuance Interface** complies with the OpenID4VCI standard (see Section 5.8) and is used when the Wallet Unit communicates with a PID Provider to request and receive PIDs to be stored within the Wallet Unit. > Note: In addition to supporting OpenID4VCI, PID Providers are allowed to support other protocols for issuing PIDs to (national) Wallet Units, provided these protocols comply with all relevant requirements in the Implementing Acts and the standards referenced therein. In many Member States, the PID Provider and the Wallet Provider are closely related, and can therefore bilaterally agree to support a different protocol for PID issuance.
- The **Attestation Issuance Interface** also complies with the OpenID4VCI standard and is used by the Wallet Unit to request various attestations that the User wants to include in their Wallet Unit.
- The **Remote Signing or Sealing Interface** facilitates communication between the Wallet

Unit and a Qualified Electronic Signature Remote Creation (QESRC) Provider. This interface is used by the Wallet Unit to generate a qualified electronic signature or seal.

Note that the "Attribute Deletion Request to Relying Party Interface" and the "Reporting Relying Party to DPA Interface", which are mentioned in the Regulation, are not depicted as interfaces in Figure 2. Functionality enabling a User to request a Relying Party to delete personal data (i.e., User attributes) obtained from the User's Wallet Unit is seen as a feature of the Wallet Solution. The same applies to functionalities enabling the User to report a Relying Party to a Data Protection Authority.

4.4 Data presentation flows

4.4.1 Overview

This section defines four distinct communication flows that can be used when a Wallet Unit presents a PID or attestation to a Relying Party Instance:

- **Proximity Supervised Flow**: In this flow, the User and their User device are physically near the Relying Party Instance. PIDs and attestations are exchanged using proximity technology (e.g., NFC or Bluetooth) between the Wallet Unit and the Relying Party Instance. Both devices may be with or without internet connectivity. A human representative of the Relying Party supervises the process.
- **Proximity Unsupervised Flow**: This flow is like the supervised flow, but the Wallet Unit presents attestations to a machine, without human supervision. The interfaces and protocols used in this flow are the same as for the proximity supervised flow, and are described in Section 4.4.2.
- **Remote Same-Device Flow**: In this flow, the User uses a web browser or another application on their User device to access a Relying Party's service. The service requires the Relying Party to obtain specific attributes from the User's Wallet Unit, and therefore the Relying Party sends a presentation request to the Wallet Unit. As explained in Section 4.4.3.1, the transmission channel to send the request and the response are set up either using custom URIs, or via the web browser on the User's device, using the W3C Digital Credentials API. Section 4.4.3.4 explains the latter option in more detail.
- **Remote Cross-Device Flow**: In this flow, the User uses a web browser on a device other than the User device on which their Wallet Unit is installed to access the Relying Party's service. This other device could be a desktop, laptop, or another mobile device. Like with same-device flows, the communication channel between the other device and

the User's device is set up either by using custom URIs, or by using the W3C Digital Credentials API. Section 4.4.3.5 explains the latter option in more detail.

Specific use cases integrate one or more of these flows. Each of these flows is described in more detail in one of the next sections.

4.4.2 Proximity presentation flows

Figure 3 shows how attestation presentation works when the User and their User Device are physically near the Relying Party Instance and do not have (or do not want to use) an internet connection between them. In this case, the ISO/IEC 18013-5 standard specifies how a communication channel is set up and how a presentation request and the corresponding response are exchanged using short-range communication technologies.

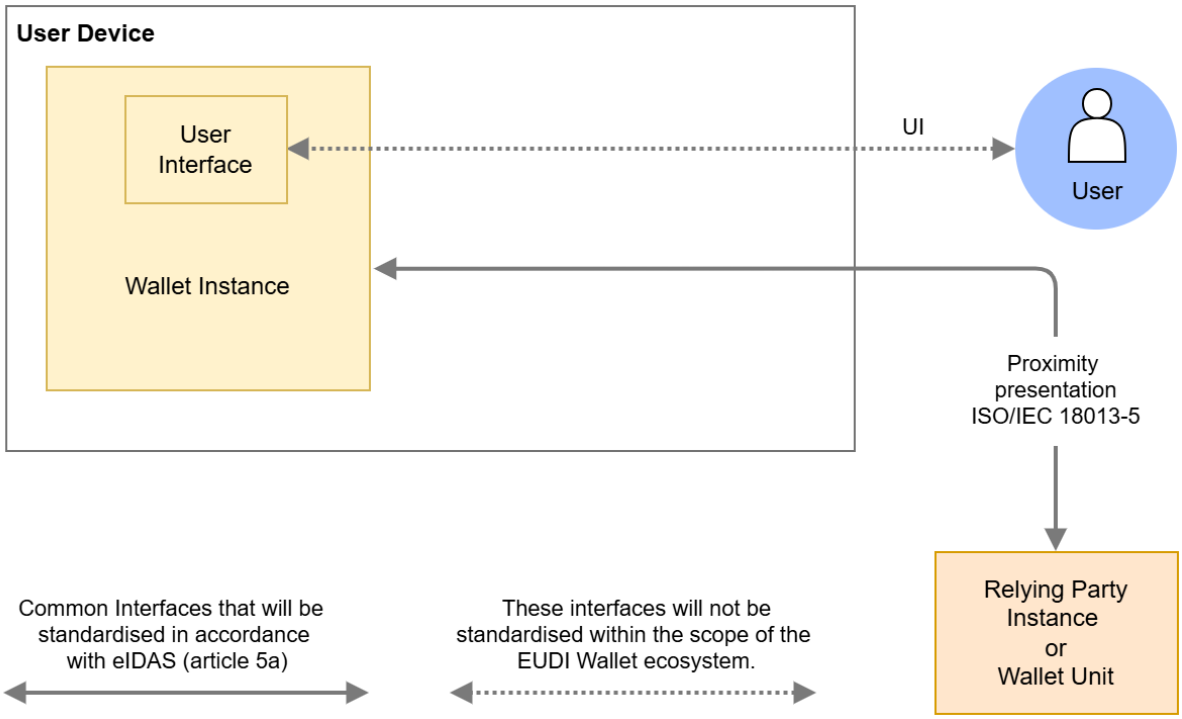


Figure 3: Proximity presentations

An attribute presentation flow according to ISO/IEC 18013-5 begins when the User opens the Wallet Instance and instructs it to display a QR code or present an NFC tag. This QR code or NFC tag contains the information necessary to establish an NFC, BLE, or Wi-Fi Aware connection. The Relying Party Instance scans the QR code or the NFC tag and sets up a connection towards the Wallet Unit. The QR code or NFC tag also contains the information necessary to create an

authenticated and encrypted secure channel on top of the NFC, BLE, or Wi-Fi Aware connection between both entities.

For more information about the protocol and transmission mechanism specified in ISO/IEC 18013-5, please see Section 5.7.2. For high-level requirements, see Topic 24.

Note that a Wallet Unit and a Relying Party do not necessarily use proximity technologies if they are close together. They are free to use a remote flow according to Section 4.4.3. However, there may be situations where either the Wallet Unit or the Relying Party Instance does not have an internet connection. In such cases, Wallet Units must be able to use a proximity presentation flow, if it is close to a Relying Party Instance supporting the ISO/IEC 18013-5 standard.

4.4.3 Remote presentation transaction flows

4.4.3.1 Introduction

Remote presentation transaction flows are use cases in which the Relying Party Instance is remote from the User and the User device. The Relying Party Instance requests data from the Wallet Unit over the internet. There are two main mechanisms that can be used to set up a transmission channel between a Wallet Unit and a remote Relying Party Instance:

- Using a custom URI.
- Using a mediating API implemented in the browser and/or the OS of the User device. The only specification of such an API that is currently available is the W3C Digital Credentials API.

Wallet Units support both mechanisms, although the use of custom URI schemes is not recommended for cross-device flows, due to the challenges described in the next section. Moreover, support for the custom URI scheme specified in ISO/IEC 18013-7 is optional. For detailed high-level requirements, please refer to Topic 1.

A remote **same-device** attribute presentation flow using **custom URIs** begins when the User accesses the Relying Party's website using a browser on their device. The website may provide an option for the User to present attributes from their Wallet Unit, typically via a button or similar interface. When the User selects this option, the browser sends a URI using a custom URI scheme, such as openid4vp:// or mdoc://, to the OS of the User device. The URI contains the URL of the remote Relying Party Instance. The Wallet Unit has registered for receiving URIs

of these custom schemes. Therefore, the OS will invoke the Wallet Unit and send it the URI. The Wallet Unit connects to the remote Relying Party Instance at the URL in the custom URI.

Note: A similar approach is to use domain-bound universal links, also known as app links. This has the drawback that such a link can be used only for a specific Wallet Solution. In other words, a Relying Party Instance, when trying to set up a connection to a Wallet Unit, must know upfront who is the Wallet Provider of that Wallet Unit.

A **cross-device** attribute presentation flow using **custom URIs** begins when the User uses a browser on a device different from their User device to visit the website of the Relying Party. The website may offer the User the possibility to present attributes from their Wallet Unit, for example by presenting a QR code. If the User scans this QR code using an app on their User device, that app sends a URI using a custom URI scheme to the OS of the User device. The remainder of the flow is identical to the same-device flow, as described in the previous paragraph.

Remote **same-device** presentation flows using the **W3C Digital Credentials API** are described in Section 4.4.3.4.

Remote **cross-device** presentation flows using the **W3C Digital Credentials API** are described in Section 4.4.3.5.

4.4.3.2 Challenges for remote presentation flows using custom URIs

Remote presentation flows, when implemented over transmission channels set up using custom URIs (as described in the previous section) come with a number of challenges that are not present for proximity flows:

1. **Secure Cross-Device Flows**: Cross-device flows are vulnerable to phishing and relay attacks, necessitating enhanced security measures. Proximity checks managed by the operating system of the User device can mitigate the risks derived from these vulnerabilities, ensuring they are both secure and reliable.
2. **Wallet Unit Selection**: In remote flows, interactions do not originate from the Wallet Unit but from the remote Relying Party Instance. Users may encounter difficulties in selecting the appropriate Wallet Unit to fulfil a specific presentation request, particularly when multiple Wallet Units are present on the device. A unified interface provided by the web browser and the device operating system can streamline this process, offering a seamless and intuitive User experience.

3. **Invocation Mechanism**: Establishing a communication channel between the Wallet Unit and the remote Relying Party Instance using custom URI schemes presents challenges due to inconsistent invocation methods. User experiences across different browsers and operating systems may be different, resulting in operational inefficiencies and potential security risks.
4. **Clear Origin Verification**: Protecting against relay attacks requires the Wallet Unit to have precise identification of the Relying Party Instance's origin. Including the origin information, such as the website domain or app package name, within the presentation request ensures the authenticity of the request and enhances trust for both Wallet Units and Users.
5. **Session binding**: When presenting a PID or attestation to a remote Relying Party Instance, Users have to switch contexts. Using custom URIs to set up the connection to the Wallet Unit may enable attacks where the contexts are not bound to each other, resulting in session hijacking. Using an interface provided by the web browser and the device OS allows information about a session to be embedded in a presentation request. This enables the browser and the operating system to handle context switching properly, preventing session hijacking.

The next sections describe how these challenges might be solved for both same-device and cross-device remote presentation flows by using the W3C Digital Credentials API.

4.4.3.3 The W3C Digital Credentials API

4.4.3.3.1 Overview

The current version of the W3C Digital Credentials API extends the Credential Management Level 1 API (the same API used by WebAuthn / Passkeys (see Section 4.7)) to allow websites to request an attestation. This is achieved by providing a sequence of "presentation requests", where each presentation request includes an "exchange protocol" and "request data". The format of the request data is specific to the exchange protocol. The W3C Digital Credentials API specifications will include a registry of supported protocols. For more information see the Topic F: Digital Credentials API discussion paper.

The W3C Digital Credentials API is still under development and has not yet been released as a W3C Recommendation. It is currently a W3C Working Draft. Moreover, the API has not been implemented yet by all browsers and operating systems. Although support of this API by Wallet Units is mandatory, Relying Parties may choose to use custom URL schemes to set

up remote connections. If a Wallet Unit implements a custom URL scheme, it will need to implement mitigations for the challenges described in this section.

Implementations of the W3C Digital Credentials API by browsers and operating systems will have to align with the expectations outlined in Section 4.4.3.3.2. Similarly, implementations of the underlying CTAP protocol will have to align with the expectations outlined in Section 4.4.3.3.3.

4.4.3.3.2 Expectations for implementations of the Digital Credentials API

If the transmission channel between the Relying Party Instance and the Wallet Unit is set up via the operating system and/or the browser using the W3C Digital Credentials API, the Relying Party's presentation request will be processed by the browser and/or the operating system for searching available attestations, for preventing fraud targeting the User, or for troubleshooting purposes. Moreover, the request may be processed for User security purposes. However, the request will not be processed by the browser and/or the operating system for market analysis purposes (including as a secondary purpose) or for the browser's and/or the operating system's own purposes.

In particular, implementations of the W3C Digital Credentials API must meet critical expectations regarding functionality, neutrality, privacy, and availability.

- **Functionality**: Implementations support both Wallet Unit selection and invocation for attestation presentation and issuance. They support the protocols specified in the Implementing Acts for remote presentation and issuance. They also enable secure cross-device flows to mitigate phishing and relay attacks.
- **Technological neutrality**: Implementations preserve neutrality, avoiding vendor-specific extensions. Implementations do not restrict, block, or discriminate against specific protocols, credential formats, or attestation types. Any EUDI Wallet Solution will be able to use a Digital Credentials API implementation, without additional vendor vetting.
- **Privacy and responsibility**: Implementations do not compromise User privacy. The Wallet Unit remains solely responsible for requesting User approval. The Wallet Unit retains full responsibility over attestation management, ensuring the operating system does not override or disrupt the Wallet Unit's security functions. The attestation matching mechanism used by the operating system are privacy-preserving, only accessing the minimum necessary information without disclosing attributes or values.
- **Availability**: Implementations prevent Denial-of-Service attacks against Wallet Units by ensuring Attestation Providers or Relying Parties cannot send multiple invalid requests.

4.4.3.3.3 Expectations for implementations of the CTAP protocol in cross-device flows

For cross-device flows, implementations of the CTAP protocol underlying the Digital Credentials API also meet specific requirements:

- **Mandatory proximity check**: The Wallet Unit verifies that the device interacting with the Wallet Unit is in close physical proximity to the User's device, using a secure, direct, and user-mediated local communication channel (such as a short-range wireless technology). In CTAP terms, this proximity check is the BLE proximity engagement, present in both the Hybrid transport in CTAP v2.2 and in CTAP v2.3. The Wallet Unit does not continue the transaction if the proximity check does not succeed.
- **Transport preference**: Where both devices support it, the underlying operating systems, browsers, mediating APIs, or any other technical layer outside the control of the Wallet Unit, should prefer performing both the proximity check and the data transfer over a local short-range channel (as enabled by CTAP v2.3) over the use of a Hybrid tunnel service first defined in CTAP v2.2. Where the fully-local path is not supported by both devices, CTAP-Hybrid with a tunnel server remains an acceptable fallback for the data transfer. However, this is out of scope of the ARF.

4.4.3.4 Same-device remote presentation flows using the Digital Credentials API

4.4.3.4.1 Using a web browser

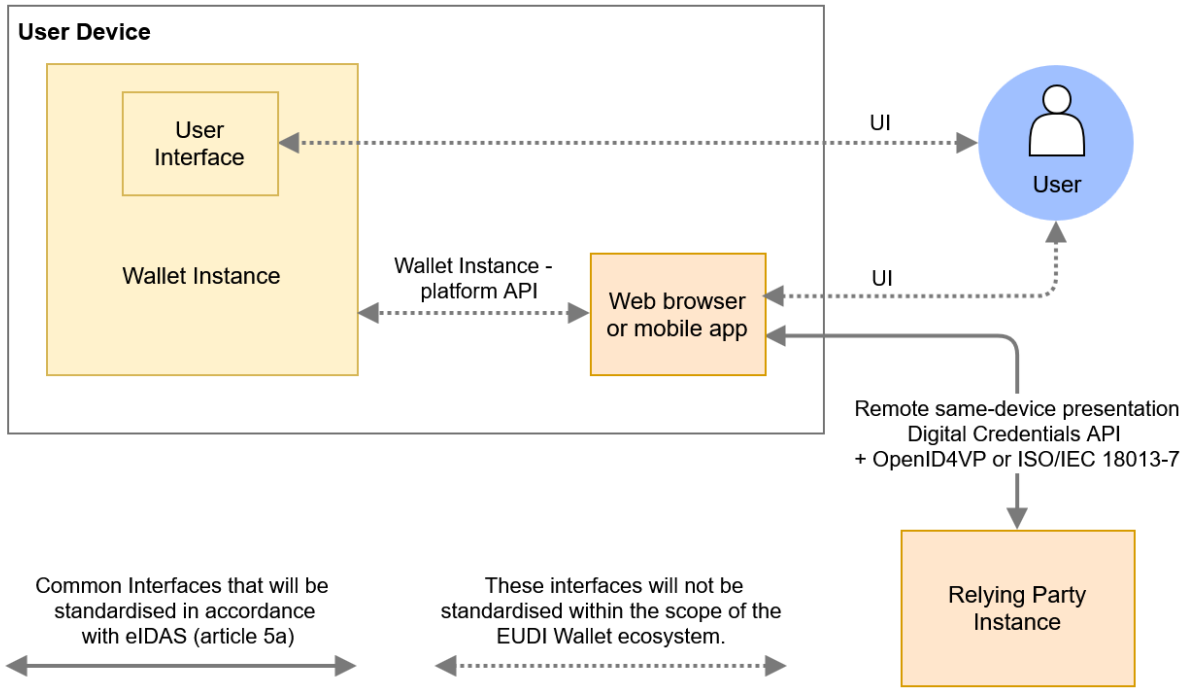


Figure 4: Remote same-device presentations

Compared to Figure 2, Figure 4 shows additional detail. In particular, it shows the browser on the User device and the relevant interfaces of this browser:

- The **Remote same-device presentation** interface establishes communication between the web browser and a remote Relying Party Instance, which may operate on a server managed by the Relying Party. This interface complies with the W3C Digital Credentials API.
- The **Wallet Instance-platform API** interface is a mechanism provided by the device's operating system that may implement the W3C Digital Credentials API mechanism at OS level. There are however no current plans to standardise this interface on the level of the API calls. These calls will be specified in the developer documentation for the respective OS. One of the main properties of this API is that a Wallet Unit receives reliable information regarding the origin of the presentation request.

Obviously, the browser also has a User interface allowing the User to interact with it. This interface will not be standardised in the context of the EUDI Wallet ecosystem.

A remote same-device attribute presentation flow using the Digital Credentials API begins when the User accesses the Relying Party's website using a browser on their device. The website may provide an option for the User to present attributes from their Wallet Unit, typically via a button or similar interface. When the User selects this option, the browser may ask the

User for permission to initiate the presentation flow. Upon granting permission, the Relying Party Instance sends a presentation request compliant with the OpenID4VP specification to the browser via the Digital Credentials API. The browser, working in tandem with the device's operating system (OS), forwards the request to the Wallet Unit using the Wallet Instance-platform API. If the device hosts multiple Wallet Units, the browser and OS will determine which Wallet Unit handles the request. To enable the browser and the OS to do this, the request is unencrypted. The selection decision may involve consulting the User.

The selected Wallet Unit processes the presentation request and seeks the User's approval before returning the requested attributes in an encrypted format to the browser. The browser then forwards this encrypted response to the remote Relying Party Instance.

4.4.3.4.2 Using a mobile app

Figure 4 also illustrates an inter-app attribute presentation flow. In this scenario, an application on the User's device, such as a banking or shopping app, interacts with the Wallet Unit over the Wallet Instance-platform API. This app acts as the Relying Party Instance, possibly in cooperation with a remote server of the entity that provisioned the app. The app can use the User attributes retrieved from the Wallet Unit itself, for example for User authentication or to automatically fill in data fields like User name and address. Alternatively, the app can send these User attributes to the remote server. All requirements on Relying Parties in this ARF, such as those regarding Relying Party registration and authentication, User approval, and other aspects, are applicable in this use case as well.

In this use case, the attribute presentation flow begins when the User opens the app and initiates a request for attributes from the Wallet Unit via the WI-platform API. Notably, this is the same API used in remote same-device presentation flow involving a browser. The primary difference lies in the origin information included in the presentation request, which may vary.

4.4.3.5 Cross-device remote presentation flows using the Digital Credentials API

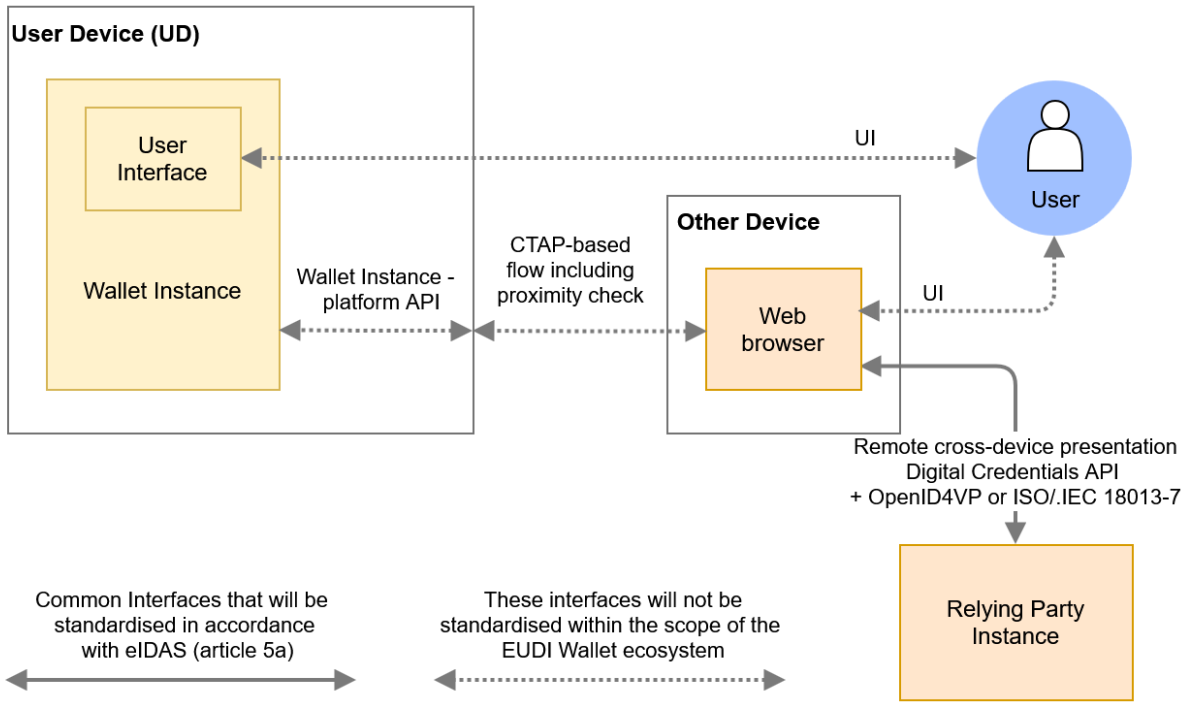


Figure 5: Remote cross-device presentations

A remote cross-device attribute presentation flow using the Digital Credentials API begins when the User uses a browser on a device different from their User device to visit the website of the Relying Party. The website may offer the User the possibility to present attributes from their Wallet Unit, for example by clicking a button. If the User does so, the browser may ask the User for permission to initiate the presentation flow. If the User allows this, the Relying Party Instance sends a presentation request to the browser over the W3C Digital Credentials API. The browser then establishes a tunnel towards the User device, using the FIDO CTAP hybrid flow, see section 11.5 of CTAP. Note that this flow is also used for FIDO Passkeys. This is done as follows:

1. The browser presents a QR code that includes information about the tunnel endpoint, as well as keys that will be used for establishing a secure channel over this tunnel.
2. The User scans the QR code using the camera on the User device.
3. The User device emits a BLE advertisement, which is received by the browser. The advertisement includes, in an encrypted form, information required for establishing the secure tunnel. This advertisement is used as a proximity check: the tunnel cannot be established if the User device and the device on which the browser runs are not close to each other.
4. A tunnel is established between the two devices.

The browser then sends the OpenID4VP-compliant presentation request to the User device. If there are multiple Wallet Instances present on the User device, the device OS will determine to which of these the request will be forwarded, possibly after consulting the User. The selected Wallet Unit will process the presentation request and, after requesting approval from the User, will return the requested attributes in encrypted format to the browser, using the established tunnel. The browser will forward the response to the remote Relying Party Instance.

Note that the Wallet Instance does not see any difference between the cross-device flow and the same-device flow. In both cases, it receives an OpenID4VP-compliant presentation request over the Wallet Instance-platform API described in the previous section.

The proximity check in step 3 is mandatory for cross-device flows (see Section 4.4.3.3.3). The flow described above carries the presentation request and response over the CTAP-Hybrid tunnel. Where both devices support CTAP v2.3, the proximity check and the data transfer may instead both be carried over a local short-range channel without a tunnel server. This fully-local option should be preferred over the CTAP-Hybrid tunnel services, which however remain an acceptable fallback.

4.5 WSCD architecture types

4.5.1 Introduction

Figure 2 shows four different types of architecture for the WSCD, which are:

- Remote WSCD, see Section 4.5.2
- Local external WSCD, see Section 4.5.3
- Local internal WSCD, see Section 4.5.4
- Local native WSCD, see Section 4.5.5

Within the EUDI Wallet ecosystem, a Wallet Provider is allowed to use any of these architectures.

For more information, please refer to the Discussion Paper for Topic P.

Notes:

- Regardless of the chosen architecture, the Wallet Provider is responsible for ensuring that the Wallet Instance can access a WSCA/WSCD with a security level sufficient to meet **Level of Assurance High**, as required by the European Digital Identity Regulation for

PIDs. Although this section discusses a few specific WSCD architectures and technologies, this does not necessarily imply that a given implementation of these architectures or technologies will be able to pass the required security certification.

- The Wallet Provider manages the cryptographic keys on the WSCD (through the WSCA) throughout the lifetime of the Wallet Unit, and attest the properties of the WSCD, including relevant certifications, in a Key Attestation (KA). See Section 6.5.3.4.
- User access to the WSCA/WSCD always requires **two User authentication mechanisms**, one implemented by the User's device OS (possibly augmented by a Wallet Instance-specific PIN), and the other by the WSCA/WSCD, irrespective of the architecture used. See Section 6.5.3.3.

4.5.2 Remote WSCD

In this architecture, the Wallet Secure Cryptographic Device is situated remotely from the User device. Typically, it will be implemented by the Wallet Provider using an HSM running on a secure server. The Wallet Provider will also provide the WSCA with which the Wallet Unit interacts. The WSCA does not necessary run (fully) on the HSM hardware.

This architecture is typically used if the User device lacks sufficiently secure hardware, or if the Wallet Provider does not want to have a dependency on such hardware.

If a remote HSM is used as the WSCA/WSCD, the Wallet Provider takes appropriate measures to ensure that only the legitimate Wallet Instance can access the remote HSM and use the critical assets of the Wallet Unit. The Wallet Provider may do so, for example, by using a split-key architecture, where the keys at the side of Wallet Instance are stored and managed in an embedded Secure Element or other keystore. During the certification process, the security of the HSM access control solution will be evaluated.

4.5.3 Local external WSCD

If the User device lacks sufficiently secure hardware, another option is to use a local external hardware component as the WSCD. This local external WSCD is typically a smart card or a secure token. It is connected to the User device via NFC or another short-range connection, and is able to perform all of the cryptographic operations required from a WSCA/WSCD in the ARF. Note that many existing smart cards, such as identity cards, will not be able to do this.

The WSCA typically takes the form of a Java Card applet. The WSCA is installed prior to issuance of the smart card or secure token to the User. The issuer of the WSCD and of the WSCA is

the Wallet Provider or another entity acting on behalf of or in cooperation with the Wallet Provider.

4.5.4 Local internal WSCD

In this architecture, the Wallet Secure Cryptographic Device is integrated directly within the User's device. This includes solutions like UICCs, e-SIM/SAMs, or embedded Secure Elements. Such solutions typically are compliant with the GlobalPlatform Card Specifications GP CS or with the GSMA Secured Applications for Mobile GSMA SAM specification.

The WSCA will typically be a Java Card applet, and it is remotely issued to the WSCD by the Wallet Provider, at the moment the Wallet Unit is activated; see Section 6.5.3. In order to do this, the Wallet Provider may need to connect to and collaborate with other entities, such as a Trusted Service Manager employed by the owner of the WSCD.

A local internal WSCD is typically not provided by the Wallet Provider. However, the Wallet Provider is responsible for verifying that the local internal WSCD is compliant with all applicable requirements, in particular regarding security certification. In this regard, CIR 2024/2981, Annex IV, (3) states: > When the WSCA is not provided by the wallet provider, national certification schemes shall formulate assumptions for this evaluation of the WSCA under which resistance against attackers with high attack potential in accordance with Implementing Regulation (EU) 2015/1502 […]

This implies that a local internal WSCD may be covered by an assumption regarding its resistance against attackers with high attack potential. This assumption can be based, for instance, on a security evaluation of the local internal WSCD by a third party.

4.5.5 Local native WSCD

A local native WSCD is integrated into the User device, just like the local internal WSCD discussed in the previous section. However, the API to access the WSCD is included in the operating system of the User device. Therefore, no separate WSCA is necessary. Alternatively, the API offered by the OS may be viewed as the WSCA.

The Wallet Provider is responsible for verifying that the local native WSCD is compliant with all applicable requirements, in particular regarding security certification. In this regard, the statements regarding certification of local internal WSCDs in the previous section apply to local native WSCDs as well.

4.6 State diagrams

4.6.1 Introduction

In this section, state diagrams are presented for Wallet Solutions, Wallet Units, PID Providers and Attestation Providers, PIDs and attestations, and Relying Parties.

4.6.2 Wallet Provider

Figure 6 shows the possible states of a Wallet Provider.

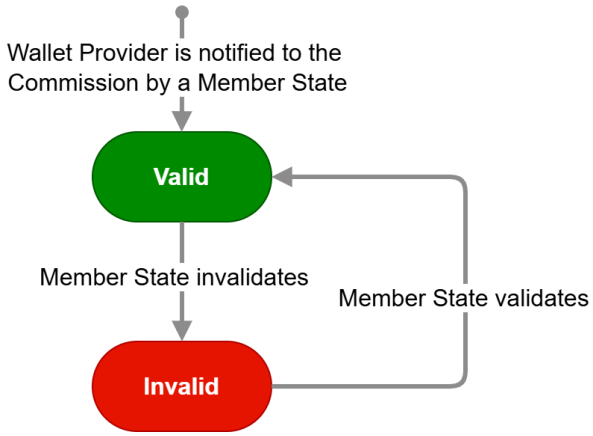


Figure 1: Figure 6

Figure 6: State diagram of Wallet Provider

The **Valid** state is the first state of a Wallet Provider. This means it has been notified by a Member State to the Commission, as described in Section 6.2.2) and in CIR 2024/2980 Annex II, 2. This notification includes the certified Wallet Solution(s) provided by the Wallet Provider.

If the Member State notifies the Commission that the notified entity is no longer a valid Wallet Provider, the Wallet Provider moves to the state **Invalid**.

4.6.3 Wallet Solution

A Wallet Solution has a state diagram of its own, independent of the lifecycle of the associated Wallet Provider. The state of a Wallet Solution affects the state of all Wallet Units of that Wallet Solution. Figure 7 below shows the states of the Wallet Solution:

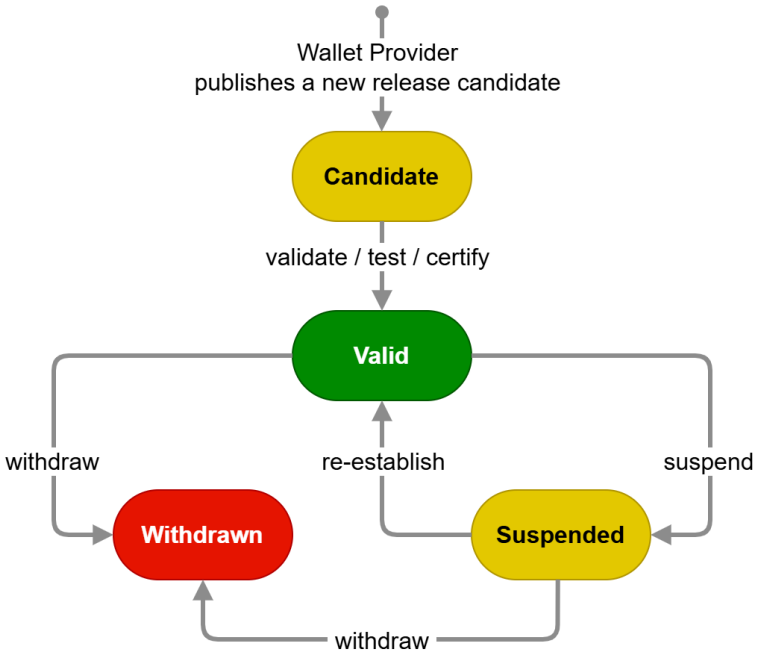


Figure 2: Figure 7

Figure 7: State diagram of Wallet Solution

The **Candidate** state is the first state of a Wallet Solution. This means it is fully implemented and the Wallet Provider requests the solution to be certified as a Wallet Solution as part of an EUDI Wallet eID scheme.

If all the legal and technical criteria have been met, a Member State may decide to allow a Wallet Provider to start providing the Wallet Solution to Users. The Member State notifies its Supervisory Body of the issuance of a certificate of conformity of the Wallet Solution (see CIR 2024/2981). The state of the Wallet Solution becomes **Valid**. This means the Wallet Solution can be officially launched, and can be provided to Users. The issuing Member State informs the Commission of each change in the certification status of their EUDI Wallet eID scheme and the Wallet Solutions provided under that scheme.

The issuing Member State can temporarily suspend a Wallet Solution. This would for example be the result of a critical security issue. This leads to the **Suspended** state. The issuing Member State can re-establish the Wallet Solution, bringing the Solution back to the **Valid** state. The issuing Member State can also decide to withdraw the Wallet Solution, which brings the Wallet Solution in the **Withdrawn** state. This state change cannot be undone.

Article 5e of the European Digital Identity Regulation requires Wallet Providers, in case of a

security issue, to first “suspend the provision and the use of European Digital Identity Wallets” and to “withdraw [them] and revoke their validity” only if the issue cannot be solved within three months. CIR 2025/847 interprets this as applying to Wallet Solutions, not Wallet Units. Wallet Units can only be revoked. When a Wallet Solution is suspended, according to CIR 2025/847 Article 4, point 2, the Member State decides whether it is necessary to revoke the corresponding Wallet Units. If it decides not to, the Wallet Units continue functioning normally. If it decides to revoke its Wallet Units, these Wallet Units cannot request the issuance of a PID or attestation any more. Also, PID Providers will revoke their PIDs on such Wallet Units, and other Attestation Providers may similarly revoke their attestations. If a Wallet Solution is withdrawn, the Wallet Provider revokes all associated Wallet Units.

4.6.4 Wallet Unit

Figure 8 below shows the states of a Wallet Unit.

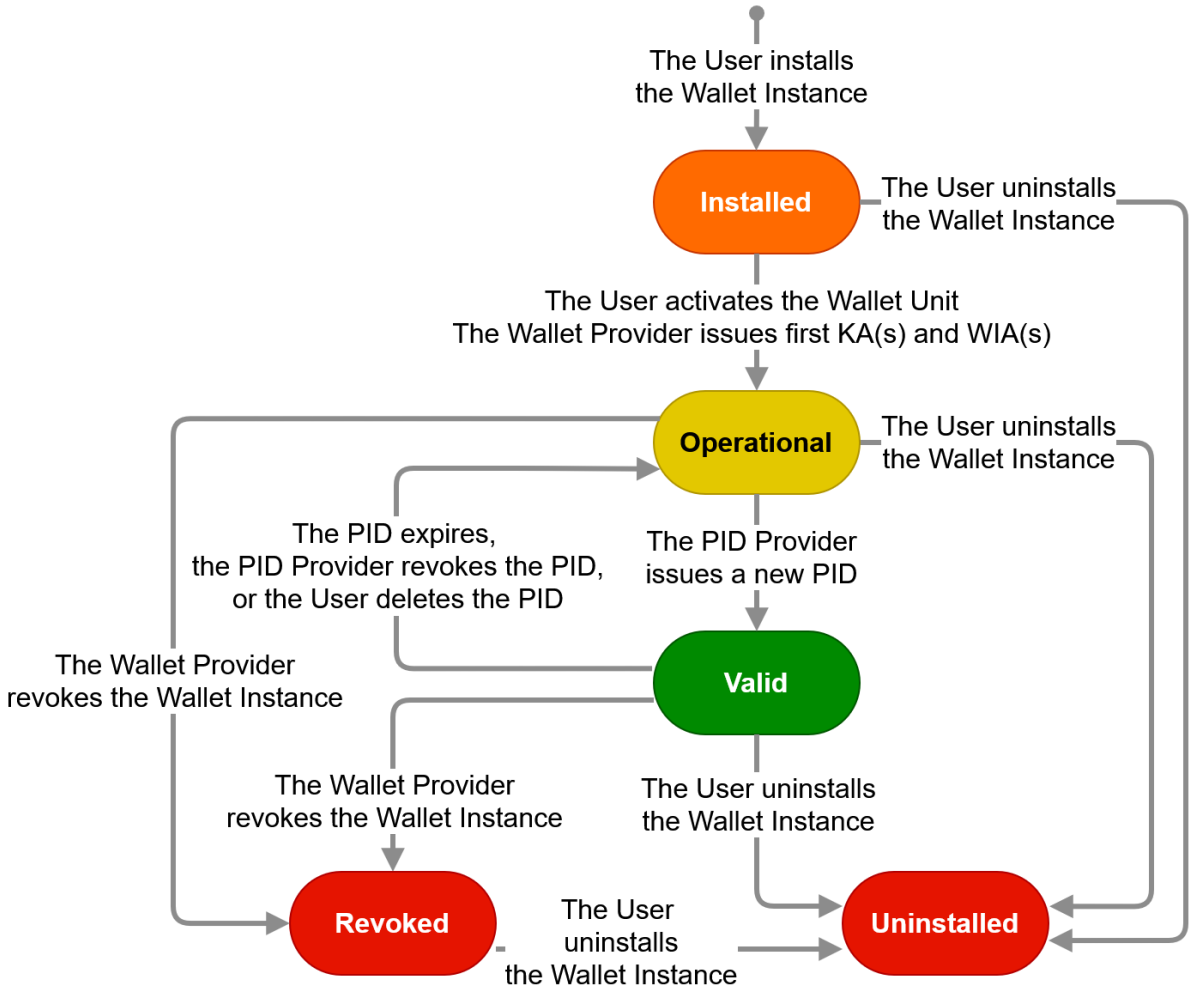


Figure 3: Figure 8

Figure 8: State diagram of Wallet Unit

A Wallet Unit lifecycle begins when the User installs a Wallet Instance on their User device, see Section 6.5.2. The Wallet Unit's state is then **Installed**. In this state, the User and the Wallet Provider can perform only one action, namely activating the Wallet Unit, as described in Section 6.5.3. As part of the activation process, the Wallet Provider issues one or more Key Attestations (KA, see Section 6.5.3.4) and Wallet Instance Attestations (WIA, see Section 6.5.3.5) to the Wallet Unit.

Once a Wallet Unit is activated, it is in the **Operational** state. If, in the **Operational** state, a PID Provider issues a PID to a Wallet Unit, it transitions to the **Valid** state. If, in either of these two states, the Wallet Provider revokes the Wallet Instance or revokes the WSCD or a keystore of

the Wallet Unit, the Wallet Unit moves to the **Revoked** state. Revocation cannot be undone.

If, in the **Valid** state the last or only PID in the Wallet Unit expires, is revoked, or is deleted, the Wallet Unit's state is moved back to **Operational**. Note that if there are multiple PIDs in the Wallet Unit, it does not move to the **Operational** state as long as at least one of them is valid.

In the **Valid** state, the following actions can be performed:

- The Wallet Provider updates the Wallet Unit to a new version,
- The User requests issuance of a PID, a QEAA, a PuB-EAA, or an EAA.
- The User views the PID(s) and attestation(s) in their Wallet Unit, including their attribute values.
- The User views the transaction log (see Section 6.6.3.13) and optionally report suspicious requests by a Relying Party to a Data Protection Agency, or requests a Relying Party to erase personal data.
- The User presents attributes from a PID, a QEAA, a PuB-EAA, or an EAA to a Relying Party.
- The User deletes a PID, a QEAA, a PuB-EAA, or an EAA.
- The Wallet Provider revokes the Wallet Unit, for instance at the User's request or if the security of the Wallet Instance is broken. Revocation of the Wallet Unit is accomplished by revoking the Wallet Instance, using a status list referenced in the WIA. The Wallet Provider can also revoke the WSCD or a keystore that is part of the Wallet Unit, using a status list referenced in the corresponding Key Attestation; see Topic 9 and Topic 38.
- A PID, a QEAA, a PuB-EAA, or an EAA is revoked by its Provider (if it is valid for more than 24 hours).
- The User uninstalls the Wallet Instance.

In the **Operational** state, the same actions can be performed as in the **Valid** state. However, obviously, the User cannot present a PID to a Relying Party, nor can any other action with a PID be performed, because by definition no valid PID is present in this state.

Note that in the **Operational** and **Valid** states, the Wallet Provider ensures that the Wallet Unit can always present a valid WIA and KA to a PID Provider or Attestation Provider. For that reason, Figure 8 does not contain an **Expired** state. However, if the Wallet Provider fails to ensure this, all of the actions listed above can still be performed, except for the User requesting the issuance of a PID or attestation.

In the **Revoked** state, the same actions can be performed as in the **Operational** state, except:

- the User cannot request issuance of a PID or attestation.

- the User cannot present a valid PID, since PID Providers will revoke any PIDs that reside on a revoked Wallet Unit.
- the User cannot present any valid attestation for which the Attestation Providers similarly decides to revoke any attestations that reside on a revoked Wallet Unit.

4.6.5 PID Provider or Attestation Provider

Figure 9 shows the possible states of a PID Provider or Attestation Provider.

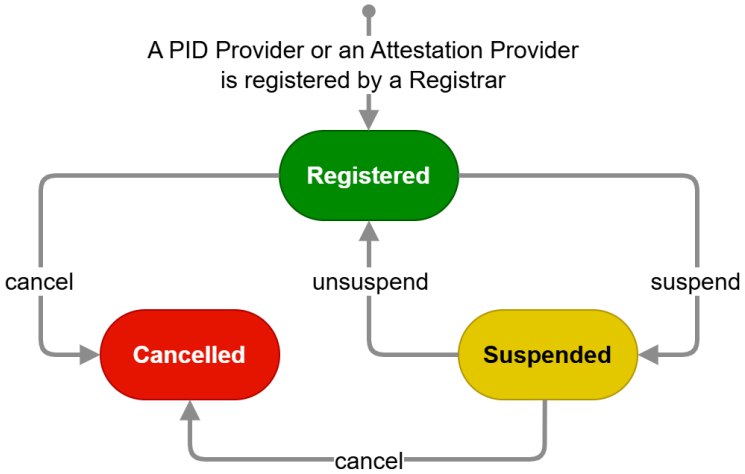


Figure 4: Figure 9

Figure 9: State diagram of PID Provider or Attestation Provider

The **Registered** state is the first state of a PID Provider or Attestation Provider. This means it is registered by a Member State Registrar and notified to the Commission, as described in Section 6.3.2.

The Registrar can temporarily suspend a PID Provider or Attestation Provider. This leads to the **Suspended** state. The Registrar can unsuspend the PID Provider or Attestation Provider, bringing it back to the **Registered** state. The Registrar can also decide to completely cancel registration of the PID Provider or Attestation Provider, which brings it in the **Cancelled** state. For more information about suspension or cancellation, please refer to Section 6.3.3). A PID Provider or Attestation Provider with suspended or cancelled registration cannot issue PIDs or attestations to Wallet Units, nor will a PID or attestation issued by such a PID Provider or Attestation Provider be accepted by Relying Parties.

4.6.6 PID or attestation

Figure 10 shows the possible states of a PID or attestation.

In the context of the EUDI Wallet ecosystem, a PID or attestation begins its lifecycle when being issued to a Wallet Unit. Please note that this means that the management of attributes in the Authentic Source (adhering to national structures and attribute definitions) is outside the scope of the ARF.

For certain use cases, a PID or attestation may be pre-provisioned, meaning it is not yet valid when issued. In that case, its state is **Issued**, and it will transition to **Valid** when it reaches the beginning of its validity period. However, if a PID or attestation is issued on or after the validity start date, its state directly changes to **Valid**.

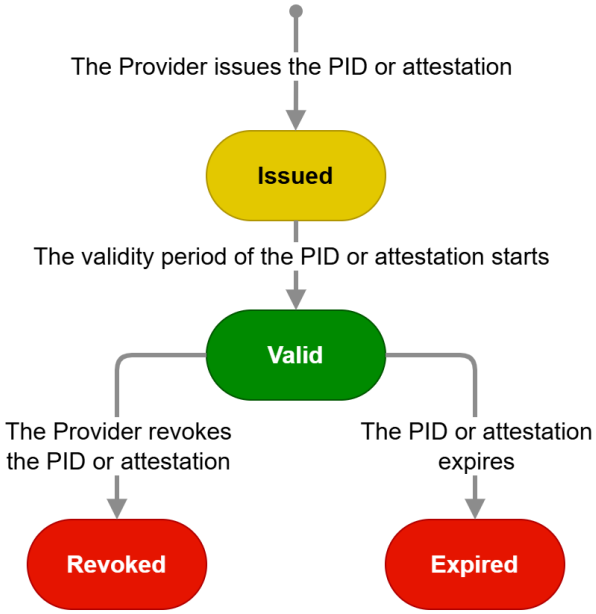


Figure 5: Figure 10

Figure 10: State diagram of PID or attestation

There are two possible transitions for a valid PID or attestation: it expires by passing through the validity end date and transitions to the **Expired** state, or it is revoked by its PID Provider or Attestation Provider, ending up in the **Revoked** state. Expiration and revocation are independent transitions. Once a PID or attestation is expired or revoked, it cannot transition back to **Valid**.

4.6.7 Relying Party

Figure 11 shows the possible states of a Relying Party.

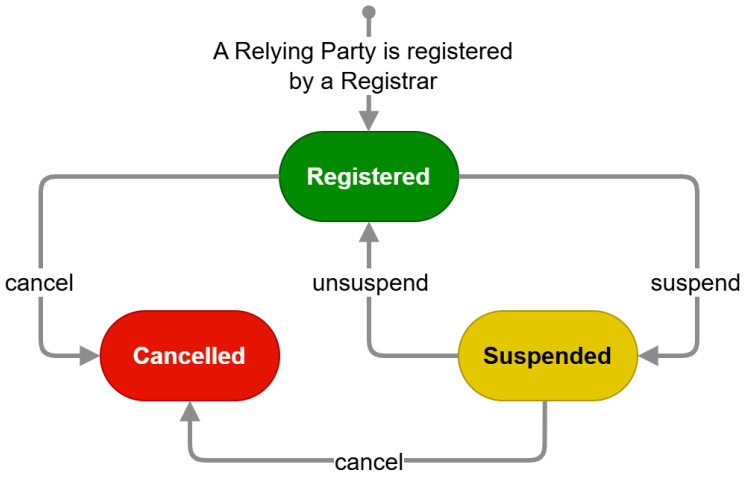


Figure 6: Figure 11

Figure 11: State diagram of Relying Party

The **Registered** state is the first state of a Relying Party. This means it has been registered by a Registrar, as described in Section 6.4.2.

The Registrar can suspend registration of a Relying Party. This leads to the **Suspended** state. The Registrar can unsuspend the Relying Party, bringing it back to the **Registered** state. The Registrar can also decide to completely cancel registration of the Relying Party, which brings it in the **Cancelled** state. For more information about suspension or cancellation, please refer to Section 6.4.3. A Wallet Unit will not present a PID or attestation to a Relying Party that has its registration suspended or cancelled.

4.7 Possible implementations of pseudonyms

4.7.1 Introduction: types of pseudonyms

Section 2.5 discussed four different use cases for pseudonyms, which can potentially be supported in the EUDI Wallet ecosystem. This section introduces three different types of pseudonyms that could potentially be used in the EUDI Wallet ecosystem to achieve these use cases:

- **Verifiable pseudonym:** A verifiable pseudonym is a pseudonym that allows a User to prove possession over the pseudonym and thereby authenticate as the pseudonym. Section 4.7.2 discusses how a Wallet Unit could support a specific type of verifiable pseudonyms called Passkeys.
- **Attested pseudonym:** An attested pseudonym is a subtype of a verifiable pseudonym, allowing Relying Parties to verify that a third party has attested that a pseudonym is owned by a User. Within the EUDI Wallet ecosystem, this third party would be an Attestation Provider, who issues pseudonym attestations in the form of a (Q)EAA or PuB-EAA. Section 4.7.3 discusses how attested pseudonyms can be issued within the EUDI Wallet ecosystem.
- **Scope rate-limited pseudonym:** A scope rate-limited pseudonym is a subtype of a verifiable pseudonym guaranteeing that the User is limited to control only a certain number of pseudonyms (called the rate) for a given scope. A special case occurs when the rate is set to 1. In that case, each User is guaranteed to have at most one valid pseudonym within the relevant scope, for example, in an electronic voting system. This is often referred to as a scope-unique or scope-exclusive pseudonym. Section 4.7.4 contains more details.

Verifiable pseudonyms can support use cases A (Pseudonymous authentication) and B (Presentation of attributes with subsequent authentication using pseudonyms).

Attested pseudonyms can similarly support use cases A and B, although the Relying Party cannot determine the value of the pseudonym used for each User, unless it also can acts as a Pseudonym Attestation Provider. By default (meaning without special rules on how a Wallet Unit handles a pseudonym attestation), attested pseudonyms also support use case D (Linkable pseudonymous authentication).

Scope rate-limited pseudonyms can support use case C (Rate-limited participation).

4.7.2 Verifiable pseudonyms

4.7.2.1 Introduction to Passkeys

W3C WebAuthn defines the technical specification for a type of verifiable pseudonyms called Passkeys. Passkeys are a widely used type of credential which are created and asserted using the WebAuthn API. Within the EUDI Wallet ecosystem, one option for Wallet Providers to

support verifiable pseudonyms is to let their Wallet Units perform the role of a WebAuthn authenticator as defined in the W3C WebAuthn specification.

Passkeys can be seen as an alternative to passwords. The idea is that a User, when registering a user account at a service, uses a secure device to generate a public-private key pair, registers the public key at the service, and can then subsequently use the private key to authenticate towards the service at later points in time.

In a bit more detail, the flow for using Passkeys is as follows:

Registration:

1. The User generates a public-private key pair and stores both the public and the private key at their secure device (referred to as an Authenticator).
2. The User registers the public key at the desired Relying Party service.

Authentication:

1. When the User wishes to authenticate towards a service, the service will send them a challenge consisting of a random value.
2. The User uses the private key stored on their Authenticator to sign the challenge and sends this back to the service.
3. The service verifies that the signature on the challenge can be verified using the registered public key. If the signature verifies and the origin matches the expected origin, the User is considered authenticated and thereby granted access to the service.

4.7.2.2 Introduction to W3C WebAuthn

4.7.2.2.1 Overview

W3C WebAuthn defines an API for the creation and use of Passkeys. Conceptually, in addition to the User, there are four different logical components in this specification:

- **Relying Party Server:** The Relying Party that wishes to offer a service based on User authentication using Passkeys.
- **Relying Party Client:** The program provided by the Relying Party that runs in the Client of the User and communicates with the Relying Party Server. The Relying Party Client is typically some JavaScript code, provided by the Relying Party, that runs on the Client (i.e., browser).
- **Client:** The client that the User uses to interact with the Relying Party's server and with the User's authenticator. The Client can be thought of as the browser that the User uses

to access the Relying Party's service. Note that the Relying Party Client and the Client are two programs that are executed on the same physical machine.

- **Authenticator:** The device controlled by the User to create, store, and use the Passkeys. If a Wallet Provider decides to implement pseudonyms in the form of Passkeys, the Wallet Unit will be the Authenticator.

W3C WebAuthn defines a model dividing the responsibilities between these different entities and defines an interface between the Relying Party Client and the Client. Additionally, it defines a challenge/response protocol to authenticate with Passkeys. The interface is referred to as the *WebAuthn API*. However, W3C WebAuthn does not specify how the Authenticator and the Client must communicate.

W3C WebAuthn relies on several different types of identifiers, including:

- **Relying Party ID:** An identifier unique to the Relying Party, which must be a valid domain string. This what the User will identify the Relying Party by and let the Authenticator learn which Relying Party is asking for registration/authentication.
- **Credential ID:** A unique identifier chosen by the Authenticator for each Passkey.
- **User ID:** An identifier unique to each User, which is assigned by the Relying Party. This will be provided to the Authenticator when registering a new Passkey. Subsequently, it will be provided by the Authenticator when authenticating towards the Relying Party. The Authenticator will keep track of which Passkeys are available for which User IDs and Relying Party IDs. The Relying Party keeps track of a User Name for each User ID.
- **User Name:** An alias that may be chosen by the User or the Relying Party and assigned to a specific Passkey on the Authenticator. This allows the User to easily distinguish and select which Passkey they want to authenticate with, if several are present in the Authenticator for the given Relying Party.

The next sections explain how the different components work together to allow User registration and subsequent authentication using Passkeys.

4.7.2.2.2 Registration

The flow for registering a Passkey in W3C WebAuthn is the following:

0. The User requests (out of band of WebAuthn) the Relying Party to create a new Pseudonym.
1. The Relying Party Server creates a challenge and sends this along with the User ID, the Relying Party ID, and the User Name to the Relying Party Client.
2. The Relying Party Client forwards the information to the Client using the WebAuthn API.

3. The Client checks that the Relying Party ID is consistent with the caller's origin and forwards the information to the Authenticator along with other contextual data.
4. The Authenticator authenticates the User (for example using a PIN or via biometrics). It then generates a new key pair with a new Credential ID and set the scope of this to the specific Relying Party ID and User ID. Finally, the Authenticator may generate an attestation (explained in Section 4.7.2.2.3) and send this, as well as the public key and its Credential ID, to the Client.
5. The Client then forwards the information to the Relying Party Client that again forwards it to the Relying Party Server.
6. The Relying Party Server verifies the attestation (if present) and registers the received public key for this User ID.

Note that the Authenticator stores the public key in a way such that it is scoped uniquely to a specific Relying Party, aligning with the requirements of CIR 2024/2979, Article 14 (2), which states that the pseudonyms must be unique to each Relying Party.

4.7.2.2.3 Pseudonym attestation

The term 'attestation' is used differently in this section than elsewhere in the ARF. In the context of Passkeys, the attestation is not about attributes of the User, but rather about attributes of the Authenticator. The attestation serves to ensure the Relying Party that they are talking with an Authenticator with certain attributes. The attestation often takes the form of a signature on the challenge as well as some other contextual data.

In W3C WebAuthn, five different types of attestations are mentioned:

- **Basic Attestation:** The Authenticator stores a single master public and private key. The private key is used to sign all attestations and a certificate on the public key is included in the attestation data to allow the Relying Party to verify the signature.
- **Attestation CA:** Similar to the above, in the sense that the Authenticator stores a single master public and private key. However, instead of using this to attest Passkeys, the Authenticator uses this to authenticate towards a Certificate Authority (CA), which is configured to issue certificates to the Authenticator on multiple attestation key pairs. The Authenticator then uses these attestation private keys to sign attestations.
- **Anonymisation CA:** Similar to the second bullet above, except that it is explicit that the Authenticator requests a certificate for a new attestation key pair per generated Passkey.

- **Self Attestation:** The attestation is signed with the private key of the newly generated key pair in the Passkey. Note that this does not give any guarantees for the Relying Party about the Authenticator they are interacting with.
- **No Attestation Statement:** No attestation is given. Note that this does not give any guarantees for the Relying Party about the Authenticator they are interacting with.

Please note that Article 5a (5) a) viii) of the European Digital Identity Regulation states "*European Digital Identity Wallets shall, in particular support common protocols and interfaces: … for relying parties to verify the authenticity and validity of European Digital Identity Wallets;…*". The latter two forms of attestation do not align with this requirement. Section 6.1 of the Discussion Paper for Topic E discusses how the other three possibilities relate to privacy risks about User surveillance identified in Section 7.4.3.5.

4.7.2.2.4 Authentication

The flow for authentication using a Passkey following W3C WebAuthn is:

1. The Relying Party Server creates a challenge and sends this along with its Relying Party ID to the Relying Party Client.
2. The Relying Party Client forwards the information to the Client using the WebAuthn API.
3. The Client checks that the Relying Party ID is consistent with the caller's origin and forwards the information to the Authenticator along with other contextual data.
4. The Authenticator authenticates the User (for example using a PIN or via biometrics). It then prompts the User to select one of the Passkeys scoped to this Relying Party ID, if there are multiple. For this step the User Name can be presented to the User. Finally, the Authenticator uses the private key of the chosen key pair (= Passkey) to sign the challenge as well as some contextual data including the User ID, Credential ID, and the Relying Party ID. The Authenticator then sends this to the Client.
5. The Client forwards the information to the Relying Party Client, which again forwards it to the Relying Party Server.
6. The Relying Party Server verifies the signature with the stored public key for this User ID and Credential ID, and, depending on the outcome of this verification, considers the User to be authenticated.

4.7.3 Attested pseudonyms

Within the EUDI Wallet ecosystem, attested pseudonyms can be issued by an Attestation Provider, in the form of a (device-bound) attestation that contains one or multiple pseudonym

values as attributes. A User can subsequently authenticate pseudonymously by presenting that attestation to Relying Parties.

The pseudonym values in a pseudonym attestation can have different properties, to serve different use cases. A simple case is where each pseudonym is just a (pseudo-)random number. However, pseudonym values can also be generated by the Attestation Provider using some cryptographic algorithm that takes the identity of the User and/or the identity of the Relying Party as input.

There is no EU-wide definition of such an attestation type. Schema Providers are free to define a type of pseudonym Attestation in an Attestation Rulebook.

4.7.4 Scope rate-limited pseudonyms

This version of the ARF does not specify or reference a protocol and cryptographic mechanisms to implement scope rate-limited pseudonyms. However, section E of Topic 11 contains a set of requirements that such a protocol and cryptographic mechanisms are expected to comply with.

5 Data model and data exchange protocols

5.1 Attestation elements

Within the EUDI Wallet ecosystem, data is exchanged in the form of Electronic Attestations of Attributes (EAA), hereafter referred to as 'attestations.' Apart from EAA, the European Digital Identity Regulation explicitly defines another category of data, called Person Identification Data (PID), see Section 5.2.

Each PID and attestation consists of the following key elements:

- A set of **attributes**, which provide information, typically about the subject of the attestation. A Relying Party will request one or more of these attributes to get the reliable information they need to provide some service to the User. The set of attributes that an attestation may contain is defined in an attestation scheme, see below.
- A set of **metadata**, meaning information about the attestation itself, such as its attestation type (PID, mDL, diploma, etc.), its Attestation Provider, and its administrative validity period, if applicable. This kind of metadata is also defined in an attestation

scheme. In addition, metadata also includes information that is necessary to ensure the security of the attestation. This includes at least its technical validity period. For PIDs and device-bound attestations, it also includes a public key of the PID or attestation, which a Relying Party will use to verify that the PID or attestation was not copied, see Section 6.6.3.8. It may also include information allowing the Relying Party to verify that the PID or attestation was not revoked, see Section 6.6.3.7.

- A **proof**, which ensures the integrity, authenticity, and support of selective disclosure of the attestation. The format of the proof complies with the proof mechanism specified for this type of attestation, see below. The proof includes information that enables a Relying Party to verify the proof, for example an Attestation Provider certificate and a reference to a trust anchor that can be used to verify that certificate.

An **attestation scheme** defines the logical organisation of all mandatory and optional attributes within an attestation, as well as the format of each attribute, meaning its unique identifier, encoding, allowed values, and serialisation. In addition, an attestation scheme specifies some of the attestation metadata, such as its attestation type and information about its Attestation Provider, validity period, etc. Within the EUDI Wallet ecosystem, the attestation scheme for each attestation type may be specified by an Attestation Scheme Provider, next to an Attestation Rulebook; see Section 5.5.

A **proof mechanism** defines the method used to create the attestation proof. For example, a 'standard' digital signature is a proof ensuring integrity and authenticity, but not allowing selective disclosure. Proof mechanisms are specified in standards or technical specifications. The attestation formats listed in Section 5.4 either specify a proof mechanism that allows for selective disclosure, or leave it to other technical specifications to do so.

5.2 Attestation categories

5.2.1 Overview

Within the European Digital Identity Wallet ecosystem, the European Digital Identity Regulation distinguishes four legal categories of attestations:

- Person Identification Data (PID),
- Qualified Electronic Attestation of Attributes (QEAA),
- Electronic attestation of attributes issued by or on behalf of a public sector body responsible for an authentic source (PuB-EAA),

- Non-Qualified EAA.

The next subsections give more information about each of these categories. Please note that the differences between them are purely legal. For example, a diploma may be a QEAA or a non-qualified EAA, depending on whether it is issued by a qualified trust service provider (QTSP) or by an unqualified one. Similarly, an mDL may be issued as a PuB-EAA, a QEAA, or a non-qualified EAA, depending on the legal status of the party issuing mobile driving licences in each Member State. From a technical point of view, all PIDs, QEAAs, PuB-EAAs, and EAAs comply with one of the attestation formats listed in Section 5.4.

5.2.2 Person Identification Data (PID)

A PID is a set of data that is issued in accordance with Union or national law and that enables the establishment of the identity of a natural or legal person, or of a natural person representing another natural person or a legal person.

Besides the fact that the European Digital Identity Regulation defines the PID as a category of data that is legally distinct from Electronic Attestations of Attributes (EAA), another difference between PID and EAA is that the presence or absence of a valid PID determines whether a Wallet Unit is in the Operational or the Valid state, as discussed in Section 4.6.4.

As implied in that section, it is possible for a Wallet Unit to contain multiple PIDs. If the User has multiple nationalities, they may be able to receive a PID from multiple PID Providers in a single Wallet Unit. However, please note that a Wallet Provider is free to decide that its Wallet Unit does not support all PID Providers, and that, conversely, a PID Provider may decide that it does not support all Wallet Solutions; see Section 6.5.2.3. Note that the subject of all PIDs in the Wallet Unit will be the same person, namely the User of the Wallet Unit.

For more information, please refer to Section 3.4.

5.2.3 Qualified Electronic Attestation of Attributes (QEAA)

A QEAA is an electronic attestation of attributes which is issued by a qualified trust service provider (QTSP) and meets the requirements laid down in Annex V of the European Digital Identity Regulation. For more information, please refer to Section 3.6.

5.2.4 Electronic attestation of attributes issued by or on behalf of a public sector body responsible for an authentic source (PuB-EAA)

A PuB-EAA is an electronic attestation of attributes issued by a public sector body that is responsible for an authentic source or by a public sector body that is designated by the Member State to issue such attestations of attributes on behalf of the public sector bodies responsible for authentic sources in accordance with Article 45f and with Annex VII of the European Digital Identity Regulation.

For more information, please refer to Section 3.7.

5.2.5 Non-Qualified Electronic Attestation of Attributes (EAA)

A non-qualified EAA is an EAA which is not a QEAA or a PuB-EAA. For more information, please refer to Section 3.8.

5.3 Logical versus technical PIDs and attestations

When discussing PIDs and attestations, it is important to make a distinction between 'logical' and 'technical' PIDs and attestations. By a 'logical PID or attestation', this ARF means a PID or attestation as it will be understood, for instance, by a non-expert User. When such a User says they have a PID in their Wallet, what they mean is that they see their PID and its attributes in the UI of their Wallet Unit, and that they can present PID attributes to a Relying Party. They do not know about, or care about, the format of that PID or the proof mechanism used by it. In contrast, what this ARF calls a 'technical PID or attestation' is a specific data structure having a specific encoding and proof mechanism, as explained in Section 5.4.

Each technical PID or attestation that is present in a Wallet Unit corresponds to a logical PID or attestation of the User of that Wallet Unit. However, a single logical PID or attestation can (and will) correspond to multiple technical PIDs or attestations, which are present in the User's Wallet Unit either simultaneously or over time. For example, as explained in Section 7.4.3.5.2, a PID Provider may issue a batch of technical PIDs to a Wallet Unit, and then stipulate that the Wallet Unit must present a different technical PID each time when the User presents their logical PID. This eliminates the risk that a fraudulent Relying Party, possibly in collusion with other Relying Parties, tracks or traces the User by linking attestations based on their unique elements, such as public keys.

The difference between logical and technical PIDs and attestations is particularly important when discussing re-issuance of PIDs and attestations. For reasons of privacy and security, a technical PID or attestation has a technical validity period, which is usually rather short. That

means that during the lifetime of the associated logical PID or attestation, it will be necessary to regularly issue new technical PIDs or attestations. For more information about re-issuance, see Section 6.6.6.2.

Please note that when this ARF talks about PIDs or attestations, it means *technical* PIDs or attestations, unless explicitly mentioned otherwise.

5.4 Technical attestation formats and proof mechanisms

5.4.1 Overview

Feature	ISO/IEC 18013-5 / ISO/IEC 23220-2	SD-JWT VC	W3C VCDM v2.0
Data Format	CBOR (Binary)	JSON Web Token (JSON)	JSON-LD (Linked Data)
Proof Type	Embedded (Salted Hashes)	Embedded (Salted Hashes)	Detached or Embedded
Key Use Case	Proximity (e.g., mDL)	Remote (e.g., remote identification)	General (requires profiling)
Wallet Support	Mandatory	Mandatory	Optional

Section 5.1 listed a proof mechanism as one of the key elements needed to define a type of attestation. The proof mechanism for an attestation is closely related to the format of that attestation. Within the EUDI Wallet ecosystem, the following standardised formats for electronic attestations of attributes can be used:

- The format specified in ISO/IEC 18013-5 and generalised in ISO/IEC 23220-2,
- The format specified in 'SD-JWT-based Verifiable Credentials' SD-JWT VC,
- The format specified in 'W3C Verifiable Credentials Data Model v2.0' W3C VCDM v2.0.

The next subsections give more information about each of these formats and specifications, and explain where the different elements of an attestation, as explained in Section 5.1 are defined for that attestation format.

Within the EUDI Wallet ecosystem, Wallet Units will support the first two formats above. Support for the third format is optional and meant for non-qualified EAAs only. Topic 12 states

the detailed requirements regarding support by Wallet Units, PID Providers, and Attestation Providers for these formats and specifications.

5.4.2 ISO/IEC 18013-5 and ISO/IEC 23220-2

The ISO/IEC 18013-5 standard was originally developed as a standard for mobile driving licences (mDL) and mDL readers. In terms of this ARF, an mDL is a Wallet Unit containing an mDL attestation (as defined in the mDL Rulebook), while an mDL reader is a Relying Party requesting such an attestation.

ISO/IEC 18013-5 specifies:

- An attestation scheme containing all attributes and metadata for an mDL. The scheme specifies the semantics of these attributes and metadata, as well as their encoding in Concise Binary Object Representation (CBOR), see RFC 8949. The standard also specifies the use of namespaces to avoid collision of attribute identifiers.
- A proof mechanism ensuring the authenticity and integrity of a PID or attestation, while allowing selective disclosure of attributes.
- A mandatory security mechanism enabling device binding of PIDs and attestations, see Section 6.6.3.8,
- All other aspects necessary to securely request, present, and verify an mDL attestation in proximity flows, see Section 5.7.2.

Points to note about ISO/IEC 18013-5:

- the mDL attestation scheme (see first bullet above) is the only aspect of ISO/IEC 18013-5 that is specific for mDLs. All other aspects are generic and can be used for any other attestation type, including PIDs. This means that another ISO/IEC 18013-5-compliant attestation type can be created simply by specifying an appropriate attestation scheme using CBOR, and referring to ISO/IEC 18013-5 for all other details. Please refer to Chapter 3 of the PID Rulebook for an example. Within the EUDI Wallet ecosystem, such an attestation scheme is specified in an Attestation Rulebook, see Section 5.5. ISO/IEC 23220-2 specifies a generic set of attributes for use in different attestation types, and also specifies how these can be encoded in CBOR.
- An ISO/IEC standard for presenting mobile documents in general (not mDLs specifically) is in preparation and will become [ISO/IEC 23220-4]. This standard will generalise ISO/IEC 18013-5, in the sense that it will allow more options and communication flows. Once that standard is published, all references in this ARF to ISO/IEC 18013-5 may be

replaced by appropriate references to [ISO/IEC 23220-4]. However, at the moment [ISO/IEC 23220-4] is not finished yet and therefore cannot be referenced.
- Within the EUDI Wallet ecosystem, ISO/IEC 18013-5-compliant attestations are requested and presented in proximity using the transmission mechanism and protocol described in Section 5.7.2. For remote presentation, such attestations are requested and presented either using the transmission mechanism and protocol specified in ISO/IEC 18013-7, see Section 5.7.3, or using the ones described in OpenID4VP and HAIP, see Section 5.7.4.

5.4.3 SD-JWT VC

'SD-JWT-based Verifiable Credentials' SD-JWT VC specifies a data format and processing rules to express verifiable credentials (i.e., attestations). "SD-JWT" here stands for 'Selectively Disclosable JSON Web Token'. As that name suggests, SD-JWTs are a special form of JWTs RFC 7519 that are selectively disclosable. The mechanisms used to make them selectively disclosable is often described as using 'salted hashes', and is conceptually identical to the mechanism used for the same purpose in ISO/IEC 18013-5.

SD-JWT VC specifies the following aspects:

- The encoding to be used for attributes and metadata, namely JSON, as well as rules to prevent collisions of claim names,
- A proof mechanisms ensuring the authenticity and integrity of a PID or attestation, while allowing selective disclosure of attributes, see above.
- A security mechanism enabling device binding of PIDs and attestations, see Section 6.6.3.8. This mechanism is optional in SD-JWT VC.

In addition to these aspects, within the EUDI Wallet ecosystem,

- attestation schemes for specific SD-JWT VC-compliant attestation types will be specified in Attestation Rulebooks, see Section 5.5. Please refer to Chapter 4 of the PID Rulebook for an example.
- SD-JWT VC-compliant attestations will be requested and presented remotely using the protocol and transmission mechanism specified in OpenID4VP and HAIP, see Section 5.7.4. SD-JWT VC-compliant attestations cannot be used in proximity presentations.

Since SD-JWT VC contains a number of options, the use of the profile for SD-JWT VCs specified in HAIP is necessary to ensure interoperability between Wallet Units and Relying Parties.

5.4.4 W3C Verifiable Credentials

The W3C Verifiable Credentials Data Model W3C VCDM v2.0 defines a general data model, offering a high-level structure but leaving many technical aspects open for further definition, including:

- Security mechanisms
- Signature formats
- Transport protocols

Key features of W3C VCDM are:

- JSON-LD (Linked Data)-based: The use of JSON-LD ensures structured and interoperable data exchange, but introduces complexity.
- Extensible Framework: Allows different implementations but requires additional specifications.
- Security and Signature Formats: Not inherently defined — must be specified separately.

To implement W3C VCDM-based attestations, separate specifications are needed for security mechanisms and signatures, such as:

1. 'Securing Verifiable Credentials using JOSE and COSE' W3C VC-JOSE-COSE: Defines how to use one of the following to secure attestations in the VCDM model:
   - a JWT (see RFC 7519),
   - a SD-JWT (see the previous section), or
   - a CBOR Web Token (CWT, see RFC 8392).
2. 'Verifiable Credential Data Integrity' W3C VC Data Integrity: Provides a cryptographic proof format independent of JWT or CWT, relying on detached proofs (not embedded signatures) for better flexibility.

These mechanisms offer different trade-offs, allowing PID Providers or Attestation Providers and Relying Parties to choose the appropriate security model based on their privacy, interoperability, and trust requirements. In order to achieve interoperability, the specification of a profile standard making specific choices will be necessary.

In addition to these aspects, within the EUDI Wallet ecosystem,

- attestation schemes for specific W3C VCDM-compliant attestation types (if any) will be specified in Attestation Rulebooks, see Section 5.5.

- W3C VCDM-compliant attestations may be requested and presented remotely using the protocol and transmission mechanism specified in OpenID4VP and HAIP, see Section 5.7.4. However, this ARF does not currently require this, and for any W3C VCDM-compliant attestation, the applicable transport protocol must be defined in the corresponding Rulebook. W3C VCDM-compliant attestations cannot be used in proximity presentations using ISO/IEC 18013-5.

  Note: As the W3C VCDM format is used as the reference format for attestations in particular in the educational sector, Wallet Units may be required to support this format when the new profiles (created by ETSI) on the W3C VCDM format are available.

See chapters 3 and 4 of the Discussion Paper for Topic V for more considerations regarding the formats specified in SD-JWT VC and [W3C VCDM 2.0] and their interoperability within the EUDI Wallet ecosystem.

5.5 Attestation Rulebooks and Attestation schemes

5.5.1 Introduction

An **Attestation Scheme Provider** defines a type of attestation (e.g., PID, mDL, diploma) and publishes a **human-readable Attestation Rulebook** that explains what the attestation is and how it works: which attributes it contains, what each attribute means, how the attributes are encoded, how proofs are produced, and, where needed, how trust and presentation are handled. When the attestation is listed in the European Commission's **catalogue of attestation schemes** (the official index that lets ecosystem participants discover and reuse attestation types), the Attestation Scheme Provider also includes a **machine-readable attestation scheme**, so software can automatically build requests to Wallet Units and verify responses.

In short: the **Rulebook** is the documentation for people, the **scheme** is the specification for software, and the **catalogue** is where everyone finds them.

Section 5.1 listed an attestation scheme as a key element of any attestation type. This section introduces the **Attestation Rulebook**, which for each attestation type specifies:

- the **attestation scheme** and proof mechanisms;
- where required, the **trust mechanisms** for authentication and authorisation;

- the **unique identifiers, syntax and encoding, and semantics** of all attributes that may appear in the attestation;

- the **presentation protocol(s)** that relevant attestations must support.

The requirements for Rulebooks are defined in Topic 12.

5.5.2 Who defines Rulebooks and schemes

Attestation Rulebooks are defined by **Attestation Scheme Providers** (see Section 3.15). This role can be held by various parties:

- **The European Commission**, in consultation with EDICG, currently maintains the PID Rulebook and the mDL Rulebook.
- **Public administrations or sectoral or cross-border organisations** will create EU-wide or sectoral Attestation Rulebooks. These organisations represent relevant stakeholders, to avoid duplicative Rulebooks (e.g., for diplomas) and unnecessary syntax or semantics divergence. Selection of the responsible organisation for a particular type of attestation is out of scope for this document.
- **Individual Attestation Providers** can create Provider-specific Rulebooks as add-ons to a EU-wide or sectoral Rulebook, when they must include **domestic or provider-specific attributes** not covered by the EU-wide or sectoral Rulebook (see Topic 12).
- **Single organisations** may write Attestation Rulebooks for attestations intended solely for internal use.

5.5.3 Publication in the catalogue

An Attestation Scheme Provider may publish a new attestation in the **catalogue of attestation schemes** to enable discovery by Relying Parties and other actors (see Section 5.6.3). When doing so, the provider **also supplies the machine-readable attestation scheme** in accordance with Technical Specification 11.

5.6 Catalogue of attributes and catalogue of attestation schemes

5.6.1 Introduction

Article 45e(2) of Regulation (EU) 2024/1183 empowers the Commission to establish **specifications and procedures** for: (i) the **catalogue of attributes**, (ii) the **catalogue of attestation schemes**, and (iii) **verification procedures** for qualified electronic attestations of attributes.

The objective of this provision is to reach a high level of interoperability:

- **Technical interoperability** through common standards, protocols, and technical specifications enabling issuance, presentation, and processing of attestations (see Sections 5.4 and 5.7).
- **Semantic interoperability** through clear definitions of attestation contents, i.e., which attributes exist for each attestation type and their identifiers, syntax, and semantics (see Section 5.5).

To support discovery and re-use across the EUDI Wallet ecosystem, two Commission-run catalogues are defined:

- a **Catalogue of attributes** that draws on authentic public-sector sources (see Section 5.6.2); and
- a **Catalogue of attestation schemes** for QEAAs, PuB-EAAs, and EAAs (see Section 5.6.3).

5.6.2 Catalogue of attributes

The catalogue of attributes is exclusively intended for use by QTSPs issuing QEAAs, and enables them to find the access point of the Authentic Source responsible for a given attribute, at which the QTSP can verify the value of that attribute for a given User. This verification is discussed in Topic 42 in Annex 2.

See Topic 25 and Commission Implementing Regulation 2025/1569, particularly Article 7, for the high-level requirements for the catalogue of attributes.

For more details, see also the Discussion Paper on Topic O. Detailed interface specifications for registering and managing attributes in the catalogue and for querying the catalogue can be found in Technical Specification 11.

5.6.3 Catalogue of attestation schemes

The catalogue of attestation schemes is intended for use by Relying Parties, Attestation Providers, and other actors in the EUDI Wallet ecosystem. It enables them to discover which types of attestations already exist within the ecosystem, and to understand the identifiers, syntax, and semantics of all attributes within each type of attestation.

This section defines the following principles for the catalogue of attestation schemes:

- Attestation schemes are machine-readable, and each attestation scheme published in the catalogue refers to the corresponding human-readable Attestation Rulebook.
- Attestation schemes for QEAAs and PuB-EAAs used within the EUDI Wallet ecosystem may be registered and published in the catalogue of attestation schemes, but this is not mandatory.
- The catalogue of attestation schemes may also include attestation schemes for non-qualified EAAs. Registration and publication of non-qualified EEAs is not mandatory.
- The Commission will take measures to establish and maintain the catalogue of attestation schemes.
- The catalogue of attestation schemes will be publicly accessible.
- Registration of attestation scheme in the catalogue does not create any obligation for acceptance of the relevant type of attestation by any actor in the EUDI Wallet ecosystem. Neither does it automatically imply cross-border recognition of the type of attestation.
- Where possible, existing tools created by Member States, the Commission and cross-border organisations, will be used to connect to the catalogue and to interact with its stakeholders. Also, mechanisms to add new and existing data sets to the catalogue will be implemented.

See Commission Implementing Regulation 2025/1569, particularly Article 8, for the high-level requirements for the catalogue of attestation schemes.

For more details, see also the Discussion Paper on Topic O. Detailed interface specifications for registering and managing attestation schemes in the catalogue and for querying the catalogue can be found in Technical Specification 11.

5.7 Protocols and transmission mechanisms for attestation presentation

5.7.1 Introduction

A protocol for attestation presentation consists of a series of messages that are exchanged between a Wallet Unit and a Relying Party Instance. A transmission mechanism specifies how a communication channel is established between these entities to enable them to exchange the protocol messages.

Within the EUDI Wallet ecosystem, the protocol and transmission mechanism specified in ISO/IEC 18013-5 is used for proximity attestation presentation flows. For remote attestation

presentation flows, Wallet Units and Relying Parties support the following protocols and transmission mechanisms:

- The protocol specified in OpenID4VP, combined with a transmission mechanism based on redirects and custom URI schemes,
- The protocol specified in OpenID4VP, combined with a transmission mechanism specified in W3C Digital Credentials API,
- The protocol specified in ISO/IEC 18013-7, combined with a transmission mechanism specified in W3C Digital Credentials API.
- Optionally, the protocol specified in ISO/IEC 18013-7, combined with a transmission mechanism based on redirects and custom URI schemes.

This section briefly describes these protocols. For high-level requirements, please refer to Topic 1. Also refer to ETSI TS 119 472-2.

5.7.2 Proximity attestation presentation using ISO/IEC 18013-5

ISO/IEC 18013-5 specifies the following aspects related to secure data exchange for attestation presentations:

1. Message structures and transaction flows allowing a Wallet Unit and a Relying Party to request and present attestations.
2. Proximity interface specifications, allowing a Wallet Unit and a Relying Party to set up a communication channel using QR code or NFC, and to subsequently communicate over BLE, NFC, or Wi-Fi Aware.
3. Security mechanisms ensuring
    - the confidentiality and authenticity of all data exchanged between a Wallet Unit and a Relying Party,
    - Relying Party authentication, see Section 6.6.3.2.

As already explained in Section 5.4.2, although ISO/IEC 18013-5 nominally specifies the mobile driving licence, all of the above aspects are generic and can be used for any type of attestation.

5.7.3 Remote attestation presentation using ISO/IEC 18013-7

Whereas ISO/IEC 18013-5 specifies proximity transaction flows only, ISO/IEC 18013-7 specifies how to transmit ISO/IEC 18013-5-compliant request and response messages in remote trans-

action flows. ISO/IEC 18013-7 can be used only to request and present attestations in ISO/IEC 18013-5-compliant format.

ISO/IEC 18013-7 specifies two transmission mechanisms for transporting presentation requests and responses between a Relying Party Instance and a Wallet Unit:

- The mechanism specified in Annex A is based on the use of a custom URI scheme.
- The mechanism specified in Annex C uses the W3C Digital Credentials API.

More information about custom URI schemes and the Digital Credentials API can be found in Section 4.4.3.

5.7.4 Remote attestation presentation using OpenID4VP and HAIP

The OpenID4VP standard defines message structures, transaction flows, and an HTTP-based interface specification for attestation presentations by Wallet Units to Relying Parties. OpenID4VP also specifies security mechanisms ensuring:

- the confidentiality and authenticity of all data exchanged between a Wallet Unit and a Relying Party,
- Relying Party authentication.

OpenID4VP is suitable only for remote presentation transaction flows. OpenID4VP can be used for presenting attestations in different formats, including especially the SD-JWT VC-compliant and ISO/IEC 18013-5-compliant formats used within the EUDI Wallet ecosystem.

Since OpenID4VP contains a number of options, the use of the profile for 'OpenID for Verifiable Presentations for IETF SD-JWT VC' specified in HAIP is necessary to ensure interoperability between Wallet Units and Relying Parties. HAIP specifies two transmission mechanisms for transporting presentation requests and responses between a Relying Party Instance and a Wallet Unit. The first uses redirects and is based on the use of a custom URI scheme. The second uses the W3C Digital Credentials API. More information about custom URI schemes and the Digital Credentials API can be found in Section 4.4.3.

5.7.5 Transactional data using ISO/IEC 18013-5 and OpenID4VP

In some use cases, a Relying Party must be able to include additional data in the attestation presentation request. Primary examples include strong customer authentication for payments, see Section 2.6.4, and the creation of qualified electronic signatures, see Section 2.4. In the case of strong customer authentication for payments, the Relying Party sends payment

information, such as the payment amount and the payee, to the Wallet Unit. In the case of electronic signatures, the Relying Party may send (a representation of) data to be signed to the Wallet Unit. In Topic 20, such data is called transactional data.

The Wallet Unit will process the transactional data in a use-case specific way, and, after consulting the User, will sign a (representation of the) transactional data to authenticate it. The Wallet Unit will then return the signed data in the presentation response, together with the presented attributes, if any.

Both ISO/IEC 18013-5 and OpenID4VP allow for sending, authenticating, and returning transactional data. In both protocols, the presentation request can be extended with use-case specific (proprietary) transactional data. The Wallet Unit can subsequently sign this data by including it in the device binding process, see Section 6.6.3.8. Therefore, no extensions of the presentation response are necessary to return the signed transactional data.

5.8 Protocols and transmission mechanisms for attestation issuance

A protocol for attestation issuance consists of a series of messages that are exchanged between a Wallet Unit and a PID Provider or Attestation Provider. A transmission mechanism specifies how a communication channel is established between these entities to enable them to exchange the protocol messages.

Within the EUDI Wallet ecosystem, the protocol and transmission mechanism specified in OpenID4VCI is used for PID and attestation issuance flows. The OpenID4VCI standard defines message structures, transaction flows, and an HTTP-based interface specification for attestation issuance, based on OAuth 2.0. It inherits many features of OAuth 2.0, such as the use of an Authorization Server to manage the authentication of Wallet Units (“clients”) to one or more Credential Issuers (“Resource Servers”), and the use of Authorization Codes and Access Tokens. It adds specific features such as a Credential Offer endpoint to inform Wallet Units about the type(s) of credential that a particular Credential Issuer offers. It also specifies security mechanisms ensuring:

- the confidentiality and authenticity of all data exchanged between a Wallet Unit and a PID Provider or Attestation Provider,
- Wallet Unit authentication,
- Transport of public keys to be included in attestations (credentials) from the Wallet Unit to the PID Provider or Attestation Provider.

Since OpenID4VCI contains a number of options, the use of the profile for 'OpenID for Verifiable Credential Issuance' specified in HAIP is necessary to ensure interoperability between Wallet Units and Relying Parties. Technical Specification 3 specifies additional EUDI Wallet ecosystem-specific mechanisms on top of these specifications, in particular regarding the use of Wallet Instance Attestations (WIA) and Key Attestations (KA).

Lastly, ETSI TS 119 472-3 also contains EUDI Wallet ecosystem-specific mechanisms applicable to PID and attestation issuance, especially with regards to

- the several methods for PID or attestation re-issuance explained in Section 6.6.6.2 and Section 7.4.3.5.2,
- EUDI Wallet ecosystem-specific Credential Issuer metadata, in particular access certificates and registration certificates.

  Note: In addition to supporting OpenID4VCI in combination with HAIP and ETSI TS 119 472-3, PID Providers are allowed to support other protocols for issuing PIDs to (national) Wallet Units, provided these protocols comply with all relevant requirements in the Implementing Acts and the standards referenced therein.. In many Member States, the PID Provider and the Wallet Provider are closely related, and can therefore bilaterally agree to support a different protocol for PID issuance.

6 Trust model

6.1 Scope

This chapter explains how trust works in the EUDI Wallet system, how it is established, maintained, validated, and managed. It describes the rules and assumptions that decide whether different parts of the system, like a wallet app, a user's device, or a service provider, can be trusted.

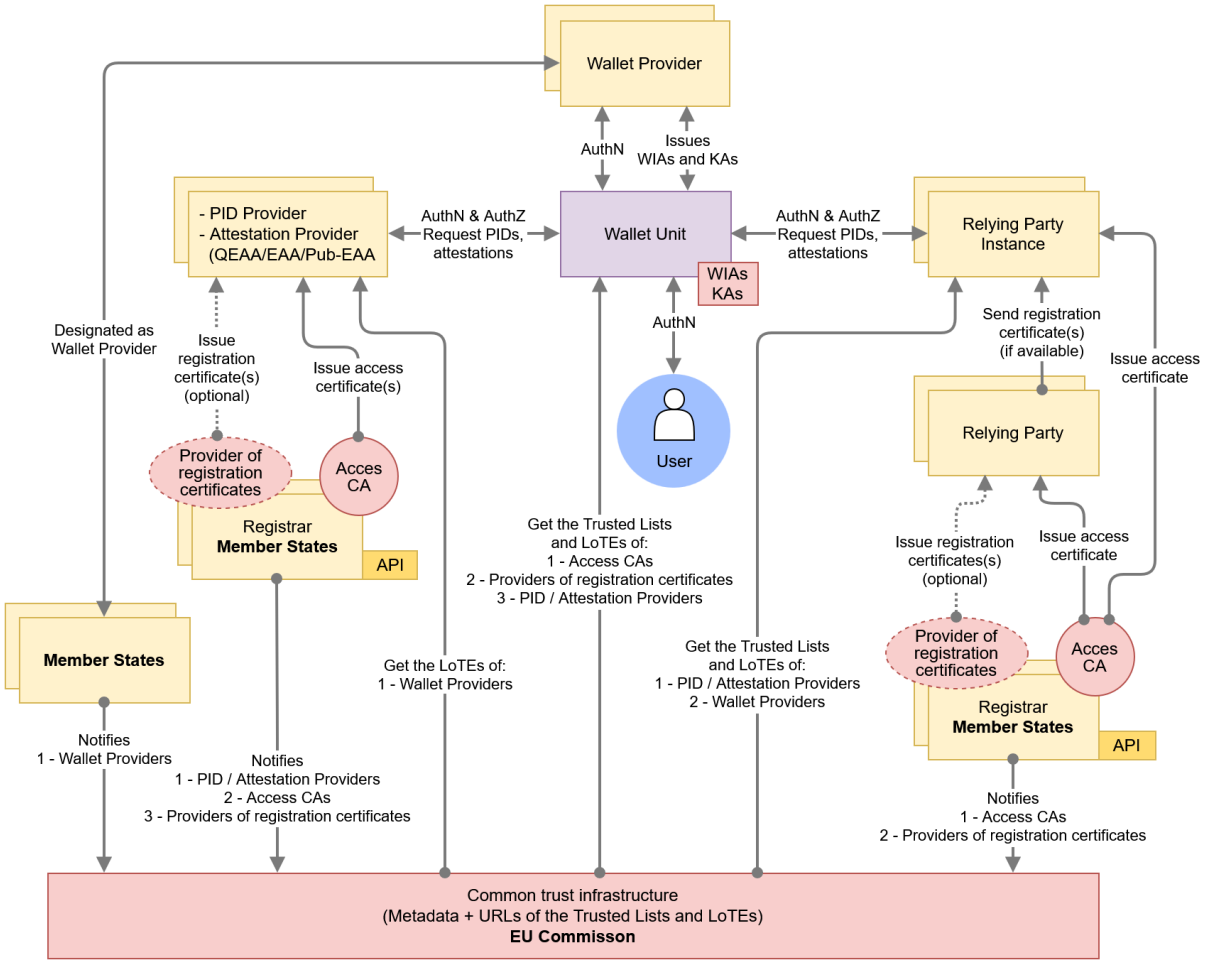


Figure 7: Figure 12

Figure 12 illustrates the main entities and their relationships in the trust model of the EUDI Wallet ecosystem.

At its core is the **Wallet Unit** (top middle, blue), which interacts with various entities throughout its lifecycle. The Wallet Unit lifecycle is described in Section 6.5 and consists of installation, activation, management, and uninstallation. Each Wallet Unit is a configuration of a **Wallet Solution**, comprising a **Wallet Instance**, a **WSCA/WSCD**, and one or more **keystores**, provided by a **Wallet Provider** or by the **User's device**. The User installs a Wallet Instance on their device, which leads to the activation of the Wallet Unit by the Wallet Provider. The Wallet Provider manages a Wallet Unit until it is uninstalled by the User. The Wallet Provider ensures that a valid Wallet Unit is in possession of at least one **Key Attestation (KA)** for each WSCA/WSCD or keystore, and at least one **Wallet Instance Attestation (WIA)**. A KA attests the properties of a

WSCA/WSCD or keystore and contains public keys for cryptographic binding. A WIA attests the integrity and revocation status of the Wallet Instance and describes the associated Wallet Solution. The Wallet Provider can revoke the Wallet Instance via the WIA revocation status to revoke the Wallet Unit. The Wallet Provider can revoke a WSCA/WSCD or keystore via the KA revocation status. See Section 6.5.

The Wallet Unit handles User **PIDs** and **attestations** (QEAAs, PuB-EAAs, and non-qualified EAAs). PIDs are issued by **PID Providers** and attestations by **Attestation Providers**, both positioned to the left of the Wallet Unit in Figure 12. Before interacting with a Wallet Unit, these Providers must be registered by a **Registrar**. Upon registration, they receive one or more **access certificates** from an **Access Certificate Authority** associated with the Registrar. They also obtain one or more **registration certificates** from an associated **Provider of registration certificates**. See Section 6.3.

After a Wallet Unit has received a PID or attestation, it can present **User attributes** to **Relying Party Instances** (right side of Figure 12). These instances are hardware/software setups enabling **Relying Parties** to interact with Wallet Units. Like a PID Provider or Attestation Providers, Relying Parties register with a **Registrar** in their Member State, and receive one or more **access certificates** for each of their Relying Party Instances. In addition, a Relying Party obtains one or more **registration certificates** from a Provider of registration certificates associated with the Registrar. This is discussed in Section 6.4.

Notes:

- This conceptual trust model may be implemented with slight variations across Member States, such as adopting one or multiple Certification Authorities or leveraging existing entities that already fulfil this role.
- For PIDs, qualified EAAs, and PuB-EAAs, interoperability is essential (Section 4.2.3). Interoperability is achieved by using a PKI following X.509 certificate standards (RFC 5280, RFC 3647) for signing PIDs, QEAAs, and PuB-EAAs. Non-qualified EAAs may adopt alternative trust models and verification mechanisms.
- The model supports both remote (see Section 4.4.2) and proximity (see Section 4.4.3 use cases.
- This version of the ARF does not yet include trust interactions for qualified electronic signatures or seals; see Topic 16.
- Besides the trust relationships described in this chapter, other trust relations are established as well. For instance, Users, PID Providers, Attestation Providers, and Relying Parties trust Conformity Assessment Bodies and Trusted List Providers (i.e., Member

States) or LoTE Providers (i.e., the Commission). This trust is primarily rooted in authority and in procedural measures, such as public oversight, published security and operational policies, and audits, rather than in technical measures. To verify that entities are indeed interacting with a trusted authority, standard technical measures suitable for the context will be used.

6.2 Trust throughout a Wallet Provider lifecycle

6.2.1 Wallet Provider lifecycle

Section 4.6.2 presented the lifecycle of a Wallet Provider:

1. The Wallet Provider is notified to the Commission by a Member State. This is discussed in Section 6.2.2.
2. Under specific conditions, a Member State may decide to change the status of a registered Wallet Provider to Invalid. This is discussed in Section 6.2.3.

6.2.2 Wallet Provider notification

Figure 12 depicts the Wallet Provider to the top of the Wallet Unit. To the left and below of this, the figure also shows that a Member State notifies the Wallet Provider and its (certified) Wallet Solution(s) to the European Commission. Note that Wallet Providers are not registered according to CIR 2025/848, like Relying Parties, PID Providers, and Attestation Providers are. Wallet Providers consequently do not receive access certificates or registration certificates. This is because there is no need for interoperability between Wallet Providers and Wallet Units; each Wallet Provider only needs to communicate with its own Wallet Units.

Instead, the Wallet Solution provided by the Wallet Provider is certified as described in Chapter 7, and then registered in accordance with CIR 2024/2980. In that process, information about the corresponding Wallet Provider, including its trust anchors, is notified by the Member State. If the notification process is successful, the Commission includes the trust anchors of the Wallet Provider in the Wallet Provider LoTE.

During issuance of a PID or attestation, a PID Provider or Attestation Provider can use these trust anchors for two purposes:

- to verify the authenticity of WIAs and KAs they obtain from Wallet Units, so they can be sure they are dealing with an authentic Wallet Unit from a trusted Wallet Provider.

- to verify the authenticity of Attestation Status Lists they use to verify the revocation status of received WIAs and KAs.

Note that the trust anchors for these two purposes may be the same. However, they also may be different, because a Wallet Provider can outsource the responsibility of providing revocation lists to a third party. However, if so, the Wallet Provider ensures that the relevant trust anchors are included in the Wallet Provider LoTE.

See Section 6.6.2.4 and Topic 9.

More details on the Wallet Provider notification process can be found in Topic 31.

6.2.3 Wallet Provider invalidation

The Member State may decide to notify the Commission that the Wallet Provider's status in the corresponding LoTE should be changed to Invalid. As a result of this status change, PID Providers and Attestation Providers will no longer trust the trust anchors of the Wallet Provider, which they need to verify the KAs and WIAs they receive from Wallet Units. They will therefore refuse to issue PIDs and attestations to any Wallet Unit provided by that Wallet Provider. The Member State can subsequently notify the Commission that the Wallet Provider's status should be changed to Valid again. The notification of the status change and its reflection in the Wallet Provider LoTE follow the procedures laid down in CIR 2024/2980.

As a result of being invalidated, the Wallet Provider will revoke its valid Wallet Units, see Section 6.5.4.2.

> Note that independently of the status of the Wallet Provider, its Wallet Solution may be suspended or withdrawn, see Section 4.6.3. In that case, the Wallet Provider revokes all associated Wallet Units if necessary, see Section 6.5.4.2. The result is the same: PID Providers and Attestation Providers will stop issuing PIDs and attestations to these Wallet Units.

6.3 Trust throughout a PID Provider or an Attestation Provider lifecycle

6.3.1 PID Provider or Attestation Provider lifecycle

Section 4.6.5 presented the lifecycle of a PID Provider or Attestation Provider:

1. A PID Provider or an Attestation Provider is registered by a Registrar in its Member State. This is discussed in Section 6.3.2.

2. Under specific conditions, the Registrar may decide to suspend or cancel registration of a registered PID Provider or Attestation Provider. This is discussed in Section 6.3.3.

6.3.2 PID Provider or Attestation Provider registration and notification

6.3.2.1 Introduction

Figure 12 depicts the PID Providers and Attestation Providers to the left of the Wallet Unit. To the left and below of this, the figure also shows that each PID Provider and Attestation Provider will register itself with a Registrar in its Member State. The Member State conditionally notifies a PID Provider or Attestation Provider to the European Commission:

- **PID Providers** are notified to the Commission.
- **QEAA Providers** are not notified to the Commission, except for establishing the Art. 22 Trusted List once a qualified status is granted.
- **PuB-EAA Providers** are notified to the Commission.
- **Non-qualified EAA Providers** are not notified to the Commission.

If the registration and notification processes are successful, at least the following happens:

- Data about the PID Provider or Attestation Provider is included in the registry of the relevant Registrar.
- The PID Provider or Attestation Provider receives one or more access certificates and one or more registration certificates.
- The trust anchors of the PID Provider or Attestation Provider are conditionally included in a Trusted List or LoTE.

These processes are discussed in the next subsections.

6.3.2.2 Data about the PID Provider or Attestation Provider is included in the registry

When a PID Provider or Attestation Provider is registered, the Registrar registers a set of data about the PID Provider or Attestation Provider in its register. The Registrar makes the contents of the register available to the general public, both in machine-readable and human-readable format. High-level requirements on the registration process can be found in Topic 27.

The data to be registered about a PID Provider, QEAA Provider, PuB-EAA Provider, or EAA Provider includes the PID or attestation type(s) that the Provider intends to issue to Wallet

Units. This enables Wallet Units and Relying Parties to verify that a given PID Provider or Attestation Provider registered its intent to issue a specific PID or attestation type. For example, a PuB-EAA Provider may have registered for issuing mDLs, but not to issue diplomas.

Regarding PID Providers or QEAA Providers, it may be argued that Wallet Units do not have to do this verification, since these are trusted parties. Nevertheless, it is beneficial if a Wallet Unit verifies if a PID Provider or QEAA Provider is registered for issuing a PID or a particular type of QEAA, prior to requesting the issuance of such a PID or QEAA. Doing this helps to prevent attempts to issue a PID or attestation while not being entitled to do so, either fraudulently or as a result of an error.

Note that the Registrar collects the following information only for the purpose of transparency and does not apply any pre-authorisation process on it:

- Contact information of the registering PID Provider or Attestation Provider,
- Description of the services of the PID Provider or Attestation Provider,
- Types of attestation registered.

In particular, registration of a specific attestation type for a specific PID Provider or Attestation Provider does not imply that the Registrar (or any other entity in the EUDI Wallet ecosystem) authorises the Provider to issue attestations of that type. If authorisation is necessary for issuing a specific attestation type, it takes place out of scope of the EUDI Wallet ecosystem.

6.3.2.3 PID Provider or Attestation Provider receives access certificate(s) and registration certificate(s)

When a PID Provider or Attestation Provider is registered by a Member State, an Access Certificate Authority (see Section 3.18) issues one or more access certificates to the PID Provider or to the Attestation Provider. A PID Provider or an Attestation Provider needs such a certificate to authenticate itself towards a Wallet Unit when issuing a PID or an attestation to it, as described in Section 6.6.2.2.

A PID Provider access certificate does not indicate that its subject is a PID Provider. Similarly, an Attestation Provider access certificate does not indicate that its subject is a QEAA Provider, a PuB-EAA Provider, or a non-qualified EAA Provider. Furthermore, the access certificate of a PID Provider or Attestation Provider does not contain the Provider's registration to issue attestations of a specific type, for instance an mDL or diploma. Such information is instead included in registration certificates. Upon registration, the PID Provider or Attestation Provider

receives one or more registration certificates from a Provider of registration certificates, see Section 3.19.

A Wallet Unit can use the information in the registration certificate to verify that an Attestation Provider it is contacting to issue a specific type of attestation is in fact registered for that type of attestation. The information in a registration certificate is also available in human-readable and machine-readable format via the Registrar's online service. The API and interfaces for that are specified in Technical Specification 5.

The PID Provider or Attestation Provider includes an access certificate and a registration certificate in its Credential Issuer metadata, specified per OpenID4VCI and ETSI TS 119 472-3, to make them available to Wallet Units.

Note that an Attestation Provider may simultaneously be a Relying Party, for instance in case it intends to request data from the User's PID during issuance of an attestation. Such an Attestation Provider would then register both as a Relying Party (which is called a Service Provider in Technical Specification 5) and as a QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider. In that case, the registration certificate(s) issued to the Attestation Provider will include both roles. Registration certificates for Relying Parties are discussed in Section 6.4.2.

See Sections 6.6.2.2 and 6.6.2.3 to learn more about how Wallet Units use a PID Provider's or Attestation Provider's access certificates and registration certificates.

6.3.2.4 PID Provider or Attestation Provider trust anchors are conditionally included in a Trusted List or LoTE

For a PID Provider or a PuB-EAA Provider, successful registration and notification also means that the Provider is notified to the European Commission and that its trust anchors are included in the respective LoTE by the Commission. The trust anchors of a QEAA Provider are included in a Trusted List once it gets the qualified status.

Relying Parties can use these trust anchors for two purposes:

- to verify the authenticity of PIDs, QEAAs, and PuB-EAAs they obtain from Wallet Units.
- to verify the authenticity of Attestation Status Lists or Attestation Revocation Lists they use to verify the revocation status of received PIDs, QEAAs, and PuB-EAAs, if any.

Note that the trust anchors for these two purposes may be the same. However, they also may be different, because a PID Provider or Attestation Provider can outsource the responsibility

of providing revocation lists to a third party. However, if so, the PID Provider or Attestation Provider ensures that the relevant trust anchors are included in the relevant Trusted List or LoTE.

Non-qualified EAA Providers are not notified by a Member State and their trust anchors are not included in a LoTE by the Commission. However, if a Relying Party requests a non-qualified EAA from a Wallet Instance, it must know how to obtain the trust anchor it needs to verify the signature over that EAA. To help with this, Topic 12 recommends that the applicable Rulebook specifies the mechanisms enabling this. This mechanism may be a LoTE complying with ETSI TS 119 602. However, other methods may be used as well, and even if such a LoTE exists, it does not have to comply with the requirements in Topic 31.

High-level requirements on the PID Provider or Attestation Provider notification process, as well as on the information registered and published in the respective Trusted List or LoTE, can be found in Topic 31.

6.3.3 Suspension or cancellation of the registration of a PID Provider or Attestation Provider

Under specific conditions, a Registrar may decide to suspend or cancel the registration of a PID Provider or Attestation Provider. The conditions for this will be specified by each Registrar.

Suspension or cancellation implies that the PID Provider's or Attestation Provider's access certificates are revoked. As a result, the PID Provider or Attestation Provider will no longer be able to issue PIDs or attestations to Wallet Units.

For a PID Provider, QEAA Provider, or PuB-EAA Provider, suspension or cancellation also implies that its status in the respective Trusted List or LoTE will be changed to Invalid. As a result, Relying Parties will no longer trust PIDs or attestations issued by that Provider. For non-qualified EAA Providers, the applicable Rulebook (see Topic 12) may define similar mechanisms ensuring that Relying Parties will no longer trust the trust anchors of EAA Providers of which the registration was suspended or cancelled.

When a Registrar suspends or cancels the registration of a PID Provider or Attestation Provider, the PID Provider or Attestation Provider revokes all of their PIDs or attestations as described in Section 6.6.6.4.

6.4 Trust throughout a Relying Party lifecycle

6.4.1 Relying Party lifecycle

Section 4.6.7 presented the lifecycle of a Relying Party:

1. A Relying Party is registered by a Registrar in the Member State where it resides. Relying Party registration is discussed in Section 6.4.2.
2. Under specific conditions, a Registrar may decide to suspend or cancel the registration of a Relying Party. This is discussed in Section 6.4.3.

6.4.2 Relying Party registration

Figure 12 depicts the Relying Party Instance to the right of the Wallet Unit. A Relying Party Instance is a combination of hardware and software used by a Relying Party to interact with a Wallet Unit. A Relying Party can operate multiple Relying Party Instances. This will happen especially in case the interactions with the Wallet Unit take place in proximity; for instance, a border control agency at an airport employing multiple lines (each operated by an agency employee) where arriving passengers can present their PID. However, a single Relying Party operating multiple Relying Party Instances can also happen in a remote context, for example if there is an operational system (including a remote Relying Party Instance) next to a fallback system used for business continuity purposes. A Relying Party may also use multiple remote Relying Party Instances for load distribution.

Figure 12 also shows the Relying Party. Below that, it shows that each Relying Party will register itself with a Registrar in its Member State. If the registration process is successful, the Registrar includes the Relying Party in its public registry.

A Relying Party may register in the context of several services, having different intended uses. Each intended use will require a different set of attributes to be obtained from a Wallet Unit. As a result, a single Relying Party may register multiple times and may be issued more than one registration certificate.

Note that the Registrar collects the following information only for the purpose of transparency and does not apply any pre-authorisation process on it:

- Contact information of the registering Relying Party,
- Description of the services of the Relying Party,
- Attributes registered for each intended use,
- Description of each intended use.

In particular, registration of a specific set of attributes for a specific intended use of a specific Relying Party does not imply that the Registrar (or any other entity in the EUDI Wallet ecosystem) authorises the Provider to request those attributes for that intended use. If authorisation is necessary for requesting specific attributes, it takes place out of scope of the EUDI Wallet ecosystem.

As a result of successful registration,

- a Provider of registration certificates (see Section 3.19) associated with the Registrar issues one or more registration certificates to the Relying Party. The purpose of the registration certificate is described in Section 6.6.3.3. The Provider of registration certificates complies with the requirements in CIR 2025/848, including those for the associated policy and practice statement in Annex V. Issuance of registration certificates takes places in an automated manner and without undue delay.
- an Access Certificate Authority (see Section 3.18) associated with the Registrar issues an access certificate to each Relying Party Instance of the Relying Party. A Relying Party Instance needs such a certificate to authenticate itself towards Wallet Units when requesting the presentation of attributes, as described in Section 6.6.3.2. Issuing access certificates to a registered Relying Party is mandatory.

See Sections 6.6.3.2 and 6.6.3.3 to learn more about how Wallet Units use a Relying Party's access certificates and registration certificates.

High-level requirements on the Relying Party registration process can be found in Topic 27.

6.4.3 Relying Party suspension or cancellation

Under specific conditions, a Registrar may decide to suspend or cancel the registration of a registered Relying Party. The conditions for this will be specified by each Registrar.

Suspension or cancellation involves revocation of all valid access certificates of the Relying Party by the relevant Access CA, such that the Relying Party is no longer able to interact with Wallet Units. It also implies that all of the Relying Party's registration certificates are revoked. The Provider of registration certificates publishes revocation information (in the form of a status list) in accordance with ETSI TS 119 475.

6.5 Trust throughout a Wallet Unit lifecycle

6.5.1 Wallet Unit lifecycle

Section 4.6.4 above presented the lifecycle of a Wallet Unit:

1. The Wallet Instance that is part of the Wallet Unit is installed on a device by a User. The required trust relationships for installation are discussed in Section 6.5.2 below.
2. Next, the Wallet Unit is activated by the Wallet Provider and the User and becomes operational. The goals and required trust relationships for activation are discussed in Section 6.5.3.
3. Once in the **Operational** or **Valid** state, the Wallet Unit is managed by the User and the Wallet Provider. This management includes at least revoking the Wallet Unit when necessary. This is discussed in Section 6.5.4. Management will also include regular updates of the Wallet Instance application to ensure its continued security and functionality. However, this is not further defined in this chapter.
4. The User may uninstall the Wallet Instance; see Section 6.5.5.

6.5.2 Wallet Instance installation

6.5.2.1 Required trust relationships

Note: This section assumes that the Wallet Instance is an app installed on the User's device. As explained in Section 4.3.2, a Wallet Instance can also be implemented as a web application. In that case, installation of the app is not necessary. Instead, the User will create an account at the Wallet Provider, see Section 6.5.3.6, and all attestations and other data in the Wallet Instance will be associated with that account. The descriptions in this section and the associated requirements in Topic 40, section A, do no apply to web wallets.

The lifecycle of a Wallet Unit starts when a User decides to install a Wallet Instance application on their device. This application in an instance of a Wallet Solution, which is provided to the User by a Wallet Provider.

When downloading and installing the Wallet Instance, the following trust relationships are established:

1. On behalf of the User, the OS of the User's device and the relevant app store verify that the Wallet Instance (i.e., the application the User is installing) is genuine and authentic and does not contain any malware or other threats.
2. The User verifies that they can obtain the PID(s) they need in an instance of this Wallet Solution. If the relevant PID Provider does not support the Wallet Solution, the User

will not be able to use the Wallet Unit for obtaining those PID(s).

The next two sections discuss these trust relationships. For high-level requirements regarding Wallet Instance installation, see Topic 40, section A.

6.5.2.2 Wallet Solution authenticity is verified

To ensure that the User can trust the Wallet Solution, Wallet Providers preferably make their certified Wallet Solutions available for installation via the official app store of the relevant operating system (e.g., Android, iOS). This allows the operating system of the device to perform relevant checks regarding the authenticity of the app. It also allows Users to use the same well-known channel for obtaining a Wallet Instance as they use for obtaining other apps. Finally, it avoids a situation where a User must allow side-loading of apps, which would increase the risk of unintentionally installing malicious apps.

If a Wallet Provider makes its Wallet Solution available for installation through other means than the official OS app store, it implements a mechanism allowing the User to verify the authenticity of the Wallet Unit. Moreover, the Wallet Provider provides clear instructions to the User on how to install the Wallet Unit, including:

- instructions on how to verify the authenticity of the Wallet Instance to be installed. This can be done, for example, by comparing the hash value of the application downloaded by the User with a hash value published by the Wallet Provider.
- instructions on bypassing of any operating system limitations on side-loading of apps, if applicable, and ensuring that these limitations are restored after the Wallet Instance has been installed.

6.5.2.3 User validates that Wallet Solution is usable with relevant PID

A User installs a Wallet Unit because they want to obtain and use one or more PIDs. However, PID Providers are not required to support all Wallet Solutions in the EUDI Wallet ecosystem. 'Support' here means that the PID Provider is willing to issue a PID to an instance of a given Wallet Solution on request of the User. Instead, a PID Provider may choose to support only a single Wallet Solution or a limited number of Wallet Solutions. Therefore, each PID Provider will publish a list of Wallet Solutions that they support, such that a User that wants to request a PID from that PID Provider knows which Wallet Unit they should install. This list could be published, for example, on the PID Provider's website.

Conversely, a Wallet Solution is not required to support all PID Providers, where 'support' means that it is able to request the issuance of a PID from a PID Provider. Each Wallet Provider will, prior to or during installation of a Wallet Instance, let the User know which PID Providers are supported by this Wallet Solution.

For QEAAs, PuB-EAAs, and non-qualified EAAs, the situation is different. Providers of such attestations will support all Wallet Solutions and are not allowed to discriminate between them when processing a request for the issuance of an attestation. Conversely, a Wallet Solution supports all Attestation Providers, and cannot discriminate between different Attestation Providers when requesting the issuance of an attestation at the User's request.

6.5.3 Wallet Unit activation

6.5.3.1 Introduction

After installation of the Wallet Instance, the new Wallet Instance will contact the Wallet Provider to start the activation process. For successful Wallet Unit activation, the following trust relations are established:

1. The Wallet Instance authenticates the Wallet Provider, meaning that the instance is sure that it is dealing with the genuine Wallet Provider who provided it to the User.
2. The Wallet Provider authenticates the Wallet Instance. This means that the Wallet Provider is sure that the instance is indeed a true instance of their Wallet Solution, and not a fake app.

Both of these trust relationships are the responsibility of the Wallet Provider. The ARF does not specify how these trust relationships can be satisfied.

During the activation process, at least the following steps happen:

1. The Wallet Provider requests data about the User's device from the Wallet Instance.
2. The Wallet Provider requests the User to set up two User authentication mechanisms.
3. The Wallet Provider issues one or more Key Attestations (KA) to the Wallet Unit.
4. The Wallet Provider issues one or more Wallet Instance Attestations (WIA) to the Wallet Unit.
5. The Wallet Provider sets up a User account for the User.

These steps are described in the sections below. For high-level requirements regarding Wallet Unit activation, see Topic 40, section B.

6.5.3.2 Wallet Provider requests data about the User's device from the Wallet Instance

6.5.3.2.1 Data collection for WSCA/WSCD and keystore deployment

The Wallet Instance connects to the Wallet Provider to be activated. Then, the Wallet Provider requests data about the User's device from the Wallet Instance. This data includes the characteristics of the local WSCD(s) and keystores available to the device for securely storing cryptographic keys and data. The Wallet Provider needs this information to deploy a WSCA/WSCD and optionally one or more keystores in the Wallet Unit, and to be able to issue one or more Key Attestations for each WSCA/WSCD or keystore to the Wallet Unit, see Section 6.5.3.4.

Notes:

- As discussed in Section 4.5, a WSCD may be integrated directly within the User's device. Examples of this include an e-SIM, a UICC, an embedded Secure Element, or native secure hardware accessible via the device's OS. If so, the Wallet Instance will discover the presence of such a WSCD during activation and will communicate the characteristics of the WSCD to the Wallet Provider. In some cases, the Wallet Provider will subsequently deploy a WSCA to the WSCD to facilitate communication between the Wallet Instance and the WSCD.
- Sometimes, the User's device does not contain a local WSCD, or the local WSCD does not have the security posture necessary to enable the Wallet Unit to be an identity means at LoA High, or the Wallet Provider does not want to use a local WSCD. In such cases, the Wallet Provider ensures the Wallet Unit gets access to a remote HSM operated by the Wallet Provider.

6.5.3.2.2 Data collection for Wallet Solution maintenance

In addition, the need for Wallet Solution maintenance may require the Wallet Provider to monitor its operational Wallet Instances. It is customary for mobile application developers to collect limited bug and error reports at runtime for improvement purposes. Error logs collected are minimised and, as a rule, do not contain personal data of the User. Where the monitoring described below nevertheless collects data that may constitute personal data under Regulation (EU) 2016/679 (for example device identifiers or locale), the Wallet Provider ensures an appropriate legal basis and privacy safeguards for that processing. A list of possible data types to be collected, reasons for collection, and how the Wallet Instance monitoring occurs (frequency, mechanisms, does the collection require Wallet User's approval beyond standard app vendor practices) is collected in the following table:

Data type	Reason for monitoring (if applicable, regulation)	Monitoring frequency etc.
Runtime errors	Uncaught errors in production code	runtime and crash logs
UX and telemetry information	UX field analysis, may not be used to obtain behavioural data	runtime logs - *user consent preferred*
OS version and health data	OS vulnerabilities	At Wallet Unit activation or OS update/upgrade and at continuous security posture monitoring
Wallet SDK and SW library versions	Wallet Instance code vulnerabilities	At Wallet Unit roll out (as part of CI/CD process), at continuous security posture monitoring
User locale/localisation data	Catching localisation related errors	runtime and crash logs - *user consent preferred*
Wallet Instance version	Old version related vulnerabilities or errors	At Wallet Unit activation, at continuous security posture monitoring
Supported WSCA/WSCDs and keystores	Cryptography-related incompatibilities	At Wallet Unit activation, at continuous security posture monitoring
WSCx capabilities supported	Cryptography configuration for EUDI Wallet use cases	At Wallet Unit activation
Unique device identifier such as IDFV or persisted UUID (iOS) or AndroidID (Android)	Up-to-date list of Wallet Instance related device installations, potential malicious use (unrecognised identifier)	At Wallet Unit activation

Data type	Reason for monitoring (if applicable, regulation)	Monitoring frequency etc.
Sensor identifiers and patch levels	Up-to-date sensor hardware	At Wallet Unit activation, at continuous security posture monitoring
Hardware-level details on device	Identify known hardware-based problems or vulnerabilities	At Wallet Unit activation
BLE radio presence	Security of proximity use cases	At Wallet Unit activation
NFC support	Security of proximity use cases	At Wallet Unit activation

6.5.3.2.3 Data collection for fraud or risk signal monitoring

Although complete fraud or risk signal collection is not in scope of the ARF, Wallet Providers keep an active understanding of each individual Wallet Instance's security posture, provided this can be done in a privacy-preserving way. A list of information related to fraud or risk signals that is often collected in context of mobile devices, is presented in the table below, with an indication whether the data is collected by the Wallet Provider.

Data or tool type	Reason for security posture monitoring (if applicable, regulation)	Monitoring at Wallet Instance
Device OS	Detect potential OS vulnerabilities	OK - see previous table
Device type	Detect potential type-specific vulnerabilities	OK - see previous table
Behavioural data	Detect unusual transaction detection, including possible account takeovers (ATO)	Not OK (privacy preservation)

Data or tool type	Reason for security posture monitoring (if applicable, regulation)	Monitoring at Wallet Instance
Device fingerprinting	Flag logins from unfamiliar devices, ATO	Not relevant - Wallet Provider has list of devices with an active Wallet Instance
Geolocation (IP address)	Network-layer anomaly detection, ATO	Not OK (privacy preservation)
Geolocation (GNSS)	Geospatial anomaly detection, ATO	Not OK (privacy preservation)
Active phone call detection	Detect authorised push payment fraud / phishing / social engineering	Not OK (privacy preservation)
VPN detection	Detect attempted identity or location masking through VPN	Not OK
Incognito mode detection	Detect attempts at hiding malicious activity or multiple login attempts	Not relevant
Device rooting/jailbreaking detection	Detect compromised device security as a whole	OK
Emulator detection	Detect emulation of User device by fraudsters	OK
Malware detection	Identify and neutralise malicious software	OK

For high-level requirements on Wallet Solution maintenance and the collection of fraud and risk signals by Wallet Provider, see Topic 56.

6.5.3.3 Wallet Unit requests User to set up two User authentication mechanisms

6.5.3.3.1 Introduction

During Wallet Unit activation, the Wallet Unit ensures that the Users sets up two User authentication mechanisms. The first of these mechanisms is implemented by the OS of the User's device, optionally combined with a Wallet Instance-specific PIN, and will be used before any operation of the Wallet Unit. The second mechanism is implemented by the WSCA/WSCD and will be used additionally when a PID or an attestation bound to the WSCA/WSCD is issued, presented, or deleted.

These two mechanisms are described in the next two subsections. See also the requirements on User authentication in Topic 40, Section C.

6.5.3.3.2 OS-level User authentication before any operation

During Wallet Unit activation, the Wallet Instance forces the operating system of the User's device to activate a multi-factor User authentication mechanism, if this is not already active. One of the authentication factors for this mechanism is the possession of the device and the other is knowledge-based or inherence-based. The Wallet Instance ensures that the authentication mechanism has security policies that are adequate for any operation of the Wallet Unit, excluding the issuance or presentation of PIDs, KAs describing the WSCA/WSCD, and attestations bound to the WSCA/WSCD. As described in the next section, for these actions User authentication by the WSCA/WSCD is necessary.

Actions for which OS-level authentication is sufficient include generating and presenting pseudonyms, accessing the transaction log via the dashboard, data export and migration, requesting the erasure of personal data by a Relying Party, and reporting a Relying Party to a Data Protection Authority. It also includes issuing, presenting, and deleting of attestations that are either not device-bound or bound to a keystore rather than the WSCA/WSCD. This implies that it must be possible to unlock the keystore(s) available to the Wallet Unit using this User authentication mechanism.

The User can optionally decide to use a Wallet Instance-specific PIN in addition to the OS-level User authentication mechanism.

User authentication to the Wallet Unit using the OS-level mechanism (plus optional PIN) will take place whenever the User opens the Wallet Instance, before the Wallet Unit performs any operation. This is necessary to prevent anyone except the User from accessing the Wallet Unit and inspecting the User's attestations and attribute values, as this data is personal and might be sensitive.

6.5.3.3.3 WSCA/WSCD-level User authentication before cryptographic operations

An additional User authentication, performed by the WSCA/WSCD, happens when the Wallet

Unit performs any cryptographic operation involving cryptographic assets in the WSCA/WSCD. This will happen at least when:

- The User instructs the Wallet Unit to request the issuance of a new PID, see Section 6.6.2,
- The Wallet Unit asks the User for approval to present some attributes from a PID to a Relying Party, see Section 6.6.3.5,
- The User deletes a PID in their Wallet Unit, see Section 6.6.7.

In addition, if an Attestation Provider requested during issuance that the cryptographic assets of their attestation are stored and managed in the WSCA/WSCD, the WSCA/WSCD will also perform User authentication before such an attestation is issued, presented, or deleted.

Note that, as discussed in the first bullet in Section 6.6.3.9, these User authentication mechanisms can also play a role in ensuring User binding for PIDs or device-bound attestations. User binding allows a Relying Party to trust that the person presenting a PID or attestation is the User to whom the PID or the attestation was issued.

6.5.3.4 Wallet Provider issues one or more Key Attestations to the Wallet Unit

During the activation of a Wallet Unit, the Wallet Provider issues one or more Key Attestations (KA) to the Wallet Unit. A KA is a signed information object that has three main purposes:

- It describes the certification and properties of the WSCA/WSCD or a keystore that is part of the Wallet Unit. This allows a PID Provider or an Attestation Provider to verify that the WSCA/WSCD or keystore complies with the Provider's requirements and therefore is fit to protect the private keys for a PID or a device-bound attestation from the Provider.
- Moreover, a KA contains one or more public keys. The Wallet Provider attests that the private keys corresponding to these public keys are generated by and stored in the WSCA/WSCD or keystore described in the KA. During the issuance of a PID or a device-bound attestation (see Section 6.6.2.4), a PID Provider or Attestation Provider can use each of these public keys to bind a new PID or attestation to.
- Lastly, a KA contains a revocation reference allowing a PID Provider or an Attestation Provider to verify that the Wallet Provider did not revoke the WSCD or keystore described in the KA. The Wallet Provider selects either a type-shared index approach or a per-KA index approach for managing the revocation status of the WSCD or keystore; see Technical Specification 3. The revocation mechanisms for Wallet Units are described in Topic 38.

High-level requirements for KAs can be found in Topic 9. The detailed format of a KA, as well as the way in which it is used, is specified in Technical Specification 3.

A Wallet Unit does not send a KA to an Attestation Provider if the attestation it is requesting is not device-bound. For non-device-bound attestations, the Attestation Provider does not need to receive public keys to include in the attestations, and neither does it need information about the WSCA/WSCD or a keystore.

To ensure User privacy, the Wallet Unit presents KAs only to PID Providers and Attestation Providers, but not to Relying Parties. This is because PID Providers and Attestation Providers have a valid business reason to know these properties, whereas Relying Parties do not. Moreover, a Wallet Unit will present each KA only once. Apart from preventing linkability, this is also to prevent that the public keys in the KA are used in multiple PIDs or attestations.

Regarding the KA revocation maintenance period, an important requirement in CIR 2024/2977, Article 5, 4.(b) is that a PID Provider must revoke a PID when the Wallet Unit to which that PID was issued is revoked. Therefore, a PID Provider must be able to regularly check whether the Wallet Provider revoked the WSCD or keystore described in the KA the PID Provider received from the Wallet Unit during PID issuance, during the entire validity period of the PID. This implies that

- the technical validity period of a PID cannot exceed the end of the revocation maintenance period indicated in the KA received by the PID Provider during issuance. The same applies to the WIA; see Section 6.5.3.5. The Wallet Provider commits to maintaining the revocation status of the WSCD or keystore during the entire revocation maintenance period indicated in its KAs.
- a KA contains the information necessary to enable the PID Provider to check the revocation status of the WSCD or keystore. See also Section 6.6.2.5.

The responsibilities of the Wallet Provider regarding issuance of a KA are similar to those of a PID Provider or Attestation Provider regarding the issuance of a PID or an attestation. This means that after the initial issuance of KAs during activation, the Wallet Provider will manage the KAs and will issue new KAs to the Wallet Unit as needed, during the lifetime of the Wallet Unit.

6.5.3.5 Wallet Provider issues one or more WIAs to the Wallet Unit

During the activation of a Wallet Unit, the Wallet Provider also issues one or more Wallet Instance Attestations (WIA) to the Wallet Unit. Similar to KAs, WIAs are information objects

signed by the Wallet Provider, and they contain a public key. However, a WIA differs from a KA in a few aspects:

- A WIA contains information about the Wallet Instance, including the Wallet Solution name, version, and certification of the Wallet Solution. This allows PID Providers and Attestation Providers to verify that the Wallet Instance belongs to a trusted and certified Wallet Solution, as registered in the Wallet Provider Trusted List.
- A WIA carries a revocation reference for the Wallet Instance, enabling PID Providers and Attestation Providers to check whether the Wallet Instance has been revoked.
- A WIA has a short technical validity period (less than 24 hours), ensuring that it reflects a recent integrity check of the Wallet Instance. In addition, a WIA specifies a revocation maintenance period, which may be considerably longer than the technical validity period. The Wallet Provider commits to maintaining the revocation status of the Wallet Instance during this entire period, enabling PID Providers to verify the revocation status of the Wallet Instance throughout the lifetime of the PID.
- The private key corresponding to the public key in the WIA is managed by the Wallet Instance; it does not have to be managed by the WSCA/WSCD or a keystore.
- A Wallet Unit sends a WIA to a PID Provider or Attestation Provider for both device-bound and non-device-bound attestations.

Similar to KAs, the Wallet Unit presents WIAs only to PID Providers and Attestation Providers, but not to Relying Parties.

Technical Specification 3 contains more information and requirements on the WIA.

6.5.3.6 Wallet Provider sets up a User account for User

The User needs a User account at the Wallet Provider to ensure that they can request the revocation of their Wallet Unit in case of theft or loss. The Wallet Provider associates the Wallet Unit with the User account. The Wallet Provider registers one or more backend-based User authentication methods that the Wallet Provider will use to authenticate the User. Note that:

- The Wallet Provider does not need to know any real-world attributes of the User, unless this is deemed necessary for PID activation, see Section 6.6.2.7. Otherwise, the User can use a pseudonym to register, for example an e-mail address. If the Wallet Provider wants to request additional User attributes, for instance to be able to provide additional services, they are free to do so if the User consents.

- In any case, User details registered by the Wallet Provider will not be included in a KA or a WIA. They are strictly for use by the Wallet Provider only.
- If the User already has an account with the Wallet Provider, the Wallet Provider can ask the User to log in to that account, rather than create a new account. Such a situation will primarily occur when the User migrates to a new Wallet Unit, for example in case they are moving to a new device. See Section 6.5.4.3.

6.5.3.7 Wallet Provider ensures User can verify they are using a trusted, certified Wallet Solution

According to the European Digital Identity Regulation, the User needs to be provided with a means to verify that they are installing or (after activation) are indeed using a trusted, certified Wallet Solution. The solution specified in this ARF to comply with this requirement is a Trust Mark view in the User interface of the Wallet Instance. When the User invokes this Trust Mark, it:

- renders the official Trust Mark graphics and/or logo,
- shows an informational text about Wallet Solution certification, localised for the User's device language, and
- provides web links to a list of certified Wallet Solutions, as well as to a web page containing certification information of User's Wallet Solution.

The information in the third bullet is hosted and managed dynamically by the European Commission. The Technical Specification 1 on the EUDI Wallet Trust Mark concentrates on defining the exact technical contents and the provisioning process to enable the User interface view rendering at the Wallet Instance. Topic 19 sets the high-level requirements for the Trust Mark as part of the Wallet Unit dashboard functionality. Topic 40 specifies what is required regarding the Trust Mark upon Wallet Unit activation and maintenance. Finally, Article 14a of CIR 2024/2979 and the Annexes mentioned therein specify detailed requirements for the formatting of the Trust Mark.

6.5.4 Wallet Unit management

6.5.4.1 Introduction

Starting from Wallet Unit activation and until the Wallet Instance is uninstalled by the User, a Wallet Unit is managed by the User and the Wallet Provider. The Wallet Provider is responsible

at least to:

- update the Wallet Unit by installing new versions of the Wallet Solution on the User's device as necessary;
- update the KAs and WIAs in the Wallet Unit as necessary; see Sections 6.5.3.4 and 6.5.3.5.
- revoke the Wallet Unit when needed; see Section 6.5.4.2.
- ensure that the Wallet Provider cannot access the contents of the Wallet Unit, in particular to learn the value of any User attestations or attributes, as well as the contents of the transaction log kept by the Wallet Unit.
- support procedures for migrating the PIDs and attestations it contains to a different Wallet Solution. See Section 6.5.4.3

To allow Wallet Unit management, the following trust relations are established:

1. When contacting the Wallet Provider, for instance to request the revocation of the Wallet Unit, the User authenticates the Wallet Provider. This means the User is sure that they are visiting the website or the User portal of the genuine Wallet Provider who is responsible for the User's Wallet Unit, and not a spoofed website or portal. This risk can be partly mitigated by using standard mechanisms such as TLS server authentication. However, in addition the User will need to be vigilant as well, just as with any website on the internet.
2. When contacted by a User, the Wallet Provider authenticates the User. This means that the Wallet Provider is sure that the User is indeed the User that was associated with the Wallet Unit during activation. For this, the Wallet Provider uses the authentication methods established in the User's account during activation, see Section 6.5.3.
3. When the Wallet Unit and the Wallet Provider set up a communication channel, the Wallet Unit authenticates the Wallet Provider, meaning that the Wallet Unit is sure that it is dealing with the genuine Wallet Provider. Similarly, the Wallet Provider authenticates the Wallet Unit. This means that the Wallet Provider is sure that the EUDI Wallet Instance is indeed a true instance of their Wallet Solution, and not a fake app. This will be ensured by the Wallet Provider. The ARF does not specify how these trust relationships can be satisfied.
4. When contacted by a PID Provider to request Wallet Unit revocation, the Wallet Provider authenticates the PID Provider. Section 6.6.2.2 below describes how a Wallet Unit can do this during PID issuance; a Wallet Provider can use the same mechanism.

For high-level requirements regarding Wallet Instance management, see Topic 40, section C.

6.5.4.2 Wallet Unit revocation

The Wallet Provider will revoke the Wallet Unit at least in the following circumstances:

- If the User requests the Wallet Provider to revoke the Wallet Unit, for example in case of loss or theft of the User's device.
- If the Wallet Unit contains a PID, and the PID Provider requests the Wallet Provider to revoke the Wallet Unit because the natural person using the Wallet Unit has died. To identify the Wallet Unit that is to be revoked, the PID Provider uses a Wallet Instance identifier provided by the Wallet Unit in the WIA during PID issuance; see Topic 9. Note: This identifier is the URI and index to the Attestation Status List for WIAs; see Topic 7.
- If the security of the Wallet Unit is breached or compromised.
- If the Wallet Solution is suspended (optionally) or when it is withdrawn (mandatorily), see Section 4.6.3.
- If the Wallet Provider is invalidated by its Member State and (consequently) its status in the Wallet Provider LoTE is changed to Invalid. See Section 6.2.3

Regarding the detection of a security breach or compromise in an individual Wallet Unit, the Wallet Provider can use analysis mechanisms that allow continuous detection of changes in signals relevant to the security posture of the Wallet Instances it has deployed. These signals are discussed in Section 6.5.3.2.3. The Wallet Provider can potentially use a 4-level security posture framework as introduced in the table below.

Level	Posture status	Key indicators & checks	Wallet Provider policy response
Level 4	**Critical**	Confirmed Root/Jailbreak, Active Debugger/Emulator Detected, Private Key Compromised, Critical OS Vulnerability (unpatched) exploited, Wallet Instance integrity check failed (tampering detected), Use of a compromised WSCD-protected private key detected (**see also Note 1**).	Revoke Wallet Instance; revoke corresponding WSCD(s)/keystore(s). Force reinstallation of Wallet Instance on a vulnerability-free device before re-issuing KAs and WIAs.

Level	Posture status	Key indicators & checks	Wallet Provider policy response
Level 3	**High Risk**	High-risk, unpatched OS version detected, Failed biometric attempts exceeding high threshold, Unavailability of a local WSCA/WSCD due to repeated connection error or other errors.	Revoke Wallet Instance; revoke corresponding WSCD(s)/keystore(s). Require step-up authentication (e.g., PIN re-entry), or force re-activation of the Wallet Unit before re-issuing KAs and WIAs.
Level 2	**Moderate Risk**	Minor integrity checks failed (e.g., non-critical file modification), Wallet Instance running in background with high resource usage, Failed PIN attempts (low threshold).	**Allow use, but limit scope** (e.g., restrict high-value presentations), force User re-authentication after inactivity.
Level 1	**Low Risk**	Successful device attestation, Wallet Instance integrity check passed, Current OS patch level.	**Full functionality** allowed, including presentation of high-value attestations (PID/QEAA).

The Wallet Provider revokes a Wallet Unit by setting all indices of WIAs issued to the corresponding Wallet Instance in the relevant status list. In addition, depending on the cause, the Wallet Provider revokes a corresponding WSCD or keystore(s) by setting all indices of KAs describing that WSCA/WSCD or keystore in the relevant status list:

- If the Wallet Provider must revoke the entire Wallet Unit (for example by request of the User or a PID Provider, or because there is a security breach of the Wallet Instance or the OS of the User's device), then the Wallet Provider revokes the Wallet Instance.
- If there is a security breach of a (type of) WSCD, then the Wallet Provider revokes that WSCD. If only a single WSCD is breached, the Wallet Provider also revokes the Wallet Instance using it. If a type of WSCD is breached, the Wallet Provider also revokes all Wallet Instances using a WSCD of that type.

- If there is a security breach of a (type of) keystore, then the Wallet Provider revokes that keystore. The Wallet Provider also revokes the Wallet Instance(s) using that (type of) keystore, unless the Wallet Provider creates a risk analysis showing that not revoking these does not lead to unacceptable risks to the User, PID Providers and Attestation Providers, Relying Parties, or the Wallet Provider itself. If the Wallet Provider does not revoke the Wallet Instance(s), only the attestations bound to the revoked (type of) keystore will be impacted. Other functionalities of the Wallet Unit, including the presentation of a PID, will remain available to the User.

See Section 4.6.4 for the full state diagram of the Wallet Unit. See Section 6.6.2.5 and sections referenced there for explanations of how PID Providers, Attestation Providers, and Relying Parties deal with Wallet Unit revocation. See Topic 38 for high-level requirements on Wallet Unit revocation.

6.5.4.3 Migrating the PIDs and attestations in a Wallet Unit to a different Wallet Solution

Article 5a 4 (g) of the European Digital Identity Regulation ensures the User's rights to data portability. Data portability means that a User can migrate to a different Wallet Solution. The User installs an instance of the new Wallet Solution, and then wants to restore the PIDs and attestations in their existing Wallet Unit to their new Wallet Unit. This should be possible with as minimal an effort as possible, and independent of whether the User still has access to their existing Wallet Unit.

This section introduces a Migration Object in each Wallet Unit. This object is a list of PIDs and attestations contained in the Wallet Unit, together with the information needed to request (re-)issuance of that PID or attestation. In addition, the Migration Object also contains the transaction log kept by the Wallet Unit, see Section 6.6.3.13. The Migration Object does not contain any private keys of PIDs or device-bound attestations. In most security architectures for a Wallet Solution described in Section 4.5, this is impossible at least for PIDs, since the WSCA/WSCD that contains the PID private keys does not allow their extraction under any circumstances. An exception may be architectures in which PID private keys are managed in a remote HSM and the migration is to a new Wallet Unit of the same Wallet Provider. However, in such cases, restoring functionality of the PIDs in a new Wallet Unit does not necessitate that private keys are exported to another HSM. Rather, it implies the User must be able to authenticate towards the existing HSM from the new Wallet Unit, and be recognised as an existing User. For attestations bound to a keystore (rather than a WSCA/WSCD), the properties

of the keystore determine if it's possible to export the attestation private keys to a location of the User's choosing. Most keystores will not allow this.

The fact that the Migration Object does not contain private keys means that PIDs and device-bound attestations cannot be backed up and restored from the object in such a way that they are usable in a new Wallet Unit without involvement of the PID Provider or Attestation Provider. Instead, the User must ask the respective PID Provider(s) or Attestation Provider(s) to issue the PID(s) or device-bound attestation(s) existing on the User's old Wallet Unit once again to the new Wallet Unit. The only function of the Migration Object is to simplify this process by listing the PIDs and attestations present in the existing Wallet Unit, together with the information needed by the new Wallet Unit to start the issuance process. For PIDs and device-bound attestations, the Migration Object does not contain attribute values or attribute identifiers, as that data is considered sensitive and is not useful anyway because of the limitations explained above. Instead, the object contains a list of attestation types and the related Attestation Providers.

For a non-device-bound attestation, there are no private keys stored in a WSCA/WSCD or keystore and hence it is in principle possible to back up such an attestation and restore it in a different Wallet Unit without involvement of the Attestation Provider. For non-device-bound attestations, the Migration Object therefore either contains the same data as for device-bound attestations, or it contains all data including attribute identifiers.

The Migration Object is stored in such a way that its confidentiality is ensured and that it can be used only by the User.

See Topic 34 for high-level requirements regarding migration.

The migration functionality of a Wallet Unit also enables backup and restore. Backup and restore is needed in case the User has lost access to their current Wallet Unit, for example in case of loss, theft, or breakdown. It is also needed if the User wants to start using another Wallet Unit, for example because they have bought a new device, need to factory-reset their existing device, or want to migrate to another Wallet Solution. In all of these cases, the User wants to restore the PIDs and attestations in their existing Wallet Unit on their new Wallet Unit, with as minimal an effort as possible.

The European Digital Identity Regulation does not contain a requirement mandating backup and restore functionality in the Wallet. However, Wallet Providers will implement backup and restore functionality nevertheless, because it will be expected by Users. In fact, the requirements in Topic 34 also ensure the possibility of backup and restore.

6.5.5 Wallet Instance uninstallation

No trust relationships are required for Wallet Instance uninstallation; anybody able to access the device of the User will be able to do this.

If the User uninstalls the Wallet Instance while it still contains PID(s) or attestation(s), the corresponding private keys will remain present in the respective WSCA/WSCD or keystore. This is because deletion of these private keys would require the Wallet Unit to authenticate the User, which is impossible if the Wallet Unit is being deleted by the device OS.

To partly solve this challenge, the Wallet Unit enables the User to 'factory reset' the Wallet Unit, which causes the deletion of all attestations, the log, and all other personal data, settings, and configurations from the Wallet Unit. If the User resets the Wallet Unit, the Wallet Instance request the associated WSCA/WSCD and keystore(s) to delete all cryptographic assets related to the Wallet Unit and to all PIDs and device-bound attestations on the Wallet Unit, if the WSCA/WSCD and keystore(s) are connected to the User device. The User can use this option, for instance, in preparation to the planned uninstallation of the Wallet Instance.

Notes:

- The Wallet Unit does not necessarily inform the Wallet Provider about the factory reset.
- It may happen there is no connection to the WSCA/WSCD or to a keystore at the moment the User resets the Wallet Unit. For instance, in case the WSCA/WSCD is an external smart card and the User does not present that card to the User device. Another example occurs when the WSCA/WSCD is a remote HSM and the User device is offline at that moment. In such cases, the cryptographic assets will remain present in the WSCA/WSCD or in the keystore, even though they will never be used again. If needed, it is up to the Wallet Provider to define how the Wallet Unit should handle such situations. For example, an HSM manager could address such cases by deciding to delete cryptographic keys in the HSM that are too old or haven't been used for too long, while being aware of the risks in doing so.

If the User resets the Wallet Unit, the Wallet Unit also discloses the fact that it no longer stores any previously disclosed PID(s) or attestation(s) to the W3C Digital Credentials API framework.

6.6 Trust throughout a PID or an attestation lifecycle

6.6.1 PID or attestation lifecycle

Section 4.6.6 above presented the lifecycle of a PID or attestation within a Wallet Unit:

1. Using their Wallet Unit, the User requests the **issuance** of a logical PID or attestation from a PID Provider or an Attestation Provider. This results in the Wallet Unit requesting one or multiple technical PIDs or attestations from that Provider. The required trust relationships for issuance are discussed in Section 6.6.2 below.
2. Once one or more technical PIDs or attestations are issued into the Wallet Unit, the User can **present** attributes from it to the following entities:
    - First of all, to a Relying Party Instance. Presentation happens according to the User's decision and depending on successful authentication of the Relying Party. The required trust relationships for presenting PIDs and attestations, including User approval and Relying Party authentication, are discussed in Section 6.6.3.
    - Instead of presenting attributes to a Relying Party, a User can also present them to another User, meaning that their Wallet Unit is interacting with another Wallet Unit. This is discussed in Section 6.6.4.
    - Finally, the User can also present attributes to an intermediary, who interacts with the Wallet Unit on behalf of a Relying Party. Section 6.6.5 discusses how presentation to an intermediary is different from presentation to a 'normal' Relying Party.
3. The PID Provider or the Attestation Provider remains responsible for **management** of the logical PID or attestation over its lifetime. Management may include re-issuing the corresponding technical PIDs or attestations with the same or different attribute values. The Provider can also revoke the PID or the attestation, possibly based on a request of the User. The management of PIDs and attestations is discussed in Section 6.6.6.
4. Finally, Section 6.6.7 discusses what happens if a User decides to **delete** a logical PID or attestation from their Wallet Unit.

6.6.2 PID or attestation issuance

6.6.2.1 Required trust relationships

The lifecycle of a PID or an attestation starts when a User, using their Wallet Unit, requests a PID Provider or an Attestation Provider to issue the PID or an attestation to their Wallet Unit. The following trust relationships are established during issuance:

1. The Wallet Unit authenticates the PID Provider or Attestation Provider using the access certificate referred to in Section 6.3. This ensures that the User can trust that the PID or attestation they are about to receive, is issued by an authenticated PID Provider or Attestation Provider respectively. See Section 6.6.2.2 below describing how this will be done.
2. The Wallet Unit verifies the PID Provider's or Attestation Provider's entitlements and registered attestation types. This ensure that the Provider has registered itself as either a PID Provider, a QEAA Provider, a PuB-EAA Provider, or a non-qualified EAA Provider, and has also registered the type(s) of attestations it issues. See Section 6.6.2.3 for more information.
3. If the above verifications pass, the Wallet Units sends an authorization request to the PID Provider or Attestation Provider. Subsequently, the PID Provider or Attestation Provider authenticates the Wallet Unit, see Section 6.6.2.4 below.
4. The PID Provider or Attestation Provider verifies that the Wallet Provider did not revoke the Wallet Unit. This is described in Section 6.6.2.5.
5. If necessary, the PID Provider or Attestation Provider authenticates the User, meaning that the Provider is sure about the identity of the User. In most use cases, this is necessary to enable determination of the values of the attributes that the Provider will attest to. For instance, a PID Provider needs to authenticate the User to ensure it provides a PID containing the correct family name and date of birth. In some use cases User authentication is not necessary; for example, when a shop owner issues a voucher or a receipt to a customer, the shop owner does not need to know who the customer is. The method by which the PID Provider or Attestation Provider performs User identification and authentication is out of scope of the ARF, as these processes are specific to each PID Provider or Attestation Provider. However, for a PID, these processes will satisfy the requirements for Level of Assurance High in Commission Implementing Regulation (EU) 2015/1502. For a QEAA, the User identification process will satisfy the reference standards laid down in CIR 2025/1566 on verification of the identity and attributes of the person to whom a qualified certificate or qualified electronic attestation of attributes is to be issued. For other attestations, user authentication is performed on a security level commensurate with the required level of security for the attestation issued.
6. After the PID or attestation is issued to the Wallet Unit, the Wallet Unit verifies the authenticity of the PID or attestation; see Section 6.6.2.6.
7. The User will activate a PID before they can use it; see Section 6.6.2.7.
8. If the OpenID4VCI Credential Issuer metadata for an attestation contains an embedded

disclosure policy, the Wallet Unit retrieves the policy and stores it locally, so that it can apply the policy in case a Relying Party requests attributes from the attestation. See Section 6.6.2.8.

More detailed requirements for the issuance process of PIDs and attestations, for instance regarding the issuance protocol, are included in Topic 10.

6.6.2.2 Wallet Unit authenticates the PID Provider or Attestation Provider

To start the process of requesting a PID or an attestation, the User directs the Wallet Unit to contact the PID Provider or Attestation Provider at a service supply point. A service supply point is a system at which a Wallet Unit can start the process of requesting and obtaining a PID or attestation. The User may for example use the Wallet Unit to scan a QR code or tap an NFC tag to do so, or the Wallet Provider may configure each Wallet Unit with a pre-defined list of PID Providers and Attestation Providers, including the URLs of their service supply points and associated attestation type(s). Note that no centralised service discovery mechanism for PID or attestation issuance is foreseen.

Before requesting the issuance of a PID or an attestation, the Wallet Unit authenticates the PID Provider or the Attestation Provider. To do so, the Wallet Unit follows the same process as for authenticating a Relying Party, see Section 6.6.3.2, with the following differences:

- A PID Provider or Attestation Provider does not send it access certificate to the Wallet Unit in a request, but makes it available in its Credential Issuer metadata according to OpenID4VCI and ETSI TS 119 472-3.
- The PID Provider or Attestation Provider does not sign a request, but rather its Credential Issuer metadata.

The Wallet Unit verifies that the access certificate of the PID Provider or Attestation Provider is valid and authentic, and the signature over the metadata is valid. If this is not the case, the Wallet Unit warns the User that it could not verify the identity of the PID Provider or Attestation Provider, and does not request the issuance of a PID or attestation.

6.6.2.3 Wallet Unit verifies Provider's entitlements and registered attestation types

During registration, the PID Provider or Attestation Provider registered its entitlements, meaning whether it is a PID Provider, QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider; see Section 6.3.2. It also registered the type(s) of PID or attestation it intends to issue

to Wallet Units. A Provider of registration certificates listed this information in one or more registration certificate(s) and sent these to the PID Provider or Attestation Provider. Subsequently, the PID Provider or Attestation Provider distributed the registration certificate(s) to its service supply points. Note that it is up to the PID Provider or Attestation Provider to determine if all of its supply points need all of the registration certificates, or that some supply points are used only for a subset of the attestation type(s) that this Provider issues, and consequently only need the registration certificates describing those attestation type(s). Each service supply point includes it registration certificate in its Credential Issuer metadata, similar to its access certificate; see the previous section.

The Wallet Unit obtains the registration certificate from the Credential Issuer metadata and verifies it. The Wallet Unit verifies that:

- the registration certificate is present and well-formed,
- the signature over the registration certificate can be verified using a trust anchor from the LoTE of Providers of registration certificates,
- the registration certificate has not expired and is not revoked,
- the registration certificate contains the same PID Provider or Attestation Provider identifier and the same Service identifier as the access certificate contained in the same Credential Issuer metadata. If that is not the case, a fraudulent entity could be using a registration certificate that was issued to a genuine PID Provider or Attestation Provider.

If any of these checks fail, the Wallet Unit warns the User that it could not obtain or validate the information registered about the PID Provider or Attestation Provider, and does not request the issuance of a PID or attestation.

If all of the above checks pass, the Wallet Unit retrieves from the registration certificate the entitlements and the list of attestations registered by the PID Provider or Attestation Provider. The Wallet Unit verifies that the entitlement (i.e., PID Provider, QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider) matches with its expectations, for example based on the the type of PID or attestation it wants to receive. Next, the Wallet Unit verifies that the type of attestation it wants to receive is included in the list of attestation types in the registration certificate. If one of these verifications comes out negative, the Wallet Unit warns the User and does not request the issuance of a PID or attestation.

> Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

For more information, see Topic 44.

6.6.2.4 PID Provider or Attestation Provider validates the Wallet Unit

6.6.2.4.1 Verifies the authenticity of the Wallet Unit

As shown in Figure 12, a PID Provider or an Attestation Provider downloads the Wallet Provider LoTE from the location published by the Commission. Note that for PID Providers it is not mandatory to possess the trust anchors of all Wallet Providers in the ecosystem. This is because it is not mandatory for a PID Provider to accept all certified Wallet Solutions. Each PID Provider will choose which trust anchors they need to trust. This is different for Attestation Providers: they must accept all Wallet Solutions and hence must possess all Wallet Provider trust anchors.

Section 6.5.3 above described that a Wallet Provider issues KAs and WIAs to the Wallet Unit. When the Wallet Unit requests the issuance of a PID or an attestation, it sends a WIA, and in most cases also a KA, to the PID Provider or the Attestation Provider. The PID Provider or Attestation Provider verifies the signature over the WIA and the KA, using the Wallet Provider trust anchor obtained from the Trusted List. This proves that the Wallet Unit is authentic and is provided by a trusted Wallet Provider. For more details see Topic 9 and Technical Specification 3.

6.6.2.4.2 Optionally, validates the properties of the WSCA/WSCD or the keystore

A key attestation (KA) describes the certifications and the other relevant properties of the WSCA/WSCD or a keystore. Because the WSCA/WSCD contains the private keys of the PID, the security level of the WSCA/WSCD is a key determinant for reaching the overall Level of Assurance (LoA) High, as required for the PID in the Wallet Unit. PID Providers therefore may want to validate a KA describing the WSCA/WSCD to verify that the WSCA/WSCD indeed complies with the requirements for Level of Assurance High.

For other device-bound attestations, the security of the attestation private keys is similarly important for guaranteeing the overall security of the attestation. The Attestation Provider decides on the required level of security for the keystore and indicates this in the Credential Issuer metadata specified in OpenID4VCI. The Wallet Unit selects the WSCA/WSCD or a keystore that complies with the required level of security, and sends a KA describing this WSCA/WSCD or keystore to the Attestation Provider. The Attestation Provider can validate the KA to verify that the WSCA/WSCD or keystore indeed complies with its security requirements.

For non-device-bound attestations, the Wallet Unit does not send a key attestation to the Attestation Provider.

6.6.2.4.3 Verifies that key for new PID or device-bound attestation is protected by the WSCD or keystore

Knowing the properties of the WSCA/WSCD or keystore is not very useful if the PID Provider or Attestation Provider cannot be sure that the private key for their new PID or device-bound attestation is indeed protected by that WSCA/WSCD or keystore. To enable this, each KA contains one or more public keys. By including these keys into a KA, the Wallet Provider attests that all of the associated private keys are indeed generated by and stored in the WSCA/WSCD or keystore described in the KA. The PID Provider or Attestation Provider can use each of these keys to bind a new PID or attestation to.

Apart from verifying the authenticity of the KA, the PID Provider or Attestation Provider also verifies that the KA is bound to the context of the PID or attestation issuance process. In other words, that it was not copied and replayed by an attacker. OpenID4VCI and Technical Specification 3 describe two methods for doing so. In both methods, during the issuance process, the PID Provider or Attestation Provider sends a nonce to the Wallet Unit. Subsequently it verifies that either

- The key attestation contains this nonce, meaning that the Wallet Provider signed it during the issuance process, or
- The Wallet Unit signed this nonce using the private key corresponding to one of the public keys in the key attestation, thereby proving possession of that key.

6.6.2.5 PID Provider or Attestation Provider verifies that Wallet Unit is not revoked

Section 6.5.3.4 and Section 6.5.3.5 above described that a Wallet Provider issues Key Attestations (KA) and Wallet Instance Attestations (WIA) to the Wallet Unit. Both a KA and a WIA contain revocation information. During the lifetime of the Wallet Unit, the Wallet Provider regularly verifies that the security of the Wallet Unit is not breached or compromised. If the Wallet Unit is no longer secure, the Wallet Provider revokes the Wallet Instance and, if the breach involves a WSCA/WSCD or keystore, revokes the corresponding KAs. The WIA and KA thus allow PID Providers and Attestation Providers to verify that the Wallet Unit is not revoked.

CIR 2024/2977 requires that PID Providers must verify regularly, during the entire lifetime of the PID, whether the Wallet Instance has been revoked (using the revocation information in

the WIA received during PID issuance) and whether the WSCD or keystore has been revoked (using the revocation information in the KA received during PID issuance). If either the Wallet Instance or the WSCD or keystore has been revoked, the PID Provider must revoke the PID. This is possible because both the WIA and the KA have a revocation maintenance period, which is at least as long as the validity period of the PID. PID Providers also verify regularly whether the Wallet Provider has been suspended or cancelled in the associated LoTE. If any of these events happens, the PID Provider revokes the PID. Therefore, by verifying the revocation status of the PID, the Relying Party Instance implicitly verifies the revocation status of the Wallet Unit. See Technical Specification 3 for more information.

Attestation Providers can use the same mechanism as well, to provide the same assurance to Relying Parties, although this is not required by the CIR. See also Section 6.6.3.12.

Topic 38 describes Wallet Unit revocation in more detail.

Once it has done all verifications, the PID Provider or Attestation Provider will issue the PID or attestation to the Wallet Unit.

6.6.2.6 Wallet Unit verifies PID or attestation

After the Wallet Unit receives the PID or attestation, it will

- verify that the PID or attestation it received matches the request.
- verify the signature of the PID or attestation, using the appropriate trust anchor if available, in the same way as described for a Relying Party Instance in Section 6.6.3.6. Note that for a non-qualified attestation, the Wallet Unit may not be in possession of the necessary trust anchor.
- display the contents (i.e., attribute values) of the new PID or attestation to the User and request the User's approval for storing the new PID or attestation. When requesting approval, the Wallet Unit displays the contents of the PID or attestation to the User. The Wallet Unit also informs the User about the identity of the PID Provider or Attestation Provider, using the subject information from the PID Provider's or Attestation Provider's access certificate.

If any of these verifications fail, the Wallet Unit will delete the PID or attestation, and will inform the User that issuance was not successful. Otherwise, the Wallet Unit will store the PID or attestation and will inform the User that issuance was successful. The Wallet Unit will also disclose the fact that it contains the new PID or attestation to the W3C Digital Credentials API framework, see Section 4.4.3, unless the User has disabled such disclosure.

6.6.2.7 User activates the PID

Commission Implementing Regulation (EU) 2015/1502 requires that for an eID means on Level of Assurance High, an activation process is implemented to verify that the eID means was delivered only into the possession of the person to whom it belongs. In the context of the EUDI Wallet, this means that it must be verified that a PID is issued into the Wallet Unit of the PID subject. Note that activation is required only for PIDs, since the European Digital Identity Regulation only requires PIDs to be issued at LoA High.

PID Providers, in combination with Wallet Providers, have to ensure that the PID issuing process complies with this requirement, see also requirement ISSU_05 in Annex 2. During certification the responsible CAB decides whether the implemented process is indeed compliant.

The ARF does not specify a process or mechanism for PID activation. PID Providers and Wallet Providers are free to specify a suitable mechanism. Several options have been suggested, but others may be used as well:

1. Wallet Providers, PID Providers, and CABs could decide that no additional mechanism for PID activation is needed, if they conclude that existing mechanisms are sufficient to ensure that the new PID can only end up on the device used by the subject of the PID:
    - User authentication to the Wallet Unit that starts the request for PID issuance,
    - Mutual authentication and secure communication between the Wallet Unit and the PID Provider (as specified in OpenID4VCI), and
    - User authentication to the PID Provider as part of the PID issuance process, using an eID means on LoA High (or an eID means on LoA Substantial in conjunction with additional remote onboarding procedures, in accordance with article 5a.24 of the European Digital Identity Regulation).
2. Another option is to let the WSCA/WSCD perform identity matching during PID issuance. This would require that the Wallet Provider identifies the Wallet User and puts some identifying data, for instance User first and last name, in the WSCA/WSCD. Then, during PID issuance, the WSCA verifies that the data in the new PID match the data stored in the WSCA/WSCD.
3. A third option is to perform activation by using an activation code shared via a trusted channel. In this setup, the Wallet Provider would identify the Wallet User and store a random activation code in the WSCA/WSCD. The Wallet Provider would share the activation code with the relevant PID Provider, indicating the Wallet User's identity.

During PID issuance, the PID Provider would retrieve the correct activation code and send the code to the PID subject's known address. To activate the PID, the PID subject (who is also the Wallet User) enters the code in the Wallet Instance.

Note that options 2 and 3 introduce a need for the Wallet Provider to identify the Wallet User. As explained in Section 6.5.3.6, this is not needed for any other purpose, and any implications for the privacy of the User need to be assessed. Also, these options require additional functionality of the Wallet Instance and the WSCA/WSCD, which would probably mean that PID activation can be done only for specific combinations of a Wallet Provider and a PID Provider. However, as pointed out in Section 6.5.2.3, this is allowed.

6.6.2.8 Provisioning embedded disclosure policies

6.6.2.8.1 Introduction

During attestation issuance, an Attestation Provider can optionally create an embedded disclosure policy for the attestation. If so, the Attestation Provider will provide it to Wallet Units during attestation issuance, by including it in the Credential Issuer metadata (defined in OpenID4VCI) for that attestation. Such an embedded disclosure policy contains rules determining which (types of) Relying Parties are allowed by the Attestation Provider to receive the attestation.

Note that the European Digital Identity Regulation does not contain a requirement for PIDs to be able to contain an embedded disclosure policy, but only for QEAAs and PuB-EAAs.

For more information regarding embedded disclosure policies, please refer to the Discussion Paper for Topic D.

6.6.2.8.2 Types of embedded disclosure policies

Annex III of CIR 2024/2979 defines the following common embedded disclosure policies that must be supported:

1. 'No policy' indicating that no policy applies to the electronic attestations of attributes.
2. 'Authorised relying parties only policy', indicating that wallet users may only disclose electronic attestations of attributes to authenticated relying parties which are explicitly listed in the disclosure policies.
3. 'Specific root of trust' indicating that wallet users should only disclose the specific electronic attestation of attributes to authenticated wallet-relying parties with wallet-

relying party access certificates derived from a specific root (or list of specific roots) or intermediate certificate(s).

The first of these policies is the default and will be applied if the Attestation Provider does not provide an embedded disclosure policy for an attestation.

For expressing conditions on Relying Parties, an embedded disclosure policy will refer to information included in the registration certificate provided to the Wallet Unit by the Relying Party. Note that registration certificates are signed and hence the information they contain is authenticated. Moreover, each registration certificate is bound to the access certificate used by the Relying Party to authenticate itself towards the Wallet Unit. Therefore, the Wallet Unit can trust that the information in the registration certificate applies to the Relying Party that sends the presentation request.

Wallet Units will provide support for at least policies 2. and 3. above. Note that these policies apply on the level of attestations, not individual attributes.

6.6.2.8.3 Distributing embedded disclosure policies

An Attestation Provider will provide an embedded disclosure policy, if any, in the Credential Issuer metadata specified in OpenID4VCI. This does not require modifications to the attestation format. Embedded disclosure policies will be integrated directly into the metadata, rather than being "linked" using a URL and stored by the Attestation Provider. ETSI TS 119 472-3 specifies how these policies are expressed and how an Attestation Provider includes them in the Credential Issuer metadata.

The approach ensures that the Wallet Unit is not required to communicate with the Attestation Provider in order to be able to obtain and evaluate a policy for an attestation requested by a Relying Party. Instead, during issuance of an attestation, the Wallet Unit retrieves any relevant disclosure policy from the Credential Issuer metadata and stores it locally. A consequence of this approach is that an Attestation Provider will revoke an attestation if a relevant embedded disclosure policy is updated.

6.6.2.9 Batch issuance

Batch issuance means that instead of issuing a single technical PID or attestation to a Wallet Unit, a PID Provider or Attestation Provider issues a batch of them. All PIDs or attestations in a batch represent the same logical PID or attestation and have the same attestation type, attribute values and technical validity period. Apart from that, all of the descriptions in this section 6.6.2 apply regardless of the number of attestations issued (single or batch).

Batch issuance is discussed in more detail in the Discussion Paper for Topic B.

6.6.3 PID or attestation presentation to a Relying Party

6.6.3.1 Required trust relationships

A Relying Party can request a User to present some attributes from a PID or from an attestation in their Wallet Unit. Figure 12 shows that a Relying Party uses a Relying Party Instance to interact with the Wallet Unit of the User. The relationship between the Relying Party and their Relying Party Instance is similar to the relationship between the User and their Wallet Unit.

When processing the request, the following trust relationships are established:

1. The Wallet Unit authenticates the Relying Party Instance, ensuring the User about the Relying Party's identity. Section 6.6.3.2 explains how this will be done.
2. The Wallet Unit verifies that the Relying Party does not request more attributes than it has registered for, and informs the User about the outcome of this verification. See Section 6.6.3.3 for more information.
3. The Attestation Provider, during issuance, may optionally embedded a disclosure policy in the attestation. If such a policy is present for the requested attestation, the Wallet Unit evaluates the disclosure policy and informs the User about the outcome of this evaluation. See Section 6.6.3.4.
4. The User approves or rejects the presentation of the requested attributes. User approval and selective disclosure are described in Section 6.6.3.5. Subsequently, after the Wallet Unit presents the selected attributes from the PID or attestation to the Relying Party Instance by sending a response to the request, the Relying Party validates the response. The following trust relationships are established:
5. The Relying Party Instance verifies the signature of the PID or attestation. This ensures that the Relying Party can trust that the PID or attestation it receives is issued by an authentic Provider and has not been changed. This is described in Section 6.6.3.6.
6. The Relying Party verifies that the PID Provider or Attestation Provider did not revoke the PID or attestation. This is described in Section 6.6.3.7.
7. For PIDs and device-bound attestations, the Relying Party verifies that the PID Provider or Attestation Provider issued this PID or attestation to the same Wallet Unit that presented it to the Relying Party. In other words, it checks that the PID or attestation was not copied or replayed. This is generally called device binding, and it is discussed in Section 6.6.3.8.

8. In some use cases, the Relying Party verifies that the person presenting the PID or attestation is the User to whom the PID or the attestation was issued. This is called User binding. In other use cases, the Relying Party trusts that the Wallet Unit and/or the WSCA/WSCD have done this check. User binding is discussed in Section 6.6.3.9.
9. The Relying Party can request attributes from two or more attestations in the same interaction. This is called a **combined presentation of attributes**. If so, the Relying Party verifies that these attestations belong to the same User. This is discussed in Section 6.6.3.10.
10. Finally, after the interaction with the Relying Party Instance is over, the Wallet Unit enables the User to report unlawful or suspicious requests for personal data by a Relying Party, based on information logged by the Wallet Unit. In addition, the Wallet Unit enables the User to send a request to a Relying Party to delete personal data (i.e., User attributes) obtained from the Wallet Unit. This is discussed in Section 6.6.3.13.

6.6.3.2 Wallet Unit authenticates the Relying Party Instance

Relying Party authentication is a process whereby a Relying Party proves its identity to a Wallet Unit, in the context of an interaction in which the Relying Party requests the Wallet Unit to present some attributes.

Relying Party authentication is included in the protocol used by a Wallet Unit and a Relying Party Instance to communicate. As documented in Topic 12, at least two different protocols can be used within the EUDI Wallet ecosystem, namely the ones specified in ISO/IEC 18013-5 and OpenID4VP. Both protocols include functionality allowing the Wallet Unit to authenticate the Relying Party Instance. Although these protocols differ in the details, on a high level, they both implement Relying Party authentication as shown in Figure 13 below.

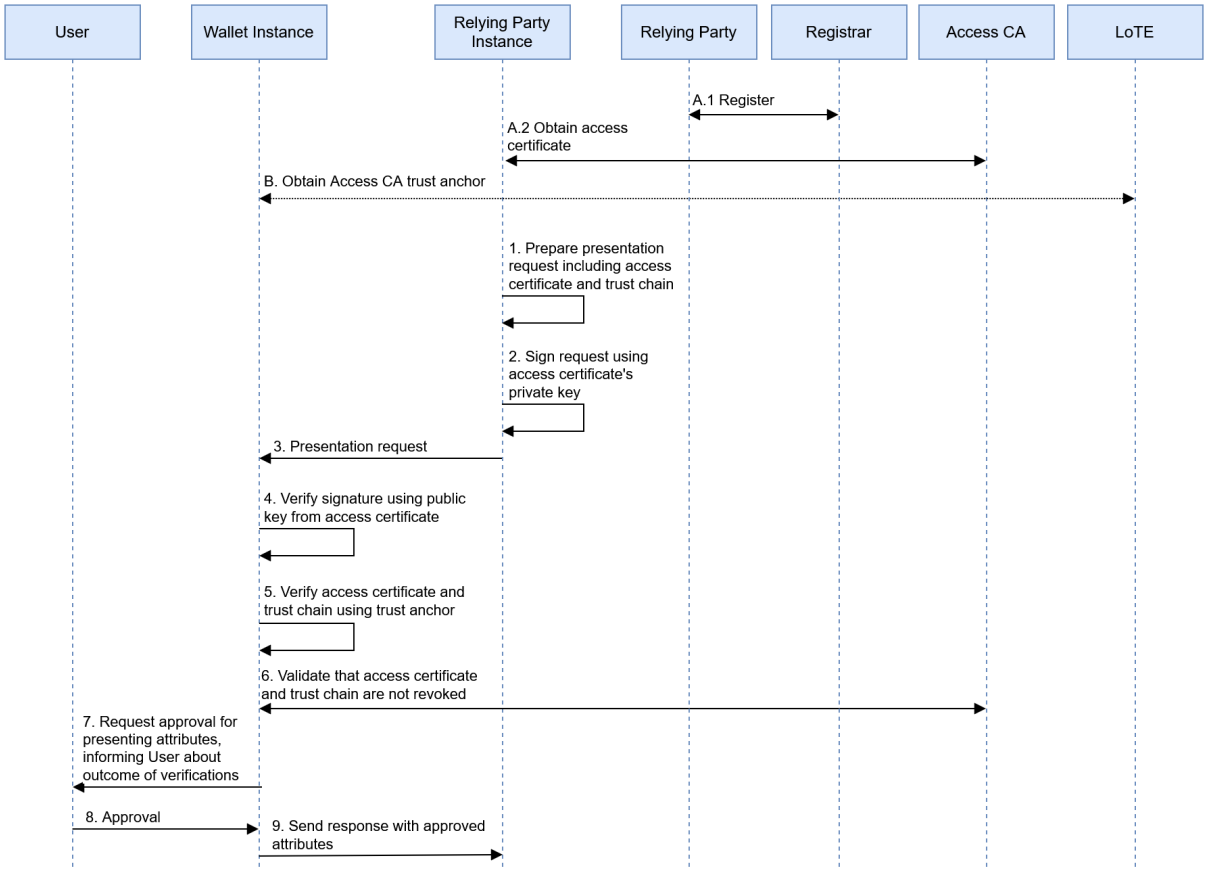


Figure 8: Figure 13

Figure 13 High-level overview of Relying Party authentication process

The figure shows the following:

First, there are two preconditions that need to be fulfilled before the Relying Party authentication process can begin. Note that these actions are not carried out for every presentation, but only once (excluding possible updates):

A) The Relying Party registered itself with a Registrar in its Member State, as described in Section 6.4.2, and obtained one or more access certificate for each of its Relying Party Instances from an Access Certificate Authority (See Section 3.18) associated with the Registrar.

B) The Wallet Unit obtained the trust anchor of the Access Certificate Authority from the respective List of Trusted Entities (LoTE, see Section 3.5).

Subsequently, during each presentation of attributes:

1. The Relying Party Instance prepares a request for some attributes to the Wallet Unit and includes its access certificate in the request, plus all intermediate certificates up to (but excluding) the trust anchor.
2. The Relying Party Instance signs some data in the attribute request using its private key.
3. The Relying Party Instance sends the request to the Wallet Unit.
4. The Wallet Unit checks the authenticity of the request by verifying the signature over the request using the public key in the access certificate.
5. The Wallet Unit checks the authenticity of the Relying Party by validating the access certificate and all intermediate certificates included in the request. For validating the last intermediate certificate, the Wallet Unit uses the trust anchor it obtained from the LoTE in step B above.
6. The Wallet Unit validates that none of the certificates in the trust chain have been revoked. This includes the access certificate as well as all other certificates in the trust chain, including the trust anchor itself if applicable. For revocation checking, the Wallet Unit uses the standard CRL or OCSP mechanisms, as specified in RFC 5280, ETSI TS 119 411-8, and in the Certification Practices Statement of the Access CA. For offline revocation checking, a Wallet Unit caches the CRLs of all Access Certificate Authorities.
7. The Wallet Unit continues by requesting the User for approval.
8. The User approves the attributes that will be presented.
9. The Wallet Unit sends a response containing only the approved attributes to the Relying Party Instance.

If Relying Party authentication fails for any reason (in steps 4. - 6.), the Wallet Unit notifies the User. In addition, the Wallet Unit either does not present the requested attributes to the Relying Party, or gives the User the choice to present the requested attributes or not. It is up to the Wallet Provider to make a choice for one of these two options, considering the precise reason for which authentication failed. To give some examples:

- If the signature over the request is not valid, the Wallet Unit will likely stop the transaction, since this may point to a man-in-the-middle attack or another serious security issue.
- Similarly, if the access certificate chain cannot be verified using a trust anchor from the Access Certificate Authority LoTE, the Wallet Unit will stop the transaction, because the Relying Party may be using a fake access certificate.
- If the Wallet Unit cannot verify the revocation status of the access certificate or another certificate because no sufficiently fresh revocation information is available, it is up to the Wallet Provider to decide to continue the transaction (by asking for User approval)

or to stop it, perhaps taking into account the sensitivity of the requested attributes.

- If there is some minor error in the format of the (properly signed) access certificate, the Wallet Unit will continue the transaction, if there are no associated security risks.

For more information on Relying Party authentication, please refer to Topic 6.

6.6.3.3 Wallet Unit verifies that Relying Party does not request more attributes than it registered

Figure 14 shows how a Wallet Unit verifies that the Relying Party properly registered all attributes it request in the presentation request.

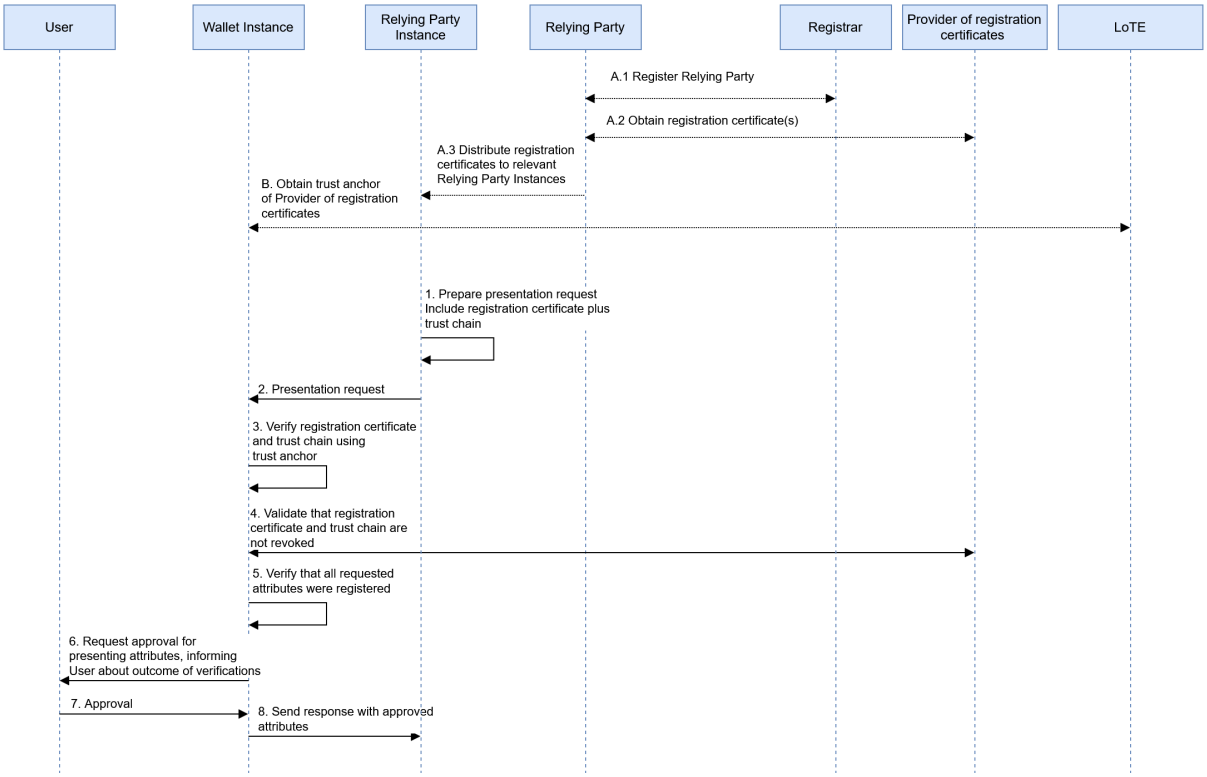


Figure 9: Figure 14

Figure 14 High-level overview of registration certificate verification process

First, there are two preconditions that need to be fulfilled before the verification process can begin. Note that these actions are not carried out for every presentation, but only once (excluding possible updates):

A) During registration, the Relying Party registered which attributes it intends to request from Wallet Units for each of the services (intended uses) it has; see Section 6.4.2. The Registrar ensured that an associated Provider of registration certificates listed these attributes in a separate registration certificate for each intended use and sent it to the Relying Party. Subsequently, the Relying Party distributed the registration certificates it received to its Relying Party Instances. Note that it is up to the Relying Party to determine if all of its Relying Party Instances need all of the registration certificates, or that some Relying Party Instances are used only for a subset of the Relying Party's intended uses, and consequently only need the registration certificates describing those intended uses.

B) The Wallet Unit obtained the trust anchor of the Provider of registration certificates from the respective List of Trusted Entities (LoTE, see Section 3.5).

Subsequently, during each presentation of attributes:

1. The Relying Party Instance prepares a presentation request and includes a single registration certificate pertaining to the intended use of the request. Note that a single intended use may cover multiple attributes from multiple attestations. For example, a Relying Party selling alcoholic beverages online may register that for this intended use they will request an age verification attribute from the PID and a User address from some other attestation. However, if a Relying Party really has multiple intended uses for interacting with a Wallet Unit, it needs to send multiple presentation requests, each including the relevant registration certificate. to the Wallet Unit
2. The Relying Party Instance sends the request to the Wallet Unit.
3. The Wallet Unit verifies the registration certificate. The Wallet Unit verifies that:
    - the registration certificate is present and well-formed,
    - the signature over the registration certificate can be verified using a trust anchor from the LoTE of Providers of registration certificates,
    - the registration certificate contains the same Relying Party identifier and Service identifier as the access certificate contained in the same presentation request. If that is not the case, a fraudulent Relying Party could be using a registration certificate that was issued to another Relying Party. Note that there two different ways in which this condition can be fulfilled:
        - Either the access certificate and the registration certificate were issued to the same Relying Party, in which the subject fields of both certificates contain the same set of identifiers,

- Or the access certificate was issued to an intermediary (see Section 6.6.5), and the registration certificate indicates that the intermediated Relying Party uses the services of this intermediary, by including the Relying Party identifier and Service identifier of the intermediary in a `usesIntermediary` field according to Technical Specification 5.

4. The Wallet Unit verifies that the registration certificate has not expired and is not revoked.

   In case any of the checks in point 3. and 4. fail, the Wallet Unit warns the User, when asking the User for approval, see Section 6.6.3.5, that it could not obtain or validate the information registered about the Relying Party. In addition, it is up to the Wallet Provider to determine, based on its risk analysis and security policy, whether and under which conditions the User may approve (or reject) the presentation of attributes despite specific failed validation checks. Moreover, any User approval must be explicit; silence or pre-ticked boxes do not suffice.

5. If all of the above checks pass, the Wallet Unit retrieves from the registration certificate the list of attributes registered by the Relying Party. The Wallet Unit compares this list to the attributes that the Relying Party requests in the presentation request. In case the Relying Party requested some attributes that are not included in the registration certificate, the Wallet Unit warns the User that the Relying Party is requesting more information than it has registered. The Wallet Unit does so when asking the User for approval, see step 6. and Section 6.6.3.5. In addition, it is up to the Wallet Provider to determine, based on its risk analysis, security policy, and applicable law, whether the Wallet Unit must
   - enable the User to approve (or reject) the presentation of all requested attributes, including the non-registered ones,
   - enable the User to approve (or reject) the presentation of the registered attributes only, or
   - reject the presentation of all requested attributes.

   Moreover, any User approval must be explicit; silence or pre-ticked boxes do not suffice.

6. The Wallet Unit informs the User about the outcome of the above verifications and requests approval for presenting the requested attributes.

7. The User approves the attributes that will be presented.

8. The Wallet Unit sends a response containing only the approved attributes to the Relying Party Instance.

   Notes: - The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982. - The process and verifications describe above ensure that Wallet Providers comply with the 'general access policy' described in CIR 2025/848.

For more information, see Topic 44.

6.6.3.4 Wallet Unit evaluates embedded disclosure policy, if present

During attestation issuance, an Attestation Provider optionally created an embedded disclosure policy for the attestation, see Section 6.6.2.8. If such a policy is present for the requested attestation, the Wallet Unit evaluates the policy, together with information in the registration certificate, to determine whether the Attestation Provider allows this Relying Party to receive the requested attestation. Note that the Wallet Unit verifies the authenticity of the registration certificate before using any data contained in it.

The Wallet Unit presents the outcome of the disclosure policy evaluation to the User when requesting User approval, see Section 6.6.3.5.7.

For more details on the embedded disclosure policy, see Topic 43.

6.6.3.5 Wallet Unit obtains User approval for presenting selected attributes

6.6.3.5.1 Introduction

Note: In this document the term 'User approval' exclusively refers to a User's decision to present an attribute to a Relying Party. Under no circumstances User approval to present data from their Wallet Unit should be construed as lawful grounds for the processing of personal data by the Relying Party or any other entity. A Relying Party requesting or processing personal data from a Wallet Unit must ensure that it has grounds for lawful processing of that data, according to Article 6 of Regulation (EU) 2016/679 (the GDPR).

Before presenting any attribute to a Relying Party, the Wallet Unit requests the User for their approval. This is critical for ensuring that the User remains in control of their attributes.

A Wallet Unit requests User approval in all use cases, both in proximity flow and remote flow, and including:

- Use cases where the Relying Party could be assumed to be trusted, for example, when the Relying Party is part of law enforcement or another government agency.
- Use cases where the requested attributes are critical for the Relying Party to grant access to the User or deliver the requested services.
- Use cases where there is, according to the GDPR or other legislation, no legal need to ask for the User's approval because another legal basis exists for requesting the attributes.

A number of conditions must be fulfilled for effective User approval:

1. The Wallet Unit authenticated the User; see Section 6.6.3.5.2,
2. The Wallet Unit informed the User about the identity of the Relying Party and about the identity of the intermediary, if applicable; see Section 6.6.3.5.3,
3. The Wallet Unit informed the User about the attributes the Relying Party requested; see Section 6.6.3.5.4,
4. The Wallet Unit informed the User about the Relying Party's intended use and privacy policy for these attributes; see Section 6.6.3.5.5,
5. The Wallet Unit informed the User about the outcome of the evaluation of the requested attributes; see Section 6.6.3.5.6,
6. The Wallet Unit informed the User about the outcome of the evaluation of the embedded disclosure policy, if any; see Section 6.6.3.5.7,
7. The Wallet Unit enables the User to approve or deny the requested attributes; see Section 6.6.3.5.8.

These conditions are further discussed in the next subsections. After the User gives their approval, the Wallet Unit will present the approved User attributes to the Relying Party Instance.

High-level requirements regarding User approval can be found in Topic 6

6.6.3.5.2 Wallet Unit authenticates the User

A prerequisite for requesting User approval is that the Wallet Unit is sure that the person using the Wallet Unit (and giving the approval) is in fact the User. Therefore, the Wallet Unit authenticates the User prior to or during requesting User approval, on request of the Wallet Unit. To do so, the Wallet Unit uses one of the User authentication mechanisms set up during Wallet Unit activation, see Section 6.5.3.3.

6.6.3.5.3 Wallet Unit informs the User about the identity of the Relying Party

In order to be able to give approval, a User needs to be informed about the identity of the Relying Party. The Wallet Unit displays to the User the User-friendly Relying Party trade

name and Service trade name. The Wallet Unit obtains this information from the registration certificate presented by the Relying Party Instance.

If the Relying Party uses an intermediary, the Wallet Unit does not inform the User about the trade names of the intermediary and its Service during the transaction; see Section 6.6.5. However, it does log the intermediary's trade names in the transaction log. The Wallet Unit finds the trade names of the intermediary in the access certificate presented by the Relying Party Instance, whereas it obtains the trade names of the intermediated Relying Party from the registration certificate.

6.6.3.5.4 Wallet Unit informs the User about the attributes the Relying Party requested

In order to be able to give approval, a User also needs to know which attributes the Relying Party wishes to receive. Note that a Relying Party may request attributes from multiple attestations in a single request; for example information from a diploma and from a PID.

In case a Relying Party requests the presentation of the portrait in a PID, the Wallet Unit warns the User that the request involves the presentation of biometric data. The Wallet Unit then ensures that User approval for presenting the portrait is explicit; silence or a pre-ticked box do not suffice.

6.6.3.5.5 Wallet Unit informs the User about the Relying Party's intended use and privacy policy

According to the GDPR, a User must be informed about the Relying Party's intended use for the requested attributes. For each presentation request, the Relying Party can have only one intended use. If the Relying Party has multiple intended uses for requesting attributes from a Wallet Unit, it needs to send multiple presentation requests. In such a case, the Wallet Unit will request the User for their approval multiple times.

The registration certificate sent by the Relying Party Instance to the Wallet Unit contains a User-friendly description of the Relying Party's intended use, as well as a URL to the applicable privacy policy of the Relying Party. The Wallet Unit displays this information to the User.

6.6.3.5.6 Wallet Unit informs the User about the outcome of the evaluation of the requested attributes

Section 6.6.3.3 above described how the Wallet Unit can verify the attributes requested by the Relying Party against the attributes that the Relying Party registered for the given intended use. If the outcome is negative, the Wallet Unit will inform the User that this is the case. For example, "<Relying Party name> requested <attribute1>, but it did not register this attribute.

Do you want to continue?" Note that it is up to the Wallet Provider to decide if the User can overrule a negative outcome of this verification and decide to approve the request.

6.6.3.5.7 Wallet Unit informs the User about the outcome of the evaluation of the embedded disclosure policy

Section 6.6.3.4 above described that an Attestation Provider can add an embedded disclosure policy for an attestation. It also described how a Wallet Unit can evaluate such a policy. The Wallet Unit presents the outcome of the disclosure policy evaluation to the User when asking for User approval. For example, "The issuer of your <attestation name> does not want you to present data to <Relying Party name>. Do you want to continue?" Note that the User can overrule a negative outcome of the disclosure policy evaluation and decide to approve the request.

6.6.3.5.8 Wallet Unit enables the User to approve or deny the requested attributes

After presenting all of the above information to the User, the Wallet Unit enables the User to approve or deny the requested attributes. Preferably, the User gives approval either to present all attributes requested, or none of them. This is because partial approval would mean that the Relying Party cannot deliver the service, but nevertheless receives some User attributes. This would be a violation of the User's privacy. Note that a Relying Party is not allowed to request more data than is justified for the intended use. Therefore, if the User feels that the Relying Party is actually requesting more data than needed, that implies that the Relying Party is not trustworthy. The User will probably not approve the presentation of any data in that case.

The Wallet Unit will present all approved User attributes, and only these, to the Relying Party Instance.

6.6.3.6 Relying Party Instance verifies the authenticity of the PID or attestation

The Relying Party Instance receives a PID or attestation, including some attributes, from the Wallet Unit. Subsequently, it verifies the signature over the PID or attestation. To do this for PIDs, QEAAs, and PuB-EAAs, the Relying Party Instance uses a trust anchor of the Provider obtained from a LoTE or Trusted List. Note that the Provider may use an intermediate signing certificate to sign the PID or attestation, and use the trust anchor to sign the signing certificate, instead of signing the PID or attestation directly with the trust anchor.

For non-qualified EAAs, the applicable Rulebook may describe how the Relying Party Instance obtains the relevant trust anchor.

The above implies that a Relying Party Instance is aware whether the attestation it is requesting from a Wallet Instance is a PID, a QEAA, a PuB-EAA, or a non-qualified EAA. Also, the Relying Party Instance stores trust anchors in such a way that, at the time of verification, it is able to distinguish between trust anchors usable either for PIDs, for QEAAs, for PuB-EAAs, or for non-qualified EAAs.

A Relying Party performs regular trust anchor management. It downloads the latest version of all applicable Trusted Lists and LoTEs. If if finds that new trusted entities have been added, or that new trust anchors have been added for existing trusted entities, it ensures that these trust anchors are properly stored in all relevant Relying Party Instances. Conversely, if the Relying Party finds that an existing trusted entity has been invalidated in the Trusted List or LoTE, or that some of the trust anchors of existing trusted entities have expired, been revoked, or otherwise been invalidated, it ensures that these trust anchors are removed from all Relying Party Instances.

The technical implementation of the signature verification process depends on which of the standards mentioned in Topic 12 is supported by the Wallet Unit. Each of these standards specifies in detail how to carry out signature verification.

In addition, the Relying Party may want to verify that the Attestation Provider is registered to issue the type of attestation in question, as described in Section 6.3.2.3.

Notes:

- All PIDs and attestations in the EUDI Wallet ecosystem are digitally signed by the respective PID Provider or Attestation Provider. All attributes in a PID will be included in that signature; these are called issuer-signed attributes. In addition, Attestation Providers can enable the WSCA/WSCD or a keystore in the Wallet Unit to sign attributes itself, using the private key associated with the public key in an attestation. Such attributes are called device-signed or self-issued attributes. This possibility is used primarily by SUA attestations for signing transactional data; see Section 2.6.4. The Attestation Rulebook for a specific type of attestation specifies the device-signed (self-issued) attributes that may be present in that attestation, if any. PIDs are not allowed to contain device-signed attributes; this implies that PIDs cannot be used to sign transactional data.

6.6.3.7 Relying Party verifies that the PID or attestation is not revoked

To allow revocation checking of a PID or attestation, the PID Provider or Attestation Provider includes revocation information in the PID or attestation, if it is valid for longer than 24 hours.

This revocation information includes a URL indicating the location where a Relying Party can obtain a status list or revocation list, and an identifier or index for this specific certificate or attestation within that list.

Notes:

- For attestations with a validity period of less than 24 hours, including revocation information is not necessary.
- A status list is a bit string or byte string in which each bit or group of bits denotes the current revocation status (valid or revoked) of one attestation. To get the status of the attestation it has received from the Wallet Unit, the Relying Party obtains the status list from the URL specified in the attestation and verifies the value encoded at the bit position given by the index value in the attestation. For more information, see Token Status List.
- A revocation list is a list of PID identifiers or attestation identifiers revoked by the PID Provider or Attestation Provider. To get the status of the PID or attestation it has received from the Wallet Unit, the Relying Party obtains the revocation list from the URL specified in the attestation and verifies whether the identifier included in the attestation is on the list or not. For more information, see the (draft) second edition of ISO/IEC 18013-5, available on the GitHub repository of the responsible ISO Working Group.
- In some cases, no reliable information regarding the revocation status of a PID or attestation will be available, for example in case a Relying Party Instance is offline and does not have access to a cached status list or revocation list, or if the requested attestation is non-qualified and the responsible Attestation Provider choose to not have a revocation service for the attestation. In such a case, a Relying Party performs a risk analysis considering all relevant factors for the use case, before taking a decision to accept or refuse the PID or attestation.
- It is recommended but not mandatory for a Relying Party Instance to verify the revocation status of a PID or attestation.

For more details and requirements on revocation, see Topic 7. See also Section 6.6.6.4.

6.6.3.8 Relying Party Instance verifies device binding

Device binding is the cryptographic link that ensures a PID or attestation belongs exclusively to the WSCD or to a keystore in the User's Wallet Unit. This key property prevents copying or cloning, significantly boosting the attestation's security. Device binding is also a prereq-

uisite for User binding, allowing the Relying Party to trust the Wallet Unit's internal User authentication mechanisms to verify the presenter is the rightful User.

Within the EUDI Wallet ecosystem, implementing device binding is mandatory for PIDs, since PIDs must be managed at Level of Assurance High, which is impossible without device binding to a WSCA/WSCD. It is also mandatory for attestations complying with ISO/IEC 18013-5, due to the fact that this is required in that standard. For SD-JWT VC-compliant attestations, implementing device binding is recommended but not mandatory. However, note that OpenID4VP enables the Relying Party to indicate if it wants to receive a proof of device binding for a requested attestations, via the `require_cryptographic_holder_binding` parameter in the request. It also stipulates that a Wallet Unit cannot return a non-device-bound attestation in case the Relying Party requests such a proof.

A PID Provider or an Attestation Provider can implement device binding by including a cryptographic public key in the PID or attestation and signing it. The corresponding private key is protected by the WSCA/WSCD or keystore in the Wallet Unit.

A WSCA/WSCD or keystore generates a public-private key pair for each PID and device-bound attestation upon request of the Wallet Unit. The Wallet Unit sends the public key to the PID Provider or Attestation Provider.

After receiving a presentation response, the Relying Party Instance may verify that a PID or device-bound attestation it received from a Wallet Unit is indeed bound to the WSCA/WSCD or keystore included in the Wallet Unit. The Relying Party Instance does so by requesting the Wallet Unit to sign some (pseudo-)random data provided by the Relying Party, using the private key corresponding to the public key in the PID or attestation. For this reason, device binding is also called 'proof of possession'. In ISO/IEC 18013-5 it is called 'mdoc authentication'. In SD-JWT VC it is called 'key binding'. Note that it is recommended but not mandatory for a Relying Party Instance to verify the device binding signature in the presentation response, if present.

The technical implementation of this verification depends on which of the standards mentioned in Topic 12 is supported by the Wallet Unit. Each of these standards specifies in detail how to carry out this verification.

The data signed by the Wallet Unit may include (a representation of) some transactional data which the Relying Party included in the presentation request, see Section 5.7.5. Note that neither ISO/IEC 18013-5 nor OpenID4VP or SD-JWT VC specify the full syntax and semantics of the transactional data. Nor do these standards specify how a Wallet Unit processes this

data, or how it is presented to the User prior to being signed. All of these aspects will need to be specified in the Attestation Rulebook or Technical Specification for the type of attestation that is being requested in the presentation request.

6.6.3.9 Relying Party Instance verifies or trusts User binding

User binding (sometimes also called 'holder binding') is the property that the person that presents the PID or attestation to the Relying Party is in fact the User to whom the PID or the attestation was issued. User binding prevents an attacker from successfully presenting a PID or an attestation that they are not legally allowed to use.

The mechanism(s) available for User binding depend on the presentation flow type (proximity or remote, supervised or unsupervised, see also Section 4.4), and on the attributes issued to the User by the PID Provider or Attestation Provider:

1. In the first place, for PIDs and device-bound attestations the Relying Party can always decide to trust the User authentication mechanisms implemented by the Wallet Unit (see Section 6.5.3.3). This means that the Relying Party trusts that the User device or the WSCA/WSCD has properly authenticated the User before allowing the User to present the attributes. Note that:
    - This trust is not based on the outcome of any verification by the Relying Party itself, but on a a-priori trust in the certified Wallet Unit and (for PIDs and attestations with a security level High) the certified WSCA/WSCD.
    - Using this method implies that Relying Parties must verify device binding, as described in Section 6.6.3.8. The Relying Party Instance in fact first verifies that the PID or attestation is bound to the Wallet Unit (i.e., to a WSCA/WSCD or keystore attested in a KA), and then trusts that the Wallet Unit has authenticated the User.
    - As a matter of fact, this User binding method will always be carried out, since the Wallet Unit (and for PIDs additionally the WSCA/WSCD) must authenticate the User before it can present a PID or attestation, see Section 6.5.3.3.
2. In addition, in some cases, if a Relying Party does not want to only trust the User authentication mechanisms of the Wallet Unit, it may be able to use User attributes to carry out an additional User binding process. For example, if the PID or attestation contains a User portrait, the Relying Party may be able to visually compare that portrait to the face of the person presenting the attestation, or do a biometrical matching to a photo taken of that face by an automated machine or as a "selfie". This will generally be possible in

supervised proximity presentations by human inspection, or in an unsupervised proximity flow if equipped with the appropriate equipment. It may also be possible to do this in unsupervised remote presentations by using face recognition technology, possibly even remotely. However, to generate trustworthy outcomes in such situations, special conditions and dedicated security measures are required, such as good lighting, clear instructions for the User for positioning their face and an approved liveness detection mechanism supporting Presentation Attacks Detection (PAD), as well as mechanisms for injection attack detection, in particular deepfake detection.

3. Lastly, if the person presenting the PID or attestation is able to present an identity document, the Relying Party may be able to verify User binding by comparing attributes from the PID or attestation, such as first and last name, to those in the identity document. However, this requires that the Relying Party can verify that the identity document is authentic and really belongs to the person presenting it. In practice this will often mean that the identity document is a photo ID, and the presentation must consequently be done in proximity and be supervised, or done remotely and supported by PAD.

6.6.3.10 Relying Party Instance verifies combined presentation of attributes

6.6.3.10.1 Introduction

According to the European Digital Identity Regulation, a combined presentation of attributes is a request for attributes from two or more attestations in the same action. Scenarios where a User is asked to present different attributes from various physical documents are common in the real world, and are also relevant in the digital domain. Several examples, including university admissions, professional licencing, and rental or loan applications, are discussed in the Discussion Paper for Topic K. These scenarios can be addressed more efficiently through combined presentation, allowing a Relying Party to receive a consolidated set of attributes from different attestations.

In such cases, the Relying Party will need to verify that these attestations belong to the same User. This can be done in different ways, including (but not necessarily limited to):

- **Presentation-Based Binding**: A Relying Party may assume that attributes presented in a single presentation response belong to the same User. However, this means that the Relying Party trusts that the Wallet Instance that created the response is not hacked or fraudulent. In some high-security use cases, such trust may not be warranted.
- **Attribute-Based Binding**: Multiple attestations may include a shared unique identi-

fier (e.g., a PID number), which can then serve as a binding reference across different attestations. Another possibility is the use of the same identifying data, such as full name and date of birth, in multiple attestations, which can be used to relate attestations to each other and to a User. This is analogous to many present-day processes using paper documents, which may be seen as an advantage. However, this method implies that identifying data of the User must be presented even in use cases where this is not necessary for the purposes of the use case itself. Moreover, this method may not be conclusive, for instance if multiple people share the same name.

- **Cryptographic Binding**: The WSCA/WSCD or a keystore in the Wallet Unit may generate a cryptographic proof demonstrating that it manages the private keys associated with all of the involved PIDs and device-bound attestations. Since the WSCA/WSCD or keystore complies with (much) higher security requirements than the device OS does, such a solution is more secure than presentation-based binding. To a lesser extent, this also applies for keystores. Cryptographic binding is more privacy-preserving than attribute-based binding, since no attributes other than those strictly necessary for the use case have to be presented.

Cryptographic binding of attestations is discussed in the next section.

6.6.3.10.2 Cryptographic binding between attestations

Cryptographic binding between attestations is an envisioned cryptographic mechanism that enables a WSCA/WSCD or keystore to prove that it manages the private keys corresponding to two (or more) public keys. A proof of cryptographic binding between attestations can be used during attestation presentation, e.g., to prove that the public keys associated with two (or more) device-bound attestations are managed by the same WSCA/WSCD or keystore and that, therefore, these attestations belong to the same User.

When designed with privacy in mind, cryptographic binding between attestations becomes a powerful tool for protecting individuals from unnecessary exposure. Rather than relying on full User identification for each presented attestation, for instance by requesting the User's name from each of them, a Relying Party can instead implement solutions that enable Users to prove only what is strictly necessary — without revealing who they are. This aligns directly with the commitments laid out in the European Digital Identity Regulation: access to digital services must be privacy-protective by design (recital 4), supported by privacy-enhancing technologies (recital 14), and uphold the principle of unobservability (recital 32).

In this light, Article 5a(16)(b) provides a clear obligation: when attributes are presented

together, this must be done in a way that avoids unnecessary identification of the User. Instead, a privacy-preserving cryptographic binding between attestations opens the door to new possibilities. It enables the transition of many real-world processes — currently performed under full User identification — into more private digital equivalents.

Consider, for example, eligibility checks for educational programs. A student should be able to prove they reside in a particular city (as attested in their PID) and have qualifying grades (from a diploma) without revealing their name, gender, or exact address. With the right cryptographic mechanisms in place, we can minimize data exposure while maintaining trust in the combination of presented attributes.

Note that:

- By definition, cryptographic binding between attestations can only be used for PIDs and device-bound attestations.
- This version of the ARF does not specify or reference a specific cryptographic mechanism to implement cryptographic binding between attestations. However, Topic 18 specifies high-level requirements for a cryptographic binding between attestations scheme.
- This ARF assumes that each Wallet Unit (and therefore each WSCA/WSCD and keystore) contains attestations for only one User (see also Section 3.2). Therefore, a proof of cryptographic binding between two attestations proves that these attestations belong to the same User. However, some additional actions must be done to use such a mechanism in practice:
  - During attestation issuance, an Attestation Provider must request the Wallet Unit to bind the new attestation to an existing PID or attestation. For this, the Attestation Provider must verify that the existing PID or attestation refers to the same User to whom the new attestation refers. How the Attestation Provider does this is out of scope of the ARF. For example, the Attestation Provider could request the User name and birth date from a PID on the Wallet Unit, verify that this information matches a record in its database, issue an attestation corresponding to the information in that record, and then request the Wallet Unit to bind the public key in that attestation to the public key in the PID.
  - A Relying Party that has verified a proof of cryptographic binding between two attestations needs to verify that these attestations belong to the User presenting them. This is User binding, as discussed in Section 6.6.3.9. Note that, if User binding is proven for one of the bound attestations, it is proven for all of them.

6.6.3.11 Relying Party Instance trusts issuer to have authenticated the Wallet Unit and the Wallet Provider

The Relying Party Instance does not have a way to directly verify the authenticity of the Wallet Unit and the Wallet Provider. Rather, the Relying Party trusts the PID Provider or the Attestation Provider to have done this during issuance of the PID or attestation.

6.6.3.12 Relying Party optionally trusts issuer to regularly verify that Wallet Unit is not revoked

Section 6.6.2.5 explained how a PID Provider or an Attestation Provider can verify that a Wallet Unit is not revoked, using the revocation information in the WIA and KA. That section also noted that the CIR 2024/2977 requires PID Providers to verify regularly, during the entire lifetime of the PID, whether the Wallet Unit on which that PID is residing is revoked by the Wallet Provider. If that happens, the PID Provider must revoke the PID. Therefore, by verifying the revocation status of the PID, the Relying Party Instance can also trust the revocation status of the Wallet Unit. Consequently, there is no need for a separate mechanism that would allow the Relying Party to verify the revocation status of a Wallet Unit directly with the Wallet Provider.

Attestation Providers can use the same mechanism to provide the same assurance to Relying Parties, although this is not required by the CIR. If an Attestation Provider does not support this, a Relying Party obtaining an attestation issued by that Attestation Provider has no way of knowing whether the Wallet Unit is revoked. It is up to a Relying Party to check, before requesting a particular type of attestation from Wallet Units to fulfil a particular use case, if the Attestation Provider provides this assurance. If not, the Relying Party must decide whether the associated risk is acceptable.

6.6.3.13 Wallet Unit enables the User to report suspicious requests by a Relying Party and to request a Relying Party to erase personal data

A Wallet Unit enables the User to report unlawful or suspicious requests for personal data by a Relying Party to a Data Protection Authority (DPA). To allow this, a Wallet Unit provides a dashboard displaying a log of all attestation presentation transactions (as well as all other types of transaction) performed by the Wallet Unit. For presentation transactions, this log includes the identifiers of the attributes that were requested and presented, but not their values. For high-level requirements on this transaction log, see Topic 19.

The Wallet Unit enables the User to easily report a suspicious presentation request in the transaction log to a DPA. By default, this is the DPA that supervises the Relying Party, but if the Wallet Unit does not know which DPA this is (because this information was not available during the transaction), it will present the User with the contact details of at least the DPA of the region in which the Wallet Provider resides. The User can make such a report regardless of whether any attributes were actually presented to the Relying Party. Even if the Wallet Instance prevented the presentation of any attributes, for instance because Relying Party authentication failed, or if the User did not approve the presentation of any attributes, the User can still report the request to a Data Protection Authority.

For more information and requirements on reporting presentation requests to a DPA, see Topic 50.

The dashboard and the transaction log kept by the Wallet Unit also enable the User to request a Relying Party to delete personal data in accordance with Regulation (EU) 2016/679 (the GDPR). In the context of EUDI Wallet, this personal data consists of attributes that were presented to the Relying Party by the User, using their Wallet Unit. Relying parties, which act as data processors or controllers, already have procedures, protocols, and interfaces in place to handle data deletion requests in accordance with the GDPR. Wallet Units re-use these already existing interfaces. As there are no standardised protocols and interfaces for this purpose, this implies that a Wallet Unit can either

- open a specific URL with an external browser to ask for the deletion of data in a web form provided by the Relying Party,
- open an external mail client with a suitable template text, or
- open an external phone client to enable the User to call the Relying Party.

The registration certificate of the Relying Party (see Section 6.4.2) contains the necessary contact information, including the URL of a web form for privacy-related enquiries, an e-mail address, and/or a phone number.

A Relying Party may use the services of an intermediary to request data from a Wallet Unit, see Topic 52. However, such intermediaries are required to delete any data they obtain from a Wallet Unit immediately after sending it to the Relying Party. Data deletion requests are therefore always sent to the Relying Party, not the intermediary.

For more information and requirements on requesting a Relying Party to delete personal data, see Topic 48.

6.6.4 PID or attestation presentation to another Wallet Unit

6.6.4.1 Introduction

Section 6.6.3 discussed the trust relationships necessary when a Wallet Unit receives a request from a Relying Party Instance and presents attributes to that Relying Party Instance. However, the European Digital Identity Regulation requires that a Wallet Unit is also able to receive such a request from another Wallet Unit, and present attributes to that requesting Wallet Unit. In this context, the ARF calls the requesting Wallet Unit the Verifier Wallet Unit, and the presenting Wallet Unit the Holder Wallet Unit. The User of a Holder Wallet Unit is called a Holder, and the User of a Verifier Wallet Unit is called a Verifier.

Wallet-to-Wallet interactions cover use cases where a natural person, the Holder, wishes to present a PID or attestation to another natural person, the Verifier, where both are using their Wallet Units. As an example, the use case could occur in a setting where one private person (the Verifier) wants to rent out their car to another private person (the Holder), provided the Holder has a valid driving licence.

Note that legal entities are not allowed to bypass the processes and rules governing Relying Parties, in particular regarding the obligation to register, by using Wallet-to-Wallet interactions. Therefore,

- **Wallet-to-Wallet interactions will only take place in proximity, not remotely.** This ensures that both Users are aware of the device they are connecting to, because they have to present and scan a QR code or NFC tag. Being in proximity also allows for out-of-band communication and authentication possibilities between Holder and Verifier.
- **Wallet Units will be restricted in the number of times they can act as a Verifier per unit of time.** Since many Relying Parties will need to have frequent interactions with multiple Wallet Units, this ensures that it will not be feasible for a Relying Party to use a Wallet Unit for all of these interactions.
- **A User will need to select a dedicated 'Holder Wallet Unit' mode to start using Wallet-to-Wallet interactions.** If this mode is selected, a Holder Wallet Unit will clearly indicate to its User that they are presenting attributes to another natural person, and that they should not proceed if they are in fact interacting with a legal entity.

For more information and high-level requirements, please refer to Technical Specification 9 and Topic 30. The next section describes a Wallet-to-Wallet transaction flow on a high level.

6.6.4.2 General transaction flow

Figure 15 shows the transaction flow for Wallet-to-Wallet interactions.

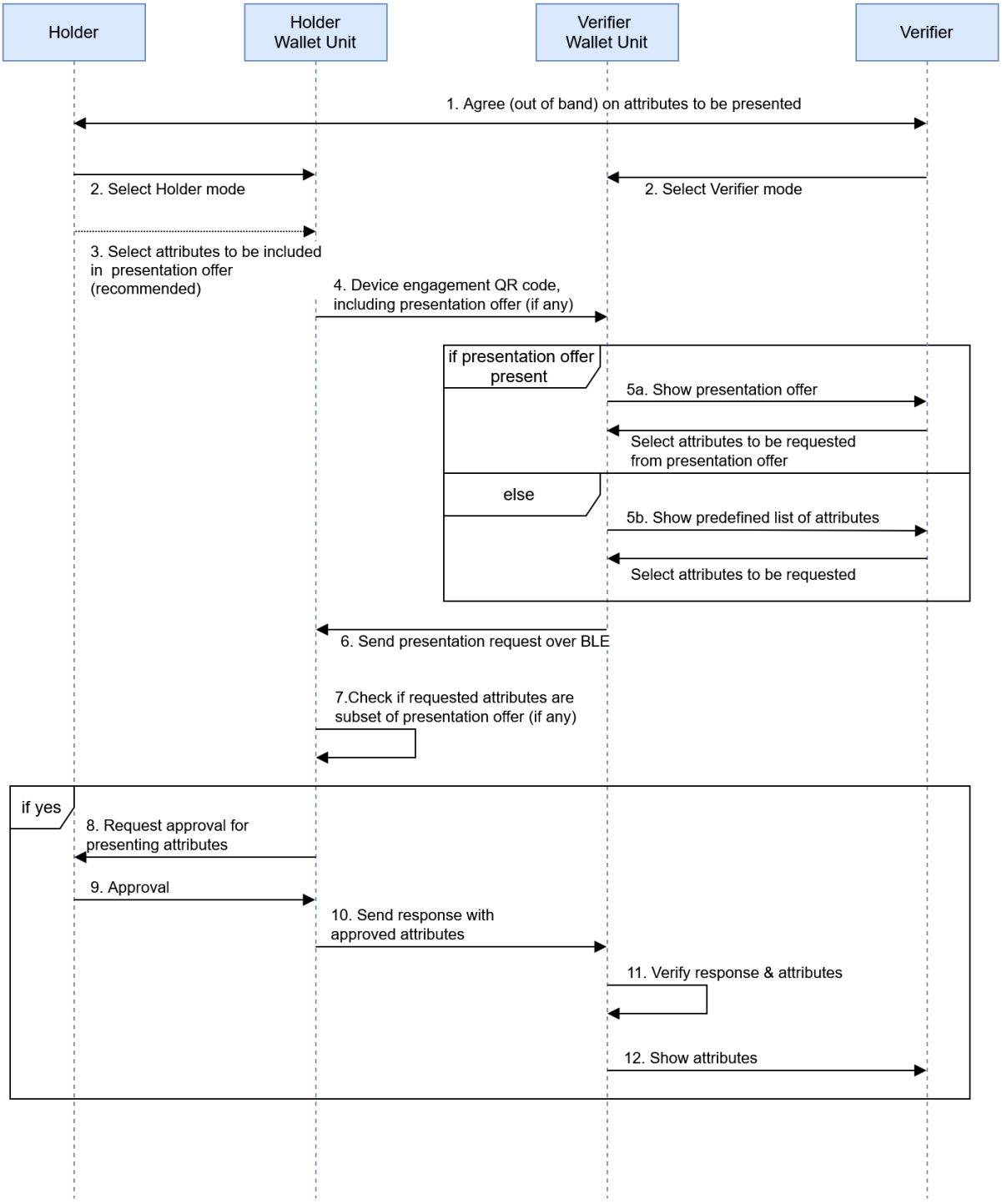


Figure 10: Figure 15

Figure 15 Wallet-to-Wallet transaction flow

The transaction flow can be described as follows:

1. The two EUDI Wallet Users meet in physical proximity and agree that one (the Holder) will present specific attributes from a PID or attestation to the other (the Verifier). This agreement takes place out of band of the EUDI Wallet ecosystem; typically, it will be done orally.
2. Both Users select a dedicated 'Wallet-to-Wallet mode' in their respective Wallet Unit and are asked to specify their role (Holder or Verifier).
3. The Holder Wallet Unit gives the Holder an option to suggest to the Verifier which PID or attestation, and which attributes, the Verifier should request. This suggestion is called a presentation offer.
4. A handshake protocol (called device engagement in ISO/IEC 18013-5) is performed and a data connection is established between the two devices as specified ISO/IEC 18013-5. This protocol also sends the presentation offer to the Verifier, if the User specified such an offer.
5. The Verifier tells the Verifier Wallet Unit what attributes should be included in the presentation request:
    - If the Holder specified a presentation offer in step 3, the Verifier Wallet Unit displays the offer to the Verifier. The Verifier selects all or a subset of the offered attributes, but is not allowed to add additional attributes.
    - If there is no presentation offer in the handshake, the Verifier Wallet Unit assists the Verifier in creating a presentation request from scratch, by allowing the Verifier to select attributes from a pre-defined list populated by the Wallet Provider.
6. The Verifier Wallet Unit sends the presentation request to the Holder Wallet Unit.
7. The Holder Wallet Unit checks if the presentation request matches the presentation offer created in step 3 (if any), and aborts the transaction in case the request contains attributes that were not present in the offer. The Holder Wallet Unit informs the Holder about the reason for aborting. If no presentation offer was sent in step 4, then this check is omitted.
8. The Holder Wallet Unit prompts the Holder for approval to present the requested attributes to the Verifier.
9. The Holder approves the presentation.
10. The Holder Wallet Unit sends a presentation to the Verifier Wallet Unit.
11. The Verifier Wallet Unit verifies the received presentation.
12. The Verifier Wallet Unit presents the received attributes to the Verifier.

Notes:

- Step 2 ensures that both parties actively accept that a local data connection towards a natural-person Wallet Unit will be established. For the Holder this is very important, because many (if not all) of the verifications usually done on a presentation request from a Relying Party will not be performed when a Wallet Unit acts as a Holder Wallet Unit; see the note to step 6 below. For the Verifier, this is necessary as well, since the functionality offered by a Verifier Wallet Unit is completely different then when acting a 'normal' Wallet Unit.
- In step 3, if the Holder wishes to let the Verifier specify the requested information, the presentation offer is left empty. However, the use of a presentation offer is recommended, as this increases the chance of success of the use case.
- Step 4 establishes a local data connection. ISO/IEC 18013-5 requires that an mdoc reader (i.e., a Verifier Wallet Unit) must support both a QR code and NFC for device engagement, and both BLE and NFC for data retrieval. An mdoc (i.e., a Holder Wallet Unit) then chooses to use either a QR code or NFC for device engagement, and either BLE or NFC for data retrieval. The requirements regarding supported technologies are therefore more stringent for an mdoc than for an mdoc reader. Depending on the device it's installed on and the technologies chosen by the Holder, this may mean that a Wallet Unit is not able to act as a Verifier Wallet Unit. For example, if a Holder Wallet Unit uses only NFC for device engagement, then a Wallet Unit on a device that does not have NFC will be not be able to act as a Verifier Wallet Unit towards that Holder Wallet Unit. Technical Specification 9 therefore limits the choice offered by ISO/IEC 18013-5 and stipulates that in Wallet-to-Wallet interactions, device engagement always uses a QR code and data retrieval always uses BLE.
- In step 5, if the offered attributes do not fulfil the needs of the Verifier for the use case, the Verifier may decide to stop the transaction and return to step 1 to communicate (out of band) to the Holder which attributes the Holder should offer.
- In step 5, if there is no presentation offer, the Verifier Wallet Unit will present the Verifier with a list of 'frequently used' attributes to include in the presentation request. Conceivably, the Verifier Wallet Unit may limit the number of attributes in the list by asking the Verifier a set of pre-defined questions about the purpose of the use case. However, there is no guarantee that the Holder Wallet Unit contains these attributes. For the success of the use case, the presence of a presentation offer is very helpful.
- A user-friendly User interface is important in steps 3 and 5 (when Users select what attributes to offer cq. request).

- In step 6, a presentation request from a Verifier Wallet Unit does not contain an access certificate (see Section 6.6.3.2) or a registration certificate (see Section 6.6.3.3). The Holder therefore cannot be certain about the Verifier's identity, nor is there any check regarding the Verifier's reasonable need to request these User attributes. This is because a Verifier is a User, and is not required to register as a Relying Party. Additionally, because there is no registration certificate in the presentation request, the Holder Wallet Unit is not able to evaluate an embedded disclosure policy, if existing, see Section 6.6.3.4.
- However, the presentation request in step 6 will include a cryptographic proof that the Verifier Wallet Unit is a genuine, non-revoked EUDI Wallet Unit operated by a recognised Wallet Provider, once a common method to provide such a proof will be available. ETSI is preparing a technical specification of such a common method, which will probably use a WIA of the Verifier Wallet Unit. If such a proof is available in the request, the Holder Wallet Unit will verify it.
- In step 11, the Verifier Wallet Unit verifies the authenticity of the presented PID or attestation in the same way a Relying Party Instance does, as specified in Section 6.6.3.6. This implies that the Verifier Wallet Unit needs to obtain the trust anchors of the relevant PID Provider or Attestation Provider from the respective Trusted List or LoTE. Additionally, the Verifier Wallet Unit optionally also verifies the revocation status of the presented PID or attestation as specified in Section 6.6.3.7.

6.6.5 PID or attestation presentation to an intermediary

Section 3.11.4 introduced intermediaries, which are a special category of Relying Party. An intermediary interacts with a Wallet Unit to request User attributes on behalf of another (intermediated) Relying Party. The current section explains the interactions between the intermediated Relying Party, the intermediary, and the Wallet Unit in the course of such an interaction.

1. The intermediary registers once as a Relying Party with a Registrar (see Section 3.17) and obtains one or more access certificate(s) (see Section 3.18) bearing its own Relying Party identifier and trade name and Relying Party Service identifier and trade name. These access certificates are not different from an access certificate issued to a 'normal' Relying Party, since an intermediary is, as a matter of legal fact, a Relying Party. As explained in Section 3.11.3, an intermediary needs a separate access certificate for each of its Relying Party Instances.

   Moreover, according to the (amended) CIR 2025/848, Annex IV, point 3(k), an access

certificate for an intermediary contains “an association to the wallet-relying party that is relying upon the intermediary to whom the wallet-relying party access certificate has been issued and that is acting on behalf of the relying party who intends to rely upon the wallet.” This implies that an intermediary receives a separate set of access certificates for each of its intermediated Relying Parties. For example, if an intermediary has 100 Relying Party Instances and 1000 customers (intermediated Relying Parties), it will need to request and manage 100.000 access certificates.

In addition, the intermediary receives one or more registration certificate (see Section 3.19). However, these registration certificates will not be used in intermediated transactions.

2. Next, the intermediary tries to find customers, meaning Relying Parties that want to use the intermediary’s services to connect to Wallet Units and request User attributes on their behalf. If Relying Parties signs up with them, the intermediary ensures that they are registered in the Member State where they are established; as described in Section 6.4.2. The intermediary also ensures that it receives a registration certificate for each of the registered intended uses of the intermediated Relying Party. Finally, the intermedia also registers the new intermediated Relying Party with its own Registrar, see the (amended) CIR 2025/848, Annex I, point 16.

   Note that it is up to each Registrar to design a suitable process to achieve these goals. For example, it may decide an intermediary can register the intermediated Relying Parties at the Registrar, and receive the registration certificates in return. Alternatively, the Registrar could request the intermediated Relying Parties register themselves and indicate the intermediary they will be using, in which case they will receive the registration certificates and must send them to the intermediary. Alternative processes can be used as well.

   The registration certificates of the intermediated Relying Party show that it uses the services of the intermediary; both entities are identified by their unique Relying Party identifier and Service identifier. Before registering this relationship between an intermediary and an intermediated Relying Party and issuing a registration certificate attesting to this, a Registrar ensures it obtains legally valid evidence that this particular Relying Party will indeed use the services of this particular intermediary to interact with Wallet Units. A Registrar is free to decide which evidence it needs and how it obtains this evidence. For example, the Registrar could require either the intermediary or the Relying Party to provide a signed copy of the contract between both parties. Alternatively, the

Registrar could ask an authorised representative of the Relying Party to sign off on a registration that was done by the intermediary, or could ask for a legally valid mandate from the intermediated Relying Party to the intermediary to register the Relying Party.

3. When asked by an intermediated Relying Party, the intermediary will request a presentation of attributes from a Wallet Unit, using one of the flows described in Section 4.4. For this, the intermediary will use its own access certificate (containing the association to the intermediated Relying Party, see point 1. above) and the registration certificate of the intermediated Relying Party (point 2. above).
4. If the Wallet Unit sees in the registration certificate that the Relying Party uses the services of an intermediary, it verifies that the identifier and Service identifier of the intermediary listed in the `usesIntermediary` field of the registration certificate are identical to the identifier and Service identifier listed in the access certificate. If this verification is not successful, the Wallet Unit informs the User and, depending on the Wallet Provider's security policy, may stop the transaction. If the verification is successful, the Wallet Unit displays only the trade name of the intermediated Relying Party, together with the trade names of its Service, to the User when asking for User approval to present the requested attributes. >Note: The Wallet Unit does not display the trade names of the intermediary and its Service to the User, because the intermediary operates on behalf of the intermediated Relying Party and is not a party in the use case taking place between the User and the Relying Party. The User would probably not expect or recognise the name of the intermediary or its Service, and may be confused if the Wallet Unit would show these names. However, the intermediary name and service are logged by the Wallet Unit, see Section 6.6.3.13, so the fact that an intermediary was used in the transaction is visible to the User.
5. When a Wallet Unit presents a PID or attestation to the intermediary, the intermediary carries out the verifications described in Section 6.6.3, if the intermediary has agreed to do so with the intermediated Relying Party. This means it may verify the authenticity of the PID or attestation, its revocation status, device binding (if expected), and User binding, as well as any combined presentation of attributes, if applicable. Note that a Relying Party is not obliged to carry out all of these verifications. Therefore, the intermediary and any Relying Party using its services must agree on what verifications the intermediary will carry out.
6. If these verifications are successful, the intermediary forwards the User attributes it

obtained from the Wallet Unit to the intermediated Relying Party. There must be an interface between an intermediary and a Relying Party, over which the intermediated Relying Party can request the intermediary to request some User attributes from a Wallet Unit and that the intermediary uses to send back the attribute values presented by the Wallet Unit. However, specifying this interface or the (security) requirements with which it needs to comply, is out of scope of the ARF. In particular, it is not required that the User attributes are end-to-end encrypted between the Wallet Unit and the intermediated Relying Party, such that an intermediary would not be able to see them.

7. The intermediary deletes any PIDs or attestations it obtained from the Wallet Unit, including any User attributes, immediately after it has sent the User attributes to the Relying Party. If the intermediary does not send any User attributes to the Relying Party, for example because one of the verifications in the previous step failed, the intermediary deletes the PIDs or attestations immediately after it has completed all necessary verifications.

Note that this approach implies that an intermediated Relying Party using the services of an intermediary will not need an access certificate.

For high-level requirements on intermediaries, see Topic 52.

6.6.6 PID or attestation management

6.6.6.1 Overview

Starting from the issuance of a logical PID or attestation, the PID or attestation is managed by the User and the PID Provider or Attestation Provider. Management is performed until the PID or attestation is deleted by the User (see Section 6.6.7) or the Wallet Instance is uninstalled by the User (see Section 6.5.5). Management includes at least the following processes:

1. Re-issuance of technical PIDs or attestations when necessary.
2. Deletion of an unusable technical PID or attestation, typically after it has been replaced in a re-issuance process.
3. Revocation of the PID or attestation when necessary.

These processes are discussed in the next subsections.

6.6.6.2 PID or attestation re-issuance

6.6.6.2.1 Introduction

Re-issuance means the replacement of a technical PID or attestation that already exists in a Wallet Unit by a technical PID or attestation having the same attestation type. Moreover, the existing and the new technical PID or attestation represent the same logical PID or attestation, see Section 5.3.Re-issuance is therefore always performed by the same PID Provider or Attestation Provider that issued the existing PID or attestation. Re-issuance is always initiated by the Wallet Unit, although the User may prompt the Wallet Unit to start the process, and the PID Provider or Attestation Provider may tell the User that re-issuance is necessary.

The value of the attributes in the new PID or attestation will typically be the same as in the original PID or attestation. However, this is not required; the PID Provider or Attestation Provider may change one or more attribute values, and this may actually be the reason for re-issuance.

Note that, in general, if the logical PID or attestation was originally issued in the form of a batch of technical PIDs or attestations, then the PID Provider or Attestation Provider will re-issue a batch of technical PIDs or attestations as well.

Re-issuance is only applied within the administrative validity period of a logical PID or attestation, if applicable. As an example, a mobile driving licence (mDL) will be issued in the form of technical attestations which typically have a technical validity period shorter than the administrative validity period of the licence itself. Re-issuance is used for obtaining fresh technical attestations as needed during the administrative validity period, to ensure that the User can always present a valid mDL. When the administrative validity period ends, there will be an administrative process for obtaining a new driving licence, which is however out of scope of this document. Note that not all logical PIDs and attestations have an administrative validity period. For example, a diploma often has no expiry date, nor will a voucher (since it will typically be usable only once).

There may be different reasons for re-issuing a PID or attestation, for example:

- The current technical PID(s) or attestation(s) are near the end of their technical validity period, or the Wallet Unit is running out of once-only attestations. A short technical validity period or a requirement that an attestation can be presented only once are used to mitigate the risk of Relying Party linkability. For more information, see Section 7.4.3.5.
- The value of one or more of the attributes in the logical PID or attestation has changed.

- The security architecture of the Wallet Solution uses PIDs and/or attestations that are issued just-in-time, at the moment that PID or attestation is being requested by a Relying Party. This is sometimes called synchronous issuing.

These reasons are discussed in the next subsections. Re-issuance is discussed in more detail in the Discussion Paper for Topic B.

6.6.6.2.2 Re-issuance to limit Relying Party linkability

As specified in ISO/IEC 18013-5 or SD-JWT VC, each technical PID or attestation contains metadata indicating its technical validity period. Determining the length of the technical validity period is the responsibility of the PID Provider or the Attestation Provider. The technical validity period chosen by the PID Provider or Attestation Provider will depend on several factors, primarily the security architecture of the Wallet Solution and the strategy chosen to mitigate Relying Party linkability, see Section 7.4.3.5.

Given the above factors, it can generally be assumed that the technical validity period of a PID or attestations will be much shorter than the lifetime of the corresponding logical PID or attestation, meaning the period of time that a User wants to keep that PID or attestation in their Wallet Unit. That implies that new technical PIDs and attestations will need to be re-issued periodically, to replace the ones that are reaching end of their technical validity.

A similar reason for re-issuing PIDs and attestations occurs when the PID Provider or Attestation Provider uses once-only attestations (see Section 7.4.3.5), which can be presented only once to a Relying Party. In that case, the Wallet Unit, or rather the User, will regularly need new technical PIDs or attestations to avoid running out and to remain able to use the logical PID or attestation.

Re-issuance of PIDs or attestations for these reasons is a purely technical matter. To the maximum extent possible, the User does not notice that new technical attestations have been issued for their logical PID or attestation, nor do they have to take any action to ensure that re-issuance happens in time. These conditions are very different from a first-time issuance of a PID or attestation, where the User must take the initiative to request the PID or attestation, and is potentially involved in the process in other ways as well.

This implies, among other, that no User authentication takes place during re-issuance for an existing logical PID or attestation. Nevertheless, a Wallet Unit may offer the User the option to receive a notification of re-issuance.

In the absence of User authentication, and to prevent that a re-issued technical PID or attestation ends up at the wrong User, the PID Provider or Attestation Provider ensures that a

re-issued PID or attestation is issued to same Wallet Unit as the technical PID or attestation it replaces. This can be done by the use of device-bound refresh tokens, see OpenID4VCI.

Finally, since the User is not involved, it is the Wallet Unit itself that triggers the re-issuance of PIDs and attestations when necessary.

6.6.6.2.3 Re-issuance because of a change of attribute values

During the lifetime of a logical PID or attestation, the value of some of the attributes may change. For example, at the date of birth of the User, an age attestation attribute (i.e., an attribute indicating whether the User has reached a certain age) may have to be changed from value False to value True. In another example, the User of a mobile driving licence may have passed the examination for a different vehicle category. In this case, the PID Provider or Attestation Provider re-issues technical PID(s) or attestation(s) with the correct attribute values, and revokes the existing technical attestation(s).

Re-issuance of a PID or attestation for this reason will have an impact on the User, because they will notice that their attribute values have been changed. Therefore, in this case Users will be informed when re-issuance happens. Additionally, an Attestation Provider may state in their terms of conditions that re-issuance of an attestation may be used.

6.6.6.2.4 Re-issuance when using synchronous issuing

A third reason for re-issuing a technical PID or attestation is where the PID Provider or Attestation Provider uses synchronous issuing in their security architecture. In such an architecture, the Wallet Unit requests the re-issuance of a new technical PID or attestation **after** it has received a request for presentation of the corresponding logical PID or attestation from a Relying Party. Such a technical PID or attestation is very short-lived and is used only once.

The conditions on User awareness and authentication discussed in Section 6.6.6.2.2 are also valid for a synchronous re-issuance process.

6.6.6.3 Deletion of unusable technical PIDs or attestations

Some time after it is issued, a technical PID or attestation will become unusable, in the sense that the User cannot present it any longer to a Relying Party. For example, it expires, or a once-only PID or attestation (see Section 7.4.3.5) has been presented to a Relying Party already. Typically (but not always), such a technical PID or attestation will already have been replaced in a re-issuance process as described in Section 6.6.6.2.2.

Wallet Providers need to decide what to do with unusable technical PIDs or attestations. Non-device-bound attestation can be simply deleted, but for PIDs and device-bound attestations this is more complicated, as the Wallet Provider needs to manage the associated private keys in the WSCA/WSCD or keystore of the Wallet Unit. Typically, the amount of storage space available in a WSCA/WSCD or keystore is limited, and Wallet Providers will want to delete these keys to prevent an accumulation of unused private keys. Deletion of cryptographic assets in the WSCA/WSCD in particular is a cryptographic key operation and cannot be done without User authentication by the WSCA/WSCD; see Section 6.5.3.3. At the same time, for usability reasons the User should not be involved in such 'cleaning up' processes, just like the User does not have to take any action for re-issuance processes (Section 6.6.6.2.2).

The recommended solution for this challenge is to ensure that, whenever the WSCA/WSCD successfully authenticates the User, the Wallet Unit checks if there are any technical PIDs or device-bound attestations that cannot be presented any longer to Relying Parties. The Wallet Unit then requests the WSCA/WSCD to destroy all cryptographic key material in the WSCA/WSCD related to these PIDs or attestations. Thus, the Wallet Unit takes advantage of the fact that the User authenticates for another purpose, for example because they want to present a PID, to also carry out any necessary key deletion operations. A last aspect of this to be mentioned here is that the Wallet Unit will not delete the last technical PID or attestation corresponding to a logical PID or attestation, even when it is no longer usable. This is because that would mean the corresponding logical PID or attestation is deleted from the Wallet Unit. Instead, the Wallet Unit keeps such a last technical PID or attestation and keeps trying to trigger the re-issuance of new ones. See also Topic 40 in Annex 2.

6.6.6.4 PID or attestation revocation

PID or attestation management includes ensuring that PIDs and attestations can be revoked if necessary. The User can request the PID Provider or Attestation Provider to revoke the logical PID or attestation at least in case of loss or theft. The PID Provider or Attestation Provider can also decide itself to revoke a logical PID or attestation, for example in case the Wallet Unit on which the associated technical PIDs or attestations are residing is revoked; see Section 6.5.3.4, or for any other valid reason outside the scope of the EUDI Wallet ecosystem.

Revoking a logical PID or attestation implies that all technical PIDs or attestations associated with that logical PID or attestation will be revoked if they are still valid for more than 24 hours. Revocation of technical PIDs and attestations is discussed in Topic 7.

In addition to revoking a technical PID or attestation, a PID Provider or Attestation Provider can revoke the certificate that it used for signing that PID or attestation, or any intermediate certificate between that signing certificate and the corresponding trust anchor. In all of these cases, a Relying Party that performs revocation checking will not accept the technical PID or attestation.

6.6.7 PID or attestation deletion

In case the User no longer wants to retain a specific logical PID or attestation in their Wallet Unit, the User can delete it. If the PID Provider or Attestation Provider issued a batch of multiple technical PIDs or attestations corresponding to the logical attestation, the Wallet Unit deletes them all. Deleting a technical PID or a device-bound attestation also means that the WSCA/WSCD or keystore destroys the cryptographic key material associated with that PID or attestation. Before deleting critical assets of a PID, the WSCA/WSCD included in the Wallet Unit will authenticate the User.

The Wallet Unit also discloses the fact that it no longer contains the PID or attestation to the W3C Digital Credentials API framework, see Section 4.4.3.

For high-level requirements on this topic, see Topic 51.

7 Wallet Solution Certification and Risk Management

7.1 Introduction

This chapter briefly describes the certification of Wallet Solutions and the eID schemes under which they are provided, covering the overall certification approach, design principles, and main requirements outlined in the European Digital Identity Regulation and Commission Implementing Regulation CIR 2024/2981 laying down rules for on the certification of Wallet Solutions. Furthermore, references are made to the Annex I of CIR 2024/2981, and to the Risk Register supporting the risk-based approach of the Wallet Solutions. For more detailed requirements, please refer to CIR 2024/2981 itself.

The European Digital Identity Regulation requires certification of Wallet Solutions to ensure conformity of the Wallet Solutions with functional, security, and privacy-related requirements, to achieve a high level of interoperability, security, and trustworthiness. Certification applies to the Wallet Solutions and the eID schemes under which they are provided; for ease of reading

this chapter only refers to Wallet Solutions. Furthermore, the object of certification includes software components, hardware components (in cases where they are provided directly or indirectly by the Wallet Provider) and the processes that support the provision and operation of a Wallet Solution, such as Wallet Unit activation, see Section 6.5.3.

The aim is to harmonise the implementation of the requirements laid down by the European Digital Identity Regulation and avoid divergent approaches to the maximum extent possible. For this reason, the Commission requested ENISA to prepare a candidate European certification scheme under the Cybersecurity Act (CSA). As defining and adopting a dedicated, harmonised certification scheme for Wallet Solutions depends on agreements between Member States on detailed security requirements, on the availability of underlying certification schemes, and on established good practices in the Member States themselves, a transitory approach is foreseen by means of national certification schemes.

In other words, the certification approach for Wallet Solutions follows two phases. In the short-term, Member States provide national (transitory) certification schemes. In the medium term, a harmonised CSA scheme will be established. When the CSA-based scheme becomes available, it replaces the national schemes as for cybersecurity requirements. The schemes may continue to exist for functional requirements.

7.2 Certification of Wallet Solutions against national certification schemes

Until a dedicated Wallet Solution cybersecurity certification scheme under the CSA is available, the European Digital Identity Regulation requires Member States to establish national certification schemes. This will be done in time to make available the Wallet Solutions before the end of 2026. The Commission has adopted the CIR 2024/2981 to provide the main requirements on Member States for creation of national certification schemes. The CIR 2024/2981 and resulting national certification schemes are defined around a number of guiding principles:

First, the goal is to **harmonise** requirements to the extent possible. Member States are also encouraged to work together in the design and implementation of national schemes. Additionally, national schemes will leverage the use of **relevant and existing certification schemes and standards** for Wallet Solution certification and evaluation. Where available, relevant European CSA schemes must be used. Currently, only the Common Criteria-based European candidate cybersecurity certification EUCC scheme is available for the cybersecurity certification of ICT products, parts, or components for products. Upcoming CSA-based schemes include EUCS and EU5G. Additionally, other existing or upcoming schemes include

schemes based on FITCEM (EN 17640), national schemes such as on remote identity verification, or other private schemes (e.g. for mobile devices and apps). For harmonisation of functional requirements, the Commission Implementing Regulations (CIRs) adopted under the European Digital Identity Regulation article 5(a) are referenced. For harmonisation of certification requirements, the [ISO/IEC 17065] framework under Regulation [765/2008] is used, complemented by [ISO/IEC 17067] on the definition of schemes.

Next, the CIR 2024/2981 refers to the **composite nature** of the Wallet Solutions as well as the potential different architectures in Member States, considering that the European Digital Identity Regulation is technology (and architecture) neutral. This means that a final ('top-level') certification of the Wallet Solution will yield a composite certificate, built on certification of separate components, such as EUCC certification. Wallet Solutions are always to be certified against assurance level High, as set out in the European Digital Identity Regulation as well as CIR (EU) 2015/1502. That assurance level has to be reached by the overall Wallet Solution. Under this Regulation, some components of the Wallet Solution may be certified at a lower assurance level, provided this is duly justified and without prejudice to the assurance level High reached by the overall Wallet Solution. For the use of assurance information from other certification schemes or sources, a dependency analysis will be performed.

Finally, in order to ensure a harmonised approach to cybersecurity and the assessment of the most critical risks that might affect the provision and operation of Wallet Units, a **register of risks and threats** is defined, see Section 7.4. The Risk Register contains high level risks and threats in relation to Wallet Solutions and the ecosystem, as well as detailed threat scenarios that will be taken into consideration when designing Wallet Solutions, independent of their specific architecture.

As a first step towards certification of Wallet Solutions under national schemes, Member States will assign a scheme owner, and design and roll out the scheme. As part of this process, Conformity Assessment Bodies (CABs) will be accredited to carry out conformity assessments of Wallet Solutions against the requirements of the CIR 2024/2981 and the national scheme. Wallet Providers then request one or more designated CABs to assess and certify the conformity of their Wallet Solution. The CAB evaluates and certifies the conformity of the Wallet Solution if they meet the requirements.

The European Commission and ENISA support Member States in designing and implementing national certification schemes in the Cooperation Group.

Once a Wallet Solution has been certified, the Member State submits information about that certification to the Commission and the Cooperation Group in accordance with CIR

2025/849.

7.3 Certification of Wallet Solutions against a dedicated CSA-based scheme

In parallel to the work described above, ENISA is requested to draft a dedicated European cybersecurity certification scheme for the Wallet Solutions under the CSA. Once available, this CSA-based scheme will replace the national transitory schemes mentioned above for the cybersecurity requirement it covers. This scheme will be based on available national schemes and harmonised requirements. It will identify any additional requirements relevant for cybersecurity. The scheme will further detail the cybersecurity requirements, identify and set normative standards, and define the target level of assurance or security for the relevant Wallet Solution components.

The work to develop the CSA-based scheme follows the milestones set out by the CSA and is supported by the Ad Hoc Working Group or 'AHWG'. This group is composed of selected experts from private organisations and industry, with extensive knowledge and experience in the areas of cybersecurity certification, digital wallets, electronic identification, and trust services. The first step is to have a candidate scheme ready for public consultation and submitted for feedback of the European Cybersecurity Certification Group or ECCG. The ECCG's opinion serves as advisory input to ensure the candidate scheme aligns to EU cybersecurity objectives, standards and regulatory requirements. Although the ECCG's opinion is not binding, it will hold significant influence, as it reflects the collective expertise of national cybersecurity authorities, aiming to harmonise cybersecurity certification practices across Member States. Based on this input, the candidate scheme might be updated further. After finalisation of the ECCG opinion, the scheme will be transformed into a new Implementing Regulation and adopted by comitology procedure.

Finally, ENISA is also asked to facilitate the transition from national certification schemes to the dedicated cybersecurity certification scheme under the CSA.

7.4 Risk-based approach and risk register

7.4.1 Introduction

This section details the approach to develop harmonised guidelines for the development of the transitory national certification schemes. In addition to the requirements set out in the European Digital Identity Regulation article 5c, cybersecurity risks and threats associated with

the Wallet Solutions will be identified. Here, a risk-based approach is envisioned as the basis for certification by Member States, ensuring that the Wallet Solutions uphold confidentiality, availability, and strong safeguards for User privacy and data protection. This is inspired by known processes, such as for the General Data Protection Regulation (GDPR) and related Data Protection Impact Assessments (DPIA).

The risk-based approach sets out a common Risk Register that contains a comprehensive but non-exhaustive list of risks and threats related to the Wallet Solution. These risks and threats are architecture-agnostic and provide a benchmark overview of the most critical risks and threats to Wallet Solutions. By adopting this common set of risks and threats, national transitory certification schemes will achieve a baseline level of harmonisation.

The risk register will be applied by scheme owners, Wallet Providers, and Conformity Assessment Bodies. When establishing their certification schemes, scheme owners will perform a risk assessment to refine and complement the risks and threats listed in the register with those specific to their architecture, and consider how the applicable risks and threats can be appropriately treated. Wallet Providers will complement the scheme's risk assessment to identify any risks and threats specific to their implementation and propose appropriate mitigation measures for evaluation by the CAB.

7.4.2 High-level risks and threats

The following is an excerpt from Risk Register. To keep in line with the continuously evolving threat landscape, the risk register will be maintained and regularly updated in collaboration with the Cooperation Group.

High-level risks and threats

- R1 Creation or use of an existing electronic identity
- R2 Creation or use of a fake electronic identity
- R3 Creation or use of fake attributes
- R4 Identity theft
- R5 Data theft
- R6 Data disclosure
- R7 Data manipulation
- R8 Data loss
- R9 Unauthorised transaction
- R10 Transaction manipulation

- R11 Repudiation
- R12 Transaction data disclosure
- R13 Service disruption
- R14 Surveillance

System-related risks

- SR1 Wholesale surveillance
- SR2 Reputational damage
- SR3 Legal non-compliance

Technical threats

- TT1 Physical attacks
  - 1.1 Theft
  - 1.2 Information leakage
  - 1.3 Tampering
- TT2 Errors and misconfigurations
  - 2.1 Errors made when managing an IT system
  - 2.2 Application-level errors or usage errors
  - 2.3 Development-time errors and system misconfigurations
- TT3 Use of unreliable sources
  - 3.1 Erroneous use or configuration of wallet components
- TT4 Failure and outages
  - 4.1 Failure or dysfunction of equipment, devices or systems
  - 4.2 Loss of resources
  - 4.3 Loss of support services
- TT5 Malicious actions
  - 5.1 Interception of information
  - 5.2 Phishing and spoofing
  - 5.3 Replay of messages
  - 5.4 Brute-force attack
  - 5.5 Software vulnerabilities
  - 5.6 Supply chain attacks
  - 5.7 Malware
  - 5.8 Random number prediction

7.4.3 Risks and mitigation measures discussed in Chapter 6 of this ARF

7.4.3.1 Introduction

This section briefly discusses some of the risks that were considered when the trust model in Chapter 6 was created, together with the mitigations for these risks and the residual risks that remain after these mitigations. This section is not intended to be a comprehensive risk register for the EUDI Wallet ecosystem as a whole; for that register, see Risk Register and Section 7.4.2 above. This section is limited to the scope of the ARF, namely, the Wallet Unit and its interactions with other entities in the ecosystem, as depicted in Figure 12 in Chapter 6.

7.4.3.2 Risks and mitigation measures related to confidentiality, integrity, and authenticity

Within the EUDI Wallet ecosystem, many interactions take place between entities in which one entity requests another entity to perform a task. For example, a User may ask a PID Provider or an Attestation Provider to provide a PID or an attestation to a Wallet Unit, or a Relying Party may ask a User to present attributes from an attestation in their Wallet Unit. For any of these interactions, the following risks apply:

- An attacker could impersonate one of the interacting entities. Therefore, the receiver of a message must be able to verify the identity of the sender, and vice versa. In other words, mutual authentication is needed. This authentication can be performed because valid entities in the EUDI Wallet ecosystem are put on a Trusted List or List of Trusted Entities (LoTE); see Section 3.5. By verifying the signature over a message and verifying the associated public key certificates with a trust anchor included in a Trusted List or LoTE, the receiver of a message can be sure about the identity of the message's sender.
- Messages between entities could be intercepted, meaning that they could be read by an attacker. To mitigate this risk, messages must be encrypted to ensure confidentiality.
- Intercepted messages could be changed by an attacker. To mitigate this risk, messages must be authenticated, so that the receiver can verify that they originate from the authenticated sender and were not changed.

7.4.3.3 Risks and mitigation measures related to tampering of cryptographic keys and sensitive data

The mechanisms for authentication and confidentiality described in the previous section rely on the security of cryptographic keys, especially private and secret keys. If an attacker can obtain, use, or tamper with these keys, these security mechanisms would break down. Therefore, all critical assets on Wallet Units are managed by dedicated secure applications (WSCAs), running on secure hardware (WSCDs), as described in Section 4.3. The security of WSCDs and WSCAs is ensured by means of an appropriate certification process.

Similar mitigation measures apply for all other entities in the EUDI Wallet ecosystem that use cryptographic keys, including Wallet Providers, PID Providers and Attestation Providers, Trusted List Providers and LoTE Providers, Providers of registration certificates, and Access Certificate Authorities. Such parties will typically use a certified Hardware Security Module (HSM) for managing private and secret keys. For Relying Parties and Relying Party Instances, such measures are formally not required.

A WSCA/WSCD or keystore in a Wallet Unit may also be used to store sensitive data other than cryptographic keys. In particular, they could be used to store User attributes, in such a way that attackers, including malicious applications residing on the same User device as the Wallet Instance, cannot retrieve these attributes. This could be beneficial for User privacy.

7.4.3.4 Risks and mitigation measures related to authorisation

In certain cases, there is a risk that a legitimate entity within the EUDI Wallet ecosystem may attempt to perform actions beyond its authorised scope. This risk primarily affects two types of actors:

First, a Relying Party in the EUDI Wallet ecosystem may attempt to request attributes from a Wallet Unit that it does not reasonably need for its use case. This risk of 'overasking' is mitigated by three measures:

1. **Selective Disclosure and User Control** - The attestation formats and protocols specified in ISO/IEC 18013-5 and SD-JWT VC (in combination with OpenID4VP) enable selective disclosure of attributes. This allows a Relying Party to specify which attributes within an attestation it wishes to receive while excluding others, a feature known as *collection limitation*. Additionally, selective disclosure ensures that the User retains control over their data, as they can approve or deny the presentation of requested attributes. More details on selective disclosure and User approval can be found in Section 6.6.3.5.
2. **Mandatory Relying Party Registration of Attributes Intended to be Requested** - The European Digital Identity Regulation mandates that each Relying Party must register

the attributes it intends to request from Wallet Units. According to CIR 2024/2982, the Member State Registrar publishes the data registered about each Relying Party in a publicly accessible register, both in a human-readable and machine-readable format. The Registrar also includes these registered attributes in a Relying Party registration certificate, which it issues to the Relying Party. The Relying Party then includes this registration certificate in the presentation request, such that the Wallet Unit can use it to verify the legitimacy of the request and inform the User accordingly. This transparency ensures that Users can make an informed decision about whether to approve or deny the presentation of the requested attributes. More details on this requirement can be found in Section 6.6.3.3.

3. **Attestation Provider Disclosure Policy Enforcement** - The European Digital Identity Regulation also mandates that Attestation Providers can embed a disclosure policy within their attestations. This policy may include rules governing whether the Attestation Provider approves the presentation of this attestation to an authenticated Relying Party. The Wallet Unit evaluates this policy —if present— using authenticated data in the registration certificate of the Relying Party, and informs the User of the outcome. This mechanism further supports the User in making a well-informed decision on whether to approve or deny attribute presentation. More information on disclosure policy enforcement can be found in Sections 6.6.2.8 and 6.6.3.4.

Second, an Attestation Provider may attempt to issue attestations for which it lacks the necessary authorisation. For example, an Attestation Provider that has not been officially designated by a Member State or another relevant authority to issue diplomas may still attempt to generate an attestation of the diploma type. Wallet Units can mitigate this risk in a manner similar to the one described in the second bullet point above, by inspecting the registration certificate of the Attestation Provider before requesting that Attestation Provider to issue an attestation to the Wallet Unit. Relying Parties can query the online service of the Registrar after receiving an attestation issued by a specific Attestation Provider, to verify that the Attestation Provider is registered for issuing that type of attestation.

7.4.3.5 Risks and mitigation measures related to User privacy

7.4.3.5.1 Linkability

User privacy is a very important consideration in the design and implementation of the EUDI Wallet ecosystem. An important aspect of privacy is unlinkability. Unlinkability implies that, if

a User presents attributes from an attestation multiple times, the receiving Relying Parties cannot link these separate presentations to conclude that they concern the same User.

Within the EUDI Wallet ecosystem, attributes are presented in electronic attestations containing unique, fixed elements such as hash values, salts, public keys, and signatures. Malicious Relying Parties could exploit these values to track Users by storing and comparing them across multiple transactions, identifying recurring patterns. This privacy threat, known as **Relying Party linkability**, can occur within a single Relying Party or among colluding entities. It can also occur when a third party attacks the systems of one or more Relying Parties, resulting in a data breach. For that reason, Relying Parties will discard the unique fixed elements in received attestations as soon as they no longer need these elements.

A similar privacy threat arises when colluding Relying Parties share the unique values they obtained from an attestation with a malicious PID Provider or Attestation Provider. This allow the PID Provider or Attestation Provider to track User activity across multiple services. This form of linkability is called **Attestation Provider linkability**.

This topic is discussed in more detail in the Discussion Paper for Topic A.

7.4.3.5.2 Mitigating Relying Party linkability

Regarding the mitigation of Relying Party linkability: A trustworthy PID Provider or Attestation Provider can mitigate Relying Party linkability fully by issuing multiple technical PIDs or attestations to the same Wallet Unit, all representing the same logical PID or attestation. (For the difference between logical and technical attestations, see Section 5.3.)

Wallet Units can use these technical attestations as disposable (single-use) attestations, which ensures attestations can never be linked by Relying Parties. Topic 10 in Annex 2 calls this **method A**, 'once-only attestations', and requires Wallet Solutions to support this method. It also specifies how a PID Provider or Attestation Provider can indicate that they want a Wallet Unit to treat their PIDs or attestations in this way.

However, the 'once-only' approach increases issuance complexity and management overhead. Therefore, Topic 10 also mandates support for another solution, where technical PIDs and attestations are valid for a limited time only. This limits the number of technical PIDs and attestations to be issued, but only partially mitigates Relying Party linkability. Topic 10 calls this **method B**, 'limited-time attestations'.

Furthermore, Topic 10 describes two other approaches, which are optionally supported by Wallet Solutions, namely:

- the Attestation Provider issues technical attestations in batches to the Wallet Unit. The Wallet Unit then uses the attestations from a batch in a random order, until it has presented all attestations in the batch once. Then it 'resets' the batch and starts using them again in a random order. Topic 10 calls this **method C**, 'rotating-batch attestations'.
- the Wallet Unit will present different technical attestations to different Relying Parties. However, in case a Relying Party requests attributes from this attestation multiple times, the Wallet Unit will present the same attestation to this Relying Party each time. Topic 10 calls this **method D**, 'Per-Relying Party attestations'.

Additionally, organisational and enforcement measures can help deter Relying Parties from colluding and tracking Users. In particular, Relying Parties found in violation will have their access certificates revoked, preventing them from further interactions with Wallet Units.

7.4.3.5.3 Zero-Knowledge Proofs

> **NOTE: Discussions on Zero-Knowledge Proofs (ZKPs) are ongoing. No specific ZKP has been selected to be supported by components in the EUDI Wallet ecosystem. For more information, see**
>
> - **Technical Specification 4 Specification for ZKP Implementation in EUDI Wallet,**
> - **Technical Specification 13 Specification for the implementation of Zero-Knowledge Proofs based on arithmetic circuits in the EUDI Wallet, and**
> - **Technical Specification 14 Specification for the implementation of Zero-Knowledge Proofs based on multi-message signatures in the EUDI Wallet.**

Unlike Relying Party linkability, Attestation Provider linkability cannot be fully eliminated when using attestation formats using a proof mechanism based on salted hashes. The only viable mitigation is to adopt Zero-Knowledge Proofs (ZKPs) as a proof mechanism instead of relying on salted-attribute hashes. A Zero-Knowledge Proof (ZKP) is a cryptographic protocol that allows one party (the prover) to convince another party (the verifier) that a given statement is true without revealing any additional information beyond the validity of the statement itself. This ensures that the verifier gains no knowledge about how the prover knows the statement to be true, thus preserving privacy while enabling trust.

However, the integration of ZKPs in the EUDI Wallet ecosystem is still under discussion and development, due to the complexity of implementing ZKP solutions in secure hardware and

the lack of support in currently available secure hardware (WSCDs). As with Relying Party linkability, organisational and enforcement measures can help deter Attestation Providers from colluding and tracking Users. Additionally, many Attestation Providers are subject to regular audits, making it easier to detect collusion and tracking compared to Relying Parties.

Zero-Knowledge Proof (ZKP) mechanisms for verifying personal information are highly promising and essential for ensuring privacy in various use cases. They enable Users to prove statements such as "I am over 18" without disclosing any personal data, offering a robust solution for privacy-preserving authentication and verification.

One area of development is age verification, where the European Commission is actively exploring and testing ZKP-based solutions. The outcomes of this initiative could pave the way for the adoption of ZKPs within the EUDI Wallet ecosystem, further strengthening privacy protections in future implementations.

The Discussion Paper for Topic G (Zero-Knowledge Proofs) presents the (desired) privacy properties of Zero-Knowledge Proof schemes. It introduces the main families of Zero-Knowledge Proof schemes and gives an overview of representative solutions. Finally, it discusses topics related to the integration of Zero-Knowledge Proof schemes into the EUDI Wallet ecosystem.

High-level requirements for Zero-Knowledge Proofs to be used in the EUDI Wallet ecosystem are included in Topic 53 of Annex 2.

7.5 Functional conformance (FCAF)

Section 7.2 and Section 7.3 address the certification of Wallet Solutions against cybersecurity requirements. In addition, the European Digital Identity Regulation and CIR 2024/2981 require conformity assessment of the **functional requirements** that Wallet Solutions must support. These are defined in the Commission Implementing Regulations referenced in Annex III of CIR 2024/2981, in particular:

- integrity and core functionalities — CIR 2024/2979;
- protocols and interfaces — CIR 2024/2982; and
- person identification data and electronic attestations of attributes — CIR 2024/2977.

To harmonise how these requirements are assessed during certification, the European Commission and the Member States, through the EDICG, are establishing the **Functional Conformance Assessment Framework (FCAF)**, published and maintained at conformance.eudi.dev.

The FCAF provides a shared, transparent, and reusable set of test cases and supporting framework content that Conformity Assessment Bodies (CABs), test laboratories, Wallet Providers, tool vendors, and other stakeholders can apply consistently.

The FCAF's overriding goal is **interoperability**: a Wallet Unit, PID Provider, Attestation Provider, or Relying Party built to the same tested requirements should work with any other, across implementations and Member States. Its objectives are to:

- **drive interoperability**, so that independently built components operate together seamlessly;
- **prevent market fragmentation**, by giving every stakeholder a single, shared set of test cases and expected results;
- **make conformance testing coherent and comparable**, so that results from different CABs and test laboratories are consistent and reproducible;
- **ensure uniform adherence to the functional and functional-security requirements** set out in the applicable CIRs, standards, and technical specifications;
- **reduce certification costs and duplication**, by making the test material reusable across schemes and Member States; and
- **increase transparency and auditability** of the testing process.

The FCAF assesses functional conformance only: it demonstrates that a Wallet Solution behaves as required by the applicable standards, technical specifications, profiles, and regulatory requirements, and that it can interoperate within the EUDI Wallet ecosystem. This covers both:

- **external interfaces** of the Wallet Solution, for example towards PID Providers and Attestation Providers, Relying Parties, and infrastructure components; and
- **internal functional requirements** that cannot be validated through a standardised external interface, and which may therefore require structured manual testing or observation of behaviour — for example, a Wallet Unit requesting User approval before sharing attributes with a Relying Party.

Functional conformance is therefore one component of the national EUDI Wallet certification schemes, and complements rather than replaces the security evaluation in Section 7.2 and Section 7.3: the FCAF supplies the test cases for the functional requirements, but does not by itself provide cybersecurity assurance, nor does it cover non-functional testing such as performance, scalability, penetration, or availability testing. The other components defined in CIR 2024/2981 — including the cybersecurity and risk-based requirements described above

and the risk register referred to in European Digital Identity Regulation Article 5c — must also be met for full certification.

Finally, the FCAF neither provides nor mandates testing tools or execution environments; such tooling may be developed externally and used by CABs, test laboratories, or other implementers. Because the FCAF is developed and released independently of this ARF, this document does not reproduce its detailed structure or versioning; conformance.eudi.dev remains the authoritative and up-to-date source for its content.

8 Accessibility

8.1 Introduction

Accessibility of all User-facing components of the EUDI Wallet ecosystem, such as Wallet Units, websites, User authentication methods of PID Providers and Attestation Providers, and registries (see Section 3.17), is essential to ensure that these digital tools are inclusive by design and aligned with the applicable European legal and technical frameworks.

Accessibility is not only a matter of legal compliance but also a fundamental condition for equal access, User trust, and widespread adoption across all segments of the population, including persons with disabilities.

For high-level requirements on accessibility, please refer to Topic 54.

For more information, also see the Discussion Paper for Topic Q.

8.2 Legal instruments and standards

The following main legislative instruments and standards apply:

- Directive (EU) 2016/2102 on the accessibility of websites and mobile applications of public sector bodies. This Directive establishes a common framework to harmonise accessibility requirements across Member States, ensuring that digital public services, including mobile applications, are perceivable, operable, understandable, and robust for all Users. In particular, it requires compliance with ETSI EN 301 549 v1.1.2, which defines accessibility requirements for ICT products and services, covering web content, software, mobile applications, hardware interfaces, and documentation.

- Directive (EU) 2019/882, the European Accessibility Act (EAA). This Directive extends accessibility obligations to a wider range of products and services placed on the EU market, including digital services beyond the public sector. It sets essential accessibility requirements for economic operators, including service providers and manufacturers, ensuring that solutions such as Wallet Units are accessible to persons with disabilities throughout their entire lifecycle, from design and development to marketing and after-sales support.

8.3 Wallet Units and other User-facing components

Together, these legal instruments create a **coherent legal and normative environment** that supports the development of accessible Wallet Units and related components. Compliance with these frameworks is both a regulatory obligation and a driver of **innovation, social inclusion, and digital equality**.

It is therefore crucial that accessibility is integrated into:

- Technical specifications
- User interface design
- Testing processes
- Procurement criteria

for all elements of the Wallet ecosystem.

Member States and implementing entities should also ensure ongoing monitoring, effective feedback mechanisms, and continuous improvement of accessibility practices. This requires close collaboration with Users, accessibility experts, and organisations representing persons with disabilities, to guarantee that Wallet Units and other User-facing components remain usable, effective, and inclusive for all.

9 Document development

9.1 Publication and Lifecycle

The **Architecture and Reference Framework (ARF)** is developed by the **European Digital Identity Cooperation Group (EDICG)**, composed of experts from Member States and the Commission.

The ARF serves as the technical foundation for the **Implementing Acts (CIRs)**. While the Implementing Acts provide the legal requirements and mandatory standards, the ARF offers the detailed technical specifications and architectural patterns necessary for a harmonised implementation across the Union.

This document is made publicly available at the official GitHub repository. Updates are released periodically to reflect the evolution of technology and regulatory requirements.

9.2 Contributing and Community Engagement

The EDICG welcome active participation from the community. Engagement is managed through two main channels on GitHub:

- **Issues:** Used for specific technical corrections, bug reporting, and proposed text changes. Detailed etiquette and workflows are available in **CONTRIBUTING.md**.
- **Discussions:** Used for broader architectural debates, conceptual questions, and the "Discussion Topics" that inform future iterations of the Framework.

The EDICG reviews these contributions to ensure that the ARF remains aligned with the needs of Member States and the European Digital Identity ecosystem.

9.3 Document Versioning

To ensure interoperability and transparency, the ARF follows a version control system based on the Semantic Versioning scheme. Each release is published under the *MAJOR.MINOR.PATCH* format:

- **MAJOR** version is incremented (i.e., new version), when significant changes are introduced, particularly those involving breaking changes in the architecture or core protocols.

- **MINOR** version is incremented when new features, requirements, or information are added or removed without breaking existing architectural principles.
- **PATCH** version is incremented for minor adjustments, such as editorial corrections, formatting, or fixing typos.

10 References

10.1 Commission Regulations and Decisions

Item Reference	Regulation name/details
CID 2015/1505	Commission Implementing Decision (EU) 2015/1505 of 8 September 2015 laying down technical specifications and formats relating to trusted lists pursuant to Article 22(5) of Regulation (EU) No 910/2014 of the European Parliament and of the Council on electronic identification and trust services for electronic transactions in the internal market.
Directive 2016/2102	Directive (EU) 2016/2102 of the European Parliament and of the Council of 26 October 2016 on the accessibility of the websites and mobile applications of public sector bodies
Directive 2019/882	Directive (EU) 2019/882 of the European Parliament and of the Council of 17 April 2019 on the accessibility requirements for products and services
European Digital Identity Regulation	Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework

Item Reference	Regulation name/details
Risk Register	Commission Implementing Regulation (EU) 2024/2981, Annex I of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the certification of European Digital Identity Wallets
CIR 2024/2977	Commission Implementing Regulation (EU) 2024/2977 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards person identification data and electronic attestations of attributes issued to European Digital Identity Wallets
CIR 2024/2979	Commission Implementing Regulation (EU) 2024/2979 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the integrity and core functionalities of European Digital Identity Wallets
CIR 2024/2980	Commission Implementing Regulation (EU) 2024/2980 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards notifications to the Commission concerning the European Digital Identity Wallet ecosystem
CIR 2024/2981	Commission Implementing Regulation (EU) 2024/2981 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the certification of European Digital Identity Wallets

Item Reference	Regulation name/details
CIR 2024/2982	Commission Implementing Regulation (EU) 2024/2982 of 28 November 2024 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards protocols and interfaces to be supported by the European Digital Identity Wallet Framework
CIR 2025/846	Commission Implementing Regulation (EU) 2025/846 of 6 May 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards cross-border identity matching of natural persons
CIR 2025/847	Commission Implementing Regulation (EU) 2025/847 of 6 May 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reactions to security breaches of European Digital Identity Wallets
CIR 2025/848	Commission Implementing Regulation (EU) 2025/848 of 6 May 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the registration of wallet-relying parties
CIR 2025/849	Commission Implementing Regulation (EU) 2025/849 of 6 May 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the submission of information to the Commission and to the Cooperation Group for the list of certified European Digital Identity Wallets

Item Reference	Regulation name/details
CIR 2025/1566	Commission Implementing Regulation (EU) 2025/1566 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards for the verification of the identity and attributes of the person to whom the qualified certificate or the qualified electronic attestation of attributes is to be issued
CIR 2025/1567	Commission Implementing Regulation (EU) 2025/1567 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the management of remote qualified electronic signature creation devices and of remote qualified electronic seal creation devices as qualified trust services
CIR 2025/1568	Commission Implementing Regulation (EU) 2025/1568 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards procedural arrangements for peer reviews of electronic identification schemes and for cooperation on the organisation of such reviews within the Cooperation Group and repealing Commission Implementing Decision (EU) 2015/296

Item Reference	Regulation name/details
CIR 2025/1569	Commission Implementing Regulation (EU) 2025/1569 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards qualified electronic attestations of attributes and electronic attestations of attributes provided by or on behalf of a public sector body responsible for an authentic source
CIR 2025/1570	Commission Implementing Regulation (EU) 2025/1570 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards notification of information on certified qualified electronic signature creation devices and certified qualified electronic seal creation devices
CIR 2025/1571	Commission Implementing Regulation (EU) 2025/1571 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the formats and procedures for annual reports by supervisory bodies
CIR 2025/1572	Commission Implementing Regulation (EU) 2025/1572 of 29 July 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the format and procedures for notification of intention and verification with regard to the initiation of qualified trust services

Item Reference	Regulation name/details
CIR 2025/1929	Commission Implementing Regulation (EU) 2025/1929 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the binding of date and time to data and establishing the accuracy of the time sources for the provision of qualified electronic time stamps
CIR 2025/1942	Commission Implementing Regulation (EU) 2025/1942 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards qualified validation services for qualified electronic signatures and qualified validation services for qualified electronic seals
CIR 2025/1943	Commission Implementing Regulation (EU) 2025/1943 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards for qualified certificates for electronic signatures and qualified certificates for electronic seals
CIR 2025/1944	Commission Implementing Regulation (EU) 2025/1944 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards for processes for sending and receiving data in qualified electronic registered delivery services and as regards interoperability of those services

Item Reference	Regulation name/details
CIR 2025/1945	Commission Implementing Regulation (EU) 2025/1945 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the validation of qualified electronic signatures and of qualified electronic seals and the validation of advanced electronic signatures based on qualified certificates and of advanced electronic seals based on qualified certificates
CIR 2025/1946	Commission Implementing Regulation (EU) 2025/1946 of 29 September 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards qualified preservation services for qualified electronic signatures and for qualified electronic seals
CIR 2025/2160	Commission Implementing Regulation (EU) 2025/2160 of 27 October 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards, specifications and procedures for the management of risks to the provision of non-qualified trust services
CIR 2025/2162	Commission Implementing Regulation (EU) 2025/2162 of 27 October 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and the Council as regards the accreditation of conformity assessment bodies performing the assessment of qualified trust service providers and the qualified trust services they provide, the conformity assessment report and the conformity assessment scheme

Item Reference	Regulation name/details
CID 2025/2164	Commission Implementing Decision (EU) 2025/2164 of 27 October 2025 amending Implementing Decision (EU) 2015/1505 as regards the version of the standard on which the common template for the trusted lists is based
CIR 2025/2527	Commission Implementing Regulation (EU) 2025/2527 of 16 December 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards for qualified certificates for website authentication
CIR 2025/2530	Commission Implementing Regulation (EU) 2025/2530 of 16 December 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards requirements for qualified trust service providers providing qualified trust services
CIR 2025/2531	Commission Implementing Regulation (EU) 2025/2531 of 16 December 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards and specifications for qualified electronic ledgers
CIR 2025/2532	Commission Implementing Regulation (EU) 2025/2532 of 16 December 2025 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards and specifications for qualified electronic archiving services

Item Reference	Regulation name/details
CIR 2026/248	Commission Implementing Regulation (EU) 2026/248 of 2 February 2026 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards the formats of advanced electronic signatures and advanced electronic seals recognised by public sector bodies
CIR 2026/798	Commission Implementing Regulation (EU) 2026/798 of 7 April 2026 laying down rules for the application of Regulation (EU) No 910/2014 of the European Parliament and of the Council as regards reference standards and specifications for the remote onboarding of users to the European Digital Identity Wallet

10.2 International and European standards and technical specifications

Note: All standards and technical specifications listed in this section are undated. A link is added to the entry for the respective document on the Standards and Technical Specifications Roadmap, which contains the latest information regarding the targeted version.

Item Reference	Standard name/details
ISO/IEC 18013-5	ISO/IEC 18013-5, Personal identification - ISO-compliant driving licence - Part 5: Mobile driving licence (mDL) application
ISO/IEC 18013-7	ISO/IEC 18013-7, Personal identification - ISO-compliant driving licence - Part 7: Mobile driving licence (mDL) add-on functions

Item Reference	Standard name/details
ISO/IEC 23220-2	ISO/IEC 23220-2, - Cards and security devices for personal identification — Building blocks for identity management via mobile devices - Part 2: Data objects and encoding rules for generic eID systems
ISO 3166-1	ISO 3166-1: Codes for the representation of names of countries and their subdivisions - Part 1: Country codes: alpha-2 country
ISO 3166-2	ISO 3166-2: Codes for the representation of names of countries and their subdivisions - Part 2: Country subdivision code
ISO/IEC 5218	ISO/IEC 5218 Codes for the representation of human sexes
ISO/IEC 19794-5	ISO/IEC 19794-5 Biometric data interchange formats — Part 5: Face image data
ISO/IEC 39794-5	ISO/IEC 39794-5 Extensible biometric data interchange formats — Part 5: Face image data
ETSI TS 119 101	ETSI TS 119 101 - Electronic Signatures and Infrastructures (ESI); Policy and security requirements for applications for signature creation and signature validation
ETSI TS 119 602	ETSI TS 119 602: Electronic Signatures and Infrastructures (ESI); Lists of trusted entities; Data model
ETSI TS 119 612	ETSI TS 119 612: Electronic Signatures and Infrastructures (ESI); Trusted Lists
ETSI EN 319 411-1	ETSI EN 319 411-1 - Electronic Signatures and Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 1: General requirements

Item Reference	Standard name/details
ETSI EN 319 411-2	ETSI EN 319 411-2 - Electronic Signatures and Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 2: Requirements for trust service providers issuing EU qualified certificates
ETSI TS 119 411-8	ETSI TS 119 411-8 - Electronic Signatures and Trust Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 8: Access Certificate Policy for EUDI Wallet Relying Parties
ETSI TS 119 412-6	ETSI TS 119 412-6 - Electronic Signatures and Trust Infrastructures (ESI); Certificate Profiles; Part 6: Certificate profile requirements for PID, Wallet, EAA, QEAA, and PSBEAA providers
ETSI TS 119 431-1	ETSI TS 119 431-1 - Electronic Signatures and Infrastructures (ESI); Policy and security requirements for trust service providers; Part 1: TSP service components operating a remote QSCD / SCDev.
ETSI TS 119 431-2	ETSI TS 119 431-2 - Electronic Signatures and Infrastructures (ESI); Policy and security requirements for trust service providers; Part 2: TSP service components supporting AdES digital signature creation
ETSI TS 119 432	ETSI TS 119 432 - Electronic Signatures and Infrastructures (ESI); Protocols for remote digital signature creation
ETSI TS 119 471	ETSI TS 119 471 - Electronic Signatures and Trust Infrastructures (ESI); Policy and Security requirements for Providers of Electronic Attestation of Attribute Services

Item Reference	Standard name/details
ETSI TS 119 472-1	ETSI TS 119 472-1 - Electronic Signatures and Trust Infrastructures (ESI); Profiles for Electronic Attestations of Attributes; Part 1: General requirements
ETSI TS 119 472-2	ETSI TS 119 472-2 - Electronic Signatures and Trust Infrastructures (ESI); Profiles for Electronic Attestation of Attributes; Part 2: Profiles for EAA/PID Presentations to Relying Party
ETSI TS 119 472-3	ETSI TS 119 472-3 - Electronic Signatures and Trust Infrastructures (ESI); Profiles for Electronic Attestation of Attributes; Part 3: Profiles for issuance of EAA or PID
ETSI TS 119 475	ETSI TS 119 475 - Electronic Signatures and Trust Infrastructures (ESI); Relying party attributes supporting EUDI Wallet user's authorisation decisions
ETSI TS 119 478	ETSI TS 119 478 - Electronic Signatures and Trust Infrastructures (ESI); Specification of interfaces related to Authentic Sources
ETSI EN 301 549	ETSI EN 301 549 - Accessibility requirements for ICT products and services
ETSI EN 319 132-1	ETSI EN 319 132-1 - Electronic Signatures and Infrastructures (ESI); XAdES digital signatures; Part 1: Building blocks and XAdES baseline signatures (XAdES)
ETSI TS 119 182-1	ETSI TS 119 182-1 - Electronic Signatures and Infrastructures (ESI); JAdES digital signatures; Part 1: Building blocks and JAdES baseline signatures

Item Reference	Standard name/details
ETSI EN 319 122-1	ETSI EN 319 122-1 - Electronic Signatures and Infrastructures (ESI); CAdES digital signatures; Part 1: Building blocks and CAdES baseline signatures
ETSI EN 319 162-1	ETSI EN 319 162-1 - Electronic Signatures and Infrastructures (ESI); Associated Signature Containers (ASiC); Part 1: Building blocks and ASiC baseline containers
ETSI EN 319 162-2	ETSI EN 319 162-2 - Electronic Signatures and Infrastructures (ESI); Associated Signature Containers (ASiC); Part 2: Additional ASiC container types
PSD2	Directive (EU) 2015/2366 of the European Parliament and of the Council on payment services in the internal market (PSD2)
ETSI EN 319 142-1	ETSI EN 319 142-1 - Electronic Signatures and Infrastructures (ESI); PAdES digital signatures; Part 1: Building blocks and PAdES baseline signatures
ECCG Agreed Cryptographic Mechanisms v2.0	ECCG Agreed Cryptographic Mechanisms v2.0
CEN EN 419 241-1	CEN EN 419 241-1 - Trustworthy Systems Supporting Server Signing - Part 1: General System Security Requirements
SD-JWT VC	SD-JWT-based Verifiable Credentials (SD-JWT VC).
RFC 2119	RFC 2119 - Key words for use in RFCs to Indicate Requirement Levels
RFC 3339	RFC 3339 - Date and Time on the Internet: Timestamps
RFC 9562	RFC 9562 - Universally Unique IDentifiers (UUIDs)

Item Reference	Standard name/details
RFC 5280	RFC 5280 - Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile
RFC 5322	RFC 5322 - Internet Message Format
RFC 3647	RFC 3647 - Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework
RFC 7519	RFC 7519 - JSON Web Token (JWT)
RFC 8259	RFC 8259 - The JavaScript Object Notation (JSON) Data Interchange Format
RFC 8392	RFC 8392 - CBOR Web Token (CWT)
RFC 8610	RFC 8610 - Concise Data Definition Language (CDDL): A Notational Convention to Express Concise Binary Object Representation (CBOR) and JSON Data Structures
RFC 8943	RFC 8943 - Concise Binary Object Representation (CBOR) Tags for Date
RFC 8949	RFC 8949 - Concise Binary Object Representation (CBOR)
Token Status List	Token Status List - Token Status List (TSL)
CSC API	Cloud Signature Consortium API Specification v2.0
GP OMAPI	GPD_SPE_075 Open Mobile API Specification, GlobalPlatform
GP CS	GPC_SPE_034 Card Specification, GlobalPlatform
GSMA SAM	GSMA Secured Applications for Mobile, GSM Association
W3C VCDM v2.0	Sporny, M. *et al,* Verifiable Credentials Data Model v2.0, W3C Recommendation

Item Reference	Standard name/details
W3C VC-JOSE-COSE	Jones, M. *et al,* Securing Verifiable Credentials using JOSE and COSE, W3C Recommendation
W3C VC Data Integrity	Sporny, M. *et al,* Verifiable Credential Data Integrity 1.0, W3C Recommendation
W3C Digital Credentials API	Caceres, M., Cappalli, T., Goto, S. *et al,* W3C Digital Credentials API, Draft Community Group Report
W3C WebAuthn	Jeff Hodges *et al,* Web Authentication, An API for accessing Public Key Credentials Level 2, W3C Recommendation
CTAP	John Bradley *et al,*Client to Authenticator Protocol (CTAP), FIDO Alliance
OpenID4VCI	Lodderstedt, T. *et al.*, OpenID for Verifiable Credential Issuance, OpenID Foundation.
OpenID4VP	Terbu, O. *et al.*, OpenID Connect for Verifiable Presentations, OpenID Foundation.
OIDC	Sakimura, N. *et al.*, OpenID Connect Core 1.0, OpenID Foundation.
EKYC	Lodderstedt, T. *et al.*, OpenID Connect for Identity Assurance Claims Registration 1.0, OpenID Foundation.
EKYC Schema	Lodderstedt, T. et al., OpenID Identity Assurance Schema Definition 1.0, OpenID Foundation.
HAIP	Yasuda, K. *et al*, OpenID4VC High Assurance Interoperability Profile, OpenId Foundation.
IANA-JWT-Claims	IANA JSON Web Token Claims Registry
FCAF	Functional Conformance Assessment Framework, governed by the European Commission in cooperation with the Member States through the EDICG

10.3 Topics from Annex 2

Note: All topics listed in this section are undated. The ARF main document and Annex 2 are always updated in combination. A link is added to the respective Topic in the latest version of Annex 2.

Item Reference	Standard name/details
[Topic 4]	Annex 2 - mDL Rulebook
[Topic 6]	Annex 2 - Relying Party authentication and User approval
[Topic 7]	Annex 2 - Attestation revocation and revocation checking
[Topic 9]	Annex 2 - Key Attestation and Wallet Instance Attestation
[Topic 10]	Annex 2 - Issuing a PID or attestation to a Wallet Unit
[Topic 11]	Annex 2 - Pseudonyms
[Topic 12]	Annex 2 - Attestation Rulebooks
[Topic 16]	Annex 2 - Signing documents with a Wallet Unit
[Topic 18]	Annex 2 - Combined presentations of attributes
[Topic 19]	Annex 2 - User Navigation requirements (Dashboard logs for transparency)
[Topic 20]	Annex 2 - Strong User authentication for electronic payments
[Topic 24]	Annex 2 - User identification in proximity scenarios
[Topic 25]	Annex 2 - Unified definition and controlled vocabularies for attributes
[Topic 27]	Annex 2 - Registration of PID Providers, Providers of QEAAs, PuB-EAAs, and (non-qualified) EAAs, and Relying Parties
[Topic 29]	Annex 2 - Representation paradigm

Item Reference	Standard name/details
[Topic 30]	Annex 2 - Interaction between Wallet Units
[Topic 31]	Annex 2 - PID Provider, Wallet Provider, Attestation Provider, Access Certificate Authority, and Provider of registration certificates notification and publication
[Topic 34]	Annex 2 - Migrate to a different Wallet solution
[Topic 38]	Annex 2 - Wallet Unit revocation
[Topic 40]	Annex 2 - Wallet Instance installation and Wallet Unit activation and management
[Topic 42]	Annex 2 - Requirements for QTSPs to access Authentic Sources
[Topic 43]	Annex 2 - Embedded disclosure policies
[Topic 44]	Annex 2 - Relying Party registration certificates
[Topic 48]	Annex 2 - Blueprint for requesting data deletion to Relying Parties
[Topic 50]	Annex 2 - Blueprint to report unlawful or suspicious request of data
[Topic 51]	Annex 2 - PID or attestation deletion
[Topic 52]	Annex 2 - Relying Party intermediaries
[Topic 53]	Annex 2 - Zero-Knowledge Proofs
[Topic 54]	Annex 2 - Accessibility
[Topic 55]	Annex 2 - Certificate Transparency
[Topic 56]	Annex 2 - Wallet Provider Support and Maintenance

10.4 Technical Specifications published by the Commission

Note: All Technical Specifications listed in this section are undated. A link is added to the latest version of the respective Technical Specification, published by the Commission.

Item Reference	Technical Specification name/details
Technical Specification 1	Specification of EUDI Wallet Trust Mark
Technical Specification 2	Specification of systems enabling the notification and subsequent publication of Provider information
Technical Specification 3	Specification of Wallet Unit Attestations (WUA) used in issuance of PID and Attestations
Technical Specification 4	Specification of Zero-Knowledge Proof (ZKP) Implementation in EUDI Wallet
Technical Specification 5	Specification of common formats and API for Relying Party Registration information
Technical Specification 6	Common Set of Relying Party Information to be Registered
Technical Specification 7	Specification of Common Interface for Data Deletion Requests to Relying Parties
Technical Specification 8	Specification of Common Interface for reporting of Relying Parties to Data Protection Authorities
Technical Specification 9	Specification of Wallet to Wallet interactions
Technical Specification 10	Data Portability and Download (Export)
Technical Specification 11	Specification of interfaces and formats for the catalogue of attributes and the catalogue of attestations
Technical Specification 12	Specification of Strong Customer Authentication (SCA) Implementation with the Wallet
Technical Specification 13	Specification for the implementation of Zero-Knowledge Proofs based on arithmetic circuits in the EUDI Wallet
Technical Specification 14	Specification for the implementation of Zero-Knowledge Proofs based on multi-message signatures in the EUDI Wallet

11 Annexes

- Definitions - Annex 1
- High Level Technical Requirements - Annex 2
  - High Level Technical Requirements by topic - Annex 2.02
  - High Level Technical Requirements by category - Annex 2.03
- Rulebooks - Annex 3:
  - PID Rulebook - Annex 3.1
  - mDL Rulebook - Annex 3.2
- Service Blueprints - Annex 4:
  - Blueprint Initialisation and activation - Annex 4.1
  - Blueprint Online identification and authentication - Annex 4.2
  - Blueprint Issuing mDL - Annex 4.3
  - Blueprint Presenting mDL (proximity-supervised) - Annex 4.4
  - Blueprint Presenting mDL (proximity-unsupervised) - Annex 4.5
  - Blueprint Remote QES – Creating a signature for authentication / authorisation - Annex 4.6
  - Blueprint Remote QES - Enrolment - Annex 4.7
  - Blueprint Remote QES - Creating a signature channelled by a Wallet Unit - Annex 4.8
  - Blueprint Remote QES - Creating a signature channelled by Relying Party - Annex 4.9
  - Blueprint QES – View history of signatures - Annex 4.10
  - Blueprint Local QES - Enrolment - Annex 4.11
  - Blueprint Local QES – Creating a signature - Annex 4.12
- Design Guides - Annex 5:
  - Wallet Unit design guide - Annex 5.1
  - Wallet Unit design guide – data sharing scenarios - Annex 5.2
- Certification Requirements - Annex 6

ANNEX 1 - Definitions

A.1 Introduction

In the Architecture Reference Framework (ARF) many terms are used that need a precise definition. This Annex contains the definitions of these terms.

In fact, there are three sources for these definitions:

- In the first place, the European Digital Identity Regulation defines several of these terms. For convenience, these definitions are listed in Section A.2.
- Secondly, the adopted Commission Implementing Regulations CIR 2024/2977, CIR 2024/2979, CIR 2024/2980, CIR 2024/2981, and CIR 2024/2982 also contain a list of definitions. Again for convenience, these definitions are included in Section A.3
- Thirdly, in writing the ARF, additional technical terms and corresponding definitions are used. These are listed in Section A.4.

A.2 Definitions from the European Digital Identity Regulation

The following terms are defined in the European Digital Identity Regulation and used in the ARF.

Term	Definition in European Digital Identity Regulation
Electronic attestation of attributes (EAA)	An attestation in electronic form that allows attributes to be authenticated.
Attribute	A characteristic, quality, right or permission of a natural or legal person or of an object.

Term	Definition in European Digital Identity Regulation
Authentic Source	A repository or system, held under the responsibility of a public sector body or private entity, that contains and provides attributes about a natural or legal person or object and that is considered to be a primary source of that information or recognised as authentic in accordance with Union law or national law, including administrative practice.
Authentication	An electronic process that enables the confirmation of the electronic identification of a natural or legal person or the confirmation of the origin and integrity of data in electronic form.
Conformity Assessment Body (CAB)	A conformity assessment body as defined in Article 2, point 13, of Regulation (EC) No 765/2008, which is accredited in accordance with that Regulation as competent to carry out conformity assessment of a qualified trust service provider and the qualified trust services it provides, or as competent to carry out certification of European Digital Identity Wallets or electronic identification means.
Electronic attestation of attributes issued by or on behalf of a public sector body (PuB-EAA)	An electronic attestation of attributes issued by a public sector body that is responsible for an authentic source or by a public sector body that is designated by the Member State to issue such attestations of attributes on behalf of the public sector bodies responsible for authentic sources in accordance with Article 45f and with Annex VII.

Term	Definition in European Digital Identity Regulation
Electronic identification scheme	A system for electronic identification under which electronic identification means are issued to natural or legal persons or natural persons representing other natural persons or legal persons.
(Electronic) signature	Data in electronic form which is attached to or logically associated with other data in electronic form and which is used by the signatory to sign.
(Electronic) seal	Data in electronic form which is attached to or logically associated with other data in electronic form to ensure the latter's origin and integrity.
Person Identification Data (PID)	A set of data that is issued in accordance with Union or national law and that enables the establishment of the identity of a natural or legal person, or of a natural person representing another natural person or a legal person.
Public Sector Body	A state, regional or local authority, a body governed by public law or an association formed by one or several such authorities or one or several such bodies governed by public law, or a private entity mandated by at least one of those authorities, bodies or associations to provide public services, when acting under such a mandate.
Qualified Electronic Attestation of Attributes (QEAA)	An electronic attestation of attributes which is issued by a qualified trust service provider and meets the requirements laid down in Annex V.

Term	Definition in European Digital Identity Regulation
Qualified Electronic Signature (QES)	An advanced electronic signature that is created by a qualified electronic signature creation device, and which is based on a qualified certificate for electronic signatures.
Qualified Electronic Signature Creation Device (QSCD)	Configured software or hardware used to create an electronic signature that meets the requirements laid down in Annex II of the European Digital Identity Regulation.
Qualified Trust Service Provider (QTSP)	Qualified Trust Service Provider means a trust service provider who provides one or more qualified trust services and is granted the qualified status by the supervisory body.
strong User authentication	An authentication based on the use of at least two authentication factors from different categories of either knowledge, something only the user knows, possession, something only the user possesses or inherence, something the user is, that are independent, in that the breach of one does not compromise the reliability of the others, and is designed in such a way as to protect the confidentiality of the authentication data
User	A natural or legal person, or a natural person representing another natural person or a legal person, that uses trust services or electronic identification means provided in accordance with the European Digital Identity Regulation.

Table 1: Definition of terms used in the ARF originating from the European Digital Identity Regulation

A.3 Definitions from the adopted Commission Implementing Regulations

The following terms are defined in the adopted Commission Implementing Regulations and used in the ARF. Note that small differences exist in the way in which terms are written, for example regarding capitalisation. The table contains the term as used in the ARF, and uses brackets to indicate shortened or alternative forms used in the ARF.

Term	Definition
(Wallet) User	A user who is in control of the Wallet Unit
Wallet Unit	A unique configuration of a Wallet Solution that includes Wallet Instances, Wallet Secure Cryptographic Applications and Wallet Secure Cryptographic Devices provided by a Wallet Provider to an individual Wallet User. *Note: In this ARF, a Wallet Unit may additionally include one or more Keystores as specified in Section A.4.*
Wallet Solution	A combination of software, hardware, services, settings, and configurations, including Wallet Instances, one or more Wallet Secure Cryptographic Applications and one or more Wallet Secure Cryptographic Devices
Provider of person identification data (PID Provider)	A natural or legal person responsible for issuing and revoking the person identification data and ensuring that the person identification data of a user is cryptographically bound to a Wallet Unit

Term	Definition
Wallet Unit Attestation (WUA)	A data object that describes the components of the Wallet Unit or allows authentication and validation of those components. *Note: The ARF defines two concrete subtypes: the Wallet Instance Attestation (WIA) and the Key Attestation (KA).*
Embedded disclosure policy	A set of rules, embedded in an electronic attestation of attributes by its provider, that indicates the conditions that a wallet-relying party has to meet to access the electronic attestation of attributes
Registrar (of wallet-relying parties)	The body responsible for establishing and maintaining the list of registered wallet-relying parties established in their territory and who has been designated by a Member State
Wallet Instance	The application installed and configured on a Wallet User's device or environment, which is part of a Wallet Unit, and which the Wallet User uses to interact with the Wallet Unit *Note: Technically speaking, a Wallet Instance can also be a web application.*
Wallet Secure Cryptographic Application (WSCA)	An application that manages critical assets by being linked to and using the cryptographic and non-cryptographic functions provided by the Wallet Secure Cryptographic Device

Term	Definition
Wallet Secure Cryptographic Device (WSCD)	A tamper-resistant device that provides an environment that is linked to and used by the Wallet Secure Cryptographic Application to protect critical assets and provide cryptographic functions for the secure execution of critical operations
Wallet Provider	A natural or legal person who provides Wallet Solutions in accordance with Article 5a of Regulation (EU) No 910/2014.
critical assets	Assets within or in relation to a Wallet Unit of such extraordinary importance that where their availability, confidentiality or integrity are compromised, this would have a very serious, debilitating effect on the ability to rely on the Wallet Unit
Wallet-relying party	A relying party that intends to rely upon Wallet Units for the provision of public or private services by means of digital interaction *Note: The ARF uses this term only in direct quotes from the Commission Implementing Regulations. It mostly uses 'Relying Party', as specified in section A.4.*
(Wallet-relying party) access certificate	A certificate for electronic seals or signatures authenticating and validating the wallet-relying party, issued by a provider of wallet-relying party access certificates
Provider of wallet-relying party access certificates (Access Certificate Authority, Access CA)	A natural or legal person mandated by a Member State to issue wallet-relying party access certificates to wallet-relying parties registered in that Member State.

Term	Definition
Provider of (wallet-relying party) registration certificates	A natural or legal person mandated by a Member State to issue wallet-relying party registration certificates to wallet-relying parties registered in that Member State
(Wallet-relying party) registration certificate	A data object that indicates the attributes the wallet-relying party has registered to intend to request from Users

A.4 Additional definitions used in the ARF

Note: The technical terms and definitions in Table 3 below are intended to be defined in such a way that they are aligned with the definitions used in the European Digital Identity Regulation and the Commission Implementing Regulations in Tables 1 and 2, and should be interpreted as such. In case any definition in Table 3 contradicts a definition from the European Digital Identity Regulation or the Commission Implementing Regulations, the latter take precedence.

In some cases, a term has its origin in the context of a specific Topic in Annex 2. In such a case, the topic number is mentioned in a note. If the definition relies on an external source, such as a standard or a formal publication, that source is mentioned.

Term	Definition
Administrative validity period (of a PID or attestation)	The date(s) from and/or up to which the attributes in the attestation are valid, which are represented as attribute(s) in the attestation. *Note: Some attestations, for instance diplomas, do not have an administrative validity period.*
Attestation	When not further qualified, a collective term for a QEAA, PuB-EAA, or (non-qualified) EAA.

Term	Definition
Attestation Provider	When not further qualified, a collective term for QEAA Provider, PuB-EAA Provider, or (non-qualified) EAA Provider.
Attestation Revocation List	An Attestation revocation mechanism that publishes a list of identifiers of revoked PIDs or attestations. *Note: See Topic 7.*
Attestation revocation mechanism	A mechanism provided by a PID Provider or an Attestation Provider (or by an entity acting on its behalf) for communicating the revocation status of PIDs and attestations. *Notes: - Two specific mechanisms are defined in this Annex: the Attestation Revocation List and the Attestation Status List. - See Topic 7.*
Attestation Rulebook	A document describing the attestation type, namespace(s), and other features for a specific attestation type. *Note: See Topic 12.*
Attestation scheme	A machine-readable counterpart of an Attestation Rulebook for a given attestation type, used by software to build requests to Wallet Units and to validate responses at runtime. *Note: See Section 3.15 and Section 5.5 of the main document.*
Attestation Scheme Provider	A natural or legal person that defines a specific attestation type and publishes the corresponding Attestation Rulebook and Attestation scheme. *Note: See Section 3.15 of the main document.*

Term	Definition
Attestation Status List	An Attestation revocation mechanism that publishes status information (Valid or Invalid) for all relevant PIDs or attestations. *Notes: - Which PIDs or attestations are relevant is determined by the entity publishing the status list. For example, a status list may contain all PIDs or attestations whose validity period is not over yet at the time of publication of the list. - See Topic 7.*
Attestation type	An identifier for a type of attestation, unique within the context of the EUDI Wallet ecosystem. *Note: See Topic 12.*
Certificate Authority (CA)	An entity which is trusted by one or more parties in the EUDI Wallet ecosystem to create and seal certificates.
Certificate Policy (CP)	A named set of rules that indicates the applicability of a certificate to a particular community and/or class of application with common security requirements.
Device-bound attestation	An attestation that is cryptographically bound to a private key generated by and kept in a WSCA/WSCD or keystore available to the Wallet Unit, such that a Relying Party can verify that the attestation is being presented from the Wallet Unit to which it was issued. *Note: See Topic 9.*
Holder	A User presenting attributes from a PID or attestation to a Verifier in a Wallet-to-Wallet interaction. *Notes: - This term is used only in the context of Wallet-to-Wallet interaction. - See also Verifier. - See Topic 30.*

Term	Definition
Holder Wallet Unit	A Wallet Unit operating in Wallet-to-Wallet mode (see Technical Specification 9) and being used by a Holder to present attributes from a PID or attestation to a Verifier. *Note: See Topic 30.*
Intermediary	A natural or legal person providing services to one or more Relying Parties ('intermediated Relying Parties') by interacting with Wallet Units on their behalf to request and receive User attributes, in accordance with Art. 5b(10) of the European Digital Identity Regulation. *Notes: - According to Art. 5b(10), intermediaries are deemed to be Relying Parties. - See Topic 52.*
Key Attestation (KA)	A type of Wallet Unit Attestation that attests the certification and properties of a WSCA/WSCD or keystore available to the Wallet Unit, and that contains one or more public keys whose corresponding private keys are generated by and stored in that WSCA/WSCD or keystore, as well as a revocation reference for the WSCD or keystore. *Note: See Topic 9.*
Keystore	A hardware-backed repository and service that generates, stores, and uses non-critical cryptographic assets within a dedicated hardware security boundary. *Notes: - Examples include a Secure Element, a TPM, TEE, or secure enclave, or a remote HSM. - Critical cryptographic assets are generated, stored, and used in a WSCA/WSCD.*

Term	Definition
List of Trusted Entities (LoTE)	List of entities that are recognized as trustworthy within a given approval scheme for a specific scope or purpose. *Based on ETSI TS 119 602.*
Logical PID or attestation	A PID or attestation as it is understood by the User and seen in their Wallet Unit, independent of any specific data structure, encoding, or proof mechanism. *Notes: - See Section 5.3. - A single logical PID or attestation can correspond to multiple Technical PIDs or attestations issued to the User's Wallet Unit, simultaneously or over time.*
Namespace	A specification of the attribute identifier, syntax and semantics of attributes that can be used in an attestation, having an identifier that is unique within the context of the EUDI Wallet ecosystem. *Note: See Topic 12.*
National Accreditation Body (NAB)	A body that performs accreditation with authority derived from a Member State under Regulation (EC) No 765/2008.
Non-device-bound attestation	An attestation that is not cryptographically bound to a private key kept in a WSCA/WSCD or keystore available to the Wallet Unit. *Note: See Topic 9.*
Notification	The act of transferring information to the European Commission. *Note: See Topic 31.*

Term	Definition
Pseudonym	Data uniquely representing a User which in itself does not allow to infer the User's attributes or person identification data, without the use of additional information that is kept separately by the issuer of the data uniquely representing the user. *Note: See Topic 11.*
Public Key Infrastructure (PKI)	Systems, software, and communication protocols that are used by EUDI Wallet ecosystem components to distribute, manage, and control public keys. A PKI publishes public keys and establishes trust within an environment by validating and verifying the public keys mapping to an entity.
Qualified Electronic Signature Remote Creation Provider (QESRC Provider)	A natural or a legal person that offers services related to the remote creation, validation, and management of qualified electronic signatures that meet legal requirements and standards in the European Digital Identity Regulation to be considered as legally equivalent to handwritten signatures.

Term	Definition
Relying Party	For the purposes of this ARF, a service provider interacting with a Wallet Unit to request and receive User attributes. *Note: As specified in the European Digital Identity Regulation, legally speaking, the term 'relying party' includes Attestation Providers (i.e., QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers), as well as service providers, because all of them rely on European Digital Identity Wallets. Moreover, this term also includes natural or legal persons that rely on a trust service rather than European Digital Identity Wallets. The CIRs use the term 'wallet-relying party' to refer to Attestation Providers and service providers that specifically rely on wallet units (and not on a trust service). However, technically speaking the responsibilities of Attestation Providers are quite different from those of service providers, as is the way they interact with Wallet Units. To avoid confusion, the ARF therefore distinguishes between Relying Parties (i.e., service providers) on the one hand and PID Providers and Attestation Providers on the other hand.*
Relying Party Instance	A software and/or hardware module with the capability to interact with a Wallet Unit and to perform Relying Party authentication, that is controlled by a Relying Party.
Selective Disclosure	The capability enabling the User to present a subset of the attributes included in a PID or attestation.

Term	Definition
SUA attestation	An attestation used for strong user authentication in the context of electronic payments, such that, when a Relying Party sends a presentation request for the attestation to a Wallet Unit, it includes transactional data in the request. *Note: See Topic 20*
Technical PID or attestation	A PID or attestation as a specific data structure with a specific encoding and proof mechanism, that is present in a Wallet Unit and that corresponds to a Logical PID or attestation of the User of that Wallet Unit. *Notes: - When this ARF talks about 'PIDs' or 'attestations', without qualification, it means technical PIDs or attestations. - See Section 5.3 and Section 5.4.*
Technical validity period (of a PID or attestation)	T The dates (and possibly times) from and up to which a technical PID or attestation is valid, which are represented as metadata of the PID or attestation. *Note: All technical PIDs and attestations have a technical validity period, which is typically much shorter than the administrative validity period of the corresponding logical PID or attestation (if existent). The technical validity period is chosen by the PID Provider or Attestation Provider based on a risk analysis, e.g. with regard to User privacy.*
Trust Anchor	An authoritative entity represented by a public key and associated data. *Based on RFC 5914.*

Term	Definition
Trusted List	List that provides information about the status and the status history of the trust services from trust service providers regarding compliance with the applicable requirements and the relevant provisions of the applicable legislation. *Based on ETSI TS 119 612.*
Verifier	A User requesting attributes from a PID or attestation from a Holder in a Wallet-to-Wallet interaction. *Notes: - This term is used only in the context of Wallet-to-Wallet interaction. - See also Holder. - See Topic 30.*
Verifier Wallet Unit	A Wallet Unit operating in Wallet-to-Wallet mode (see Technical Specification 9) and being used by a Verifier to request attributes from a PID or attestation from a Holder. *Note: See Topic 30.*
Wallet Instance Attestation (WIA)	A type of Wallet Unit Attestation that attests the integrity and authenticity of a Wallet Instance, and that carries a revocation reference for the Wallet Instance, as well as information about the Wallet Solution, including its name, version, and certification. *Note: See Topic 9.*
Wallet Provider backend	The part of a Wallet Solution that is operated by the Wallet Provider and that offers Users support with their Wallet Units, performs essential maintenance, and issues Key Attestations and Wallet Instance Attestations to the Wallet Unit. *Note: See Section 4.3.2 of the main document.*

Term	Definition
Wallet Unit Service	The parts of a Wallet Unit running on the Wallet Provider backend (if any).

ANNEX 2.01 - High-Level Requirements

Since ARF 2.7.0, all high-level requirements in Annex 2 are included in the high-level-requirements.csv file, which allows for easy sorting and filtering of requirements. Insofar relevant, the texts in the introduction to each Topic in the original Annex 2 were moved to suitable sections in the ARF main document.

For the convenience of readers, the high-level requirements in the .csv file are also included in two new .md files, called annex-2.02-high-level-requirements-by-topic.md and annex-2.03-high-level-requirements-by-category.md, which were generated from the .csv file. Note that in case of deviations between the .csv file and the .md files, the .csv file takes precedence.

The requirements in these files are identical, but they are ordered in a different manner. The file annex-2.02-high-level-requirements-by-topic.md contains the high-level requirements in the same order as the original (i.e., pre-v2.7.0) Annex 2 file, meaning ordered per discussion topic. It also contains the same Topic numbers and section indicators. However, Topics in the original file that did not contain any high-level requirements have been removed from the .csv file and hence from the resulting .md file.

The file annex-2.03-high-level-requirements-by-category.md orders the high-level requirements on the basis of their subject, meaning the entity that has to comply with each requirement. To enable this, a new system of requirement identifiers was developed, next to the existing identifiers which are based on topic. These new requirement identifiers have a simple, hierarchical format: PART-CATEGORY-TOPIC-ID, where

- PART is either actor-specific requirements (AS) or ecosystem-wide requirements (EW).
- CATEGORY is a two or three-letter code based on the six main categories established below. This provides immediate context.
- TOPIC is the number of of the topic in which this requirement was originally included.
- ID is a three-digit sequential number (e.g., 001, 002) to ensure uniqueness.

Categories under Part 1: Actor-Specific Requirements:

- **Wallet Providers (WP)**: This category includes all HLRs that are the direct responsibility of the entities developing and maintaining the EUDI Wallet solutions. It covers core functionalities, security, user interface elements, and lifecycle management of the wallet.
- **Member States & Registrars (MS)**: This category includes all requirements for Member States, including their designated Registrars and authorities. It focuses on establishing the legal and trust infrastructure, such as setting up registries, notifying the Commission, and defining national policies.
- **Attestation Providers & PID Providers (AP)**: In this categories, all HLRs for the organizations that issue digital credentials are placed. This includes requirements for identity verification, issuance protocols, data formats, and revocation procedures.
- **Relying Parties (RP)**: This category consolidates all requirements for the services that accept EUDI Wallet Units. It covers how they must register, authenticate themselves to the wallet, request user attributes, and handle User attributes.

Categories under Part 2: Ecosystem-Wide Requirements:

- **Protocols & Interoperability (PIO)**: This category includes the HLRs that define the common communication standards and protocols. It ensures that a Wallet Unit from one Wallet Provider can interact seamlessly with a Relying Party service in another, covering how different components talk to each other.
- **Data Models & Attestation Rules (DM)**: Finally, this category defines the structure and rules for the data (attestations) itself. It includes HLRs for PIDs, Attestation Rulebooks, and Catalogues, ensuring that the information exchanged is consistent and understandable across the entire ecosystem.

ANNEX 2.02 - High-Level Requirements by topic

A.2 High-level requirements by topic

A.2.1 Introduction

A.2.1.1 Overview

This annex to the ARF main document includes high-level requirements (HLRs) related to the EUDI Wallet ecosystem. The requirements define the responsible actor that should implement each requirement. There are no requirements imposed on the Users.

A.2.1.2 Key words

This Annex uses the capitalised key words 'SHALL', 'SHOULD' and 'MAY' as specified in RFC 2119, i.e., to indicate requirements, recommendations and options specified in this annex.

In addition, 'must' (non-capitalised) is used to indicate an external constraint, i.e., a requirement that is not mandated by this document, but, for instance, by an external standard or specification. The word 'can' indicates a capability, whereas other words, such as 'will', and 'is' or 'are', are intended as statements of fact.

A.2.2 Structure and order of presentation of the HLRs

Topics presented in Section A.2.3 are ordered by a Topic number.

Each Topic includes a short description, followed by the High-Level Requirements (HLRs), identified by a unique identifier. The identifier includes a prefix which signifies the context of the HLRs (e.g. ISSU for issuance), an underscore and a numerator, e.g. ISSU_10. Each requirement is anchorable: link directly to it with #<identifier>, e.g. #ISSU_10.

A.2.3 High-Level Requirements

A.2.3.1 Topic 1 - Accessing Online Services with a Wallet Unit

OIA_01SHALL

For proximity presentation flows, a Wallet Unit SHALL support the transmission mechanism specified in ISO/IEC 18013-5 to receive and respond to presentation requests for person identification data (PID) and attestations by Relying Parties.

OIA_01aSHALL

For remote presentation flows, a Wallet Unit SHALL support the following transmission mechanisms: - The API-mediated mechanisms specified in OIA_08, OIA_08a, and OIA_08b, - The mechanisms based on redirects specified in OIA_03b and OIA_03c.

OIA_02SHALL

A Wallet Unit SHALL support proving cryptographic device binding between the WSCA/WSCD or a keystore included in the Wallet Unit and a PID or attestation, in accordance with SD-JWT VC or ISO/IEC 18013-5.

Note: Such a mechanism is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC.

OIA_03SHALL

When issuing, presenting, or verifying an attestation, Wallet Units, PID Providers, Attestation Providers, and Relying Parties SHALL only use cryptographic algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

OIA_03a

Empty

OIA_03bSHALL

For remote presentation flows using redirects and OpenID4VP, when the format of the requested attestation complies with ISO/IEC 18013-5, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.1 and 5.3.1, as well as with the 'ISO mdocs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. This does not include sections 5.1, 5.2, and 5.3. b) For clarity: in HAIP v1.0, the 'ISO mdocs' profile implies that Relying Parties and Wallet Units must comply with the applicable requirements in OpenID4VP Annex B.2. c) This requirement and OIA_03c both correspond to the profile for transmission via redirects specified in ETSI TS 119 472-2 Section 1, but are more specific with regard to format of the attestation.

OIA_03cSHALL

For remote presentation flows using redirects and OpenID4VP, when the format of the requested attestation complies with SD-JWT VC, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.1, and 5.3.2, as well as with the 'IETF SD-JWT VCs' profile in Section 6 and with Sections 7 and 8

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. This does not include sections 5.1, 5.2, and 5.3. b) For clarity: in HAIP v1.0 Section 6, the 'IETF SD-JWT VCs' profile implies that Relying Parties and Wallet Units must comply with the requirements in OpenID4VP Annex B.3, as well as with the requirements in Section 6.1.

OIA_03dMAY

For remote presentation flows using redirects and ISO/IEC 18013-7, Relying Parties and Wallet Units MAY comply with the requirements in ISO/IEC 18013-7 Annex A.

OIA_04

Empty

OIA_05SHALL

After verifying and processing a PID or attestation request, the Wallet Unit SHALL display to the User the identity of the requesting Relying Party and the requested attributes.

OIA_06SHALL

A Wallet Unit SHALL present the requested attributes only after having received the User's approval.

Note: See also OIA_07.

OIA_07SHALL

A Wallet Unit SHALL support selective disclosure of attributes from PIDs and attestations to be presented to the requesting Relying Parties.

OIA_08SHALL

For remote presentation flows using the W3C Digital Credentials API and OpenID4VP, when the format of the requested attestation complies with ISO/IEC 18013-5, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.2 and 5.3.1, as well as with the 'ISO mdocs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. b) For clarity: in HAIP v1.0, the 'ISO mdocs' profile implies that Relying Parties and Wallet Units must comply with the applicable requirements in OpenID4VP Annex B.2. c) This requirement and OIA_08a both correspond to the profile for API-mediated transmission specified in ETSI TS 119 472-2 Section 1, but are more specific with regard to format of the attestation.

OIA_08aSHALL

For remote presentation flows using the W3C Digital Credentials API and OpenID4VP, when the format of the requested attestation complies with SD-JWT VC, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.2 and 5.3.2, as well as with the 'IETF SD-JWT VCs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. b) For clarity: in HAIP v1.0 Section 6, the 'IETF SD-JWT VCs' profile implies that Relying Parties and Wallet Units must comply with the requirements in OpenID4VP Annex B.3, as well as with the requirements in Section 6.1.

OIA_08bSHALL

For remote presentation flows using the W3C Digital Credentials API and ISO/IEC 18013-7, Relying Party Instances and Wallet Units SHALL comply with the requirements in ISO/IEC 18013-7 Annex C.

Note: The latter restriction applies even if such disclosure would enhance the services provided by the operating system to the Wallet Unit, for example, attestation selection in the context of the Digital Credentials API.

OIA_08cSHOULD

Wallet Units SHOULD NOT support using a redirects-based transmission mechanism for cross-device presentation flows.

OIA_08dSHALL

If a Relying Party uses a redirects-based transmission mechanism for cross-device presentation flows, it SHALL implement adequate mitigations for the challenges described in Section 4.4.3.1 of the ARF main document.

OIA_08eSHALL

A Wallet Unit SHALL, by default (see OIA_08f), disclose the presence of all stored attestations (meaning their attestation type) to the Digital Credentials API framework, but it SHALL NOT disclose the presence of attributes in these attestations, nor their values.

Note: The latter restriction applies even if such disclosure would enhance the services provided by the operating system to the Wallet Unit, for example, attestation selection in the context of the Digital Credentials API.

OIA_08fSHALL

A Wallet Unit SHALL provide a global User setting to disable the disclosure of stored attestations to the Digital Credentials API framework, as described in OIA_08e. When this setting is set to disable disclosure, the Wallet Unit SHOULD subsequently enable the User to select individual attestations to be disclosed to the DC API.

Note: If this setting is set to disable disclosure and the User does not subsequently select any individual attestations to be disclosed, the Wallet Unit will not disclose any attributes at all. As a result, presentation requests sent using the DC API will likely fail.

OIA_08gSHALL

In cross-device presentation flows using the W3C Digital Credentials API, a Wallet Unit SHALL verify that the Relying Party Instance is in close physical proximity to the Wallet Unit. For this proximity check the Wallet Unit SHALL use a secure, direct, and user-mediated local communication channel, such as a short-range wireless communication technology.

Note: In CTAP terms, this proximity check is the BLE proximity engagement, present in both the Hybrid transport specified in CTAP v2.2 and in CTAP v2.3. Where both devices support it, the underlying operating systems, browsers, mediating APIs, or any other technical layer outside the control of the Wallet Unit, should prefer performing both the proximity check and the data transfer over a local short-range channel (as enabled by CTAP v2.3) over the use of a Hybrid tunnel service first defined in CTAP v2.2.

OIA_09SHALL

For remote presentation flows the Wallet Unit SHALL ensure that the attributes included in the presented attestation are accessible only to the Relying Party Instance, by encrypting the presentation response.

OIA_10SHALL

For both proximity and remote presentation flows, if a Wallet Unit contains multiple PIDs having the same encoding (e.g. ISO/IEC 18013-5 or SD-JWT VC-compliant) and a Relying Party requests a PID having that encoding, the Wallet Unit SHALL ask the User which of these PIDs they want to present, unless the Wallet Unit can decide from context.

Note: This requirement is not about multiple technical PIDs corresponding to a single logical PID, but to different logical PIDs whose technical PIDs have the same encoding. Probably, these logical PIDs are issued by different PID Providers.

OIA_11SHALL

For both proximity and remote presentation flows, if a Wallet Unit contains multiple attestations having the same encoding (e.g. ISO/IEC 18013-5 or SD-JWT VC-compliant) and the same attestation type, and a Relying Party requests an attestation having that type and encoding, the Wallet Unit SHALL ask the User which of these attestations they want to present, unless the Wallet Unit can decide from context.

Note: a) Attestation types are explained in Topic 12]. b) See note to OIA_10, which applies mutatis mutandis.

OIA_12SHALL

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a PID using a trust anchor provided in a PID Provider LoTE made available in accordance with Topic 31].

OIA_13SHALL

For both proximity and remote presentation flows, a Relying Party SHALL validate the qualified signature of a QEAA in accordance with Art.32 of the European Digital Identity Regulation. For the verification, the Relying Party SHALL use a trust anchor provided in a QEAA Provider Trusted List made available in accordance with Art. 22 of the European Digital Identity Regulation.

OIA_14SHALL

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a PuB-EAA using a trust anchor provided in a Pub-EAA Provider LoTE made available in accordance with Topic 31].

OIA_15SHALL

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a non-qualified EAA using a trust anchor provided according to the mechanism(s) specified in the applicable Attestation Rulebook, see Topic 12].

Note: a) OIA_12 - OIA_15 imply that a Relying Party Instance must know if the attestation it is requesting from a Wallet Instance is a PID, a QEAA, a PuB-EAA, or a non-qualified EAA. These requirements also imply that the Relying Party Instance must store trust anchors in such a way that, at the time of verification, it is able to distinguish between trust anchors usable either for PIDs, for QEAAs, for PuB-EAAs, or for non-qualified EAAs.

OIA_15aSHALL

A Relying Party SHALL perform regular trust anchor management, meaning it SHALL download the latest version of all applicable Trusted Lists and LoTEs. If it finds that new trusted entities have been added, or that new trust anchors have been added for existing trusted entities, it SHALL ensure that these trust anchors are properly stored in all relevant Relying Party Instances. Conversely, if the Relying Party finds that an existing trusted entity has been invalidated in the Trusted List or LoTE, or that some of the trust anchors of existing trusted entities have expired, been revoked, or otherwise been invalidated, it SHALL ensure that these trust anchors are removed from all Relying Party Instances.

OIA_15bSHALL

For the retrieval and management of trust anchors, Relying Parties and Relying Party Instances SHALL support both Trusted Lists complying with ETSI TS 119 612 and LoTEs complying with ETSI TS 119 602.

Note: Trusted Lists complying with ETSI TS 119 612 are used for the distribution of trust anchors of QEAA Providers. LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of PID Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

OIA_16SHALL

When receiving a PID or attestation, a Relying Party Instance SHALL discard the values of all unique elements, including at least the ones mentioned in requirement ISSU_35 in Topic 10, as well as any timestamps, as soon as they are no longer needed. The Relying Party Instance SHALL NOT communicate these values to the Relying Party or to any other party inside or outside the EUDI Wallet ecosystem.

OIA_17SHOULD

A Relying Party Instance SHOULD verify the device-binding signature or Message Authentication Code provided in the presentation response of the Wallet Unit during the presentation of a PID or device-bound attestation, following the steps specified per ISO/IEC 18013-5 or SD-JWT VC, as applicable.

A.2.3.2 Topic 3 - PID Rulebook

A. Generic HLRs

PID_01SHALL

PIDs and PID Providers SHALL comply with all requirements in PID Rulebook.

PID_02SHALL

A PID Provider SHALL issue any PID in both the format specified in ISO/IEC 18013-5 ISO/IEC 18013-5 and the format specified in SD-JWT VC.

PID_03SHALL

During issuance of a PID, the PID Provider MAY enable the User to opt out from receiving a portrait attribute in their PID. If the User opts out, the PID Provider SHALL include the `portrait` attribute in the PID as an empty JSON `string` or CBOR `bstr`, as applicable given the format of the PID.

Note: As described in the PID Rulebook and in the Regulation amending CIR 2024/2977, inclusion of the `portrait` attribute in the PID is mandatory only from 24 months after the entry into force of that Regulation.

PID_03aSHALL

If a Relying Party obtains the `portrait` attribute from a User's PID, it SHALL NOT retain the portrait, unless its processing is necessary for the purposes of identification and authentication in compliance with Union data protection law or where this is provided for by Union or national law, in compliance with Union data protection law. The Relying Party SHALL NOT transfer the portrait to third countries or international organisations unless permitted by Union data protection law.

Note: See CIR 2024/2977.

B. HLRs for ISO/IEC 18013-5-compliant PIDs

PID_04SHALL

PID Providers SHALL use "eu.europa.ec.eudi.pid.1" as the attestation type for ISO/IEC 18013-5-compliant PIDs.

Note: a) This identifier uses the general format [Reverse Domain].[Domain Specific Extension]. Since the European Commission controls the domain ec.europa.eu, this attestation type identifier will not collide with any attestation type identifiers defined by other organisations in other Attestation Rulebooks. b) The version number 1 in this identifier is used to distinguish between the first version of the PID, defined in the PID Rulebook, and any future version, which will then have an incremented version number.

PID_05SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL use the value "eu.europa.ec.eudi.pid.1" for the identifier of the namespace for the PID attributes specified in Section 4.2 of the PID Rulebook.

Note: a) The version number 1 allows for future extension(s) or change(s) of the ISO/IEC 18013-5-compliant PID attributes. b) This namespace has the same value as the attestation type specified in requirement PID_04. This is allowed according to ISO/IEC 18013-5.

PID_06SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider MAY include attributes that are not defined in the PID Rulebook. If so, these attributes SHALL be defined within a

domestic PID namespace as meant in requirement ARB_10 in Topic 12. The PID Provider SHALL generate the identifier for this domestic PID namespace by appending the applicable ISO 3166-1 alpha-2 country code or the ISO 3166-2 region code, separated by a period, to the PID namespace identifier specified in PID_05, excluding the version number. The PID Provider MAY include a version number in the domestic PID namespace identifier.

Note: For example, the identifier of the first domestic PID namespace for Germany could be "eu.europa.ec.eudi.pid.de.1".

PID_07SHALL

A PID Provider that defines a domestic namespace SHALL publish the namespace, including all attribute identifiers, their definition, presence and encoding format, in an Attestation Rulebook complying with all applicable requirements in Topic 12.

PID_08SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL include both the attributes and the metadata specified in CIR 2024/2977 in the PID as issuer-signed data elements.

Note: This implies that technically speaking, there is no difference between these attributes and metadata.

PID_09SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL encode each attribute or metadata in the PID as specified in the third column of the tables in Section 4.2.1 of the PID Rulebook.

PID_10SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL encode each attribute or metadata in the PID in Concise Binary Object Representation (CBOR) according to RFC 8949.

PID_11SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL ensure that each PID contains at most one attribute with the same attribute identifier.

PID_12SHALL

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL ensure that the value of all attributes and metadata in the PID is valid at the value of the timestamp in the

validFrom element in the MSO, see ISO/IEC 18013-5 clause 9.1.2.4.

Note: The value of the age_over_18, age_over_NN, or age_in_years attributes, if present, changes whenever the User to whom the person identification data relates has a relevant birthday. The value of many other attributes will also change over time.

PID_13SHALL

If a PID Provider issues PIDs compliant with ISO/IEC 18013-5 and containing the `issuance_date` or `expiry_date` attributes, the PID Provider SHALL have a policy for determining the value of these attributes relative to the `validFrom` and `validUntil` elements in the MSO, see ISO/IEC 18013-5 clause 9.1.2.4.

Note: See the notes to the `issuance_date` and `expiry_date` attributes in PID Rulebook. Examples of aspects to be considered in the policy may include (but are not limited to) the following: 1) If an `issuance_date` or `expiry_date` is encoded as a `full-date` (rather than a `tdate`), it has no time element. However, `validFrom` and `validUntil` contain a time element, which is expressed in UTC. Therefore, comparing `expiry_date` to `validUntil`, for instance, may give ambiguous results in case the local time is not equal to UTC. The policy should ensure that situations are avoided where the User can legitimately expect (based on the values of `issuance_date` and `expiry_date` shown by the Wallet Unit when displaying the PID) that they can use their PID, while in reality its technical validity period (as determined by `validFrom` and `validUntil`) has not yet begun or has ended. 2) The exact meaning of `issuance_date` and `expiry_date` depends on local law and regulations. For example, in some jurisdictions an identity document whose `expiry_date` is in the past may by law still be used for identification for some purposes. However, this requires that the PID is still valid according to the `validFrom` and `validUntil` timestamps in the MSO. 3) A local requirement may exist stating that `issuance_date` and `expiry_date` must be identical to the dates on an existing physical document of the User.

C. HLRs for SD-JWT VC-compliant PIDs

PID_14SHALL

A PID Provider issuing SD-JWT VC-compliant PIDs SHALL include the vct claim in their PIDs, where the vct claim SHALL be a URN within the `urn:eudi:pid:` namespace. The type indicated by the vct claim SHALL be `urn:eudi:pid:1` for the type defined in this document or a domestic type that extends it.

PID_15

Empty

PID_16SHALL

A PID Provider that defines a domestic type SHALL publish information about the type, including all claim identifiers, their definition, presence and encoding format, in an Attestation Rulebook complying with all applicable requirements in Topic 12.

PID_17SHALL

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL include both the attributes and the metadata specified in CIR 2024/2977 in the PID as claims.

Note: This implies that technically speaking, there is no difference between these attributes and metadata.

PID_18SHALL

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL encode each attribute or metadata in the PID as specified in the tables in Section 5.2 of the PID Rulebook.

PID_19SHALL

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL ensure that the value of all attributes and metadata in the PID is valid at the value of the timestamp in the nbf claim, if present.

Note: The value of the age-related claims, if present, changes whenever the User to whom the person identification data relates has a relevant birthday. The value of many other attributes will also change over time.

PID_20SHALL

If a PID Provider issues PIDs compliant with SD-JWT VC and containing the `date_of_issuance` or `date_of_expiry` claims, the PID Provider SHALL have a policy for determining the value of these claims relative to the `nbf` and `exp` claims in the SD-JWT VC, see SD-JWT VC section 3.2.2.2.

Note: See the notes to the `date_of_issuance` and `date_of_expiry` attributes in PID Rulebook. Examples of aspects to be considered in the policy may include (but are not limited to) the following: 1) `date_of_issuance` and `date_of_expiry` claims do not have a time element. However, `nbf` and `exp` express a time relative to UTC. Therefore, comparing `date_of_expiry` to `exp`, for instance, may give ambiguous results in case the local time is

not equal to UTC. The policy should ensure that situations are avoided where the User can legitimately expect (based on the value of `date_of_issuance` *and* `date_of_expiry` *shown by the Wallet Unit when displaying the PID) that they can use their PID, while in reality its technical validity period (as determined by* `nbf` *and* `exp`*) has not yet begun or has ended. 2) The exact meaning of* `date_of_issuance` *and* `date_of_expiry` *depends on local law and regulations. For example, in some jurisdictions an identity document whose* `date_of_expiry` *is in the past may by law still be used for identification for some purposes. However, this requires that the PID is still valid according to the* `nbf` *and* `exp` *timestamps in the SD_JWT VC. 3) A local requirement may exist stating that* `date_of_issuance` *and* `date_of_expiry` *must be identical to the dates on an existing physical document of the User.*

PID_21SHALL

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL make all claims (i.e., all top-level properties, all nested properties, and all array entries) selectively disclosable individually, except those claims defined as non-selectively disclosable in SD-JWT VC.

A.2.3.3 Topic 4 - mDL Rulebook

mDL_01SHALL

mDLs and mDL Providers SHALL comply with all requirements in mDL Rulebook.

A.2.3.4 Topic 6 - Relying Party authentication and User approval

A. Relying Party authentication

RPA_01SHALL

The Wallet Unit used by a User, as well as the Relying Party Instance used by the Relying Party, SHALL implement a mechanism for Relying Party authentication in PID or attestation presentation transactions. This mechanism SHALL: - enable the Wallet Unit to identify and authenticate the Relying Party, - enable the Wallet Unit to verify that the request from the Relying Party was not copied and replayed, - use an access certificate issued in accordance with Topic 27].

Note: Wallet Units and Relying Parties comply with this requirement if they comply with the requirements in this Topic.

RPA_01aSHALL

A Wallet Unit SHALL retain full authority over the process meant in RPA_01. In particular, this process SHALL NOT be handled by a third party, including the browser and the operating system.

Note: This requirement applies, in particular, in the context of the W3C Digital Credentials API.

RPA_02SHALL

For performing Relying Party authentication, Wallet Units and Relying Party Instances SHALL support access certificates as specified in ETSI TS 119 475 and ETSI TS 119 411-8.

Note: In ISO/IEC 18013-5, the Relying Party authentication mechanism is called mdoc reader authentication and uses an X.509 certificate. For OpenID4VP, HAIP specifies that Client Identifier Prefix `x509_hash` must be used to authenticate the Relying Party. This mechanism also uses an X.509 certificate.

RPA_02a

Empty

RPA_03SHALL

A Wallet Unit and a Relying Party Instance SHALL perform Relying Party authentication in all PID or attestation presentation transactions to Relying Parties, whether proximity or remote, using an access certificate.

Note: The actions both entities perform differ. For example, while the Relying Party creates a signature over some data in the request, the Wallet Unit validates that signature.

RPA_04SHALL

For the verification of access certificates, a Wallet Unit SHALL accept only the trust anchors in the LoTE(s) of all Access Certificate Authorities notified by Member States.

Note: For more information about Access Certificate Authorities, please see Topic 31].

RPA_05SHALL

If Relying Party authentication fails for any reason, the Wallet Instance SHALL inform the User that the identity of the Relying Party could not be verified and that therefore the request is not trustworthy.

RPA_06SHALL

If Relying Party authentication succeeds, the Wallet Instance SHALL display to the User the trade names of the Relying Party and its Service, as included in the access certificate received

from the Relying Party Instance, together with the attributes requested by the Relying Party. The Wallet Instance SHALL do so when asking the User for approval according to RPA_07.

Note: a) A Relying Party Instance may be used for multiple Relying Party Services, provided it has received a separate access certificate for each, see Reg_10a. b) If the authenticated Relying Party is an intermediary acting on behalf of an intermediated Relying Party, the Wallet Instance does not display the trade names of the intermediary and its Service, but only those of the intermediated Relying Party; see RPI_07.

RPA_06aSHALL

If Relying Party authentication fails for any reason, the Wallet Unit SHALL notify the User. In addition, the Wallet Unit SHALL either not present the requested attributes to the Relying Party, or give the User the choice to present the requested attributes or not.

Note: It is up to the Wallet Provider to make a choice for one of these two options.

B. User approval

RPA_07SHALL

A Wallet Unit SHALL ensure the User approved the presentation of any attribute(s) in the Wallet Unit to a Relying Party or Verifier Wallet Unit, prior to presenting these attributes. A Wallet Unit SHALL always allow the User to refuse presenting an attribute requested by the Relying Party or Verifier Wallet Unit.

RPA_07aSHALL

A Wallet Unit SHALL retain full authority over the process meant in RPA_07, RPA_07b, and RPA_07c. In particular, this process SHALL NOT be handled by a third party, including the browser and the operating system.

Note: This requirement applies, in particular, in the context of the W3C Digital Credentials API.

RPA_07bSHALL

In addition to RPA_07, in case the Wallet Unit warns the User about failed verifications regarding the Relying Party's access certificate or registration certificate, the Wallet Unit SHALL ensure that User approval is explicit. Silence or pre-ticked boxes SHALL NOT suffice.

RPA_07cSHALL

In addition to RPA_07, in case a Relying Party requests the presentation of the portrait in a PID (see PID Rulebook), the Wallet Unit SHALL warn the User that the request involves

the presentation of biometric data. The Wallet Unit SHALL ensure that User approval for presenting the portrait is explicit. Silence or a pre-ticked box SHALL NOT suffice.

RPA_08SHALL

A Wallet Unit SHALL authenticate the User before allowing the User to give or refuse approval for releasing any attributes, in accordance with WIAM_14 or WIAM_15, as applicable.

RPA_09

Empty

RPA_10SHALL

When asking for User approval, the Wallet Unit SHALL show to the User the User-friendly description of the Relying Party's intended use and the link to the applicable privacy policy.

Note: The User-friendly description of the Relying Party's intended use is included in the registration certificate. The link to the privacy policy is also included in the registration certificate. See Topic 44 for details.

RPA_10aSHOULD

The Wallet Unit SHOULD ensure that the User gives approval either to present all attributes requested in a presentation request, or none of them.

Note: This means that a User should be asked either to approve the presentation of all requested attributes or to deny all of them. The Wallet Unit should not allow partial approval, since this would mean that the Relying Party cannot deliver the service, but nevertheless receives some User attributes. This would be a violation of the User's privacy. Note that a Relying Party is not allowed to request more data than is justified for the intended use. So if the User feels that the Relying Party is actually requesting more data than needed, that implies that the Relying Party is not trustworthy and should not receive any data.

RPA_11SHALL

When the presentation of an attestation or a PID is denied by the User, the Wallet Unit SHALL behave towards the Relying Party as if the attestation or PID did not exist.

RPA_12MAY

When asking for User approval, the Wallet Unit MAY indicate to the User whether the attestation requested by a Relying Party is device-bound or not.

Note: The intent of this indication is to warn the User that a non-device-bound attestation may be copied by the Relying Party and presented to a third party.

A.2.3.5 Topic 7 - Attestation revocation and revocation checking

VCR_01SHALL

A PID Provider, QEAA Provider, or PuB-EAA Provider SHALL use one of the following methods for revocation of an ISO/IEC 18013-5-compliant PID, QEAA, or PuB-EAA: - Only issue short-lived attestations having a validity period of 24 hours or less, such that revocation will never be necessary, - Use an Attestation Status List mechanism specified per VCR_11, or - Use an Attestation Revocation List mechanism specified per VCR_11.

Note: The 24-hour period originates from ETSI EN 319 411-1 V1.4.1, requirement REV-6.2.4-03A. This requires that the process of revocation must take at most 24 hours. Consequently, revocation may make no sense if the attestation is valid for less than 24 hours, because it may reach the end of its validity period before it is revoked.

VCR_01aSHALL

A Wallet Provider SHALL use the method specified in Technical Specification 3 for maintaining the revocation status of the underlying objects referenced in a WIA or key attestation.

Note: The 'underlying object' is the object that is actually revoked by revoking the WIA or key attestation, i.e., the Wallet Instance in case of a WIA and a WSCA/WSCD or keystore in case of a key attestation.

VCR_01bSHALL

A PID Provider, QEAA Provider, or PuB-EAA Provider SHALL use one of the following methods for revocation of a SD-JWT VC-compliant PID, QEAA, or PuB-EAA: - Only issue short-lived attestations having a validity period of 24 hours or less, such that revocation will never be necessary or, - Use an Attestation Status List mechanism specified per VCR_11.

Note: The 24-hour period originates from ETSI EN 319 411-1 V1.4.1, requirement REV-6.2.4-03A. This requires that the process of revocation must take at most 24 hours. Consequently, revocation may make no sense if the attestation is valid for less than 24 hours, because it may reach the end of its validity period before it is revoked.

VCR_02SHALL

For non-qualified EAAs, the relevant Rulebook SHALL specify whether that type of EAA must be revocable. If a non-qualified EAA type must be revocable, the relevant Rulebook SHALL determine which of the methods mentioned in VCR_01 or VCR_01b (as applicable) must be implemented by the relevant EAA Providers for the revocation of such an EAA.

VCR_03SHALL

If a PID or attestation is revocable, the PID Provider of a given PID, or the Attestation Provider of a given attestation, SHALL be the only party in the EUDI Wallet ecosystem responsible for executing the revocation of that PID or attestation.

Note: A PID Provider or Attestation Provider MAY outsource the operation of the revocation process to a third party.

VCR_03aSHALL

The Wallet Provider of a given WIA or KA SHALL be the only party in the EUDI Wallet ecosystem responsible for maintaining the revocation status of the underlying object attested in that WIA or KA.

Note: A Wallet Provider MAY outsource the operation of the revocation process to a third party.

VCR_04SHALL

A PID Provider, Attestation Provider, or Wallet Provider that revoked a PID, attestation, WIA, or KA SHALL NOT reverse the revocation.

VCR_05SHALL

If a PID, attestation, WIA, or KA is revocable, the PID Provider, Attestation Provider, or Wallet Provider SHALL have a policy specifying under which conditions a PID, attestation, WIA, or KA it issued will be revoked.

VCR_06SHALL

If a PID or attestation is revocable, the PID Provider or Attestation Provider SHALL revoke a PID or attestation when its security has been compromised.

VCR_07SHALL

A Wallet Provider SHALL revoke the Wallet Instance upon the explicit request of the User to revoke their Wallet Unit.

Note: See also WURevocation_07 and _10.

VCR_07aSHALL

If a PID is revocable, the PID Provider SHALL revoke that PID upon the explicit request of the User to whom the PID was issued.

VCR_07bSHOULD

If an attestation is revocable, the Attestation Provider SHOULD revoke that attestation upon the explicit request of the User to whom the attestation was issued.

VCR_07cSHALL

If a PID is revocable, the PID Provider SHALL revoke that PID if the Wallet Unit on which it resides is revoked, in compliance with requirement WURevocation_18 in Topic 38.

VCR_07dMAY

If an attestation is revocable, the Attestation Provider MAY revoke that attestation if the Wallet Unit on which it resides is revoked, in compliance with requirement WURevocation_19 in Topic 38.

VCR_07eSHALL

If a Wallet Provider uses the per-KA approach for key attestation revocation (see WUA_28), it SHALL revoke a WSCD or keystore upon the explicit request of the User to revoke their WSCD or keystore.

Note: a) The most likely cause of such a request would be that the WSCD or keystore is a local external smart card and the User lost their WSCD or keystore. b) In contrast, under the type-shared index approach (see WUA_28), revoking the WSCD or keystore is not a per-Wallet Unit action that can be triggered by user requests. c) See also WURevocation_07a.

VCR_08SHALL

If a PID is revocable, the PID Provider SHALL revoke a PID upon the death of the natural person who is the subject of the PID.

Note: a) In addition, in these circumstances the PID Provider also requests the Wallet Provider to revoke the Wallet Unit, see WURevocation_11. b) The topic of Wallet Units for legal persons, possibly containing a legal-person PID, has has been removed from this ARF in view of the development of a separate business wallet.

VCR_09SHALL

If a technical PID or attestation is revocable, the PID Provider or Attestation Provider SHALL revoke that PID or attestation if the value of one or more of the attributes in the corresponding logical PID or attestation was changed (including attributes being added or deleted) and the technical PID or attestation is still valid for at least 24 hours. Subsequently, if the User's contact details are known, the PID Provider or Attestation Provider SHOULD, via an out-of-band manner, notify the User about the revocation and ask the User to request re-issuance of the PID or attestation using their Wallet Unit.

Note: If the value of the attributes is determined by a party different from the PID Provider or Attestation Provider, such as an Authentic Source, the Provider is responsible for ensuring that this third party notifies them about such changes.

VCR_10SHALL

Wallet Providers SHALL implement the Attestation Status List and Attestation Revocation List mechanisms specified per VCR_11 in their Wallet Solutions.

VCR_11SHALL

For ISO/IEC 18013-5-compliant PIDs and attestations, the PID Provider or Attestation Provider SHALL implement the Attestation Status List or Attestation Revocation List mechanism as specified in Annex 2 of (the amended) CIR [2024/2979).

Note: a) 'Attestation Status List' and 'Attestation Revocation List' are specific mechanisms, these terms are defined in Annex 1. b) Attestation Revocation Lists are sometimes referred to as 'Identifier Lists'. c) The relevant texts in this CIR are copied from the forthcoming 2nd edition of ISO/IEC 18013-5, available here.

VCR_11aSHALL

For SD-JWT VC-compliant PIDs and attestations, the PID Provider or Attestation Provider SHALL implement the Attestation Status List mechanism as specified in Token Status List.

Note: No suitable specification of Attestation Revocation Lists in JSON format is available.

VCR_12SHALL

If a Relying Party decides it needs to be able to verify the revocation status of PIDs or attestations, it SHALL support both the Attestation Status List mechanism and the Attestation Revocation List mechanism specified per VCR_11.

Note: Per VCR_13, it is recommended but not mandatory for a Relying Party to verify whether a PID or attestation is revoked.

VCR_12aSHALL

A PID Provider or Attestation Provider SHALL support the mechanism specified per VCR_01a for verifying the revocation status of a WIA or KA.

VCR_13SHALL

A Relying Party Instance SHOULD verify the revocation status of a revocable PID or attestation upon obtaining it from a Wallet Unit. When a Relying Party considers deviating from this

recommendation by not performing revocation checking, it SHALL perform a risk analysis considering all relevant factors for the use case, including risks to the User, the PID Provider or Attestation Provider, and risks to the Relying Party itself.

VCR_14SHALL

A Relying Party SHALL perform a risk analysis considering all relevant factors for the use case, including risks to the User and risks to the Relying Party itself, to determine whether it will accept or refuse a PID or attestation in case no reliable information regarding the revocation status of that PID or attestation is available.

Note: Examples of conditions under which no reliable revocation information is available are 1) The attestation does not contain revocation information (because it is not revocable). 2) The Relying Party Instance is offline and any cached status information is no longer valid. 3) The latest attestation status lists or attestation identifier lists provided by the PID Provider or Attestation Provider (i.e., available online) are no longer valid. 4) The Relying Party Instance is offline, but the use case requires up-to-date revocation information (instead of trusting cached information that is still valid.)

VCR_15SHOULD

A Relying Party Instance SHOULD NOT request the relevant Attestation Status List or Attestation Revocation List each time an attestation is presented to it by a Wallet Unit. Rather, the Relying Party operating the Relying Party Instance SHOULD download each new version of the list once, at a time and from a location unrelated to the presentation of a PID or attestation by a User. The Relying Party SHOULD then distribute the list to all of its Relying Party Instances, using an Relying Party-internal distribution mechanism. Each Relying Party Instance SHOULD cache the list, so that it can perform revocation checks without making an online request. The Relying Party SHOULD perform a risk analysis to determine the frequency with which it will download the revocation lists and the maximum caching period its Relying Party Instances will use.

VCR_16SHALL

A PID Provider, Attestation Provider or Wallet Provider SHALL NOT require the Relying Party or Relying Party Instance to authenticate itself before downloading an Attestation Status List or Attestation Revocation List.

VCR_17SHALL

When using an Attestation Status List for revocation, the PID Provider, Attestation Provider or

Wallet Provider SHALL randomly assign the index for each PID or attestation, to prevent this index from becoming a correlator.

Note: Randomly assigning indices within a bitstring or byte array is more complicated than creating random identifiers (e.g. serial numbers) for attestations, as is needed for an Attestation Revocation List. This is because duplicate indices and unnecessarily long bitstrings or byte arrays must be prevented.

VCR_18SHALL

When using an Attestation Status List for revocation, the PID Provider, Attestation Provider, or Wallet Provider SHALL represent a sufficiently large number of PIDs, attestations, WIAs, or KAs on each Attestation Status List to ensure herd privacy.

Note: In this context, herd privacy means that if an entity requests a particular status list, the PID Provider, Attestation Provider, or Wallet Provider is not able to deduce which PID, attestation, WIA, or KA (likely) was presented to that entity. Complying with this requirement may be difficult in case the number of PIDs, attestations, WIAs, or KAs to be represented on the list is small. In such a case, decoy entries can be added to the list to obfuscate the real number of referenced PIDs, attestations, WIAs, or KAs.

VCR_19SHALL

A Wallet Instance SHOULD regularly check the revocation status of its PIDs and attestations. In addition, the Wallet Instance SHOULD regularly check whether itself or any WSCD or keystore it uses has been revoked. In case of any revocation, the Wallet Instance SHALL notify the User accordingly.

Note: A Wallet Instance can check its own revocation status using its WIAs, and the revocation status of its WSCD and keystores using its key attestations.

A.2.3.6 Topic 9 - Key Attestation and Wallet Instance Attestation

A. Key attestations

WUA_01SHALL

A Key Attestation SHALL contain information about the certification of the WSCA/WSCD or a keystore available to the Wallet Unit, and SHALL comply with the relevant requirements in Technical Specification 3.

Note: A PID Provider or Attestation Provider can use this information to take a well-grounded decision on whether to issue a PID or attestation to the Wallet Unit.

WUA_02SHALL

A Key Attestation SHALL enable PID Providers and Attestation Providers to verify the authenticity of a WSCD or keystore and to check whether the WSCD or keystore has been revoked.

Note: A KA carries a revocation reference that is valid for the WSCD or keystore of the Wallet Unit. How this revocation reference is managed (individually or per type of WSCD/keystore) depends on the approach chosen by the Wallet Provider (see WUA_28), but this is not relevant for the PID Provider or Attestation Provider that receives the KA.

WUA_03SHALL

A Wallet Provider SHALL ensure that a non-revoked Wallet Unit at all times can present a temporally valid and non-revoked KA to a PID Provider or Attestation Provider during the issuance process of a PID or device-bound attestation.

Note: a) Revocation refers to the attested WSCD/keystore, not to the KA itself. b) For example, the Wallet Provider could pro-actively issue new KAs to the Wallet Unit, so that the Wallet Unit is always in possession of a valid KA. Alternatively, the Wallet Provider could ensure that whenever the User opens the Wallet Unit, it checks whether it is possession of a valid KA, and requests the Wallet Provider to issue a new KA if needed. A third possibility is that the Wallet Unit does this check only when it starts the process of requesting the (re-)issuance of a PID or attestation. Other alternatives to comply with this requirement may be used as well.

WUA_04SHALL

When issuing, presenting, or verifying a WIA or KA, Wallet Providers, Wallet Units, PID Providers, and Attestation Providers SHALL only use cryptographic algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

WUA_05SHALL

During issuance of a PID, the Wallet Unit SHALL provide the PID Provider with a valid KA describing the WSCA/WSCD that generated the new PID private key.

Note: A PID private key is always generated and managed by the WSCA/WSCD, which by definition complies with requirements for Level of Assurance High.

WUA_05aSHALL

During issuance of a device-bound attestation, a Wallet Unit SHALL retrieve the requirements of the Attestation Provider regarding key storage from the Credential Issuer metadata (see ISSU_27d). The Wallet Unit SHALL determine which of its WSCA/WSCD or keystore(s), if any,

comply with these requirements. If a compliant WSCA/WSCD or keystore is available to the Wallet Unit, the Wallet Unit SHALL provide the Attestation Provider with a valid KA describing the selected WSCA/WSCD or keystore.

Note: A KA describes the certification properties of the WSCA/WSCD or a keystore (see WUA_01) and contains one or more public key(s) corresponding to private key(s) generated by and stored in that WSCA/WSCD or keystore (see WUA_09).

WUA_06SHALL

If a Wallet Unit contains a WSCA/WSCD and one or more keystores, it SHALL, internally and securely, keep track of which PID(s) and attestation(s) are bound to which WSCA/WSCD or keystore.

WUA_07SHALL

A Wallet Unit SHALL present a KA only to a PID Provider or Attestation Provider, as part of the issuance process of a PID or a key-bound attestation, and not to a Relying Party or any other entity.

WUA_08SHALL

A WIA SHALL enable PID Providers to request a Wallet Provider to revoke a Wallet Unit, in accordance with requirement WURevocation_11, by including an identifier for the Wallet Instance in the WIA. The Wallet Provider SHALL ensure that this Wallet Instance identifier does not enable tracking of the User.

Note: a) This is a legal requirement from CIR 2024/2977. b) Under Technical Specification 3 V1.5, this Wallet Instance identifier is the URI and index to the Attestation Status List for WIAs.

B. Key Attestation and Cryptographic Keys

WUA_09SHALL

A KA SHALL contain one or more public keys, and the corresponding private keys SHALL be generated by and stored in the WSCA/WSCD or the keystore described in the KA.

Note: By signing the KA, the Wallet Provider attests to the fact that the private key(s) corresponding to the public key(s) in the KA are generated by and stored in this WSCA/WSCD or keystore. This implies that the Wallet Provider has verified that this is actually the case. However, neither the ARF nor Technical Specification 3 specify at which moment the WSCA/WSCD or keystore generated the private keys, or how the Wallet Provider verified that it did so.

WUA_09aSHALL

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL bind the issued PID(s) or attestation(s) to one of the public keys attested in the KA received from the Wallet Unit.

Note: This implements device binding, see ISSU_17 and ISSU_27.

WUA_10SHALL

Wallet Providers SHALL ensure that the certificates they use for signing WIAs and KAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 5.

WUA_10aSHALL

An Attestation Provider issuing non-device-bound attestations SHALL indicate in its Credential Issuer metadata that it does not need a KA, as specified in Technical Specification 3. A Wallet Unit SHALL NOT send a KA to an Attestation Provider when requesting a non-device-bound attestation.

Note: A Wallet Unit sends a WIA to the Attestation Provider regardless of whether the attestations it issues are device-bound or not.

WUA_10bSHALL

A Wallet Provider SHALL ensure that the presentation of a KA is cryptographically bound to the specific context it is intended to be used in.

Note: As specified in Technical Specification 3, this is achieved by letting the signed KA itself contain a nonce provided by the PID Provider or Attestation Provider during the issuance process. Alternatively, the Wallet Unit presents the KA along with a Proof-of-Possession consisting of a signature over that nonce, created by the private key corresponding to one of the public keys attested in the KA.

WUA_11MAY

When asking for User approval to store an attestation (see ISSU_11), the Wallet Unit MAY indicate to the User whether the attestation requested by a Relying Party is device-bound or not.

Note: The intent of this indication is to warn the User that a non-device-bound attestation may be copied by an attacker breaching the Wallet Unit's security. See also RPA_12.

WUA_11aSHALL

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL verify the KA in accordance with the requirements in OpenID4VCI Appendix F.4. In addition, the PID Provider or Attestation Provider SHALL validate that the KA is not revoked.

Note: If the verification of the KA is successful, the PID Provider or Attestation Provider can trust that all public keys in the KA are bound to the WSCD or keystore described in the KA (see WUA_09).

WUA_11b

Empty

WUA_12SHALL

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL receive a proof that the Wallet Unit possesses the private keys corresponding to all public keys in the KA.

Note: As specified in Technical Specification 3, this proof consists of the signature of the Wallet Provider over the KA in combination with the proof mentioned in WUA_10b.

WUA_13

Empty

WUA_14

Empty

WUA_15

Empty

WUA_16

Empty

WUA_16aSHALL

A WSCA SHALL NOT enable export of private keys from a WSCD.

Note: The WSCA is dedicated firmware and/or software implementing specific functions needed within the EUDI Wallet ecosystem. Within that context, there is no need for private key export. Therefore, a WSCA must not support it. However, a WSCD or a keystore may enable private key export via native firmware or software, for generic purposes.

C. Requirements Regarding Privacy

WUA_17SHALL

A Wallet Provider SHALL consider all relevant factors, including offline usage, interoperability, and the risk of a WIA or KA becoming a vector to track the User, when deciding on the validity period of a WIA or KA.

Note: a) Regarding interoperability, see WUA_30, which limits the validity period of PIDs issued based on the revocation maintenance periods of the WIA and KA received during issuance. b) As specified in Technical Specification 3, a PID Provider or Attestation Provider may communicate its preferences regarding the minimum revocation maintenance period of the WIA and KA to the Wallet Unit. The Wallet Unit and the Wallet Provider should take this into account (see WUA_32). c) For the WIA specifically, a short technical validity period is required to ensure freshness. See WUA_33.

WUA_18

Empty

WUA_19

Empty

WUA_20

Empty

WUA_20a

Empty

WUA_21

Empty

D. Wallet Instance Attestations

WUA_22SHALL

A Wallet Provider SHALL ensure that a non-revoked Wallet Unit at all times can present a temporally valid and non-revoked WIA to a PID Provider or Attestation Provider during the issuance process of a PID or attestation.

Note: a) This requirement applies to both device-bound and non-device-bound attestations. b) Revocation refers to the attested Wallet Instance, not to the WIA itself. c) For example, the Wallet

Provider could pro-actively issue new WIAs to the Wallet Unit, so that the Wallet Unit is always in possession of a valid WIA. Alternatively, the Wallet Provider could ensure that whenever the User opens the Wallet Unit, it checks whether it is possession of a valid WIA, and requests the Wallet Provider to issue a new WIA if needed. A third possibility is that the Wallet Unit does this check only when it starts the process of requesting the (re-)issuance of a PID or attestation. Other alternatives to comply with this requirement may be used as well.

WUA_23

Empty

WUA_24SHALL

A Wallet Unit SHALL present a WIA only to a PID Provider or Attestation Provider, as part of the issuance process of a PID or an attestation, and not to a Relying Party or any other entity.

WUA_25SHALL

During issuance of a PID or attestation, the PID Provider or Attestation Provider SHALL verify the WIA in accordance with the requirements in OpenID4VCI Appendix E. In addition, the PID Provider or Attestation Provider SHALL validate that the WIA is not revoked.

Note: This requirement applies to both device-bound and non-device-bound attestations.

WUA_26SHALL

A WIA SHALL enable PID Providers and Attestation Providers to verify the authenticity of a Wallet Instance and to check whether the Wallet Instance has been revoked.

Note: A WIA carries the revocation reference for a Wallet Instance. The revocation status of the Wallet Instance is maintained in a status list referenced in the WIA.

WUA_27SHALL

A WIA SHALL contain information about the Wallet Solution, including its identity, version, and certification, and SHALL comply with the relevant requirements in Technical Specification 3.

Note: This information allows PID Providers and Attestation Providers to verify that the Wallet Instance belongs to a trusted and certified Wallet Solution, as registered in the Wallet Provider Trusted List.

E. Miscellaneous

WUA_28SHALL

A Wallet Provider SHALL select either the type-shared index approach or the per-KA index approach (as specified in Section 2.5.2 of Technical Specification 3) for managing the revocation status of the WSCD or keystore referenced in a Key Attestation.

Note: a) Under the type-shared index approach, the revocation reference is shared across all Wallet Units using the same type of WSCD or keystore, so that a single revocation action covers all affected Wallet Units (e.g., when a security vulnerability is identified in a hardware component type). Under the per-KA index approach, each KA carries a revocation reference scoped to the specific Wallet Unit's WSCD or keystore instance, enabling individual revocation that may also be triggered by user request. b) The detailed requirements for each approach are specified in Technical Specification 3.

WUA_28aSHALL

If the per-KA index approach is used, the Wallet Provider SHALL ensure that the revocation reference in a KA cannot be used to link a Wallet Unit's interactions across different PID Providers or Attestation Providers.

WUA_29SHALL

Throughout the entire validity period of an issued PID, the PID Provider SHALL verify the revocation status of both the Wallet Instance and WSCD using the information in the WIA and the KA (respectively) received during the issuance of that PID. If either is revoked, the PID Provider SHALL revoke the PID.

WUA_30SHALL

The technical validity period of a PID SHALL be consistent with the period during which the Wallet Provider has committed to maintaining the revocation status of the Wallet Instance and the WSCD, as conveyed in the WIA and KA presented during issuance.

Note: a) This reflects the revocation chaining requirement: PID Providers must be able to check whether the Wallet Instance has been revoked (via the WIA) and whether the WSCD referenced in the KA has been revoked (WUA_29) for the entire PID validity period.

WUA_31SHALL

A Wallet Provider SHALL maintain the revocation status of a Wallet Instance during the entire revocation maintenance period indicated in the WIAs issued to that Wallet Instance.

WUA_31aSHALL

A Wallet Provider SHALL maintain the revocation status of a WSCD or keystore during the entire revocation maintenance period indicated in the KAs issued to the Wallet Instance(s) using that WSCD or keystore.

WUA_32SHALL

A PID Provider or Attestation Provider having minimum requirements regarding the remaining revocation maintenance period for Wallet Instances (in WIAs) or WSCDs or keystores (in KAs) SHALL communicate these requirements to the Wallet Unit at the time of PID or attestation issuance, as specified in Technical Specification 3.

Note: This allows PID Providers and Attestation Providers to ensure that they receive WIAs and KAs with a sufficiently long remaining revocation maintenance period, enabling revocation chaining for the intended validity period of the PID or attestation to be issued.

WUA_33SHALL

A Wallet Provider SHALL ensure that WIAs have a short technical validity period as specified in Technical Specification 3, such that a WIA is fresh at the time of use.

Note: As specified in Technical Specification 3, the technical validity period of a WIA SHALL be less than 24 hours. This ensures that the WIA reflects a recent integrity check of the Wallet Instance. The revocation maintenance period (see WUA_26 and WUA_31) is specified separately in the WIA and may be considerably longer than the technical validity period.

WUA_34SHALL

During issuance of a PID, a PID Provider SHALL verify that the keys attested in the KA are stored in the WSCA/WSCD described in the KA.

Note: PID private keys must be protected at Level of Assurance High, which requires key storage in a WSCA/WSCD. See also WUA_05, which requires the Wallet Unit to provide a KA describing the WSCA/WSCD that generated the PID private key.

WUA_35SHALL

A Wallet Unit SHALL comply with all relevant requirements specified in Technical Specification 3.

WUA_36SHALL

A PID Provider or Attestation Provider SHALL comply with all relevant requirements specified in Technical Specification 3.

WUA_37SHALL

A Wallet Provider SHALL maintain, for each Wallet Unit it has activated, the set of WIAs and KAs it has issued to that Wallet Unit, in such a way that this association cannot be confused with that of any other Wallet Unit, including across different Wallet Solutions or different Wallet Solution versions. The Wallet Provider SHALL document the procedures, controls, and corresponding risk analysis implementing this requirement as part of the policy meant in WURevocation_03.

Note: This requirement makes explicit at the HLR level the record-keeping duty already implicit in WURevocation_07, WURevocation_07a, WIAM_05, WIAM_06, and WIAM_10.

A.2.3.7 Topic 10 - Issuing a PID or attestation to a Wallet Unit

A - Generic HLRs

ISSU_01SHALL

Wallet Providers SHALL ensure that their Wallet Solution supports the OpenID4VCI protocol specified in OpenID4VCI, as profiled in Sections 4 and 6 of HAIP, and with additions and changes as documented in this Annex (see e.g. this Topic and Topic 9) and in Technical Specification 3.

Note: For clarity: in HAIP v1.0, Section 6 implies that Wallet Units must comply with the applicable requirements in OpenID4VCI Annex A.2 when requesting the issuance of an attestation in ISO/IEC 18013-5-compliant format, and with the applicable requirements in OpenID4VCI Annex A.3 when requesting the issuance of an attestation in SD-JWT VC format.

ISSU_01aSHALL

PID Providers and Attestation Providers SHALL support the OpenID4VCI protocol specified in OpenID4VCI, as profiled in Sections 4 and 6 of HAIP, and with additions and changes as documented in this Annex (see e.g. this Topic and Topic 9) and in Technical Specification 3.

Note: a) For clarity: in HAIP v1.0, Section 6 implies that PID Providers and Attestation Providers must comply with the applicable requirements in OpenID4VCI Annex A.2 when issuing an attestation in ISO/IEC 18013-5-compliant format, and with the applicable requirements in OpenID4VCI Annex A.3 when issuing an attestation in SD-JWT VC format. b) In addition to supporting OpenID4VCI, PID Providers are allowed to support other protocols for issuing PIDs to (national) Wallet Units, provided these protocols comply with all relevant requirements in the Implementing Acts and the standards referenced therein. In many Member States, the PID Provider and

the Wallet Provider are closely related, and can therefore bilaterally agree to support a different protocol for PID issuance.

ISSU_02SHALL

Wallet Providers SHALL ensure that their Wallet Solution supports the attestation formats specified in ISO/IEC 18013-5, see ISO/IEC 18013-5, and in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC, with additions and changes as documented in this Annex and in ETSI TS 119 472-1.

ISSU_03SHALL

Wallet Units, PID Providers, and Attestation Providers SHALL support the W3C Digital Credentials API for the issuance of PIDs and attestations.

Note: This requirement implies that the following conditions will be satisfied: a) the DC API specification will become a W3C Recommendation, b) this specification will comply with the principles outlined in Section 4.4.3.1 of the ARF main document, c) this specification will be broadly supported by relevant browsers and operating systems, and d) the OpenID4VCI standard will specify how to use OpenID4VCI with the DC API.

ISSU_04

Empty

ISSU_05SHALL

A Wallet Unit SHALL support a process to activate a newly issued PID, in accordance with the requirements for LoA High in Commission Implementing Regulation (EU) 2015/1502 Section 2.2.2. The Wallet Unit SHALL NOT allow a User to use a non-activated PID.

Note: a) The goal of the activation process is to verify that the PID was delivered into the Wallet Unit and WSCA/WSCD of the User who is the subject of the PID. b) This requirement is not applicable for QEAAs, PuB-EAAs or non-qualified EAAs, since these are not identity means in the sense of Commission Implementing Regulation (EU) 2015/1502.

ISSU_06SHALL

After a Wallet Unit receives a PID or an attestation from a PID Provider or Attestation Provider, it SHALL verify that the PID or attestation it received matches the PID or attestation requested by the Wallet Unit.

ISSU_07SHALL

After a Wallet Unit receives a PID from a PID Provider, it SHALL validate the signature of the PID using a trust anchor of the PID Provider provided in a LoTE made available in accordance with Topic 31].

Note: The Wallet Provider and PID Provider may be the same entity. In such a case, the remote WSCD used by the Wallet Provider may be the same hardware HSM that is also used by the PID Provider to sign PIDs. In such a situation, this requirement may look superfluous, since the same HSM would generate the signature and verify it. However, this is not true, since for security reasons the PID Provider and Wallet Provider must use proper partitioning and logical key segregation within the HSM. Therefore, this requirement also applies in such a situation.

ISSU_08SHALL

After a Wallet Unit receives a QEAA from a QEAA Provider, it SHALL validate the qualified signature of the QEAA in accordance with Art. 32 of the European Digital Identity Regulation. For the verification, the Wallet Unit SHALL use a trust anchor provided in a QEAA Provider Trusted List made available in accordance with Art. 22 of the European Digital Identity Regulation.

Note: a) Requirements ISSU_07 to ISSU_10 are equivalent to requirements OIA_12 to OIA_15 in Topic 1. b) These requirements imply that a Wallet Unit must be aware whether the attestation it is requesting from an issuer is a PID, a QEAA, a PuB-EAA, or a non-qualified EAA. These requirements also imply that the Wallet Unit must store trust anchors in such a way that, when it receives an issued attestation, it is able to distinguish between trust anchors usable either for PIDs, for QEAAs, for PuB-EAAs, or for non-qualified EAAs.

ISSU_09SHALL

After a Wallet Unit receives a PuB-EAA from a PUB-EAA Provider, it SHALL validate the signature of a PuB-EAA using a trust anchor provided in a Pub-EAA Provider LoTE made available in accordance with [Topic 31].

ISSU_10SHALL

After a Wallet Unit receives a non-qualified EAA from an EAA Provider, it SHALL validate the signature of the EAA if it has access to the trust anchors of the EAA Provider.

Note: For a non-qualified EAA, an Attestation Rulebook may be available, see [Topic 12], explaining how EAA Providers distribute their trust anchors. However, it is not required for Wallet Units to be in possession of the trust anchors of all non-qualified EAA Providers, even when an Attestation Rulebook is available.

ISSU_10aSHALL

A Wallet Provider SHALL perform regular trust anchor management, meaning it SHALL download the latest version of all applicable Trusted Lists and LoTEs. If it finds that new trusted entities have been added, or that new trust anchors have been added for existing trusted entities, it SHALL ensure that these trust anchors are properly stored in all relevant Wallet Units. Conversely, if the Wallet Provider finds that an existing trusted entity has been invalidated in the Trusted List or LoTE, or that some of the trust anchors of existing trusted entities have expired, been revoked, or otherwise been invalidated, it SHALL ensure that these trust anchors are removed from all Wallet Units.

ISSU_10bSHALL

For the retrieval and management of trust anchors, Wallet Providers and Wallet Units SHALL support both Trusted Lists complying with ETSI TS 119 612 and LoTEs complying with ETSI TS 119 602.

Note: Trusted Lists complying with ETSI TS 119 612 are used for the distribution of trust anchors of QEAA Providers. LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of PID Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

ISSU_11SHALL

A Wallet Unit SHALL request the User's approval before storing a PID or attestation obtained from a PID Provider or Attestation Provider. When requesting approval, the Wallet Instance SHALL display the contents of the PID or attestation to the User. The Wallet Instance SHALL also inform the User about the identity of the PID Provider or Attestation Provider, using the subject information in the PID Provider's or Attestation Provider's access certificate.

ISSU_11aSHALL

In case a PID or attestation is issued in batches, the Wallet Unit SHALL verify that all PIDs and attestations in a batch have the same attribute values and the same technical validity period.

Note: PIDs and attestations are issued in batches when Method A, Method B, or Method D is used, see ISSU_37, ISSU_43, ISSU_51.

ISSU_11bSHALL

In case one or more of the verifications in ISSU_06 - ISSU_11a fail, the Wallet Unit SHALL immediately delete the PID or attestation it received. The Wallet Instance SHALL notify the

User about the fact that issuance of the PID or attestation was not successful, including the reason for this failure.

ISSU_12SHALL

A PID Provider or Attestation Provider SHALL offer its PIDs or attestations in all formats required in the PID Rulebook or the applicable Attestation Rulebook, see Topic 12].

Note: Examples include the mdoc format specified in ISO/IEC 18013-5 and the SD-JWT VC-format specified in SD-JWT VC.

ISSU_12aSHALL

When a User instructs their Wallet Unit to request a PID or attestation from a PID Provider or Attestation Provider, the Wallet Unit SHALL request that PID or attestation in all formats offered by the PID Provider or Attestation Provider.

Note: Examples include the mdoc format specified in ISO/IEC 18013-5 and the SD-JWT VC-format specified in SD-JWT VC.

ISSU_12bSHALL

The WSCA/WSCD or a keystore SHALL generate a new key pair for a new PID or attestation on request of the Wallet Instance, unless that PID or attestation is issued synchronously in a remote HSM architecture. This generation request MAY be done either prior to the issuance of any PID or attestation, or during the issuance process.

Note: a) See also WUA_05 and WUA_05a. b) In case of synchronous issuing in a remote HSM architecture, re-use of an existing key pair within a limited period of time can be acceptable, based on the PID Provider's or Attestation Provider's issuance security policy. This is similar to a choice between Method A or Method B (see ISSU_37 and ISSU_38) when issuing PIDs or attestations non-synchronously.

ISSU_12cSHALL

The expiration date of a PID SHALL be no later than the end of the revocation maintenance periods of the WIA and the KA presented as part of the PID issuance process.

Note: This requirement is an implication of WURevocation_18 in Topic 38 and WUA_29 - WUA_31. If the PID would be valid beyond the period for which the Wallet Provider has committed to maintaining the revocation status of the Wallet Instance and the WSCD, the PID Provider would not be able to fulfil its obligation to regularly check whether the Wallet Instance and WSCD have been revoked for the full PID validity period.

ISSU_12dSHALL

If an Attestation Provider supports revocation chaining for its attestations per WURevocation_19 in Topic 38, the expiration date of an attestation SHALL be no later than the end of the revocation maintenance periods of the WIA and the KA (if applicable) presented as part of the attestation issuance process.

Note: See note in ISSU_12c.

B - HLRs for PID issuance

ISSU_13SHALL

A Wallet Provider SHALL ensure that at least one PID Provider is willing to issue a PID complying with PID Rulebook to Users of the Wallet Units it provides.

ISSU_14SHALL

A PID Provider SHALL ensure that all PIDs it issues to Wallet Units comply with the requirements specified in PID Rulebook.

ISSU_15SHALL

A PID Provider SHALL support the OpenID4VCI protocol referenced in ISSU_01 for issuing PIDs.

ISSU_16

Empty

ISSU_17SHALL

A PID Provider SHALL implement device binding for all PIDs it issues, meaning it SHALL ensure that a PID is cryptographically bound to the WSCA/WSCD included in the Wallet Unit, as specified in Topic 9.

Note: Device binding is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC.

ISSU_18SHALL

A PID Provider SHALL verify the identity of the subject of the PID in compliance with Level of Assurance (LoA) High requirements.

Note: These requirements will be determined by the relevant eID scheme.

ISSU_18a

Empty

ISSU_19SHALL

For the verification of a WIA or KA, a PID Provider SHALL accept the Wallet Provider trust anchors it needs, as published by the Commission in the Wallet Provider LoTE.

Note: a) The Wallet Provider LoTE is explained in Topic 31. b) It is not mandatory for a PID Provider to store all Wallet Provider trust anchors. This is because it is not mandatory for a PID Provider to accept all certified Wallet Solutions in the EUDI Wallet ecosystem. Each PID Provider will choose which trust anchors they need to use.

ISSU_19aSHALL

A PID Provider SHALL support all Wallet Solutions recognised under the corresponding notified eID scheme, meaning that it is willing and able to issue a PID to a Wallet Unit on request of the User.

ISSU_19bSHALL

For the retrieval and management of trust anchors, PID Providers SHALL support LoTEs complying with ETSI TS 119 602.

Note: LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of Wallet Providers.

ISSU_20SHALL

To inform its potential PID subjects about the Wallet Solution(s) they can use for requesting a PID, a PID Provider SHALL publish a list of supported Wallet Solutions in such a way that it can be easily found, for example on the PID Provider's website.

Note: This a policy requirement rather than a technical requirement.

ISSU_21SHALL

Before issuing a PID, a PID Provider SHALL verify the Wallet Unit's WIA and KA using a trust anchor registered in the Wallet Provider LoTE. Moreover, it SHALL verify that the Wallet Instance referenced in the WIA has not been revoked, and that the WSCD referenced in the KA has not been revoked.

Note: a) For WIAs and KAs, see Topic 9 and Topic 38. b) CIR 2024/2977, Article 3 (9), also allows another authentication mechanism in accordance with an electronic identity scheme notified

at assurance level high. However, the ARF does not further specify such other authentication mechanisms, which means that in general they will not be interoperable.

ISSU_22SHALL

A PID Provider SHALL sign its Credential Issuer metadata as specified in section 12.2.3 of OpenID4VCI. To do so, the PID Provider SHALL use the private key corresponding to the public key in its access certificate. The PID Provider SHALL include its access certificate, as well as all intermediate certificate(s) leading up to the trust anchor of the corresponding Access Certificate Authority (see ISSU_33) in the LoTE, in the `x5c` parameter in the JOSE header of the JSON Web Signature for the metadata.

ISSU_22a

Empty

ISSU_22b

Empty

ISSU_23SHALL

For the verification of a PID Provider's access certificates, a Wallet Unit SHALL accept all Access Certificate Authorities trust anchors published by the Commission in the relevant LoTE, and only those.

Note: a) Access Certificate Authority LoTEs are explained in [Topic 27]. b) A Wallet Unit does not have to be able to request a PID from all PID Providers in the ecosystem. It is up to each Wallet Provider to decide which PID Providers its Wallet Units will support.

ISSU_23aSHALL

A Wallet Provider SHALL support at least one PID Provider, meaning that its Wallet Units SHALL be capable of requesting the issuance of a PID from these PID Provider(s), and that the Wallet Provider has agreed with the PID Provider(s) that the PID Provider(s) will process such a request according to the agreed rules and procedures.

ISSU_23bSHALL

Prior to or during installation of a Wallet Instance, the Wallet Provider SHALL notify the User about the PID Provider(s) that are supported by the Wallet Unit.

ISSU_23cSHALL

For the verification of a PID Provider's registration certificates, a Wallet Unit SHALL accept the trust anchors of all Providers of registration certificates published by the Commission in the relevant LoTE, and only those.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

ISSU_24SHALL

A Wallet Unit SHALL authenticate and validate the access certificate of the PID Provider before requesting the issuance of a PID. The Wallet Unit SHALL verify that the access certificate is authentic and is valid at the time of validation, and that the issuer of the access certificate is included in an Access Certificate Authority LoTE.

ISSU_24aSHALL

Before requesting the issuance of a PID, the Wallet Unit SHALL verify that the PID Provider is indeed a registered PID Provider. To do so, the Wallet Unit SHALL inspect the `entitlement` member in the registration certificate of the PID Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the PID Provider is indeed registered as a PID Provider, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of a PID.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

ISSU_24bSHALL

Before requesting the issuance of a PID, the Wallet Unit SHALL verify whether the PID Provider properly registered for the issuance of PIDs. To do so, the Wallet Unit SHALL inspect the `providesAttestations` member in the registration certificate of the PID Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the PID Provider registered for the issuance of PIDs, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of a PID.

Note: a) It may be argued that this verification is superfluous, since an entity registered as a PID Provider (ISSU_24a) by definition is registered for issuing PIDs. However, this verification was added to ensure that Wallet Unit can use the same verification process for PIDs as for other attestations (see ISSU_34b), as well as to ensure that in the future, it is possible to distinguish

between different types of PID if needed, where not all PID Providers are registered to issue all types of PID. b) The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

C - HLRs for Attestation Issuance

ISSU_25SHALL

An Attestation Provider SHALL ensure all attestations issued to Wallet Units comply with the requirements specified in the applicable Attestation Rulebook, as described in Topic 12].

ISSU_26SHALL

An Attestation Provider SHALL support the OpenID4VCI protocol referenced in ISSU_01 for issuing attestations.

ISSU_27SHALL

An Attestation Provider SHOULD implement device binding for all attestations it issues. If an issued attestation is device-bound, the Attestation Provider SHALL ensure that the attestation is cryptographically bound to a WSCA/WSCD or a keystore available to the Wallet Unit, as specified in Topic 9.

Note: a) Device binding is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC. b) Implementing mdoc authentication is mandatory in ISO/IEC 18013-5 and therefore, it is mandatory for attestations complying with that standard. c) See ISSU_27d.

ISSU_27aSHALL

If the subject of the attestation is a natural person, an Attestation Provider SHALL verify the identity of the subject of the attestation, in compliance with applicable requirements and in accordance with relevant standards or Implementing Regulations.

Note: Not every attestation has a natural person as its subject. For example, a holiday voucher may be valid for any User that can present it to a Relying Party and therefore has no subject. This is comparable to the concept of a 'bearer token'.

ISSU_27bSHALL

If applicable, an Attestation Provider SHALL ensure that the attributes attested in the attestation issued are valid for the identified attestation subject.

ISSU_27cSHALL

The Attestation Provider SHALL verify that the User requesting the attestation has the right to receive it.

ISSU_27dSHALL

An Attestation Provider issuing device-bound attestations SHALL indicate the desired level of security for the private key storage and for User authentication in its Credential Issuer metadata, according to OpenID4VCI section 12.2.4 and Appendix D.2.

Note: See also WIAM_14b, WIAM_14c, and WUA_05 and WUA_05a.

ISSU_28SHALL

For the verification of a WIA or KA, an Attestation Provider SHALL accept all Wallet Provider trust anchors published by the Commission in the relevant LoTE, and only those.

Note: The Wallet Provider LoTE is explained in Topic 31.

ISSU_28aSHALL

For the retrieval and management of trust anchors, Attestation Providers SHALL support LoTEs complying with ETSI TS 119 602.

Note: LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of Wallet Providers.

ISSU_29SHALL

A QEAA Provider or PuB-EAA Provider SHALL support all Wallet Solutions, except in case the attestation in question is a Strong User Authentication (SUA) attestation as meant in Topic 20 and the Wallet Provider does not support processing of the transactional data associated with the SUA attestation. Except for such cases, a QEAA Provider or PuB-EAA Provider SHALL NOT discriminate between Wallet Solutions when processing a request for the issuance of an attestation.

Note: This requirement is not applicable for non-qualified EAA Providers. For example, a non-qualified EAA Provider may choose to issue attestations in the format specified in W3C VCDM v2.0, see ARB_01a. In that case, it will support only those Wallet Solutions that have implemented this attestation format.

ISSU_30SHALL

Before issuing a device-bound attestation, an Attestation Provider SHALL verify the Wallet Unit's key attestation using a trust anchor registered in the Wallet Provider LoTE. Moreover, it SHALL verify that the WSCD or keystore referenced in the KA has not been revoked.

Note: This requirement applies specifically to the KA received during device-bound attestation issuance. The corresponding requirement for verifying the WIA is ISSU_30a.

ISSU_30aSHALL

Before issuing an attestation, an Attestation Provider SHALL: - verify that the Wallet Provider mentioned in the Wallet Unit's WIA is present in the Wallet Provider LoTE. - authenticate and validate the WIA using the trust anchor(s) registered for the Wallet Provider in that LoTE.

Note: This requirement applies to both device-bound and non-device-bound attestations

ISSU_31

Empty

ISSU_32SHALL

An Attestation Provider SHALL sign its Credential Issuer metadata as specified in section 12.2.3 of OpenID4VCI. To do so, the Attestation Provider SHALL use the private key corresponding to the public key in its access certificate. The Attestation Provider SHALL include its access certificate, as well as all intermediate certificate(s) leading up to the trust anchor of the corresponding Access Certificate Authority in the LoTE (see ISSU_33), in the `x5c` parameter in the JOSE header of the JSON Web Signature for the metadata.

ISSU_32a

Empty

ISSU_33SHALL

For the verification of access certificates, a Wallet Unit SHALL accept all trust anchors of Access Certificate Authorities, as published by the Commission in the relevant LoTE, and only those.

Note: The Access Certificate Authority LoTE is explained in [Topic 27].

ISSU_33aSHALL

For the verification of the registration certificates of Attestation Providers, a Wallet Unit SHALL accept all trust anchors of Providers of registration certificates, as published by the Commission in the relevant LoTE, and only those.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

ISSU_33bSHALL

A Wallet Provider SHALL support all Attestation Providers, except possibly if the attestation in question is a Strong User Authentication (SUA) attestation as meant in Topic 20 and the Wallet Provider chooses to not support processing of the transactional data associated with that attestation. Except for such cases, Wallet Units SHALL be capable of requesting the issuance of a QEAA, PuB-EAA, or non-qualified EAA from all Attestation Providers at the User's request.

ISSU_34SHALL

A Wallet Unit SHALL authenticate and validate the access certificate of the Attestation Provider before requesting the issuance of an attestation. The Wallet Unit SHALL verify that the access certificate is authentic and is valid at the time of validation, and that the issuer of the access certificate is in the Access Certificate Authority LoTE, as documented in [Topic 27].

ISSU_34aSHALL

Before requesting the issuance of an attestation, the Wallet Unit SHALL verify that the Attestation Provider is a registered QEAA Provider, PuB-EAA Provider, or EAA Provider. To do so, the Wallet Unit SHALL inspect the `entitlement` member in the registration certificate of the Attestation Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the Attestation Provider is indeed registered as a QEAA Provider, PuB-EAA Provider, or EAA Provider, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of an attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

ISSU_34bSHALL

Before requesting the issuance of an attestation, the Wallet Unit SHALL verify whether the Provider properly registered for the issuance of the type of attestation that the User wants to obtain. To do so, the Wallet Unit SHALL inspect the `providesAttestations` member in the registration certificate of the Attestation Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the Attestation Provider registered for the relevant type of attestation, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of an attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

D - HLRs for Privacy Risks and Mitigation

ISSU_35SHALL

A PID Provider or Attestation Provider SHALL ensure that all unique elements in a PID or attestation have a negligible chance of having the same value across all PIDs or attestations issued by that Provider. This SHALL include at least a) the salt used for hashing every attribute, b) the hash values of all attributes, c) the attestation identifier or index used for revocation purposes (if applicable), d) the attestation public key used for device binding (if applicable), and e) the value of the Attestation Provider signature.

Note: a) The list of unique elements is based on ISO/IEC 18013-5 and SD-JWT VC. b) This requirement can be achieved, for example, by ensuring that salt values, indexes and attestation identifiers are pseudo-random numbers generated by a cryptographically secure pseudo-random number generator (CSPRNG).

ISSU_35aSHALL

A Wallet Provider SHALL ensure that all unique elements in a WIA or KA have a negligible chance of having the same value across all WIAs and KAs issued by that Wallet Provider and intended to be presented to different PID Providers or Attestation Providers. This SHALL include at least a) the attestation index for revocation, unless the per-KA index approach meant in WUA_28 is used, b) the WIA or KA public key, and c) the value of the Wallet Provider signature over the WIA or KA.

Note: In other words, the following do not have to be unique: i) WIAs presented to the same PID Provider or Attestation Provider, and ii) the revocation index in a KA under the type-shared index approach (see WUA_28). However, under the per-KA index approach (see WUA_28), the KA revocation index is unique per KA or per KA-issuer pair and is subject to this requirement.

ISSU_35bSHALL

After issuing a PID, attestation, KA, or WIA, a PID Provider, Attestation Provider or Wallet Provider SHALL discard the values of all unique elements, including at least the ones mentioned in requirement ISSU_35 or ISSU_35a (as applicable) above, as well as any timestamps, as soon as they are no longer needed. The Provider SHALL NOT communicate these values to any other party inside or outside the EUDI Wallet ecosystem.

ISSU_36SHALL

When issuing PIDs, attestations, or WIAs or KAs in a batch to a Wallet Unit, a PID Provider, Attestation Provider, or Wallet Provider SHALL ensure that the timestamps in these PIDs,

attestations, or WIAs and KAs do not enable Relying Parties to conclude that they are part of the same batch (and therefore belong to the same User).

Note: a) This can be done, for example, by making timestamps sufficiently imprecise that a high number of batches, each issued to a different Wallet Unit, share the same timestamp values (herd privacy). b) This requirement does not apply to timestamps included in the attestation as selectively disclosable attributes, see ISSU_36a.

ISSU_36aSHALL

If the exact time of the issuance of an attestation or the beginning or end of its validity period is relevant for the use case, the applicable Attestation Rulebook SHALL specify one or more selectively disclosable attribute(s) containing a timestamp with the required precision.

Note: a) An example of this may be a vehicle registration attestation indicating the date and time (down to the second) at which a car changed ownership and therefore legal responsibility. b) This requirement ensures that requirement ISSU_36 can be complied with without running into challenges related to the use case.

ISSU_37SHALL

A Wallet Provider SHALL ensure that its Wallet Solution supports the following methods for limiting the number of times a User can present the same technical PID or attestation to Relying Parties: Method A (Once-only attestations, as specified in requirement ISSU_43 - ISSU_47) and Method B (Limited-time attestations, as specified in requirement ISSU_48 - ISSU_50). In addition, a Wallet Provider MAY ensure that its Wallet Solution supports Method C (Rotating-batch attestations, as specified in requirement ISSU_51 - ISSU_54) or Method D (Per-Relying Party attestations, as specified in requirement ISSU_55 - ISSU_57).

Note: Wallet Solutions, PID Providers, Attestation Providers, and Wallet Providers are free to define and use other methods as well. However, such other methods are out of scope of the ARF.

ISSU_38SHALL

A PID Provider or Attestation Provider SHALL have a policy describing which method(s) (i.e, A, B, C, and/or D) it will use to limit the number of times a Wallet Unit may present a single technical PID or attestation. For each supported method, the policy SHALL also specify how the values for respective parameters for that method, such as technical validity period and batch size, will be chosen. The goal of the policy SHALL be to ensure that the risk of linkability is mitigated to an acceptable level, given the (expected) usage of the logical PID or attestation

by the User. To determine what an acceptable level of risk is, the PID Provider or Attestation Provider SHALL carry out a risk analysis regarding linkability.

Note: a) If an Attestation Provider issues multiple attestation types, these requirements apply for each type of attestation separately. b) Technical Specification 3 specifies that WIAs and KAs shall be sent to a PID Provider or Attestation Provider only once. In other words, for WIAs and KAs, the use of Method A is mandatory.

ISSU_39SHALL

PID Providers and Attestation Providers SHALL include the `credential_reuse_policy` parameter, specified in section 4.2.4.2 of ETSI TS 119 472-3, in their Credential Issuer Metadata to specify which of the methods A, B, C, or D the Wallet Unit must use for the logical PID or attestation issued. Indicated methods SHALL be ordered by preference.

Note: See also ISSU_40.

ISSU_39aSHALL

Wallet Units SHALL support the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3 and SHALL present each technical PID and attestation in accordance with the values set for this parameter by the relevant PID Provider or Attestation Provider.

ISSU_40SHALL

A PID Provider or Attestation Provider SHALL indicate in their OpenID4VCI Issuer metadata that either method A or method B must be used for a given type of PID or attestation. In addition, a PID Provider or Attestation Provider MAY indicate that it prefers using method C and/or method D over method A or method B, by including the methods in the metadata in the appropriate order. In such a case, a Wallet Unit supporting method C and/or method D SHALL use that method, while a Wallet Unit not supporting these methods SHALL use method A or method B, as applicable.

Note: a) This requirement implies that a PID Provider or Attestation Provider must not include both method A and method B in its metadata. b) Example: An Attestation Provider indicates methods {D, C, A} in its metadata, in that order. A Wallet Unit that supports methods C and D (as well as A and B) then uses method D for this type of attestation. A Wallet Unit supporting methods A, B and C uses method C. A Wallet Unit supporting only methods A and B uses method A.

ISSU_40aSHALL

When implementing any of the methods mentioned in ISSU_37, a Wallet Unit, PID Provider, or Attestation Provider SHALL comply with the applicable requirements in ETSI TS 119 472-3, section 4.2.4.

ISSU_41SHALL

To the maximum extent possible, Wallet Providers, PID Providers, and Attestation Providers SHALL ensure that Users do not notice which of the methods A, B, C, or D is used for their PIDs and attestations.

ISSU_42SHALL

To the maximum extent possible, Wallet Providers, PID Providers, and Attestation Providers SHALL ensure that no User action is needed for the re-issuance of WIAs or KAs, PIDs, or attestations.

Note: For the topic of re-issuance, see also the Discussion Paper for Topic B.

Method A: Once-only attestations

ISSU_43SHALL

If Method A is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue technical PIDs or attestations in batches to the Wallet Unit. All PIDs or attestations in a batch SHALL have the same attribute values and the same technical validity period.

ISSU_44SHALL

If Method A is used, the Wallet Unit SHALL present each technical PID or attestation only once to a Relying Party that requests the corresponding logical PID or attestation, except when it has fallen back to Method B as specified in ISSU_47.

ISSU_45SHALL

If Method A is used, the Wallet Unit SHALL have a lower limit for the number of unused technical PIDs or attestations it holds for each logical PID or attestation, and SHALL request the issuance of a new batch when this limit is reached. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the value of the lower limit and the size of the batch to be requested, using the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

ISSU_46SHALL

If Method A is used and the Wallet Unit must request a new batch of technical PIDs or attestations but is not able to do so (for instance because it is offline), the Wallet Unit SHALL warn the User that they are about to lose the possibility to present the corresponding logical PID or attestation to Relying Parties, and request them to connect their device to the internet.

ISSU_47SHALL

If Method A is used and the Wallet Unit has run out of unused technical PIDs or attestations, but is not able to request a new batch, it SHALL fall back to method B (see ISSU_48 - ISSU_50). This means that, when requested by a Relying Party or Attestation Provider, the Wallet Unit SHALL again present one of the already used technical PIDs or attestations. The Wallet Unit SHALL return to using method A as soon as it is able to go online and request a new batch of PIDs or attestations.

Method B: Limited-time attestations

ISSU_48SHALL

If Method B is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue a single technical PID or attestation to the Wallet Unit.

ISSU_49SHALL

If Method B is used, the Wallet Unit SHALL present a technical PID or attestation multiple times to the same Relying Party or to different Relying Parties, when a Relying Party requests the corresponding logical PID or attestation.

ISSU_50SHALL

If Method B is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to re-issue a technical PID or attestation some time before the one existing in the Wallet Unit expires. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the moment at which the Wallet Unit must request the re-issuance of a technical PID or attestation, relative to the expiration date of the existing one. To do so, the PID Provider or Attestation Provider SHALL use the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

Note: It is the responsibility of the Relying Party receiving a PID or attestation to validate whether a presented technical PID or attestation is temporally valid. A Wallet Unit is allowed to present a PID or attestation even if its expiration date is in the past.

Method C: Rotating-batch attestations

ISSU_51SHALL

If Method C is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue technical PIDs or attestations in batches to the Wallet Unit. All PIDs or attestations in a batch SHALL have the same attribute values and the same technical validity period.

ISSU_52SHALL

If Method C is used, the Wallet Unit SHALL present each technical PID or attestation in a batch once to a Relying Party that requests the corresponding logical PID or attestation, in a random order. When all PIDs or attestations in a batch have been presented once, the Wallet Unit SHALL reset the batch, and start presenting each PID or attestation in the batch again, in a random order. The Wallet Unit SHALL continue doing this until it receives a new batch, see ISSU_54.

ISSU_53

Empty

ISSU_54SHALL

If Method C is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to re-issue a batch of technical PIDs or attestations some time before the batch in the Wallet Unit expires. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the size of the batch and about the moment at which the Wallet Unit must request the re-issuance of a batch, relative to the expiration date of the existing batch. To do so, the PID Provider or Attestation Provider SHALL use the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

Method D: Per-Relying Party attestations

ISSU_55SHALL

If Method D is used, the Wallet Unit SHALL present a different technical PID or attestation to each different Relying Party that requests the corresponding logical PID or attestation. This means that it SHALL comply with all requirements for Method A for such Relying Parties.

Note: This means the Wallet Unit presents an unused technical attestation to each new Relying Party that request the logical attestation, and it requests a new batch of technical attestations if the number of remaining unused attestations goes below the lower limit. If for some reason

requesting a new batch is not successful and the Wallet Unit runs out of unused technical attestations, it re-uses one of the already used technical attestations.

ISSU_56SHALL

If Method D is used and a given Relying Party requests attributes from a given logical PID or attestation multiple times, the Wallet Unit MAY present the same technical PID or attestation to this Relying Party each time. If it does, it SHALL comply with all requirements for Method B for such a Relying Party.

ISSU_56a

Empty

ISSU_57SHALL

If Method D is used, the Wallet Unit SHALL keep track of which technical PID or attestation it has presented to which Relying Party.

Note: To do so, the Wallet Unit can use the unique RP identifier contained in the registration certificate of the presentation requests it receives.

ISSU_57a

Empty

E - HLRs for re-issuance and batch issuance of PIDs and attestations

ISSU_58SHALL

A Wallet Unit SHALL give its User the option to manually initiate a re-issuance process for any of the logical PIDs or attestations in their Wallet Unit. If the User uses this option, the Wallet Unit SHALL attempt to start the re-issuance process immediately, and SHALL notify the User if it did not succeed in requesting re-issuance.

Note: a) This requirement does not apply for KAs or WIAs, since Users must not be involved in their management. b) In the case of a PID or an attestation bound to the WSCA/WSCD, the Wallet Unit will request the User to authenticate to the WSCA/WSCD (see WIAM_14). In case of an attestation bound to a keystore, no additional User authentication is needed, see WIAM_15c.

ISSU_59SHALL

After a successful re-issuance, a Wallet Unit SHALL compare the attribute values of the re-issued technical PID or attestation with those of the existing technical PID or attestation, and SHALL notify the User in case of any differences.

Note: a) This requirement does not apply for KAs or WIAs, since Users must not be involved in their management. b) The point of this requirement is to allow the User to detect errors in the attribute values in the new attestation. The follow-up process in case of errors is not defined. Presumably, the User can contact the Attestation Provider to discuss the fact that it apparently holds false attribute values for the User, and as a result, the Attestation Provider may decide to revoke the attestation.

ISSU_60SHALL

A Wallet Unit SHALL gracefully handle situations in which re-issuance of a PID, attestation, KA, or WIA fails or is refused by the PID Provider, Attestation Provider, or Wallet Provider, for example by attempting a retry after an appropriate delay.

ISSU_61SHALL

A Wallet Unit SHALL support PID or attestation first-time batch issuance with a single User authentication, regardless of the size of the batch.

Note: See also requirement WIAM_14.

ISSU_62SHALL

If a technical PID or attestation was successfully re-issued because the value of one or more of its attributes was changed (including attributes being added or deleted), a Wallet Unit SHALL no longer present the (now obsolete) pre-existing technical PID or attestation, and SHOULD delete it.

Note: a) It is up to the Wallet Unit, possibly using metadata provided by the PID Provider or Attestation Provider using the OpenID4VCI protocol, to determine the technical PID or attestation to be deleted. b) Additionally, per requirement VCR_09, the PID Provider or Attestation Provider revokes the pre-existing technical PID or attestation.

ISSU_63SHALL

PID Providers and Attestation Providers, and Wallet Units SHALL support the features of OpenID4VCI enabling the re-issuance of PIDs and attestations.

ISSU_64SHALL

PID Providers, Attestation Providers, and Wallet Units SHALL support the features of OpenID4VCI enabling the batch issuance of technical PIDs or attestations.

ISSU_65SHALL

A PID Provider or an Attestation Provider of device-bound attestations SHALL verify that a re-issued technical PID or device-bound attestation is issued to the same Wallet Unit as the existing PID or attestation.

Note: A PID Provider or Attestation Provider can do so by issuing a device-bound refresh token to the Wallet Instance during the original issuance of the PID or attestation, and requiring that the Wallet Instance uses it to obtain a fresh access token during re-issuance. See OpenID4VCI section 14.5. The PID Provider or Attestation Provider needs to be able to trust that the Wallet Instance handles the refresh tokens in a secure way, so that an attacker cannot use them from another Wallet Instance. This requires trust in the (continued) security and integrity of both the original Wallet Instance and the other Wallet Instance. This trust is provided by providing the PID Provider or Attestation Provider with a valid KA for the new Wallet Unit during re-issuance, and by enabling the PID Provider or Attestation Provider to verify that the original Wallet Unit has not been revoked.

ISSU_66

Empty

F - HLRs for attestation-signing certificate profiles and certificate policies

ISSU_67SHALL

A PID Provider SHALL have a policy governing all aspects of PID issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to a PID. The policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of PIDs rather than public key certificates.

Note: A common dedicated policy for issuing PIDs may be developed in the future. If so, this requirement will be changed to refer to it.

ISSU_68SHALL

PID Providers SHALL ensure that the certificates they use for signing PIDs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 4.

ISSU_69SHALL

A QEAA Provider SHALL have a policy governing all aspects of QEAA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced

by CIR 2025/1569. The policy SHALL comply with at least the policy for qualified certificates issued to a natural person where the private key and the related certificate reside on a QSCD ('QCP-n-qscd') or qualified certificates issued to a legal person where the private key and the related certificate reside on a QSCD ('QCP-l-qscd') requirements as specified in ETSI EN 319 411-2, insofar applicable for the issuance of QEAAs rather than public key certificates.

Note: A common dedicated policy for issuing QEAAs may be developed in the future. If so, this requirement will be changed to refer to it.

ISSU_70SHALL

QEAA Providers SHALL ensure that the certificates they use for signing QEAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 7.

ISSU_71SHALL

Providers of non-qualified EAAs SHALL ensure that the certificates they use for signing EAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 6.

ISSU_72SHALL

A PuB-EAA Provider SHALL have a policy governing all aspects of PuB-EAA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to a PuB-EAA. The policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of PuB-EAAs rather than public key certificates.

Note: A common dedicated policy for issuing PuB-EAAs may be developed in the future. If so, this requirement will be changed to refer to it

ISSU_73SHALL

PuB-EAAs Providers SHALL ensure that the certificates they use for signing PuB-EAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 8.

A.2.3.8 Topic 11 - Pseudonyms

A. HLRs related to Use Cases A and B

PA_01SHALL

A Wallet Unit SHALL enable a User to generate a Pseudonym and register it at a Relying Party.

Note: For an attested pseudonym, pseudonym generation takes place by requesting the issuance of a pseudonym attestation. Pseudonym registration takes place by presenting the attestation.

PA_02SHALL

A Wallet Unit SHALL enable a User to authenticate with a Pseudonym towards a Relying Party if the Wallet Unit was used previously to register the Pseudonym for the same Relying Party

PA_03SHALL

A Wallet Unit SHALL be able to perform the actions specified in the above two requirements independently of whether the interaction with the Relying Party is initiated on the same device hosting the Wallet Instance or on a device different from the one hosting the Wallet Instance.

PA_04SHALL

A Wallet Unit SHALL enable the User to use multiple different Pseudonyms at a given Relying Party, unless it is explicitly designed as a scope rate-limited attestation.

PA_05SHOULD

A Wallet Unit SHOULD enable a User to freely choose a User alias for each Pseudonym registered at a Relying Party. Setting an alias SHOULD be optional for the User. The User SHOULD be able to change the alias for any Pseudonym.

PA_06SHALL

A Wallet Unit SHALL enable a User to choose which Pseudonym to authenticate with towards a Relying Party, if multiple Pseudonyms are registered for this Relying Party. The Wallet Unit SHOULD present the User with the aliases of the applicable Pseudonyms, if assigned, when making this choice.

PA_07SHALL

A Wallet Unit SHALL enable a User to delete a Pseudonym.

PA_08SHALL

A Wallet Unit SHALL enable the User to manage Pseudonyms within the Wallet Unit in a user-friendly and transparent manner.

PA_08aSHALL

A Wallet Unit SHALL log Pseudonym registration and presentation transactions as specified in Topic 19.

PA_09SHALL

A Wallet Unit SHALL enable the User to see all existing pseudonyms, including the associated Relying Party (if any).

B. HLRs related to Relying Parties

PA_10SHALL

A Relying Party SHALL be able to verify that a User is registering a Pseudonym using a non-revoked Wallet Unit.

PA_11SHALL

A Relying Party SHALL be able to verify that a User is authenticating with a Pseudonym using a non-revoked Wallet Unit.

PA_12SHALL

If Wallet Unit is used to register a Pseudonym at a Relying Party in combination with a PID or attestation being presented to the same Relying Party, then this Relying Party SHALL be able to verify that the same User performed both actions.

PA_13SHALL

The Relying Party SHALL be able to validate that the pseudonym presented to them belongs to the User presenting it.

C. HLRs related to privacy

PA_14SHALL

A Wallet Unit SHALL store the information necessary for authenticating with a Pseudonym in either a WSCA/WSCD or in a keystore.

PA_15SHALL

A Relying Party SHALL NOT be able to derive the User's true identity, or any data identifying the User, from the Pseudonym value received by the Relying Party.

PA_16SHALL

A Wallet Unit SHALL NOT reveal the same Pseudonym to different Relying Parties, unless the User explicitly chooses otherwise.

PA_17SHALL

The Wallet Provider SHALL use method(s) and/or protocol(s) to implement pseudonyms which make it impossible to correlate Pseudonyms based on their values or on metadata sent by the Wallet Unit to Relying Parties during registration and authentication.

Note: This implies that colluding Relying Parties will not be able to conclude that different Pseudonyms belong to the same User.

PA_18SHALL

The Wallet Unit SHALL ensure that Pseudonyms contain sufficient entropy to make the chance of colliding Pseudonyms (meaning two Users having the same Pseudonym value for the same Relying Party) negligible.

PA_19SHALL

A Wallet Unit SHALL NOT share the User's optionally assigned Pseudonym aliases with any Relying Party.

PA_20SHALL

The Wallet Unit SHALL verify the identity of a Relying Party when a User registers a Pseudonym or authenticates with a Pseudonym. If the profile or extension of W3C WebAuthn meant in PA_21 does not enable the Wallet Unit to do this, the Wallet Unit SHALL trust the WebAuthn Client (i.e., the browser) to verify the Relying Party identity.

Note: W3C WebAuthn currently does not offer a way for an Authenticator (i.e., the Wallet Unit) to authenticate a Relying Party. Instead, the Client (i.e., the browser) will authenticate the Relying Party, using TLS. The notion of trust is that the Wallet Unit receives the Relying Party identity from the browser and uses it without further verifications.

D. HLRs related to interoperability

PA_21SHALL

The Commission SHALL create or reference a technical specification containing a profile or extension of the W3C WebAuthn specification compliant with the HLRs specified in this Topic. This specification SHALL contain all details necessary for Wallet Units and Relying Parties to generate, register, and use Pseudonyms.

PA_22MAY

Wallet Providers MAY ensure that their Wallet Solution supports the HLRs defined for this topic by letting their Wallet Units perform the role of a WebAuthn authenticator following the W3C WebAuthn specification and the technical specification referenced in referenced in PA_21.

E. HLRs related to scope rate-limited pseudonyms

PA_23SHALL

A protocol enabling scope rate-limited pseudonyms SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

PA_24SHALL

A protocol enabling scope rate-limited pseudonyms SHALL enable a Wallet Unit to allow a User to generate a scope rate-limited pseudonym, register this by a Relying Party, and prove that this is within the rate and scope restrictions determined by the Relying Party.

PA_25SHALL

A protocol enabling scope rate-limited pseudonyms SHALL allow a Relying Party, when a User presents a scope rate-limited pseudonym, to verify that the rate is not exceeded for this User.

PA_26SHALL

A protocol enabling scope rate-limited pseudonyms SHALL allow a Relying Party to choose the scope and rate when requesting a scope rate-limited pseudonym from a User.

PA_27SHALL

A protocol enabling scope rate-limited pseudonyms SHALL NOT allow any entity or collusion of entities not including the User, to link scope rate-limited pseudonyms of the same User when used across several different Relying Parties. This SHALL hold even if the scope and rate are identical across the different Relying Parties and both for registration and authentication of the scope rate-limited pseudonym

PA_28SHALL

A protocol enabling scope rate-limited pseudonyms SHALL ensure that if the rate is larger than 1, a User's different pseudonyms SHALL be unlinkable for the same scope. This SHALL hold against any entity or collusion of entities, not including the User. Further, such protocol SHALL ensure that during registration or authentication with such a pseudonym, it SHALL NOT be

possible for the Relying Party to deduce any information about how many pseudonyms the User has already registered (except that it does not exceed the predetermined rate).

PA_29SHALL

A protocol enabling scope rate-limited pseudonyms SHALL ensure that no entity or collusion of entities, not including a User, is able to authenticate or register with a scope rate-limited pseudonym of this User.

PA_30SHALL

A Wallet Unit SHALL store cryptographic material necessary for authenticating as a scope rate-limited pseudonyms in either a WSCA/WSCD or in a keystore.

PA_31SHALL

A User's scope rate limited pseudonyms for a particular scope and rate SHALL be persistent over time even if they start using another Wallet Unit.

A.2.3.9 Topic 12 - Attestation Rulebooks

A. Requirements regarding attestation formats

ARB_01SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL specify that one or more of the following two common format(s) must be used for these attestations: - The format specified in ISO/IEC 18013-5, see ISO/IEC 18013-5. - The format specified in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC.

ARB_01aSHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHALL specify that one or more of the following three common format(s) must be used for these attestations: - The format specified in ISO/IEC 18013-5, see ISO/IEC 18013-5. - The format specified in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC. - The format specified in W3C Verifiable Credentials Data Model, see W3C VCDM v2.0.

ARB_01bSHALL

The Scheme Provider for an Attestation Rulebook describing attestations using the format specified in SD-JWT VC SHALL ensure that these attestations comply with the 'IETF SD-JWT VC Profile' specified in HAIP Section 6.1.

ARB_02SHALL

The Scheme Provider for an Attestation Rulebook SHALL analyse whether it must be possible for a User to present that type of attestation when the Wallet Unit and the Relying Party are in proximity and attestations are presented without using the internet. If so, the Attestation Rulebook SHALL specify that the attestations must be issued in the ISO/IEC 18013-5-compliant mdoc format.

Note: In theory, it is possible to use SD-JWT VC-compliant attestations in proximity use cases. In practice, however, the only protocol available to request and present SD-JWT VC-compliant attestations between a Wallet Unit and a Relying Party Instance is OpenID4VP. That protocol cannot be used without internet connectivity.

ARB_03MAY

The Scheme Provider for an Attestation Rulebook MAY specify in the Attestation Rulebook that that type of attestation must be issued in the SD-JWT VC-compliant format, provided the SD-JWT VC specification has been approved by an EU standardisation body or by the European Digital Identity Cooperation Group established pursuant to Article 46e(1) of the European Digital Identity Regulation.

ARB_04SHALL

If an Attestation Rulebook specifies that a type of attestation can be issued in a format compliant with W3C VCDM v2.0, the Scheme Provider for that Attestation Rulebook SHALL ensure the Rulebook references one or more documents specifying in detail how a Relying Party can request attributes from a such an attestation, and how a User can selectively disclose attributes from such an attestation. Moreover, these referenced documents SHALL be approved by an EU standardisation body or by the European Digital Identity Cooperation Group established pursuant to Article 46e(1) of the European Digital Identity Regulation.

B. Requirements regarding attestation types

ARB_05SHALL

The Scheme Provider for an Attestation Rulebook SHALL specify a value for the attestation type, which SHALL be unique within the scope of the EUDI Wallet ecosystem.

Note: In ISO/IEC 18013-5, the attestation type is called 'document type' and is included as a `docType` key-value pair in both the mdoc request and the mdoc response. Also, a method for generating unique attestation type values is recommended. In OpenID4VP, the attestation type is included in the `meta` property of a Credential Query in a presentation request. In SD-JWT VC, the attestation type is called 'SD-JWT VC type' and is included as a `vct` claim in the SD-JWT VC.

C. Requirements regarding attestation schemes

ARB_06SHALL

The Scheme Provider for an Attestation Rulebook SHALL define all attributes that an attestation of that type may contain. This definition SHALL first describe the semantics of each attribute in an encoding-independent manner and SHALL subsequently for each attribute specify an ISO/IEC 18013-5-compliant format, an SD-JWT VC-compliant format, or both, as needed given the choices made according to ARB_01 - ARB_04.

ARB_06aSHALL

For ISO/IEC 18013-5-compliant attestations, the Attestation Rulebook SHALL define each attribute within an attribute namespace. An attribute namespace SHALL fully define the identifier, the syntax, and the semantics of each attribute within that namespace. An attribute namespace SHALL have an identifier that is unique within the scope of the EUDI Wallet ecosystem, and each attribute identifier SHALL be unique within that namespace.

Note: In ISO/IEC 18013-5, namespaces are discussed and a method for generating unique namespace identifiers is recommended.

ARB_06bSHALL

For SD-JWT VC-compliant attestations, the Scheme Provider for the Attestation Rulebook SHALL ensure that each claim name is either: - included in the IANA registry for JWT claims, - is a Public Name as defined in RFC 7519, or is a Private Name specific to the attestation type.

Note: SD-JWT VC does not discuss how to avoid conflicting claim names. Since SD-JWTs are a special kind of JWTs, the methods specified in RFC 7519 are applicable.

ARB_07SHOULD

When determining the attributes to be included in a new attestation type, the Scheme Provider for the applicable Attestation Rulebook SHOULD consider referring to attributes that are already included in the catalogue of attributes specified in Topic 25 or specified in an attestation

scheme included in the catalogue of attestation schemes specified in Commission Implementing Regulation 2025/1569, rather than unnecessarily re-defining all attributes.

ARB_08SHOULD

The Scheme Provider for an Attestation Rulebook SHOULD, when specifying a new attribute, take into consideration existing conventions for attribute identifier values and attribute syntaxes.

Note: These conventions may depend on the format of the attestation, i.e., CBOR for ISO/IEC 18013-5-compliant attestations or JSON for SD-JWT VC-compliant attestations.

ARB_09SHALL

The Scheme Provider for an Attestation Rulebook SHALL specify, for each attribute in the attestation, whether the presence of that attribute is mandatory, optional, or conditional.

ARB_10SHALL

The Scheme Provider for an Attestation Rulebook for an ISO/IEC 18013-5 compliant attestation MAY define a domestic namespace to specify attributes that are specific to that Rulebook and are not included in the applicable EU-wide or sectoral namespace. All requirements for namespaces in this Topic SHALL also apply for domestic namespaces.

ARB_11SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook an attribute as meant in Annex V point a) and Annex VII point a) of the European Digital Identity Regulation. This attribute SHALL reference the technical specification meant in ARB_25.

ARB_12SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include an attribute in the Rulebook indicating that the attestation is an EAA. This attribute SHALL reference the technical specification meant in ARB_25.

ARB_13SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point b) of the European Digital Identity Regulation.

ARB_14SHALL

The Scheme Provider for an attestation Rulebook describing a type of attestation that is a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex VII point b) of the European Digital Identity Regulation.

ARB_15SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point b) of the European Digital Identity Regulation.

ARB_16SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes representing the set of data meant in Annex V point c) or Annex VII point c) of the European Digital Identity Regulation.

ARB_17SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes representing the set of data meant in Annex V point c) of the European Digital Identity Regulation.

ARB_18SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point e) or Annex VII point e) of the European Digital Identity Regulation.

ARB_19SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes representing the set of data meant in Annex V point e) of the European Digital Identity Regulation.

ARB_20SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the location meant in Annex V point h) or Annex VII point h) of the European Digital Identity Regulation. This location SHALL indicate at least the URL at which a machine-readable version of the trust anchor to be used for verifying the QEAA or PuB-EAA can be found or looked up.

ARB_21SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes or metadata representing the location at which a machine-readable version of the trust anchor to be used for verifying the EAA can be found or looked up.

Note: What this location indicates precisely is dependent on the nature of the mechanism used for distributing trust anchors - see requirement ARB_26.

D. Miscellaneous requirements

ARB_22SHALL

The Scheme Provider for an Attestation Rulebook SHALL specify all technical details necessary to ensure interoperability, security, and privacy of that attestation.

Note: An Attestation Rulebook may also specify requirements regarding how the Wallet Unit must display the attestation and the attributes in it to the User.

ARB_23SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL specify which of the revocation mechanisms specified in Topic 7 SHALL be supported by that attestation.

ARB_24SHALL

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHALL specify whether that type of EAA must be revocable. If an EAA type must be revocable, the relevant Rulebook SHALL determine which of the revocation mechanisms specified in Topic 7 SHALL be supported by that attestation.

ARB_24aSHALL

If an attestation is revocable, the relevant Attestation Rulebook SHALL specify the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual attestation will anyway be included in that attestation.

ARB_25SHALL

An Attribute Schema Provider SHALL include in its Attestation Rulebook the attribute `attestation_legal_category`, specified in the Attestation Rulebook Template, with the appropriate value as specified in the Template.

Note: This attribute contains the indication meant in Annex V point a) and Annex VII point a).

ARB_26SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD define in the Rulebook the mechanism(s) allowing a Relying Party to obtain, in a trustworthy manner, the trust anchor(s) of the EAA Providers issuing this type of EAA.

Note: Technical Specification 11, section 4.3.1, recommends the use of the List of trusted entities (LoTE) data model as defined in ETSI TS 119 602 for non-qualified EAAs.

ARB_27

Empty

ARB_28SHALL

An Attribute Scheme Provider MAY specify an attribute in an Attestation Rulebook that indicates whether the Attestation Provider during attestation issuance requested a cryptographic binding (as specified in Topic 18) between the new attestation and an existing PID or attestation. If present in a Rulebook, the identifier for this attribute SHALL be `cryptographically_bound_to`, and its contents SHALL be an attestation type or vct (see ARB_05).

Note: The meaning of this attribute, if present, is that this attestation is cryptographically bound to one or more attestations of the given attestation type or vct on this Wallet Unit. If a Relying Party receives this attribute from a Wallet Unit, it can subsequently request the Wallet Unit to send a proof of cryptographic binding between the attestation and an attestation indicated in the `cryptographically_bound_to` attribute.

ARB_29SHOULD

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA, PuB-EAA, or non-qualified EAA SHOULD ensure that the structure and contents of the Attestation Rulebook follow the descriptions in the Attestation Rulebook template.

ARB_30SHALL

If an Attestation Rulebook specifies a SD-JWT VC-compliant attestation, the Scheme Provider for that Attestation Rulebook SHALL specify for all claims (i.e., all top-level properties, all nested properties, and all array entries) whether an Attestation Provider MUST, MAY, or MUST NOT make that claim selectively disclosable.

Note: a) This requirement does not apply to claims defined as non-selectively disclosable in SD-JWT VC. b) There will be use cases where a specific claim must not be disclosed without simultaneously disclosing one or more other claims. Such cases should be solved by making all of these claims members of the same JSON object (or elements of the same JSON array). That JSON object (or array) is then the claim that must be selectively disclosable, while the nested properties (or individual array elements) must not be selectively disclosable. c) This requirement does not apply to ISO/IEC 18013-5-compliant attestations, since in such attestations, by definition all data elements are selectively disclosable, while none of the key-value pairs or array elements inside a data element (if any) are selectively disclosable.

ARB_31SHOULD

If an Attestation Rulebook specifies a SD-JWT VC-compliant attestation, the Scheme Provider for that Attestation Rulebook SHOULD consider defining a Type Metadata Document for it, as defined in Chapter 6 of SD-JWT VC. If the Scheme Provider defines such a document, it SHOULD contain the Claim Selective Disclosure Metadata (defined in Section 9.3 of SD-JWT VC) for each of the claims, in order to specify if that claim is selectively disclosable (see requirement ARB_30).

Note: Although a Type Metadata Document is a highly technical document, defining it has a number of advantages for developers, Attestation Providers, Relying Parties, and Wallet Units, as spelled out in Chapter 6 of SD-JWT VC.

ARB_32

Empty

ARB_33SHALL

If a Scheme Provider for an Attestation Rulebook registers an attestation scheme in the catalogue of attestation schemes meant in Commission Implementing Regulation 2025/1569, Article 8, the registration SHALL include a reference to the corresponding Attestation Rulebook.

Note: By definition, an attestation scheme is machine-readable, whereas an Attestation Rulebook is human-readable.

ARB_34SHALL

The Scheme Provider for an Attestation Rulebook SHALL specify whether that attestation is device-bound or not.

A.2.3.10 Topic 16 - Signing documents with a Wallet Unit

A. Requirement for Wallet Providers

QES_01SHALL

Wallet Providers SHALL ensure that each User has the possibility to receive a qualified certificate for Qualified Electronic Signatures, bound to a QSCD, that is either local, external, or remotely managed in relation to the Wallet Instance.

QES_02SHALL

Wallet Providers SHALL ensure that each User who is a natural person has, at least for non-professional purposes, free-of-charge access to a Signature Creation Application which allows the creation of free-of-charge Qualified Electronic Signatures using the certificates referred to in QES_01. Wallet Providers SHALL ensure that: - The Signature Creation Application SHALL, as a minimum, be capable of signing or sealing User-provided data and Relying Party-provided data. - The Signature Creation Application SHALL be implemented as part of a Wallet Solution or external to it (by providers of trust services or by Relying Parties). - The Signature Creation Application SHALL be able to generate signatures or seals in formats compliant with at least the mandatory formats referred to in QES_08.

Note: a) Signature Creation Application (SCA): see definition in ETSI TS 119 432. 2) If the SCA is external to the Wallet Solution, it may be for example a separate mobile application, or be hosted remotely, for instance by the QTSP or by a Relying Party.

QES_03SHALL

For the use of the qualified certificate referred to in QES_01, Wallet Providers SHALL ensure that a Wallet Unit implements secure authentication of the User, as well as signature or seal invocation capabilities, as a part of a local, external or remote QSCD.

QES_04SHALL

Wallet Providers SHALL enable their Wallet Units to interface with QSCDs using protocols and interfaces necessary for the implementation of secure User authentication and signature or seal functionality.

Note: In a Relying Party-centric flow, the remote QTSP will likely be selected by the Relying Party, which implies the QSCD is managed by the remote QTSP. In a Wallet Unit-driven flow, the User should be able to choose the QSCD.

QES_05SHALL

Wallet Providers SHALL enable their Wallet Units to be used for User enrolment to a remote QES Provider (i.e., a QTSP offering remote QES), except where the Wallet Unit interfaces with local or external QSCDs.

QES_06SHALL

Wallet Providers SHALL ensure that their Wallet Solution supports at least one of the following options for remote QES signature creation: - remote QES creation through secure authentication to a QTSP signature web portal, - remote QES creation channelled by the Wallet Unit, - remote QES creation channelled by a Relying Party.

QES_07

Empty

QES_08SHALL

Wallet Providers SHALL ensure that their Wallet Units are able to create signatures or seals in accordance with the mandatory PAdES format as specified in ETSI EN 319 142-1 V1.2.1 (2024-01). In addition, Wallet Providers SHOULD ensure that their Wallet Units are able to create signatures or seals in accordance with the following formats: - XAdES as specified in ETSI EN 319 132-1 V1.3.1 (2024-07), - JAdES as specified in ETSI TS 119 182-1 V1.2.1 (2024-07), - CAdES as specified in ETSI EN 319 122-1 V1.3.1 (2023-06), and - ASiC as specified in ETSI EN 319 162-1 V1.1.1 (2016-04) and ETSI EN 319 162-2 V1.1.1 (2016-04).

QES_09

Empty

QES_10SHALL

Wallet Providers SHALL ensure that, where the Signature Creation Application is implemented as part of the Wallet Unit and is used to generate signatures or seals of the representation of the document or data to be signed or sealed, the Wallet Unit presents the representation of the document or data to be signed or sealed to the User.

QES_11SHALL

Where the Signature Creation Application is implemented as part of the Wallet Unit, a Wallet Unit SHALL compute the hash or digest of the document or data to be signed through its Signature Create Application component.

QES_12SHALL

A Wallet Unit SHALL be able to create a signature over a document or data to be signed, either by using a local QSCD or by interfacing with a remote QES Provider.

Note: a local signing application is on-device. It may either be embedded in the Wallet Unit or be an external application.

QES_13SHALL

A Wallet Unit SHALL provide a log of transactions related to qualified electronic signatures or seals generated by or through the Wallet Unit, allowing the User to view the history of previously signed data or documents, according to requirement DASH_04 in Topic 19.

Note: If the signature is generated by a remote Signature Creation Application, the Wallet is at minimum used to authenticate the User to the remote QTSP and to obtain the User's consent for the usage of the private signing key. The logs then record information about these processes.

QES_14SHALL

A Wallet Unit SHALL enable the User to explicitly authorise the creation of a qualified electronic signature or seal through their Wallet Unit.

QES_15SHALL

In remote signature creation scenarios, a Wallet Unit SHALL verify that the qualified electronic signature or seal creation device is part of a qualified service, which is carried out by a qualified trust service provider.

QES_16SHOULD

A Wallet Unit SHOULD support multiple-signing scenarios, where multiple signatories are required to sign the same document or data.

QES_17SHALL

A Wallet Unit SHALL provide a signature creation confirmation upon the creation of a qualified electronic signature, informing the User about the outcome of the signature creation process.

Note: See also QES_17a.

QES_17aSHALL

If the Signature Creation Application is external to the Wallet Unit, after the User authorises the usage of the private signing key, the Signature Creation Application SHALL return the outcome of the signature creation process to the Wallet Unit.

QES_18SHALL

Wallet Providers SHALL configure at least one default qualified signing service in the Wallet Unit.

QES_19SHALL

Wallet Providers SHALL ensure that, where the Signature Creation Application is implemented as part of the Wallet Unit, a Wallet Unit supports ETSI TS 119 101 when using signing keys managed by the QSCD, whether locally, externally, or remotely in relation to the Wallet Instance.

QES_20

Empty

QES_21

Empty

QES_22

Empty

B. Requirements for QTSPs

QES_23SHALL

QTSPs providing the remote QES part of a Wallet Solution SHALL support: 1. ETSI TS 119 431-1 , 2. ETSI TS 119 431-2 , 3. ETSI TS 119 432. Wallet Providers and QTSPs providing the remote QES part of a Wallet Solution SHALL comply with Sole Control Assurance Level (SCAL) 2 as defined in CEN EN 419 241-1 .

QES_24SHALL

QTSPs providing the Signature Creation Application as part of the remote QES part of a Wallet Solution SHALL support ETSI TS 119 101.

C. Requirements for Relying Parties

QES_24aSHALL

Relying Parties providing the Signature Creation Application in a Relying Party-centric flow SHALL support ETSI TS 119 101.

D. Requirements for the Commission

QES_25

Empty

QES_26

Empty

A.2.3.11 Topic 18 - Combined presentations of attributes

ACP_01SHALL

A Cryptographic Binding of Attestations scheme SHALL enable a WSCA/WSCD or keystore to prove that it manages two or more private keys, paired with two or more public keys provided to it by the Wallet Unit.

Note: a)These public keys may be included in WIAs and KAs, PIDs, attestations, or pseudonyms. b) The proof may be transitive, so a proof that two keys are stored/managed in the same WSCA/WSCD or keystore may be done by proving these keys relate to each other via a third key (also stored in the WSCA/WSCD or keystore).

ACP_02SHALL

A Cryptographic Binding of Attestations scheme SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

ACP_03SHOULD

A Cryptographic Binding of Attestations scheme SHOULD be implemented using a Zero-Knowledge Proof mechanism that satisfies the requirements specified in Topic 53.

ACP_04SHALL

A Cryptographic Binding of Attestations scheme SHALL be compatible with the requirements for attestation issuance in this document, in particular Topic 10, as well as with requirements for both remote and proximity presentation flows in this document, in particular Topic 1 and Topic 24.

ACP_05SHALL

A Cryptographic Binding of Attestations scheme SHALL enable an Attestation Provider, during the issuance of an attestation, to request and obtain proof that the private key for the new attestation is managed by the same WSCA/WSCD or keystore as the private key of a PID or another attestation already existing on the Wallet Unit.

Note: ACP_05 and ACP_06 may require an addition to the common OpenID4VCI protocol referenced in requirement ISSU_01, or an extension or profile thereof.

ACP_06

Empty

ACP_07SHALL

Before making a request according to ACP_05, an Attestation Provider SHALL verify that the new attestation indeed belongs to the User of the existing PID or attestation.

A.2.3.12 Topic 19 - User navigation requirements (Dashboard logs for transparency)

DASH_01SHALL

A Wallet Unit SHALL provide a user-friendly dashboard functionality to its User.

DASH_02SHALL

The Wallet Unit SHALL log all transactions executed through the Wallet Unit, including any transactions that were not completed successfully. This log SHALL include all types of transaction executed through the Wallet Unit: a) PID or attestation issuance and re-issuance transactions, b) PID or attestation presentation transactions, c) Wallet-to-Wallet transactions (see Topic 30), d) pseudonym registration or presentation transactions, e) signature or seal creation transactions (see Topic 16), f) data deletion requests sent to a Relying Party (see Topic 48), g) reports sent to a Data Protection Authority (see Topic 50), h) PID or attestation deletions by the User.

Note: For the data to be logged for a data deletion request to a Relying Party or a report sent to a DPA, see Topic 48 and Topic 50, respectively. For other types of transaction, the data to be logged is specified in the requirements in this Topic.

DASH_02aSHALL

The Wallet Unit SHALL retain transactions in the log at least for the minimum retention period specified in applicable legislation. If the Wallet Unit must delete transactions from the log, for instance because of size limitations, the Wallet Unit SHALL notify the User via the dashboard

before doing so, indicating the potential consequences for the User's data protection rights, and SHALL instruct the User how to export the transactions that are about to be deleted. See DASH_07.

DASH_02bSHALL

The dashboard SHALL include a functionality to display to the User an overview of all transactions in the log.

DASH_02cSHALL

The transaction log meant in DASH_02 SHALL comply with all relevant requirement in Technical Specification 10, including measures to ensure and/or verify its confidentiality, integrity, and authenticity.

DASH_03SHALL

For a PID or attestation presentation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the trade name, unique identifier, and Service identifier of the corresponding Relying Party, and the Member State in which that Relying Party is established, c) the trade name, contact details (if available), unique identifier, and Service identifier of the intermediary, if an intermediary is involved in the transaction, d) the attestation type(s) and the identifier(s) of the attribute(s) that were requested, as well as those that were presented, e) in the case of non-completed transactions, the reason for such non-completion, f) the URL of the online service of the Relying Party's Registrar. g) the web form URL (if available), e-mail address (if available), and telephone number (if available) provided by the Relying Party for sending data deletion requests, see requirement RPRC_11 in Topic 44, h) the name and country of the Data Protection Authority supervising the Relying Party, as well as the web form URL (if available), e-mail address (if available), and telephone number (if available) provided by this DPA for reporting suspicious attribute presentation requests. i) information on the intended use and the URL to the applicable privacy policy.

Note: a) If an intermediary is involved in the transaction, the Wallet Unit obtains the information under point b) from the registration certificate in the presentation request, and the information under point c) from the access certificate. In case no intermediary is involved, the Wallet Unit obtains the information under point b) from either the registration certificate or the access certificate, because it is identical in both certificates. b) The information in points g) and h) can be retrieved from the registration certificate. At least one of the options (URL, e-mail address, or telephone number) will be present. See RPRC_11 and RPRC_12.

DASH_03aSHALL

For a PID or attestation presentation transaction or a Wallet-to-Wallet transaction executed through the Wallet Unit, the log SHALL NOT contain the value of any attributes presented to the Relying Party or the Verifier Wallet Unit.

DASH_03bSHALL

For a Wallet-to-Wallet transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the role of the Wallet Unit (Holder Wallet Unit or Verifier Wallet Unit), c) the attestation type(s) and the identifier(s) of the attribute(s) that were requested, as well as those that were presented, d) in the case of non-completed transactions, the reason for such non-completion.

DASH_03cSHALL

For a pseudonym registration or presentation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) identifying information about the Relying Party, if known to the Wallet Unit, c) whether it is a pseudonym registration or pseudonym presentation transaction, d) in the case of non-completed transactions, the reason for such non-completion.

Note: Regarding point b), see PA_20 in Topic 11.

DASH_03dSHALL

If a presentation request contains transactional data, the Wallet Unit SHALL log the value of this transactional data only to the extent explicitly required by the applicable Technical Specification associated with the requested SUA attestation, and in accordance with data minimisation principles. If the applicable Technical Specification does not explicitly specify that transactional data shall be logged, the Wallet Unit SHALL NOT log the value of any transactional data.

Note: a) For the concepts of transactional data and SUA attestations and their related Technical Specifications, see Topic 20. b) For example, for PSD2 Strong Customer Authentication transactions, the scope of transactional data to be included in the transaction log is defined in Technical Specification 12 and includes the payment transaction identifier and merchant name.

DASH_04SHALL

For a signature or seal creation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the document or data signed or sealed (if available to the Wallet Unit), c) in the case of non-completed transactions, the reason for such non-completion.

DASH_05SHALL

For a PID or attestation issuance or re-issuance transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the trade name, contact details (if available), unique identifier, and Service identifier of the corresponding PID Provider or Attestation Provider, c) the attestation type requested, as well as the attestation type issued, d) the number of attestations requested and issued (i.e., the size of the batch in case of batch issuance), e) in the case of non-completed transactions, the reason for such non-completion. f) for a re-issuance transaction, whether it was triggered by the User or by the Wallet Unit without involvement of the User, g) the URL of the associated Registrar's online service.

Note: a) The Wallet Unit obtains the information under point b) from either the registration certificate or the access certificate, because it is identical in both certificates. b) Regarding point g): this URL can be retrieved from the access certificate.

DASH_05aSHALL

For the deletion of a PID or attestation by the User, the log SHALL contain at least: a) the date and time of the deletion event, b) the attestation type of the deleted PID or attestation. c) The name and unique identifier of the corresponding PID Provider or Attestation Provider.

Note: This requirement is not about deletion of transactions from the log, as per DASH_06a.

DASH_06SHALL

The Wallet Provider SHALL ensure the confidentiality, integrity, and authenticity of all transactions included in the log.

DASH_06aSHALL

Via the dashboard, the Wallet Unit SHALL enable the User to delete any transaction in the log. Before deleting any transactions, the Wallet Unit SHALL indicate to the User the potential consequences for the User's data protection rights.

Note: This requirement applies even in case the minimum retention period specified in applicable legislation (see DASH_02a) is not yet over.

DASH_06bSHALL

The Wallet Unit SHALL ensure that no entity other than the User can delete transactions from the log, except possibly for the reason mentioned in DASH_02a.

DASH_07SHALL

The dashboard SHALL allow the User to export the details of one or more transactions in the log to a file, using the common format specified according to DASH_02c, while ensuring their confidentiality, authenticity and integrity. The file SHALL be stored in an external storage or remote storage location of the User's choice, from among the storage options supported by the Wallet Unit and SHALL use the common format and security measures specified according to DASH_02c.

DASH_08SHALL

For a natural-person User, a Wallet Instance SHALL provide a User interface.

DASH_09SHALL

The User interface referred to in DASH_08 SHALL provide a view with - the EU Digital Identity Wallet Trust Mark, - accompanying general information on the certification of Wallet Solutions, - links to the certification status information as defined in the Technical Specification 1.

DASH_09aSHALL

Positioning of the view meant in DASH_09 in the Wallet UI navigation SHALL follow design guidelines provided by the European Commission.

DASH_09bSHALL

Regarding the EUDI Wallet Trust Mark, Wallet Providers and Wallet Units SHALL comply with all relevant requirements in Technical Specification 1, as well as with the relevant requirements in Article 14a of CIR 2024/2979 and the Annexes mentioned therein.

DASH_10

Empty

Note: See requirement WIAM_12a in Topic 40.

DASH_11

Empty

DASH_12SHALL

The User interface referred to in DASH_08 SHALL enable the User, for each presentation transaction in the log, to easily request the Relying Party to delete any or all attributes presented to it in that transaction, or to send a report about that particular transaction to a DPA.

A.2.3.13 Topic 20 - Strong User authentication for electronic payments

SUA_01SHALL

A Wallet Unit SHALL be able to process the transactional data included in a presentation request for the SUA attestation(s) specified in Technical Specification 12, according to all requirements in that Technical Specification.

Note: Technical Specification 12 specifies a SUA attestation intended for performing SCA as specified in the PSD2 Regulation. The related Rulebook is called "SCA Attestation Rulebook".

SUA_02SHALL

Scheme Providers MAY specify Attestation Rulebooks (see Topic 12) and associated technical specifications for SUA attestations other that the ones specified in Technical Specification 12). The Attestation Rulebook or the technical specification of such of a SUA attestation SHALL specify the syntax and semantics of the transactional data associated with that attestation.

SUA_02aSHALL

The Technical Specification associated with a given SUA attestation SHALL specify all necessary requirements for Wallet Units to process transactional data intended for this SUA attestation, at least regarding a) rendering and displaying the data to the User when obtaining approval for presentation, b) processing (e.g., hashing) the data for inclusion in the device binding signature, and c) the scope of information to be logged about a SUA attestation presentation transaction by a Wallet Unit.

SUA_03SHALL

The Attestation Provider of a SUA attestation other than the one(s) specified in Technical Specification 12 SHALL NOT issue such an attestation to a Wallet Unit that does not comply with all relevant requirements in the SUA Attestation Rulebook and the technical specification for that attestation.

SUA_04SHALL

In the response to a presentation request for a SUA attestation that includes transactional data, a Wallet Unit SHALL include (a representation of) that data, according to requirements included in the associated technical specification or Attestation Rulebook or in information provided to the Wallet Unit in the presentation request. In the latter case, the rules to interpret such information SHALL be included in the associated technical specification or Attestation Rulebook.

Note: This requirement, as well as SUA_05, only applies if the requested SUA attestation is present on the Wallet Unit and if the User consents to signing the transactional data and presenting the requested attributes.

SUA_05SHALL

The Wallet Unit SHALL include (a representation of) the transactional data received in a presentation request in the signature creation process used for device binding, using the private key of the requested SUA attestation and the mechanisms specified for key binding in SD-JWT VC or mdoc authentication in ISO/IEC 18013-5, as applicable. For this process, the Wallet Unit SHALL comply with the applicable requirements in the technical specification and the Attestation Rulebook for the requested SUA attestation, see SUA_01 or SUA_02.

Note: a) The resulting signature value constitutes a proof of transaction. This signature value, possibly in combination with other protocols items, fulfils the requirements for the authentication code required in PSD2. b) See also requirement OIA_02 in Topic 1.

SUA_06SHALL

The Wallet Unit SHALL render or adapt the dialogue message(s) displayed to the User (like font size and colour, background colour, text position, labels in the buttons to 'approve' or 'reject' a transaction), according to requirements in Technical Specification 12.

SUA_07SHALL

Upon receiving a presentation request with transactional data, the Wallet Unit SHALL validate if the transactional data is intended for the given attestation and that the transactional data conforms to the related technical specification and/or Attestation Rulebook. In case the validation result is positive, the Wallet Unit SHALL process the transactional data in compliance with the related technical specification.

A.2.3.14 Topic 24 - User identification in proximity scenarios

ProxId_01SHALL

To enable identification using proximity flows, Wallet Units SHALL support device retrieval as specified in ISO/IEC 18013-5 for presenting PID or attestation attributes. Wallet Units SHALL comply with the requirements for mDLs and mdocs ISO/IEC 18013-5.

Note: Nominally, ISO/IEC 18013-5 is intended only for mDLs and mDL readers. The corresponding standard for mobile documents in general (including Wallet Units with the EUDI Wallet ecosystem) will be ISO/IEC 23220-4, which is based on ISO/IEC 18013-5. However, the latter standard is not finished yet and therefore cannot be referenced at the moment. To guarantee interoperability between Wallet Units and Relying Party Instances in proximity scenarios, it is necessary to make choices from among the possibilities specified in ISO/IEC 18013-5. Making the same choices as for mDLs ensure this.

ProxId_01aSHALL

If a Relying Party supports using proximity flows, its Relying Party Instances SHALL support device retrieval as specified in ISO/IEC 18013-5 for requesting PID or attestation attributes. Such Relying Party Instances SHALL comply with the requirements for mDL readers and mdoc readers in ISO/IEC 18013-5.

Note: See note to ProxId_01. Support for proximity flows by Relying Parties is not mandatory.

ProxId_02SHALL

Wallet Units, PID Providers, Attestation Providers, Wallet Providers, and Relying Parties SHALL NOT support server retrieval as specified in ISO/IEC 18013-5 for requesting and presenting PID or attestation attributes.

Note: Using server retrieval, a Relying Party would request User attributes directly from a PID Provider or Attestation Provider, after having received an authentication and/or authorisation token from the User's Wallet Unit.

ProxId_03SHALL

A Wallet Unit SHALL present the presentation request and the identity of the Relying Party to the User when processing the request.

ProxId_04SHALL

A Wallet Unit SHALL request its User to approve the presentation of attributes from their Wallet Unit for proximity identification before presenting them to the Relying Party or Verifier Wallet Unit.

ProxId_05SHALL

A Wallet Unit SHALL transmit the requested User attributes to the requesting Relying Party Instance securely in accordance with ISO/IEC 18013-5 for proximity flows.

ProxId_06

Empty

A.2.3.15 Topic 25 - Unified definition and controlled vocabularies for attributes

CAT_01

Empty

CAT_01a

Empty

CAT_01b

Empty

CAT_02

Empty

CAT_03

Empty

CAT_03b

Empty

CAT_04SHALL

A request to include or to modify an attribute in the catalogue of attributes SHALL indicate how a QTSP can use the verification point for that attribute.

Note: This could be, for instance, in the form of (a reference to) an endpoint description text.

A.2.3.16 Topic 27 - Registration of PID Providers, Providers of QEAAs, PuB-EAAs, and non-qualified EAAs, and Relying Parties

A. General requirements for Member State registration processes

Reg_01SHALL

Member States SHALL provide processes and mechanisms for PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers, and Relying Parties to register in a registry.

Note: Member States may choose to implement a single registry for all these roles, or a separate registry for each of these roles.

Reg_01aSHALL

Member States SHALL register a common set of data about a) PID Providers, b) QEAA Providers, c) PuB-EAA Providers, d) non-qualified EAA Providers. and e) Relying Parties, according to the relevant requirements in Technical Specification 6.

Note: For PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers, the common set of data specified in Technical Specification 6 include the attestation type(s) that the provider intends to issue to Wallet Units.

Reg_01bSHALL

Member States SHALL collect the following information only for the purpose of transparency and SHALL NOT apply any pre-authorisation process on it: i) Contact information of the registering entity, ii) description of its services, iii) Attributes registered for each intended use (for Relying Parties), or types of attestation registered (for PID Providers and Attestation Providers), iv) Description of each intended use (for Relying Parties).

Reg_02SHALL

Member States SHALL make publicly available all necessary details and documentation about the registration processes for their registry.

Reg_03SHALL

Member States SHALL publish the registry entries online, in a sealed or signed machine-readable common format suitable for automated processing, according to the relevant requirements in Technical Specification 5, for the purpose of transparency to Users and other stakeholders.

Reg_04SHALL

Member States SHALL make the registry entries available online, in a human-readable format. The website used for this purpose SHALL use a secure channel protecting the authenticity and integrity of the information in the registry during transport. Member States SHALL NOT require authentication or prior registration and authorisation of any person wishing to retrieve the information in the registry.

Reg_05

Empty

Reg_06SHALL

Member States SHALL support the common API specified in Technical Specification 5 to enable automated retrieval of registry entries from the Member States' registries.

Note: Technical Specification 5 specifies the use of a secure channel protecting the authenticity and integrity of the information in the registry during transport, and does not require authentication or prior registration and authorisation of any entity wishing to retrieve the information in the registry.

Reg_07SHALL

A Member State SHALL enable a registered PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party to update the information registered on it, using a process comparable to the original registration process. For Relying Parties, this SHALL be possible using the API or user interface mentioned in Reg_24.

Reg_08SHALL

A registered PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party SHALL make any updates necessary to ensure the continued correctness of the registered information without undue delay.

Reg_09SHALL

Member States SHALL log all changes made on the information registered regarding a PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party, including at least initial registration, updates, deletion of information, and suspension or cancellation.

B. General requirements for the issuance of access certificates

Reg_10SHALL

A Member State SHALL ensure that an Access Certificate Authority notified according to Topic 31] issues one or more access certificates to all PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers and Relying Parties registered in one of the Member State's registries.

Note: To be able to authenticate towards Wallet Units, each Relying Party Instance of a Relying Party and each service supply point of a PID Provider or Attestation Provider needs a separate access certificate, where the private key corresponding to the public key in the certificate is managed in the hardware and software of the Relying Party Instance or service supply point.

Reg_10aSHALL

A registering entity SHALL register one or more Services, and SHALL receive at least one access certificate for each registered Service, complying with Reg_33 and Reg_34.

Note: a) If the registering entity registers only one Service, all of its access certificates will contain an identical Service identifier and Service trade name. b) A single Relying Party Instance or service supply point may receive multiple access certificates, corresponding to multiple Services of the same Relying Party or Attestation Provider. This would enable the entity to use the same Relying Party Instance or supply point for multiple Services.

Reg_10bSHALL

When issuing an access certificate to a PID Provider, Attestation Provider, or Relying Party, an Access Certificate Authority SHALL also send the signing certificate and, if present, any intermediate certificate(s) leading up to the corresponding trust anchor of the Access CA in the respective LoTE published by the Commission.

Reg_10cSHALL

The registering entity SHALL receive at least one registration certificate for each registered Service, complying with RPRC_07a.

Note: If the registering entity registers only one Service, all of its registration certificates will contain an identical Service identifier and Service trade name.

Reg_10dSHALL

A Relying Party SHALL register which of its registered intended uses are applicable to each of its registered Services.

Note: Another way to phrase this is to say that the Relying Party must register the intended use(s) of each of it registered Services separately.

Reg_10eSHALL

A PID Provider or Attestation Provider SHALL register which type(s) of attestation each of its registered Services intends to issue to Wallet Units.

Reg_11SHALL

A Member State SHALL ensure that the issuance process of access certificates by their notified Access Certificate Authority(s) complies with ETSI TS 119 411-8. An Access Certificate Authority SHALL have a policy governing all aspects of access certificate issuance and management complying with this standard.

Reg_12SHALL

An Access CA SHALL be able to revoke an access certificate, if it has a validity period of longer than 24 hours

Reg_13SHALL

An Access CA SHALL have a policy specifying under which conditions an access certificate it issued will be revoked.

Reg_14

Empty

Reg_15

Empty

Reg_16

Empty

Reg_17

Empty

Reg_18

Empty

C. Requirements for the registration of PID Providers

Reg_19SHALL

A Member State SHALL approve a PID Provider according to a well-defined policy before including it in its PID Provider Registry. To that end, a Member State SHALL define specific vetting processes and rules of acceptance for inclusion of PID Providers in its Registry.

Reg_20SHALL

A Member State SHALL identify PID Providers at a level of confidence proportionate to the risk arising from the potential harm a fraudulent PID Provider could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

Reg_20aSHALL

A Registrar SHALL provide a method to suspend or cancel a registered PID Provider.

Reg_20bSHALL

A Registrar SHALL have a policy for the suspension or cancellation of a registered PID Provider, which SHALL specify that a PID Provider is suspended or cancelled at least on request of the PID Provider or of a competent national authority.

D. Requirements for the registration of Attestation Providers

Reg_21SHALL

A Member State SHALL approve an Attestation Provider according to a well-defined policy before including it in its Attestation Provider Registry. To that end, a Member State SHALL define specific vetting processes and rules of acceptance for inclusion of Attestation Providers in its Registry. These processes and rules SHOULD consider any relevant differences between QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers.

Reg_22SHALL

A Member State SHALL identify Attestation Providers (i.e., QEAA Providers, PuB-EAA Providers and non-qualified EAA Providers) at a level of confidence proportionate to the risk arising from the potential harm a fraudulent Attestation Provider could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

Reg_22aSHALL

A Registrar SHALL provide a method to suspend or cancel a registered Attestation Provider.

Reg_22bSHALL

A Registrar SHALL have a policy for the suspension or cancellation of a registered Attestation Provider, which SHALL specify that an Attestation Provider is suspended or cancelled at least on request of the Attestation Provider or of a competent national authority.

E. Requirements for the registration of Relying Parties

Reg_23

Empty

Reg_24SHALL

A Member State SHALL enable a Relying Party to register remotely, using an API or user interface.

Reg_25SHALL

A Member State SHALL identify a Relying Party at a level of confidence proportionate to the risk arising from the potential harm a fraudulent Relying Party could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

Reg_26SHALL

With respect to Reg_25, a Member State SHALL consider whether a registering entity intends to act as an intermediary.

Note: According to the European Digital Identity Regulation, an intermediary is a Relying Party.

Reg_27

Empty

Reg_28

Empty

Reg_29SHALL

A Member State SHALL have a policy for the cancellation of a registered Relying Party, which SHALL specify that a Relying Party is cancelled at least on request of the Relying Party or of a competent national authority.

Reg_30

Empty

F. Requirements for the contents of access certificates

Reg_31SHALL

An access certificate SHALL contain a trade name for the entity (i.e., the PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party), in a format suitable for presenting to a User. This name SHALL be identical to the name for the entity registered according to Technical Specification 6 and included in the entity's registration certificate(s) according to RPRC_06.

Reg_32SHALL

An access certificate SHALL contain an EU-wide unique identifier for the entity (i.e., the PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party), which SHALL be identical to the identifier for the entity registered according to Technical Specification 6 and included in the entity's registration certificate(s) according to RPRC_07.

Reg_32aSHALL

The trade name meant in Reg_31 and the identifier meant in Reg_32 SHALL be the same in all access certificates issued to a given entity.

Reg_33SHALL

An access certificate SHALL contain a Relying Party Service identifier, which SHALL be provided by the registering entity according to Technical Specification 5 and Technical Specification 6,

and SHALL be unique within the scope of that entity. Moreover, it SHALL be included in the entity's registration certificate according to RPRC_07a.

Reg_34SHALL

An access certificate SHALL contain a trade name for the Relying Party Service, which SHALL be provided by the registering entity according to Technical Specification 5 and Technical Specification 6, and SHALL be suitable for presenting to a User.

Reg_34aSHALL

If the subject of the access certificate is an intermediary (see Topic 52), the 'association to the wallet-relying party that is relying upon the intermediary' mentioned in Annex I (16) of CIR 2025/848 (and referenced in Annex IV, point 3(k) of that CIR) SHALL consist of the unique identifier of this Relying Party as meant in requirement Reg_32 and its Relying Party Service identifier as meant in Reg_33.

Note: a) This implies that an intermediary receives a separate set of access certificates for each of its intermediated Relying Parties. b) The association is also included in the registration certificates of the intermediated Relying Parties, see RPRC_04.

Reg_35SHALL

The access certificate format SHALL provide for the data elements to carry the elements mentioned in Reg_31 - Reg_34a.

Note: The generic X.509 certificate structure has multiple suitable data elements which could be designated for these elements.

A.2.3.17 Topic 28 - Wallet Unit for legal persons

LP_01

Empty

LP_02

Empty

LP_03

Empty

A.2.3.18 Topic 29 - Representation paradigm

RP_01SHALL

Attestation Scheme Providers MAY create one or multiple Attestation Rulebooks for representation attestations issued to a natural person representing another natural person. Each Rulebook SHALL specify the unique attestation type of these representation attestations. The Rulebook SHALL also specify attributes used for defining a validity period, the nature of the representation, and the operations the representative is authorised to perform, thereby limiting the scope of its authorisation.

RP_02SHALL

An Attestation Provider issuing representation attestations to a natural person representing another natural person SHALL ensure that either the attestations are short-lived or that all entities which, according to applicable law, must have the ability to request revocation of such attestations, are able to do so.

A.2.3.19 Topic 30 - Interaction between Wallet Units

W2W_01SHALL

A Wallet Unit SHALL be able to act as a Holder Wallet Unit, in accordance with all requirements in this Topic.

W2W_02SHALL

When acting as a Holder Wallet Unit, if there is a contradiction between a requirement for Holder Wallet Units in this Topic and any requirement for Wallet Units in other Topics in this document, the requirement in this Topic SHALL take precedence. However, when acting as a Holder Wallet Unit, a Wallet Unit SHALL comply with all requirements for Wallet Units in other Topics in this document that do not contradict any requirement in this Topic.

W2W_03SHALL

A Wallet Unit SHALL be able to act as a Verifier Wallet Unit, in accordance with all requirements in this Topic.

W2W_04SHALL

When acting as a Verifier Wallet Unit, a Wallet Unit SHALL NOT comply with any requirement for Wallet Units in other Topics in this document.

W2W_05SHALL

A Wallet Unit SHALL act as a Holder Wallet Unit only if the User selects a ‘Holder Wallet Unit mode’. If the User closes the Wallet Unit, or after a period of non-activity, the Wallet Unit SHALL return to ‘normal’ mode.

W2W_06SHALL

When entering the Holder Wallet Unit mode, a Wallet Unit SHALL inform its User that this mode should only be used for interactions with natural persons using a Wallet Unit, and that the User should not proceed if they are in fact interacting with a Relying Party.

W2W_07SHALL

A Wallet Unit SHALL act as a Verifier Wallet Unit only if the User selects a 'Verifier Wallet Unit mode'. If the User closes the Wallet Unit, or after a period of non-activity, the Wallet Unit SHALL return to 'normal' mode.

W2W_08SHALL

A Verifier Wallet Unit and a Holder Wallet Unit SHALL support attestation presentation only in proximity, meaning they SHALL support only ISO/IEC 18013-5 to communicate.

W2W_09SHALL

Holder Wallet Units SHALL comply with the requirements for mDLs and for mdocs in ISO/IEC 18013-5, unless specified differently in Technical Specification 9.

W2W_10SHALL

Verifier Wallet Units SHALL comply with the requirements for mDL readers and for mdoc readers in ISO/IEC 18013-5, unless specified differently in Technical Specification 9.

W2W_11SHALL

A Holder Wallet Unit SHOULD provide the Holder, through a user-friendly UI, with the option to inform the Verifier Wallet Unit about the attributes which the Verifier should include in the presentation request, by sending a presentation offer. If the Holder creates a presentation offer, the Holder Wallet Unit SHALL transfer it to the Verifier Wallet Unit as specified in Technical Specification 9.

Note: TS9 specifies an extension of the device engagement structure specified in ISO/IEC 18013-5.

W2W_12SHALL

A Holder Wallet Unit SHALL recommend the Holder to create a presentation offer, as this will increase the chance of success of the use case.

W2W_13SHALL

A Verifier Wallet Unit SHALL provide the Verifier, through a user-friendly UI, with the possibility to select the attributes that will be included in the presentation request.

W2W_14SHALL

For the purposes of W2W_13, if the Verifier Wallet Unit received a presentation offer, it SHALL present this offer to the Verifier, and enable the Verifier to include one or more of the attributes in the offer into the presentation request. However, the Verifier Wallet Unit SHALL NOT allow the Verifier to include any attribute not present in the offer.

W2W_15SHALL

For the purposes of W2W_13, if the Verifier Wallet Unit did not receive a presentation offer, it SHALL present the Verifier with a list of attributes that can be included in the presentation request. The Verifier Wallet Unit MAY ask the Verifier some questions about the purpose of the use case to narrow down the list.

W2W_16SHALL

A Verifier Wallet Unit SHALL authenticate the Verifier and SHALL obtain the Verifier's approval prior to sending a presentation request to a Holder Wallet Unit.

W2W_17SHALL

A Verifier Wallet Unit SHALL implement measures to limit the number of presentation requests it can send per unit of time, to prevent abuse of the Wallet-to-Wallet functionality by Relying Parties. The limitation strategy, for instance exponential backoff time between subsequent presentation requests or hard limits for the number of requests, SHALL be decided by the Wallet Provider, based on applicable requirements in Technical Specification 9.

W2W_18

Empty

W2W_19SHALL

When receiving a presentation response, a Verifier Wallet SHALL verify the received attestation according to requirements OIA_12 - OIA_15 in Topic 1.

W2W_20SHALL

A Verifier Wallet Unit SHALL display all verified attributes to the Verifier.

W2W_21SHALL

A Verifier Wallet Unit SHALL NOT persistently store any attestations or attributes received. A Verifier Wallet Unit SHOULD minimise the time the received presentation is stored in memory. A Verifier Wallet Unit SHALL comply with OIA_16 in Topic 1.

W2W_22SHOULD

Wallet Providers SHOULD take measures to prevent a User from taking screenshots while their Wallet Unit is acting as a Verifier Wallet Unit.

W2W_23SHALL

When sending a presentation request to a Holder Wallet Unit, a Verifier Wallet Unit SHALL include in that request a cryptographic proof that it is a genuine, non-revoked EUDI Wallet Unit operated by a recognised Wallet Provider, bound to the protocol session in which the presentation request is sent, if a common method to provide such a proof is established in a technical specification.

Note: Such a specification is being developed within ETSI.

W2W_24SHALL

Before presenting a received presentation request to the Holder, a Holder Wallet Unit SHALL authenticate the Verifier Wallet Unit by verifying the proof meant in W2W_23, if present.

W2W_25SHALL

If the verification required by W2W_24 fails or cannot be performed, a Holder Wallet Unit SHALL notify the User. In addition, the Wallet Unit SHALL either not present the requested attributes to the Verifier Wallet Unit, or give the User the choice to present the requested attributes or not.

Note: It is up to the Wallet Provider to make a choice for one of these two options.

A.2.3.20 Topic 31 - Notification and publication of PID Provider, Wallet Provider, Attestation Provider, Access Certificate Authority, and Provider of registration certificates

A. Generic requirements for notification

GenNot_01SHALL

Member States SHALL notify all PID Providers, PuB-EAA Providers, Wallet Providers, Access Certificate Authorities, and Providers of registration certificates to the European Commission, using a common system provided by the Commission, complying with all relevant requirements inTechnical Specification 2.

GenNot_02SHALL

In addition to Technical Specification 2 referred to in GenNot_01, the European Commission SHALL establish standard operating procedures for the notification of a PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority, or Provider of registration certificates to the Commission.

Note: The outcome of the notification procedure is the publication of the information notified by the Member State according to Article 5a (18) in a machine and human readable manner using the common system mentioned in Section H, TLPub_01.

GenNot_03SHALL

The common system mentioned in GenNot_01 SHALL enable: - A secure notification channel between Member States and the Commission for all notifications. - A notification, verification, and publication process and associated validation steps (with follow-up and monitoring) at the Commission side. - Collected data to be processed, consolidated, signed or sealed, and published in both a machine-processable LoTE and in a human-readable format, manually and/or automatically using e.g. a web service and/or API.

GenNot_04

Empty

GenNot_05SHALL

In addition to Technical Specification 2 referred to in GenNot_01, the European Commission SHALL establish standard operating procedures for the suspension or cancellation of a PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority, or Provider of registration certificates. These operating procedures SHALL include unambiguous conditions for suspension or cancellation. As an outcome of the suspension or cancellation procedure, the Commission SHALL change the status of the suspended or cancelled PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority or Provider of registration certificates in the respective LoTE to Invalid.

B. Requirements for the notification of PID Providers

PPNot_01

Empty

PPNot_02SHALL

The common set of information to be notified about a PID Provider SHALL include at least: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. A business registration number from an official record, b. Identification data from that official record. 2. PID Provider trust anchors, i.e., public keys and name as per point 1) ii) above, supporting the authentication of PIDs issued by the PID Provider, 3. If applicable, trust anchors for PID revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists or Attestation Revocation Lists used to revoke PIDs issued by the PID Provider. 4. Trust anchors of Access Certificate Authorities for PID Providers, i.e., public keys and CA name, supporting the authentication of the PID Provider by Wallet Units at the service supply point(s) listed per point 5. below. 5. Service supply point(s), i.e., the URL(s) at which a Wallet Unit can start the process of requesting and obtaining a PID. 6. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: a) Regarding point 3 above, see section 6.3.2.4 of the ARF main document. b) Relating to point 4: PID Provider Access Certificate Authority trust anchors are notified separately from the Access Certificate Authority for Relying Parties (see Section G below), since PID Providers are -legally speaking- not Relying Parties. b) For the concept of an Access Certificate Authority, see also Topic 27] and Section 6.3.2 of the ARF main document. c) Regarding point 6: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual PID will anyway be included in that PID.

PPNot_03SHALL

PID Providers SHALL ensure that all PIDs they issue can be authenticated using the PID Provider trust anchors notified to the Commission.

PPNot_03aSHALL

PID Providers SHALL ensure that all Attestation Status Lists or Attestation Revocation Lists used to revoke their PIDs can be authenticated using the trust anchors for PID revocation lists notified to the Commission.

PPNot_04SHALL

PID Providers SHALL ensure that their access certificates can be authenticated using the applicable Access Certificate Authority trust anchors notified to the Commission.

Note: Topic 6] describes how access certificates will be used.

PPNot_05SHALL

Wallet Units, Relying Parties, and other relevant actors SHALL accept PID Provider trust anchors and the trust anchors for PID revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled PID Provider LoTE, which is sealed by the Commission.

PPNot_06SHALL

Wallet Units and other relevant actors SHALL accept Access Certificate Authority trust anchors because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled LoTE, which is signed or sealed by the Commission.

PPNot_07SHALL

The format of a PID Provider LoTE SHALL comply with ETSI TS 119 602, including Annex D.

C. Requirements for the notification of Wallet Providers

WPNot_01

Empty

WPNot_02SHALL

The common set of information to be notified about a Wallet Provider SHALL include: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. Business registration number from an official record, and b. Identification data from the official record. 2. Wallet Provider trust anchors, i.e., public keys and name as per point 1. b. above, supporting the authentication of Key Attestations and Wallet Instance Attestations issued by the Wallet Provider. 3. Trust anchors for WIA and KA revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists used to revoke WIAs and KAs issued by the Wallet Provider. 4. Name and reference number of the certified Wallet Solution(s) provided by the Wallet Provider. 5. The URL at which PID Providers, Attestation Providers, and other entities can retrieve the relevant Attestation Status Lists for WIAs and KAs.

Note: a) See Topic 9] and Topic 38] for the definition of the KA and WIA. b) A Wallet Provider does not need an access certificate to interact with Wallet Units. c) Regarding point 3, see section 6.3.2.4 of the ARF main document. d) Regarding point 5: This could be the domain name only, as the full URL containing the ASL relevant for an individual WIA or KA will anyway be included in that WIA or KA.

WPNot_03SHALL

Wallet Providers SHALL ensure that all WIAs and KAs they issue can be authenticated using the trust anchors notified to the Commission.

WPNot_03aSHALL

Wallet Providers SHALL ensure that all Attestation Status Lists used to revoke their WIAs and KAs can be authenticated using the trust anchors for WIA and KA revocation lists notified to the Commission.

WPNot_04SHALL

PID Providers, Attestation Providers, and other relevant actors SHALL accept Wallet Provider trust anchors and the trust anchors for WIA and KA revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled Wallet Provider LoTE, which is sealed by the Commission.

WPNot_05SHALL

The format of a Wallet Provider LoTE SHALL comply with ETSI TS 119 602, including Annex E.

WPNot_06SHALL

If a Wallet Provider is cancelled (see requirement GenNot_05 above), that Wallet Provider SHALL immediately revoke all of its Wallet Instances and all associated WSCDs and keystores, in accordance with the requirements in Topic 38. If a Wallet Provider is suspended, that Wallet Provider and the Member State SHALL agree on the necessary precautionary measures that need to be taken, which MAY include the immediate revocation of the Wallet Instances and WSCDs or keystores for all or some of its valid Wallet Units.

D. Requirements for the notification of PuB-EAA Providers

PuBPNot_01

Empty

PuBPNot_02SHALL

The common set of information to be notified by Member States about PuB-EAA Providers SHALL include at least: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. Registration number as in official

record, and b. Official record identification data. iv. Identification data of the Union or national law under which a. Either the PuB-EAA Provider is established as the responsible body for the Authentic Source based on which the electronic attestation of attributes is issued, or b. The PuB-EAA Provider is the body designated to act on behalf of the responsible body referred to in point 1. iv. a. v.The conformity assessment report issued by a conformity assessment body, confirming that the requirements set out in paragraphs 1, 2 and 6 of Article 45f are met. 2. PuB-EAA Provider trust anchors, i.e., public keys and name as per point 1) ii) above, supporting the authentication of PuB-EAAs issued by the PuB-EAA Provider, 3. If applicable, trust anchors for PuB-EAA revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists or Attestation Revocation Lists used to revoke PuB-EAAs issued by the PuB-EAA Provider. 4. Service supply point(s), i.e., the URL(s) at which a Wallet Unit can start the process of requesting and obtaining a PuB-EAA from the PuB-EAA Provider. 5. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: c) Regarding point 3, see section 6.3.2.4 of the ARF main document. d) Regarding point 5: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual PuB-EAA will anyway be included in that PuB-EAA.

PuBPNot_03SHALL

The format of the PuB-EAA Provider LoTE SHALL comply with ETSI TS 119 602, including Annex H.

PuBPNot_04SHALL

PuB-EAA Providers SHALL ensure that all PuB-EAAs they issue can be authenticated using the trust anchors notified to the Commission.

PuBPNot_05SHALL

PuB-EAA Providers SHALL ensure that all Attestation Status Lists and Attestation Revocation Lists used to revoke their PuB-EAAs can be authenticated using the trust anchors for PuB-EAA revocation lists notified to the Commission.

PuBPNot_06SHALL

Relying Parties and other relevant actors SHALL accept PuB-EAA Provider trust anchors and the trust anchors for PuB-EAA Provider revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled PuB-EAA Provider LoTE, which is sealed by the Commission.

E. Requirements for the notification of Access Certificate Authorities and Providers of registration certificates

RPACANot_01

Empty

RPACANot_02SHALL

The common set of information to be notified about an Access Certificate Authority or a Provider of registration certificates SHALL include: 1. Identification data: i) Member State or country of establishment, ii) Name as registered in an official record, iii) Where applicable: - A business registration number from an official record, - Identification data from that official record. 2. Trust anchors of the Access Certificate Authority or Provider of registration certificates, i.e., public keys and name as per point 1) ii), supporting the authentication of access certificates and registration certificates by Wallet Units. 3.Trust anchors for access certificate or registration certificate revocation lists, i.e., public keys and name supporting the authentication of any lists used to revoke access certificates or registration certificates issued by the Access Certificate Authority or Provider of registration certificates. 4. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant CRL.

Note: Regarding point 4: This could be the domain name only, as the full URL containing the CRL relevant for an individual certificate will anyway be included in that certificate.

RPACANot_03SHALL

An Access Certificate Authority SHALL ensure that the access certificates it issues to Relying Parties, PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers can be authenticated using the trust anchors notified to the Commission.

RPACANot_03aSHALL

A Provider of registration certificates SHALL ensure that the registration certificates it issues to Relying Parties, PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers can be authenticated using the trust anchors notified to the Commission.

RPACANot_03bSHALL

Access Certificate Authorities or Providers of registration certificates SHALL ensure that all lists used to revoke their access certificates and registration certificates can be authenticated using the trust anchors for revocation lists notified to the Commission.

RPACANot_04SHALL

The trust anchors of Access Certificate Authorities and Providers of registration certificates, as well as their CRL trust anchors, SHALL be accepted because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled LoTEs, which are signed or sealed by the Commission.

RPACANot_05SHALL

The format of a LoTE for Access Certificate Authorities SHALL comply with ETSI TS 119 602, including Annex F.

RPACANot_05aSHALL

The format of a LoTE for Providers of registration certificates SHALL comply with ETSI TS 119 602, including Annex G.

RPACANot_06SHALL

If an Access Certificate Authority is suspended or cancelled (see requirement GenNot_05 above), that Access Certificate Authority SHALL immediately revoke all of its temporally valid access certificates.

Note: This implies that if an intermediary obtained its access certificates from an Access Certificate Authority that is suspended or cancelled, any intermediated Relying Party depending on that intermediary will not be able to request attributes from Wallet Units, even though its registration is still valid. Such an intermediated Relying Party will either have to transit to another intermediary (which has access certificates issued by an active Access Certification Authority) or wait until the original intermediary obtains new access certificates either from another Access CA or from the original one, once that CA can continue its operations.

RPACANot_07SHALL

If a Provider of registration certificates is suspended or cancelled (see requirement GenNot_05 above), that Provider SHALL immediately revoke all of its valid registration certificates (if any). Moreover, the corresponding Registrar SHALL prohibit all access to the registry entries published online per Reg_03 and Reg_04.

F. Requirements for the publication of LoTEs compiled by the Commission

TLPub_01SHALL

The European Commission SHALL establish technical specifications for the system enabling the publication by the Commission of the information notified by the Member States regard-

ing PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

TLPub_02SHALL

The European Commission SHALL establish technical specifications for the set of information to be published about PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities and Providers of registration certificates, based on the information notified by the Member States.

Note: The information to be published MAY be different from the information to be notified for each of these entities.

TLPub_03SHALL

The publication of the information referred to in TLPub_01 SHALL take place over a secure channel protecting the authenticity and integrity of the published information.

TLPub_04SHALL

The technical system mentioned in TLPub_01 SHALL NOT require authentication or prior registration and authorisation of any entity wishing to retrieve the published information.

TLPub_05SHALL

The information referred to in TLPub_01 SHALL be published in an electronically signed or sealed form that is suitable for automated processing, and in a human-readable format, e.g., through introspection and display facilities, over an authenticated channel.

TLPub_06SHALL

The Commission SHALL publish in the OJEU the locations of the LoTEs for PID Providers, PuB-EAA Providers, Wallet Providers, Access Certificate Authorities, and Providers of registration certificates.

TLPub_07SHALL

The Commission SHALL publish in the OJEU the trust anchors to be used for verifying the signature or seal mentioned in TLPub_05.

TLPub_08SHALL

As part of the specifications referred to in TLPub_01, the European Commission SHALL establish technical specifications for ensuring the availability and authenticity of the full history

regarding the information notified about PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

A.2.3.21 Topic 34 - Migrate to a different Wallet Solution

A. Back-up requirements

Mig_01SHALL

A Wallet Unit SHALL include and keep up-to-date a Migration Object, containing the following information: - The contents of the log for all transactions executed through the Wallet Unit, as listed in requirement DASH_02. - A list of PIDs and attestations (except Key Attestations and Wallet Instance Attestations) present in the Wallet Unit, according to the requirements in this Topic.

Mig_02SHALL

The Migration Object SHALL comply with all requirements in Technical Specification 10.

Mig_03SHALL

For each PID or device-bound attestation that is issued to it, a Wallet Unit SHALL add to the Migration Object all data necessary to request issuance of that PID or attestation once again. This SHALL include at least the attestation type and the PID Provider or Attestation Provider that issued the PID or attestation, as well as their service supply points. However, the Migration Object SHALL NOT contain attribute identifiers or attribute values, and SHALL NOT contain any private keys of the PID or device-bound attestation.

Mig_03aSHALL

For each non-device-bound attestation that is issued to it, a Wallet Unit SHALL add to the Migration Object one of the following: either all data necessary to request issuance of that attestation once again, as listed in Mig_03, or all data necessary to transfer the attestation to a new device without involvement of the Attestation Provider, including attribute identifiers and attribute values. The Wallet Unit SHALL enable the User to indicate if they want to store attribute identifiers and values in the Migration Object.

Mig_03bSHALL

If the User deletes a PID or attestation from their Wallet Unit, the Wallet Unit SHALL delete the corresponding entry from the Migration Object.

Mig_04SHALL

The Wallet Unit SHALL store the Migration Object in an external storage or remote storage location of the User's choice, from among the storage options supported by the Wallet Unit, in such a way that the User can still retrieve the object from a new Wallet Unit in case the existing Wallet Unit becomes unavailable.

Note: a) It is up to the Wallet Provider to decide which external storage options or remote storage locations the Wallet Unit supports for storing the Migration Object. b) The new Wallet Unit may be either an instance of the same Wallet Solution as the old one, or an instance of a different Wallet Solution.

Mig_05SHALL

The Wallet Unit SHALL store the Migration Object in such a way that its confidentiality, integrity, and authenticity is protected and that it is protected against use by others than the User.

Note: This could be done, for example, by using password-based cryptography to encrypt the object.

B. Restore Requirements

Mig_06SHALL

Directly after installation of a new Wallet Instance, the Wallet Instance SHALL enable the User to import a Migration Object from an external storage or remote storage location indicated by the User, from among the storage options supported by the Wallet Unit.

Mig_07SHALL

When importing a Migration Object, for each PID and device-bound attestation listed in the Migration Object, the Wallet Unit SHALL enable the User to select that PID or attestation. When a PID or device-bound attestation is selected, the Wallet Unit SHALL request the respective PID Provider or Attestation Provider to issue a new PID or attestation of the same type to the new Wallet Unit. If the User selects a PID, the Wallet Unit SHALL request issuance of the PID first, before any of the other selected attestations.

Note: a) Since no refresh tokens (see ISSU_65) will be available on the new Wallet Unit, this is a new issuance process, which will include User authentication by the PID Provider or Attestation Provider. b) The rationale for the last requirement is to ensure that if other Attestation Providers want to use a PID to do User authentication, the PID is actually available.

Mig_07aSHALL

When importing a Migration Object, for each non-device-bound attestation listed in the Migration Object, the Wallet Unit SHALL enable the User to select that attestation. When an attestation is selected, the Wallet Unit SHALL, depending on whether the Migration Object contains attribute identifiers and attribute values (see Mig_03a), either restore the technical attestation directly from the Object or request the respective Attestation Provider to issue a new attestation of the same type to the new Wallet Unit.

Mig_07bSHALL

When importing a Migration Object, the Wallet Unit SHALL ask the User whether they want to restore the log from the Migration Object. When the User agrees, the Wallet Unit SHALL restore the log, and SHALL append future transactions to this log according to the requirements in Topic 19.

Mig_08

Empty

Mig_09

Empty

Mig_10

Empty

Mig_11SHALL

The processes and interfaces used for issuance of a PID or attestation as part of a migration process SHALL be the same as those used for a 'normal' issuance process, as specified in Topic 10.

Mig_12

Empty

Mig_13

Empty

Mig_14

Empty

Mig_15

Empty

Mig_16

Empty

A.2.3.22 Topic 38 - Wallet Unit revocation

A. Issuing a Wallet Unit Attestation

WURevocation_01SHALL

To enable a PID Provider or an Attestation Provider to verify the authenticity and the revocation status of a Wallet Unit it is interacting with, a Wallet Provider SHALL issue one or more Key Attestations (KA) and Wallet Instance Attestations (WIA) to the Wallet Unit, as specified in Topic 9.

Note: The first of these KAs and WIAs will be issued during the activation phase of a Wallet Unit. During the lifetime of the Wallet Unit, the Wallet Provider will re-issue KAs and WIAs as needed.

WURevocation_02

Empty

WURevocation_03SHALL

A Wallet Provider SHALL have a policy governing all aspects of WIA and KA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to WIAs and KAs. The policy SHALL distinguish between WIAs, KAs for WSCA/WSCDs, and KAs for keystores. For KAs describing a WSCA/WSCD, the policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of KAs rather than public key certificates. For KAs describing a keystore, the policy SHALL comply with at least the normalised certificate policy ('NCP') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of KAs rather than public key certificates.

WURevocation_04

Empty

WURevocation_05

Empty

B. Revoking a Wallet Unit

WURevocation_06

Empty

WURevocation_07SHALL

To revoke the Wallet Instance of a Wallet Unit, a Wallet Provider SHALL, in the status list(s) for Wallet Instances, set the `revoked` status at all index positions mentioned in the WIAs issued to that Wallet Instance.

WURevocation_07aSHALL

To revoke a WSCD or keystore of a Wallet Unit, the Wallet Provider SHALL, in the status list(s) for WSCDs and keystores, set the `revoked` status at all index positions mentioned in the KAs describing that WSCD or keystore.

Note: For this requirement, it does not matter whether each index in the status list(s) for WSCDs and keystores refers to a type of WSCD or keystore or to an individual WSCD or keystore.

WURevocation_08

Empty

WURevocation_09SHALL

During the lifetime of a Wallet Unit, the Wallet Provider SHALL regularly verify that the security of the Wallet Unit is not breached or compromised. If the Wallet Provider detects a security breach or compromise, the Wallet Provider SHALL analyse its cause(s) and impact(s). If the breach or compromise affects the trustworthiness or reliability of the Wallet Unit, the Wallet Provider SHALL revoke the Wallet Unit by revoking the Wallet Instance according to WURevocation_07. The Wallet Provider SHALL do so at least in the following circumstances: - If the security of the Wallet Unit, or the security of the mobile device and OS on which the corresponding Wallet Instance is installed, or the security of the WSCA/WSCD it uses for managing critical cryptographic assets, is breached or compromised in a manner that affects its trustworthiness or reliability. - If the security of the Wallet Solution is breached or compromised in a manner that affects the trustworthiness or reliability of all corresponding Wallet Units. - If the security of the common authentication and data protection mechanisms used by the Wallet Unit is breached or compromised in a manner that affects their trustworthiness or reliability. - If the security of the electronic identification scheme under which the Wallet Unit is provided is breached or compromised in a manner that affects its trustworthiness or reliability.

Note: The first bullet corresponds to a Critical or High Risk level security posture risk status according to the table in Section 6.5.4.2 of the ARF main document, as analysed or detected for a Wallet Instance due to monitoring done according to WPSM_03.

WURevocation_09aSHALL

If a breach or compromise detected per WURevocation_09 affects the trustworthiness or reliability of a (type of) WSCA/WSCD or keystore, the Wallet Provider SHALL revoke the corresponding (type of) WSCA/WSCD or keystore according to WURevocation_07a.

Note: Per WURevocation_09, a compromise of a type of WSCA/WSCD always leads to the revocation of both that type of WSCA/WSCD and of all Wallet Instances using a WSCA/WSCD of that type.

WURevocation_09b

Empty

WURevocation_09cSHALL

If a Wallet Provider revokes a keystore of a Wallet Unit, it SHOULD also revoke the entire Wallet Unit by revoking the Wallet Instance. If the Wallet Provider decides to not revoke the Wallet Instance, it SHALL create a risk analysis showing that this does not lead to unacceptable risks to the User, PID Providers and Attestation Providers, Relying Parties, or the Wallet Provider itself.

Note: If the Wallet Provider does not revoke the Wallet Instance, only the attestations bound to the revoked keystore will be impacted. Other functionalities of the Wallet Unit, including the presentation of a PID, will remain available to the User.

WURevocation_10SHALL

A Wallet Provider SHALL revoke a Wallet Unit upon the explicit request of the User registered during the Wallet Unit activation process, see Topic 40. To do so, the Wallet Provider SHALL revoke the Wallet Instance (see WURevocation_07). The Wallet Provider SHALL authenticate the User before accepting a request to revoke the Wallet Unit.

WURevocation_11SHALL

A Wallet Provider SHALL revoke a Wallet Unit upon the explicit request of a PID Provider, in case the natural person using the Wallet Unit has died. To do so, the Wallet Provider SHALL revoke the Wallet Instance (see WURevocation_07). To identify the Wallet Unit that is to be revoked, the PID Provider SHALL use a Wallet Instance identifier provided by the Wallet Provider in the WIA during PID issuance.

Note: Under Technical Specification 3, the Wallet Instance identifier used for revocation is conveyed in the WIA (see WUA_08). See also the notes to WUA_08.

WURevocation_12SHALL

Before revoking a Wallet Unit per WURevocation_11, the Wallet Provider SHALL verify that the party requesting revocation is indeed a valid PID Provider listed in the LoTE of PID Providers.

WURevocation_13SHALL

Before requesting a Wallet Provider to revoke a Wallet Unit per WURevocation_11, the PID Provider SHALL ensure that the revocation does not harm the interests of any of the stakeholders. The PID Provider SHALL include a documented policy ensuring that this is the case in the policy meant in WURevocation_03.

C. Informing the User

WURevocation_14SHALL

A Wallet Provider SHALL inform a User without delay, and within 24 hours at most, in case the Wallet Provider decided to revoke the User's Wallet Unit. The Wallet Provider SHALL also inform the User about the reason(s) for the revocation. This information SHALL be understandable for the general public. It SHALL include (a reference to) technical details about any security breach if applicable. The Wallet Provider SHALL inform the User about the function(s) of the Wallet Unit that remain available to the User, if any, and functions that will not work any more. The Wallet Provider SHALL also inform the User about measures they can take to ensure they have a fully working Wallet Unit again as soon as possible, such as migrating to a different Wallet Solution.

Note: Functions that remain available to the User may include viewing their own attributes in their Wallet Unit and accessing their account at the Wallet Provider.

WURevocation_15

Empty

WURevocation_16SHALL

To inform a User about the revocation of their Wallet Unit, the Wallet Provider SHALL use a communication channel that is independent of the Wallet Unit. In addition, the Wallet Provider MAY use the Wallet Unit itself to inform the User.

D. Verifying the revocation status of a Wallet Unit

WURevocation_17

Empty

WURevocation_18SHALL

A PID Provider issuing revocable PIDs SHALL, for each of its valid PIDs, regularly verify whether the Wallet Instance on which that PID is residing has been revoked and whether the associated WSCD has been revoked, using the WIA and KA received during issuance of that PID. If either the Wallet Instance or the WSCD has been revoked, the PID Provider SHALL immediately revoke the respective PID.

Note: a) This requirement aligns with WUA_29, which requires PID Providers to check the revocation status of both the WIA and KA throughout the PID validity period. b) This is a consequence of the legal requirement in CIR 2024/2977, Article 5, 4.(b). c) See Technical Specification 3 for how the PID Provider can do this verification.

WURevocation_19SHALL

An Attestation Provider issuing revocable attestations MAY decide to revoke an attestation if the Wallet Provider revoked the Wallet Unit on which that attestation is residing, in the same manner as described in WURevocation_18. An Attestation Provider SHALL publish its policy in this regard.

Note: Publishing its policy regarding revocation allows a Relying Party to decide if it can put sufficient trust in the attestations issued by that Attestation Provider.

WURevocation_19a

Empty

WURevocation_19b

Empty

WURevocation_20

Empty

WURevocation_21

Empty

A.2.3.23 Topic 40 - Wallet Instance installation and Wallet Unit activation and management

A. HLRs for Wallet Instance installation

WIAM_01SHOULD

To ensure that the User can trust the Wallet Solution, a Wallet Provider SHOULD make its certified Wallet Solution available for installation only via the official app store of the relevant operating system (e.g., Android, iOS).

Note: This allows the operating system of the device to perform relevant checks regarding the authenticity of the Wallet Unit.

WIAM_02SHALL

If a Wallet Provider makes its certified Wallet Solution available for installation through other means than the official OS app store, it SHALL implement a mechanism allowing the User to verify the authenticity of the Wallet Unit. Moreover, it SHALL provide clear instructions to the User on how to install the Wallet Instance, including at least: - instructions on the verification of the authenticity of the Wallet Instance to be installed, - instructions on bypassing of any operating system limitations on side-loading of apps, if applicable, and ensuring that these limitations are restored after the Wallet Instance has been installed.

Note: This requirement also applies for the installation of a Wallet Instance on a User device that is not a mobile device, and for which no official operating system app store may exist.

B. HLRs for Wallet Unit activation

WIAM_03SHALL

A Wallet Provider SHALL ensure that a Wallet Instance starts a process to activate the new Wallet Unit with the Wallet Provider immediately after installation or when the User first opens the Wallet Instance. The Wallet Provider SHALL ensure that the Wallet Instance starts this process only with a secure backend of the Wallet Provider.

WIAM_04SHALL

During the activation process of a new Wallet Unit, the Wallet Provider SHALL verify that the new Wallet Instance is a genuine instance of its Wallet Solution.

WIAM_05SHALL

During the activation process of a new Wallet Unit, the Wallet Provider SHALL process information about the User device and the available WSCA/WSCD and keystore(s), as far as necessary to issue Key Attestations and Wallet Instance Attestations to the Wallet Unit conform

all requirements in Topic 9. The Wallet Provider MAY process additional information necessary for managing the Wallet Unit, but it SHALL NOT process more information than it reasonably needs for legitimate purposes. The Wallet Provider SHALL request User consent (through the Wallet Instance) for all information and data it will process, both during activation and throughout the lifetime of the Wallet Unit. The Wallet Provider SHALL inform the User about the purposes of data processing, in accordance with the General Data Protection Regulation.

WIAM_06SHALL

The Wallet Provider SHALL request the User, through the new Wallet Instance, to log in to an existing account at the Wallet Provider, or to set up a new User account if the User does not have an account yet. If a new account must be set up, the Wallet Provider SHALL explain to the User that setting up an account is necessary to enable the User to request revocation of the Wallet Unit in case of theft or loss. The Wallet Provider SHALL register one or more User authentication methods that the Wallet Provider will use to authenticate the User in the future. These methods SHALL be independent of the Wallet Unit and the User device. The Wallet Provider SHALL allow the User to register using an alias instead of true identity data. The Wallet Provider SHALL NOT use any registered User data for purposes other than User authentication, unless the User gives explicit consent to do so. The Wallet Provider SHALL register the relationship between the Wallet Unit and the corresponding User account.

Note: The User may already have an account at the Wallet Provider, for example because they use a Wallet Unit of this Wallet Provider already on another device, or if they are migrating to a new device.

WIAM_07SHALL

A Wallet Provider SHALL activate a new Wallet Unit before a User can use it to have issued an PID or attestation.

WIAM_08SHALL

A Wallet Provider SHALL only activate a new Wallet Unit if it has verified that the Wallet Unit includes a WSCA/WSCD that is certified to be compliant with applicable requirements for Level of Assurance High.

Note: a) A WSCA/WSCD by definition complies with requirements for Level of Assurance High, see WIAM_14. b) In addition, the Wallet Unit can include one or more keystores.

WIAM_08aSHALL

If a Wallet Unit contains one or more keystores, the Wallet Provider SHALL assign a

security level to every keystore, with the following possible values: `iso_18045_high`, `iso_18045_moderate`, `iso_18045_enhanced-basic`, `iso_18045_basic` or `none`, corresponding to the level of resistance for which the keystore was certified (respectively AVA_VAN.5, AVA_VAN.4, AVA_VAN.3, AVA_VAN.2 and no certification).

Note: For the definition of these security levels, also see OpenID4VCI Annex D.2

WIAM_09SHALL

If a WSCA/WSCD or keystore contains cryptographic assets related to multiple Wallet Units, the Wallet Provider SHALL ensure that a Wallet Unit can only access assets that are related to that Wallet Unit.

WIAM_10SHALL

During the activation process of a new Wallet Unit, a Wallet Provider SHALL create and sign at least one Key Attestation for the WSCA/WSCD, at least one Key Attestation for each keystore, and at least one Wallet Instance Attestation, and issue them to the Wallet Unit. The Wallet Provider SHALL verify that the private key(s) corresponding to the public key(s) in each KA are protected by the respective WSCA/WSCD or keystore, under control of the User. The Wallet Provider SHALL take measures to verify the integrity of the Wallet Instance before issuing a Wallet Instance Attestation.

WIAM_10aSHALL

During the activation process of a new Wallet Unit, the Wallet Provider SHALL offer the User a means to verify the formal certification information of their Wallet Solution.

C. HLRs for Wallet Unit management

WIAM_11

Empty

WIAM_12SHALL

All communication between the Wallet Provider and the Wallet Instance SHALL be mutually authenticated and SHOULD be encrypted.

WIAM_12aSHALL

A Wallet Provider SHALL NOT access the contents of a Wallet Instance, in particular to learn a) which attestations are present on the Wallet Unit, b) the status of these attestations, c) the

value of attributes in these attestations, and d) the contents of the Wallet Unit log meant in DASH_02.

WIAM_12bSHALL

If the contents of a Wallet Unit specified in WIAM_12a are stored in a Wallet Instance on the User's device, the Wallet Instance SHALL ensure that the Wallet Provider cannot access the contents of the Wallet Unit.

WIAM_12cSHALL

If the contents of a Wallet Unit specified in WIAM_12a are stored in a Wallet Unit Service on the Wallet Provider backend, the Wallet Provider SHALL specify and implement strict controls to limit access by the Wallet Provider to the contents of the Wallet Unit.

Note: In this situation, the Wallet Unit cannot fully prevent the Wallet Provider from accessing the Wallet Unit contents.

WIAM_13SHALL

A Wallet Unit SHALL enable the User to 'factory reset' the Wallet Unit, which SHALL cause the deletion of all attestations, the log, and all other personal data, settings, and configurations from the Wallet Unit. If the User resets the Wallet Unit, the Wallet Instance SHALL request the associated WSCA/WSCD and keystore(s) to delete all cryptographic assets related to the Wallet Unit and to all PIDs and device-bound attestations on the Wallet Unit, if the WSCA/WSCD and the keystore(s) are connected to the User device.

Note: a) The User can use this option, for instance, in preparation to the planned uninstallation of the Wallet Instance. b) Deletion of PID or KA cryptographic assets requires User authentication, as specified in requirement WIAM_14. c) The Wallet Unit does not necessarily inform the Wallet Provider about the factory reset. d) It may happen there is no connection to the WSCA/WSCD or to a keystore at the moment the User resets the Wallet Instance. For instance, in case the WSCA/WSCD is an external smart card and the User does not present that card to the User device. Another example occurs when the WSCA/WSCD is a remote HSM and the User device is offline at that moment. In such cases, the cryptographic assets will remain present on the WSCA/WSCD or on the keystore, even though they will never be used again. If needed, it is up to the Wallet Provider to define how the Wallet Unit should handle such situations. For example, an HSM manager could address such cases by deciding to delete cryptographic keys in the HSM that are too old or haven't been used for too long, while being aware of the risks in doing so.

WIAM_13aSHALL

If the User resets the Wallet Unit, the Wallet Unit SHALL disclose the fact that it no longer stores any previously disclosed PID(s) or attestation(s) to the Digital Credentials API framework.

WIAM_14SHALL

A WSCA/WSCD managing the critical assets of a PID, such as private or secret cryptographic keys, SHALL authenticate the User at Level of Assurance High before performing any cryptographic operation involving any of these assets.

Note: a) CIR 2024/2981, Annex IV, section 2 (3) states "As a prerequisite to the certification under national certification schemes, the WSCD shall be assessed against the requirements of assurance level high as set out in Implementing Regulation (EU) 2015/1502." Therefore, a WSCA/WSCD by legal definition complies with requirements of LoA High. b) Note to WIAM_14 - WIAM_14b: Many actions of the Wallet Unit, such as processing a Relying Party presentation request and presenting an attestation, require multiple cryptographic operations, for example ephemeral key generation followed by key agreement and presentation signing and encryption. These requirements does not imply that a separate User authentication is necessary before each of these operations. Rather, a successful User authentication will be valid for all cryptographic operations necessary for a Wallet Unit action. It is up to the Wallet Provider to determine what constitutes a 'Wallet Unit action', finding a balance between security (more User authentications) and User convenience (fewer User authentications). During certification of the Wallet Solution, it will be verified that the solution provides an adequate level of security.

WIAM_14aSHALL

A WSCA/WSCD managing the critical assets of a KA SHALL authenticate the User at Level of Assurance High before performing any cryptographic operation involving any of these assets.

Note: The WSCA/WSCD manages the private key(s) corresponding to the public key(s) attested in the KA.

WIAM_14bSHALL

A WSCA/WSCD managing the cryptographic assets of an attestation having a level of security High SHALL authenticate the User at level of security High before performing any cryptographic operation involving any of these assets.

Note: a) The term 'Level of Assurance', as used in the European Digital Identity Regulation and in Implementing Regulation (EU) 2015/1502, is only applicable to electronic identity means, which in the context of the EUDI Wallet means only the PID. For that reason, this requirement uses the

term 'level of security'. Levels of security are defined in standards or specifications different from CIR 2015/1502, for instance ISO/IEC 18045. b) During issuance of an attestation, the Attestation Provider in its Credential Issuer metadata indicates the level of security it requires for the key storage and user authentication for this type of attestation. See OpenID4VCI section 12.2.4 and Appendix D.2.

WIAM_14cSHALL

A Wallet Unit SHALL use either the WSCA/WSCD or a keystore to manage any cryptographic assets that are not considered to be critical assets.

Note: a) The ARF uses the term 'keystore' to refer to a hardware-backed repository and service in which non-critical cryptographic assets are generated, stored, and used exclusively inside a dedicated hardware security boundary. b) Examples of non-critical cryptographic assets are private and secret keys of attestations having a level of security lower than High. c) As mentioned in WIAM_14 and WIAM_14b, the private and secret keys of PIDs and KAs are critical assets and therefore are stored in a WSCA/WSCD.

WIAM_15SHALL

Before performing any operation, including allowing a User to view attestations and attribute values, a Wallet Instance SHALL securely authenticate the User using a multi-factor authentication mechanism provided by the User device.

Note: a) One of the authentication factors is the possession of the User device.

WIAM_15aSHALL

For the purpose of WIAM_15, the Wallet Instance SHALL enforce the activation of an OS-level User authentication mechanism with adequate security policies.

Note: Adequate' here means adequate for any operation excluding the issuance or presentation of PIDs, KAs, and potentially other attestations at level of security High. This includes but is not limited to generating pseudonyms, accessing the transaction log (dashboard), data export and migration, requesting the erasure of personal data by a Relying Party, and reporting a Relying Party to a DPA.

WIAM_15bSHALL

The Wallet Unit SHALL enable the User to use a Wallet Unit-specific authentication method for User authentication, in addition to the User authentication mechanism provided by the User device per WIAM_15. The Wallet Provider SHALL either make the use of this additional

authentication method mandatory for all Users, or leave it to each User to decide if they want to use it.

Note: a) This authentication method may be implemented by the Wallet Instance, a (local) keystore, the WSCA/WSCD, or any other component of the Wallet Unit. b) As an optimisation to reduce the number of User authentication events, the Wallet Provider can choose to implement this additional authentication method in the WSCA/WSCD, in such a way that it complies with WIAM_14.

WIAM_15cSHALL

The Wallet Instance SHALL also use the User authentication mechanism provided by the User device (WIAM_15) and possibly the Wallet Unit-specific authentication method (WIAM_15b) to unlock the keystore mentioned in WIAM_14c, where applicable.

Note: Apart from using the same mechanism, the intent of this requirement is also to minimize the number of User authentications needed (after the initial authentication per WIAM_15a) to enable the issuance or presentation of (non-PID) attestations. However, see WIAM_16 and WIAM_16a: the Wallet Provider may request another authentication if this is necessary for security.

WIAM_16SHALL

For the User authentication mechanism provided by the User device (WIAM_15), the Wallet Instance SHALL force the User device to enable a time-based control (e.g., a session timeout or re-authentication interval), to ensure that access is automatically revoked after a defined period of inactivity.

Note: It is assumed that re-authentication is required by the User device when the device is locked by the User.

WIAM_16aSHALL

For the Wallet Unit-specific User authentication method (WIAM_15b), the Wallet Provider SHALL define and implement conditions after which user authentication shall again be required, including at least an idle timeout. The Wallet Unit SHOULD provide the User with the option to set the idle timeout to a duration shorter than the default timeout set by the Wallet Provider. The Wallet Provider SHOULD also consider other factors, including the device being locked by the User and the Wallet Instance losing focus.

WIAM_17SHALL

The Wallet Provider SHALL ensure that the Wallet Unit requests the User, during activation of the Wallet Unit, to set up the authentication factors for the User authentication mechanism implemented by the WSCA/WSCD meant in WIAM_14, the authentication mechanism implemented by the User device meant in WIAM_15 and WIAM_15a, and, if used, the Wallet Unit-specific authentication method meant in WIAM_15b.

WIAM_18

Empty

WIAM_19SHALL

A WSCA/WSCD and a keystore SHALL be able to prove possession of the private key corresponding to a public key on request of a Wallet Instance, for example by signing a challenge with that private key.

WIAM_20SHALL

A WSCA/WSCD SHALL protect a private key it generated during the entire lifetime of the key. This protection SHALL at least imply that the WSCA/WSCD prevents the private key from being extracted in the clear. If a WSCA/WSCD is able to export a private key in encrypted format, the resulting level of protection SHALL be equivalent to the protection level of the private key when stored in the WSCA/WSCD.

WIAM_21SHOULD

Whenever the WSCA/WSCD successfully authenticated the User, the Wallet Unit SHOULD check if the WSCD contains cryptographic assets for technical PIDs or attestations that cannot be presented any longer to Relying Parties, for example because they have expired or because a once-only attestation (see Topic 10, section D, method A) was presented to a Relying Party already. The Wallet Unit SHOULD then request the WSCA/WSCD to destroy all cryptographic assets related to these technical PIDs or attestations. However, the Wallet Unit SHOULD NOT request the destruction of the private key belonging to the last technical PID or attestation corresponding to a logical PID or attestation.

Note: a) The reason for this recommendation is that probably, Wallet Providers will want to prevent an accumulation of unused private keys in the WSCA/WSCD, given that such devices typically do not have much storage space. However, deletion of private keys (and potentially other cryptographic assets) is a cryptographic key operation and cannot be done without User authentication - see WIAM_14. At the same time, for usability reasons the User must not be involved in such 'cleaning up' processes, see also ISSU_42. The recommended solution is to take

advantage of a User authentication event to also carry out any necessary cleaning operations. b) Method A (once-only attestations, see ISSU_ 37) includes a potential fallback to Method B (limited-time attestations) in case no unused technical PIDs or attestations are left. To ensure that falling back to Method B is always possible when needed, a Wallet Unit should ensure that for every logical PID or attestation it has, it is always in possession of at least one technical PID or attestation.

A.2.3.24 Topic 42 - Requirements for QTSPs to access Authentic Sources

QTSPAS_01SHALL

In accordance with ETSI TS 119 478 and Technical Specification 11, Member States SHALL define: - discovery mechanisms that enable QTSPs to request information about Authentic Sources or designated intermediaries recognised at the national level. This includes information regarding the attributes of a natural or legal person for which the Authentic Source or designated intermediary is considered a primary source, or for which it is recognised as authentic in accordance with Union law or national law, including administrative practices. - procedures for QTSPs to request the verification of attributes from Authentic Sources.

QTSPAS_02SHALL

An Authentic Source in the public sector, or its designated intermediary, SHALL implement an interface complying with ETSI TS 119 478 and Technical Specification 11 for receiving verification requests and sending responses. For each received request, the Authentic Source SHALL - identify and authenticate the requestor in such a way that it can subsequently determine whether the requestor is a QTSP issuing qualified electronic attestation of attributes, for example by means of a lookup in the QTSP Trusted List. - authenticate the User and obtain their approval, if it is legally obliged to do so, in addition to the User authentication and approval already performed by the QTSP according to QTSPAS_08. - verify whether the attribute values claimed by the QTSP match the values held by the Authentic Source and, finally, - respond with one of the following for each attribute: +'match', if the attribute value held for this User by the Authentic Source is identical to the value claimed by the QTSP, + 'no match', if the attribute value held for this User by the Authentic Source is not identical to the value claimed by the QTSP, including if the Authentic Source is the authentic source for this attribute but does not hold a value for this User, +'unknown', if the Authentic Source is not the authentic source for this attribute.

QTSPAS_03SHALL

An Authentic Source or designated intermediary SHALL respond to a verification request for

attributes by any QTSP issuing qualified electronic attestation of attributes.

QTSPAS_04SHALL

An Authentic Source or designated intermediary SHALL implement the technical specifications mentioned in QTSPAS_01, so that the QTSP will receive the result of the verification of the requested attributes as described in QTSPAS_02. If the verification is deferred, the response to the QTSP SHALL include the maximum time that it will take to verify the requested attributes, and a unique identifier that the QTSP SHALL use to obtain the result of the verification.

QTSPAS_05SHALL

A QTSP SHALL send an attribute verification request directly to the Authentic Source or designated intermediary recognised at national level, after discovering it using the mechanisms specified the technical specifications mentioned in QTSPAS_01.

QTSPAS_06SHALL

Member States SHALL specify the processes and mechanisms to designate the Authentic Sources or intermediaries recognised at national level in accordance with Union or national law, allowing these Authentic Sources or intermediaries to verify the attributes presented to them by QTSPs.

QTSPAS_07

Empty

QTSPAS_07a

Empty

QTSPAS_08SHALL

A QTSP SHALL obtain approval from the User to verify the authenticity of the attributes, before requesting the verification of those attributes by the relevant Authentic Source or designated intermediary.

A.2.3.25 Topic 43 - Embedded disclosure policies

EDP_01SHALL

A Wallet Unit SHALL enable an Attestation Provider to optionally express an embedded disclosure policy for a QEAA, PuB-EAA, or non-qualified EAA.

Note: The European Digital Identity Regulation does not contain a requirement for PIDs to be able to contain an embedded disclosure policy.

EDP_02SHALL

A Wallet Unit SHALL support embedded disclosure policies implementing the ‘Authorised relying parties only policy’ described in Annex III of Implementing Regulation (EU) 2024/2979 and as specified in ETSI TS 119 472-3. If present, such an embedded disclosure policy SHALL contain a list of duplets, where each duplet consists of an EU-wide unique Relying Party identifier in combination with a Service identifier, as specified in Reg_32 and Reg_33. After receiving a presentation request, the Wallet Unit SHALL retrieve the unique identifier and Service identifier of the Relying Party from the registration certificate presented by the Relying Party, and compare them to the list of authorised identifier duplets in the policy for the requested attestation. If the identifier duplet is not included in this list, the Wallet Unit SHALL consider the evaluation of the embedded disclosure policy to have failed, and inform the User.

Note: The Wallet Unit uses the Relying Party identifier and Service identifier in the registration certificate, not the identifiers in the access certificate. This is because if the Relying Party uses the services of an intermediary, the identifiers in the access certificate refer to the intermediary rather than the intermediated Relying Party. The intermediary is not relevant for the purposes of an EDP.

EDP_03SHALL

A Wallet Unit SHALL support embedded disclosure policies implementing the ‘Specific root of trust’ policy described in Annex III of Implementing Regulation (EU) 2024/2979 and as specified in ETSI TS 119 472-3. If present, such an embedded disclosure policy SHALL contain a list of root or intermediate certificates used for signing Relying Party registration certificates. After receiving a presentation request, the Wallet Unit SHALL compare all certificates in the certificate chain that was used to sign the registration certificate provided by the Relying Party to the list of authorised root or intermediate certificates in the policy for the requested attestation. If none of these certificates are included in this list, the Wallet Unit SHALL consider the evaluation of the embedded disclosure policy to have failed, and inform the User.

Note: See EDP_02 for why the Wallet Unit uses the certificate chain of the registration certificate rather than the one of the access certificate.

EDP_04

Empty

EDP_05SHALL

An embedded disclosure policy SHOULD contain a link to a website of the Attestation Provider explaining the disclosure policy in layman's terms. If this is the case, the Wallet Unit SHALL display the link to the User and allow them to navigate to that website.

EDP_06SHALL

The Wallet Unit SHALL evaluate an embedded disclosure policy in conjunction with the information received from the requesting Relying Party in the registration certificate, in order to determine if the Relying Party has permission from the Attestation Provider to access the requested attestation. The Wallet Unit SHALL perform this evaluation in compliance with the evaluation rules established in ETSI TS 119 472-3.

EDP_07SHALL

The Wallet Unit SHALL enable the User, based on the outcome of the evaluation of the applicable embedded disclosure policy(s), to deny or allow the presentation of the requested attestation to the Relying Party.

EDP_08SHALL

The format of an embedded disclosure policy SHALL comply with ETSI TS 119 472-3.

EDP_09SHALL

An Attestation Provider SHALL include an embedded disclosure policy (if any) by value in the Issuer metadata related to the attestation, in compliance with OpenID4VCI and ETSI TS 119 472-3.

EDP_10SHALL

During attestation issuance, a Wallet Unit SHALL retrieve and store the corresponding embedded disclosure policy, if any.

Note: The intent of this requirement is that the Wallet Unit is able to evaluate an EDP during a presentation transaction, without needing to request it again from the Attestation Provider. This is necessary in particular during proximity presentations, which must be able to be done without an internet connection.

EDP_11SHALL

An Attestation Provider SHALL revoke an attestation if a corresponding embedded disclosure policy is added, changed, or deleted.

A.2.3.26 Topic 44 - Registration certificates for PID Providers, Providers of QEAAs, PuB-EAAs, and non-qualified EAAs, and Relying Parties

A. Generic requirements on the specification and contents of registration certificates

RPRC_01SHALL

Providers of registration certificates SHALL comply with all relevant requirements in ETSI TS 119 475.

RPRC_01aSHALL

A Provider of registration certificates SHALL be able to revoke a registration certificate, if it has a validity period of longer than 24 hours, in accordance with the applicable requirements in ETSI TS 119 475.

RPRC_01bSHALL

A Provider of registration certificates SHALL have a policy specifying under which conditions a registration certificate it issued will be revoked.

RPRC_02SHALL

When signing a registration certificate, the Provider of registration certificates SHALL include the signing certificate and, if present, any intermediate certificate(s) leading up to the corresponding trust anchor of the Provider in the LoTE, in the `x5c` parameter in the JOSE header of the registration certificate.

RPRC_02aSHALL

For the verification of the registration certificates of Relying Parties, a Wallet Unit SHALL accept all trust anchors of Providers of registration certificates, as published by the Commission in the relevant LoTE, and only those.

RPRC_03SHALL

The contents of a registration certificate SHALL include at least the information required in Annex V of the CIR 2025/848 regarding registration of wallet-relying parties.

RPRC_04SHALL

If the subject of the registration certificate uses the services of an intermediary (see Topic 52), the 'association to the intermediary' mentioned in Annex I (15) of CIR 2025/848 (and referenced in Annex V, point 3(j) of that CIR) SHALL consist of the unique identifier of this intermediary, as meant in requirement Reg_32 and the intermediary's Relying Party Service identifier as meant in Reg_33.

Note: a) These identifiers are identical to those in the access certificate of the intermediary. b) The association is also included in the respective access certificate of the intermediary, see Reg_34a.

RPRC_04aSHALL

The registration certificate format SHALL provide for the data elements to carry the Relying Party Service identifier mentioned in Reg_33 and the Relying Party Service trade name mentioned in Reg_34.

RPRC_05SHALL

If the subject of the registration certificate is not a Relying Party (i.e. in the terms of CIR 2025/848, a Service Provider), the certificate SHALL NOT contain the intended use as meant in Annex I (9) and (10) of CIR 2025/848.

Note: A PID Provider or Attestation Provider may request attributes from the Wallet Unit during issuance, for example to identify and authenticate the User. If so, it registers as both a Service Provider and an Attestation Provider, and consequently its registration certificate contains its intended use.

RPRC_06SHALL

The contents of a registration certificate SHALL include a trade name for the subject of the certificate, in a format suitable for presenting to a User, which SHALL be identical to the trade name in the access certificates of the entity, see Reg_31.

RPRC_07SHALL

The contents of a registration certificate SHALL include an EU-wide unique identifier for the subject of the certificate, which SHALL be identical to the identifier in the access certificates of that entity, see Reg_32.

Note: a) A Wallet Unit needs an identifier for a Relying Party at least to allow the User to send a report of suspicious Relying Party presentation requests to a data protection authority according to Topic 50.

RPRC_07aSHALL

The contents of a registration certificate SHALL contain an identifier and a trade name for the Relying Party Service, which SHALL be identical to the Service identifier and trade name in one or more of the access certificates of that entity, see Reg_33 and Reg_34.

Note: There must be at least one Relying Party Instance or service supply point that is able to use a given registration certificate.

RPRC_08SHALL

The EU-wide unique identifier meant in RPRC_07 SHALL be identical in all registration certificates issued for a given entity.

Note: In case the registration certificates issued to an intermediated Relying Party are held and presented by an intermediary, the entity meant in this requirement is the intermediated Relying Party. An intermediary may obtain and hold registration certificates with a different unique identifier for other intermediated Relying Parties.

B Requirements on the issuance of registration certificates to Relying Parties

RPRC_09SHALL

During the registration process for Relying Parties, as specified in Topic 27, a Provider of registration certificates associated to the Member State Registrar SHALL create and sign or seal a separate registration certificate for each combination of intended use and Relying Party Service, as registered by the Relying Party per Reg_10d, and issue it to the Relying Party. The Provider of registration certificates SHALL do so in an automated manner and without undue delay. Each registration certificate SHALL comply with the requirements in the technical specification mentioned in RPRC_01.

Note: Example clarifying 'each combination of intended use and Relying Party Service': If a Relying Party registers Service A having intended use 1 and 2, Service B having intended uses 2, 3, 4 and 5, and Service C having intended use 4, it would receive seven registration certificates.

RPRC_10SHALL

A Relying Party SHALL distribute the registration certificates it received during registration to its Relying Party Instances. The Relying Party SHALL ensure that the registration certificate(s) sent to a Relying Party Instance contain the same Service identifier as the access certificate of that Relying Party Instance.

Note: It is up to the Relying Party to determine if all of its Relying Party Instances need all of the registration certificates, or that some Relying Party Instances are used only for a subset of the Relying Party's Services, and consequently only need the registration certificates containing the corresponding Service identifiers.

RPRC_11SHALL

The contents of a registration certificate issued to a Relying Party SHALL contain at least one of the following: a) the URL of a web form provided by the Relying Party, which Users can use to send data deletion requests, b) an e-mail address of the Relying Party, on which the Relying Party is prepared to receive data deletion requests from Users, c) a telephone number of the Relying Party, on which the Relying Party is prepared to receive data deletion requests from Users.

Note: See Topic 48 for more information about data deletion requests.

RPRC_12SHALL

The contents of a registration certificate issued to a Relying Party SHALL contain the name and country of the Data Protection Authority supervising the Relying Party. In addition, the registration certificate SHALL contain at least one of the following: a) the URL of a web form provided by the DPA, which Users can use to report suspicious attribute presentation requests. b) an e-mail address of the DPA, on which the DPA is prepared to receive reports about suspicious attribute presentation requests from Users, c) a telephone number of the DPA, on which the DPA is prepared to receive reports about suspicious attribute presentation requests from Users.

Note: See Topic 50 for more information about reporting suspicious attribute presentation requests.

C. Requirements on the issuance of registration certificates to PID Providers and Attestation Providers

RPRC_13SHALL

During the registration process for PID Providers, QEAA Providers, PuB-EAA Provider, or non-qualified EAA Providers, as specified in Topic 27, a Provider of registration certificates associated to the Member State Registrar SHALL create and sign or seal a separate registration certificate for each of the registered Services of the registering entity, and issue it to the registering entity. Each registration certificate SHALL comply with the requirements in the technical specification mentioned in RPRC_01.

RPRC_14SHALL

A PID Provider, QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider SHALL distribute the registration certificates it received during registration to all service supply points having an access certificate containing the same Service identifier.

Note: A service supply point is a system at which a Wallet Unit can start the process of requesting and obtaining a PID or attestation.

RPRC_15SHALL

The contents of a registration certificate issued to a PID Provider, a QEAA Provider, a PuB-EAA Provider, or a non-qualified EAA Provider SHALL contain the type(s) of attestation that the applicable Service of this entity intends to issue to Wallet Units.

D. Requirements on the presentation and verification of registration certificates of Relying Parties

RPRC_16

Empty

RPRC_17SHALL

A Wallet Unit SHALL verify the format, authenticity, and validity of the registration certificate it received from a Relying Party in a presentation request, according to the technical specification meant in RPRC_01. If the certificate is absent, malformed, inauthentic, or expired, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that it could not obtain or validate the information registered about the Relying Party and its Service. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether and under which conditions the Wallet Unit will allow the User to approve the presentation of the requested attributes despite specific failed verifications.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

RPRC_17aSHALL

A Wallet Unit SHALL verify that the registration certificate contains the same unique Relying Party identifier and the same Service identifier as the access certificate in the presentation request. If this is not the case, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that it could not validate the information registered about the Relying Party and its Service. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether and under which conditions the Wallet Unit will allow the User to approve the presentation of the requested attributes despite this failed verification.

Note: a) There are two ways in which a registration certificate can comply with this requirement: either the access certificate and the registration certificate were issued to the same entity, or the access certificate was issued to an intermediary (see Topic 52), and the registration certificate indicates that the intermediated Relying Party uses the services of this intermediary. b) If the registration certificate does not comply with this requirement, a fraudulent entity acting as a Relying Party may be trying to use a registration certificate that was issued to another Relying Party.

RPRC_18

Empty

RPRC_18a

Empty

RPRC_19SHALL

A Relying Party Instance SHALL include a single registration certificate applicable for its current Service and intended use in each presentation request to a Wallet Unit, according to the applicable standard's extension mentioned in RPRC_20. The registration certificate SHALL be included in the request by value, not by reference. The Relying Party Instance SHALL do so both in proximity and remote presentation flows.

Note: a) This ensures that no external requests are necessary to validate the Relying Party. b) A Relying Party Instance may be used for multiple Relying Party Services, provided it has a separate access certificate for each of these Services, see RPA_06 and Reg_10b.

RPRC_19a

Empty

RPRC_20SHALL

Relying Party Instances and Wallet Units SHALL support the extension for ISO/IEC 18013-5 or the extension for OpenID4VP, as applicable. as specified in ETSI TS 119 472-2 and amended by Annex 2 of (the amended) CIR 2024/2982, for transferring a single Relying Party registration certificate from a Relying Party Instance to a Wallet Unit.

RPRC_20a

Empty

RPRC_21SHALL

After receiving a presentation request from a Relying Party, a Wallet Unit SHALL verify that all attributes requested in the request are included in the list of attributes in the registration certificate included in the same request. If the outcome of the verification is negative, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that the Relying Party is requesting more information than it has registered. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether the Wallet Unit must a) enable the User to approve (or reject) the presentation of all requested attributes, including the non-registered ones, b) enable the User to approve (or reject) the presentation of the registered attributes only, or c) reject the presentation of all requested attributes.

Note: This ensures that Wallet Providers comply with the 'general access policy' described in CIR 2025/848.

E. Requirements on the presentation and verification of registration certificates of PID Providers and Attestation Providers

RPRC_22SHALL

A PID Provider or Attestation Provider SHALL include the registration certificate of the applicable Service in its Credential Issuer metadata used in the common OpenID4VCI protocol referenced in ISSU_01 and the extension thereof in ETSI TS 119 472-3. The registration certificate SHALL be included in the metadata by value, not by reference.

Note: This ensures that no external requests are necessary to validate the PID Provider or Attestation Provider, and that issuance transactions are atomic and self-contained.

RPRC_22aSHALL

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify the format, authenticity, and validity of the registration certificate it obtained from a PID Provider's or Attestation Provider's metadata, according to the technical specification meant in RPRC_01. If the certificate is absent, malformed, inauthentic, or expired, the Wallet Unit SHALL warn the User that it could not obtain or validate the information registered about the PID Provider or Attestation Provider, and SHALL NOT request the issuance of a PID or attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

RPRC_22bSHALL

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify that the registration certificate contains the same unique identifier as the access certificate in the PID Provider's or Attestation Provider's metadata. If this is not the case, the Wallet Unit SHALL warn the User that it could not validate the information registered about the PID Provider or Attestation Provider, and SHALL NOT request the issuance of a PID or attestation

Note: a) If the registration certificate does not comply with this requirement, a fraudulent entity acting as a PID Provider or Attestation Provider may be trying to use a registration certificate that was issued to another PID Provider or Attestation Provider. b) The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

RPRC_23SHALL

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify that the type of attestation it wants to request from a PID Provider or Attestation Provider is included in the registration certificate of that Provider. If that is not the case, the Wallet Unit SHALL warn the User that the PID Provider or Attestation Provider is not registered for issuing the desired attestation type, and SHALL NOT request the issuance of a PID or attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

A.2.3.27 Topic 48 - Blueprint for requesting data deletion to Relying Parties

DATA_DLT_01SHALL

A Wallet Unit SHALL support the possibilities mentioned in DATA_DLT_02, allowing a User to request from a Relying Party the erasure of their attributes that were presented by that Wallet Unit to that Relying Party, in accordance with Article 17 of Regulation (EU) 2016/679.

DATA_DLT_02SHALL

A Wallet Unit SHALL support at least the following possibilities to send a data erasure request to a Relying Party: a) Open a URL in an external browser to ask for the deletion of data in a web form provided by the Relying Party, b) Open an external mail client and start a draft e-mail to the Relying Party, with a suitable template text, c) open an external phone client and start a phone call. Depending on whether a Relying Party URL, e-mail address, and/or phone number was logged for the relevant attestation presentation transaction (see requirement DASH_03 in Topic 19), the Wallet Unit SHALL offer the User to use one or more of these possibilities.

DATA_DLT_02a

Empty

DATA_DLT_03SHALL

A Wallet Instance SHALL provide a function where the User may select one Relying Party to which a data deletion request must be submitted.

DATA_DLT_04

Empty

DATA_DLT_05SHALL

A Wallet Unit SHALL include the initiation of a data deletion request in a log, so it can be displayed to the User via the dashboard as specified in Topic 19.

Note: Because the request is sent by an external web browser, e-mail client, or phone client (see DATA_DLT_02), the Wallet Unit can only log the initiation of the request.

DATA_DLT_06SHALL

For the initiation of a data deletion request, the log SHALL contain at least: - Date and time of the initiation of the request, - Name and unique identifier of the Relying Party to which the request was made, - Attributes requested to be deleted.

DATA_DLT_07SHALL

Before executing a data deletion request, a Relying Party SHALL authenticate the requesting User (or the request itself), using appropriate authentication mechanisms of its own choosing. The Relying Party SHOULD use the authentication or signature facilities offered by the User's Wallet Unit for this purpose.

DATA_DLT_08SHALL

Wallet Units, Relying Parties, and Registrars SHALL comply with the relevant requirements in Technical Specification 7.

A.2.3.28 Topic 50 - Blueprint to report unlawful or suspicious request of data

RPT_DPA_01SHALL

A Wallet Unit SHALL enable the User to start the process of reporting a suspicious presentation request to a DPA. When prompted by the User, a Wallet Unit SHALL provide the contact details of the DPA which supervises the Relying Party that made the suspicious request, available in the log for that request (see DASH_03). In addition, the Wallet Unit MAY also provide the contact details of the DPA of the region in which the Wallet Provider is residing, or of other DPAs,

taken from the European Data Protection Board website (https://www.edpb.europa.eu/about-edpb/about-edpb/members_en).

RPT_DPA_02SHALL

The Wallet Unit SHALL offer the User the option to report a suspicious request to a DPA via the transaction log presented in the dashboard, see Topic 19.

RPT_DPA_02aSHALL

A Wallet Unit SHALL support at least the following possibilities to report a suspicious presentation request to a DPA, depending on what contact details are available for the DPA: a) Open a URL in an external browser to report the request in a web form provided by the DPA. b) Open an external e-mail client and start a draft e-mail to the DPA, with a suitable template text, c) open an external phone client and start a phone call.

RPT_DPA_03

Empty

RPT_DPA_04SHALL

A Wallet Provider SHALL ensure that a Wallet Unit allows its User to substantiate a report sent to a DPA, including by attaching relevant information to identify the Relying Party and the Users' claims in a machine-readable format.

Note: The log kept by the Wallet Unit is standardised in Technical Specification 10 and is machine-readable in order to enable data portability. An excerpt from this log therefore can be used to substantiate the report.

RPT_DPA_05SHALL

A Wallet Unit SHALL log the fact that it initiated the sending of a report to a DPA (see RPT_DPA_02a), as specified in Topic 19.

RPT_DPA_05aSHALL

For a report sent to a DPA, the log SHALL contain at least: a) the date and time when the report was sent, b) the name and country of the DPA, and c) the channel and contact information used for initiating sending the report, i.e., the URL, e-mail address, or phone number of the DPA.

RPT_DPA_06SHALL

Wallet Units, Data Protection Authorities, and Registrars SHALL comply with the relevant requirements in Technical Specification 8.

A.2.3.29 Topic 51 - PID or attestation deletion

PAD_01SHALL

A Wallet Unit SHALL at any time enable the User to delete any PID or attestation from their Wallet Unit.

PAD_02SHALL

If the User indicates that a logical PID or attestation must be deleted, and the Wallet Unit contains multiple physical PIDs or attestations corresponding to that logical PID or attestation, a Wallet Unit SHALL delete all of these physical PIDs and attestations simultaneously.

Note: a) This situation may occur if the PID Provider or Attestation Provider issued a batch of physical PIDs or attestations to the Wallet Unit, rather than a single one. b) Physical PIDs or attestations correspond to a logical one if they have not only the same attestation type and Provider, but also the same attribute values. In principle, the same Provider can issue two attestations of the same type to the same Wallet Unit, for example two diplomas from the same university. This corresponds to the notion of a Credential Dataset in OpenID4VCI.

PAD_03SHALL

If the Wallet Unit deletes a PID or attestation on the User's request, the Wallet Unit SHALL NOT notify the respective PID Provider or Attestation Provider.

Note: This is a matter of User privacy.

PAD_04SHALL

If the Wallet Unit deletes a PID or device-bound attestation on the User's request, the Wallet Unit SHALL ensure that all cryptographic assets in the WSCA/WSCD or keystores related to this PID or attestation are securely destroyed.

Note: Key deletion for a PID key is a cryptographic key operation and requires User authentication, as specified in requirement WIAM_14.

PAD_05SHALL

If a Wallet Unit deletes, on the User's request, a PID or attestation previously disclosed to the Digital Credentials API framework, the Wallet Instance SHALL disclose the fact that it no longer stores this PID or attestation to the Digital Credentials API framework.

PAD_06

Empty

A.2.3.30 Topic 52 - Relying Party intermediaries

RPI_01SHALL

An intermediary SHALL register as a Relying Party, in accordance with all requirements in Topic 27, while indicating it intends to act as an intermediary.

Note: a) This implies that an intermediary obtains an access certificate containing its own trade name and unique Relying Party identifier, and Service trade name and identifier. b) An intermediary may also obtain a registration certificate according to Topic 44, but this certificate will not be used for intermediated transactions. c) An entity that registered as an intermediary may also register as a Relying Party in its own capacity. In such a case, it will receive one or more registration certificates for its Services and intended use(s), (see RPRC_09), and will use one of these certificates when interacting with a Wallet Unit.

RPI_02

Empty

RPI_03SHALL

An intermediary SHALL ensure that each intermediated Relying Party that will use its services to interact with Wallet Units, is registered at a Registrar in the Member State where the intermediated Relying Party is established, according all requirements in Topic 44. The intermediary SHALL also ensure that it receives the necessary registration certificates for the intermediated Relying Party, as specified in RPRC_09. Each of these registration certificates SHALL show that the intermediated Relying Party uses the services of the intermediary.

Note: A Registrar is free to design a suitable process to achieve these goals. For example, it may decide an intermediary can register the intermediated Relying Parties at the Registrar, and receive the registration certificates in return. Alternatively, the Registrar could request the intermediated Relying Parties ro register themselves and indicate the intermediary they will be using, in which case they will receive the registration certificates and must send them to the intermediary. Alternative processes can be used as well.

RPI_04SHALL

Before registering the relationship between an intermediary and an intermediated Relying Party and issuing a registration certificate showing that the intermediated Relying Party uses the services of the intermediary, a Registrar SHALL ensure it obtains legally valid evidence that this Relying Party will indeed use the services of this intermediary to interact with Wallet Units.

Note: A Registrar is free to decide which evidence it needs and how it obtains this evidence. For example, the Registrar may require either the intermediary or the intermediated Relying Party to provide a signed copy of the contract between both parties. Alternatively, the Registrar could ask an authorised representative of the Relying Party to sign off on a registration that was done by the intermediary, or could ask for a mandate from the intermediated Relying Party to the intermediary to register the Relying Party.

RPI_05SHALL

When an intermediated Relying Party asks its intermediary to request some attributes from a Wallet Unit, it SHALL indicate which single registration certificate the intermediary must include in the presentation request.

RPI_06SHALL

When requested by an intermediated Relying Party, an intermediary SHALL request a presentation of attributes from a specific Wallet Unit. In the request, the intermediary SHALL include the applicable intermediary's access certificate meant in requirement RPI_01 and the registration certificate of the Relying Party, indicated per RPI_05.

Note: The applicable access certificate contains the association to this specific intermediated Relying Party, see Reg_34a.

RPI_06a

Empty

RPI_07SHALL

In case a Wallet Unit receives a presentation request from an intermediary on behalf of an intermediated Relying Party, it SHALL NOT display the trade names of the intermediary and the intermediary Service to the User when asking for User approval, as described in RPA_07.

RPI_07a

Empty

RPI_07b

Empty

RPI_08SHALL

When a Wallet Unit presents to an intermediary any User attributes from a PID or attestation, the intermediary SHALL, after successfully carrying out the verifications in RPI_09, forward

these attributes only to the Relying Party on behalf of which the presentation request was made. If any of the verifications in RPI_09 fail, the intermediary SHALL NOT forward any attributes to the Relying Party, nor to any other entity.

RPI_09SHALL

When a Wallet Unit presents to an intermediary any attributes from a PID or attestation, the intermediary SHALL verify the authenticity of the PID or attestation, its revocation status, device binding and User binding, as well as any combined presentation of attributes, if applicable, as specified in this ARF and if agreed with the Relying Party.

Note: The ARF does not mandate that a Relying Party must carry out all of these verifications. Therefore, the intermediary and any Relying Party using its services must agree on what verifications the intermediary will carry out.

RPI_10SHALL

The intermediary SHALL delete any PIDs or attestations it obtained from the Wallet Unit, including any User attributes, completely and immediately after it has sent the User attributes to the intermediated Relying Party. If the intermediary does not send any User attributes to the intermediated Relying Party, for example because one of the verifications in RPI_09 failed, the intermediary SHALL delete the PIDs or attestations completely and immediately as soon as it has completed all necessary verifications.

A.2.3.31 Topic 53 - Zero-Knowledge Proofs

ZKP_01SHALL

A ZKP scheme SHALL provide support for the following generic functions, while hiding all attributes of PIDs or attestations: (i) generation of a proof that an (some) attribute(s) having a specific value is (are) included in a PID or attestation, (ii) generation of a proof that a PID or attestation is within its validity period, (iii) generation of a proof that a PID or attestation has not been revoked, and (iv) generation of a proof that a PID or device-bound attestation is bound to a key stored in the WSCA/WSCD or in a keystore of the Wallet Unit. Additionally, a ZKP scheme SHOULD provide support for the following function, which SHOULD be used only when hiding the PID Provider or Attestation Provider is necessary: (v) generation of a proof that a PID or attestation has been issued by a trusted PID Provider or Attestation Provider, without revealing the PID Provider or Attestation Provider.

Note: See section 4.1.1 of the Discussion Paper for Topic G.

ZKP_02SHALL

A ZKP scheme SHALL support proving possession of attestation of a given type.

Note: See section 4.1.2 and 4.1.3 of the Discussion Paper for Topic G.

ZKP_03SHALL

A ZKP scheme SHOULD support the privacy-preserving binding of an attestation to a PID. In addition to the generic functions defined in ZKP_01, for this use case, a ZKP scheme SHALL provide support for the following functions: (i) generation of a proof that the Wallet Unit stores an attestation and a PID and that the attestation includes a specific attribute, having a specific value, which is also present in the PID.

Note: See section 4.1.4 of the Discussion Paper for Topic G.

ZKP_04SHALL

A ZKP scheme SHOULD support the derivation of a verifiable User pseudonym, by combining an attribute value that is unique for the User with Relying Party-specific context (e.g., the Relying Party identifier) In addition to the generic functions defined in ZKP_01, for this use case, a ZKP scheme SHALL provide support for the following functions: (i) generation of a request for the issuance of an attestation that includes a secret attribute unique to the User, without revealing this attribute to the Attestation Provider, (ii) generation of an attestation presentation that includes a verifiable pseudonym derived from the secret attribute, a Relying Party identifier, and context-related information.

Note: See section 4.1.5 of the Discussion Paper for Topic G.

ZKP_05SHALL

A ZKP scheme SHALL be usable in both remote and proximity presentation flows. While the inclusion of ZKP will introduce computational and verification delays, these delays SHALL NOT critically undermine or defeat the purpose of the Relying Party service (e.g. because of a critical impact on the User experience of the Wallet Unit).

ZKP_06SHOULD

A ZKP scheme SHOULD be able to generate proofs for already issued PIDs and attestations in the formats specified in ISO/IEC 18013-5 or SD-JWT VC.

ZKP_07SHALL

A ZKP scheme SHALL NOT introduce any additional communication or information that could be used to track or link User activity during, before, or after proof generation.

ZKP_08SHALL

A ZKP scheme SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

ZKP_09SHALL

Use of a ZKP scheme SHALL NOT prevent the Wallet Unit's ability to provide User authentication with Level of Assurance High.

A.2.3.32 Topic 54 - Accessibility

ACC_01SHALL

Wallet Providers SHALL ensure that their Wallet Units comply with applicable requirements and standards in Directive 2016/2012 on the accessibility of websites and mobile applications of public sector bodies.

Note: Compliance with the European Standard ETSI EN 301 549 V1.1.2 (2015-04) provides a presumption of conformity to the Accessibility Directive.

ACC_02SHALL

Wallet Providers SHALL ensure that their Wallet Units comply with accessibility requirements for products and services established under Directive (EU) 2019/882.

Note: Compliance with the European Standard ETSI EN 301 549 V1.1.2 (2015-04) potentially provides a presumption of conformity to this Directive.

A.2.3.33 Topic 55 - Certificate Transparency

CT_01SHALL

An Access CA issuing access certificates SHALL register these in a CT log according to RFC 9162, if such a log is available for access certificates.

CT_02SHALL

An Access CA issuing access certificates SHALL describe in its CPS how it logs all access certificates.

CT_03SHALL

In case a CT log provider for access certificates is available, all Access CAs SHALL act as monitors in the CT ecosystem. Access CAs SHOULD still monitor the CT logs in situations of temporary unavailability.

CT_04SHALL

An Access CA SHALL include at least one Signed Certificate Timestamp (SCT) in each access certificate.

CT_05SHALL

When verifying an access certificate during PID or attestation issuance or presentation, a Wallet Unit SHALL also verify that the access certificate includes at least one valid Signed Certificate Timestamp (SCT).

CT_06SHALL

If an access certificate does not include a valid SCT, a Wallet Unit SHALL handle this as a failure or Relying Party authentication, in compliance with all requirements in Topic 6] and in particular requirement RPA_06a.

A.2.3.34 Topic 56 - Wallet Provider Support and Maintenance

WPSM_01SHALL

A Wallet Provider SHALL monitor their installed base of operational Wallet Instances for maintenance purposes, and determine and document in a transparent manner the data it needs and is allowed to monitor in order to deliver the required support. Data or attributes that SHOULD be monitored include: 1) Runtime errors, for uncaught errors in production code, 2) UX and telemetry information, for UX field analysis, 3) OS version and health information, for detection of OS level vulnerabilities, 4) Wallet Instance SDK and software library version information, for Wallet Instance code vulnerabilities, 5) User locale/localisation data, for catching localisation related errors, 6) Wallet Instance version, for catching errors or vulnerabilities due to outdated versions, 7) Supported WSCA/WSCDs and keystores and their supported capabilities, for detection of cryptography incompatibilities, 8) Unique device identifier such as IDFV or persisted UUID (iOS) or AndroidID (Android), for maintaining an up-to-date list of Wallet Instance-related device installations and for detecting potential malicious use (unrecognised identifier), 9) Device sensor identifiers and patch levels, for checking if sensor hardware in the device is up-to-date. 10) hardware-level details about the device, to identify known hardware-based problems or vulnerabilities, 11) BLE and NFC support by device, for analysing the security and feasibility of proximity use cases with a given Wallet Instance.

WPSM_02SHALL

Wallet Providers SHALL, for maintenance purposes, write custom crash logs for sending them for further analysis.

WPSM_03SHALL

A Wallet Provider SHALL monitor the security posture of its operational Wallet Instances for the purpose of detecting critical security risks in the environment the Wallet Instance is run at, and determine and document in a transparent manner the data it needs and is allowed to monitor. Information that SHOULD be monitored for software and hardware level problems/vulnerabilities on device includes 1) detection of device rooting/jailbreaking, 2) emulator detection, 3) device OS version and health data, 4) Wallet Instance SDK and SW library versions, 5) Wallet Instance version, 6) Supported WSCA/WSCD and keystore(s) and 7) Sensor identifiers and patch levels.

WPSM_04SHALL

During the lifetime of the Wallet Unit, the Wallet Provider SHALL update the Wallet Unit as necessary to ensure its continued security and functionality.

ANNEX 2.03 - High-Level Requirements by category

A.2 High-level requirements by category

A.2.1 Introduction

This annex to the ARF main document includes high-level requirements (HLRs) related to the EUDI Wallet ecosystem. The requirements define the responsible actor that should implement each requirement. There are no requirements imposed on the Users. All requirements in this Annex only apply in the context of the EUDI Wallet ecosystem.

This Annex uses the capitalised key words ‘SHALL’, ‘SHOULD’ and ‘MAY’ as specified in RFC 2119, i.e., to indicate requirements, recommendations and options specified in this annex.

In addition, ‘must’ (non-capitalised) is used to indicate an external constraint, i.e., a requirement that is not mandated by this document, but, for instance, by an external standard or specification. The word ‘can’ indicates a capability, whereas other words, such as ‘will’, and ‘is’ or ‘are’, are intended as statements of fact. Each requirement is anchorable via its identifier, e.g. #WP_01.

Part 1: Actor-Specific Requirements

1. Wallet Providers

These requirements are the responsibility of the entities building and managing the EUDI Wallet solutions. They cover the core functionalities, security, user interface elements, and lifecycle management of the wallet.

AS-WP-06-001SHALL

Legacy ID: RPA_01 {: .eudi-hlr__meta }

The Wallet Unit used by a User, as well as the Relying Party Instance used by the Relying Party, SHALL implement a mechanism for Relying Party authentication in PID or attestation presentation transactions. This mechanism SHALL: - enable the Wallet Unit to identify and authenticate the Relying Party, - enable the Wallet Unit to verify that the request from the Relying Party was not copied and replayed, - use an access certificate issued in accordance with Topic 27].

Note: Wallet Units and Relying Parties comply with this requirement if they comply with the requirements in this Topic.

AS-WP-06-002SHALL

Legacy ID: RPA_01a {: .eudi-hlr__meta }

A Wallet Unit SHALL retain full authority over the process meant in RPA_01. In particular, this process SHALL NOT be handled by a third party, including the browser and the operating system.

Note: This requirement applies, in particular, in the context of the W3C Digital Credentials API.

AS-WP-06-003SHALL

Legacy ID: RPA_02 {: .eudi-hlr__meta }

For performing Relying Party authentication, Wallet Units and Relying Party Instances SHALL support access certificates as specified in ETSI TS 119 475 and ETSI TS 119 411-8.

Note: In ISO/IEC 18013-5, the Relying Party authentication mechanism is called mdoc reader authentication and uses an X.509 certificate. For OpenID4VP, HAIP specifies that Client Identifier Prefix `x509_hash` must be used to authenticate the Relying Party. This mechanism also uses an X.509 certificate.

AS-WP-06-004SHALL

Legacy ID: RPA_03 {: .eudi-hlr__meta }

A Wallet Unit and a Relying Party Instance SHALL perform Relying Party authentication in all PID or attestation presentation transactions to Relying Parties, whether proximity or remote, using an access certificate.

Note: The actions both entities perform differ. For example, while the Relying Party creates a signature over some data in the request, the Wallet Unit validates that signature.

AS-WP-06-005SHALL

Legacy ID: RPA_04 {: .eudi-hlr__meta }

For the verification of access certificates, a Wallet Unit SHALL accept only the trust anchors in the LoTE(s) of all Access Certificate Authorities notified by Member States.

Note: For more information about Access Certificate Authorities, please see Topic 31].

AS-WP-06-006SHALL

Legacy ID: RPA_05 {: .eudi-hlr__meta }

If Relying Party authentication fails for any reason, the Wallet Instance SHALL inform the User that the identity of the Relying Party could not be verified and that therefore the request is not trustworthy.

AS-WP-06-007SHALL

Legacy ID: RPA_06 {: .eudi-hlr__meta }

If Relying Party authentication succeeds, the Wallet Instance SHALL display to the User the trade names of the Relying Party and its Service, as included in the access certificate received from the Relying Party Instance, together with the attributes requested by the Relying Party. The Wallet Instance SHALL do so when asking the User for approval according to RPA_07.

Note: a) A Relying Party Instance may be used for multiple Relying Party Services, provided it has received a separate access certificate for each, see Reg_10a. b) If the authenticated Relying Party is an intermediary acting on behalf of an intermediated Relying Party, the Wallet Instance does not display the trade names of the intermediary and its Service, but only those of the intermediated Relying Party; see RPI_07.

AS-WP-06-008SHALL

Legacy ID: RPA_06a {: .eudi-hlr__meta }

If Relying Party authentication fails for any reason, the Wallet Unit SHALL notify the User. In addition, the Wallet Unit SHALL either not present the requested attributes to the Relying Party, or give the User the choice to present the requested attributes or not.

Note: It is up to the Wallet Provider to make a choice for one of these two options.

AS-WP-06-009SHALL

Legacy ID: RPA_07 {: .eudi-hlr__meta }

A Wallet Unit SHALL ensure the User approved the presentation of any attribute(s) in the Wallet Unit to a Relying Party or Verifier Wallet Unit, prior to presenting these attributes. A Wallet Unit SHALL always allow the User to refuse presenting an attribute requested by the Relying Party or Verifier Wallet Unit.

AS-WP-06-010SHALL

Legacy ID: RPA_07a {: .eudi-hlr__meta }

A Wallet Unit SHALL retain full authority over the process meant in RPA_07, RPA_07b, and RPA_07c. In particular, this process SHALL NOT be handled by a third party, including the browser and the operating system.

Note: This requirement applies, in particular, in the context of the W3C Digital Credentials API.

AS-WP-06-011SHALL

Legacy ID: RPA_07b {: .eudi-hlr__meta }

In addition to RPA_07, in case the Wallet Unit warns the User about failed verifications regarding the Relying Party's access certificate or registration certificate, the Wallet Unit SHALL ensure that User approval is explicit. Silence or pre-ticked boxes SHALL NOT suffice.

AS-WP-06-012SHALL

Legacy ID: RPA_07c {: .eudi-hlr__meta }

In addition to RPA_07, in case a Relying Party requests the presentation of the portrait in a PID (see PID Rulebook), the Wallet Unit SHALL warn the User that the request involves the presentation of biometric data. The Wallet Unit SHALL ensure that User approval for presenting the portrait is explicit. Silence or a pre-ticked box SHALL NOT suffice.

AS-WP-06-013SHALL

Legacy ID: RPA_08 {: .eudi-hlr__meta }

A Wallet Unit SHALL authenticate the User before allowing the User to give or refuse approval for releasing any attributes, in accordance with WIAM_14 or WIAM_15, as applicable.

AS-WP-06-014

Legacy ID: RPA_09 {: .eudi-hlr__meta }

Empty

AS-WP-06-015SHALL

Legacy ID: RPA_10 {: .eudi-hlr__meta }

When asking for User approval, the Wallet Unit SHALL show to the User the User-friendly description of the Relying Party's intended use and the link to the applicable privacy policy.

Note: The User-friendly description of the Relying Party's intended use is included in the registration certificate. The link to the privacy policy is also included in the registration certificate. See Topic 44 for details.

AS-WP-06-016SHOULD

Legacy ID: RPA_10a {: .eudi-hlr__meta }

The Wallet Unit SHOULD ensure that the User gives approval either to present all attributes requested in a presentation request, or none of them.

Note: This means that a User should be asked either to approve the presentation of all requested attributes or to deny all of them. The Wallet Unit should not allow partial approval, since this would mean that the Relying Party cannot deliver the service, but nevertheless receives some User attributes. This would be a violation of the User's privacy. Note that a Relying Party is not allowed to request more data than is justified for the intended use. So if the User feels that the Relying Party is actually requesting more data than needed, that implies that the Relying Party is not trustworthy and should not receive any data.

AS-WP-06-017SHALL

Legacy ID: RPA_11 {: .eudi-hlr__meta }

When the presentation of an attestation or a PID is denied by the User, the Wallet Unit SHALL behave towards the Relying Party as if the attestation or PID did not exist.

AS-WP-06-018MAY

Legacy ID: RPA_12 {: .eudi-hlr__meta }

When asking for User approval, the Wallet Unit MAY indicate to the User whether the attestation requested by a Relying Party is device-bound or not.

Note: The intent of this indication is to warn the User that a non-device-bound attestation may be copied by the Relying Party and presented to a third party.

AS-WP-09-001SHALL

Legacy ID: WUA_01 {: .eudi-hlr__meta }

A Key Attestation SHALL contain information about the certification of the WSCA/WSCD or a keystore available to the Wallet Unit, and SHALL comply with the relevant requirements in Technical Specification 3.

Note: A PID Provider or Attestation Provider can use this information to take a well-grounded decision on whether to issue a PID or attestation to the Wallet Unit.

AS-WP-09-002SHALL

Legacy ID: WUA_02 {: .eudi-hlr__meta }

A Key Attestation SHALL enable PID Providers and Attestation Providers to verify the authenticity of a WSCD or keystore and to check whether the WSCD or keystore has been revoked.

Note: A KA carries a revocation reference that is valid for the WSCD or keystore of the Wallet Unit. How this revocation reference is managed (individually or per type of WSCD/keystore) depends on the approach chosen by the Wallet Provider (see WUA_28), but this is not relevant for the PID Provider or Attestation Provider that receives the KA.

AS-WP-09-003SHALL

Legacy ID: WUA_03 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that a non-revoked Wallet Unit at all times can present a temporally valid and non-revoked KA to a PID Provider or Attestation Provider during the issuance process of a PID or device-bound attestation.

Note: a) Revocation refers to the attested WSCD/keystore, not to the KA itself. b) For example, the Wallet Provider could pro-actively issue new KAs to the Wallet Unit, so that the Wallet Unit is always in possession of a valid KA. Alternatively, the Wallet Provider could ensure that whenever the User opens the Wallet Unit, it checks whether it is possession of a valid KA, and requests the Wallet Provider to issue a new KA if needed. A third possibility is that the Wallet Unit does this check only when it starts the process of requesting the (re-)issuance of a PID or attestation. Other alternatives to comply with this requirement may be used as well.

AS-WP-09-004SHALL

Legacy ID: WUA_04 {: .eudi-hlr__meta }

When issuing, presenting, or verifying a WIA or KA, Wallet Providers, Wallet Units, PID Providers, and Attestation Providers SHALL only use cryptographic algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

AS-WP-09-005SHALL

Legacy ID: WUA_05 {: .eudi-hlr__meta }

During issuance of a PID, the Wallet Unit SHALL provide the PID Provider with a valid KA describing the WSCA/WSCD that generated the new PID private key.

Note: A PID private key is always generated and managed by the WSCA/WSCD, which by definition complies with requirements for Level of Assurance High.

AS-WP-09-006SHALL

Legacy ID: WUA_05a {: .eudi-hlr__meta }

During issuance of a device-bound attestation, a Wallet Unit SHALL retrieve the requirements of the Attestation Provider regarding key storage from the Credential Issuer metadata (see ISSU_27d). The Wallet Unit SHALL determine which of its WSCA/WSCD or keystore(s), if any, comply with these requirements. If a compliant WSCA/WSCD or keystore is available to the Wallet Unit, the Wallet Unit SHALL provide the Attestation Provider with a valid KA describing the selected WSCA/WSCD or keystore.

Note: A KA describes the certification properties of the WSCA/WSCD or a keystore (see WUA_01) and contains one or more public key(s) corresponding to private key(s) generated by and stored in that WSCA/WSCD or keystore (see WUA_09).

AS-WP-09-007SHALL

Legacy ID: WUA_06 {: .eudi-hlr__meta }

If a Wallet Unit contains a WSCA/WSCD and one or more keystores, it SHALL, internally and securely, keep track of which PID(s) and attestation(s) are bound to which WSCA/WSCD or keystore.

AS-WP-09-008SHALL

Legacy ID: WUA_07 {: .eudi-hlr__meta }

A Wallet Unit SHALL present a KA only to a PID Provider or Attestation Provider, as part of the issuance process of a PID or a key-bound attestation, and not to a Relying Party or any other entity.

AS-WP-09-009SHALL

Legacy ID: WUA_08 {: .eudi-hlr__meta }

A WIA SHALL enable PID Providers to request a Wallet Provider to revoke a Wallet Unit, in accordance with requirement WURevocation_11, by including an identifier for the Wallet Instance in the WIA. The Wallet Provider SHALL ensure that this Wallet Instance identifier does not enable tracking of the User.

Note: a) This is a legal requirement from CIR 2024/2977. b) Under Technical Specification 3 V1.5, this Wallet Instance identifier is the URI and index to the Attestation Status List for WIAs.

AS-WP-09-010SHALL

Legacy ID: WUA_09 {: .eudi-hlr__meta }

A KA SHALL contain one or more public keys, and the corresponding private keys SHALL be generated by and stored in the WSCA/WSCD or the keystore described in the KA.

Note: By signing the KA, the Wallet Provider attests to the fact that the private key(s) corresponding to the public key(s) in the KA are generated by and stored in this WSCA/WSCD or keystore. This implies that the Wallet Provider has verified that this is actually the case. However, neither the ARF nor Technical Specification 3 specify at which moment the WSCA/WSCD or keystore generated the private keys, or how the Wallet Provider verified that it did so.

AS-WP-09-011SHALL

Legacy ID: WUA_09a {: .eudi-hlr__meta }

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL bind the issued PID(s) or attestation(s) to one of the public keys attested in the KA received from the Wallet Unit.

Note: This implements device binding, see ISSU_17 and ISSU_27.

AS-WP-09-012SHALL

Legacy ID: WUA_10 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that the certificates they use for signing WIAs and KAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 5.

AS-WP-09-013SHALL

Legacy ID: WUA_10a {: .eudi-hlr__meta }

An Attestation Provider issuing non-device-bound attestations SHALL indicate in its Credential Issuer metadata that it does not need a KA, as specified in Technical Specification 3. A Wallet Unit SHALL NOT send a KA to an Attestation Provider when requesting a non-device-bound attestation.

Note: A Wallet Unit sends a WIA to the Attestation Provider regardless of whether the attestations it issues are device-bound or not.

AS-WP-09-014SHALL

Legacy ID: WUA_10b {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that the presentation of a KA is cryptographically bound to the specific context it is intended to be used in.

Note: As specified in Technical Specification 3, this is achieved by letting the signed KA itself contain a nonce provided by the PID Provider or Attestation Provider during the issuance process. Alternatively, the Wallet Unit presents the KA along with a Proof-of-Possession consisting of a signature over that nonce, created by the private key corresponding to one of the public keys attested in the KA.

AS-WP-09-015MAY

Legacy ID: WUA_11 {: .eudi-hlr__meta }

When asking for User approval to store an attestation (see ISSU_11), the Wallet Unit MAY indicate to the User whether the attestation requested by a Relying Party is device-bound or not.

Note: The intent of this indication is to warn the User that a non-device-bound attestation may be copied by an attacker breaching the Wallet Unit's security. See also RPA_12.

AS-WP-09-016SHALL

Legacy ID: WUA_11a {: .eudi-hlr__meta }

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL verify the KA in accordance with the requirements in OpenID4VCI Appendix F.4. In addition, the PID Provider or Attestation Provider SHALL validate that the KA is not revoked.

Note: If the verification of the KA is successful, the PID Provider or Attestation Provider can trust that all public keys in the KA are bound to the WSCD or keystore described in the KA (see WUA_09).

AS-WP-09-017

Legacy ID: WUA_11b {: .eudi-hlr__meta }

Empty

AS-WP-09-018SHALL

Legacy ID: WUA_12 {: .eudi-hlr__meta }

During issuance of a PID or a device-bound attestation, the PID Provider or Attestation Provider SHALL receive a proof that the Wallet Unit possesses the private keys corresponding to all public keys in the KA.

Note: As specified in Technical Specification 3, this proof consists of the signature of the Wallet Provider over the KA in combination with the proof mentioned in WUA_10b.

AS-WP-09-019

Legacy ID: WUA_13 {: .eudi-hlr__meta }

Empty

AS-WP-09-020

Legacy ID: WUA_14 {: .eudi-hlr__meta }

Empty

AS-WP-09-021

Legacy ID: WUA_15 {: .eudi-hlr__meta }

Empty

AS-WP-09-022

Legacy ID: WUA_16 {: .eudi-hlr__meta }

Empty

AS-WP-09-023SHALL

Legacy ID: WUA_16a {: .eudi-hlr__meta }

A WSCA SHALL NOT enable export of private keys from a WSCD.

Note: The WSCA is dedicated firmware and/or software implementing specific functions needed within the EUDI Wallet ecosystem. Within that context, there is no need for private key export. Therefore, a WSCA must not support it. However, a WSCD or a keystore may enable private key export via native firmware or software, for generic purposes.

AS-WP-09-024SHALL

Legacy ID: WUA_17 {: .eudi-hlr__meta }

A Wallet Provider SHALL consider all relevant factors, including offline usage, interoperability, and the risk of a WIA or KA becoming a vector to track the User, when deciding on the validity period of a WIA or KA.

Note: a) Regarding interoperability, see WUA_30, which limits the validity period of PIDs issued based on the revocation maintenance periods of the WIA and KA received during issuance. b) As specified in Technical Specification 3, a PID Provider or Attestation Provider may communicate its preferences regarding the minimum revocation maintenance period of the WIA and KA to the Wallet Unit. The Wallet Unit and the Wallet Provider should take this into account (see WUA_32). c) For the WIA specifically, a short technical validity period is required to ensure freshness. See WUA_33.

AS-WP-09-025

Legacy ID: WUA_18 {: .eudi-hlr__meta }

Empty

AS-WP-09-026

Legacy ID: WUA_19 {: .eudi-hlr__meta }

Empty

AS-WP-09-027

Legacy ID: WUA_20 {: .eudi-hlr__meta }

Empty

AS-WP-09-028

Legacy ID: WUA_20a {: .eudi-hlr__meta }

Empty

AS-WP-09-029

Legacy ID: WUA_21 {: .eudi-hlr__meta }

Empty

AS-WP-09-030SHALL

Legacy ID: WUA_22 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that a non-revoked Wallet Unit at all times can present a temporally valid and non-revoked WIA to a PID Provider or Attestation Provider during the issuance process of a PID or attestation.

Note: a) This requirement applies to both device-bound and non-device-bound attestations. b) Revocation refers to the attested Wallet Instance, not to the WIA itself. c) For example, the Wallet Provider could pro-actively issue new WIAs to the Wallet Unit, so that the Wallet Unit is always in possession of a valid WIA. Alternatively, the Wallet Provider could ensure that whenever the User opens the Wallet Unit, it checks whether it is possession of a valid WIA, and requests the Wallet Provider to issue a new WIA if needed. A third possibility is that the Wallet Unit does this check only when it starts the process of requesting the (re-)issuance of a PID or attestation. Other alternatives to comply with this requirement may be used as well.

AS-WP-09-031

Legacy ID: WUA_23 {: .eudi-hlr__meta }

Empty

AS-WP-09-032SHALL

Legacy ID: WUA_24 {: .eudi-hlr__meta }

A Wallet Unit SHALL present a WIA only to a PID Provider or Attestation Provider, as part of the issuance process of a PID or an attestation, and not to a Relying Party or any other entity.

AS-WP-09-033SHALL

Legacy ID: WUA_25 {: .eudi-hlr__meta }

During issuance of a PID or attestation, the PID Provider or Attestation Provider SHALL verify the WIA in accordance with the requirements in OpenID4VCI Appendix E. In addition, the PID Provider or Attestation Provider SHALL validate that the WIA is not revoked.

Note: This requirement applies to both device-bound and non-device-bound attestations.

AS-WP-09-034SHALL

Legacy ID: WUA_26 {: .eudi-hlr__meta }

A WIA SHALL enable PID Providers and Attestation Providers to verify the authenticity of a Wallet Instance and to check whether the Wallet Instance has been revoked.

Note: A WIA carries the revocation reference for a Wallet Instance. The revocation status of the Wallet Instance is maintained in a status list referenced in the WIA.

AS-WP-09-035SHALL

Legacy ID: WUA_27 {: .eudi-hlr__meta }

A WIA SHALL contain information about the Wallet Solution, including its identity, version, and certification, and SHALL comply with the relevant requirements in Technical Specification 3.

Note: This information allows PID Providers and Attestation Providers to verify that the Wallet Instance belongs to a trusted and certified Wallet Solution, as registered in the Wallet Provider Trusted List.

AS-WP-09-036SHALL

Legacy ID: WUA_28 {: .eudi-hlr__meta }

A Wallet Provider SHALL select either the type-shared index approach or the per-KA index approach (as specified in Section 2.5.2 of Technical Specification 3) for managing the revocation status of the WSCD or keystore referenced in a Key Attestation.

Note: a) Under the type-shared index approach, the revocation reference is shared across all Wallet Units using the same type of WSCD or keystore, so that a single revocation action covers all affected Wallet Units (e.g., when a security vulnerability is identified in a hardware component type). Under the per-KA index approach, each KA carries a revocation reference scoped to the specific Wallet Unit's WSCD or keystore instance, enabling individual revocation that may also be triggered by user request. b) The detailed requirements for each approach are specified in Technical Specification 3.

AS-WP-09-037SHALL

Legacy ID: WUA_28a {: .eudi-hlr__meta }

If the per-KA index approach is used, the Wallet Provider SHALL ensure that the revocation reference in a KA cannot be used to link a Wallet Unit's interactions across different PID Providers or Attestation Providers.

AS-WP-09-038SHALL

Legacy ID: WUA_29 {: .eudi-hlr__meta }

Throughout the entire validity period of an issued PID, the PID Provider SHALL verify the revocation status of both the Wallet Instance and WSCD using the information in the WIA and the KA (respectively) received during the issuance of that PID. If either is revoked, the PID Provider SHALL revoke the PID.

AS-WP-09-039SHALL

Legacy ID: WUA_30 {: .eudi-hlr__meta }

The technical validity period of a PID SHALL be consistent with the period during which the Wallet Provider has committed to maintaining the revocation status of the Wallet Instance and the WSCD, as conveyed in the WIA and KA presented during issuance.

Note: a) This reflects the revocation chaining requirement: PID Providers must be able to check whether the Wallet Instance has been revoked (via the WIA) and whether the WSCD referenced in the KA has been revoked (WUA_29) for the entire PID validity period.

AS-WP-09-040SHALL

Legacy ID: WUA_31 {: .eudi-hlr__meta }

A Wallet Provider SHALL maintain the revocation status of a Wallet Instance during the entire revocation maintenance period indicated in the WIAs issued to that Wallet Instance.

AS-WP-09-041SHALL

Legacy ID: WUA_31a {: .eudi-hlr__meta }

A Wallet Provider SHALL maintain the revocation status of a WSCD or keystore during the entire revocation maintenance period indicated in the KAs issued to the Wallet Instance(s) using that WSCD or keystore.

AS-WP-09-042SHALL

Legacy ID: WUA_32 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider having minimum requirements regarding the remaining revocation maintenance period for Wallet Instances (in WIAs) or WSCDs or keystores (in KAs) SHALL communicate these requirements to the Wallet Unit at the time of PID or attestation issuance, as specified in Technical Specification 3.

Note: This allows PID Providers and Attestation Providers to ensure that they receive WIAs and KAs with a sufficiently long remaining revocation maintenance period, enabling revocation chaining for the intended validity period of the PID or attestation to be issued.

AS-WP-09-043SHALL

Legacy ID: WUA_33 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that WIAs have a short technical validity period as specified in Technical Specification 3, such that a WIA is fresh at the time of use.

Note: As specified in Technical Specification 3, the technical validity period of a WIA SHALL be less than 24 hours. This ensures that the WIA reflects a recent integrity check of the Wallet Instance. The revocation maintenance period (see WUA_26 and WUA_31) is specified separately in the WIA and may be considerably longer than the technical validity period.

AS-WP-09-044SHALL

Legacy ID: WUA_34 {: .eudi-hlr__meta }

During issuance of a PID, a PID Provider SHALL verify that the keys attested in the KA are stored in the WSCA/WSCD described in the KA.

Note: PID private keys must be protected at Level of Assurance High, which requires key storage in a WSCA/WSCD. See also WUA_05, which requires the Wallet Unit to provide a KA describing the WSCA/WSCD that generated the PID private key.

AS-WP-09-045SHALL

Legacy ID: WUA_35 {: .eudi-hlr__meta }

A Wallet Unit SHALL comply with all relevant requirements specified in Technical Specification 3.

AS-WP-09-046SHALL

Legacy ID: WUA_36 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL comply with all relevant requirements specified in Technical Specification 3.

AS-WP-09-047SHALL

Legacy ID: WUA_37 {: .eudi-hlr__meta }

A Wallet Provider SHALL maintain, for each Wallet Unit it has activated, the set of WIAs and KAs it has issued to that Wallet Unit, in such a way that this association cannot be confused with that of any other Wallet Unit, including across different Wallet Solutions or different Wallet Solution versions. The Wallet Provider SHALL document the procedures, controls, and

corresponding risk analysis implementing this requirement as part of the policy meant in WURevocation_03.

Note: This requirement makes explicit at the HLR level the record-keeping duty already implicit in WURevocation_07, WURevocation_07a, WIAM_05, WIAM_06, and WIAM_10.

AS-WP-11-001SHALL

Legacy ID: PA_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable a User to generate a Pseudonym and register it at a Relying Party.

Note: For an attested pseudonym, pseudonym generation takes place by requesting the issuance of a pseudonym attestation. Pseudonym registration takes place by presenting the attestation.

AS-WP-11-002SHALL

Legacy ID: PA_02 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable a User to authenticate with a Pseudonym towards a Relying Party if the Wallet Unit was used previously to register the Pseudonym for the same Relying Party

AS-WP-11-003SHALL

Legacy ID: PA_03 {: .eudi-hlr__meta }

A Wallet Unit SHALL be able to perform the actions specified in the above two requirements independently of whether the interaction with the Relying Party is initiated on the same device hosting the Wallet Instance or on a device different from the one hosting the Wallet Instance.

AS-WP-11-004SHALL

Legacy ID: PA_04 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to use multiple different Pseudonyms at a given Relying Party, unless it is explicitly designed as a scope rate-limited attestation.

AS-WP-11-005SHOULD

Legacy ID: PA_05 {: .eudi-hlr__meta }

A Wallet Unit SHOULD enable a User to freely choose a User alias for each Pseudonym registered at a Relying Party. Setting an alias SHOULD be optional for the User. The User SHOULD be able to change the alias for any Pseudonym.

AS-WP-11-006SHALL

Legacy ID: PA_06 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable a User to choose which Pseudonym to authenticate with towards a Relying Party, if multiple Pseudonyms are registered for this Relying Party. The Wallet Unit SHOULD present the User with the aliases of the applicable Pseudonyms, if assigned, when making this choice.

AS-WP-11-007SHALL

Legacy ID: PA_07 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable a User to delete a Pseudonym.

AS-WP-11-008SHALL

Legacy ID: PA_08 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to manage Pseudonyms within the Wallet Unit in a user-friendly and transparent manner.

AS-WP-11-009SHALL

Legacy ID: PA_08a {: .eudi-hlr__meta }

A Wallet Unit SHALL log Pseudonym registration and presentation transactions as specified in Topic 19.

AS-WP-11-010SHALL

Legacy ID: PA_09 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to see all existing pseudonyms, including the associated Relying Party (if any).

AS-WP-11-011SHALL

Legacy ID: PA_10 {: .eudi-hlr__meta }

A Relying Party SHALL be able to verify that a User is registering a Pseudonym using a non-revoked Wallet Unit.

AS-WP-11-012SHALL

Legacy ID: PA_11 {: .eudi-hlr__meta }

A Relying Party SHALL be able to verify that a User is authenticating with a Pseudonym using a non-revoked Wallet Unit.

AS-WP-11-013SHALL

Legacy ID: PA_12 {: .eudi-hlr__meta }

If Wallet Unit is used to register a Pseudonym at a Relying Party in combination with a PID or attestation being presented to the same Relying Party, then this Relying Party SHALL be able to verify that the same User performed both actions.

AS-WP-11-014SHALL

Legacy ID: PA_13 {: .eudi-hlr__meta }

The Relying Party SHALL be able to validate that the pseudonym presented to them belongs to the User presenting it.

AS-WP-11-015SHALL

Legacy ID: PA_14 {: .eudi-hlr__meta }

A Wallet Unit SHALL store the information necessary for authenticating with a Pseudonym in either a WSCA/WSCD or in a keystore.

AS-WP-11-016SHALL

Legacy ID: PA_15 {: .eudi-hlr__meta }

A Relying Party SHALL NOT be able to derive the User's true identity, or any data identifying the User, from the Pseudonym value received by the Relying Party.

AS-WP-11-017SHALL

Legacy ID: PA_16 {: .eudi-hlr__meta }

A Wallet Unit SHALL NOT reveal the same Pseudonym to different Relying Parties, unless the User explicitly chooses otherwise.

AS-WP-11-018SHALL

Legacy ID: PA_17 {: .eudi-hlr__meta }

The Wallet Provider SHALL use method(s) and/or protocol(s) to implement pseudonyms which make it impossible to correlate Pseudonyms based on their values or on metadata sent by the Wallet Unit to Relying Parties during registration and authentication.

Note: This implies that colluding Relying Parties will not be able to conclude that different Pseudonyms belong to the same User.

AS-WP-11-019SHALL

Legacy ID: PA_18 {: .eudi-hlr__meta }

The Wallet Unit SHALL ensure that Pseudonyms contain sufficient entropy to make the chance of colliding Pseudonyms (meaning two Users having the same Pseudonym value for the same Relying Party) negligible.

AS-WP-11-020SHALL

Legacy ID: PA_19 {: .eudi-hlr__meta }

A Wallet Unit SHALL NOT share the User's optionally assigned Pseudonym aliases with any Relying Party.

AS-WP-11-021SHALL

Legacy ID: PA_20 {: .eudi-hlr__meta }

The Wallet Unit SHALL verify the identity of a Relying Party when a User registers a Pseudonym or authenticates with a Pseudonym. If the profile or extension of W3C WebAuthn meant in PA_21 does not enable the Wallet Unit to do this, the Wallet Unit SHALL trust the WebAuthn Client (i.e., the browser) to verify the Relying Party identity.

Note: W3C WebAuthn currently does not offer a way for an Authenticator (i.e., the Wallet Unit) to authenticate a Relying Party. Instead, the Client (i.e., the browser) will authenticate the Relying Party, using TLS. The notion of trust is that the Wallet Unit receives the Relying Party identity from the browser and uses it without further verifications.

AS-WP-11-022SHALL

Legacy ID: PA_21 {: .eudi-hlr__meta }

The Commission SHALL create or reference a technical specification containing a profile or extension of the W3C WebAuthn specification compliant with the HLRs specified in this Topic. This specification SHALL contain all details necessary for Wallet Units and Relying Parties to generate, register, and use Pseudonyms.

AS-WP-11-023MAY

Legacy ID: PA_22 {: .eudi-hlr__meta }

Wallet Providers MAY ensure that their Wallet Solution supports the HLRs defined for this topic by letting their Wallet Units perform the role of a WebAuthn authenticator following the W3C WebAuthn specification and the technical specification referenced in referenced in PA_21.

AS-WP-11-024SHALL

Legacy ID: PA_23 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

AS-WP-11-025SHALL

Legacy ID: PA_24 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL enable a Wallet Unit to allow a User to generate a scope rate-limited pseudonym, register this by a Relying Party, and prove that this is within the rate and scope restrictions determined by the Relying Party.

AS-WP-11-026SHALL

Legacy ID: PA_25 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL allow a Relying Party, when a User presents a scope rate-limited pseudonym, to verify that the rate is not exceeded for this User.

AS-WP-11-027SHALL

Legacy ID: PA_26 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL allow a Relying Party to choose the scope and rate when requesting a scope rate-limited pseudonym from a User.

AS-WP-11-028SHALL

Legacy ID: PA_27 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL NOT allow any entity or collusion of entities not including the User, to link scope rate-limited pseudonyms of the same User when used across several different Relying Parties. This SHALL hold even if the scope and rate are identical across the different Relying Parties and both for registration and authentication of the scope rate-limited pseudonym

AS-WP-11-029SHALL

Legacy ID: PA_28 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL ensure that if the rate is larger than 1, a User's different pseudonyms SHALL be unlinkable for the same scope. This SHALL hold against any entity or collusion of entities, not including the User. Further, such protocol SHALL ensure that during registration or authentication with such a pseudonym, it SHALL NOT be

possible for the Relying Party to deduce any information about how many pseudonyms the User has already registered (except that it does not exceed the predetermined rate).

AS-WP-11-030SHALL

Legacy ID: PA_29 {: .eudi-hlr__meta }

A protocol enabling scope rate-limited pseudonyms SHALL ensure that no entity or collusion of entities, not including a User, is able to authenticate or register with a scope rate-limited pseudonym of this User.

AS-WP-11-031SHALL

Legacy ID: PA_30 {: .eudi-hlr__meta }

A Wallet Unit SHALL store cryptographic material necessary for authenticating as a scope rate-limited pseudonyms in either a WSCA/WSCD or in a keystore.

AS-WP-11-032SHALL

Legacy ID: PA_31 {: .eudi-hlr__meta }

A User's scope rate limited pseudonyms for a particular scope and rate SHALL be persistent over time even if they start using another Wallet Unit.

AS-WP-16-001SHALL

Legacy ID: QES_01 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that each User has the possibility to receive a qualified certificate for Qualified Electronic Signatures, bound to a QSCD, that is either local, external, or remotely managed in relation to the Wallet Instance.

AS-WP-16-002SHALL

Legacy ID: QES_02 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that each User who is a natural person has, at least for non-professional purposes, free-of-charge access to a Signature Creation Application which allows the creation of free-of-charge Qualified Electronic Signatures using the certificates referred to in QES_01. Wallet Providers SHALL ensure that: - The Signature Creation Application SHALL, as a minimum, be capable of signing or sealing User-provided data and Relying Party-provided data. - The Signature Creation Application SHALL be implemented as part of a Wallet Solution or external to it (by providers of trust services or by Relying Parties). - The Signature Creation

Application SHALL be able to generate signatures or seals in formats compliant with at least the mandatory formats referred to in QES_08.

Note: a) Signature Creation Application (SCA): see definition in ETSI TS 119 432. 2) If the SCA is external to the Wallet Solution, it may be for example a separate mobile application, or be hosted remotely, for instance by the QTSP or by a Relying Party.

AS-WP-16-003SHALL

Legacy ID: QES_03 {: .eudi-hlr__meta }

For the use of the qualified certificate referred to in QES_01, Wallet Providers SHALL ensure that a Wallet Unit implements secure authentication of the User, as well as signature or seal invocation capabilities, as a part of a local, external or remote QSCD.

AS-WP-16-004SHALL

Legacy ID: QES_04 {: .eudi-hlr__meta }

Wallet Providers SHALL enable their Wallet Units to interface with QSCDs using protocols and interfaces necessary for the implementation of secure User authentication and signature or seal functionality.

Note: In a Relying Party-centric flow, the remote QTSP will likely be selected by the Relying Party, which implies the QSCD is managed by the remote QTSP. In a Wallet Unit-driven flow, the User should be able to choose the QSCD.

AS-WP-16-005SHALL

Legacy ID: QES_05 {: .eudi-hlr__meta }

Wallet Providers SHALL enable their Wallet Units to be used for User enrolment to a remote QES Provider (i.e., a QTSP offering remote QES), except where the Wallet Unit interfaces with local or external QSCDs.

AS-WP-16-006SHALL

Legacy ID: QES_06 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Solution supports at least one of the following options for remote QES signature creation: - remote QES creation through secure authentication to a QTSP signature web portal, - remote QES creation channelled by the Wallet Unit, - remote QES creation channelled by a Relying Party.

AS-WP-16-007

Legacy ID: QES_07 {: .eudi-hlr__meta }

Empty

AS-WP-16-008SHALL

Legacy ID: QES_08 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Units are able to create signatures or seals in accordance with the mandatory PAdES format as specified in ETSI EN 319 142-1 V1.2.1 (2024-01). In addition, Wallet Providers SHOULD ensure that their Wallet Units are able to create signatures or seals in accordance with the following formats: - XAdES as specified in ETSI EN 319 132-1 V1.3.1 (2024-07), - JAdES as specified in ETSI TS 119 182-1 V1.2.1 (2024-07), - CAdES as specified in ETSI EN 319 122-1 V1.3.1 (2023-06), and - ASiC as specified in ETSI EN 319 162-1 V1.1.1 (2016-04) and ETSI EN 319 162-2 V1.1.1 (2016-04).

AS-WP-16-009

Legacy ID: QES_09 {: .eudi-hlr__meta }

Empty

AS-WP-16-010SHALL

Legacy ID: QES_10 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that, where the Signature Creation Application is implemented as part of the Wallet Unit and is used to generate signatures or seals of the representation of the document or data to be signed or sealed, the Wallet Unit presents the representation of the document or data to be signed or sealed to the User.

AS-WP-16-011SHALL

Legacy ID: QES_11 {: .eudi-hlr__meta }

Where the Signature Creation Application is implemented as part of the Wallet Unit, a Wallet Unit SHALL compute the hash or digest of the document or data to be signed through its Signature Create Application component.

AS-WP-16-012SHALL

Legacy ID: QES_12 {: .eudi-hlr__meta }

A Wallet Unit SHALL be able to create a signature over a document or data to be signed, either by using a local QSCD or by interfacing with a remote QES Provider.

Note: a local signing application is on-device. It may either be embedded in the Wallet Unit or be an external application.

AS-WP-16-013SHALL

Legacy ID: QES_13 {: .eudi-hlr__meta }

A Wallet Unit SHALL provide a log of transactions related to qualified electronic signatures or seals generated by or through the Wallet Unit, allowing the User to view the history of previously signed data or documents, according to requirement DASH_04 in Topic 19.

Note: If the signature is generated by a remote Signature Creation Application, the Wallet is at minimum used to authenticate the User to the remote QTSP and to obtain the User's consent for the usage of the private signing key. The logs then record information about these processes.

AS-WP-16-014SHALL

Legacy ID: QES_14 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to explicitly authorise the creation of a qualified electronic signature or seal through their Wallet Unit.

AS-WP-16-015SHALL

Legacy ID: QES_15 {: .eudi-hlr__meta }

In remote signature creation scenarios, a Wallet Unit SHALL verify that the qualified electronic signature or seal creation device is part of a qualified service, which is carried out by a qualified trust service provider.

AS-WP-16-016SHOULD

Legacy ID: QES_16 {: .eudi-hlr__meta }

A Wallet Unit SHOULD support multiple-signing scenarios, where multiple signatories are required to sign the same document or data.

AS-WP-16-017SHALL

Legacy ID: QES_17 {: .eudi-hlr__meta }

A Wallet Unit SHALL provide a signature creation confirmation upon the creation of a qualified electronic signature, informing the User about the outcome of the signature creation process.

Note: See also QES_17a.

AS-WP-16-018SHALL

Legacy ID: QES_17a {: .eudi-hlr__meta }

If the Signature Creation Application is external to the Wallet Unit, after the User authorises the usage of the private signing key, the Signature Creation Application SHALL return the outcome of the signature creation process to the Wallet Unit.

AS-WP-16-019SHALL

Legacy ID: QES_18 {: .eudi-hlr__meta }

Wallet Providers SHALL configure at least one default qualified signing service in the Wallet Unit.

AS-WP-16-020SHALL

Legacy ID: QES_19 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that, where the Signature Creation Application is implemented as part of the Wallet Unit, a Wallet Unit supports ETSI TS 119 101 when using signing keys managed by the QSCD, whether locally, externally, or remotely in relation to the Wallet Instance.

AS-WP-16-021

Legacy ID: QES_20 {: .eudi-hlr__meta }

Empty

AS-WP-16-022

Legacy ID: QES_21 {: .eudi-hlr__meta }

Empty

AS-WP-16-023

Legacy ID: QES_22 {: .eudi-hlr__meta }

Empty

AS-WP-16-024SHALL

Legacy ID: QES_23 {: .eudi-hlr__meta }

QTSPs providing the remote QES part of a Wallet Solution SHALL support: 1. ETSI TS 119 431-1 , 2. ETSI TS 119 431-2 , 3. ETSI TS 119 432. Wallet Providers and QTSPs providing the remote QES part of a Wallet Solution SHALL comply with Sole Control Assurance Level (SCAL) 2 as defined in CEN EN 419 241-1 .

AS-WP-16-025SHALL

Legacy ID: QES_24 {: .eudi-hlr__meta }

QTSPs providing the Signature Creation Application as part of the remote QES part of a Wallet Solution SHALL support ETSI TS 119 101.

AS-WP-16-026SHALL

Legacy ID: QES_24a {: .eudi-hlr__meta }

Relying Parties providing the Signature Creation Application in a Relying Party-centric flow SHALL support ETSI TS 119 101.

AS-WP-16-027

Legacy ID: QES_25 {: .eudi-hlr__meta }

Empty

AS-WP-16-028

Legacy ID: QES_26 {: .eudi-hlr__meta }

Empty

AS-WP-18-001SHALL

Legacy ID: ACP_01 {: .eudi-hlr__meta }

A Cryptographic Binding of Attestations scheme SHALL enable a WSCA/WSCD or keystore to prove that it manages two or more private keys, paired with two or more public keys provided to it by the Wallet Unit.

Note: a)These public keys may be included in WIAs and KAs, PIDs, attestations, or pseudonyms. b) The proof may be transitive, so a proof that two keys are stored/managed in the same WSCA/WSCD or keystore may be done by proving these keys relate to each other via a third key (also stored in the WSCA/WSCD or keystore).

AS-WP-18-002SHALL

Legacy ID: ACP_04 {: .eudi-hlr__meta }

A Cryptographic Binding of Attestations scheme SHALL be compatible with the requirements for attestation issuance in this document, in particular Topic 10, as well as with requirements for both remote and proximity presentation flows in this document, in particular Topic 1 and Topic 24.

AS-WP-18-003SHALL

Legacy ID: ACP_05 {: .eudi-hlr__meta }

A Cryptographic Binding of Attestations scheme SHALL enable an Attestation Provider, during the issuance of an attestation, to request and obtain proof that the private key for the new attestation is managed by the same WSCA/WSCD or keystore as the private key of a PID or another attestation already existing on the Wallet Unit.

Note: ACP_05 and ACP_06 may require an addition to the common OpenID4VCI protocol referenced in requirement ISSU_01, or an extension or profile thereof.

AS-WP-19-001SHALL

Legacy ID: DASH_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL provide a user-friendly dashboard functionality to its User.

AS-WP-19-002SHALL

Legacy ID: DASH_02 {: .eudi-hlr__meta }

The Wallet Unit SHALL log all transactions executed through the Wallet Unit, including any transactions that were not completed successfully. This log SHALL include all types of transaction executed through the Wallet Unit: a) PID or attestation issuance and re-issuance transactions, b) PID or attestation presentation transactions, c) Wallet-to-Wallet transactions (see Topic 30), d) pseudonym registration or presentation transactions, e) signature or seal creation transactions (see Topic 16), f) data deletion requests sent to a Relying Party (see Topic 48), g) reports sent to a Data Protection Authority (see Topic 50), h) PID or attestation deletions by the User.

Note: For the data to be logged for a data deletion request to a Relying Party or a report sent to a DPA, see Topic 48 and Topic 50, respectively. For other types of transaction, the data to be logged is specified in the requirements in this Topic.

AS-WP-19-003SHALL

Legacy ID: DASH_02a {: .eudi-hlr__meta }

The Wallet Unit SHALL retain transactions in the log at least for the minimum retention period specified in applicable legislation. If the Wallet Unit must delete transactions from the log, for instance because of size limitations, the Wallet Unit SHALL notify the User via the dashboard before doing so, indicating the potential consequences for the User's data protection rights,

and SHALL instruct the User how to export the transactions that are about to be deleted. See DASH_07.

AS-WP-19-004SHALL

Legacy ID: DASH_02b {: .eudi-hlr__meta }

The dashboard SHALL include a functionality to display to the User an overview of all transactions in the log.

AS-WP-19-005SHALL

Legacy ID: DASH_02c {: .eudi-hlr__meta }

The transaction log meant in DASH_02 SHALL comply with all relevant requirement in Technical Specification 10, including measures to ensure and/or verify its confidentiality, integrity, and authenticity.

AS-WP-19-006SHALL

Legacy ID: DASH_03 {: .eudi-hlr__meta }

For a PID or attestation presentation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the trade name, unique identifier, and Service identifier of the corresponding Relying Party, and the Member State in which that Relying Party is established, c) the trade name, contact details (if available), unique identifier, and Service identifier of the intermediary, if an intermediary is involved in the transaction, d) the attestation type(s) and the identifier(s) of the attribute(s) that were requested, as well as those that were presented, e) in the case of non-completed transactions, the reason for such non-completion, f) the URL of the online service of the Relying Party's Registrar. g) the web form URL (if available), e-mail address (if available), and telephone number (if available) provided by the Relying Party for sending data deletion requests, see requirement RPRC_11 in Topic 44, h) the name and country of the Data Protection Authority supervising the Relying Party, as well as the web form URL (if available), e-mail address (if available), and telephone number (if available) provided by this DPA for reporting suspicious attribute presentation requests. i) information on the intended use and the URL to the applicable privacy policy.

Note: a) If an intermediary is involved in the transaction, the Wallet Unit obtains the information under point b) from the registration certificate in the presentation request, and the information under point c) from the access certificate. In case no intermediary is involved, the Wallet Unit obtains the information under point b) from either the registration certificate or the access certificate, because it is identical in both certificates. b) The information in points g) and h) can

be retrieved from the registration certificate. At least one of the options (URL, e-mail address, or telephone number) will be present. See RPRC_11 and RPRC_12.

AS-WP-19-007SHALL

Legacy ID: DASH_03a {: .eudi-hlr__meta }

For a PID or attestation presentation transaction or a Wallet-to-Wallet transaction executed through the Wallet Unit, the log SHALL NOT contain the value of any attributes presented to the Relying Party or the Verifier Wallet Unit.

AS-WP-19-008SHALL

Legacy ID: DASH_03b {: .eudi-hlr__meta }

For a Wallet-to-Wallet transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the role of the Wallet Unit (Holder Wallet Unit or Verifier Wallet Unit), c) the attestation type(s) and the identifier(s) of the attribute(s) that were requested, as well as those that were presented, d) in the case of non-completed transactions, the reason for such non-completion.

AS-WP-19-009SHALL

Legacy ID: DASH_03c {: .eudi-hlr__meta }

For a pseudonym registration or presentation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) identifying information about the Relying Party, if known to the Wallet Unit, c) whether it is a pseudonym registration or pseudonym presentation transaction, d) in the case of non-completed transactions, the reason for such non-completion.

Note: Regarding point b), see PA_20 in Topic 11.

AS-WP-19-010SHALL

Legacy ID: DASH_03d {: .eudi-hlr__meta }

If a presentation request contains transactional data, the Wallet Unit SHALL log the value of this transactional data only to the extent explicitly required by the applicable Technical Specification associated with the requested SUA attestation, and in accordance with data minimisation principles. If the applicable Technical Specification does not explicitly specify that transactional data shall be logged, the Wallet Unit SHALL NOT log the value of any transactional data.

Note: a) For the concepts of transactional data and SUA attestations and their related Technical Specifications, see Topic 20. b) For example, for PSD2 Strong Customer Authentication transactions, the scope of transactional data to be included in the transaction log is defined in Technical Specification 12 and includes the payment transaction identifier and merchant name.

AS-WP-19-011SHALL

Legacy ID: DASH_04 {: .eudi-hlr__meta }

For a signature or seal creation transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the document or data signed or sealed (if available to the Wallet Unit), c) in the case of non-completed transactions, the reason for such non-completion.

AS-WP-19-012SHALL

Legacy ID: DASH_05 {: .eudi-hlr__meta }

For a PID or attestation issuance or re-issuance transaction executed through the Wallet Unit, the log SHALL contain at least: a) the date and time of the transaction, b) the trade name, contact details (if available), unique identifier, and Service identifier of the corresponding PID Provider or Attestation Provider, c) the attestation type requested, as well as the attestation type issued, d) the number of attestations requested and issued (i.e., the size of the batch in case of batch issuance), e) in the case of non-completed transactions, the reason for such non-completion. f) for a re-issuance transaction, whether it was triggered by the User or by the Wallet Unit without involvement of the User, g) the URL of the associated Registrar's online service.

Note: a) The Wallet Unit obtains the information under point b) from either the registration certificate or the access certificate, because it is identical in both certificates. b) Regarding point g): this URL can be retrieved from the access certificate.

AS-WP-19-013SHALL

Legacy ID: DASH_05a {: .eudi-hlr__meta }

For the deletion of a PID or attestation by the User, the log SHALL contain at least: a) the date and time of the deletion event, b) the attestation type of the deleted PID or attestation. c) The name and unique identifier of the corresponding PID Provider or Attestation Provider.

Note: This requirement is not about deletion of transactions from the log, as per DASH_06a.

AS-WP-19-014SHALL

Legacy ID: DASH_06 {: .eudi-hlr__meta }

The Wallet Provider SHALL ensure the confidentiality, integrity, and authenticity of all transactions included in the log.

AS-WP-19-015SHALL

Legacy ID: DASH_06a {: .eudi-hlr__meta }

Via the dashboard, the Wallet Unit SHALL enable the User to delete any transaction in the log. Before deleting any transactions, the Wallet Unit SHALL indicate to the User the potential consequences for the User's data protection rights.

Note: This requirement applies even in case the minimum retention period specified in applicable legislation (see DASH_02a) is not yet over.

AS-WP-19-016SHALL

Legacy ID: DASH_06b {: .eudi-hlr__meta }

The Wallet Unit SHALL ensure that no entity other than the User can delete transactions from the log, except possibly for the reason mentioned in DASH_02a.

AS-WP-19-017SHALL

Legacy ID: DASH_07 {: .eudi-hlr__meta }

The dashboard SHALL allow the User to export the details of one or more transactions in the log to a file, using the common format specified according to DASH_02c, while ensuring their confidentiality, authenticity and integrity. The file SHALL be stored in an external storage or remote storage location of the User's choice, from among the storage options supported by the Wallet Unit and SHALL use the common format and security measures specified according to DASH_02c.

AS-WP-19-018SHALL

Legacy ID: DASH_08 {: .eudi-hlr__meta }

For a natural-person User, a Wallet Instance SHALL provide a User interface.

AS-WP-19-019SHALL

Legacy ID: DASH_09 {: .eudi-hlr__meta }

The User interface referred to in DASH_08 SHALL provide a view with - the EU Digital Identity Wallet Trust Mark, - accompanying general information on the certification of Wallet Solutions, - links to the certification status information as defined in the Technical Specification 1.

AS-WP-19-020SHALL

Legacy ID: DASH_09a {: .eudi-hlr__meta }

Positioning of the view meant in DASH_09 in the Wallet UI navigation SHALL follow design guidelines provided by the European Commission.

AS-WP-19-021SHALL

Legacy ID: DASH_09b {: .eudi-hlr__meta }

Regarding the EUDI Wallet Trust Mark, Wallet Providers and Wallet Units SHALL comply with all relevant requirements in Technical Specification 1, as well as with the relevant requirements in Article 14a of CIR 2024/2979 and the Annexes mentioned therein.

AS-WP-19-022

Legacy ID: DASH_10 {: .eudi-hlr__meta }

Empty

Note: See requirement WIAM_12a in Topic 40.

AS-WP-19-023

Legacy ID: DASH_11 {: .eudi-hlr__meta }

Empty

AS-WP-19-024SHALL

Legacy ID: DASH_12 {: .eudi-hlr__meta }

The User interface referred to in DASH_08 SHALL enable the User, for each presentation transaction in the log, to easily request the Relying Party to delete any or all attributes presented to it in that transaction, or to send a report about that particular transaction to a DPA.

AS-WP-20-001SHALL

Legacy ID: SUA_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL be able to process the transactional data included in a presentation request for the SUA attestation(s) specified in Technical Specification 12, according to all requirements in that Technical Specification.

Note: Technical Specification 12 specifies a SUA attestation intended for performing SCA as specified in the PSD2 Regulation. The related Rulebook is called "SCA Attestation Rulebook".

AS-WP-20-002SHALL

Legacy ID: SUA_02 {: .eudi-hlr__meta }

Scheme Providers MAY specify Attestation Rulebooks (see Topic 12) and associated technical specifications for SUA attestations other that the ones specified in Technical Specification 12). The Attestation Rulebook or the technical specification of such of a SUA attestation SHALL specify the syntax and semantics of the transactional data associated with that attestation.

AS-WP-20-003SHALL

Legacy ID: SUA_02a {: .eudi-hlr__meta }

The Technical Specification associated with a given SUA attestation SHALL specify all necessary requirements for Wallet Units to process transactional data intended for this SUA attestation, at least regarding a) rendering and displaying the data to the User when obtaining approval for presentation, b) processing (e.g., hashing) the data for inclusion in the device binding signature, and c) the scope of information to be logged about a SUA attestation presentation transaction by a Wallet Unit.

AS-WP-20-004SHALL

Legacy ID: SUA_03 {: .eudi-hlr__meta }

The Attestation Provider of a SUA attestation other than the one(s) specified in Technical Specification 12 SHALL NOT issue such an attestation to a Wallet Unit that does not comply with all relevant requirements in the SUA Attestation Rulebook and the technical specification for that attestation.

AS-WP-20-005SHALL

Legacy ID: SUA_04 {: .eudi-hlr__meta }

In the response to a presentation request for a SUA attestation that includes transactional data, a Wallet Unit SHALL include (a representation of) that data, according to requirements included in the associated technical specification or Attestation Rulebook or in information provided to the Wallet Unit in the presentation request. In the latter case, the rules to interpret such information SHALL be included in the associated technical specification or Attestation Rulebook.

Note: This requirement, as well as SUA_05, only applies if the requested SUA attestation is present on the Wallet Unit and if the User consents to signing the transactional data and presenting the requested attributes.

AS-WP-20-006SHALL

Legacy ID: SUA_05 {: .eudi-hlr__meta }

The Wallet Unit SHALL include (a representation of) the transactional data received in a presentation request in the signature creation process used for device binding, using the private key of the requested SUA attestation and the mechanisms specified for key binding in SD-JWT VC or mdoc authentication in ISO/IEC 18013-5, as applicable. For this process, the Wallet Unit SHALL comply with the applicable requirements in the technical specification and the Attestation Rulebook for the requested SUA attestation, see SUA_01 or SUA_02.

Note: a) The resulting signature value constitutes a proof of transaction. This signature value, possibly in combination with other protocols items, fulfils the requirements for the authentication code required in PSD2. b) See also requirement OIA_02 in Topic 1.

AS-WP-20-007SHALL

Legacy ID: SUA_06 {: .eudi-hlr__meta }

The Wallet Unit SHALL render or adapt the dialogue message(s) displayed to the User (like font size and colour, background colour, text position, labels in the buttons to 'approve' or 'reject' a transaction), according to requirements in Technical Specification 12.

AS-WP-20-008SHALL

Legacy ID: SUA_07 {: .eudi-hlr__meta }

Upon receiving a presentation request with transactional data, the Wallet Unit SHALL validate if the transactional data is intended for the given attestation and that the transactional data conforms to the related technical specification and/or Attestation Rulebook. In case the validation result is positive, the Wallet Unit SHALL process the transactional data in compliance with the related technical specification.

AS-WP-30-001SHALL

Legacy ID: W2W_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL be able to act as a Holder Wallet Unit, in accordance with all requirements in this Topic.

AS-WP-30-002SHALL

Legacy ID: W2W_02 {: .eudi-hlr__meta }

When acting as a Holder Wallet Unit, if there is a contradiction between a requirement for Holder Wallet Units in this Topic and any requirement for Wallet Units in other Topics in this document, the requirement in this Topic SHALL take precedence. However, when acting as a

Holder Wallet Unit, a Wallet Unit SHALL comply with all requirements for Wallet Units in other Topics in this document that do not contradict any requirement in this Topic.

AS-WP-30-003SHALL

Legacy ID: W2W_03 {: .eudi-hlr__meta }

A Wallet Unit SHALL be able to act as a Verifier Wallet Unit, in accordance with all requirements in this Topic.

AS-WP-30-004SHALL

Legacy ID: W2W_04 {: .eudi-hlr__meta }

When acting as a Verifier Wallet Unit, a Wallet Unit SHALL NOT comply with any requirement for Wallet Units in other Topics in this document.

AS-WP-30-005SHALL

Legacy ID: W2W_05 {: .eudi-hlr__meta }

A Wallet Unit SHALL act as a Holder Wallet Unit only if the User selects a 'Holder Wallet Unit mode'. If the User closes the Wallet Unit, or after a period of non-activity, the Wallet Unit SHALL return to 'normal' mode.

AS-WP-30-006SHALL

Legacy ID: W2W_06 {: .eudi-hlr__meta }

When entering the Holder Wallet Unit mode, a Wallet Unit SHALL inform its User that this mode should only be used for interactions with natural persons using a Wallet Unit, and that the User should not proceed if they are in fact interacting with a Relying Party.

AS-WP-30-007SHALL

Legacy ID: W2W_07 {: .eudi-hlr__meta }

A Wallet Unit SHALL act as a Verifier Wallet Unit only if the User selects a 'Verifier Wallet Unit mode'. If the User closes the Wallet Unit, or after a period of non-activity, the Wallet Unit SHALL return to 'normal' mode.

AS-WP-30-008SHALL

Legacy ID: W2W_09 {: .eudi-hlr__meta }

Holder Wallet Units SHALL comply with the requirements for mDLs and for mdocs in ISO/IEC 18013-5, unless specified differently in Technical Specification 9.

AS-WP-30-009SHALL

Legacy ID: W2W_10 {: .eudi-hlr__meta }

Verifier Wallet Units SHALL comply with the requirements for mDL readers and for mdoc readers in ISO/IEC 18013-5, unless specified differently in Technical Specification 9.

AS-WP-30-010SHALL

Legacy ID: W2W_11 {: .eudi-hlr__meta }

A Holder Wallet Unit SHOULD provide the Holder, through a user-friendly UI, with the option to inform the Verifier Wallet Unit about the attributes which the Verifier should include in the presentation request, by sending a presentation offer. If the Holder creates a presentation offer, the Holder Wallet Unit SHALL transfer it to the Verifier Wallet Unit as specified in Technical Specification 9.

Note: TS9 specifies an extension of the device engagement structure specified in ISO/IEC 18013-5.

AS-WP-30-011SHALL

Legacy ID: W2W_12 {: .eudi-hlr__meta }

A Holder Wallet Unit SHALL recommend the Holder to create a presentation offer, as this will increase the chance of success of the use case.

AS-WP-30-012SHALL

Legacy ID: W2W_13 {: .eudi-hlr__meta }

A Verifier Wallet Unit SHALL provide the Verifier, through a user-friendly UI, with the possibility to select the attributes that will be included in the presentation request.

AS-WP-30-013SHALL

Legacy ID: W2W_14 {: .eudi-hlr__meta }

For the purposes of W2W_13, if the Verifier Wallet Unit received a presentation offer, it SHALL present this offer to the Verifier, and enable the Verifier to include one or more of the attributes in the offer into the presentation request. However, the Verifier Wallet Unit SHALL NOT allow the Verifier to include any attribute not present in the offer.

AS-WP-30-014SHALL

Legacy ID: W2W_15 {: .eudi-hlr__meta }

For the purposes of W2W_13, if the Verifier Wallet Unit did not receive a presentation offer, it SHALL present the Verifier with a list of attributes that can be included in the presentation request. The Verifier Wallet Unit MAY ask the Verifier some questions about the purpose of the use case to narrow down the list.

AS-WP-30-015SHALL

Legacy ID: W2W_16 {: .eudi-hlr__meta }

A Verifier Wallet Unit SHALL authenticate the Verifier and SHALL obtain the Verifier's approval prior to sending a presentation request to a Holder Wallet Unit.

AS-WP-30-016SHALL

Legacy ID: W2W_17 {: .eudi-hlr__meta }

A Verifier Wallet Unit SHALL implement measures to limit the number of presentation requests it can send per unit of time, to prevent abuse of the Wallet-to-Wallet functionality by Relying Parties. The limitation strategy, for instance exponential backoff time between subsequent presentation requests or hard limits for the number of requests, SHALL be decided by the Wallet Provider, based on applicable requirements in Technical Specification 9.

AS-WP-30-017

Legacy ID: W2W_18 {: .eudi-hlr__meta }

Empty

AS-WP-30-018SHALL

Legacy ID: W2W_19 {: .eudi-hlr__meta }

When receiving a presentation response, a Verifier Wallet SHALL verify the received attestation according to requirements OIA_12 - OIA_15 in Topic 1.

AS-WP-30-019SHALL

Legacy ID: W2W_20 {: .eudi-hlr__meta }

A Verifier Wallet Unit SHALL display all verified attributes to the Verifier.

AS-WP-30-020SHALL

Legacy ID: W2W_21 {: .eudi-hlr__meta }

A Verifier Wallet Unit SHALL NOT persistently store any attestations or attributes received. A Verifier Wallet Unit SHOULD minimise the time the received presentation is stored in memory. A Verifier Wallet Unit SHALL comply with OIA_16 in Topic 1.

AS-WP-30-021SHOULD

Legacy ID: W2W_22 {: .eudi-hlr__meta }

Wallet Providers SHOULD take measures to prevent a User from taking screenshots while their Wallet Unit is acting as a Verifier Wallet Unit.

AS-WP-30-022SHALL

Legacy ID: W2W_23 {: .eudi-hlr__meta }

When sending a presentation request to a Holder Wallet Unit, a Verifier Wallet Unit SHALL include in that request a cryptographic proof that it is a genuine, non-revoked EUDI Wallet Unit operated by a recognised Wallet Provider, bound to the protocol session in which the presentation request is sent, if a common method to provide such a proof is established in a technical specification.

Note: Such a specification is being developed within ETSI.

AS-WP-30-023SHALL

Legacy ID: W2W_24 {: .eudi-hlr__meta }

Before presenting a received presentation request to the Holder, a Holder Wallet Unit SHALL authenticate the Verifier Wallet Unit by verifying the proof meant in W2W_23, if present.

AS-WP-30-024SHALL

Legacy ID: W2W_25 {: .eudi-hlr__meta }

If the verification required by W2W_24 fails or cannot be performed, a Holder Wallet Unit SHALL notify the User. In addition, the Wallet Unit SHALL either not present the requested attributes to the Verifier Wallet Unit, or give the User the choice to present the requested attributes or not.

Note: It is up to the Wallet Provider to make a choice for one of these two options.

AS-WP-31-001SHALL

Legacy ID: PPNot_02 {: .eudi-hlr__meta }

The common set of information to be notified about a PID Provider SHALL include at least: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. A business registration number from an official record, b. Identification data from that official record. 2. PID Provider trust anchors, i.e., public keys and name as per point 1) ii) above, supporting the authentication of PIDs issued by the PID Provider,

3. If applicable, trust anchors for PID revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists or Attestation Revocation Lists used to revoke PIDs issued by the PID Provider. 4. Trust anchors of Access Certificate Authorities for PID Providers, i.e., public keys and CA name, supporting the authentication of the PID Provider by Wallet Units at the service supply point(s) listed per point 5. below. 5. Service supply point(s), i.e., the URL(s) at which a Wallet Unit can start the process of requesting and obtaining a PID. 6. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: a) Regarding point 3 above, see section 6.3.2.4 of the ARF main document. b) Relating to point 4: PID Provider Access Certificate Authority trust anchors are notified separately from the Access Certificate Authority for Relying Parties (see Section G below), since PID Providers are -legally speaking- not Relying Parties. b) For the concept of an Access Certificate Authority, see also Topic 27] and Section 6.3.2 of the ARF main document. c) Regarding point 6: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual PID will anyway be included in that PID.

AS-WP-31-002

Legacy ID: WPNot_01 {: .eudi-hlr__meta }

Empty

AS-WP-31-003SHALL

Legacy ID: WPNot_02 {: .eudi-hlr__meta }

The common set of information to be notified about a Wallet Provider SHALL include: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. Business registration number from an official record, and b. Identification data from the official record. 2. Wallet Provider trust anchors, i.e., public keys and name as per point 1. b. above, supporting the authentication of Key Attestations and Wallet Instance Attestations issued by the Wallet Provider. 3. Trust anchors for WIA and KA revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists used to revoke WIAs and KAs issued by the Wallet Provider. 4. Name and reference number of the certified Wallet Solution(s) provided by the Wallet Provider. 5. The URL at which PID Providers, Attestation Providers, and other entities can retrieve the relevant Attestation Status Lists for WIAs and KAs.

Note: a) See Topic 9] and Topic 38] for the definition of the KA and WIA. b) A Wallet Provider does not need an access certificate to interact with Wallet Units. c) Regarding point 3, see section

6.3.2.4 of the ARF main document. d) Regarding point 5: This could be the domain name only, as the full URL containing the ASL relevant for an individual WIA or KA will anyway be included in that WIA or KA.

AS-WP-31-004SHALL

Legacy ID: WPNot_03 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that all WIAs and KAs they issue can be authenticated using the trust anchors notified to the Commission.

AS-WP-31-005SHALL

Legacy ID: WPNot_03a {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that all Attestation Status Lists used to revoke their WIAs and KAs can be authenticated using the trust anchors for WIA and KA revocation lists notified to the Commission.

AS-WP-31-006SHALL

Legacy ID: WPNot_04 {: .eudi-hlr__meta }

PID Providers, Attestation Providers, and other relevant actors SHALL accept Wallet Provider trust anchors and the trust anchors for WIA and KA revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled Wallet Provider LoTE, which is sealed by the Commission.

AS-WP-31-007SHALL

Legacy ID: WPNot_05 {: .eudi-hlr__meta }

The format of a Wallet Provider LoTE SHALL comply with ETSI TS 119 602, including Annex E.

AS-WP-31-008SHALL

Legacy ID: WPNot_06 {: .eudi-hlr__meta }

If a Wallet Provider is cancelled (see requirement GenNot_05 above), that Wallet Provider SHALL immediately revoke all of its Wallet Instances and all associated WSCDs and keystores, in accordance with the requirements in Topic 38. If a Wallet Provider is suspended, that Wallet Provider and the Member State SHALL agree on the necessary precautionary measures that need to be taken, which MAY include the immediate revocation of the Wallet Instances and WSCDs or keystores for all or some of its valid Wallet Units.

AS-WP-31-010SHALL

Legacy ID: PuBPNot_02 {: .eudi-hlr__meta }

The common set of information to be notified by Member States about PuB-EAA Providers SHALL include at least: 1. Identification data: i. MS/Country of establishment, ii. Name as registered in an official record, iii. Where applicable: a. Registration number as in official record, and b. Official record identification data. iv. Identification data of the Union or national law under which a. Either the PuB-EAA Provider is established as the responsible body for the Authentic Source based on which the electronic attestation of attributes is issued, or b. The PuB-EAA Provider is the body designated to act on behalf of the responsible body referred to in point 1. iv. a. v.The conformity assessment report issued by a conformity assessment body, confirming that the requirements set out in paragraphs 1, 2 and 6 of Article 45f are met. 2. PuB-EAA Provider trust anchors, i.e., public keys and name as per point 1) ii) above, supporting the authentication of PuB-EAAs issued by the PuB-EAA Provider, 3. If applicable, trust anchors for PuB-EAA revocation lists, i.e., public keys and name supporting the authentication of any Attestation Status Lists or Attestation Revocation Lists used to revoke PuB-EAAs issued by the PuB-EAA Provider. 4. Service supply point(s), i.e., the URL(s) at which a Wallet Unit can start the process of requesting and obtaining a PuB-EAA from the PuB-EAA Provider. 5. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: c) Regarding point 3, see section 6.3.2.4 of the ARF main document. d) Regarding point 5: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual PuB-EAA will anyway be included in that PuB-EAA.

AS-MS-31-018SHALL

Legacy ID: RPACANot_02 {: .eudi-hlr__meta }

The common set of information to be notified about an Access Certificate Authority or a Provider of registration certificates SHALL include: 1. Identification data: i) Member State or country of establishment, ii) Name as registered in an official record, iii) Where applicable: - A business registration number from an official record, - Identification data from that official record. 2. Trust anchors of the Access Certificate Authority or Provider of registration certificates, i.e., public keys and name as per point 1) ii), supporting the authentication of access certificates and registration certificates by Wallet Units. 3.Trust anchors for access certificate or registration certificate revocation lists, i.e., public keys and name supporting the authentication of any lists used to revoke access certificates or registration certificates issued

by the Access Certificate Authority or Provider of registration certificates. 4. If applicable, the URL at which Relying Parties and other entities can retrieve the relevant CRL.

Note: Regarding point 4: This could be the domain name only, as the full URL containing the CRL relevant for an individual certificate will anyway be included in that certificate.

AS-WP-31-011SHALL

Legacy ID: TLPub_01 {: .eudi-hlr__meta }

The European Commission SHALL establish technical specifications for the system enabling the publication by the Commission of the information notified by the Member States regarding PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

AS-WP-31-012SHALL

Legacy ID: TLPub_02 {: .eudi-hlr__meta }

The European Commission SHALL establish technical specifications for the set of information to be published about PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities and Providers of registration certificates, based on the information notified by the Member States.

Note: The information to be published MAY be different from the information to be notified for each of these entities.

AS-WP-31-013SHALL

Legacy ID: TLPub_06 {: .eudi-hlr__meta }

The Commission SHALL publish in the OJEU the locations of the LoTEs for PID Providers, PuB-EAA Providers, Wallet Providers, Access Certificate Authorities, and Providers of registration certificates.

AS-WP-31-014SHALL

Legacy ID: TLPub_08 {: .eudi-hlr__meta }

As part of the specifications referred to in TLPub_01, the European Commission SHALL establish technical specifications for ensuring the availability and authenticity of the full history regarding the information notified about PID Providers, Wallet Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

AS-WP-34-001SHALL

Legacy ID: Mig_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL include and keep up-to-date a Migration Object, containing the following information: - The contents of the log for all transactions executed through the Wallet Unit, as listed in requirement DASH_02. - A list of PIDs and attestations (except Key Attestations and Wallet Instance Attestations) present in the Wallet Unit, according to the requirements in this Topic.

AS-WP-34-002SHALL

Legacy ID: Mig_02 {: .eudi-hlr__meta }

The Migration Object SHALL comply with all requirements in Technical Specification 10.

AS-WP-34-003SHALL

Legacy ID: Mig_03 {: .eudi-hlr__meta }

For each PID or device-bound attestation that is issued to it, a Wallet Unit SHALL add to the Migration Object all data necessary to request issuance of that PID or attestation once again. This SHALL include at least the attestation type and the PID Provider or Attestation Provider that issued the PID or attestation, as well as their service supply points. However, the Migration Object SHALL NOT contain attribute identifiers or attribute values, and SHALL NOT contain any private keys of the PID or device-bound attestation.

AS-WP-34-004SHALL

Legacy ID: Mig_03a {: .eudi-hlr__meta }

For each non-device-bound attestation that is issued to it, a Wallet Unit SHALL add to the Migration Object one of the following: either all data necessary to request issuance of that attestation once again, as listed in Mig_03, or all data necessary to transfer the attestation to a new device without involvement of the Attestation Provider, including attribute identifiers and attribute values. The Wallet Unit SHALL enable the User to indicate if they want to store attribute identifiers and values in the Migration Object.

AS-WP-34-005SHALL

Legacy ID: Mig_03b {: .eudi-hlr__meta }

If the User deletes a PID or attestation from their Wallet Unit, the Wallet Unit SHALL delete the corresponding entry from the Migration Object.

AS-WP-34-006SHALL

Legacy ID: Mig_04 {: .eudi-hlr__meta }

The Wallet Unit SHALL store the Migration Object in an external storage or remote storage location of the User's choice, from among the storage options supported by the Wallet Unit, in such a way that the User can still retrieve the object from a new Wallet Unit in case the existing Wallet Unit becomes unavailable.

Note: a) It is up to the Wallet Provider to decide which external storage options or remote storage locations the Wallet Unit supports for storing the Migration Object. b) The new Wallet Unit may be either an instance of the same Wallet Solution as the old one, or an instance of a different Wallet Solution.

AS-WP-34-007SHALL

Legacy ID: Mig_05 {: .eudi-hlr__meta }

The Wallet Unit SHALL store the Migration Object in such a way that its confidentiality, integrity, and authenticity is protected and that it is protected against use by others than the User.

Note: This could be done, for example, by using password-based cryptography to encrypt the object.

AS-WP-34-008SHALL

Legacy ID: Mig_06 {: .eudi-hlr__meta }

Directly after installation of a new Wallet Instance, the Wallet Instance SHALL enable the User to import a Migration Object from an external storage or remote storage location indicated by the User, from among the storage options supported by the Wallet Unit.

AS-WP-34-009SHALL

Legacy ID: Mig_07 {: .eudi-hlr__meta }

When importing a Migration Object, for each PID and device-bound attestation listed in the Migration Object, the Wallet Unit SHALL enable the User to select that PID or attestation. When a PID or device-bound attestation is selected, the Wallet Unit SHALL request the respective PID Provider or Attestation Provider to issue a new PID or attestation of the same type to the new Wallet Unit. If the User selects a PID, the Wallet Unit SHALL request issuance of the PID first, before any of the other selected attestations.

Note: a) Since no refresh tokens (see ISSU_65) will be available on the new Wallet Unit, this is a new issuance process, which will include User authentication by the PID Provider or Attestation

Provider. b) The rationale for the last requirement is to ensure that if other Attestation Providers want to use a PID to do User authentication, the PID is actually available.

AS-WP-34-010SHALL

Legacy ID: Mig_07a {: .eudi-hlr__meta }

When importing a Migration Object, for each non-device-bound attestation listed in the Migration Object, the Wallet Unit SHALL enable the User to select that attestation. When an attestation is selected, the Wallet Unit SHALL, depending on whether the Migration Object contains attribute identifiers and attribute values (see Mig_03a), either restore the technical attestation directly from the Object or request the respective Attestation Provider to issue a new attestation of the same type to the new Wallet Unit.

AS-WP-34-011SHALL

Legacy ID: Mig_07b {: .eudi-hlr__meta }

When importing a Migration Object, the Wallet Unit SHALL ask the User whether they want to restore the log from the Migration Object. When the User agrees, the Wallet Unit SHALL restore the log, and SHALL append future transactions to this log according to the requirements in Topic 19.

AS-WP-34-012

Legacy ID: Mig_08 {: .eudi-hlr__meta }

Empty

AS-WP-34-013

Legacy ID: Mig_09 {: .eudi-hlr__meta }

Empty

AS-WP-34-014

Legacy ID: Mig_10 {: .eudi-hlr__meta }

Empty

AS-WP-34-015SHALL

Legacy ID: Mig_11 {: .eudi-hlr__meta }

The processes and interfaces used for issuance of a PID or attestation as part of a migration process SHALL be the same as those used for a ‘normal’ issuance process, as specified in Topic 10.

AS-WP-34-016

Legacy ID: Mig_12 {: .eudi-hlr__meta }

Empty

AS-WP-34-017

Legacy ID: Mig_13 {: .eudi-hlr__meta }

Empty

AS-WP-34-018

Legacy ID: Mig_14 {: .eudi-hlr__meta }

Empty

AS-WP-34-019

Legacy ID: Mig_15 {: .eudi-hlr__meta }

Empty

AS-WP-34-020

Legacy ID: Mig_16 {: .eudi-hlr__meta }

Empty

AS-WP-38-001SHALL

Legacy ID: WURevocation_01 {: .eudi-hlr__meta }

To enable a PID Provider or an Attestation Provider to verify the authenticity and the revocation status of a Wallet Unit it is interacting with, a Wallet Provider SHALL issue one or more Key Attestations (KA) and Wallet Instance Attestations (WIA) to the Wallet Unit, as specified in Topic 9.

Note: The first of these KAs and WIAs will be issued during the activation phase of a Wallet Unit. During the lifetime of the Wallet Unit, the Wallet Provider will re-issue KAs and WIAs as needed.

AS-WP-38-002

Legacy ID: WURevocation_02 {: .eudi-hlr__meta }

Empty

EW-DM-38-005SHALL

Legacy ID: WURevocation_07 {: .eudi-hlr__meta }

To revoke the Wallet Instance of a Wallet Unit, a Wallet Provider SHALL, in the status list(s) for Wallet Instances, set the `revoked` status at all index positions mentioned in the WIAs issued to that Wallet Instance.

EW-DM-38-007SHALL

Legacy ID: WURevocation_09 {: .eudi-hlr__meta }

During the lifetime of a Wallet Unit, the Wallet Provider SHALL regularly verify that the security of the Wallet Unit is not breached or compromised. If the Wallet Provider detects a security breach or compromise, the Wallet Provider SHALL analyse its cause(s) and impact(s). If the breach or compromise affects the trustworthiness or reliability of the Wallet Unit, the Wallet Provider SHALL revoke the Wallet Unit by revoking the Wallet Instance according to WURevocation_07. The Wallet Provider SHALL do so at least in the following circumstances: - If the security of the Wallet Unit, or the security of the mobile device and OS on which the corresponding Wallet Instance is installed, or the security of the WSCA/WSCD it uses for managing critical cryptographic assets, is breached or compromised in a manner that affects its trustworthiness or reliability. - If the security of the Wallet Solution is breached or compromised in a manner that affects the trustworthiness or reliability of all corresponding Wallet Units. - If the security of the common authentication and data protection mechanisms used by the Wallet Unit is breached or compromised in a manner that affects their trustworthiness or reliability. - If the security of the electronic identification scheme under which the Wallet Unit is provided is breached or compromised in a manner that affects its trustworthiness or reliability.

Note: The first bullet corresponds to a Critical or High Risk level security posture risk status according to the table in Section 6.5.4.2 of the ARF main document, as analysed or detected for a Wallet Instance due to monitoring done according to WPSM_03.

EW-DM-38-008SHALL

Legacy ID: WURevocation_09a {: .eudi-hlr__meta }

If a breach or compromise detected per WURevocation_09 affects the trustworthiness or reliability of a (type of) WSCA/WSCD or keystore, the Wallet Provider SHALL revoke the corresponding (type of) WSCA/WSCD or keystore according to WURevocation_07a.

Note: Per WURevocation_09, a compromise of a type of WSCA/WSCD always leads to the revocation of both that type of WSCA/WSCD and of all Wallet Instances using a WSCA/WSCD of that type.

EW-DM-38-009

Legacy ID: WURevocation_09b {: .eudi-hlr__meta }

Empty

EW-DM-38-010SHALL

Legacy ID: WURevocation_09c {: .eudi-hlr__meta }

If a Wallet Provider revokes a keystore of a Wallet Unit, it SHOULD also revoke the entire Wallet Unit by revoking the Wallet Instance. If the Wallet Provider decides to not revoke the Wallet Instance, it SHALL create a risk analysis showing that this does not lead to unacceptable risks to the User, PID Providers and Attestation Providers, Relying Parties, or the Wallet Provider itself.

Note: If the Wallet Provider does not revoke the Wallet Instance, only the attestations bound to the revoked keystore will be impacted. Other functionalities of the Wallet Unit, including the presentation of a PID, will remain available to the User.

EW-DM-38-011SHALL

Legacy ID: WURevocation_10 {: .eudi-hlr__meta }

A Wallet Provider SHALL revoke a Wallet Unit upon the explicit request of the User registered during the Wallet Unit activation process, see Topic 40. To do so, the Wallet Provider SHALL revoke the Wallet Instance (see WURevocation_07). The Wallet Provider SHALL authenticate the User before accepting a request to revoke the Wallet Unit.

EW-DM-38-012SHALL

Legacy ID: WURevocation_11 {: .eudi-hlr__meta }

A Wallet Provider SHALL revoke a Wallet Unit upon the explicit request of a PID Provider, in case the natural person using the Wallet Unit has died. To do so, the Wallet Provider SHALL revoke the Wallet Instance (see WURevocation_07). To identify the Wallet Unit that is to be revoked, the PID Provider SHALL use a Wallet Instance identifier provided by the Wallet Provider in the WIA during PID issuance.

Note: Under Technical Specification 3, the Wallet Instance identifier used for revocation is conveyed in the WIA (see WUA_08). See also the notes to WUA_08.

EW-DM-38-013SHALL

Legacy ID: WURevocation_12 {: .eudi-hlr__meta }

Before revoking a Wallet Unit per WURevocation_11, the Wallet Provider SHALL verify that the party requesting revocation is indeed a valid PID Provider listed in the LoTE of PID Providers.

EW-DM-38-014SHALL

Legacy ID: WURevocation_13 {: .eudi-hlr__meta }

Before requesting a Wallet Provider to revoke a Wallet Unit per WURevocation_11, the PID Provider SHALL ensure that the revocation does not harm the interests of any of the stakeholders. The PID Provider SHALL include a documented policy ensuring that this is the case in the policy meant in WURevocation_03.

EW-DM-38-015SHALL

Legacy ID: WURevocation_14 {: .eudi-hlr__meta }

A Wallet Provider SHALL inform a User without delay, and within 24 hours at most, in case the Wallet Provider decided to revoke the User's Wallet Unit. The Wallet Provider SHALL also inform the User about the reason(s) for the revocation. This information SHALL be understandable for the general public. It SHALL include (a reference to) technical details about any security breach if applicable. The Wallet Provider SHALL inform the User about the function(s) of the Wallet Unit that remain available to the User, if any, and functions that will not work any more. The Wallet Provider SHALL also inform the User about measures they can take to ensure they have a fully working Wallet Unit again as soon as possible, such as migrating to a different Wallet Solution.

Note: Functions that remain available to the User may include viewing their own attributes in their Wallet Unit and accessing their account at the Wallet Provider.

EW-DM-38-017SHALL

Legacy ID: WURevocation_16 {: .eudi-hlr__meta }

To inform a User about the revocation of their Wallet Unit, the Wallet Provider SHALL use a communication channel that is independent of the Wallet Unit. In addition, the Wallet Provider MAY use the Wallet Unit itself to inform the User.

AS-WP-38-018SHALL

Legacy ID: WURevocation_18 {: .eudi-hlr__meta }

A PID Provider issuing revocable PIDs SHALL, for each of its valid PIDs, regularly verify whether the Wallet Instance on which that PID is residing has been revoked and whether the associated WSCD has been revoked, using the WIA and KA received during issuance of that PID. If either

the Wallet Instance or the WSCD has been revoked, the PID Provider SHALL immediately revoke the respective PID.

Note: a) This requirement aligns with WUA_29, which requires PID Providers to check the revocation status of both the WIA and KA throughout the PID validity period. b) This is a consequence of the legal requirement in CIR 2024/2977, Article 5, 4.(b). c) See Technical Specification 3 for how the PID Provider can do this verification.

AS-WP-38-019SHALL

Legacy ID: WURevocation_19 {: .eudi-hlr__meta }

An Attestation Provider issuing revocable attestations MAY decide to revoke an attestation if the Wallet Provider revoked the Wallet Unit on which that attestation is residing, in the same manner as described in WURevocation_18. An Attestation Provider SHALL publish its policy in this regard.

Note: Publishing its policy regarding revocation allows a Relying Party to decide if it can put sufficient trust in the attestations issued by that Attestation Provider.

AS-WP-40-001SHOULD

Legacy ID: WIAM_01 {: .eudi-hlr__meta }

To ensure that the User can trust the Wallet Solution, a Wallet Provider SHOULD make its certified Wallet Solution available for installation only via the official app store of the relevant operating system (e.g., Android, iOS).

Note: This allows the operating system of the device to perform relevant checks regarding the authenticity of the Wallet Unit.

AS-WP-40-002SHALL

Legacy ID: WIAM_02 {: .eudi-hlr__meta }

If a Wallet Provider makes its certified Wallet Solution available for installation through other means than the official OS app store, it SHALL implement a mechanism allowing the User to verify the authenticity of the Wallet Unit. Moreover, it SHALL provide clear instructions to the User on how to install the Wallet Instance, including at least: - instructions on the verification of the authenticity of the Wallet Instance to be installed, - instructions on bypassing of any operating system limitations on side-loading of apps, if applicable, and ensuring that these limitations are restored after the Wallet Instance has been installed.

Note: This requirement also applies for the installation of a Wallet Instance on a User device that is not a mobile device, and for which no official operating system app store may exist.

AS-WP-40-003SHALL

Legacy ID: WIAM_03 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that a Wallet Instance starts a process to activate the new Wallet Unit with the Wallet Provider immediately after installation or when the User first opens the Wallet Instance. The Wallet Provider SHALL ensure that the Wallet Instance starts this process only with a secure backend of the Wallet Provider.

AS-WP-40-004SHALL

Legacy ID: WIAM_04 {: .eudi-hlr__meta }

During the activation process of a new Wallet Unit, the Wallet Provider SHALL verify that the new Wallet Instance is a genuine instance of its Wallet Solution.

AS-WP-40-005SHALL

Legacy ID: WIAM_05 {: .eudi-hlr__meta }

During the activation process of a new Wallet Unit, the Wallet Provider SHALL process information about the User device and the available WSCA/WSCD and keystore(s), as far as necessary to issue Key Attestations and Wallet Instance Attestations to the Wallet Unit conform all requirements in Topic 9. The Wallet Provider MAY process additional information necessary for managing the Wallet Unit, but it SHALL NOT process more information than it reasonably needs for legitimate purposes. The Wallet Provider SHALL request User consent (through the Wallet Instance) for all information and data it will process, both during activation and throughout the lifetime of the Wallet Unit. The Wallet Provider SHALL inform the User about the purposes of data processing, in accordance with the General Data Protection Regulation.

AS-WP-40-006SHALL

Legacy ID: WIAM_06 {: .eudi-hlr__meta }

The Wallet Provider SHALL request the User, through the new Wallet Instance, to log in to an existing account at the Wallet Provider, or to set up a new User account if the User does not have an account yet. If a new account must be set up, the Wallet Provider SHALL explain to the User that setting up an account is necessary to enable the User to request revocation of the Wallet Unit in case of theft or loss. The Wallet Provider SHALL register one or more User authentication methods that the Wallet Provider will use to authenticate the User in the

future. These methods SHALL be independent of the Wallet Unit and the User device. The Wallet Provider SHALL allow the User to register using an alias instead of true identity data. The Wallet Provider SHALL NOT use any registered User data for purposes other than User authentication, unless the User gives explicit consent to do so. The Wallet Provider SHALL register the relationship between the Wallet Unit and the corresponding User account.

Note: The User may already have an account at the Wallet Provider, for example because they use a Wallet Unit of this Wallet Provider already on another device, or if they are migrating to a new device.

AS-WP-40-007SHALL

Legacy ID: WIAM_07 {: .eudi-hlr__meta }

A Wallet Provider SHALL activate a new Wallet Unit before a User can use it to have issued an PID or attestation.

AS-WP-40-008SHALL

Legacy ID: WIAM_08 {: .eudi-hlr__meta }

A Wallet Provider SHALL only activate a new Wallet Unit if it has verified that the Wallet Unit includes a WSCA/WSCD that is certified to be compliant with applicable requirements for Level of Assurance High.

Note: a) A WSCA/WSCD by definition complies with requirements for Level of Assurance High, see WIAM_14. b) In addition, the Wallet Unit can include one or more keystores.

AS-WP-40-009SHALL

Legacy ID: WIAM_08a {: .eudi-hlr__meta }

If a Wallet Unit contains one or more keystores, the Wallet Provider SHALL assign a security level to every keystore, with the following possible values: `iso_18045_high`, `iso_18045_moderate`, `iso_18045_enhanced-basic`, `iso_18045_basic` or `none`, corresponding to the level of resistance for which the keystore was certified (respectively AVA_VAN.5, AVA_VAN.4, AVA_VAN.3, AVA_VAN.2 and no certification).

Note: For the definition of these security levels, also see OpenID4VCI Annex D.2

AS-WP-40-010SHALL

Legacy ID: WIAM_09 {: .eudi-hlr__meta }

If a WSCA/WSCD or keystore contains cryptographic assets related to multiple Wallet Units, the Wallet Provider SHALL ensure that a Wallet Unit can only access assets that are related to that Wallet Unit.

AS-WP-40-011SHALL

Legacy ID: WIAM_10 {: .eudi-hlr__meta }

During the activation process of a new Wallet Unit, a Wallet Provider SHALL create and sign at least one Key Attestation for the WSCA/WSCD, at least one Key Attestation for each keystore, and at least one Wallet Instance Attestation, and issue them to the Wallet Unit. The Wallet Provider SHALL verify that the private key(s) corresponding to the public key(s) in each KA are protected by the respective WSCA/WSCD or keystore, under control of the User. The Wallet Provider SHALL take measures to verify the integrity of the Wallet Instance before issuing a Wallet Instance Attestation.

AS-WP-40-012SHALL

Legacy ID: WIAM_10a {: .eudi-hlr__meta }

During the activation process of a new Wallet Unit, the Wallet Provider SHALL offer the User a means to verify the formal certification information of their Wallet Solution.

AS-WP-40-013

Legacy ID: WIAM_11 {: .eudi-hlr__meta }

Empty

AS-WP-40-014SHALL

Legacy ID: WIAM_12 {: .eudi-hlr__meta }

All communication between the Wallet Provider and the Wallet Instance SHALL be mutually authenticated and SHOULD be encrypted.

AS-WP-40-015SHALL

Legacy ID: WIAM_12a {: .eudi-hlr__meta }

A Wallet Provider SHALL NOT access the contents of a Wallet Instance, in particular to learn a) which attestations are present on the Wallet Unit, b) the status of these attestations, c) the value of attributes in these attestations, and d) the contents of the Wallet Unit log meant in DASH_02.

AS-WP-40-016SHALL

Legacy ID: WIAM_12b {: .eudi-hlr__meta }

If the contents of a Wallet Unit specified in WIAM_12a are stored in a Wallet Instance on the User's device, the Wallet Instance SHALL ensure that the Wallet Provider cannot access the contents of the Wallet Unit.

AS-WP-40-017SHALL

Legacy ID: WIAM_12c {: .eudi-hlr__meta }

If the contents of a Wallet Unit specified in WIAM_12a are stored in a Wallet Unit Service on the Wallet Provider backend, the Wallet Provider SHALL specify and implement strict controls to limit access by the Wallet Provider to the contents of the Wallet Unit.

Note: In this situation, the Wallet Unit cannot fully prevent the Wallet Provider from accessing the Wallet Unit contents.

AS-WP-40-018SHALL

Legacy ID: WIAM_13 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to 'factory reset' the Wallet Unit, which SHALL cause the deletion of all attestations, the log, and all other personal data, settings, and configurations from the Wallet Unit. If the User resets the Wallet Unit, the Wallet Instance SHALL request the associated WSCA/WSCD and keystore(s) to delete all cryptographic assets related to the Wallet Unit and to all PIDs and device-bound attestations on the Wallet Unit, if the WSCA/WSCD and the keystore(s) are connected to the User device.

Note: a) The User can use this option, for instance, in preparation to the planned uninstallation of the Wallet Instance. b) Deletion of PID or KA cryptographic assets requires User authentication, as specified in requirement WIAM_14. c) The Wallet Unit does not necessarily inform the Wallet Provider about the factory reset. d) It may happen there is no connection to the WSCA/WSCD or to a keystore at the moment the User resets the Wallet Instance. For instance, in case the WSCA/WSCD is an external smart card and the User does not present that card to the User device. Another example occurs when the WSCA/WSCD is a remote HSM and the User device is offline at that moment. In such cases, the cryptographic assets will remain present on the WSCA/WSCD or on the keystore, even though they will never be used again. If needed, it is up to the Wallet Provider to define how the Wallet Unit should handle such situations. For example, an HSM manager could address such cases by deciding to delete cryptographic keys in the HSM that are too old or haven't been used for too long, while being aware of the risks in doing so.

AS-WP-40-019SHALL

Legacy ID: WIAM_13a {: .eudi-hlr__meta }

If the User resets the Wallet Unit, the Wallet Unit SHALL disclose the fact that it no longer stores any previously disclosed PID(s) or attestation(s) to the Digital Credentials API framework.

AS-WP-40-020SHALL

Legacy ID: WIAM_14 {: .eudi-hlr__meta }

A WSCA/WSCD managing the critical assets of a PID, such as private or secret cryptographic keys, SHALL authenticate the User at Level of Assurance High before performing any cryptographic operation involving any of these assets.

Note: a) CIR 2024/2981, Annex IV, section 2 (3) states "As a prerequisite to the certification under national certification schemes, the WSCD shall be assessed against the requirements of assurance level high as set out in Implementing Regulation (EU) 2015/1502." Therefore, a WSCA/WSCD by legal definition complies with requirements of LoA High. b) Note to WIAM_14 - WIAM_14b: Many actions of the Wallet Unit, such as processing a Relying Party presentation request and presenting an attestation, require multiple cryptographic operations, for example ephemeral key generation followed by key agreement and presentation signing and encryption. These requirements does not imply that a separate User authentication is necessary before each of these operations. Rather, a successful User authentication will be valid for all cryptographic operations necessary for a Wallet Unit action. It is up to the Wallet Provider to determine what constitutes a 'Wallet Unit action', finding a balance between security (more User authentications) and User convenience (fewer User authentications). During certification of the Wallet Solution, it will be verified that the solution provides an adequate level of security.

AS-WP-40-021SHALL

Legacy ID: WIAM_14a {: .eudi-hlr__meta }

A WSCA/WSCD managing the critical assets of a KA SHALL authenticate the User at Level of Assurance High before performing any cryptographic operation involving any of these assets.

Note: The WSCA/WSCD manages the private key(s) corresponding to the public key(s) attested in the KA.

AS-WP-40-022SHALL

Legacy ID: WIAM_14b {: .eudi-hlr__meta }

A WSCA/WSCD managing the cryptographic assets of an attestation having a level of security

High SHALL authenticate the User at level of security High before performing any cryptographic operation involving any of these assets.

Note: a) The term 'Level of Assurance', as used in the European Digital Identity Regulation and in Implementing Regulation (EU) 2015/1502, is only applicable to electronic identity means, which in the context of the EUDI Wallet means only the PID. For that reason, this requirement uses the term 'level of security'. Levels of security are defined in standards or specifications different from CIR 2015/1502, for instance ISO/IEC 18045. b) During issuance of an attestation, the Attestation Provider in its Credential Issuer metadata indicates the level of security it requires for the key storage and user authentication for this type of attestation. See OpenID4VCI section 12.2.4 and Appendix D.2.

AS-WP-40-023SHALL

Legacy ID: WIAM_14c {: .eudi-hlr__meta }

A Wallet Unit SHALL use either the WSCA/WSCD or a keystore to manage any cryptographic assets that are not considered to be critical assets.

Note: a) The ARF uses the term 'keystore' to refer to a hardware-backed repository and service in which non-critical cryptographic assets are generated, stored, and used exclusively inside a dedicated hardware security boundary. b) Examples of non-critical cryptographic assets are private and secret keys of attestations having a level of security lower than High. c) As mentioned in WIAM_14 and WIAM_14b, the private and secret keys of PIDs and KAs are critical assets and therefore are stored in a WSCA/WSCD.

AS-WP-40-024SHALL

Legacy ID: WIAM_15 {: .eudi-hlr__meta }

Before performing any operation, including allowing a User to view attestations and attribute values, a Wallet Instance SHALL securely authenticate the User using a multi-factor authentication mechanism provided by the User device.

Note: a) One of the authentication factors is the possession of the User device.

AS-WP-40-025SHALL

Legacy ID: WIAM_15a {: .eudi-hlr__meta }

For the purpose of WIAM_15, the Wallet Instance SHALL enforce the activation of an OS-level User authentication mechanism with adequate security policies.

Note: Adequate' here means adequate for any operation excluding the issuance or presentation of PIDs, KAs, and potentially other attestations at level of security High. This includes but is not limited to generating pseudonyms, accessing the transaction log (dashboard), data export and migration, requesting the erasure of personal data by a Relying Party, and reporting a Relying Party to a DPA.

AS-WP-40-026SHALL

Legacy ID: WIAM_15b {: .eudi-hlr__meta }

The Wallet Unit SHALL enable the User to use a Wallet Unit-specific authentication method for User authentication, in addition to the User authentication mechanism provided by the User device per WIAM_15. The Wallet Provider SHALL either make the use of this additional authentication method mandatory for all Users, or leave it to each User to decide if they want to use it.

Note: a) This authentication method may be implemented by the Wallet Instance, a (local) keystore, the WSCA/WSCD, or any other component of the Wallet Unit. b) As an optimisation to reduce the number of User authentication events, the Wallet Provider can choose to implement this additional authentication method in the WSCA/WSCD, in such a way that it complies with WIAM_14.

AS-WP-40-027SHALL

Legacy ID: WIAM_15c {: .eudi-hlr__meta }

The Wallet Instance SHALL also use the User authentication mechanism provided by the User device (WIAM_15) and possibly the Wallet Unit-specific authentication method (WIAM_15b) to unlock the keystore mentioned in WIAM_14c, where applicable.

Note: Apart from using the same mechanism, the intent of this requirement is also to minimize the number of User authentications needed (after the initial authentication per WIAM_15a) to enable the issuance or presentation of (non-PID) attestations. However, see WIAM_16 and WIAM_16a: the Wallet Provider may request another authentication if this is necessary for security.

AS-WP-40-028SHALL

Legacy ID: WIAM_16 {: .eudi-hlr__meta }

For the User authentication mechanism provided by the User device (WIAM_15), the Wallet Instance SHALL force the User device to enable a time-based control (e.g., a session timeout

or re-authentication interval), to ensure that access is automatically revoked after a defined period of inactivity.

Note: It is assumed that re-authentication is required by the User device when the device is locked by the User.

AS-WP-40-029SHALL

Legacy ID: WIAM_16a {: .eudi-hlr__meta }

For the Wallet Unit-specific User authentication method (WIAM_15b), the Wallet Provider SHALL define and implement conditions after which user authentication shall again be required, including at least an idle timeout. The Wallet Unit SHOULD provide the User with the option to set the idle timeout to a duration shorter than the default timeout set by the Wallet Provider. The Wallet Provider SHOULD also consider other factors, including the device being locked by the User and the Wallet Instance losing focus.

AS-WP-40-030SHALL

Legacy ID: WIAM_17 {: .eudi-hlr__meta }

The Wallet Provider SHALL ensure that the Wallet Unit requests the User, during activation of the Wallet Unit, to set up the authentication factors for the User authentication mechanism implemented by the WSCA/WSCD meant in WIAM_14, the authentication mechanism implemented by the User device meant in WIAM_15 and WIAM_15a, and, if used, the Wallet Unit-specific authentication method meant in WIAM_15b.

AS-WP-40-031

Legacy ID: WIAM_18 {: .eudi-hlr__meta }

Empty

AS-WP-40-032SHALL

Legacy ID: WIAM_19 {: .eudi-hlr__meta }

A WSCA/WSCD and a keystore SHALL be able to prove possession of the private key corresponding to a public key on request of a Wallet Instance, for example by signing a challenge with that private key.

AS-WP-40-033SHALL

Legacy ID: WIAM_20 {: .eudi-hlr__meta }

A WSCA/WSCD SHALL protect a private key it generated during the entire lifetime of the key. This protection SHALL at least imply that the WSCA/WSCD prevents the private key from being extracted in the clear. If a WSCA/WSCD is able to export a private key in encrypted format, the resulting level of protection SHALL be equivalent to the protection level of the private key when stored in the WSCA/WSCD.

AS-WP-40-034SHOULD

Legacy ID: WIAM_21 {: .eudi-hlr__meta }

Whenever the WSCA/WSCD successfully authenticated the User, the Wallet Unit SHOULD check if the WSCD contains cryptographic assets for technical PIDs or attestations that cannot be presented any longer to Relying Parties, for example because they have expired or because a once-only attestation (see Topic 10, section D, method A) was presented to a Relying Party already. The Wallet Unit SHOULD then request the WSCA/WSCD to destroy all cryptographic assets related to these technical PIDs or attestations. However, the Wallet Unit SHOULD NOT request the destruction of the private key belonging to the last technical PID or attestation corresponding to a logical PID or attestation.

Note: a) The reason for this recommendation is that probably, Wallet Providers will want to prevent an accumulation of unused private keys in the WSCA/WSCD, given that such devices typically do not have much storage space. However, deletion of private keys (and potentially other cryptographic assets) is a cryptographic key operation and cannot be done without User authentication - see WIAM_14. At the same time, for usability reasons the User must not be involved in such 'cleaning up' processes, see also ISSU_42. The recommended solution is to take advantage of a User authentication event to also carry out any necessary cleaning operations. b) Method A (once-only attestations, see ISSU_ 37) includes a potential fallback to Method B (limited-time attestations) in case no unused technical PIDs or attestations are left. To ensure that falling back to Method B is always possible when needed, a Wallet Unit should ensure that for every logical PID or attestation it has, it is always in possession of at least one technical PID or attestation.

AS-WP-43-001SHALL

Legacy ID: EDP_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable an Attestation Provider to optionally express an embedded disclosure policy for a QEAA, PuB-EAA, or non-qualified EAA.

Note: The European Digital Identity Regulation does not contain a requirement for PIDs to be able to contain an embedded disclosure policy.

AS-WP-43-002SHALL

Legacy ID: EDP_02 {: .eudi-hlr__meta }

A Wallet Unit SHALL support embedded disclosure policies implementing the ‘Authorised relying parties only policy’ described in Annex III of Implementing Regulation (EU) 2024/2979 and as specified in ETSI TS 119 472-3. If present, such an embedded disclosure policy SHALL contain a list of duplets, where each duplet consists of an EU-wide unique Relying Party identifier in combination with a Service identifier, as specified in Reg_32 and Reg_33. After receiving a presentation request, the Wallet Unit SHALL retrieve the unique identifier and Service identifier of the Relying Party from the registration certificate presented by the Relying Party, and compare them to the list of authorised identifier duplets in the policy for the requested attestation. If the identifier duplet is not included in this list, the Wallet Unit SHALL consider the evaluation of the embedded disclosure policy to have failed, and inform the User.

Note: The Wallet Unit uses the Relying Party identifier and Service identifier in the registration certificate, not the identifiers in the access certificate. This is because if the Relying Party uses the services of an intermediary, the identifiers in the access certificate refer to the intermediary rather than the intermediated Relying Party. The intermediary is not relevant for the purposes of an EDP.

AS-WP-43-003SHALL

Legacy ID: EDP_03 {: .eudi-hlr__meta }

A Wallet Unit SHALL support embedded disclosure policies implementing the ‘Specific root of trust’ policy described in Annex III of Implementing Regulation (EU) 2024/2979 and as specified in ETSI TS 119 472-3. If present, such an embedded disclosure policy SHALL contain a list of root or intermediate certificates used for signing Relying Party registration certificates. After receiving a presentation request, the Wallet Unit SHALL compare all certificates in the certificate chain that was used to sign the registration certificate provided by the Relying Party to the list of authorised root or intermediate certificates in the policy for the requested attestation. If none of these certificates are included in this list, the Wallet Unit SHALL consider the evaluation of the embedded disclosure policy to have failed, and inform the User.

Note: See EDP_02 for why the Wallet Unit uses the certificate chain of the registration certificate rather than the one of the access certificate.

AS-WP-43-004SHALL

Legacy ID: EDP_05 {: .eudi-hlr__meta }

An embedded disclosure policy SHOULD contain a link to a website of the Attestation Provider explaining the disclosure policy in layman's terms. If this is the case, the Wallet Unit SHALL display the link to the User and allow them to navigate to that website.

AS-WP-43-005SHALL

Legacy ID: EDP_06 {: .eudi-hlr__meta }

The Wallet Unit SHALL evaluate an embedded disclosure policy in conjunction with the information received from the requesting Relying Party in the registration certificate, in order to determine if the Relying Party has permission from the Attestation Provider to access the requested attestation. The Wallet Unit SHALL perform this evaluation in compliance with the evaluation rules established in ETSI TS 119 472-3.

AS-WP-43-006SHALL

Legacy ID: EDP_07 {: .eudi-hlr__meta }

The Wallet Unit SHALL enable the User, based on the outcome of the evaluation of the applicable embedded disclosure policy(s), to deny or allow the presentation of the requested attestation to the Relying Party.

AS-WP-43-007SHALL

Legacy ID: EDP_08 {: .eudi-hlr__meta }

The format of an embedded disclosure policy SHALL comply with ETSI TS 119 472-3.

AS-WP-43-008SHALL

Legacy ID: EDP_10 {: .eudi-hlr__meta }

During attestation issuance, a Wallet Unit SHALL retrieve and store the corresponding embedded disclosure policy, if any.

Note: The intent of this requirement is that the Wallet Unit is able to evaluate an EDP during a presentation transaction, without needing to request it again from the Attestation Provider. This is necessary in particular during proximity presentations, which must be able to be done without an internet connection.

AS-WP-48-001SHALL

Legacy ID: DATA_DLT_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL support the possibilities mentioned in DATA_DLT_02, allowing a User to request from a Relying Party the erasure of their attributes that were presented by that Wallet Unit to that Relying Party, in accordance with Article 17 of Regulation (EU) 2016/679.

AS-WP-48-002

Legacy ID: DATA_DLT_04 {: .eudi-hlr__meta }

Empty

AS-WP-48-003SHALL

Legacy ID: DATA_DLT_05 {: .eudi-hlr__meta }

A Wallet Unit SHALL include the initiation of a data deletion request in a log, so it can be displayed to the User via the dashboard as specified in Topic 19.

Note: Because the request is sent by an external web browser, e-mail client, or phone client (see DATA_DLT_02), the Wallet Unit can only log the initiation of the request.

AS-WP-48-004SHALL

Legacy ID: DATA_DLT_08 {: .eudi-hlr__meta }

Wallet Units, Relying Parties, and Registrars SHALL comply with the relevant requirements in Technical Specification 7.

AS-WP-50-001SHALL

Legacy ID: RPT_DPA_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL enable the User to start the process of reporting a suspicious presentation request to a DPA. When prompted by the User, a Wallet Unit SHALL provide the contact details of the DPA which supervises the Relying Party that made the suspicious request, available in the log for that request (see DASH_03). In addition, the Wallet Unit MAY also provide the contact details of the DPA of the region in which the Wallet Provider is residing, or of other DPAs, taken from the European Data Protection Board website (https://www.edpb.europa.eu/about-edpb/about-edpb/members_en).

AS-WP-50-002SHALL

Legacy ID: RPT_DPA_02 {: .eudi-hlr__meta }

The Wallet Unit SHALL offer the User the option to report a suspicious request to a DPA via the transaction log presented in the dashboard, see Topic 19.

AS-WP-50-003SHALL

Legacy ID: RPT_DPA_02a {: .eudi-hlr__meta }

A Wallet Unit SHALL support at least the following possibilities to report a suspicious presentation request to a DPA, depending on what contact details are available for the DPA: a) Open a URL in an external browser to report the request in a web form provided by the DPA. b) Open an external e-mail client and start a draft e-mail to the DPA, with a suitable template text, c) open an external phone client and start a phone call.

AS-WP-50-004SHALL

Legacy ID: RPT_DPA_04 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that a Wallet Unit allows its User to substantiate a report sent to a DPA, including by attaching relevant information to identify the Relying Party and the Users' claims in a machine-readable format.

Note: The log kept by the Wallet Unit is standardised in Technical Specification 10 and is machine-readable in order to enable data portability. An excerpt from this log therefore can be used to substantiate the report.

AS-WP-50-005SHALL

Legacy ID: RPT_DPA_05 {: .eudi-hlr__meta }

A Wallet Unit SHALL log the fact that it initiated the sending of a report to a DPA (see RPT_DPA_02a), as specified in Topic 19.

AS-WP-50-006SHALL

Legacy ID: RPT_DPA_06 {: .eudi-hlr__meta }

Wallet Units, Data Protection Authorities, and Registrars SHALL comply with the relevant requirements in Technical Specification 8.

AS-WP-51-001SHALL

Legacy ID: PAD_01 {: .eudi-hlr__meta }

A Wallet Unit SHALL at any time enable the User to delete any PID or attestation from their Wallet Unit.

AS-WP-51-002SHALL

Legacy ID: PAD_02 {: .eudi-hlr__meta }

If the User indicates that a logical PID or attestation must be deleted, and the Wallet Unit contains multiple physical PIDs or attestations corresponding to that logical PID or attestation, a Wallet Unit SHALL delete all of these physical PIDs and attestations simultaneously.

Note: a) This situation may occur if the PID Provider or Attestation Provider issued a batch of physical PIDs or attestations to the Wallet Unit, rather than a single one. b) Physical PIDs or attestations correspond to a logical one if they have not only the same attestation type and Provider, but also the same attribute values. In principle, the same Provider can issue two attestations of the same type to the same Wallet Unit, for example two diplomas from the same university. This corresponds to the notion of a Credential Dataset in OpenID4VCI.

AS-WP-51-003SHALL

Legacy ID: PAD_03 {: .eudi-hlr__meta }

If the Wallet Unit deletes a PID or attestation on the User's request, the Wallet Unit SHALL NOT notify the respective PID Provider or Attestation Provider.

Note: This is a matter of User privacy.

AS-WP-51-004SHALL

Legacy ID: PAD_04 {: .eudi-hlr__meta }

If the Wallet Unit deletes a PID or device-bound attestation on the User's request, the Wallet Unit SHALL ensure that all cryptographic assets in the WSCA/WSCD or keystores related to this PID or attestation are securely destroyed.

Note: Key deletion for a PID key is a cryptographic key operation and requires User authentication, as specified in requirement WIAM_14.

AS-WP-51-005SHALL

Legacy ID: PAD_05 {: .eudi-hlr__meta }

If a Wallet Unit deletes, on the User's request, a PID or attestation previously disclosed to the Digital Credentials API framework, the Wallet Instance SHALL disclose the fact that it no longer stores this PID or attestation to the Digital Credentials API framework.

AS-WP-51-006

Legacy ID: PAD_06 {: .eudi-hlr__meta }

Empty

AS-WP-54-001SHALL

Legacy ID: ACC_01 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Units comply with applicable requirements and standards in Directive 2016/2012 on the accessibility of websites and mobile applications of public sector bodies.

Note: Compliance with the European Standard ETSI EN 301 549 V1.1.2 (2015-04) provides a presumption of conformity to the Accessibility Directive.

AS-WP-54-002SHALL

Legacy ID: ACC_02 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Units comply with accessibility requirements for products and services established under Directive (EU) 2019/882.

Note: Compliance with the European Standard ETSI EN 301 549 V1.1.2 (2015-04) potentially provides a presumption of conformity to this Directive.

AS-WP-56-001SHALL

Legacy ID: WPSM_01 {: .eudi-hlr__meta }

A Wallet Provider SHALL monitor their installed base of operational Wallet Instances for maintenance purposes, and determine and document in a transparent manner the data it needs and is allowed to monitor in order to deliver the required support. Data or attributes that SHOULD be monitored include: 1) Runtime errors, for uncaught errors in production code, 2) UX and telemetry information, for UX field analysis, 3) OS version and health information, for detection of OS level vulnerabilities, 4) Wallet Instance SDK and software library version information, for Wallet Instance code vulnerabilities, 5) User locale/localisation data, for catching localisation related errors, 6) Wallet Instance version, for catching errors or vulnerabilities due to outdated versions, 7) Supported WSCA/WSCDs and keystores and their supported capabilities, for detection of cryptography incompatibilities, 8) Unique device identifier such as IDFV or persisted UUID (iOS) or AndroidID (Android), for maintaining an up-to-date list of Wallet Instance-related device installations and for detecting potential malicious use (unrecognised identifier), 9) Device sensor identifiers and patch levels, for checking if sensor hardware in the device is up-to-date. 10) hardware-level details about the device, to identify known hardware-based problems or vulnerabilities, 11) BLE and NFC support by device, for analysing the security and feasibility of proximity use cases with a given Wallet Instance.

AS-WP-56-002SHALL

Legacy ID: WPSM_02 {: .eudi-hlr__meta }

Wallet Providers SHALL, for maintenance purposes, write custom crash logs for sending them for further analysis.

AS-WP-56-003SHALL

Legacy ID: WPSM_03 {: .eudi-hlr__meta }

A Wallet Provider SHALL monitor the security posture of its operational Wallet Instances for the purpose of detecting critical security risks in the environment the Wallet Instance is run at, and determine and document in a transparent manner the data it needs and is allowed to monitor. Information that SHOULD be monitored for software and hardware level problems/vulnerabilities on device includes 1) detection of device rooting/jailbreaking, 2) emulator detection, 3) device OS version and health data, 4) Wallet Instance SDK and SW library versions, 5) Wallet Instance version, 6) Supported WSCA/WSCD and keystore(s) and 7) Sensor identifiers and patch levels.

AS-WP-56-004SHALL

Legacy ID: WPSM_04 {: .eudi-hlr__meta }

During the lifetime of the Wallet Unit, the Wallet Provider SHALL update the Wallet Unit as necessary to ensure its continued security and functionality.

---

2. Member States & Registrars

These requirements are for the public bodies that establish the legal and trust infrastructure. They focus on establishing registries, notifying the Commission, and defining national policies.

AS-MS-18-001SHALL

Legacy ID: ACP_02 {: .eudi-hlr__meta }

A Cryptographic Binding of Attestations scheme SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

AS-MS-25-001

Legacy ID: CAT_01 {: .eudi-hlr__meta }

Empty

AS-MS-25-002

Legacy ID: CAT_01a {: .eudi-hlr__meta }

Empty

AS-MS-25-003

Legacy ID: CAT_01b {: .eudi-hlr__meta }

Empty

AS-MS-25-004

Legacy ID: CAT_02 {: .eudi-hlr__meta }

Empty

AS-MS-25-005

Legacy ID: CAT_03 {: .eudi-hlr__meta }

Empty

AS-MS-25-006

Legacy ID: CAT_03b {: .eudi-hlr__meta }

Empty

AS-MS-25-007SHALL

Legacy ID: CAT_04 {: .eudi-hlr__meta }

A request to include or to modify an attribute in the catalogue of attributes SHALL indicate how a QTSP can use the verification point for that attribute.

Note: This could be, for instance, in the form of (a reference to) an endpoint description text.

AS-MS-27-001SHALL

Legacy ID: Reg_01 {: .eudi-hlr__meta }

Member States SHALL provide processes and mechanisms for PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers, and Relying Parties to register in a registry.

Note: Member States may choose to implement a single registry for all these roles, or a separate registry for each of these roles.

AS-MS-27-002SHALL

Legacy ID: Reg_01a {: .eudi-hlr__meta }

Member States SHALL register a common set of data about a) PID Providers, b) QEAA Providers, c) PuB-EAA Providers, d) non-qualified EAA Providers. and e) Relying Parties, according to the relevant requirements in Technical Specification 6.

Note: For PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers, the common set of data specified in Technical Specification 6 include the attestation type(s) that the provider intends to issue to Wallet Units.

AS-MS-27-003SHALL

Legacy ID: Reg_01b {: .eudi-hlr__meta }

Member States SHALL collect the following information only for the purpose of transparency and SHALL NOT apply any pre-authorisation process on it: i) Contact information of the registering entity, ii) description of its services, iii) Attributes registered for each intended use (for Relying Parties), or types of attestation registered (for PID Providers and Attestation Providers), iv) Description of each intended use (for Relying Parties).

AS-MS-27-004SHALL

Legacy ID: Reg_02 {: .eudi-hlr__meta }

Member States SHALL make publicly available all necessary details and documentation about the registration processes for their registry.

AS-MS-27-005SHALL

Legacy ID: Reg_03 {: .eudi-hlr__meta }

Member States SHALL publish the registry entries online, in a sealed or signed machine-readable common format suitable for automated processing, according to the relevant requirements in Technical Specification 5, for the purpose of transparency to Users and other stakeholders.

AS-MS-27-006SHALL

Legacy ID: Reg_04 {: .eudi-hlr__meta }

Member States SHALL make the registry entries available online, in a human-readable format. The website used for this purpose SHALL use a secure channel protecting the authenticity and integrity of the information in the registry during transport. Member States SHALL NOT require authentication or prior registration and authorisation of any person wishing to retrieve the information in the registry.

AS-MS-27-007

Legacy ID: Reg_05 {: .eudi-hlr__meta }

Empty

AS-MS-27-008SHALL

Legacy ID: Reg_06 {: .eudi-hlr__meta }

Member States SHALL support the common API specified in Technical Specification 5 to enable automated retrieval of registry entries from the Member States' registries.

Note: Technical Specification 5 specifies the use of a secure channel protecting the authenticity and integrity of the information in the registry during transport, and does not require authentication or prior registration and authorisation of any entity wishing to retrieve the information in the registry.

AS-MS-27-009SHALL

Legacy ID: Reg_07 {: .eudi-hlr__meta }

A Member State SHALL enable a registered PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party to update the information registered on it, using a process comparable to the original registration process. For Relying Parties, this SHALL be possible using the API or user interface mentioned in Reg_24.

AS-MS-27-010SHALL

Legacy ID: Reg_08 {: .eudi-hlr__meta }

A registered PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party SHALL make any updates necessary to ensure the continued correctness of the registered information without undue delay.

AS-MS-27-011SHALL

Legacy ID: Reg_09 {: .eudi-hlr__meta }

Member States SHALL log all changes made on the information registered regarding a PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party, including at least initial registration, updates, deletion of information, and suspension or cancellation.

AS-MS-27-012SHALL

Legacy ID: Reg_10 {: .eudi-hlr__meta }

A Member State SHALL ensure that an Access Certificate Authority notified according to Topic 31] issues one or more access certificates to all PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers and Relying Parties registered in one of the Member State's registries.

Note: To be able to authenticate towards Wallet Units, each Relying Party Instance of a Relying Party and each service supply point of a PID Provider or Attestation Provider needs a separate access certificate, where the private key corresponding to the public key in the certificate is managed in the hardware and software of the Relying Party Instance or service supply point.

AS-MS-27-013SHALL

Legacy ID: Reg_10a {: .eudi-hlr__meta }

A registering entity SHALL register one or more Services, and SHALL receive at least one access certificate for each registered Service, complying with Reg_33 and Reg_34.

Note: a) If the registering entity registers only one Service, all of its access certificates will contain an identical Service identifier and Service trade name. b) A single Relying Party Instance or service supply point may receive multiple access certificates, corresponding to multiple Services of the same Relying Party or Attestation Provider. This would enable the entity to use the same Relying Party Instance or supply point for multiple Services.

AS-MS-27-014SHALL

Legacy ID: Reg_10b {: .eudi-hlr__meta }

When issuing an access certificate to a PID Provider, Attestation Provider, or Relying Party, an Access Certificate Authority SHALL also send the signing certificate and, if present, any intermediate certificate(s) leading up to the corresponding trust anchor of the Access CA in the respective LoTE published by the Commission.

AS-MS-27-015SHALL

Legacy ID: Reg_10c {: .eudi-hlr__meta }

The registering entity SHALL receive at least one registration certificate for each registered Service, complying with RPRC_07a.

Note: If the registering entity registers only one Service, all of its registration certificates will contain an identical Service identifier and Service trade name.

AS-MS-27-016SHALL

Legacy ID: Reg_10d {: .eudi-hlr__meta }

A Relying Party SHALL register which of its registered intended uses are applicable to each of its registered Services.

Note: Another way to phrase this is to say that the Relying Party must register the intended use(s) of each of it registered Services separately.

AS-MS-27-017SHALL

Legacy ID: Reg_10e {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL register which type(s) of attestation each of its registered Services intends to issue to Wallet Units.

AS-MS-27-018SHALL

Legacy ID: Reg_11 {: .eudi-hlr__meta }

A Member State SHALL ensure that the issuance process of access certificates by their notified Access Certificate Authority(s) complies with ETSI TS 119 411-8. An Access Certificate Authority SHALL have a policy governing all aspects of access certificate issuance and management complying with this standard.

AS-MS-27-019SHALL

Legacy ID: Reg_12 {: .eudi-hlr__meta }

An Access CA SHALL be able to revoke an access certificate, if it has a validity period of longer than 24 hours

AS-MS-27-020SHALL

Legacy ID: Reg_13 {: .eudi-hlr__meta }

An Access CA SHALL have a policy specifying under which conditions an access certificate it issued will be revoked.

AS-MS-27-021

Legacy ID: Reg_14 {: .eudi-hlr__meta }

Empty

AS-MS-27-022

Legacy ID: Reg_15 {: .eudi-hlr__meta }

Empty

AS-MS-27-023

Legacy ID: Reg_16 {: .eudi-hlr__meta }

Empty

AS-MS-27-024

Legacy ID: Reg_17 {: .eudi-hlr__meta }

Empty

AS-MS-27-025

Legacy ID: Reg_18 {: .eudi-hlr__meta }

Empty

AS-MS-27-026SHALL

Legacy ID: Reg_19 {: .eudi-hlr__meta }

A Member State SHALL approve a PID Provider according to a well-defined policy before including it in its PID Provider Registry. To that end, a Member State SHALL define specific vetting processes and rules of acceptance for inclusion of PID Providers in its Registry.

AS-MS-27-027SHALL

Legacy ID: Reg_20 {: .eudi-hlr__meta }

A Member State SHALL identify PID Providers at a level of confidence proportionate to the risk arising from the potential harm a fraudulent PID Provider could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

AS-MS-27-028SHALL

Legacy ID: Reg_20a {: .eudi-hlr__meta }

A Registrar SHALL provide a method to suspend or cancel a registered PID Provider.

AS-MS-27-029SHALL

Legacy ID: Reg_20b {: .eudi-hlr__meta }

A Registrar SHALL have a policy for the suspension or cancellation of a registered PID Provider, which SHALL specify that a PID Provider is suspended or cancelled at least on request of the PID Provider or of a competent national authority.

AS-MS-27-030SHALL

Legacy ID: Reg_21 {: .eudi-hlr__meta }

A Member State SHALL approve an Attestation Provider according to a well-defined policy before including it in its Attestation Provider Registry. To that end, a Member State SHALL define specific vetting processes and rules of acceptance for inclusion of Attestation Providers in its Registry. These processes and rules SHOULD consider any relevant differences between QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers.

AS-MS-27-031SHALL

Legacy ID: Reg_22 {: .eudi-hlr__meta }

A Member State SHALL identify Attestation Providers (i.e., QEAA Providers, PuB-EAA Providers and non-qualified EAA Providers) at a level of confidence proportionate to the risk arising from the potential harm a fraudulent Attestation Provider could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

AS-MS-27-032SHALL

Legacy ID: Reg_22a {: .eudi-hlr__meta }

A Registrar SHALL provide a method to suspend or cancel a registered Attestation Provider.

AS-MS-27-033SHALL

Legacy ID: Reg_22b {: .eudi-hlr__meta }

A Registrar SHALL have a policy for the suspension or cancellation of a registered Attestation Provider, which SHALL specify that an Attestation Provider is suspended or cancelled at least on request of the Attestation Provider or of a competent national authority.

AS-MS-27-034

Legacy ID: Reg_23 {: .eudi-hlr__meta }

Empty

AS-MS-27-035SHALL

Legacy ID: Reg_24 {: .eudi-hlr__meta }

A Member State SHALL enable a Relying Party to register remotely, using an API or user interface.

AS-MS-27-036SHALL

Legacy ID: Reg_25 {: .eudi-hlr__meta }

A Member State SHALL identify a Relying Party at a level of confidence proportionate to the risk arising from the potential harm a fraudulent Relying Party could cause to Users and other stakeholders in the EUDI Wallet ecosystem.

AS-MS-27-037SHALL

Legacy ID: Reg_26 {: .eudi-hlr__meta }

With respect to Reg_25, a Member State SHALL consider whether a registering entity intends to act as an intermediary.

Note: According to the European Digital Identity Regulation, an intermediary is a Relying Party.

AS-MS-27-038

Legacy ID: Reg_27 {: .eudi-hlr__meta }

Empty

AS-MS-27-039

Legacy ID: Reg_28 {: .eudi-hlr__meta }

Empty

AS-MS-27-040SHALL

Legacy ID: Reg_29 {: .eudi-hlr__meta }

A Member State SHALL have a policy for the cancellation of a registered Relying Party, which SHALL specify that a Relying Party is cancelled at least on request of the Relying Party or of a competent national authority.

AS-MS-27-041

Legacy ID: Reg_30 {: .eudi-hlr__meta }

Empty

AS-MS-27-042SHALL

Legacy ID: Reg_31 {: .eudi-hlr__meta }

An access certificate SHALL contain a trade name for the entity (i.e., the PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party), in a format suitable for presenting to a User. This name SHALL be identical to the name for the entity registered according to Technical Specification 6 and included in the entity's registration certificate(s) according to RPRC_06.

AS-MS-27-043SHALL

Legacy ID: Reg_32 {: .eudi-hlr__meta }

An access certificate SHALL contain an EU-wide unique identifier for the entity (i.e., the PID Provider, QEAA Provider, PuB-EAA Provider, non-qualified EAA Provider, or Relying Party), which SHALL be identical to the identifier for the entity registered according to Technical Specification 6 and included in the entity's registration certificate(s) according to RPRC_07.

AS-MS-27-044SHALL

Legacy ID: Reg_32a {: .eudi-hlr__meta }

The trade name meant in Reg_31 and the identifier meant in Reg_32 SHALL be the same in all access certificates issued to a given entity.

AS-MS-27-045SHALL

Legacy ID: Reg_33 {: .eudi-hlr__meta }

An access certificate SHALL contain a Relying Party Service identifier, which SHALL be provided by the registering entity according to Technical Specification 5 and Technical Specification 6, and SHALL be unique within the scope of that entity. Moreover, it SHALL be included in the entity's registration certificate according to RPRC_07a.

AS-MS-27-046SHALL

Legacy ID: Reg_34 {: .eudi-hlr__meta }

An access certificate SHALL contain a trade name for the Relying Party Service, which SHALL be provided by the registering entity according to Technical Specification 5 and Technical Specification 6, and SHALL be suitable for presenting to a User.

AS-MS-27-047SHALL

Legacy ID: Reg_34a {: .eudi-hlr__meta }

If the subject of the access certificate is an intermediary (see Topic 52), the 'association to the wallet-relying party that is relying upon the intermediary' mentioned in Annex I (16) of CIR 2025/848 (and referenced in Annex IV, point 3(k) of that CIR) SHALL consist of the unique identifier of this Relying Party as meant in requirement Reg_32 and its Relying Party Service identifier as meant in Reg_33.

Note: a) This implies that an intermediary receives a separate set of access certificates for each of its intermediated Relying Parties. b) The association is also included in the registration certificates of the intermediated Relying Parties, see RPRC_04.

AS-MS-27-048SHALL

Legacy ID: Reg_35 {: .eudi-hlr__meta }

The access certificate format SHALL provide for the data elements to carry the elements mentioned in Reg_31 - Reg_34a.

Note: The generic X.509 certificate structure has multiple suitable data elements which could be designated for these elements.

AS-MS-28-001

Legacy ID: LP_01 {: .eudi-hlr__meta }

Empty

AS-MS-29-001SHALL

Legacy ID: RP_01 {: .eudi-hlr__meta }

Attestation Scheme Providers MAY create one or multiple Attestation Rulebooks for representation attestations issued to a natural person representing another natural person. Each Rulebook SHALL specify the unique attestation type of these representation attestations. The Rulebook SHALL also specify attributes used for defining a validity period, the nature of the representation, and the operations the representative is authorised to perform, thereby limiting the scope of its authorisation.

AS-MS-31-001SHALL

Legacy ID: GenNot_01 {: .eudi-hlr__meta }

Member States SHALL notify all PID Providers, PuB-EAA Providers, Wallet Providers, Access Certificate Authorities, and Providers of registration certificates to the European Commission, using a common system provided by the Commission, complying with all relevant requirements inTechnical Specification 2.

AS-MS-31-002SHALL

Legacy ID: GenNot_02 {: .eudi-hlr__meta }

In addition to Technical Specification 2 referred to in GenNot_01, the European Commission SHALL establish standard operating procedures for the notification of a PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority, or Provider of registration certificates to the Commission.

Note: The outcome of the notification procedure is the publication of the information notified by the Member State according to Article 5a (18) in a machine and human readable manner using the common system mentioned in Section H, TLPub_01.

AS-MS-31-003SHALL

Legacy ID: GenNot_03 {: .eudi-hlr__meta }

The common system mentioned in GenNot_01 SHALL enable: - A secure notification channel between Member States and the Commission for all notifications. - A notification, verification, and publication process and associated validation steps (with follow-up and monitoring) at the Commission side. - Collected data to be processed, consolidated, signed or sealed, and published in both a machine-processable LoTE and in a human-readable format, manually and/or automatically using e.g. a web service and/or API.

AS-MS-31-004

Legacy ID: GenNot_04 {: .eudi-hlr__meta }

Empty

AS-MS-31-005SHALL

Legacy ID: GenNot_05 {: .eudi-hlr__meta }

In addition to Technical Specification 2 referred to in GenNot_01, the European Commission SHALL establish standard operating procedures for the suspension or cancellation of a PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority, or Provider of registration certificates. These operating procedures SHALL include unambiguous conditions for suspension or cancellation. As an outcome of the suspension or cancellation procedure, the Commission SHALL change the status of the suspended or cancelled PID Provider, PuB-EAA Provider, Wallet Provider, Access Certificate Authority or Provider of registration certificates in the respective LoTE to Invalid.

AS-MS-31-006

Legacy ID: PPNot_01 {: .eudi-hlr__meta }

Empty

AS-MS-31-007SHALL

Legacy ID: PPNot_03 {: .eudi-hlr__meta }

PID Providers SHALL ensure that all PIDs they issue can be authenticated using the PID Provider trust anchors notified to the Commission.

AS-MS-31-008SHALL

Legacy ID: PPNot_03a {: .eudi-hlr__meta }

PID Providers SHALL ensure that all Attestation Status Lists or Attestation Revocation Lists used to revoke their PIDs can be authenticated using the trust anchors for PID revocation lists notified to the Commission.

AS-MS-31-009SHALL

Legacy ID: PPNot_04 {: .eudi-hlr__meta }

PID Providers SHALL ensure that their access certificates can be authenticated using the applicable Access Certificate Authority trust anchors notified to the Commission.

Note: Topic 6] describes how access certificates will be used.

AS-MS-31-010SHALL

Legacy ID: PPNot_05 {: .eudi-hlr__meta }

Wallet Units, Relying Parties, and other relevant actors SHALL accept PID Provider trust anchors and the trust anchors for PID revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled PID Provider LoTE, which is sealed by the Commission.

AS-MS-31-011SHALL

Legacy ID: PPNot_06 {: .eudi-hlr__meta }

Wallet Units and other relevant actors SHALL accept Access Certificate Authority trust anchors because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled LoTE, which is signed or sealed by the Commission.

AS-MS-31-012SHALL

Legacy ID: PPNot_07 {: .eudi-hlr__meta }

The format of a PID Provider LoTE SHALL comply with ETSI TS 119 602, including Annex D.

AS-WP-31-009

Legacy ID: PuBPNot_01 {: .eudi-hlr__meta }

Empty

AS-MS-31-013SHALL

Legacy ID: PuBPNot_03 {: .eudi-hlr__meta }

The format of the PuB-EAA Provider LoTE SHALL comply with ETSI TS 119 602, including Annex H.

AS-MS-31-014SHALL

Legacy ID: PuBPNot_04 {: .eudi-hlr__meta }

PuB-EAA Providers SHALL ensure that all PuB-EAAs they issue can be authenticated using the trust anchors notified to the Commission.

AS-MS-31-015SHALL

Legacy ID: PuBPNot_05 {: .eudi-hlr__meta }

PuB-EAA Providers SHALL ensure that all Attestation Status Lists and Attestation Revocation Lists used to revoke their PuB-EAAs can be authenticated using the trust anchors for PuB-EAA revocation lists notified to the Commission.

AS-MS-31-016SHALL

Legacy ID: PuBPNot_06 {: .eudi-hlr__meta }

Relying Parties and other relevant actors SHALL accept PuB-EAA Provider trust anchors and the trust anchors for PuB-EAA Provider revocation lists because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled PuB-EAA Provider LoTE, which is sealed by the Commission.

AS-MS-31-017

Legacy ID: RPACANot_01 {: .eudi-hlr__meta }

Empty

AS-MS-31-019SHALL

Legacy ID: RPACANot_03 {: .eudi-hlr__meta }

An Access Certificate Authority SHALL ensure that the access certificates it issues to Relying Parties, PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers can be authenticated using the trust anchors notified to the Commission.

AS-MS-31-020SHALL

Legacy ID: RPACANot_03a {: .eudi-hlr__meta }

A Provider of registration certificates SHALL ensure that the registration certificates it issues to Relying Parties, PID Providers, QEAA Providers, PuB-EAA Providers, and non-qualified EAA Providers can be authenticated using the trust anchors notified to the Commission.

AS-MS-31-021SHALL

Legacy ID: RPACANot_03b {: .eudi-hlr__meta }

Access Certificate Authorities or Providers of registration certificates SHALL ensure that all lists used to revoke their access certificates and registration certificates can be authenticated using the trust anchors for revocation lists notified to the Commission.

AS-MS-31-022SHALL

Legacy ID: RPACANot_04 {: .eudi-hlr__meta }

The trust anchors of Access Certificate Authorities and Providers of registration certificates, as well as their CRL trust anchors, SHALL be accepted because of their secure notification by the Member States to the Commission and by their publication in the corresponding Commission-compiled LoTEs, which are signed or sealed by the Commission.

AS-MS-31-023SHALL

Legacy ID: RPACANot_05 {: .eudi-hlr__meta }

The format of a LoTE for Access Certificate Authorities SHALL comply with ETSI TS 119 602, including Annex F.

AS-MS-31-024SHALL

Legacy ID: RPACANot_05a {: .eudi-hlr__meta }

The format of a LoTE for Providers of registration certificates SHALL comply with ETSI TS 119 602, including Annex G.

AS-MS-31-026SHALL

Legacy ID: RPACANot_07 {: .eudi-hlr__meta }

If a Provider of registration certificates is suspended or cancelled (see requirement GenNot_05 above), that Provider SHALL immediately revoke all of its valid registration certificates (if any). Moreover, the corresponding Registrar SHALL prohibit all access to the registry entries published online per Reg_03 and Reg_04.

AS-MS-31-027SHALL

Legacy ID: TLPub_07 {: .eudi-hlr__meta }

The Commission SHALL publish in the OJEU the trust anchors to be used for verifying the signature or seal mentioned in TLPub_05.

AS-MS-55-001SHALL

Legacy ID: CT_01 {: .eudi-hlr__meta }

An Access CA issuing access certificates SHALL register these in a CT log according to RFC 9162, if such a log is available for access certificates.

AS-MS-55-002SHALL

Legacy ID: CT_02 {: .eudi-hlr__meta }

An Access CA issuing access certificates SHALL describe in its CPS how it logs all access certificates.

AS-MS-55-003SHALL

Legacy ID: CT_03 {: .eudi-hlr__meta }

In case a CT log provider for access certificates is available, all Access CAs SHALL act as monitors in the CT ecosystem. Access CAs SHOULD still monitor the CT logs in situations of temporary unavailability.

AS-MS-55-004SHALL

Legacy ID: CT_04 {: .eudi-hlr__meta }

An Access CA SHALL include at least one Signed Certificate Timestamp (SCT) in each access certificate.

AS-MS-55-005SHALL

Legacy ID: CT_05 {: .eudi-hlr__meta }

When verifying an access certificate during PID or attestation issuance or presentation, a Wallet Unit SHALL also verify that the access certificate includes at least one valid Signed Certificate Timestamp (SCT).

AS-MS-55-006SHALL

Legacy ID: CT_06 {: .eudi-hlr__meta }

If an access certificate does not include a valid SCT, a Wallet Unit SHALL handle this as a failure or Relying Party authentication, in compliance with all requirements in Topic 6] and in particular requirement RPA_06a.

---

3. Attestation & PID Providers

These requirements are for the organizations that issue digital credentials to the wallet. This includes requirements for identity verification, issuance protocols, data formats, and revocation policies.

AS-AP-07-001SHALL

Legacy ID: VCR_01 {: .eudi-hlr__meta }

A PID Provider, QEAA Provider, or PuB-EAA Provider SHALL use one of the following methods for revocation of an ISO/IEC 18013-5-compliant PID, QEAA, or PuB-EAA: - Only issue short-lived attestations having a validity period of 24 hours or less, such that revocation will never be necessary, - Use an Attestation Status List mechanism specified per VCR_11, or - Use an Attestation Revocation List mechanism specified per VCR_11.

Note: The 24-hour period originates from ETSI EN 319 411-1 V1.4.1, requirement REV-6.2.4-03A. This requires that the process of revocation must take at most 24 hours. Consequently, revocation may make no sense if the attestation is valid for less than 24 hours, because it may reach the end of its validity period before it is revoked.

AS-AP-07-002SHALL

Legacy ID: VCR_01a {: .eudi-hlr__meta }

A Wallet Provider SHALL use the method specified in Technical Specification 3 for maintaining the revocation status of the underlying objects referenced in a WIA or key attestation.

Note: The 'underlying object' is the object that is actually revoked by revoking the WIA or key attestation, i.e., the Wallet Instance in case of a WIA and a WSCA/WSCD or keystore in case of a key attestation.

AS-AP-07-003SHALL

Legacy ID: VCR_01b {: .eudi-hlr__meta }

A PID Provider, QEAA Provider, or PuB-EAA Provider SHALL use one of the following methods for revocation of a SD-JWT VC-compliant PID, QEAA, or PuB-EAA: - Only issue short-lived attestations having a validity period of 24 hours or less, such that revocation will never be necessary or, - Use an Attestation Status List mechanism specified per VCR_11.

Note: The 24-hour period originates from ETSI EN 319 411-1 V1.4.1, requirement REV-6.2.4-03A. This requires that the process of revocation must take at most 24 hours. Consequently, revocation may make no sense if the attestation is valid for less than 24 hours, because it may reach the end of its validity period before it is revoked.

AS-AP-07-004SHALL

Legacy ID: VCR_02 {: .eudi-hlr__meta }

For non-qualified EAAs, the relevant Rulebook SHALL specify whether that type of EAA must be revocable. If a non-qualified EAA type must be revocable, the relevant Rulebook SHALL determine which of the methods mentioned in VCR_01 or VCR_01b (as applicable) must be implemented by the relevant EAA Providers for the revocation of such an EAA.

AS-AP-07-005SHALL

Legacy ID: VCR_03 {: .eudi-hlr__meta }

If a PID or attestation is revocable, the PID Provider of a given PID, or the Attestation Provider of a given attestation, SHALL be the only party in the EUDI Wallet ecosystem responsible for executing the revocation of that PID or attestation.

Note: A PID Provider or Attestation Provider MAY outsource the operation of the revocation process to a third party.

AS-AP-07-006SHALL

Legacy ID: VCR_03a {: .eudi-hlr__meta }

The Wallet Provider of a given WIA or KA SHALL be the only party in the EUDI Wallet ecosystem responsible for maintaining the revocation status of the underlying object attested in that WIA or KA.

Note: A Wallet Provider MAY outsource the operation of the revocation process to a third party.

AS-AP-07-007SHALL

Legacy ID: VCR_04 {: .eudi-hlr__meta }

A PID Provider, Attestation Provider, or Wallet Provider that revoked a PID, attestation, WIA, or KA SHALL NOT reverse the revocation.

AS-AP-07-008SHALL

Legacy ID: VCR_05 {: .eudi-hlr__meta }

If a PID, attestation, WIA, or KA is revocable, the PID Provider, Attestation Provider, or Wallet Provider SHALL have a policy specifying under which conditions a PID, attestation, WIA, or KA it issued will be revoked.

AS-AP-07-009SHALL

Legacy ID: VCR_06 {: .eudi-hlr__meta }

If a PID or attestation is revocable, the PID Provider or Attestation Provider SHALL revoke a PID or attestation when its security has been compromised.

AS-AP-07-010SHALL

Legacy ID: VCR_07 {: .eudi-hlr__meta }

A Wallet Provider SHALL revoke the Wallet Instance upon the explicit request of the User to revoke their Wallet Unit.

Note: See also WURevocation_07 and _10.

AS-AP-07-011SHALL

Legacy ID: VCR_07a {: .eudi-hlr__meta }

If a PID is revocable, the PID Provider SHALL revoke that PID upon the explicit request of the User to whom the PID was issued.

AS-AP-07-012SHOULD

Legacy ID: VCR_07b {: .eudi-hlr__meta }

If an attestation is revocable, the Attestation Provider SHOULD revoke that attestation upon the explicit request of the User to whom the attestation was issued.

AS-AP-07-013SHALL

Legacy ID: VCR_07c {: .eudi-hlr__meta }

If a PID is revocable, the PID Provider SHALL revoke that PID if the Wallet Unit on which it resides is revoked, in compliance with requirement WURevocation_18 in Topic 38.

AS-AP-07-014MAY

Legacy ID: VCR_07d {: .eudi-hlr__meta }

If an attestation is revocable, the Attestation Provider MAY revoke that attestation if the Wallet Unit on which it resides is revoked, in compliance with requirement WURevocation_19 in Topic 38.

AS-AP-07-015SHALL

Legacy ID: VCR_07e {: .eudi-hlr__meta }

If a Wallet Provider uses the per-KA approach for key attestation revocation (see WUA_28), it SHALL revoke a WSCD or keystore upon the explicit request of the User to revoke their WSCD or keystore.

Note: a) The most likely cause of such a request would be that the WSCD or keystore is a local external smart card and the User lost their WSCD or keystore. b) In contrast, under the type-shared index approach (see WUA_28), revoking the WSCD or keystore is not a per-Wallet Unit action that can be triggered by user requests. c) See also WURevocation_07a.

AS-AP-07-016SHALL

Legacy ID: VCR_08 {: .eudi-hlr__meta }

If a PID is revocable, the PID Provider SHALL revoke a PID upon the death of the natural person who is the subject of the PID.

Note: a) In addition, in these circumstances the PID Provider also requests the Wallet Provider to revoke the Wallet Unit, see WURevocation_11. b) The topic of Wallet Units for legal persons, possibly containing a legal-person PID, has has been removed from this ARF in view of the development of a separate business wallet.

AS-AP-07-017SHALL

Legacy ID: VCR_09 {: .eudi-hlr__meta }

If a technical PID or attestation is revocable, the PID Provider or Attestation Provider SHALL revoke that PID or attestation if the value of one or more of the attributes in the corresponding logical PID or attestation was changed (including attributes being added or deleted) and the technical PID or attestation is still valid for at least 24 hours. Subsequently, if the User's contact details are known, the PID Provider or Attestation Provider SHOULD, via an out-of-band manner, notify the User about the revocation and ask the User to request re-issuance of the PID or attestation using their Wallet Unit.

Note: If the value of the attributes is determined by a party different from the PID Provider or Attestation Provider, such as an Authentic Source, the Provider is responsible for ensuring that this third party notifies them about such changes.

AS-AP-07-018SHALL

Legacy ID: VCR_10 {: .eudi-hlr__meta }

Wallet Providers SHALL implement the Attestation Status List and Attestation Revocation List mechanisms specified per VCR_11 in their Wallet Solutions.

AS-AP-07-019SHALL

Legacy ID: VCR_11 {: .eudi-hlr__meta }

For ISO/IEC 18013-5-compliant PIDs and attestations, the PID Provider or Attestation Provider SHALL implement the Attestation Status List or Attestation Revocation List mechanism as specified in Annex 2 of (the amended) CIR [2024/2979).

Note: a) 'Attestation Status List' and 'Attestation Revocation List' are specific mechanisms, these terms are defined in Annex 1. b) Attestation Revocation Lists are sometimes referred to as 'Identifier Lists'. c) The relevant texts in this CIR are copied from the forthcoming 2nd edition of ISO/IEC 18013-5, available here.

AS-AP-07-020SHALL

Legacy ID: VCR_11a {: .eudi-hlr__meta }

For SD-JWT VC-compliant PIDs and attestations, the PID Provider or Attestation Provider SHALL implement the Attestation Status List mechanism as specified in Token Status List.

Note: No suitable specification of Attestation Revocation Lists in JSON format is available.

AS-AP-07-021SHALL

Legacy ID: VCR_12 {: .eudi-hlr__meta }

If a Relying Party decides it needs to be able to verify the revocation status of PIDs or attestations, it SHALL support both the Attestation Status List mechanism and the Attestation Revocation List mechanism specified per VCR_11.

Note: Per VCR_13, it is recommended but not mandatory for a Relying Party to verify whether a PID or attestation is revoked.

AS-AP-07-022SHALL

Legacy ID: VCR_12a {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL support the mechanism specified per VCR_01a for verifying the revocation status of a WIA or KA.

AS-AP-07-023SHALL

Legacy ID: VCR_13 {: .eudi-hlr__meta }

A Relying Party Instance SHOULD verify the revocation status of a revocable PID or attestation upon obtaining it from a Wallet Unit. When a Relying Party considers deviating from this recommendation by not performing revocation checking, it SHALL perform a risk analysis considering all relevant factors for the use case, including risks to the User, the PID Provider or Attestation Provider, and risks to the Relying Party itself.

AS-AP-07-024SHALL

Legacy ID: VCR_14 {: .eudi-hlr__meta }

A Relying Party SHALL perform a risk analysis considering all relevant factors for the use case, including risks to the User and risks to the Relying Party itself, to determine whether it will accept or refuse a PID or attestation in case no reliable information regarding the revocation status of that PID or attestation is available.

Note: Examples of conditions under which no reliable revocation information is available are 1) The attestation does not contain revocation information (because it is not revocable). 2) The Relying Party Instance is offline and any cached status information is no longer valid. 3) The latest attestation status lists or attestation identifier lists provided by the PID Provider or Attestation Provider (i.e., available online) are no longer valid. 4) The Relying Party Instance is offline, but the use case requires up-to-date revocation information (instead of trusting cached information that is still valid.)

AS-AP-07-025SHOULD

Legacy ID: VCR_15 {: .eudi-hlr__meta }

A Relying Party Instance SHOULD NOT request the relevant Attestation Status List or Attestation Revocation List each time an attestation is presented to it by a Wallet Unit. Rather, the Relying Party operating the Relying Party Instance SHOULD download each new version of the list once, at a time and from a location unrelated to the presentation of a PID or attestation by a User. The Relying Party SHOULD then distribute the list to all of its Relying Party Instances, using an Relying Party-internal distribution mechanism. Each Relying Party Instance SHOULD cache the list, so that it can perform revocation checks without making an online request. The Relying Party SHOULD perform a risk analysis to determine the frequency with which it will download the revocation lists and the maximum caching period its Relying Party Instances will use.

AS-AP-07-026SHALL

Legacy ID: VCR_16 {: .eudi-hlr__meta }

A PID Provider, Attestation Provider or Wallet Provider SHALL NOT require the Relying Party or Relying Party Instance to authenticate itself before downloading an Attestation Status List or Attestation Revocation List.

AS-AP-07-027SHALL

Legacy ID: VCR_17 {: .eudi-hlr__meta }

When using an Attestation Status List for revocation, the PID Provider, Attestation Provider or Wallet Provider SHALL randomly assign the index for each PID or attestation, to prevent this index from becoming a correlator.

Note: Randomly assigning indices within a bitstring or byte array is more complicated than creating random identifiers (e.g. serial numbers) for attestations, as is needed for an Attestation Revocation List. This is because duplicate indices and unnecessarily long bitstrings or byte arrays must be prevented.

AS-AP-07-028SHALL

Legacy ID: VCR_18 {: .eudi-hlr__meta }

When using an Attestation Status List for revocation, the PID Provider, Attestation Provider, or Wallet Provider SHALL represent a sufficiently large number of PIDs, attestations, WIAs, or KAs on each Attestation Status List to ensure herd privacy.

Note: In this context, herd privacy means that if an entity requests a particular status list, the PID Provider, Attestation Provider, or Wallet Provider is not able to deduce which PID, attestation, WIA, or KA (likely) was presented to that entity. Complying with this requirement may be difficult in case the number of PIDs, attestations, WIAs, or KAs to be represented on the list is small. In such a case, decoy entries can be added to the list to obfuscate the real number of referenced PIDs, attestations, WIAs, or KAs.

AS-AP-07-029SHALL

Legacy ID: VCR_19 {: .eudi-hlr__meta }

A Wallet Instance SHOULD regularly check the revocation status of its PIDs and attestations. In addition, the Wallet Instance SHOULD regularly check whether itself or any WSCD or keystore it uses has been revoked. In case of any revocation, the Wallet Instance SHALL notify the User accordingly.

Note: A Wallet Instance can check its own revocation status using its WIAs, and the revocation status of its WSCD and keystores using its key attestations.

AS-AP-10-001SHALL

Legacy ID: ISSU_01a {: .eudi-hlr__meta }

PID Providers and Attestation Providers SHALL support the OpenID4VCI protocol specified in OpenID4VCI, as profiled in Sections 4 and 6 of HAIP, and with additions and changes as documented in this Annex (see e.g. this Topic and Topic 9) and in Technical Specification 3.

Note: a) For clarity: in HAIP v1.0, Section 6 implies that PID Providers and Attestation Providers must comply with the applicable requirements in OpenID4VCI Annex A.2 when issuing an attestation in ISO/IEC 18013-5-compliant format, and with the applicable requirements in OpenID4VCI Annex A.3 when issuing an attestation in SD-JWT VC format. b) In addition to supporting OpenID4VCI, PID Providers are allowed to support other protocols for issuing PIDs to (national) Wallet Units, provided these protocols comply with all relevant requirements in the Implementing Acts and the standards referenced therein. In many Member States, the PID Provider and the Wallet Provider are closely related, and can therefore bilaterally agree to support a different protocol for PID issuance.

AS-AP-10-002SHALL

Legacy ID: ISSU_02 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Solution supports the attestation formats specified in ISO/IEC 18013-5, see ISO/IEC 18013-5, and in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC, with additions and changes as documented in this Annex and in ETSI TS 119 472-1.

AS-AP-10-003SHALL

Legacy ID: ISSU_03 {: .eudi-hlr__meta }

Wallet Units, PID Providers, and Attestation Providers SHALL support the W3C Digital Credentials API for the issuance of PIDs and attestations.

Note: This requirement implies that the following conditions will be satisfied: a) the DC API specification will become a W3C Recommendation, b) this specification will comply with the principles outlined in Section 4.4.3.1 of the ARF main document, c) this specification will be broadly supported by relevant browsers and operating systems, and d) the OpenID4VCI standard will specify how to use OpenID4VCI with the DC API.

AS-AP-10-004

Legacy ID: ISSU_04 {: .eudi-hlr__meta }

Empty

AS-AP-10-005SHALL

Legacy ID: ISSU_05 {: .eudi-hlr__meta }

A Wallet Unit SHALL support a process to activate a newly issued PID, in accordance with the requirements for LoA High in Commission Implementing Regulation (EU) 2015/1502 Section 2.2.2. The Wallet Unit SHALL NOT allow a User to use a non-activated PID.

Note: a) The goal of the activation process is to verify that the PID was delivered into the Wallet Unit and WSCA/WSCD of the User who is the subject of the PID. b) This requirement is not applicable for QEAAs, PuB-EAAs or non-qualified EAAs, since these are not identity means in the sense of Commission Implementing Regulation (EU) 2015/1502.

AS-AP-10-006SHALL

Legacy ID: ISSU_06 {: .eudi-hlr__meta }

After a Wallet Unit receives a PID or an attestation from a PID Provider or Attestation Provider, it SHALL verify that the PID or attestation it received matches the PID or attestation requested by the Wallet Unit.

AS-AP-10-007SHALL

Legacy ID: ISSU_07 {: .eudi-hlr__meta }

After a Wallet Unit receives a PID from a PID Provider, it SHALL validate the signature of the PID using a trust anchor of the PID Provider provided in a LoTE made available in accordance with Topic 31].

Note: The Wallet Provider and PID Provider may be the same entity. In such a case, the remote WSCD used by the Wallet Provider may be the same hardware HSM that is also used by the PID Provider to sign PIDs. In such a situation, this requirement may look superfluous, since the same HSM would generate the signature and verify it. However, this is not true, since for security reasons the PID Provider and Wallet Provider must use proper partitioning and logical key segregation within the HSM. Therefore, this requirement also applies in such a situation.

AS-AP-10-008SHALL

Legacy ID: ISSU_08 {: .eudi-hlr__meta }

After a Wallet Unit receives a QEAA from a QEAA Provider, it SHALL validate the qualified signature of the QEAA in accordance with Art. 32 of the European Digital Identity Regulation. For

the verification, the Wallet Unit SHALL use a trust anchor provided in a QEAA Provider Trusted List made available in accordance with Art. 22 of the European Digital Identity Regulation.

Note: a) Requirements ISSU_07 to ISSU_10 are equivalent to requirements OIA_12 to OIA_15 in Topic 1. b) These requirements imply that a Wallet Unit must be aware whether the attestation it is requesting from an issuer is a PID, a QEAA, a PuB-EAA, or a non-qualified EAA. These requirements also imply that the Wallet Unit must store trust anchors in such a way that, when it receives an issued attestation, it is able to distinguish between trust anchors usable either for PIDs, for QEAAs, for PuB-EAAs, or for non-qualified EAAs.

AS-AP-10-009SHALL

Legacy ID: ISSU_09 {: .eudi-hlr__meta }

After a Wallet Unit receives a PuB-EAA from a PUB-EAA Provider, it SHALL validate the signature of a PuB-EAA using a trust anchor provided in a Pub-EAA Provider LoTE made available in accordance with [Topic 31].

AS-AP-10-010SHALL

Legacy ID: ISSU_10 {: .eudi-hlr__meta }

After a Wallet Unit receives a non-qualified EAA from an EAA Provider, it SHALL validate the signature of the EAA if it has access to the trust anchors of the EAA Provider.

Note: For a non-qualified EAA, an Attestation Rulebook may be available, see [Topic 12], explaining how EAA Providers distribute their trust anchors. However, it is not required for Wallet Units to be in possession of the trust anchors of all non-qualified EAA Providers, even when an Attestation Rulebook is available.

AS-AP-10-011SHALL

Legacy ID: ISSU_10a {: .eudi-hlr__meta }

A Wallet Provider SHALL perform regular trust anchor management, meaning it SHALL download the latest version of all applicable Trusted Lists and LoTEs. If it finds that new trusted entities have been added, or that new trust anchors have been added for existing trusted entities, it SHALL ensure that these trust anchors are properly stored in all relevant Wallet Units. Conversely, if the Wallet Provider finds that an existing trusted entity has been invalidated in the Trusted List or LoTE, or that some of the trust anchors of existing trusted entities have expired, been revoked, or otherwise been invalidated, it SHALL ensure that these trust anchors are removed from all Wallet Units.

AS-AP-10-012SHALL

Legacy ID: ISSU_10b {: .eudi-hlr__meta }

For the retrieval and management of trust anchors, Wallet Providers and Wallet Units SHALL support both Trusted Lists complying with ETSI TS 119 612 and LoTEs complying with ETSI TS 119 602.

Note: Trusted Lists complying with ETSI TS 119 612 are used for the distribution of trust anchors of QEAA Providers. LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of PID Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

AS-AP-10-013SHALL

Legacy ID: ISSU_11 {: .eudi-hlr__meta }

A Wallet Unit SHALL request the User's approval before storing a PID or attestation obtained from a PID Provider or Attestation Provider. When requesting approval, the Wallet Instance SHALL display the contents of the PID or attestation to the User. The Wallet Instance SHALL also inform the User about the identity of the PID Provider or Attestation Provider, using the subject information in the PID Provider's or Attestation Provider's access certificate.

AS-AP-10-014SHALL

Legacy ID: ISSU_11a {: .eudi-hlr__meta }

In case a PID or attestation is issued in batches, the Wallet Unit SHALL verify that all PIDs and attestations in a batch have the same attribute values and the same technical validity period.

Note: PIDs and attestations are issued in batches when Method A, Method B, or Method D is used, see ISSU_37, ISSU_43, ISSU_51.

AS-AP-10-015SHALL

Legacy ID: ISSU_11b {: .eudi-hlr__meta }

In case one or more of the verifications in ISSU_06 - ISSU_11a fail, the Wallet Unit SHALL immediately delete the PID or attestation it received. The Wallet Instance SHALL notify the User about the fact that issuance of the PID or attestation was not successful, including the reason for this failure.

AS-AP-10-016SHALL

Legacy ID: ISSU_12 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL offer its PIDs or attestations in all formats required in the PID Rulebook or the applicable Attestation Rulebook, see Topic 12].

Note: Examples include the mdoc format specified in ISO/IEC 18013-5 and the SD-JWT VC-format specified in SD-JWT VC.

AS-AP-10-017SHALL

Legacy ID: ISSU_12a {: .eudi-hlr__meta }

When a User instructs their Wallet Unit to request a PID or attestation from a PID Provider or Attestation Provider, the Wallet Unit SHALL request that PID or attestation in all formats offered by the PID Provider or Attestation Provider.

Note: Examples include the mdoc format specified in ISO/IEC 18013-5 and the SD-JWT VC-format specified in SD-JWT VC.

AS-AP-10-018SHALL

Legacy ID: ISSU_12b {: .eudi-hlr__meta }

The WSCA/WSCD or a keystore SHALL generate a new key pair for a new PID or attestation on request of the Wallet Instance, unless that PID or attestation is issued synchronously in a remote HSM architecture. This generation request MAY be done either prior to the issuance of any PID or attestation, or during the issuance process.

Note: a) See also WUA_05 and WUA_05a. b) In case of synchronous issuing in a remote HSM architecture, re-use of an existing key pair within a limited period of time can be acceptable, based on the PID Provider's or Attestation Provider's issuance security policy. This is similar to a choice between Method A or Method B (see ISSU_37 and ISSU_38) when issuing PIDs or attestations non-synchronously.

AS-AP-10-019SHALL

Legacy ID: ISSU_12c {: .eudi-hlr__meta }

The expiration date of a PID SHALL be no later than the end of the revocation maintenance periods of the WIA and the KA presented as part of the PID issuance process.

Note: This requirement is an implication of WURevocation_18 in Topic 38 and WUA_29 - WUA_31. If the PID would be valid beyond the period for which the Wallet Provider has committed to maintaining the revocation status of the Wallet Instance and the WSCD, the PID Provider would

not be able to fulfil its obligation to regularly check whether the Wallet Instance and WSCD have been revoked for the full PID validity period.

AS-AP-10-020SHALL

Legacy ID: ISSU_12d {: .eudi-hlr__meta }

If an Attestation Provider supports revocation chaining for its attestations per WURevocation_19 in Topic 38, the expiration date of an attestation SHALL be no later than the end of the revocation maintenance periods of the WIA and the KA (if applicable) presented as part of the attestation issuance process.

Note: See note in ISSU_12c.

AS-AP-10-021SHALL

Legacy ID: ISSU_13 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that at least one PID Provider is willing to issue a PID complying with PID Rulebook to Users of the Wallet Units it provides.

AS-AP-10-022SHALL

Legacy ID: ISSU_14 {: .eudi-hlr__meta }

A PID Provider SHALL ensure that all PIDs it issues to Wallet Units comply with the requirements specified in PID Rulebook.

AS-AP-10-023SHALL

Legacy ID: ISSU_15 {: .eudi-hlr__meta }

A PID Provider SHALL support the OpenID4VCI protocol referenced in ISSU_01 for issuing PIDs.

AS-AP-10-024

Legacy ID: ISSU_16 {: .eudi-hlr__meta }

Empty

AS-AP-10-025SHALL

Legacy ID: ISSU_17 {: .eudi-hlr__meta }

A PID Provider SHALL implement device binding for all PIDs it issues, meaning it SHALL ensure that a PID is cryptographically bound to the WSCA/WSCD included in the Wallet Unit, as specified in Topic 9.

Note: Device binding is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC.

AS-AP-10-026SHALL

Legacy ID: ISSU_18 {: .eudi-hlr__meta }

A PID Provider SHALL verify the identity of the subject of the PID in compliance with Level of Assurance (LoA) High requirements.

Note: These requirements will be determined by the relevant eID scheme.

AS-AP-10-027

Legacy ID: ISSU_18a {: .eudi-hlr__meta }

Empty

AS-AP-10-028SHALL

Legacy ID: ISSU_19 {: .eudi-hlr__meta }

For the verification of a WIA or KA, a PID Provider SHALL accept the Wallet Provider trust anchors it needs, as published by the Commission in the Wallet Provider LoTE.

Note: a) The Wallet Provider LoTE is explained in Topic 31. b) It is not mandatory for a PID Provider to store all Wallet Provider trust anchors. This is because it is not mandatory for a PID Provider to accept all certified Wallet Solutions in the EUDI Wallet ecosystem. Each PID Provider will choose which trust anchors they need to use.

AS-AP-10-029SHALL

Legacy ID: ISSU_19a {: .eudi-hlr__meta }

A PID Provider SHALL support all Wallet Solutions recognised under the corresponding notified eID scheme, meaning that it is willing and able to issue a PID to a Wallet Unit on request of the User.

AS-AP-10-030SHALL

Legacy ID: ISSU_19b {: .eudi-hlr__meta }

For the retrieval and management of trust anchors, PID Providers SHALL support LoTEs complying with ETSI TS 119 602.

Note: LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of Wallet Providers.

AS-AP-10-031SHALL

Legacy ID: ISSU_20 {: .eudi-hlr__meta }

To inform its potential PID subjects about the Wallet Solution(s) they can use for requesting a PID, a PID Provider SHALL publish a list of supported Wallet Solutions in such a way that it can be easily found, for example on the PID Provider's website.

Note: This a policy requirement rather than a technical requirement.

AS-AP-10-032SHALL

Legacy ID: ISSU_21 {: .eudi-hlr__meta }

Before issuing a PID, a PID Provider SHALL verify the Wallet Unit's WIA and KA using a trust anchor registered in the Wallet Provider LoTE. Moreover, it SHALL verify that the Wallet Instance referenced in the WIA has not been revoked, and that the WSCD referenced in the KA has not been revoked.

Note: a) For WIAs and KAs, see Topic 9 and Topic 38. b) CIR 2024/2977, Article 3 (9), also allows another authentication mechanism in accordance with an electronic identity scheme notified at assurance level high. However, the ARF does not further specify such other authentication mechanisms, which means that in general they will not be interoperable.

AS-AP-10-033SHALL

Legacy ID: ISSU_22 {: .eudi-hlr__meta }

A PID Provider SHALL sign its Credential Issuer metadata as specified in section 12.2.3 of OpenID4VCI. To do so, the PID Provider SHALL use the private key corresponding to the public key in its access certificate. The PID Provider SHALL include its access certificate, as well as all intermediate certificate(s) leading up to the trust anchor of the corresponding Access Certificate Authority (see ISSU_33) in the LoTE, in the `x5c` parameter in the JOSE header of the JSON Web Signature for the metadata.

AS-AP-10-034

Legacy ID: ISSU_22a {: .eudi-hlr__meta }

Empty

AS-AP-10-035

Legacy ID: ISSU_22b {: .eudi-hlr__meta }

Empty

AS-AP-10-036SHALL

Legacy ID: ISSU_23 {: .eudi-hlr__meta }

For the verification of a PID Provider's access certificates, a Wallet Unit SHALL accept all Access Certificate Authorities trust anchors published by the Commission in the relevant LoTE, and only those.

Note: a) Access Certificate Authority LoTEs are explained in [Topic 27]. b) A Wallet Unit does not have to be able to request a PID from all PID Providers in the ecosystem. It is up to each Wallet Provider to decide which PID Providers its Wallet Units will support.

AS-AP-10-037SHALL

Legacy ID: ISSU_23a {: .eudi-hlr__meta }

A Wallet Provider SHALL support at least one PID Provider, meaning that its Wallet Units SHALL be capable of requesting the issuance of a PID from these PID Provider(s), and that the Wallet Provider has agreed with the PID Provider(s) that the PID Provider(s) will process such a request according to the agreed rules and procedures.

AS-AP-10-038SHALL

Legacy ID: ISSU_23b {: .eudi-hlr__meta }

Prior to or during installation of a Wallet Instance, the Wallet Provider SHALL notify the User about the PID Provider(s) that are supported by the Wallet Unit.

AS-AP-10-039SHALL

Legacy ID: ISSU_23c {: .eudi-hlr__meta }

For the verification of a PID Provider's registration certificates, a Wallet Unit SHALL accept the trust anchors of all Providers of registration certificates published by the Commission in the relevant LoTE, and only those.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-040SHALL

Legacy ID: ISSU_24 {: .eudi-hlr__meta }

A Wallet Unit SHALL authenticate and validate the access certificate of the PID Provider before requesting the issuance of a PID. The Wallet Unit SHALL verify that the access certificate is

authentic and is valid at the time of validation, and that the issuer of the access certificate is included in an Access Certificate Authority LoTE.

AS-AP-10-041SHALL

Legacy ID: ISSU_24a {: .eudi-hlr__meta }

Before requesting the issuance of a PID, the Wallet Unit SHALL verify that the PID Provider is indeed a registered PID Provider. To do so, the Wallet Unit SHALL inspect the `entitlement` member in the registration certificate of the PID Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the PID Provider is indeed registered as a PID Provider, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of a PID.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-042SHALL

Legacy ID: ISSU_24b {: .eudi-hlr__meta }

Before requesting the issuance of a PID, the Wallet Unit SHALL verify whether the PID Provider properly registered for the issuance of PIDs. To do so, the Wallet Unit SHALL inspect the `providesAttestations` member in the registration certificate of the PID Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the PID Provider registered for the issuance of PIDs, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of a PID.

Note: a) It may be argued that this verification is superfluous, since an entity registered as a PID Provider (ISSU_24a) by definition is registered for issuing PIDs. However, this verification was added to ensure that Wallet Unit can use the same verification process for PIDs as for other attestations (see ISSU_34b), as well as to ensure that in the future, it is possible to distinguish between different types of PID if needed, where not all PID Providers are registered to issue all types of PID. b) The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-043SHALL

Legacy ID: ISSU_25 {: .eudi-hlr__meta }

An Attestation Provider SHALL ensure all attestations issued to Wallet Units comply with the requirements specified in the applicable Attestation Rulebook, as described in Topic 12].

AS-AP-10-044SHALL

Legacy ID: ISSU_26 {: .eudi-hlr__meta }

An Attestation Provider SHALL support the OpenID4VCI protocol referenced in ISSU_01 for issuing attestations.

AS-AP-10-045SHALL

Legacy ID: ISSU_27 {: .eudi-hlr__meta }

An Attestation Provider SHOULD implement device binding for all attestations it issues. If an issued attestation is device-bound, the Attestation Provider SHALL ensure that the attestation is cryptographically bound to a WSCA/WSCD or a keystore available to the Wallet Unit, as specified in Topic 9.

Note: a) Device binding is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC. b) Implementing mdoc authentication is mandatory in ISO/IEC 18013-5 and therefore, it is mandatory for attestations complying with that standard. c) See ISSU_27d.

AS-AP-10-046SHALL

Legacy ID: ISSU_27a {: .eudi-hlr__meta }

If the subject of the attestation is a natural person, an Attestation Provider SHALL verify the identity of the subject of the attestation, in compliance with applicable requirements and in accordance with relevant standards or Implementing Regulations.

Note: Not every attestation has a natural person as its subject. For example, a holiday voucher may be valid for any User that can present it to a Relying Party and therefore has no subject. This is comparable to the concept of a 'bearer token'.

AS-AP-10-047SHALL

Legacy ID: ISSU_27b {: .eudi-hlr__meta }

If applicable, an Attestation Provider SHALL ensure that the attributes attested in the attestation issued are valid for the identified attestation subject.

AS-AP-10-048SHALL

Legacy ID: ISSU_27c {: .eudi-hlr__meta }

The Attestation Provider SHALL verify that the User requesting the attestation has the right to receive it.

AS-AP-10-049SHALL

Legacy ID: ISSU_27d {: .eudi-hlr__meta }

An Attestation Provider issuing device-bound attestations SHALL indicate the desired level of security for the private key storage and for User authentication in its Credential Issuer metadata, according to OpenID4VCI section 12.2.4 and Appendix D.2.

Note: See also WIAM_14b, WIAM_14c, and WUA_05 and WUA_05a.

AS-AP-10-050SHALL

Legacy ID: ISSU_28 {: .eudi-hlr__meta }

For the verification of a WIA or KA, an Attestation Provider SHALL accept all Wallet Provider trust anchors published by the Commission in the relevant LoTE, and only those.

Note: The Wallet Provider LoTE is explained in Topic 31.

AS-AP-10-051SHALL

Legacy ID: ISSU_28a {: .eudi-hlr__meta }

For the retrieval and management of trust anchors, Attestation Providers SHALL support LoTEs complying with ETSI TS 119 602.

Note: LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of Wallet Providers.

AS-AP-10-052SHALL

Legacy ID: ISSU_29 {: .eudi-hlr__meta }

A QEAA Provider or PuB-EAA Provider SHALL support all Wallet Solutions, except in case the attestation in question is a Strong User Authentication (SUA) attestation as meant in Topic 20 and the Wallet Provider does not support processing of the transactional data associated with the SUA attestation. Except for such cases, a QEAA Provider or PuB-EAA Provider SHALL NOT discriminate between Wallet Solutions when processing a request for the issuance of an attestation.

Note: This requirement is not applicable for non-qualified EAA Providers. For example, a non-qualified EAA Provider may choose to issue attestations in the format specified in W3C VCDM v2.0,

see ARB_01a. In that case, it will support only those Wallet Solutions that have implemented this attestation format.

AS-AP-10-053SHALL

Legacy ID: ISSU_30 {: .eudi-hlr__meta }

Before issuing a device-bound attestation, an Attestation Provider SHALL verify the Wallet Unit's key attestation using a trust anchor registered in the Wallet Provider LoTE. Moreover, it SHALL verify that the WSCD or keystore referenced in the KA has not been revoked.

Note: This requirement applies specifically to the KA received during device-bound attestation issuance. The corresponding requirement for verifying the WIA is ISSU_30a.

AS-AP-10-054SHALL

Legacy ID: ISSU_30a {: .eudi-hlr__meta }

Before issuing an attestation, an Attestation Provider SHALL: - verify that the Wallet Provider mentioned in the Wallet Unit's WIA is present in the Wallet Provider LoTE. - authenticate and validate the WIA using the trust anchor(s) registered for the Wallet Provider in that LoTE.

Note: This requirement applies to both device-bound and non-device-bound attestations

AS-AP-10-055

Legacy ID: ISSU_31 {: .eudi-hlr__meta }

Empty

AS-AP-10-056SHALL

Legacy ID: ISSU_32 {: .eudi-hlr__meta }

An Attestation Provider SHALL sign its Credential Issuer metadata as specified in section 12.2.3 of OpenID4VCI. To do so, the Attestation Provider SHALL use the private key corresponding to the public key in its access certificate. The Attestation Provider SHALL include its access certificate, as well as all intermediate certificate(s) leading up to the trust anchor of the corresponding Access Certificate Authority in the LoTE (see ISSU_33), in the `x5c` parameter in the JOSE header of the JSON Web Signature for the metadata.

AS-AP-10-057

Legacy ID: ISSU_32a {: .eudi-hlr__meta }

Empty

AS-AP-10-058SHALL

Legacy ID: ISSU_33 {: .eudi-hlr__meta }

For the verification of access certificates, a Wallet Unit SHALL accept all trust anchors of Access Certificate Authorities, as published by the Commission in the relevant LoTE, and only those.

Note: The Access Certificate Authority LoTE is explained in [Topic 27].

AS-AP-10-059SHALL

Legacy ID: ISSU_33a {: .eudi-hlr__meta }

For the verification of the registration certificates of Attestation Providers, a Wallet Unit SHALL accept all trust anchors of Providers of registration certificates, as published by the Commission in the relevant LoTE, and only those.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-060SHALL

Legacy ID: ISSU_33b {: .eudi-hlr__meta }

A Wallet Provider SHALL support all Attestation Providers, except possibly if the attestation in question is a Strong User Authentication (SUA) attestation as meant in Topic 20 and the Wallet Provider chooses to not support processing of the transactional data associated with that attestation. Except for such cases, Wallet Units SHALL be capable of requesting the issuance of a QEAA, PuB-EAA, or non-qualified EAA from all Attestation Providers at the User's request.

AS-AP-10-061SHALL

Legacy ID: ISSU_34 {: .eudi-hlr__meta }

A Wallet Unit SHALL authenticate and validate the access certificate of the Attestation Provider before requesting the issuance of an attestation. The Wallet Unit SHALL verify that the access certificate is authentic and is valid at the time of validation, and that the issuer of the access certificate is in the Access Certificate Authority LoTE, as documented in [Topic 27].

AS-AP-10-062SHALL

Legacy ID: ISSU_34a {: .eudi-hlr__meta }

Before requesting the issuance of an attestation, the Wallet Unit SHALL verify that the Attestation Provider is a registered QEAA Provider, PuB-EAA Provider, or EAA Provider. To do so, the Wallet Unit SHALL inspect the `entitlement` member in the registration certificate of

the Attestation Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the Attestation Provider is indeed registered as a QEAA Provider, PuB-EAA Provider, or EAA Provider, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of an attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-063SHALL

Legacy ID: ISSU_34b {: .eudi-hlr__meta }

Before requesting the issuance of an attestation, the Wallet Unit SHALL verify whether the Provider properly registered for the issuance of the type of attestation that the User wants to obtain. To do so, the Wallet Unit SHALL inspect the `providesAttestations` member in the registration certificate of the Attestation Provider, provided in the Credential Issuer Metadata per ETSI TS 119 472-3 section 4.2.3, and verify the authenticity of the registration certificate. If this procedure does not confirm that the Attestation Provider registered for the relevant type of attestation, the Wallet Unit SHALL display a warning to the User, and SHALL NOT request the issuance of an attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-10-064SHALL

Legacy ID: ISSU_35 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL ensure that all unique elements in a PID or attestation have a negligible chance of having the same value across all PIDs or attestations issued by that Provider. This SHALL include at least a) the salt used for hashing every attribute, b) the hash values of all attributes, c) the attestation identifier or index used for revocation purposes (if applicable), d) the attestation public key used for device binding (if applicable), and e) the value of the Attestation Provider signature.

Note: a) The list of unique elements is based on ISO/IEC 18013-5 and SD-JWT VC. b) This requirement can be achieved, for example, by ensuring that salt values, indexes and attestation identifiers are pseudo-random numbers generated by a cryptographically secure pseudo-random number generator (CSPRNG).

AS-AP-10-065SHALL

Legacy ID: ISSU_35a {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that all unique elements in a WIA or KA have a negligible chance of having the same value across all WIAs and KAs issued by that Wallet Provider and intended to be presented to different PID Providers or Attestation Providers. This SHALL include at least a) the attestation index for revocation, unless the per-KA index approach meant in WUA_28 is used, b) the WIA or KA public key, and c) the value of the Wallet Provider signature over the WIA or KA.

Note: In other words, the following do not have to be unique: i) WIAs presented to the same PID Provider or Attestation Provider, and ii) the revocation index in a KA under the type-shared index approach (see WUA_28). However, under the per-KA index approach (see WUA_28), the KA revocation index is unique per KA or per KA-issuer pair and is subject to this requirement.

AS-AP-10-066SHALL

Legacy ID: ISSU_35b {: .eudi-hlr__meta }

After issuing a PID, attestation, KA, or WIA, a PID Provider, Attestation Provider or Wallet Provider SHALL discard the values of all unique elements, including at least the ones mentioned in requirement ISSU_35 or ISSU_35a (as applicable) above, as well as any timestamps, as soon as they are no longer needed. The Provider SHALL NOT communicate these values to any other party inside or outside the EUDI Wallet ecosystem.

AS-AP-10-067SHALL

Legacy ID: ISSU_36 {: .eudi-hlr__meta }

When issuing PIDs, attestations, or WIAs or KAs in a batch to a Wallet Unit, a PID Provider, Attestation Provider, or Wallet Provider SHALL ensure that the timestamps in these PIDs, attestations, or WIAs and KAs do not enable Relying Parties to conclude that they are part of the same batch (and therefore belong to the same User).

Note: a) This can be done, for example, by making timestamps sufficiently imprecise that a high number of batches, each issued to a different Wallet Unit, share the same timestamp values (herd privacy). b) This requirement does not apply to timestamps included in the attestation as selectively disclosable attributes, see ISSU_36a.

AS-AP-10-068SHALL

Legacy ID: ISSU_36a {: .eudi-hlr__meta }

If the exact time of the issuance of an attestation or the beginning or end of its validity period

is relevant for the use case, the applicable Attestation Rulebook SHALL specify one or more selectively disclosable attribute(s) containing a timestamp with the required precision.

Note: a) An example of this may be a vehicle registration attestation indicating the date and time (down to the second) at which a car changed ownership and therefore legal responsibility. b) This requirement ensures that requirement ISSU_36 can be complied with without running into challenges related to the use case.

AS-AP-10-069SHALL

Legacy ID: ISSU_37 {: .eudi-hlr__meta }

A Wallet Provider SHALL ensure that its Wallet Solution supports the following methods for limiting the number of times a User can present the same technical PID or attestation to Relying Parties: Method A (Once-only attestations, as specified in requirement ISSU_43 - ISSU_47) and Method B (Limited-time attestations, as specified in requirement ISSU_48 - ISSU_50). In addition, a Wallet Provider MAY ensure that its Wallet Solution supports Method C (Rotating-batch attestations, as specified in requirement ISSU_51 - ISSU_54) or Method D (Per-Relying Party attestations, as specified in requirement ISSU_55 - ISSU_57).

Note: Wallet Solutions, PID Providers, Attestation Providers, and Wallet Providers are free to define and use other methods as well. However, such other methods are out of scope of the ARF.

AS-AP-10-070SHALL

Legacy ID: ISSU_38 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL have a policy describing which method(s) (i.e, A, B, C, and/or D) it will use to limit the number of times a Wallet Unit may present a single technical PID or attestation. For each supported method, the policy SHALL also specify how the values for respective parameters for that method, such as technical validity period and batch size, will be chosen. The goal of the policy SHALL be to ensure that the risk of linkability is mitigated to an acceptable level, given the (expected) usage of the logical PID or attestation by the User. To determine what an acceptable level of risk is, the PID Provider or Attestation Provider SHALL carry out a risk analysis regarding linkability.

Note: a) If an Attestation Provider issues multiple attestation types, these requirements apply for each type of attestation separately. b) Technical Specification 3 specifies that WIAs and KAs shall be sent to a PID Provider or Attestation Provider only once. In other words, for WIAs and KAs, the use of Method A is mandatory.

AS-AP-10-071SHALL

Legacy ID: ISSU_39 {: .eudi-hlr__meta }

PID Providers and Attestation Providers SHALL include the `credential_reuse_policy` parameter, specified in section 4.2.4.2 of ETSI TS 119 472-3, in their Credential Issuer Metadata to specify which of the methods A, B, C, or D the Wallet Unit must use for the logical PID or attestation issued. Indicated methods SHALL be ordered by preference.

Note: See also ISSU_40.

AS-AP-10-072SHALL

Legacy ID: ISSU_39a {: .eudi-hlr__meta }

Wallet Units SHALL support the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3 and SHALL present each technical PID and attestation in accordance with the values set for this parameter by the relevant PID Provider or Attestation Provider.

AS-AP-10-073SHALL

Legacy ID: ISSU_40 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL indicate in their OpenID4VCI Issuer metadata that either method A or method B must be used for a given type of PID or attestation. In addition, a PID Provider or Attestation Provider MAY indicate that it prefers using method C and/or method D over method A or method B, by including the methods in the metadata in the appropriate order. In such a case, a Wallet Unit supporting method C and/or method D SHALL use that method, while a Wallet Unit not supporting these methods SHALL use method A or method B, as applicable.

Note: a) This requirement implies that a PID Provider or Attestation Provider must not include both method A and method B in its metadata. b) Example: An Attestation Provider indicates methods {D, C, A} in its metadata, in that order. A Wallet Unit that supports methods C and D (as well as A and B) then uses method D for this type of attestation. A Wallet Unit supporting methods A, B and C uses method C. A Wallet Unit supporting only methods A and B uses method A.

AS-AP-10-074SHALL

Legacy ID: ISSU_40a {: .eudi-hlr__meta }

When implementing any of the methods mentioned in ISSU_37, a Wallet Unit, PID Provider, or Attestation Provider SHALL comply with the applicable requirements in ETSI TS 119 472-3, section 4.2.4.

AS-AP-10-075SHALL

Legacy ID: ISSU_41 {: .eudi-hlr__meta }

To the maximum extent possible, Wallet Providers, PID Providers, and Attestation Providers SHALL ensure that Users do not notice which of the methods A, B, C, or D is used for their PIDs and attestations.

AS-AP-10-076SHALL

Legacy ID: ISSU_42 {: .eudi-hlr__meta }

To the maximum extent possible, Wallet Providers, PID Providers, and Attestation Providers SHALL ensure that no User action is needed for the re-issuance of WIAs or KAs, PIDs, or attestations.

Note: For the topic of re-issuance, see also the Discussion Paper for Topic B.

AS-AP-10-077SHALL

Legacy ID: ISSU_43 {: .eudi-hlr__meta }

If Method A is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue technical PIDs or attestations in batches to the Wallet Unit. All PIDs or attestations in a batch SHALL have the same attribute values and the same technical validity period.

AS-AP-10-078SHALL

Legacy ID: ISSU_44 {: .eudi-hlr__meta }

If Method A is used, the Wallet Unit SHALL present each technical PID or attestation only once to a Relying Party that requests the corresponding logical PID or attestation, except when it has fallen back to Method B as specified in ISSU_47.

AS-AP-10-079SHALL

Legacy ID: ISSU_45 {: .eudi-hlr__meta }

If Method A is used, the Wallet Unit SHALL have a lower limit for the number of unused technical PIDs or attestations it holds for each logical PID or attestation, and SHALL request the issuance of a new batch when this limit is reached. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the value of the lower limit and the size of the batch to be

requested, using the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

AS-AP-10-080SHALL

Legacy ID: ISSU_46 {: .eudi-hlr__meta }

If Method A is used and the Wallet Unit must request a new batch of technical PIDs or attestations but is not able to do so (for instance because it is offline), the Wallet Unit SHALL warn the User that they are about to lose the possibility to present the corresponding logical PID or attestation to Relying Parties, and request them to connect their device to the internet.

AS-AP-10-081SHALL

Legacy ID: ISSU_47 {: .eudi-hlr__meta }

If Method A is used and the Wallet Unit has run out of unused technical PIDs or attestations, but is not able to request a new batch, it SHALL fall back to method B (see ISSU_48 - ISSU_50). This means that, when requested by a Relying Party or Attestation Provider, the Wallet Unit SHALL again present one of the already used technical PIDs or attestations. The Wallet Unit SHALL return to using method A as soon as it is able to go online and request a new batch of PIDs or attestations.

AS-AP-10-082SHALL

Legacy ID: ISSU_48 {: .eudi-hlr__meta }

If Method B is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue a single technical PID or attestation to the Wallet Unit.

AS-AP-10-083SHALL

Legacy ID: ISSU_49 {: .eudi-hlr__meta }

If Method B is used, the Wallet Unit SHALL present a technical PID or attestation multiple times to the same Relying Party or to different Relying Parties, when a Relying Party requests the corresponding logical PID or attestation.

AS-AP-10-084SHALL

Legacy ID: ISSU_50 {: .eudi-hlr__meta }

If Method B is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to re-issue a technical PID or attestation some time before the one existing in the Wallet Unit expires. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the moment at

which the Wallet Unit must request the re-issuance of a technical PID or attestation, relative to the expiration date of the existing one. To do so, the PID Provider or Attestation Provider SHALL use the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

Note: It is the responsibility of the Relying Party receiving a PID or attestation to validate whether a presented technical PID or attestation is temporally valid. A Wallet Unit is allowed to present a PID or attestation even if its expiration date is in the past.

AS-AP-10-085SHALL

Legacy ID: ISSU_51 {: .eudi-hlr__meta }

If Method C is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to issue technical PIDs or attestations in batches to the Wallet Unit. All PIDs or attestations in a batch SHALL have the same attribute values and the same technical validity period.

AS-AP-10-086SHALL

Legacy ID: ISSU_52 {: .eudi-hlr__meta }

If Method C is used, the Wallet Unit SHALL present each technical PID or attestation in a batch once to a Relying Party that requests the corresponding logical PID or attestation, in a random order. When all PIDs or attestations in a batch have been presented once, the Wallet Unit SHALL reset the batch, and start presenting each PID or attestation in the batch again, in a random order. The Wallet Unit SHALL continue doing this until it receives a new batch, see ISSU_54.

AS-AP-10-087

Legacy ID: ISSU_53 {: .eudi-hlr__meta }

Empty

AS-AP-10-088SHALL

Legacy ID: ISSU_54 {: .eudi-hlr__meta }

If Method C is used, the Wallet Unit SHALL request the PID Provider or Attestation Provider to re-issue a batch of technical PIDs or attestations some time before the batch in the Wallet Unit expires. The PID Provider or Attestation Provider SHALL inform the Wallet Unit about the size of the batch and about the moment at which the Wallet Unit must request the re-issuance of a batch, relative to the expiration date of the existing batch. To do so, the PID

Provider or Attestation Provider SHALL use the `credential_reuse_policy` Credential Issuer Metadata parameter specified in section 4.2.4.2 of ETSI TS 119 472-3.

AS-AP-10-089SHALL

Legacy ID: ISSU_55 {: .eudi-hlr__meta }

If Method D is used, the Wallet Unit SHALL present a different technical PID or attestation to each different Relying Party that requests the corresponding logical PID or attestation. This means that it SHALL comply with all requirements for Method A for such Relying Parties.

Note: This means the Wallet Unit presents an unused technical attestation to each new Relying Party that request the logical attestation, and it requests a new batch of technical attestations if the number of remaining unused attestations goes below the lower limit. If for some reason requesting a new batch is not successful and the Wallet Unit runs out of unused technical attestations, it re-uses one of the already used technical attestations.

AS-AP-10-090SHALL

Legacy ID: ISSU_56 {: .eudi-hlr__meta }

If Method D is used and a given Relying Party requests attributes from a given logical PID or attestation multiple times, the Wallet Unit MAY present the same technical PID or attestation to this Relying Party each time. If it does, it SHALL comply with all requirements for Method B for such a Relying Party.

AS-AP-10-091

Legacy ID: ISSU_56a {: .eudi-hlr__meta }

Empty

AS-AP-10-092SHALL

Legacy ID: ISSU_57 {: .eudi-hlr__meta }

If Method D is used, the Wallet Unit SHALL keep track of which technical PID or attestation it has presented to which Relying Party.

Note: To do so, the Wallet Unit can use the unique RP identifier contained in the registration certificate of the presentation requests it receives.

AS-AP-10-093

Legacy ID: ISSU_57a {: .eudi-hlr__meta }

Empty

AS-AP-10-094SHALL

Legacy ID: ISSU_58 {: .eudi-hlr__meta }

A Wallet Unit SHALL give its User the option to manually initiate a re-issuance process for any of the logical PIDs or attestations in their Wallet Unit. If the User uses this option, the Wallet Unit SHALL attempt to start the re-issuance process immediately, and SHALL notify the User if it did not succeed in requesting re-issuance.

Note: a) This requirement does not apply for KAs or WIAs, since Users must not be involved in their management. b) In the case of a PID or an attestation bound to the WSCA/WSCD, the Wallet Unit will request the User to authenticate to the WSCA/WSCD (see WIAM_14). In case of an attestation bound to a keystore, no additional User authentication is needed, see WIAM_15c.

AS-AP-10-095SHALL

Legacy ID: ISSU_59 {: .eudi-hlr__meta }

After a successful re-issuance, a Wallet Unit SHALL compare the attribute values of the re-issued technical PID or attestation with those of the existing technical PID or attestation, and SHALL notify the User in case of any differences.

Note: a) This requirement does not apply for KAs or WIAs, since Users must not be involved in their management. b) The point of this requirement is to allow the User to detect errors in the attribute values in the new attestation. The follow-up process in case of errors is not defined. Presumably, the User can contact the Attestation Provider to discuss the fact that it apparently holds false attribute values for the User, and as a result, the Attestation Provider may decide to revoke the attestation.

AS-AP-10-096SHALL

Legacy ID: ISSU_60 {: .eudi-hlr__meta }

A Wallet Unit SHALL gracefully handle situations in which re-issuance of a PID, attestation, KA, or WIA fails or is refused by the PID Provider, Attestation Provider, or Wallet Provider, for example by attempting a retry after an appropriate delay.

AS-AP-10-097SHALL

Legacy ID: ISSU_61 {: .eudi-hlr__meta }

A Wallet Unit SHALL support PID or attestation first-time batch issuance with a single User authentication, regardless of the size of the batch.

Note: See also requirement WIAM_14.

AS-AP-10-098SHALL

Legacy ID: ISSU_62 {: .eudi-hlr__meta }

If a technical PID or attestation was successfully re-issued because the value of one or more of its attributes was changed (including attributes being added or deleted), a Wallet Unit SHALL no longer present the (now obsolete) pre-existing technical PID or attestation, and SHOULD delete it.

Note: a) It is up to the Wallet Unit, possibly using metadata provided by the PID Provider or Attestation Provider using the OpenID4VCI protocol, to determine the technical PID or attestation to be deleted. b) Additionally, per requirement VCR_09, the PID Provider or Attestation Provider revokes the pre-existing technical PID or attestation.

AS-AP-10-099SHALL

Legacy ID: ISSU_63 {: .eudi-hlr__meta }

PID Providers and Attestation Providers, and Wallet Units SHALL support the features of OpenID4VCI enabling the re-issuance of PIDs and attestations.

AS-AP-10-100SHALL

Legacy ID: ISSU_64 {: .eudi-hlr__meta }

PID Providers, Attestation Providers, and Wallet Units SHALL support the features of OpenID4VCI enabling the batch issuance of technical PIDs or attestations.

AS-AP-10-101SHALL

Legacy ID: ISSU_65 {: .eudi-hlr__meta }

A PID Provider or an Attestation Provider of device-bound attestations SHALL verify that a re-issued technical PID or device-bound attestation is issued to the same Wallet Unit as the existing PID or attestation.

Note: A PID Provider or Attestation Provider can do so by issuing a device-bound refresh token to the Wallet Instance during the original issuance of the PID or attestation, and requiring that the Wallet Instance uses it to obtain a fresh access token during re-issuance. See OpenID4VCI section 14.5. The PID Provider or Attestation Provider needs to be able to trust that the Wallet Instance handles the refresh tokens in a secure way, so that an attacker cannot use them from another Wallet Instance. This requires trust in the (continued) security and integrity of both the original Wallet Instance and the other Wallet Instance. This trust is provided by providing the PID Provider or Attestation Provider with a valid KA for the new Wallet Unit during re-issuance,

and by enabling the PID Provider or Attestation Provider to verify that the original Wallet Unit has not been revoked.

AS-AP-10-102

Legacy ID: ISSU_66 {: .eudi-hlr__meta }

Empty

AS-AP-10-103SHALL

Legacy ID: ISSU_67 {: .eudi-hlr__meta }

A PID Provider SHALL have a policy governing all aspects of PID issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to a PID. The policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of PIDs rather than public key certificates.

Note: A common dedicated policy for issuing PIDs may be developed in the future. If so, this requirement will be changed to refer to it.

AS-AP-10-104SHALL

Legacy ID: ISSU_68 {: .eudi-hlr__meta }

PID Providers SHALL ensure that the certificates they use for signing PIDs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 4.

AS-AP-10-105SHALL

Legacy ID: ISSU_69 {: .eudi-hlr__meta }

A QEAA Provider SHALL have a policy governing all aspects of QEAA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569. The policy SHALL comply with at least the policy for qualified certificates issued to a natural person where the private key and the related certificate reside on a QSCD ('QCP-n-qscd') or qualified certificates issued to a legal person where the private key and the related certificate reside on a QSCD ('QCP-l-qscd') requirements as specified in ETSI EN 319 411-2, insofar applicable for the issuance of QEAAs rather than public key certificates.

Note: A common dedicated policy for issuing QEAAs may be developed in the future. If so, this requirement will be changed to refer to it.

AS-AP-10-106SHALL

Legacy ID: ISSU_70 {: .eudi-hlr__meta }

QEAA Providers SHALL ensure that the certificates they use for signing QEAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 7.

AS-AP-10-107SHALL

Legacy ID: ISSU_71 {: .eudi-hlr__meta }

Providers of non-qualified EAAs SHALL ensure that the certificates they use for signing EAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 6.

AS-AP-10-108SHALL

Legacy ID: ISSU_72 {: .eudi-hlr__meta }

A PuB-EAA Provider SHALL have a policy governing all aspects of PuB-EAA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to a PuB-EAA. The policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of PuB-EAAs rather than public key certificates.

Note: A common dedicated policy for issuing PuB-EAAs may be developed in the future. If so, this requirement will be changed to refer to it

AS-AP-10-109SHALL

Legacy ID: ISSU_73 {: .eudi-hlr__meta }

PuB-EAAs Providers SHALL ensure that the certificates they use for signing PuB-EAAs comply with all applicable requirements in ETSI TS 119 412-6, in particular Clause 8.

AS-AP-12-001SHALL

Legacy ID: ARB_01 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL specify that one or more of the following two common format(s) must be used for these attestations: - The format specified in ISO/IEC 18013-5, see ISO/IEC 18013-5. - The format specified in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC.

AS-AP-18-001SHOULD

Legacy ID: ACP_03 {: .eudi-hlr__meta }

A Cryptographic Binding of Attestations scheme SHOULD be implemented using a Zero-Knowledge Proof mechanism that satisfies the requirements specified in Topic 53.

AS-AP-18-002

Legacy ID: ACP_06 {: .eudi-hlr__meta }

Empty

AS-AP-18-003SHALL

Legacy ID: ACP_07 {: .eudi-hlr__meta }

Before making a request according to ACP_05, an Attestation Provider SHALL verify that the new attestation indeed belongs to the User of the existing PID or attestation.

AS-AP-28-001

Legacy ID: LP_02 {: .eudi-hlr__meta }

Empty

AS-AP-42-001SHALL

Legacy ID: QTSPAS_01 {: .eudi-hlr__meta }

In accordance with ETSI TS 119 478 and Technical Specification 11, Member States SHALL define: - discovery mechanisms that enable QTSPs to request information about Authentic Sources or designated intermediaries recognised at the national level. This includes information regarding the attributes of a natural or legal person for which the Authentic Source or designated intermediary is considered a primary source, or for which it is recognised as authentic in accordance with Union law or national law, including administrative practices. - procedures for QTSPs to request the verification of attributes from Authentic Sources.

AS-AP-42-002SHALL

Legacy ID: QTSPAS_02 {: .eudi-hlr__meta }

An Authentic Source in the public sector, or its designated intermediary, SHALL implement an interface complying with ETSI TS 119 478 and Technical Specification 11 for receiving verification requests and sending responses. For each received request, the Authentic Source SHALL - identify and authenticate the requestor in such a way that it can subsequently determine whether the requestor is a QTSP issuing qualified electronic attestation of attributes, for example by means of a lookup in the QTSP Trusted List. - authenticate the User and obtain their approval, if it is legally obliged to do so, in addition to the User authentication and approval

already performed by the QTSP according to QTSPAS_08. - verify whether the attribute values claimed by the QTSP match the values held by the Authentic Source and, finally, - respond with one of the following for each attribute: +‘match’, if the attribute value held for this User by the Authentic Source is identical to the value claimed by the QTSP, + ‘no match’, if the attribute value held for this User by the Authentic Source is not identical to the value claimed by the QTSP, including if the Authentic Source is the authentic source for this attribute but does not hold a value for this User, +‘unknown’, if the Authentic Source is not the authentic source for this attribute.

AS-AP-42-003SHALL

Legacy ID: QTSPAS_03 {: .eudi-hlr__meta }

An Authentic Source or designated intermediary SHALL respond to a verification request for attributes by any QTSP issuing qualified electronic attestation of attributes.

AS-AP-42-004SHALL

Legacy ID: QTSPAS_04 {: .eudi-hlr__meta }

An Authentic Source or designated intermediary SHALL implement the technical specifications mentioned in QTSPAS_01, so that the QTSP will receive the result of the verification of the requested attributes as described in QTSPAS_02. If the verification is deferred, the response to the QTSP SHALL include the maximum time that it will take to verify the requested attributes, and a unique identifier that the QTSP SHALL use to obtain the result of the verification.

AS-AP-42-005SHALL

Legacy ID: QTSPAS_05 {: .eudi-hlr__meta }

A QTSP SHALL send an attribute verification request directly to the Authentic Source or designated intermediary recognised at national level, after discovering it using the mechanisms specified the technical specifications mentioned in QTSPAS_01.

AS-AP-42-006SHALL

Legacy ID: QTSPAS_06 {: .eudi-hlr__meta }

Member States SHALL specify the processes and mechanisms to designate the Authentic Sources or intermediaries recognised at national level in accordance with Union or national law, allowing these Authentic Sources or intermediaries to verify the attributes presented to them by QTSPs.

AS-AP-42-007

Legacy ID: QTSPAS_07 {: .eudi-hlr__meta }

Empty

AS-AP-42-008

Legacy ID: QTSPAS_07a {: .eudi-hlr__meta }

Empty

AS-AP-42-009SHALL

Legacy ID: QTSPAS_08 {: .eudi-hlr__meta }

A QTSP SHALL obtain approval from the User to verify the authenticity of the attributes, before requesting the verification of those attributes by the relevant Authentic Source or designated intermediary.

AS-AP-43-001SHALL

Legacy ID: EDP_11 {: .eudi-hlr__meta }

An Attestation Provider SHALL revoke an attestation if a corresponding embedded disclosure policy is added, changed, or deleted.

AS-AP-44-001SHALL

Legacy ID: RPRC_13 {: .eudi-hlr__meta }

During the registration process for PID Providers, QEAA Providers, PuB-EAA Provider, or non-qualified EAA Providers, as specified in Topic 27, a Provider of registration certificates associated to the Member State Registrar SHALL create and sign or seal a separate registration certificate for each of the registered Services of the registering entity, and issue it to the registering entity. Each registration certificate SHALL comply with the requirements in the technical specification mentioned in RPRC_01.

AS-AP-44-002SHALL

Legacy ID: RPRC_14 {: .eudi-hlr__meta }

A PID Provider, QEAA Provider, PuB-EAA Provider, or non-qualified EAA Provider SHALL distribute the registration certificates it received during registration to all service supply points having an access certificate containing the same Service identifier.

Note: A service supply point is a system at which a Wallet Unit can start the process of requesting and obtaining a PID or attestation.

AS-AP-44-003SHALL

Legacy ID: RPRC_15 {: .eudi-hlr__meta }

The contents of a registration certificate issued to a PID Provider, a QEAA Provider, a PuB-EAA Provider, or a non-qualified EAA Provider SHALL contain the type(s) of attestation that the applicable Service of this entity intends to issue to Wallet Units.

AS-AP-44-004SHALL

Legacy ID: RPRC_22 {: .eudi-hlr__meta }

A PID Provider or Attestation Provider SHALL include the registration certificate of the applicable Service in its Credential Issuer metadata used in the common OpenID4VCI protocol referenced in ISSU_01 and the extension thereof in ETSI TS 119 472-3. The registration certificate SHALL be included in the metadata by value, not by reference.

Note: This ensures that no external requests are necessary to validate the PID Provider or Attestation Provider, and that issuance transactions are atomic and self-contained.

AS-AP-44-005SHALL

Legacy ID: RPRC_22a {: .eudi-hlr__meta }

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify the format, authenticity, and validity of the registration certificate it obtained from a PID Provider's or Attestation Provider's metadata, according to the technical specification meant in RPRC_01. If the certificate is absent, malformed, inauthentic, or expired, the Wallet Unit SHALL warn the User that it could not obtain or validate the information registered about the PID Provider or Attestation Provider, and SHALL NOT request the issuance of a PID or attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-44-006SHALL

Legacy ID: RPRC_22b {: .eudi-hlr__meta }

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify that the registration certificate contains the same unique identifier as the access certificate in the PID Provider's or Attestation Provider's metadata. If this is not the case, the Wallet Unit SHALL warn the User that it could not validate the information registered about the PID Provider or Attestation Provider, and SHALL NOT request the issuance of a PID or attestation

Note: a) If the registration certificate does not comply with this requirement, a fraudulent entity acting as a PID Provider or Attestation Provider may be trying to use a registration certificate that was issued to another PID Provider or Attestation Provider. b) The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-44-007SHALL

Legacy ID: RPRC_23 {: .eudi-hlr__meta }

Before requesting the issuance of a PID or an attestation, a Wallet Unit SHALL verify that the type of attestation it wants to request from a PID Provider or Attestation Provider is included in the registration certificate of that Provider. If that is not the case, the Wallet Unit SHALL warn the User that the PID Provider or Attestation Provider is not registered for issuing the desired attestation type, and SHALL NOT request the issuance of a PID or attestation.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

AS-AP-53-001SHALL

Legacy ID: ZKP_04 {: .eudi-hlr__meta }

A ZKP scheme SHOULD support the derivation of a verifiable User pseudonym, by combining an attribute value that is unique for the User with Relying Party-specific context (e.g., the Relying Party identifier) In addition to the generic functions defined in ZKP_01, for this use case, a ZKP scheme SHALL provide support for the following functions: (i) generation of a request for the issuance of an attestation that includes a secret attribute unique to the User, without revealing this attribute to the Attestation Provider, (ii) generation of an attestation presentation that includes a verifiable pseudonym derived from the secret attribute, a Relying Party identifier, and context-related information.

Note: See section 4.1.5 of the Discussion Paper for Topic G.

---

4. Relying Parties

These requirements are for the services and entities that accept and use the EUDI Wallet. They cover how they must register, authenticate themselves to the wallet, request user attributes, and handle user data.

EW-PIO-01-024SHALL

Legacy ID: OIA_12 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a PID using a trust anchor provided in a PID Provider LoTE made available in accordance with Topic 31].

AS-RP-01-002SHALL

Legacy ID: OIA_16 {: .eudi-hlr__meta }

When receiving a PID or attestation, a Relying Party Instance SHALL discard the values of all unique elements, including at least the ones mentioned in requirement ISSU_35 in Topic 10, as well as any timestamps, as soon as they are no longer needed. The Relying Party Instance SHALL NOT communicate these values to the Relying Party or to any other party inside or outside the EUDI Wallet ecosystem.

AS-RP-01-003SHOULD

Legacy ID: OIA_17 {: .eudi-hlr__meta }

A Relying Party Instance SHOULD verify the device-binding signature or Message Authentication Code provided in the presentation response of the Wallet Unit during the presentation of a PID or device-bound attestation, following the steps specified per ISO/IEC 18013-5 or SD-JWT VC, as applicable.

AS-RP-06-001

Legacy ID: RPA_02a {: .eudi-hlr__meta }

Empty

AS-RP-48-001SHALL

Legacy ID: DATA_DLT_02 {: .eudi-hlr__meta }

A Wallet Unit SHALL support at least the following possibilities to send a data erasure request to a Relying Party: a) Open a URL in an external browser to ask for the deletion of data in a web form provided by the Relying Party, b) Open an external mail client and start a draft e-mail to the Relying Party, with a suitable template text, c) open an external phone client and start a phone call. Depending on whether a Relying Party URL, e-mail address, and/or phone number was logged for the relevant attestation presentation transaction (see requirement DASH_03 in Topic 19), the Wallet Unit SHALL offer the User to use one or more of these possibilities.

AS-RP-48-002

Legacy ID: DATA_DLT_02a {: .eudi-hlr__meta }

Empty

AS-RP-48-003SHALL

Legacy ID: DATA_DLT_03 {: .eudi-hlr__meta }

A Wallet Instance SHALL provide a function where the User may select one Relying Party to which a data deletion request must be submitted.

AS-RP-48-004SHALL

Legacy ID: DATA_DLT_06 {: .eudi-hlr__meta }

For the initiation of a data deletion request, the log SHALL contain at least: - Date and time of the initiation of the request, - Name and unique identifier of the Relying Party to which the request was made, - Attributes requested to be deleted.

AS-RP-48-005SHALL

Legacy ID: DATA_DLT_07 {: .eudi-hlr__meta }

Before executing a data deletion request, a Relying Party SHALL authenticate the requesting User (or the request itself), using appropriate authentication mechanisms of its own choosing. The Relying Party SHOULD use the authentication or signature facilities offered by the User's Wallet Unit for this purpose.

AS-RP-52-001SHALL

Legacy ID: RPI_01 {: .eudi-hlr__meta }

An intermediary SHALL register as a Relying Party, in accordance with all requirements in Topic 27, while indicating it intends to act as an intermediary.

Note: a) This implies that an intermediary obtains an access certificate containing its own trade name and unique Relying Party identifier, and Service trade name and identifier. b) An intermediary may also obtain a registration certificate according to Topic 44, but this certificate will not be used for intermediated transactions. c) An entity that registered as an intermediary may also register as a Relying Party in its own capacity. In such a case, it will receive one or more registration certificates for its Services and intended use(s), (see RPRC_09), and will use one of these certificates when interacting with a Wallet Unit.

AS-RP-52-002

Legacy ID: RPI_02 {: .eudi-hlr__meta }

Empty

AS-RP-52-003SHALL

Legacy ID: RPI_03 {: .eudi-hlr__meta }

An intermediary SHALL ensure that each intermediated Relying Party that will use its services to interact with Wallet Units, is registered at a Registrar in the Member State where the intermediated Relying Party is established, according all requirements in Topic 44. The intermediary SHALL also ensure that it receives the necessary registration certificates for the intermediated Relying Party, as specified in RPRC_09. Each of these registration certificates SHALL show that the intermediated Relying Party uses the services of the intermediary.

Note: A Registrar is free to design a suitable process to achieve these goals. For example, it may decide an intermediary can register the intermediated Relying Parties at the Registrar, and receive the registration certificates in return. Alternatively, the Registrar could request the intermediated Relying Parties ro register themselves and indicate the intermediary they will be using, in which case they will receive the registration certificates and must send them to the intermediary. Alternative processes can be used as well.

AS-RP-52-004SHALL

Legacy ID: RPI_04 {: .eudi-hlr__meta }

Before registering the relationship between an intermediary and an intermediated Relying Party and issuing a registration certificate showing that the intermediated Relying Party uses the services of the intermediary, a Registrar SHALL ensure it obtains legally valid evidence that this Relying Party will indeed use the services of this intermediary to interact with Wallet Units.

Note: A Registrar is free to decide which evidence it needs and how it obtains this evidence. For example, the Registrar may require either the intermediary or the intermediated Relying Party to provide a signed copy of the contract between both parties. Alternatively, the Registrar could ask an authorised representative of the Relying Party to sign off on a registration that was done by the intermediary, or could ask for a mandate from the intermediated Relying Party to the intermediary to register the Relying Party.

AS-RP-52-005SHALL

Legacy ID: RPI_05 {: .eudi-hlr__meta }

When an intermediated Relying Party asks its intermediary to request some attributes from a Wallet Unit, it SHALL indicate which single registration certificate the intermediary must include in the presentation request.

AS-RP-52-006SHALL

Legacy ID: RPI_06 {: .eudi-hlr__meta }

When requested by an intermediated Relying Party, an intermediary SHALL request a presentation of attributes from a specific Wallet Unit. In the request, the intermediary SHALL include the applicable intermediary's access certificate meant in requirement RPI_01 and the registration certificate of the Relying Party, indicated per RPI_05.

Note: The applicable access certificate contains the association to this specific intermediated Relying Party, see Reg_34a.

AS-RP-52-007

Legacy ID: RPI_06a {: .eudi-hlr__meta }

Empty

AS-RP-52-008SHALL

Legacy ID: RPI_07 {: .eudi-hlr__meta }

In case a Wallet Unit receives a presentation request from an intermediary on behalf of an intermediated Relying Party, it SHALL NOT display the trade names of the intermediary and the intermediary Service to the User when asking for User approval, as described in RPA_07.

AS-RP-52-009

Legacy ID: RPI_07a {: .eudi-hlr__meta }

Empty

AS-RP-52-010

Legacy ID: RPI_07b {: .eudi-hlr__meta }

Empty

AS-RP-52-011SHALL

Legacy ID: RPI_08 {: .eudi-hlr__meta }

When a Wallet Unit presents to an intermediary any User attributes from a PID or attestation, the intermediary SHALL, after successfully carrying out the verifications in RPI_09, forward

these attributes only to the Relying Party on behalf of which the presentation request was made. If any of the verifications in RPI_09 fail, the intermediary SHALL NOT forward any attributes to the Relying Party, nor to any other entity.

AS-RP-52-012SHALL

Legacy ID: RPI_09 {: .eudi-hlr__meta }

When a Wallet Unit presents to an intermediary any attributes from a PID or attestation, the intermediary SHALL verify the authenticity of the PID or attestation, its revocation status, device binding and User binding, as well as any combined presentation of attributes, if applicable, as specified in this ARF and if agreed with the Relying Party.

Note: The ARF does not mandate that a Relying Party must carry out all of these verifications. Therefore, the intermediary and any Relying Party using its services must agree on what verifications the intermediary will carry out.

AS-RP-52-013SHALL

Legacy ID: RPI_10 {: .eudi-hlr__meta }

The intermediary SHALL delete any PIDs or attestations it obtained from the Wallet Unit, including any User attributes, completely and immediately after it has sent the User attributes to the intermediated Relying Party. If the intermediary does not send any User attributes to the intermediated Relying Party, for example because one of the verifications in RPI_09 failed, the intermediary SHALL delete the PIDs or attestations completely and immediately as soon as it has completed all necessary verifications.

Part 2: Ecosystem-Wide Rules

5. Protocols & Interoperability

These requirements define the common communication standards and protocols that ensure the entire system works together seamlessly across borders. This covers how different components talk to each other.

EW-PIO-01-001SHALL

Legacy ID: OIA_01 {: .eudi-hlr__meta }

For proximity presentation flows, a Wallet Unit SHALL support the transmission mechanism specified in ISO/IEC 18013-5 to receive and respond to presentation requests for person identification data (PID) and attestations by Relying Parties.

EW-PIO-01-002SHALL

Legacy ID: OIA_01a {: .eudi-hlr__meta }

For remote presentation flows, a Wallet Unit SHALL support the following transmission mechanisms: - The API-mediated mechanisms specified in OIA_08, OIA_08a, and OIA_08b, - The mechanisms based on redirects specified in OIA_03b and OIA_03c.

EW-PIO-01-003SHALL

Legacy ID: OIA_02 {: .eudi-hlr__meta }

A Wallet Unit SHALL support proving cryptographic device binding between the WSCA/WSCD or a keystore included in the Wallet Unit and a PID or attestation, in accordance with SD-JWT VC or ISO/IEC 18013-5.

Note: Such a mechanism is called 'mdoc authentication' in ISO/IEC 18013-5 and 'key binding' in SD-JWT VC.

EW-PIO-01-004SHALL

Legacy ID: OIA_03 {: .eudi-hlr__meta }

When issuing, presenting, or verifying an attestation, Wallet Units, PID Providers, Attestation Providers, and Relying Parties SHALL only use cryptographic algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

EW-PIO-01-005

Legacy ID: OIA_03a {: .eudi-hlr__meta }

Empty

EW-PIO-01-006SHALL

Legacy ID: OIA_03b {: .eudi-hlr__meta }

For remote presentation flows using redirects and OpenID4VP, when the format of the requested attestation complies with ISO/IEC 18013-5, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.1 and 5.3.1, as well as with the 'ISO mdocs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. This does not include sections 5.1, 5.2, and 5.3. b) For clarity: in HAIP v1.0, the 'ISO mdocs' profile implies that Relying Parties and Wallet Units must comply with the applicable requirements in OpenID4VP Annex B.2. c) This requirement and OIA_03c both correspond to the profile for transmission via redirects specified in ETSI TS 119 472-2 Section 1, but are more specific with regard to format of the attestation.

EW-PIO-01-007SHALL

Legacy ID: OIA_03c {: .eudi-hlr__meta }

For remote presentation flows using redirects and OpenID4VP, when the format of the requested attestation complies with SD-JWT VC, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.1, and 5.3.2, as well as with the 'IETF SD-JWT VCs' profile in Section 6 and with Sections 7 and 8

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. This does not include sections 5.1, 5.2, and 5.3. b) For clarity: in HAIP v1.0 Section 6, the 'IETF SD-JWT VCs' profile implies that Relying Parties and Wallet Units must comply with the requirements in OpenID4VP Annex B.3, as well as with the requirements in Section 6.1.

EW-PIO-01-008MAY

Legacy ID: OIA_03d {: .eudi-hlr__meta }

For remote presentation flows using redirects and ISO/IEC 18013-7, Relying Parties and Wallet Units MAY comply with the requirements in ISO/IEC 18013-7 Annex A.

EW-PIO-01-009

Legacy ID: OIA_04 {: .eudi-hlr__meta }

Empty

EW-PIO-01-010SHALL

Legacy ID: OIA_05 {: .eudi-hlr__meta }

After verifying and processing a PID or attestation request, the Wallet Unit SHALL display to the User the identity of the requesting Relying Party and the requested attributes.

EW-PIO-01-011SHALL

Legacy ID: OIA_06 {: .eudi-hlr__meta }

A Wallet Unit SHALL present the requested attributes only after having received the User's approval.

Note: See also OIA_07.

EW-PIO-01-012SHALL

Legacy ID: OIA_07 {: .eudi-hlr__meta }

A Wallet Unit SHALL support selective disclosure of attributes from PIDs and attestations to be presented to the requesting Relying Parties.

EW-PIO-01-013SHALL

Legacy ID: OIA_08 {: .eudi-hlr__meta }

For remote presentation flows using the W3C Digital Credentials API and OpenID4VP, when the format of the requested attestation complies with ISO/IEC 18013-5, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.2 and 5.3.1, as well as with the 'ISO mdocs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. b) For clarity: in HAIP v1.0, the 'ISO mdocs' profile implies that Relying Parties and Wallet Units must comply with the applicable requirements in OpenID4VP Annex B.2. c) This requirement and OIA_08a both correspond to the profile for API-mediated transmission specified in ETSI TS 119 472-2 Section 1, but are more specific with regard to format of the attestation.

EW-PIO-01-014SHALL

Legacy ID: OIA_08a {: .eudi-hlr__meta }

For remote presentation flows using the W3C Digital Credentials API and OpenID4VP, when the format of the requested attestation complies with SD-JWT VC, Relying Parties and Wallet Units SHALL comply with the requirements in HAIP Sections 5, 5.2 and 5.3.2, as well as with the 'IETF SD-JWT VCs' profile in Section 6 and with Sections 7 and 8.

Note: a) 'HAIP Section 5' refers only to the requirements directly under the Section 5 heading. b) For clarity: in HAIP v1.0 Section 6, the 'IETF SD-JWT VCs' profile implies that Relying Parties and Wallet Units must comply with the requirements in OpenID4VP Annex B.3, as well as with the requirements in Section 6.1.

EW-PIO-01-015SHALL

Legacy ID: OIA_08b {: .eudi-hlr__meta }

For remote presentation flows using the W3C Digital Credentials API and ISO/IEC 18013-7, Relying Party Instances and Wallet Units SHALL comply with the requirements in ISO/IEC 18013-7 Annex C.

Note: The latter restriction applies even if such disclosure would enhance the services provided by the operating system to the Wallet Unit, for example, attestation selection in the context of the Digital Credentials API.

EW-PIO-01-016SHOULD

Legacy ID: OIA_08c {: .eudi-hlr__meta }

Wallet Units SHOULD NOT support using a redirects-based transmission mechanism for cross-device presentation flows.

EW-PIO-01-017SHALL

Legacy ID: OIA_08d {: .eudi-hlr__meta }

If a Relying Party uses a redirects-based transmission mechanism for cross-device presentation flows, it SHALL implement adequate mitigations for the challenges described in Section 4.4.3.1 of the ARF main document.

EW-PIO-01-018SHALL

Legacy ID: OIA_08e {: .eudi-hlr__meta }

A Wallet Unit SHALL, by default (see OIA_08f), disclose the presence of all stored attestations (meaning their attestation type) to the Digital Credentials API framework, but it SHALL NOT disclose the presence of attributes in these attestations, nor their values.

Note: The latter restriction applies even if such disclosure would enhance the services provided by the operating system to the Wallet Unit, for example, attestation selection in the context of the Digital Credentials API.

EW-PIO-01-019SHALL

Legacy ID: OIA_08f {: .eudi-hlr__meta }

A Wallet Unit SHALL provide a global User setting to disable the disclosure of stored attestations to the Digital Credentials API framework, as described in OIA_08e. When this setting is set to disable disclosure, the Wallet Unit SHOULD subsequently enable the User to select individual attestations to be disclosed to the DC API.

Note: If this setting is set to disable disclosure and the User does not subsequently select any individual attestations to be disclosed, the Wallet Unit will not disclose any attributes at all. As a result, presentation requests sent using the DC API will likely fail.

EW-PIO-01-020SHALL

Legacy ID: OIA_08g {: .eudi-hlr__meta }

In cross-device presentation flows using the W3C Digital Credentials API, a Wallet Unit SHALL verify that the Relying Party Instance is in close physical proximity to the Wallet Unit. For this proximity check the Wallet Unit SHALL use a secure, direct, and user-mediated local communication channel, such as a short-range wireless communication technology.

Note: In CTAP terms, this proximity check is the BLE proximity engagement, present in both the Hybrid transport specified in CTAP v2.2 and in CTAP v2.3. Where both devices support it, the underlying operating systems, browsers, mediating APIs, or any other technical layer outside the control of the Wallet Unit, should prefer performing both the proximity check and the data transfer over a local short-range channel (as enabled by CTAP v2.3) over the use of a Hybrid tunnel service first defined in CTAP v2.2.

EW-PIO-01-021SHALL

Legacy ID: OIA_09 {: .eudi-hlr__meta }

For remote presentation flows the Wallet Unit SHALL ensure that the attributes included in the presented attestation are accessible only to the Relying Party Instance, by encrypting the presentation response.

EW-PIO-01-022SHALL

Legacy ID: OIA_10 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, if a Wallet Unit contains multiple PIDs having the same encoding (e.g. ISO/IEC 18013-5 or SD-JWT VC-compliant) and a Relying Party requests a PID having that encoding, the Wallet Unit SHALL ask the User which of these PIDs they want to present, unless the Wallet Unit can decide from context.

Note: This requirement is not about multiple technical PIDs corresponding to a single logical PID, but to different logical PIDs whose technical PIDs have the same encoding. Probably, these logical PIDs are issued by different PID Providers.

EW-PIO-01-023SHALL

Legacy ID: OIA_11 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, if a Wallet Unit contains multiple attestations having the same encoding (e.g. ISO/IEC 18013-5 or SD-JWT VC-compliant) and the same attestation type, and a Relying Party requests an attestation having that type and encoding, the Wallet Unit SHALL ask the User which of these attestations they want to present, unless the Wallet Unit can decide from context.

Note: a) Attestation types are explained in Topic 12]. b) See note to OIA_10, which applies mutatis mutandis.

EW-PIO-01-025SHALL

Legacy ID: OIA_13 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, a Relying Party SHALL validate the qualified signature of a QEAA in accordance with Art.32 of the European Digital Identity Regulation. For the verification, the Relying Party SHALL use a trust anchor provided in a QEAA Provider Trusted List made available in accordance with Art. 22 of the European Digital Identity Regulation.

EW-PIO-01-026SHALL

Legacy ID: OIA_14 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a PuB-EAA using a trust anchor provided in a Pub-EAA Provider LoTE made available in accordance with Topic 31].

EW-PIO-01-027SHALL

Legacy ID: OIA_15 {: .eudi-hlr__meta }

For both proximity and remote presentation flows, a Relying Party SHALL validate the signature of a non-qualified EAA using a trust anchor provided according to the mechanism(s) specified in the applicable Attestation Rulebook, see Topic 12].

Note: a) OIA_12 - OIA_15 imply that a Relying Party Instance must know if the attestation it is requesting from a Wallet Instance is a PID, a QEAA, a PuB-EAA, or a non-qualified EAA. These requirements also imply that the Relying Party Instance must store trust anchors in such a way that, at the time of verification, it is able to distinguish between trust anchors usable either for PIDs, for QEAAs, for PuB-EAAs, or for non-qualified EAAs.

EW-PIO-01-028SHALL

Legacy ID: OIA_15a {: .eudi-hlr__meta }

A Relying Party SHALL perform regular trust anchor management, meaning it SHALL download the latest version of all applicable Trusted Lists and LoTEs. If it finds that new trusted entities have been added, or that new trust anchors have been added for existing trusted entities, it SHALL ensure that these trust anchors are properly stored in all relevant Relying Party Instances. Conversely, if the Relying Party finds that an existing trusted entity has been invalidated in the Trusted List or LoTE, or that some of the trust anchors of existing trusted entities have expired, been revoked, or otherwise been invalidated, it SHALL ensure that these trust anchors are removed from all Relying Party Instances.

EW-PIO-01-029SHALL

Legacy ID: OIA_15b {: .eudi-hlr__meta }

For the retrieval and management of trust anchors, Relying Parties and Relying Party Instances SHALL support both Trusted Lists complying with ETSI TS 119 612 and LoTEs complying with ETSI TS 119 602.

Note: Trusted Lists complying with ETSI TS 119 612 are used for the distribution of trust anchors of QEAA Providers. LoTEs complying with ETSI TS 119 602 are used for the distribution of trust anchors of PID Providers, PuB-EAA Providers, Access Certificate Authorities, and Providers of registration certificates.

EW-PIO-10-001SHALL

Legacy ID: ISSU_01 {: .eudi-hlr__meta }

Wallet Providers SHALL ensure that their Wallet Solution supports the OpenID4VCI protocol specified in OpenID4VCI, as profiled in Sections 4 and 6 of HAIP, and with additions and changes as documented in this Annex (see e.g. this Topic and Topic 9) and in Technical Specification 3.

Note: For clarity: in HAIP v1.0, Section 6 implies that Wallet Units must comply with the applicable requirements in OpenID4VCI Annex A.2 when requesting the issuance of an attestation in ISO/IEC 18013-5-compliant format, and with the applicable requirements in OpenID4VCI Annex A.3 when requesting the issuance of an attestation in SD-JWT VC format.

EW-PIO-24-001SHALL

Legacy ID: ProxId_01 {: .eudi-hlr__meta }

To enable identification using proximity flows, Wallet Units SHALL support device retrieval as specified in ISO/IEC 18013-5 for presenting PID or attestation attributes. Wallet Units SHALL comply with the requirements for mDLs and mdocs ISO/IEC 18013-5.

Note: Nominally, ISO/IEC 18013-5 is intended only for mDLs and mDL readers. The corresponding standard for mobile documents in general (including Wallet Units with the EUDI Wallet ecosystem) will be ISO/IEC 23220-4, which is based on ISO/IEC 18013-5. However, the latter standard is not finished yet and therefore cannot be referenced at the moment. To guarantee interoperability between Wallet Units and Relying Party Instances in proximity scenarios, it is necessary to make choices from among the possibilities specified in ISO/IEC 18013-5. Making the same choices as for mDLs ensure this.

EW-PIO-24-002SHALL

Legacy ID: ProxId_01a {: .eudi-hlr__meta }

If a Relying Party supports using proximity flows, its Relying Party Instances SHALL support device retrieval as specified in ISO/IEC 18013-5 for requesting PID or attestation attributes. Such Relying Party Instances SHALL comply with the requirements for mDL readers and mdoc readers in ISO/IEC 18013-5.

Note: See note to ProxId_01. Support for proximity flows by Relying Parties is not mandatory.

EW-PIO-24-003SHALL

Legacy ID: ProxId_02 {: .eudi-hlr__meta }

Wallet Units, PID Providers, Attestation Providers, Wallet Providers, and Relying Parties SHALL NOT support server retrieval as specified in ISO/IEC 18013-5 for requesting and presenting PID or attestation attributes.

Note: Using server retrieval, a Relying Party would request User attributes directly from a PID Provider or Attestation Provider, after having received an authentication and/or authorisation token from the User's Wallet Unit.

EW-PIO-24-004SHALL

Legacy ID: ProxId_03 {: .eudi-hlr__meta }

A Wallet Unit SHALL present the presentation request and the identity of the Relying Party to the User when processing the request.

EW-PIO-24-005SHALL

Legacy ID: ProxId_04 {: .eudi-hlr__meta }

A Wallet Unit SHALL request its User to approve the presentation of attributes from their Wallet Unit for proximity identification before presenting them to the Relying Party or Verifier Wallet Unit.

EW-PIO-24-006SHALL

Legacy ID: ProxId_05 {: .eudi-hlr__meta }

A Wallet Unit SHALL transmit the requested User attributes to the requesting Relying Party Instance securely in accordance with ISO/IEC 18013-5 for proximity flows.

EW-PIO-24-007

Legacy ID: ProxId_06 {: .eudi-hlr__meta }

Empty

EW-PIO-29-001SHALL

Legacy ID: RP_02 {: .eudi-hlr__meta }

An Attestation Provider issuing representation attestations to a natural person representing another natural person SHALL ensure that either the attestations are short-lived or that all entities which, according to applicable law, must have the ability to request revocation of such attestations, are able to do so.

EW-PIO-30-001SHALL

Legacy ID: W2W_08 {: .eudi-hlr__meta }

A Verifier Wallet Unit and a Holder Wallet Unit SHALL support attestation presentation only in proximity, meaning they SHALL support only ISO/IEC 18013-5 to communicate.

EW-PIO-43-001SHALL

Legacy ID: EDP_09 {: .eudi-hlr__meta }

An Attestation Provider SHALL include an embedded disclosure policy (if any) by value in the Issuer metadata related to the attestation, in compliance with OpenID4VCI and ETSI TS 119 472-3.

---

6. Data Models & Attestation Rules

These requirements define the structure and meaning of the data being exchanged. This includes HLRs for PIDs, Attestation Rulebooks, and Catalogues, ensuring that the information exchanged is consistent and understandable across the entire ecosystem.

EW-DM-03-01SHALL

Legacy ID: PID_01 {: .eudi-hlr__meta }

PIDs and PID Providers SHALL comply with all requirements in PID Rulebook.

EW-DM-03-02SHALL

Legacy ID: PID_02 {: .eudi-hlr__meta }

A PID Provider SHALL issue any PID in both the format specified in ISO/IEC 18013-5 ISO/IEC 18013-5 and the format specified in SD-JWT VC.

EW-DM-03-03SHALL

Legacy ID: PID_03 {: .eudi-hlr__meta }

During issuance of a PID, the PID Provider MAY enable the User to opt out from receiving a portrait attribute in their PID. If the User opts out, the PID Provider SHALL include the `portrait` attribute in the PID as an empty JSON `string` or CBOR `bstr`, as applicable given the format of the PID.

Note: As described in the PID Rulebook and in the Regulation amending CIR 2024/2977, inclusion of the `portrait` attribute in the PID is mandatory only from 24 months after the entry into force of that Regulation.

AS-RP-03-01SHALL

Legacy ID: PID_03a {: .eudi-hlr__meta }

If a Relying Party obtains the `portrait` attribute from a User's PID, it SHALL NOT retain the portrait, unless its processing is necessary for the purposes of identification and authentication in compliance with Union data protection law or where this is provided for by Union or national law, in compliance with Union data protection law. The Relying Party SHALL NOT transfer the portrait to third countries or international organisations unless permitted by Union data protection law.

Note: See CIR 2024/2977.

EW-DM-03-04SHALL

Legacy ID: PID_04 {: .eudi-hlr__meta }

PID Providers SHALL use "eu.europa.ec.eudi.pid.1" as the attestation type for ISO/IEC 18013-5-compliant PIDs.

Note: a) This identifier uses the general format [Reverse Domain].[Domain Specific Extension]. Since the European Commission controls the domain ec.europa.eu, this attestation type identifier will not collide with any attestation type identifiers defined by other organisations in other Attestation Rulebooks. b) The version number 1 in this identifier is used to distinguish between the first version of the PID, defined in the PID Rulebook, and any future version, which will then have an incremented version number.

EW-DM-03-05SHALL

Legacy ID: PID_05 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL use the value "eu.europa.ec.eudi.pid.1" for the identifier of the namespace for the PID attributes specified in Section 4.2 of the PID Rulebook.

Note: a) The version number 1 allows for future extension(s) or change(s) of the ISO/IEC 18013-5-compliant PID attributes. b) This namespace has the same value as the attestation type specified in requirement PID_04. This is allowed according to ISO/IEC 18013-5.

EW-DM-03-06SHALL

Legacy ID: PID_06 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider MAY include attributes that are not defined in the PID Rulebook. If so, these attributes SHALL be defined within a domestic PID namespace as meant in requirement ARB_10 in Topic 12. The PID Provider SHALL generate the identifier for this domestic PID namespace by appending the applicable ISO 3166-1 alpha-2 country code or the ISO 3166-2 region code, separated by a period, to the PID namespace identifier specified in PID_05, excluding the version number. The PID Provider MAY include a version number in the domestic PID namespace identifier.

Note: For example, the identifier of the first domestic PID namespace for Germany could be "eu.europa.ec.eudi.pid.de.1".

EW-DM-03-07SHALL

Legacy ID: PID_07 {: .eudi-hlr__meta }

A PID Provider that defines a domestic namespace SHALL publish the namespace, including all attribute identifiers, their definition, presence and encoding format, in an Attestation Rulebook complying with all applicable requirements in Topic 12.

EW-DM-03-08SHALL

Legacy ID: PID_08 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL include both the attributes and the metadata specified in CIR 2024/2977 in the PID as issuer-signed data elements.

Note: This implies that technically speaking, there is no difference between these attributes and metadata.

EW-DM-03-09SHALL

Legacy ID: PID_09 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL encode each attribute or metadata in the PID as specified in the third column of the tables in Section 4.2.1 of the PID Rulebook.

EW-DM-03-10SHALL

Legacy ID: PID_10 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL encode each attribute or metadata in the PID in Concise Binary Object Representation (CBOR) according to RFC 8949.

EW-DM-03-11SHALL

Legacy ID: PID_11 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL ensure that each PID contains at most one attribute with the same attribute identifier.

EW-DM-03-12SHALL

Legacy ID: PID_12 {: .eudi-hlr__meta }

When issuing a PID compliant with ISO/IEC 18013-5, a PID Provider SHALL ensure that the value of all attributes and metadata in the PID is valid at the value of the timestamp in the validFrom element in the MSO, see ISO/IEC 18013-5 clause 9.1.2.4.

Note: The value of the age_over_18, age_over_NN, or age_in_years attributes, if present, changes whenever the User to whom the person identification data relates has a relevant birthday. The value of many other attributes will also change over time.

EW-DM-03-13SHALL

Legacy ID: PID_13 {: .eudi-hlr__meta }

If a PID Provider issues PIDs compliant with ISO/IEC 18013-5 and containing the `issuance_date` or `expiry_date` attributes, the PID Provider SHALL have a policy for determining the value of these attributes relative to the `validFrom` and `validUntil` elements in the MSO, see ISO/IEC 18013-5 clause 9.1.2.4.

Note: See the notes to the `issuance_date` and `expiry_date` attributes in PID Rulebook. Examples of aspects to be considered in the policy may include (but are not limited to) the following: 1) If an `issuance_date` or `expiry_date` is encoded as a `full-date` (rather than a `tdate`), it has no time element. However, `validFrom` and `validUntil` contain a time element, which is expressed in UTC. Therefore, comparing `expiry_date` to `validUntil`, for instance, may give ambiguous results in case the local time is not equal to UTC. The policy should ensure that situations are avoided where the User can legitimately expect (based on the values of `issuance_date` and `expiry_date` shown by the Wallet Unit when displaying the PID) that they can use their PID, while in reality its technical validity period (as determined by `validFrom` and `validUntil`) has not yet begun or has ended. 2) The exact meaning of `issuance_date` and `expiry_date` depends on local law and regulations. For example, in some jurisdictions an identity document whose `expiry_date` is in the past may by law still be used for identification for some purposes. However, this requires that the PID is still valid according to the `validFrom` and `validUntil` timestamps in the MSO. 3) A local requirement may exist stating that `issuance_date` and `expiry_date` must be identical to the dates on an existing physical document of the User.

EW-DM-03-14SHALL

Legacy ID: PID_14 {: .eudi-hlr__meta }

A PID Provider issuing SD-JWT VC-compliant PIDs SHALL include the vct claim in their PIDs, where the vct claim SHALL be a URN within the `urn:eudi:pid:` namespace. The type indicated by the vct claim SHALL be `urn:eudi:pid:1` for the type defined in this document or a domestic type that extends it.

EW-DM-03-15

Legacy ID: PID_15 {: .eudi-hlr__meta }

Empty

EW-DM-03-16SHALL

Legacy ID: PID_16 {: .eudi-hlr__meta }

A PID Provider that defines a domestic type SHALL publish information about the type, including all claim identifiers, their definition, presence and encoding format, in an Attestation Rulebook complying with all applicable requirements in Topic 12.

EW-DM-03-17SHALL

Legacy ID: PID_17 {: .eudi-hlr__meta }

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL include both the attributes and the metadata specified in CIR 2024/2977 in the PID as claims.

Note: This implies that technically speaking, there is no difference between these attributes and metadata.

EW-DM-03-18SHALL

Legacy ID: PID_18 {: .eudi-hlr__meta }

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL encode each attribute or metadata in the PID as specified in the tables in Section 5.2 of the PID Rulebook.

EW-DM-03-19SHALL

Legacy ID: PID_19 {: .eudi-hlr__meta }

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL ensure that the value of all attributes and metadata in the PID is valid at the value of the timestamp in the nbf claim, if present.

Note: The value of the age-related claims, if present, changes whenever the User to whom the person identification data relates has a relevant birthday. The value of many other attributes will also change over time.

EW-DM-03-20SHALL

Legacy ID: PID_20 {: .eudi-hlr__meta }

If a PID Provider issues PIDs compliant with SD-JWT VC and containing the `date_of_issuance` or `date_of_expiry` claims, the PID Provider SHALL have a policy for determining the value of these claims relative to the `nbf` and `exp` claims in the SD-JWT VC, see SD-JWT VC section 3.2.2.2.

Note: See the notes to the `date_of_issuance` and `date_of_expiry` attributes in PID Rulebook. Examples of aspects to be considered in the policy may include (but are not limited to) the following: 1) `date_of_issuance` and `date_of_expiry` claims do not have a

time element. However, `nbf` and `exp` express a time relative to UTC. Therefore, comparing `date_of_expiry` to `exp`, for instance, may give ambiguous results in case the local time is not equal to UTC. The policy should ensure that situations are avoided where the User can legitimately expect (based on the value of `date_of_issuance` and `date_of_expiry` shown by the Wallet Unit when displaying the PID) that they can use their PID, while in reality its technical validity period (as determined by `nbf` and `exp`) has not yet begun or has ended. 2) The exact meaning of `date_of_issuance` and `date_of_expiry` depends on local law and regulations. For example, in some jurisdictions an identity document whose `date_of_expiry` is in the past may by law still be used for identification for some purposes. However, this requires that the PID is still valid according to the `nbf` and `exp` timestamps in the SD_JWT VC. 3) A local requirement may exist stating that `date_of_issuance` and `date_of_expiry` must be identical to the dates on an existing physical document of the User.

EW-DM-03-21SHALL

Legacy ID: PID_21 {: .eudi-hlr__meta }

When issuing a PID compliant with SD-JWT VC, a PID Provider SHALL make all claims (i.e., all top-level properties, all nested properties, and all array entries) selectively disclosable individually, except those claims defined as non-selectively disclosable in SD-JWT VC.

EW-DM-04-001SHALL

Legacy ID: mDL_01 {: .eudi-hlr__meta }

mDLs and mDL Providers SHALL comply with all requirements in mDL Rulebook.

EW-DM-12-001SHALL

Legacy ID: ARB_01a {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHALL specify that one or more of the following three common format(s) must be used for these attestations: - The format specified in ISO/IEC 18013-5, see ISO/IEC 18013-5. - The format specified in SD-JWT-based Verifiable Credentials (SD-JWT VC), see SD-JWT VC. - The format specified in W3C Verifiable Credentials Data Model, see W3C VCDM v2.0.

EW-DM-12-002SHALL

Legacy ID: ARB_01b {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing attestations using the format

specified in SD-JWT VC SHALL ensure that these attestations comply with the 'IETF SD-JWT VC Profile' specified in HAIP Section 6.1.

EW-DM-12-003SHALL

Legacy ID: ARB_02 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL analyse whether it must be possible for a User to present that type of attestation when the Wallet Unit and the Relying Party are in proximity and attestations are presented without using the internet. If so, the Attestation Rulebook SHALL specify that the attestations must be issued in the ISO/IEC 18013-5-compliant mdoc format.

Note: In theory, it is possible to use SD-JWT VC-compliant attestations in proximity use cases. In practice, however, the only protocol available to request and present SD-JWT VC-compliant attestations between a Wallet Unit and a Relying Party Instance is OpenID4VP. That protocol cannot be used without internet connectivity.

EW-DM-12-004MAY

Legacy ID: ARB_03 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook MAY specify in the Attestation Rulebook that that type of attestation must be issued in the SD-JWT VC-compliant format, provided the SD-JWT VC specification has been approved by an EU standardisation body or by the European Digital Identity Cooperation Group established pursuant to Article 46e(1) of the European Digital Identity Regulation.

EW-DM-12-005SHALL

Legacy ID: ARB_04 {: .eudi-hlr__meta }

If an Attestation Rulebook specifies that a type of attestation can be issued in a format compliant with W3C VCDM v2.0, the Scheme Provider for that Attestation Rulebook SHALL ensure the Rulebook references one or more documents specifying in detail how a Relying Party can request attributes from a such an attestation, and how a User can selectively disclose attributes from such an attestation. Moreover, these referenced documents SHALL be approved by an EU standardisation body or by the European Digital Identity Cooperation Group established pursuant to Article 46e(1) of the European Digital Identity Regulation.

EW-DM-12-006SHALL

Legacy ID: ARB_05 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL specify a value for the attestation type, which SHALL be unique within the scope of the EUDI Wallet ecosystem.

Note: In ISO/IEC 18013-5, the attestation type is called 'document type' and is included as a `docType` *key-value pair in both the mdoc request and the mdoc response. Also, a method for generating unique attestation type values is recommended. In OpenID4VP, the attestation type is included in the* `meta` *property of a Credential Query in a presentation request. In SD-JWT VC, the attestation type is called 'SD-JWT VC type' and is included as a* `vct` *claim in the SD-JWT VC.*

EW-DM-12-007SHALL

Legacy ID: ARB_06 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL define all attributes that an attestation of that type may contain. This definition SHALL first describe the semantics of each attribute in an encoding-independent manner and SHALL subsequently for each attribute specify an ISO/IEC 18013-5-compliant format, an SD-JWT VC-compliant format, or both, as needed given the choices made according to ARB_01 - ARB_04.

EW-DM-12-008SHALL

Legacy ID: ARB_06a {: .eudi-hlr__meta }

For ISO/IEC 18013-5-compliant attestations, the Attestation Rulebook SHALL define each attribute within an attribute namespace. An attribute namespace SHALL fully define the identifier, the syntax, and the semantics of each attribute within that namespace. An attribute namespace SHALL have an identifier that is unique within the scope of the EUDI Wallet ecosystem, and each attribute identifier SHALL be unique within that namespace.

Note: In ISO/IEC 18013-5, namespaces are discussed and a method for generating unique namespace identifiers is recommended.

EW-DM-12-009SHALL

Legacy ID: ARB_06b {: .eudi-hlr__meta }

For SD-JWT VC-compliant attestations, the Scheme Provider for the Attestation Rulebook SHALL ensure that each claim name is either: - included in the IANA registry for JWT claims, - is a Public Name as defined in RFC 7519, or is a Private Name specific to the attestation type.

Note: SD-JWT VC does not discuss how to avoid conflicting claim names. Since SD-JWTs are a special kind of JWTs, the methods specified in RFC 7519 are applicable.

EW-DM-12-010SHOULD

Legacy ID: ARB_07 {: .eudi-hlr__meta }

When determining the attributes to be included in a new attestation type, the Scheme Provider for the applicable Attestation Rulebook SHOULD consider referring to attributes that are already included in the catalogue of attributes specified in Topic 25 or specified in an attestation scheme included in the catalogue of attestation schemes specified in Commission Implementing Regulation 2025/1569, rather than unnecessarily re-defining all attributes.

EW-DM-12-011SHOULD

Legacy ID: ARB_08 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHOULD, when specifying a new attribute, take into consideration existing conventions for attribute identifier values and attribute syntaxes.

Note: These conventions may depend on the format of the attestation, i.e., CBOR for ISO/IEC 18013-5-compliant attestations or JSON for SD-JWT VC-compliant attestations.

EW-DM-12-012SHALL

Legacy ID: ARB_09 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL specify, for each attribute in the attestation, whether the presence of that attribute is mandatory, optional, or conditional.

EW-DM-12-013SHALL

Legacy ID: ARB_10 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook for an ISO/IEC 18013-5 compliant attestation MAY define a domestic namespace to specify attributes that are specific to that Rulebook and are not included in the applicable EU-wide or sectoral namespace. All requirements for namespaces in this Topic SHALL also apply for domestic namespaces.

EW-DM-12-014SHALL

Legacy ID: ARB_11 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook an attribute as meant in Annex V point a) and Annex VII point a) of the European Digital Identity Regulation. This attribute SHALL reference the technical specification meant in ARB_25.

EW-DM-12-015SHALL

Legacy ID: ARB_12 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include an attribute in the Rulebook indicating that the attestation is an EAA. This attribute SHALL reference the technical specification meant in ARB_25.

EW-DM-12-016SHALL

Legacy ID: ARB_13 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point b) of the European Digital Identity Regulation.

EW-DM-12-017SHALL

Legacy ID: ARB_14 {: .eudi-hlr__meta }

The Scheme Provider for an attestation Rulebook describing a type of attestation that is a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex VII point b) of the European Digital Identity Regulation.

EW-DM-12-018SHOULD

Legacy ID: ARB_15 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point b) of the European Digital Identity Regulation.

EW-DM-12-019SHALL

Legacy ID: ARB_16 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes representing the set of data meant in Annex V point c) or Annex VII point c) of the European Digital Identity Regulation.

EW-DM-12-020SHOULD

Legacy ID: ARB_17 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes representing the set of data meant in Annex V point c) of the European Digital Identity Regulation.

EW-DM-12-021SHALL

Legacy ID: ARB_18 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the set of data meant in Annex V point e) or Annex VII point e) of the European Digital Identity Regulation.

EW-DM-12-022SHOULD

Legacy ID: ARB_19 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes representing the set of data meant in Annex V point e) of the European Digital Identity Regulation.

EW-DM-12-023SHALL

Legacy ID: ARB_20 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL include in the Rulebook one or more attributes or metadata representing the location meant in Annex V point h) or Annex VII point h) of the European Digital Identity Regulation. This location SHALL indicate at least the URL at which a machine-readable version of the trust anchor to be used for verifying the QEAA or PuB-EAA can be found or looked up.

EW-DM-12-024SHOULD

Legacy ID: ARB_21 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD include in the Rulebook one or more attributes or metadata representing the location at which a machine-readable version of the trust anchor to be used for verifying the EAA can be found or looked up.

Note: What this location indicates precisely is dependent on the nature of the mechanism used for distributing trust anchors - see requirement ARB_26.

EW-DM-12-025SHALL

Legacy ID: ARB_22 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL specify all technical details necessary to ensure interoperability, security, and privacy of that attestation.

Note: An Attestation Rulebook may also specify requirements regarding how the Wallet Unit must display the attestation and the attributes in it to the User.

EW-DM-12-026SHALL

Legacy ID: ARB_23 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA or a PuB-EAA SHALL specify which of the revocation mechanisms specified in Topic 7 SHALL be supported by that attestation.

EW-DM-12-027SHALL

Legacy ID: ARB_24 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHALL specify whether that type of EAA must be revocable. If an EAA type must be revocable, the relevant Rulebook SHALL determine which of the revocation mechanisms specified in Topic 7 SHALL be supported by that attestation.

EW-DM-12-028SHALL

Legacy ID: ARB_24a {: .eudi-hlr__meta }

If an attestation is revocable, the relevant Attestation Rulebook SHALL specify the URL at which Relying Parties and other entities can retrieve the relevant Attestation Status Lists or Attestation Revocation Lists.

Note: This could be the domain name only, as the full URL containing the ASL or ARL relevant for an individual attestation will anyway be included in that attestation.

EW-DM-12-029SHALL

Legacy ID: ARB_25 {: .eudi-hlr__meta }

An Attribute Schema Provider SHALL include in its Attestation Rulebook the attribute `attestation_legal_category`, specified in the Attestation Rulebook Template, with the appropriate value as specified in the Template.

Note: This attribute contains the indication meant in Annex V point a) and Annex VII point a).

EW-DM-12-030SHOULD

Legacy ID: ARB_26 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a non-qualified EAA SHOULD define in the Rulebook the mechanism(s) allowing a Relying Party to obtain, in a trustworthy manner, the trust anchor(s) of the EAA Providers issuing this type of EAA.

Note: Technical Specification 11, section 4.3.1, recommends the use of the List of trusted entities (LoTE) data model as defined in ETSI TS 119 602 for non-qualified EAAs.

EW-DM-12-031

Legacy ID: ARB_27 {: .eudi-hlr__meta }

Empty

EW-DM-12-032SHALL

Legacy ID: ARB_28 {: .eudi-hlr__meta }

An Attribute Scheme Provider MAY specify an attribute in an Attestation Rulebook that indicates whether the Attestation Provider during attestation issuance requested a cryptographic binding (as specified in Topic 18) between the new attestation and an existing PID or attestation. If present in a Rulebook, the identifier for this attribute SHALL be `cryptographically_bound_to`, and its contents SHALL be an attestation type or vct (see ARB_05).

Note: The meaning of this attribute, if present, is that this attestation is cryptographically bound to one or more attestations of the given attestation type or vct on this Wallet Unit. If a Relying Party receives this attribute from a Wallet Unit, it can subsequently request the Wallet Unit to send a proof of cryptographic binding between the attestation and an attestation indicated in the `cryptographically_bound_to` attribute.

EW-DM-12-033SHOULD

Legacy ID: ARB_29 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook describing a type of attestation that is a QEAA, PuB-EAA, or non-qualified EAA SHOULD ensure that the structure and contents of the Attestation Rulebook follow the descriptions in the Attestation Rulebook template.

EW-DM-12-034SHALL

Legacy ID: ARB_30 {: .eudi-hlr__meta }

If an Attestation Rulebook specifies a SD-JWT VC-compliant attestation, the Scheme Provider for that Attestation Rulebook SHALL specify for all claims (i.e., all top-level properties, all nested properties, and all array entries) whether an Attestation Provider MUST, MAY, or MUST NOT make that claim selectively disclosable.

Note: a) This requirement does not apply to claims defined as non-selectively disclosable in SD-JWT VC. b) There will be use cases where a specific claim must not be disclosed without simultaneously disclosing one or more other claims. Such cases should be solved by making all of these claims members of the same JSON object (or elements of the same JSON array). That JSON object (or array) is then the claim that must be selectively disclosable, while the nested properties (or individual array elements) must not be selectively disclosable. c) This requirement does not apply to ISO/IEC 18013-5-compliant attestations, since in such attestations, by definition all data elements are selectively disclosable, while none of the key-value pairs or array elements inside a data element (if any) are selectively disclosable.

EW-DM-12-035SHOULD

Legacy ID: ARB_31 {: .eudi-hlr__meta }

If an Attestation Rulebook specifies a SD-JWT VC-compliant attestation, the Scheme Provider for that Attestation Rulebook SHOULD consider defining a Type Metadata Document for it, as defined in Chapter 6 of SD-JWT VC. If the Scheme Provider defines such a document, it SHOULD contain the Claim Selective Disclosure Metadata (defined in Section 9.3 of SD-JWT VC) for each of the claims, in order to specify if that claim is selectively disclosable (see requirement ARB_30).

Note: Although a Type Metadata Document is a highly technical document, defining it has a number of advantages for developers, Attestation Providers, Relying Parties, and Wallet Units, as spelled out in Chapter 6 of SD-JWT VC.

EW-DM-12-036

Legacy ID: ARB_32 {: .eudi-hlr__meta }

Empty

EW-DM-12-037SHALL

Legacy ID: ARB_33 {: .eudi-hlr__meta }

If a Scheme Provider for an Attestation Rulebook registers an attestation scheme in the catalogue of attestation schemes meant in Commission Implementing Regulation 2025/1569,

Article 8, the registration SHALL include a reference to the corresponding Attestation Rulebook.

Note: By definition, an attestation scheme is machine-readable, whereas an Attestation Rulebook is human-readable.

EW-DM-12-038SHALL

Legacy ID: ARB_34 {: .eudi-hlr__meta }

The Scheme Provider for an Attestation Rulebook SHALL specify whether that attestation is device-bound or not.

EW-DM-28-001

Legacy ID: LP_03 {: .eudi-hlr__meta }

Empty

AS-MS-31-025SHALL

Legacy ID: RPACANot_06 {: .eudi-hlr__meta }

If an Access Certificate Authority is suspended or cancelled (see requirement GenNot_05 above), that Access Certificate Authority SHALL immediately revoke all of its temporally valid access certificates.

Note: This implies that if an intermediary obtained its access certificates from an Access Certificate Authority that is suspended or cancelled, any intermediated Relying Party depending on that intermediary will not be able to request attributes from Wallet Units, even though its registration is still valid. Such an intermediated Relying Party will either have to transit to another intermediary (which has access certificates issued by an active Access Certification Authority) or wait until the original intermediary obtains new access certificates either from another Access CA or from the original one, once that CA can continue its operations.

EW-DM-31-002SHALL

Legacy ID: TLPub_03 {: .eudi-hlr__meta }

The publication of the information referred to in TLPub_01 SHALL take place over a secure channel protecting the authenticity and integrity of the published information.

EW-DM-31-003SHALL

Legacy ID: TLPub_04 {: .eudi-hlr__meta }

The technical system mentioned in TLPub_01 SHALL NOT require authentication or prior registration and authorisation of any entity wishing to retrieve the published information.

EW-DM-31-004SHALL

Legacy ID: TLPub_05 {: .eudi-hlr__meta }

The information referred to in TLPub_01 SHALL be published in an electronically signed or sealed form that is suitable for automated processing, and in a human-readable format, e.g., through introspection and display facilities, over an authenticated channel.

EW-DM-38-001SHALL

Legacy ID: WURevocation_03 {: .eudi-hlr__meta }

A Wallet Provider SHALL have a policy governing all aspects of WIA and KA issuance and management, in line with clauses 6 and 7 of ETSI TS 119 471, incorporating the amendments introduced by CIR 2025/1569 and subject to the necessary adaptations to WIAs and KAs. The policy SHALL distinguish between WIAs, KAs for WSCA/WSCDs, and KAs for keystores. For KAs describing a WSCA/WSCD, the policy SHALL comply with at least the extended normalised certificate policy ('NCP+') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of KAs rather than public key certificates. For KAs describing a keystore, the policy SHALL comply with at least the normalised certificate policy ('NCP') requirements as specified in ETSI EN 319 411-1, insofar applicable for the issuance of KAs rather than public key certificates.

EW-DM-38-002

Legacy ID: WURevocation_04 {: .eudi-hlr__meta }

Empty

EW-DM-38-003

Legacy ID: WURevocation_05 {: .eudi-hlr__meta }

Empty

EW-DM-38-004

Legacy ID: WURevocation_06 {: .eudi-hlr__meta }

Empty

EW-DM-38-023SHALL

Legacy ID: WURevocation_07a {: .eudi-hlr__meta }

To revoke a WSCD or keystore of a Wallet Unit, the Wallet Provider SHALL, in the status list(s) for WSCDs and keystores, set the `revoked` status at all index positions mentioned in the KAs describing that WSCD or keystore.

Note: For this requirement, it does not matter whether each index in the status list(s) for WSCDs and keystores refers to a type of WSCD or keystore or to an individual WSCD or keystore.

EW-DM-38-006

Legacy ID: WURevocation_08 {: .eudi-hlr__meta }

Empty

EW-DM-38-016

Legacy ID: WURevocation_15 {: .eudi-hlr__meta }

Empty

EW-DM-38-018

Legacy ID: WURevocation_17 {: .eudi-hlr__meta }

Empty

EW-DM-38-019

Legacy ID: WURevocation_19a {: .eudi-hlr__meta }

Empty

EW-DM-38-020

Legacy ID: WURevocation_19b {: .eudi-hlr__meta }

Empty

EW-DM-38-021

Legacy ID: WURevocation_20 {: .eudi-hlr__meta }

Empty

EW-DM-38-022

Legacy ID: WURevocation_21 {: .eudi-hlr__meta }

Empty

EW-DM-43-001

Legacy ID: EDP_04 {: .eudi-hlr__meta }

Empty

EW-DM-44-001SHALL

Legacy ID: RPRC_01 {: .eudi-hlr__meta }

Providers of registration certificates SHALL comply with all relevant requirements in ETSI TS 119 475.

EW-DM-44-002SHALL

Legacy ID: RPRC_01a {: .eudi-hlr__meta }

A Provider of registration certificates SHALL be able to revoke a registration certificate, if it has a validity period of longer than 24 hours, in accordance with the applicable requirements in ETSI TS 119 475.

EW-DM-44-003SHALL

Legacy ID: RPRC_01b {: .eudi-hlr__meta }

A Provider of registration certificates SHALL have a policy specifying under which conditions a registration certificate it issued will be revoked.

EW-DM-44-004SHALL

Legacy ID: RPRC_02 {: .eudi-hlr__meta }

When signing a registration certificate, the Provider of registration certificates SHALL include the signing certificate and, if present, any intermediate certificate(s) leading up to the corresponding trust anchor of the Provider in the LoTE, in the `x5c` parameter in the JOSE header of the registration certificate.

EW-DM-44-005SHALL

Legacy ID: RPRC_02a {: .eudi-hlr__meta }

For the verification of the registration certificates of Relying Parties, a Wallet Unit SHALL accept all trust anchors of Providers of registration certificates, as published by the Commission in the relevant LoTE, and only those.

EW-DM-44-006SHALL

Legacy ID: RPRC_03 {: .eudi-hlr__meta }

The contents of a registration certificate SHALL include at least the information required in Annex V of the CIR 2025/848 regarding registration of wallet-relying parties.

EW-DM-44-007SHALL

Legacy ID: RPRC_04 {: .eudi-hlr__meta }

If the subject of the registration certificate uses the services of an intermediary (see Topic 52), the 'association to the intermediary' mentioned in Annex I (15) of CIR 2025/848 (and referenced in Annex V, point 3(j) of that CIR) SHALL consist of the unique identifier of this intermediary, as meant in requirement Reg_32 and the intermediary's Relying Party Service identifier as meant in Reg_33.

Note: a) These identifiers are identical to those in the access certificate of the intermediary. b) The association is also included in the respective access certificate of the intermediary, see Reg_34a.

EW-DM-44-008SHALL

Legacy ID: RPRC_04a {: .eudi-hlr__meta }

The registration certificate format SHALL provide for the data elements to carry the Relying Party Service identifier mentioned in Reg_33 and the Relying Party Service trade name mentioned in Reg_34.

EW-DM-44-009SHALL

Legacy ID: RPRC_05 {: .eudi-hlr__meta }

If the subject of the registration certificate is not a Relying Party (i.e. in the terms of CIR 2025/848, a Service Provider), the certificate SHALL NOT contain the intended use as meant in Annex I (9) and (10) of CIR 2025/848.

Note: A PID Provider or Attestation Provider may request attributes from the Wallet Unit during issuance, for example to identify and authenticate the User. If so, it registers as both a Service Provider and an Attestation Provider, and consequently its registration certificate contains its intended use.

EW-DM-44-010SHALL

Legacy ID: RPRC_06 {: .eudi-hlr__meta }

The contents of a registration certificate SHALL include a trade name for the subject of the certificate, in a format suitable for presenting to a User, which SHALL be identical to the trade name in the access certificates of the entity, see Reg_31.

EW-DM-44-011SHALL

Legacy ID: RPRC_07 {: .eudi-hlr__meta }

The contents of a registration certificate SHALL include an EU-wide unique identifier for the subject of the certificate, which SHALL be identical to the identifier in the access certificates of that entity, see Reg_32.

Note: a) A Wallet Unit needs an identifier for a Relying Party at least to allow the User to send a report of suspicious Relying Party presentation requests to a data protection authority according to Topic 50.

EW-DM-44-012SHALL

Legacy ID: RPRC_07a {: .eudi-hlr__meta }

The contents of a registration certificate SHALL contain an identifier and a trade name for the Relying Party Service, which SHALL be identical to the Service identifier and trade name in one or more of the access certificates of that entity, see Reg_33 and Reg_34.

Note: There must be at least one Relying Party Instance or service supply point that is able to use a given registration certificate.

EW-DM-44-013SHALL

Legacy ID: RPRC_08 {: .eudi-hlr__meta }

The EU-wide unique identifier meant in RPRC_07 SHALL be identical in all registration certificates issued for a given entity.

Note: In case the registration certificates issued to an intermediated Relying Party are held and presented by an intermediary, the entity meant in this requirement is the intermediated Relying Party. An intermediary may obtain and hold registration certificates with a different unique identifier for other intermediated Relying Parties.

EW-DM-44-014SHALL

Legacy ID: RPRC_09 {: .eudi-hlr__meta }

During the registration process for Relying Parties, as specified in Topic 27, a Provider of registration certificates associated to the Member State Registrar SHALL create and sign or seal a separate registration certificate for each combination of intended use and Relying Party Service, as registered by the Relying Party per Reg_10d, and issue it to the Relying Party. The Provider of registration certificates SHALL do so in an automated manner and without undue

delay. Each registration certificate SHALL comply with the requirements in the technical specification mentioned in RPRC_01.

Note: Example clarifying 'each combination of intended use and Relying Party Service': If a Relying Party registers Service A having intended use 1 and 2, Service B having intended uses 2, 3, 4 and 5, and Service C having intended use 4, it would receive seven registration certificates.

EW-DM-44-015SHALL

Legacy ID: RPRC_10 {: .eudi-hlr__meta }

A Relying Party SHALL distribute the registration certificates it received during registration to its Relying Party Instances. The Relying Party SHALL ensure that the registration certificate(s) sent to a Relying Party Instance contain the same Service identifier as the access certificate of that Relying Party Instance.

Note: It is up to the Relying Party to determine if all of its Relying Party Instances need all of the registration certificates, or that some Relying Party Instances are used only for a subset of the Relying Party's Services, and consequently only need the registration certificates containing the corresponding Service identifiers.

EW-DM-44-016SHALL

Legacy ID: RPRC_11 {: .eudi-hlr__meta }

The contents of a registration certificate issued to a Relying Party SHALL contain at least one of the following: a) the URL of a web form provided by the Relying Party, which Users can use to send data deletion requests, b) an e-mail address of the Relying Party, on which the Relying Party is prepared to receive data deletion requests from Users, c) a telephone number of the Relying Party, on which the Relying Party is prepared to receive data deletion requests from Users.

Note: See Topic 48 for more information about data deletion requests.

EW-DM-44-017SHALL

Legacy ID: RPRC_12 {: .eudi-hlr__meta }

The contents of a registration certificate issued to a Relying Party SHALL contain the name and country of the Data Protection Authority supervising the Relying Party. In addition, the registration certificate SHALL contain at least one of the following: a) the URL of a web form provided by the DPA, which Users can use to report suspicious attribute presentation requests. b) an e-mail address of the DPA, on which the DPA is prepared to receive reports about suspicious attribute presentation requests from Users, c) a telephone number of the DPA, on which

the DPA is prepared to receive reports about suspicious attribute presentation requests from Users.

Note: See Topic 50 for more information about reporting suspicious attribute presentation requests.

EW-DM-44-018

Legacy ID: RPRC_16 {: .eudi-hlr__meta }

Empty

EW-DM-44-019SHALL

Legacy ID: RPRC_17 {: .eudi-hlr__meta }

A Wallet Unit SHALL verify the format, authenticity, and validity of the registration certificate it received from a Relying Party in a presentation request, according to the technical specification meant in RPRC_01. If the certificate is absent, malformed, inauthentic, or expired, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that it could not obtain or validate the information registered about the Relying Party and its Service. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether and under which conditions the Wallet Unit will allow the User to approve the presentation of the requested attributes despite specific failed verifications.

Note: The requirement for Wallet Units to verify and validate registration certificates only applies as of 24 months after entry into force of the Regulation amending CIR 2024/2982.

EW-DM-44-020SHALL

Legacy ID: RPRC_17a {: .eudi-hlr__meta }

A Wallet Unit SHALL verify that the registration certificate contains the same unique Relying Party identifier and the same Service identifier as the access certificate in the presentation request. If this is not the case, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that it could not validate the information registered about the Relying Party and its Service. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether and under which conditions the Wallet Unit will allow the User to approve the presentation of the requested attributes despite this failed verification.

Note: a) There are two ways in which a registration certificate can comply with this requirement: either the access certificate and the registration certificate were issued to the same entity, or the

access certificate was issued to an intermediary (see Topic 52), and the registration certificate indicates that the intermediated Relying Party uses the services of this intermediary. b) If the registration certificate does not comply with this requirement, a fraudulent entity acting as a Relying Party may be trying to use a registration certificate that was issued to another Relying Party.

EW-DM-44-021

Legacy ID: RPRC_18 {: .eudi-hlr__meta }

Empty

EW-DM-44-022

Legacy ID: RPRC_18a {: .eudi-hlr__meta }

Empty

EW-DM-44-023SHALL

Legacy ID: RPRC_19 {: .eudi-hlr__meta }

A Relying Party Instance SHALL include a single registration certificate applicable for its current Service and intended use in each presentation request to a Wallet Unit, according to the applicable standard's extension mentioned in RPRC_20. The registration certificate SHALL be included in the request by value, not by reference. The Relying Party Instance SHALL do so both in proximity and remote presentation flows.

Note: a) This ensures that no external requests are necessary to validate the Relying Party. b) A Relying Party Instance may be used for multiple Relying Party Services, provided it has a separate access certificate for each of these Services, see RPA_06 and Reg_10b.

EW-DM-44-024

Legacy ID: RPRC_19a {: .eudi-hlr__meta }

Empty

EW-DM-44-025SHALL

Legacy ID: RPRC_20 {: .eudi-hlr__meta }

Relying Party Instances and Wallet Units SHALL support the extension for ISO/IEC 18013-5 or the extension for OpenID4VP, as applicable. as specified in ETSI TS 119 472-2 and amended by Annex 2 of (the amended) CIR 2024/2982, for transferring a single Relying Party registration certificate from a Relying Party Instance to a Wallet Unit.

EW-DM-44-026

Legacy ID: RPRC_20a {: .eudi-hlr__meta }

Empty

EW-DM-44-027SHALL

Legacy ID: RPRC_21 {: .eudi-hlr__meta }

After receiving a presentation request from a Relying Party, a Wallet Unit SHALL verify that all attributes requested in the request are included in the list of attributes in the registration certificate included in the same request. If the outcome of the verification is negative, the Wallet Unit SHALL, when asking for User approval according to RPA_07, warn the User that the Relying Party is requesting more information than it has registered. In addition, the Wallet Provider SHALL determine, based on its risk analysis and security policy, whether the Wallet Unit must a) enable the User to approve (or reject) the presentation of all requested attributes, including the non-registered ones, b) enable the User to approve (or reject) the presentation of the registered attributes only, or c) reject the presentation of all requested attributes.

Note: This ensures that Wallet Providers comply with the 'general access policy' described in CIR 2025/848.

EW-DM-50-001

Legacy ID: RPT_DPA_03 {: .eudi-hlr__meta }

Empty

EW-DM-50-002SHALL

Legacy ID: RPT_DPA_05a {: .eudi-hlr__meta }

For a report sent to a DPA, the log SHALL contain at least: a) the date and time when the report was sent, b) the name and country of the DPA, and c) the channel and contact information used for initiating sending the report, i.e., the URL, e-mail address, or phone number of the DPA.

EW-DM-53-001SHALL

Legacy ID: ZKP_01 {: .eudi-hlr__meta }

A ZKP scheme SHALL provide support for the following generic functions, while hiding all attributes of PIDs or attestations: (i) generation of a proof that an (some) attribute(s) having a specific value is (are) included in a PID or attestation, (ii) generation of a proof that a PID

or attestation is within its validity period, (iii) generation of a proof that a PID or attestation has not been revoked, and (iv) generation of a proof that a PID or device-bound attestation is bound to a key stored in the WSCA/WSCD or in a keystore of the Wallet Unit. Additionally, a ZKP scheme SHOULD provide support for the following function, which SHOULD be used only when hiding the PID Provider or Attestation Provider is necessary: (v) generation of a proof that a PID or attestation has been issued by a trusted PID Provider or Attestation Provider, without revealing the PID Provider or Attestation Provider.

Note: See section 4.1.1 of the Discussion Paper for Topic G.

EW-DM-53-002SHALL

Legacy ID: ZKP_02 {: .eudi-hlr__meta }

A ZKP scheme SHALL support proving possession of attestation of a given type.

Note: See section 4.1.2 and 4.1.3 of the Discussion Paper for Topic G.

EW-DM-53-003SHALL

Legacy ID: ZKP_03 {: .eudi-hlr__meta }

A ZKP scheme SHOULD support the privacy-preserving binding of an attestation to a PID. In addition to the generic functions defined in ZKP_01, for this use case, a ZKP scheme SHALL provide support for the following functions: (i) generation of a proof that the Wallet Unit stores an attestation and a PID and that the attestation includes a specific attribute, having a specific value, which is also present in the PID.

Note: See section 4.1.4 of the Discussion Paper for Topic G.

EW-DM-53-004SHALL

Legacy ID: ZKP_05 {: .eudi-hlr__meta }

A ZKP scheme SHALL be usable in both remote and proximity presentation flows. While the inclusion of ZKP will introduce computational and verification delays, these delays SHALL NOT critically undermine or defeat the purpose of the Relying Party service (e.g. because of a critical impact on the User experience of the Wallet Unit).

EW-DM-53-005SHOULD

Legacy ID: ZKP_06 {: .eudi-hlr__meta }

A ZKP scheme SHOULD be able to generate proofs for already issued PIDs and attestations in the formats specified in ISO/IEC 18013-5 or SD-JWT VC.

EW-DM-53-006SHALL

Legacy ID: ZKP_07 {: .eudi-hlr__meta }

A ZKP scheme SHALL NOT introduce any additional communication or information that could be used to track or link User activity during, before, or after proof generation.

EW-DM-53-007SHALL

Legacy ID: ZKP_08 {: .eudi-hlr__meta }

A ZKP scheme SHALL rely solely on algorithms included in the ECCG Agreed Cryptographic Mechanisms v2.0.

EW-DM-53-008SHALL

Legacy ID: ZKP_09 {: .eudi-hlr__meta }

Use of a ZKP scheme SHALL NOT prevent the Wallet Unit's ability to provide User authentication with Level of Assurance High.

A.2.2 Backward Reference: Original Topics

This section provides the titles and descriptions of the original topics from which the High-Level Requirements were sourced and restructured.

- **Topic 1 - Accessing Online Services with a Wallet Unit**: One of the main use cases of the EUDI Wallet ecosystem is to enable Users to access online services and to enable Relying Parties offering such services to, where needed, identify and authenticate Users with a high level of assurance.
- **Topic 2 - Mobile Driving Licence within the EUDI Wallet ecosystem**: A User can obtain their mobile Driving Licence (mDL) from an mDL Provider and store it in a Wallet Unit. The User can then present the mDL to a Relying Party upon request to prove their driving rights conveniently, securely, and in compliance with the Driving Licences Directive.
- **Topic 3 - PID Rulebook**: The Person Identification Data (PID) Rulebook contains requirements specific to the PID within the EUDI Wallet ecosystem.
- **Topic 4 - mDL Rulebook**: The mobile driving licence (mDL) Rulebook contains requirements specific to the mDL use case within the EUDI Wallet ecosystem.

- **Topic 6 - Relying Party authentication and User approval**: Relying Party authentication is a process whereby a Relying Party proves its identity to a Wallet Unit, in the context of a transaction in which the Relying Party requests the Wallet Unit to release some attributes.
- **Topic 7 - Attestation revocation and revocation checking**: This Topic contains the high-level requirements (HLRs) relating to the (possible) revocation of PIDs, QEAAs, PuB-EAAs, non-qualified EAAs, and WUAs by their providers.
- **Topic 9 - Wallet Unit Attestation**: When a User's Wallet Unit interacts with other actors in the EUDI Wallet ecosystem, in particular PID Providers, Attestation Providers, or Relying Parties, these actors may want to verify if the Wallet Unit is authentic and has not been revoked.
- **Topic 10 - Issuing a PID or attestation to a Wallet Unit**: PID Providers and Attestation Providers issue PIDs and attestations to Wallet Units. This Topic lists the high-level technical requirements related to PID and attestation issuance.
- **Topic 11 - Pseudonyms**: Wallet Units will support generating pseudonyms for Users in compliance with the W3C WebAuthn API specification.
- **Topic 12 - Attestation Rulebooks**: This Topic describes the high-level requirements for the Attestation Rulebooks that will specify the details of new types of attestations.
- **Topic 16 - Signing documents with a Wallet Unit**: A Wallet Unit SHALL enable its User to create qualified electronic signatures or seals.
- **Topic 17 - Identity matching**: Users would like to use their PID in their Wallet Unit to access their existing online account(s), even if their PID attribute values are not exactly the same as those in their account(s).
- **Topic 18 - Combined presentations of attributes**: The concept of combined presentation refers to a process where a Relying Party requests multiple attributes concerning a single User, drawn from separate attestations, and receives a consolidated response.
- **Topic 19 - User navigation requirements (Dashboard logs for transparency)**: The User is accessing a dashboard of the Wallet Unit, which provides a record of all transactions executed through the Wallet Unit.
- **Topic 20 - Strong User authentication for electronic payments**: The European Digital Identity Regulation requires Wallet Units to provide a functionality of strong User authentication (SUA), among others in the context of payments.
- **Topic 24 - User identification in proximity scenarios**: In this use case, the User is using their Wallet Unit for identification purposes in proximity scenarios.
- **Topic 25 - Unified definition and controlled vocabularies for attributes**: This Topic

defines high-level requirements regarding the catalogue for Attestation Rulebooks.

- **Topic 27 - Registration of PID Providers, Providers of QEAAs, PuB-EAAs, and non-qualified EAAs, and Relying Parties**: PID Providers, QEAA Providers, PuB-EAA Providers, non-qualified EAA Providers, and Relying Parties register with a Registrar in their Member State.
- **Topic 28 - Wallet Unit for legal persons**: This topic is focused on identifying high-level requirements for a legal-person Wallet Unit.
- **Topic 29 - Representation paradigm**: It should be possible to issue a dedicated representation attestation for a natural person to a representative, in accordance with applicable national and European legislation.
- **Topic 30 - Interaction between Wallet Units**: A User can request another User to present an attestation, where both Users use their Wallet Unit.
- **Topic 31 - Notification and publication**: PID Providers, PuB-EAA Providers, Wallet Providers, Access Certificate Authorities, and Providers of registration certificates must be notified by a Member State to the Commission.
- **Topic 33 - Wallet Unit backup and restore**: Backup and restore functionality is needed in case the User has lost access to their current Wallet Unit.
- **Topic 34 - Migrate to a different Wallet Solution**: Data portability means that a User can migrate to a different Wallet Solution.
- **Topic 35 - PID issuance service blueprint**: This Topic analyses the User journeys for PID issuance to a Wallet Unit.
- **Topic 38 - Wallet Unit revocation**: This Topic discusses Wallet Unit revocation.
- **Topic 40 - Wallet Instance installation and Wallet Unit activation and management**: This Topic discusses requirements related to the installation of a Wallet Instance by the User, the subsequent activation of the Wallet Unit, and the management of the Wallet Unit throughout its lifetime.
- **Topic 42 - Requirements for QTSPs to access Authentic Sources**: This Topic discusses the ability of QTSPs to verify attributes by electronic means at the request of the User, wherever those attributes rely on Authentic Sources within the public sector.
- **Topic 43 - Embedded disclosure policies**: This topic is focused on identifying high-level requirements for disclosure policies which may be embedded in an attestation.
- **Topic 44 - Registration certificates**: This topic identifies high-level requirements for registration certificates.
- **Topic 48 - Blueprint for requesting data deletion to Relying Parties**: A User requests the deletion of their personal attributes from Relying Parties with which they have

interacted through their Wallet Unit.

- **Topic 50 - Blueprint to report unlawful or suspicious request of data**: A User reports a Relying Party to the competent national data protection authority for an unlawful or inappropriate request for attributes.
- **Topic 51 - PID or attestation deletion**: This topic lists high-level requirements related to a User deleting a PID or attestation from their Wallet Unit.
- **Topic 52 - Relying Party intermediaries**: This topic lists high-level requirements regarding intermediaries, which form a special class of Relying Party.
- **Topic 53 - Zero-Knowledge Proofs**: This topic lists high-level requirements for a Zero-Knowledge Proof scheme to be used within the EUDI Wallet ecosystem.
- **Topic 54 - Accessibility**: It is essential to ensure that Wallet Units are inclusive by design and fully aligned with the applicable European legal and technical frameworks on accessibility.

ANNEX 3.01 - PID Rulebook

The **PID rulebook** has been moved to a dedicated repository and is now available in the attestation rulebooks catalog on GitHub.

ANNEX 3.02 - mDL Rulebook

The **mDL rulebook** has been moved to a dedicated repository and is now available in the attestation rulebooks catalog on GitHub.

EUDI Wallet - Design Guide

For the EUDI Wallet ecosystem

November 2024 v1.1.0

This is a working document that holds no legal value and does not reflect any common agreement or position of the co-legislators. It presents a state-of-play of ongoing work of the eIDAS Expert Group. This document is being continuously updated and should not be considered final.

1 Introduction

1.1 Purpose of the design guide

This design guide outlines the principles, guidelines, and best practices for creating consistent and effective design solutions for the EUDI wallet. The purpose of a design guide is to ensure that all design work produced by a team or across different teams is consistent, coherent, adheres to certain standards and aligns with the overall goals and values of the project.

As many sections will be subject to national implementation this document includes guidelines to assist in creating a user interface that is useful, usable, and enjoyable to use. It also provides specific instructions and tips for creating accessible and inclusive designs.

1.2 Boundaries of the design guide

It shall be highlighted that this design guide does not aim to provide detailed design elements to be adopted by national EUDI Wallet implementations. Overall, the objective of the EUDI Wallet Design Guide is to:

- Identify key design principles and provide guidelines against these design principles;
- Identify specific areas of the EUDI Wallet for which design principles are considered important and expand on those in future iterations of the EUDI Wallet Design Guide.

The design guidelines listed in this document shall not be considered as mandatory towards the implementations of the EUDI Wallet, but rather stand as recommendations to ensure a common user experience across the different national implementations.

1.3 Importance of design consistency

UI (User Interface) consistency is important because it provides a better user experience and helps users navigate a mobile application more easily. When elements such as icons, colours, and fonts are consistent throughout an application, users can quickly learn how to use it and understand the application's intention.

Familiarity

Consistent UI elements give users a sense of familiarity and they can feel more comfortable using the application. If the user interface changes too often, it can cause confusion and frustration.

Efficiency

Consistency in the user interface can make navigation easier and more efficient. Users will know where to find the features they need, and they reduce cognitive load.

Accessibility

Consistent UI elements make it easier for users with disabilities to navigate the application. Users with visual impairments, for example, can more easily use screen readers when consistent UI elements are used.

Overall, UI consistency is an essential aspect of good user interface design. It makes the application more user-friendly, efficient, and accessible.

1.4 Overview of design criteria

Twelve design criteria have been selected which we go over in details in 'Section 2'. The first 10 are the usability heuristics from the Nielsen Norman group. They are called "heuristics" because they are broad rules of thumb and not specific usability guidelines. These are used to evaluate a User Interface, so it is good to have them as guiding principles during the design phase as well. These 10 principles are:

- Visibility of system status
- Match between system and the real world
- User control and freedom
- Consistency and standards
- Error prevention
- Recognition rather than recall
- Flexibility and efficiency of use
- Aesthetic and minimalist design

- Help users recognize, diagnose, and recover from errors
- Help and documentation

An additional 2 were added to address these important areas:

- Accessibility
- Writing

---

2 Design criteria

```
Disclaimer: The design guidelines listed in this document shall not be
considered as mandatory towards the implementations of the EUDI Wallet, but
rather stand as recommendations to ensure a common user experience across the
different national implementations. Any design elements included in the
following chapter are indicative and are only used to better illustrate the
corresponding design criteria.
```

2.1 Visibility of system status

```
The design should always keep users informed about what is going on through
appropriate feedback within a reasonable amount of time.
```

2.1.1 Indicative examples

Document management

When adding or removing a document the application should let the user know whether the process was completed successfully of not.

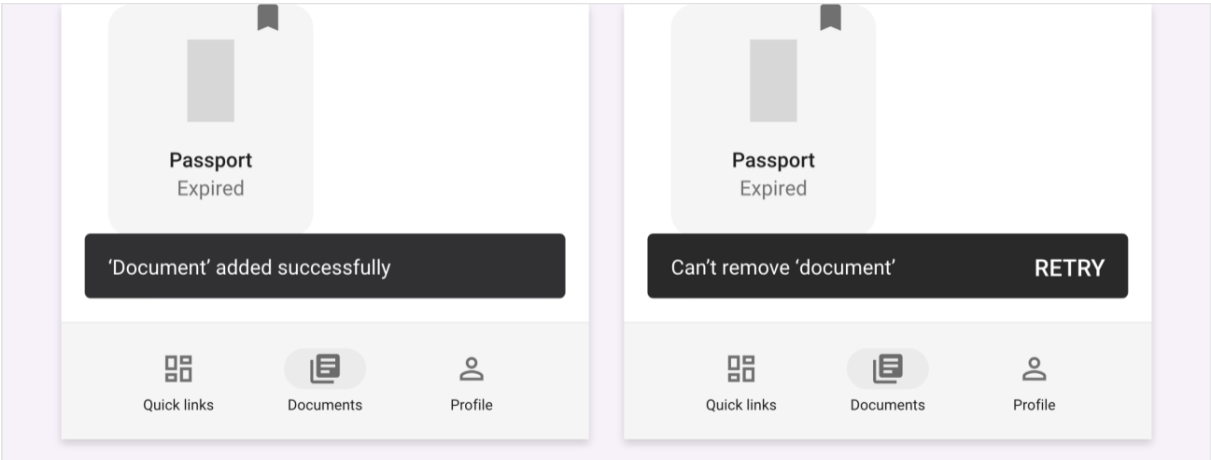


Figure 1: Document Management example

Interactive elements

Interactive elements such as buttons must have a pressed and focused state.

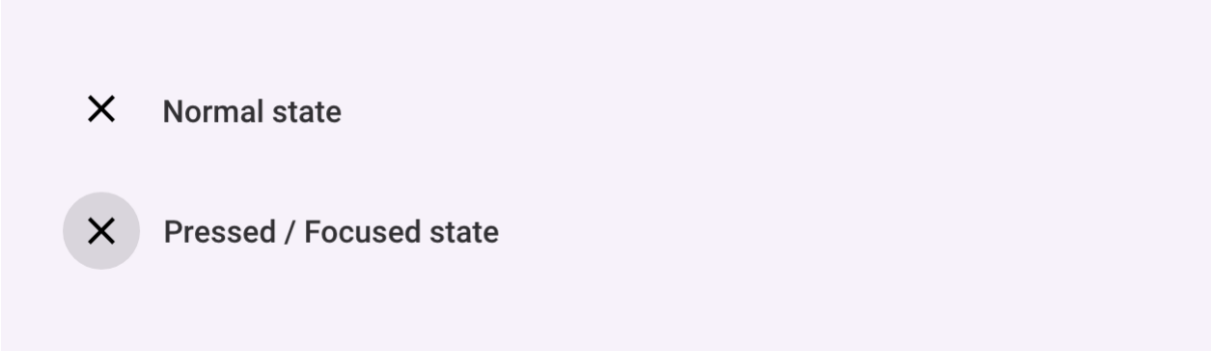


Figure 2: Interactive Elements example

2.2 Match between system and the real world

```
1 The design should speak the users' language. Use words, phrases,
    and concepts
2 familiar to the user, rather than internal jargon. Follow real-
    world
3 conventions, making information appear in a natural and logical
    order.
```

2.2.1 Indicative examples

Document representation

Documents should be (where possible) represented in the UI by what is familiar to the user instead of generic / ambiguous icons.

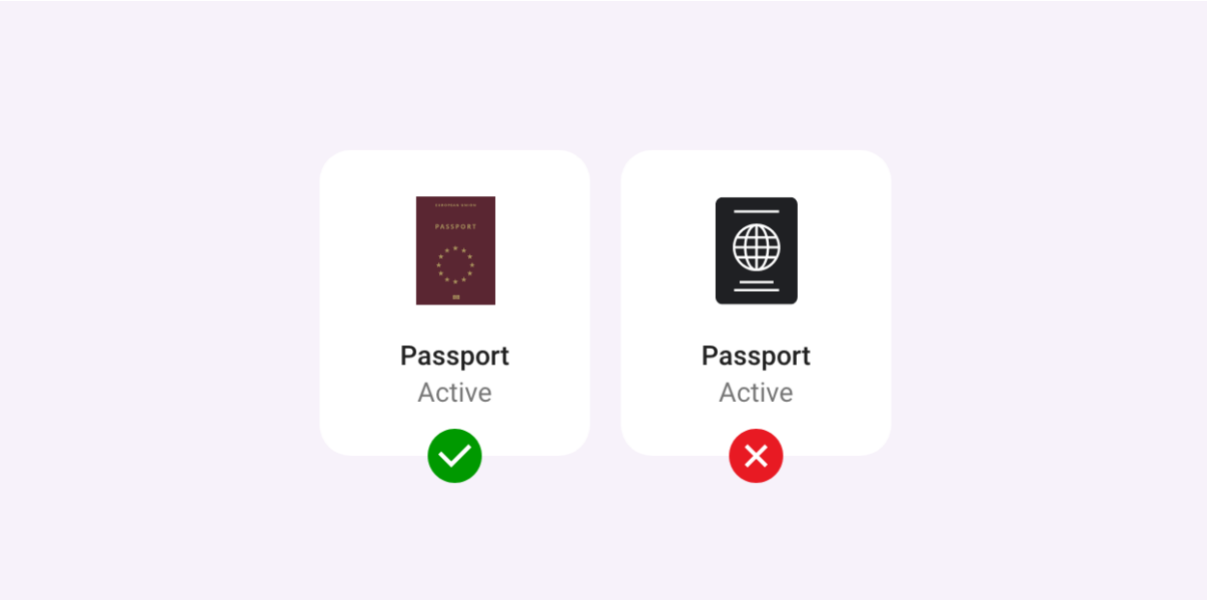


Figure 3: Document Presentation Example

Labels

Stay away from technical terms and jargon. Use labels that people use in their everyday life.

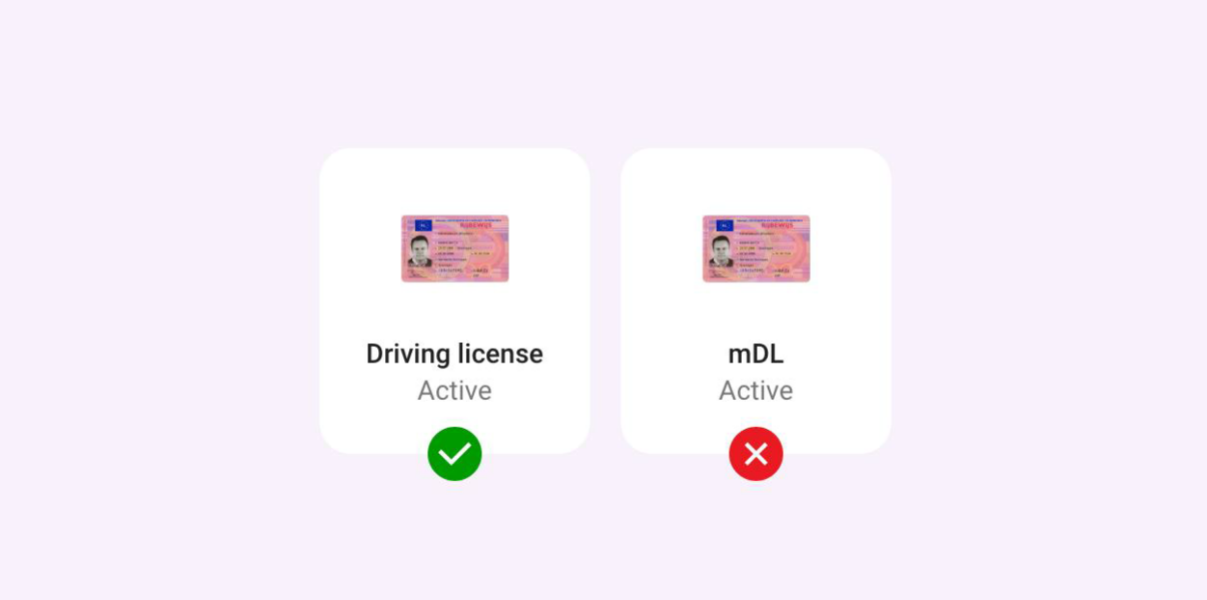


Figure 4: Labels example

Icons

People spend most of their time in other apps/websites. Use icons that are familiar and clear to them instead on ambiguous ones.

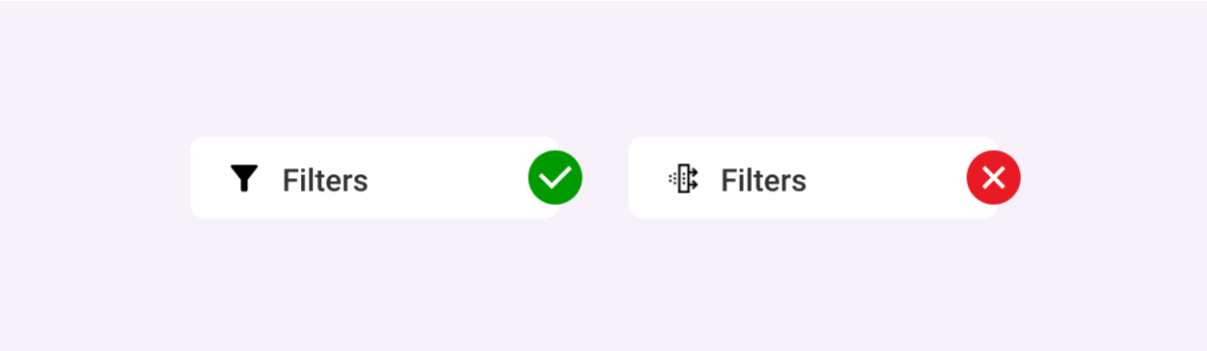


Figure 5: Icons Example

2.3 User control and freedom

```
1 Users often perform actions by mistake. They need a clearly
     marked "emergency
2 exit" to leave the unwanted action without having to go through
     an extended
3 process.
```

2.3.1 Indicative examples

Undo & Redo

The third principle talks about giving the freedom to the user to navigate and perform actions

- for instance, the freedom to undo or redo any accidental moves

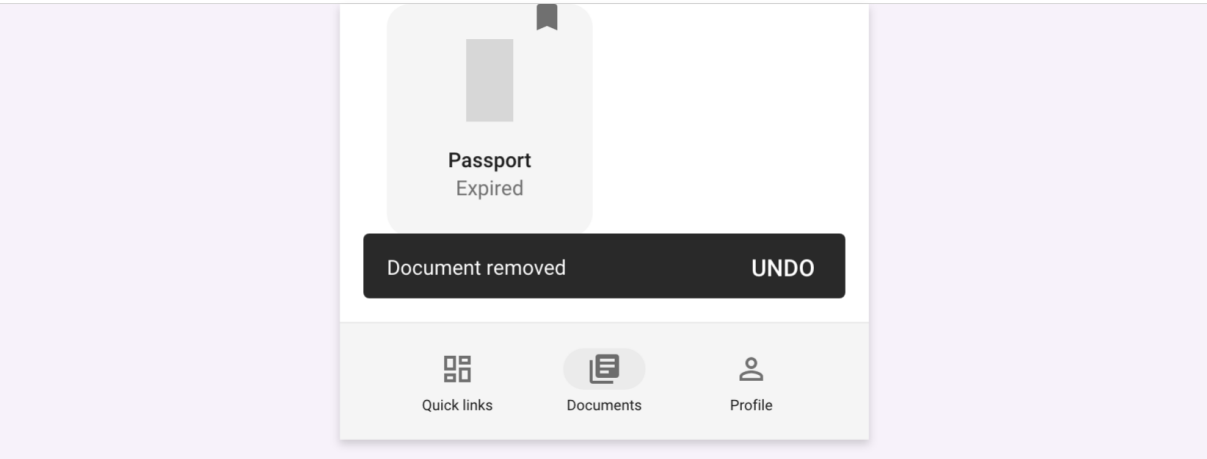


Figure 6: Undo and Redo Example

2.4 Consistency and standards

```
Users should not have to wonder whether different words,
   situations, or actions
mean the same thing. Follow platform and industry conventions.
```

App should follow interface standards and platform conventions. Conventions have been established that users are familiar with. This knowledge should be capitalised upon to make the app have a higher level of intuitiveness.

E.g. Position of menu, Navigation bar, Search location

2.5 Error prevention

```
Good error messages are important, but the best designs
   carefully prevent
problems from occurring in the first place. Either eliminate
   error-prone
conditions or check for them and present users with a
   confirmation option before
they commit to the action.
```

2.5.1 Indicative examples

Confirmation dialogue

For accidental actions such as miss-clicks

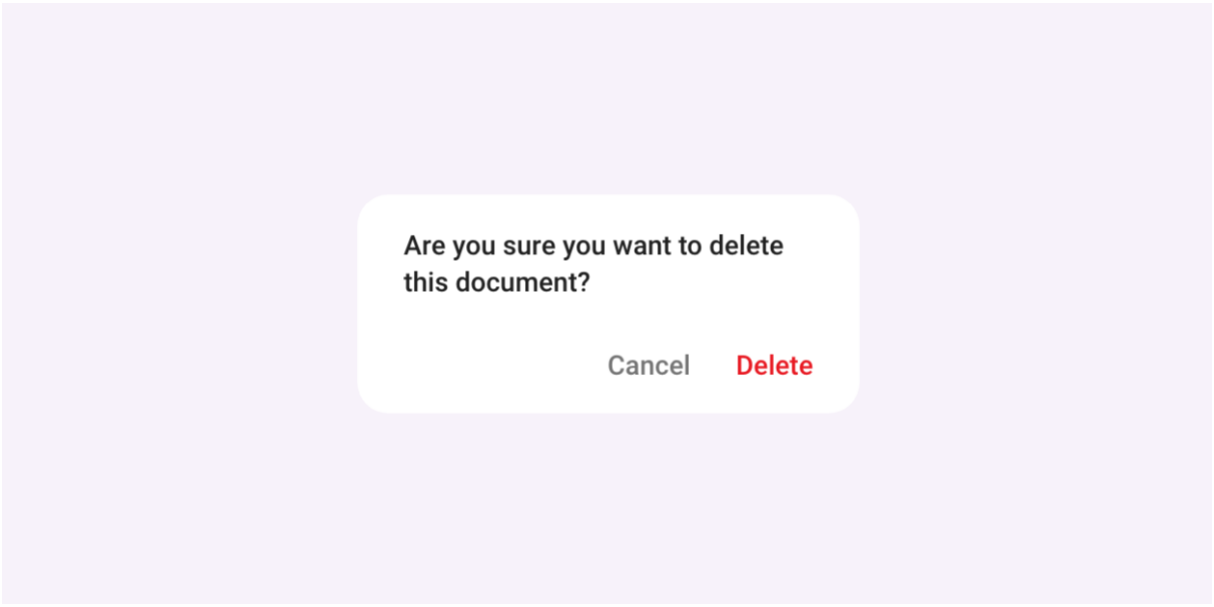


Figure 7: Confirmation Dialogues Example

Flexible inputs

Flexible inputs allow people to answer questions the way they want instead of the way a database requires them to. But these input fields come with a promise to users: “whatever format you choose, we’ll take it.” For example, a phone number can be entered in various ways by different people. The field can either format it accordingly on each own or provide a hint of the expected format instead of producing in-line errors or result in guesswork.

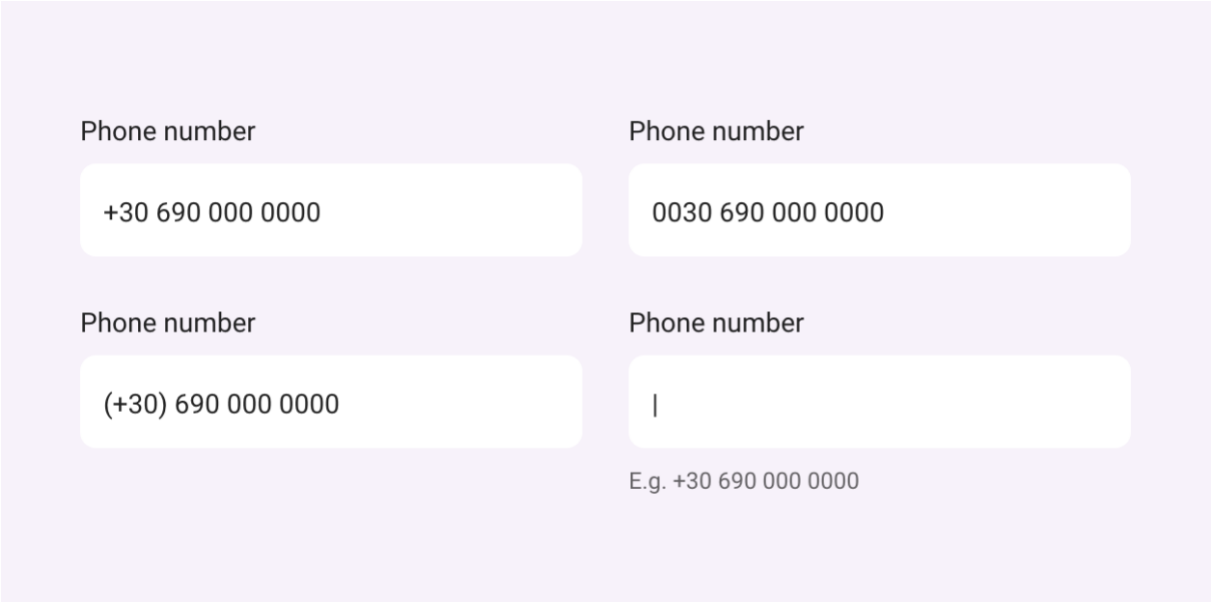


Figure 8: Flexible Inputs Example

2.6 Recognition rather than recall

```
Minimize the user's memory load by making elements, actions, and
    options
visible. The user should not have to remember information from
   one part of the
interface to another. Information required to use the design (e.
   g. field labels
or menu items) should be visible or easily retrievable when
   needed.
```

2.7 Flexibility and efficiency of use

```
Offer shortcuts quick ways to get one or more tasks done with
   your apps. They
should speed up the interaction with an app for the expert user
```

2.7.1 Indicative examples

It's possible to improve the efficiency of interaction with an app for experienced users with ways that will allow them to complete frequent actions faster.

Bookmarked or Recently used documents on homepage

Users can customise their home screens with the documents most relevant for them.

2.8 Aesthetic and minimalist design

```
Interfaces should not contain information which is irrelevant or
    rarely needed.
Every extra unit of information in an interface competes with
   the relevant units
of information and diminishes their relative visibility. Use
   whitespace in
harmony with your content.
```

2.9 Help users recognize, diagnose, and recover from errors

```
Error messages should be expressed in plain language (no error
   codes), precisely
indicate the problem, and constructively suggest a solution.
```

2.9.1 Indicative examples

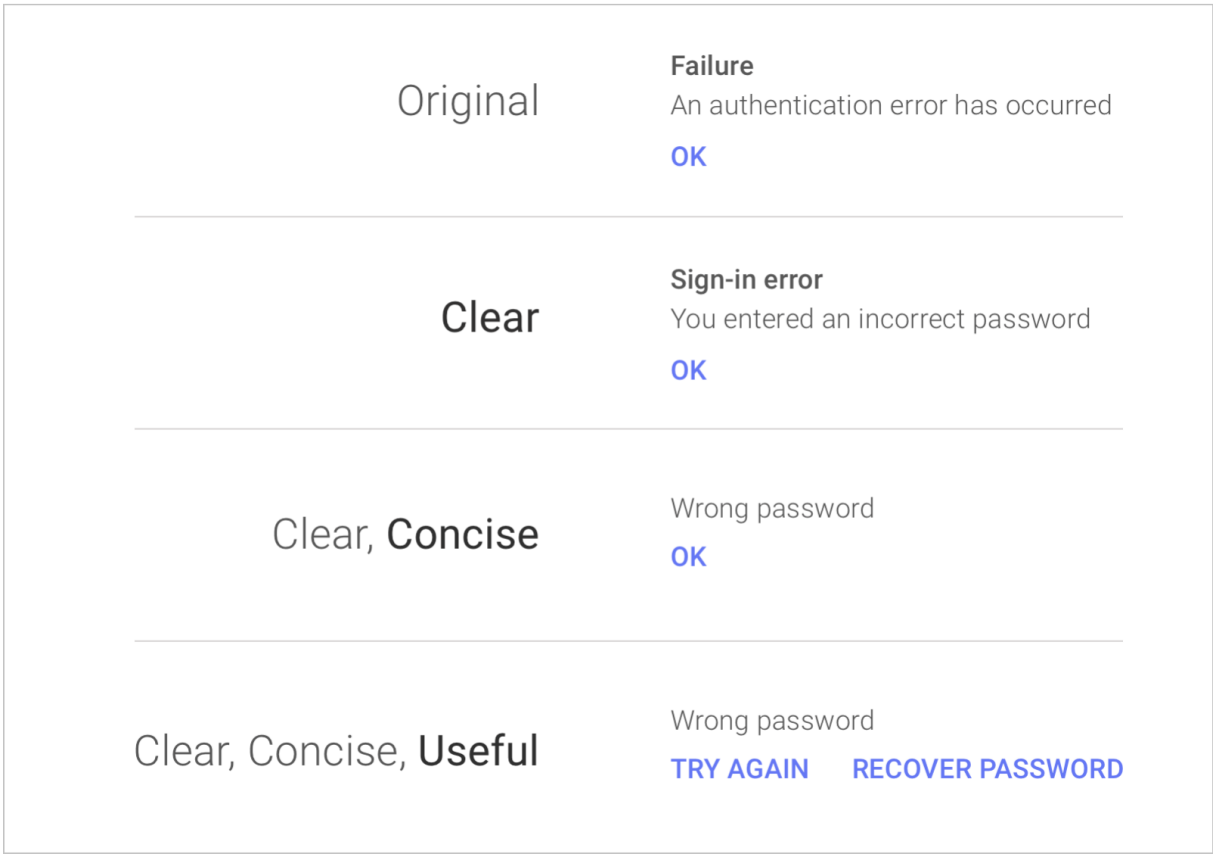


Figure 9: Error Messages Examples

2.10 Help and documentation

```
It's best if the system doesn't need any additional explanation. However, it may
be necessary to provide documentation to help users understand how to complete
their tasks.
```

2.10.1 Indicative examples

This can come in the form of App-onboarding, tutorials, F.A.Q.s or a Help section.

2.11 Accessibility

An estimated 100 million people in the EU have some form of disability, and so represent an important segment of its population and a large user group.

With Europe's ageing population this number is only going to rise. Keeping this in mind, it is important to distinguish accessibility from disabilities. Accessibility in this case, refers to making a website accessible to users who due to their temporary or permanent condition, their age, or their situation may face issues with accessing website content. For example, individuals with reduced manual dexterity due to injury or neurological conditions (permanent), or with an injured arm (temporary), or a new parent holding a baby (situational) all experience difficulties that may impede movement, coordination, or sensation or what is most commonly referred to as motor disability. Therefore, it concerns a much wider audience that one may initially think. The definition of disability differs as the term disability refers to 'long- term physical, mental, intellectual or sensory impairments which in interaction with various barriers may hinder a person's full and effective participation in society on an equal basis with others. By delivering the user experience in a way that is accessible to people with the aforementioned needs, we are providing equal access to information for all citizens regardless of their situation or condition.

2.11.1 Layout

Aim to have at least the main controls for the app at the bottom half of the screen when they are easily reachable with the thumb when operating the phone with one hand. The top half should be used for displaying information, documents, QR codes etc.

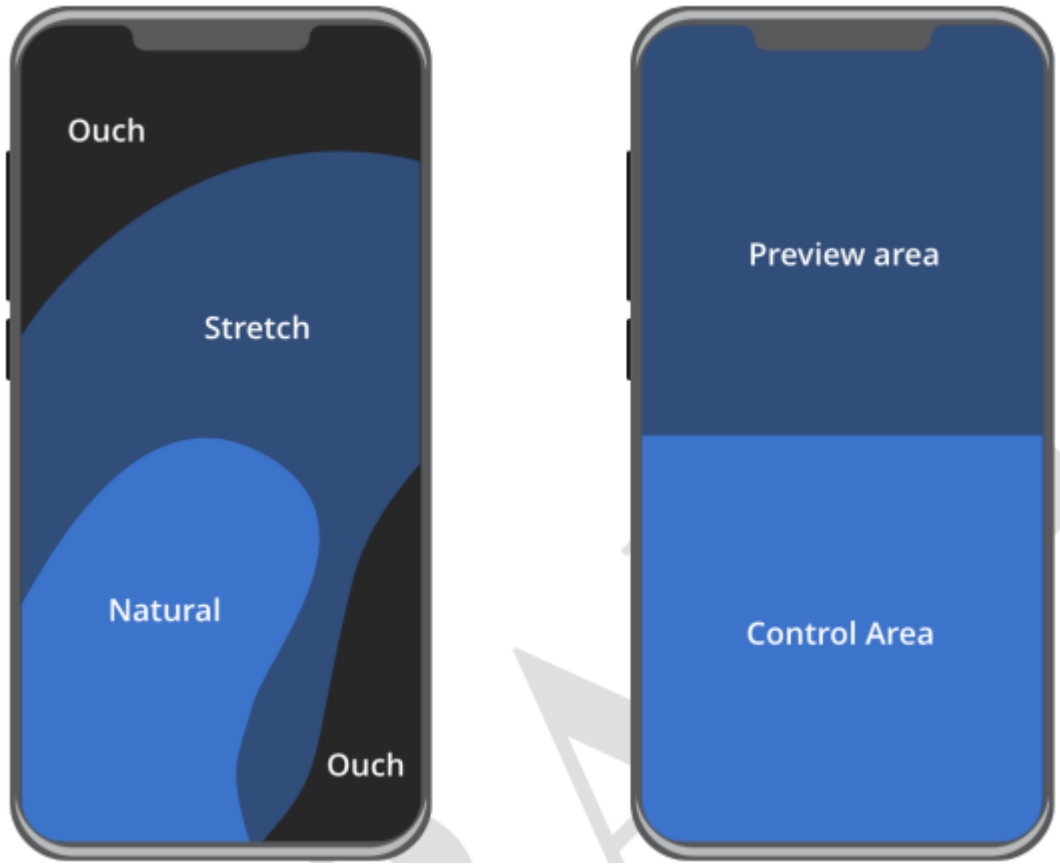


Figure 10: Layout

2.11.2 Target sizes

A target size is the area that can be activated in order to interact with an element. Individuals with dexterity challenges may find it more challenging to utilize a website if the target size is smaller. In this section, we'll examine methods (Apple's HIG and Google's Material for generating target sizes that are user-friendly, uniform, and properly spaced. A person's ability to interact with smaller controls may be impacted by a disability or a combination of disabilities that affect their motor movements and dexterity, as well as by the act of using a website while on the move, such as while walking or commuting.

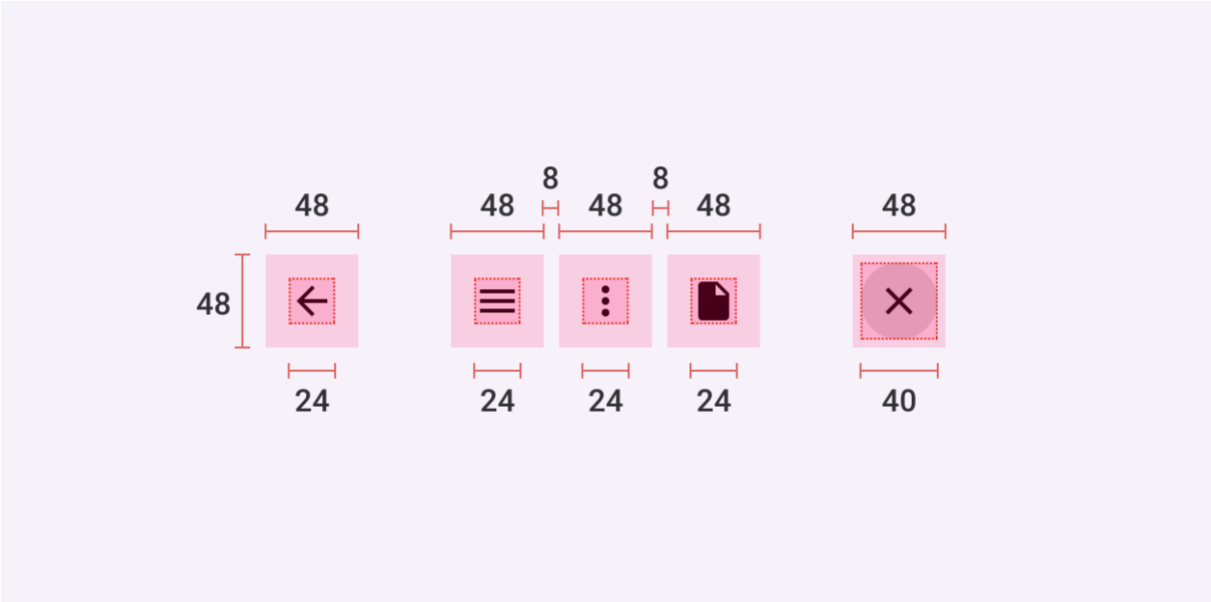


Figure 11 : Target Sizes

2.11.3 Colour contrast guidelines

Text to background colour contrast should meet a 4.5:1 ratio.

How to check: enter the hex codes for the foreground and background colours using: https://whocanuse.com/

2.11.4 Font size guidelines

The UI should be designed to support up to x 2 the text size without breaking.

2.11.5 Animations

Avoid adding flashing, blinking, and rotating animations on the background. Excessive screen movement with no mechanism to control can make it difficult for users to gather information.

Animations and transitions should be:

- **Informative** (Motion design informs users by highlighting relationships between elements, action availability, and action outcomes.)
- **Focused** (Motion focuses attention on what's important, without creating unnecessary distraction.)
- **Expressive** (Motion celebrates moments in user journeys, adds character to common interactions, and can express a brand's style.)

2.11.6 Screen readers

Make sure you provide the relative support for screen readers. Consider how the reader is going to read the screen and place items accordingly for convenience. In case of having to read through a lot of content to get to the main controls, consider providing a skip button.

2.12 Writing

Text should be understandable by anyone, anywhere, regardless of their culture or language. UI text can make interfaces more usable and build trust. Text should be clear, accurate, and concise.

2.12.1 Write in the present tense

Use the present tense to describe product behaviour. Avoid using the future tense as this usually requires later updates.

Use the present tense to describe product behaviour. Avoid using the future tense to describe the way a product always acts. When you need to write in the past or future tenses, use simple verb forms. This may not be applicable to all languages; the overall goal is to be as concise as possible without compromising clarity.



Figure 11: Example showing “Document added” text

Write in the present tense.

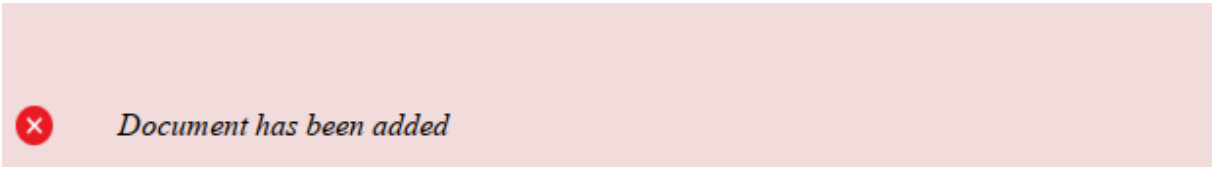


Figure 12: Example showing “Document has been added” text

Don’t write in different variations of the present tense, such as the present perfect tense.

2.12.2 Begin with the objective

When a phrase describes a goal and the action needed to achieve it, start the sentence with the goal.

```
1 To add a document, click +
```

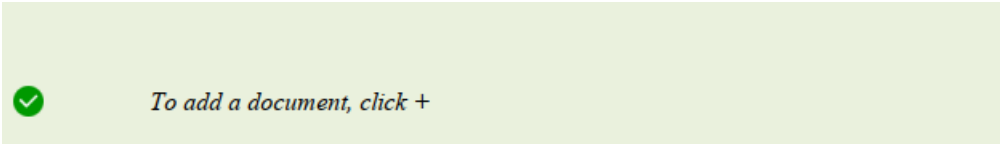


Figure 13: Example showing “To add a document, click +” text

Start a statement with the objective (“to add a document”) and end it with the user action (“click +”).

```
1 Click + to add a document
```

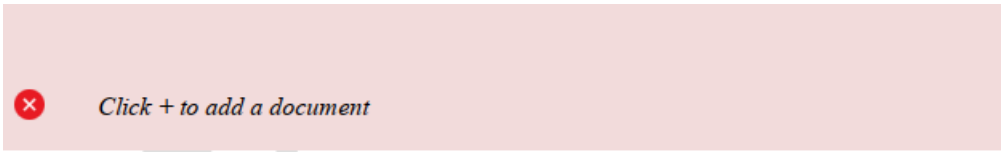


Figure 14: Example showing “Click + to add a document” text

Don’t state the action the user takes (“Click +”) before the objective (“to add a document”).

2.12.3 Avoid combining first and second person

To avoid confusing the user, avoid using “me” or “my,” and “you” or “your,” in the same phrase.

```
Change your preferences in My Account
```

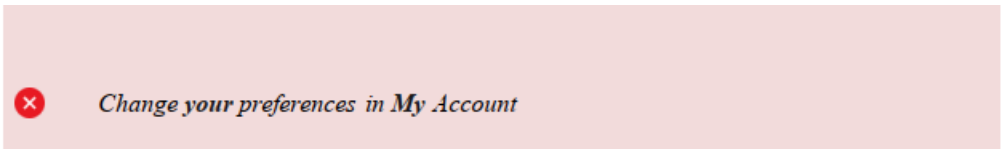


Figure 15: Example showing “Change your preferences in My Account” text

Don’t refer to the user in both the second person and the first person within the same phrase.

```
Change your preferences in Account
```

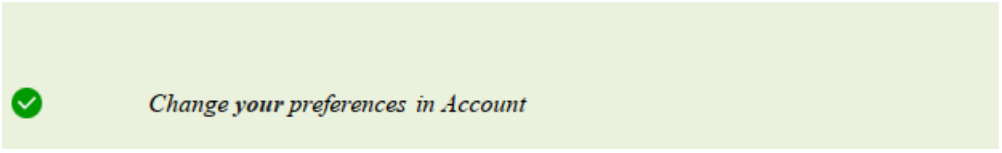


Figure 16: Example showing “Change your preferences in Account” text

---

3 EUDI Wallet - Design Considerations

This section lists specific areas/features on which design considerations are deemed important to ensure a common user experience across the national implementations of the EUDI Wallets. It shall be noted that this list highlights specific areas which are prioritised as important but does not aim to be an exhaustive list.

3.1 User authentication

- Covering common user authentication aspects, e.g. PIN, biometrics etc.
- Exploring the balance between the corresponding security aspects comparing to the user friction points throughout the entire user flow (e.g. required only at the point of sharing data? Or at login as well?)
- *Guidelines around 'user consent'* in data sharing scenarios (e.g. requesting user consent, enforcing trust)

3.2 Browsing credentials/documents

- Guidelines in relation to displaying a list of credentials/attestations in the EUDI Wallet

---

3.3 QR code presentation

- Guidelines in relation to presenting the QR code for the corresponding proximity use cases

---

3.4 Confirmation/Summary/Authentication results

- Guidelines in relation to the authentication results presentation, i.e. successful/unsuccessful identification and authentication

- Guidelines in relation to data transfer results for proximity sharing use cases, i.e. successful/unsuccessful data transfer)
- Covering guidelines related to the confirmation/summary results presented to the user

---

3.5 Error Messages

- Handling/Display of error messages in different scenarios
  - Erroneous user credentials
  - User is not authenticated.
  - Document is considered invalid.
  - Relying party is not considered trusted.
- Principles/guidelines on how these shall be presented/structured etc.

3.6 Privacy/Security by Design

- Covering applicability of privacy/security aspects in the data sharing process (e.g. visual representation _of ‘password’ field)

3.7 Trust Mark

- Establish trust through the use of the EUDI Wallet Trust Mark
- Applicability and placement in the corresponding sharing processes

---

3.8 Notification guidelines

- Guidelines in relation to displaying user notifications (where applicable) in the EUDI Wallet

---

4 Conclusion

In conclusion, this EUDI Wallet Design Guide document represents the first iteration of what intends to be a 'living' document, which will be further elaborated for the specificities of the EUDI Wallet functionalities, as listed in section 3 of the document. As such, it is recognized that there may be areas for further elaboration and analysis on which feedback and improvement suggestions from stakeholders is anticipated.

Taking into consideration that the EUDI Wallet Design Guide shall be applicable for the national implementations of the EUDI Wallet, the boundaries of this document are set to common principles that shall be applicable to all national implementations. These shall be considered as recommendations to ensure a similar user experience across the different national implementations. By taking a collaborative approach and continuously improving upon this document, the aim is to create a EUDI Wallet Design Guide that assists in the national implementations, while at the same time meets the user expectations. We encourage stakeholders to review this EUDI Wallet Design Guide document thoroughly and kindly provide feedback that will assist if further shaping this design guide.

EUDI WALLET DESIGN GUIDE - DATA SHARING SCENARIOS

v1.11.0

1 Situations for Identification/Authorization

In alignment with section '6.4' of the Architecture Reference Framework (ARF), there are four main types of flows that the EUDI Wallet must support. These main flows are as follows:

- Remote same-device flow
- Remote cross-device flow
- Proximity supervised flow
- Proximity unsupervised flow

It shall be noted that remote supervised cases are also considered as possible in some use cases, but the document focuses mainly on the types of flows detailed in the ARF, as listed in the above list.

The ‘EUDI Wallet Design Guide’ aims to expand on the defined ‘Service Blueprints’ (published in ‘ARF v1.1.0’ where the focus is on the ‘remote same-device’ and ‘proximity’ flows. However, design interactions applicable for the ‘remote cross-device’ flow will also be analysed at a high-level.

In relation to the remote flows, it shall be noted that the data exchange occurs over the Internet, but the key differentiator is related to the devices being utilized in the flows. In the ‘remote same-device’ flow, the EUDI Wallet User is on a mobile device, requesting access to a Relying Party’s service (i.e. app or browser) and authorizes by using the EUDI Wallet app, which is also installed on the same device.



Figure 17: Login interface showing EUDI Wallet login button on mobile device

In contrast, in the ‘remote cross-device’ flow, the EUDI Wallet user consumes information from a Relying Party service on another device than the EUDI Wallet device, e.g. user visits the relying party’s service on their web browser on a PC and uses the EUDI Wallet app to scan a QR Code on a login page in order to get access to a service provided by the Relying Party.

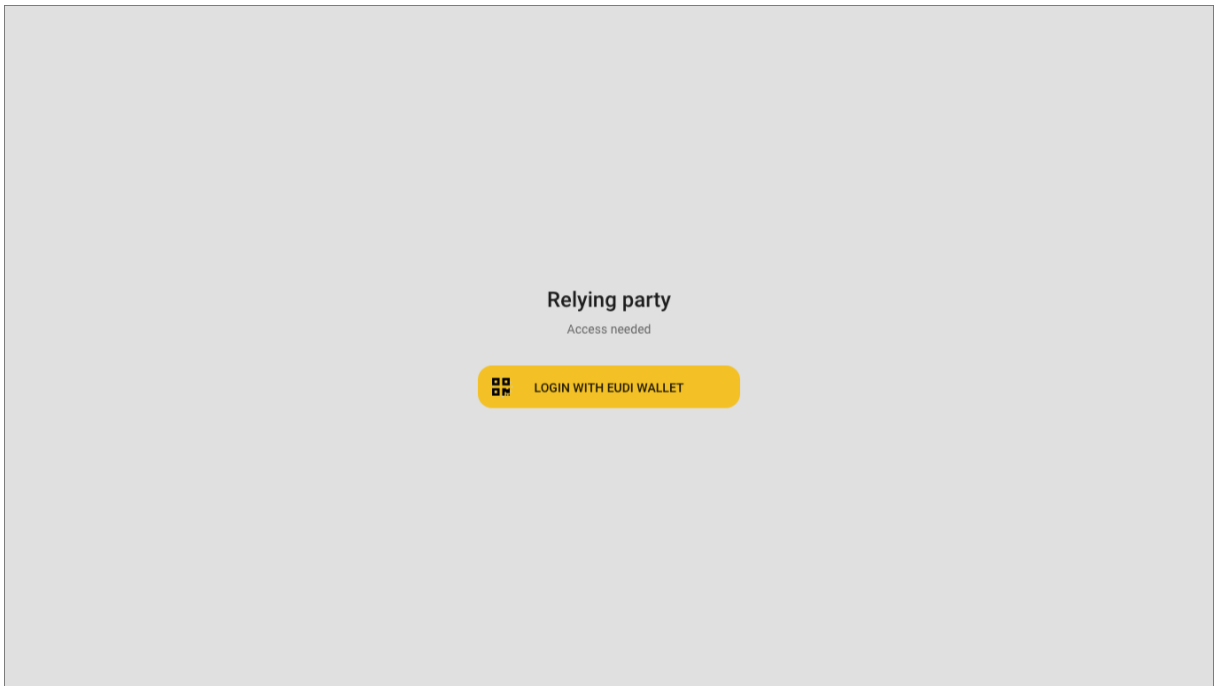


Figure 18: Login screen with EUDI Wallet login option on desktop browser

In relation to the ‘proximity’ flows, both flows are related to scenarios where the EUDI Wallet User is physically close to a Relying Party, the user does not necessarily have internet connectivity and the data presentation occurs using proximity protocols (NFC, Bluetooth, QR- Code, etc.). The key differentiator in the two proximity flows, is that in the supervised flow, the EUDI Wallet presents data (e.g. a mobile driving license) to, or under the supervision of, a human acting as a Relying Party (who may operate a device of their own). In the unsupervised flow, the EUDI Wallet presents verifiable attributes to a machine without human supervision.

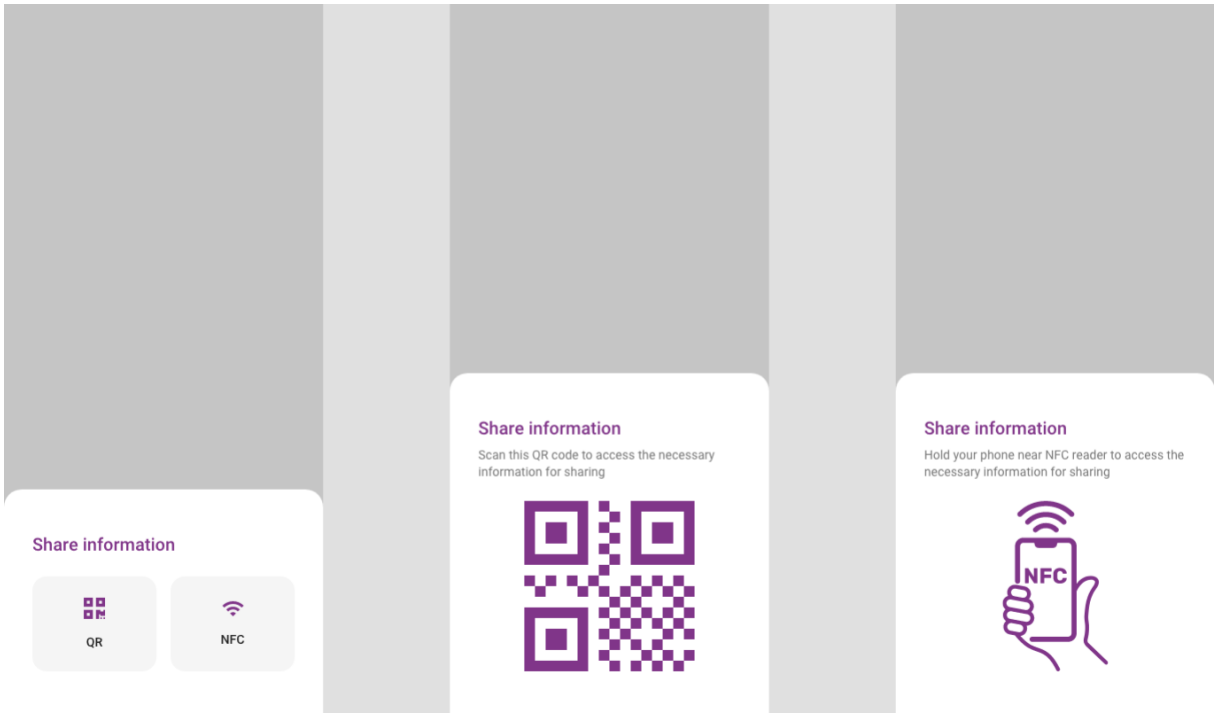


Figure 19: Share information screen showing QR and NFC sharing options

---

2 Identifications

2.1 Identification Points

The following points are depicted as identification points within the described user flows:

- identification on application launch
- identification when authorizing disclosure of data in proximity flows (possibility to be disabled via corresponding settings) (authorization process)
- identification when presenting via deep link (authorization process)
- identification after being idle

2.2 Identification Methods

A set of 'authentication means' applicable for the EUDI Wallet are being analysed in this Design Guide. These are:

- PIN
- Pattern
- Biometrics
- Password
- OTP

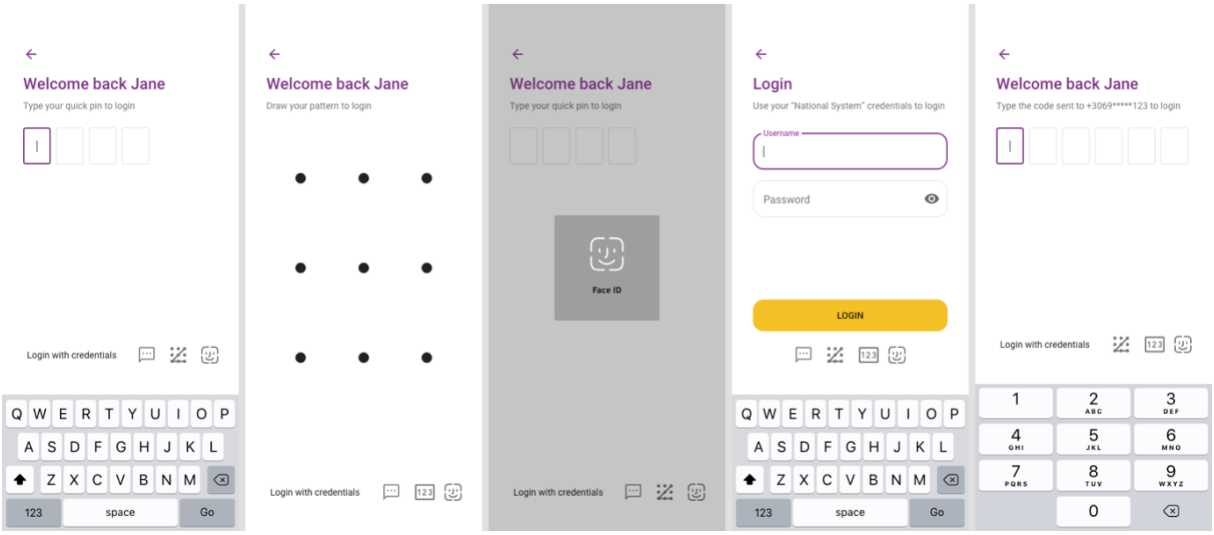


Figure 20: Multiple authentication method screens showing PIN, pattern, biometrics, password and OTP options

It shall be clarified that different levels of security shall be required per use case, e.g. sharing a user's 'Person Identification Data' is associated with 'High Level of Assurance', while presenting a 'loyalty card' may be associated with simpler means of authentication.

Thus, it is expected that a combination of 'authentication means' are available for the user to select and be used as per the needs of the applicable use case. However, it shall be clarified that the available authentication means are defined by the 'EUDI Wallet Provider' and the 'Device Manufacturer' and in principle shall adhere to the native way of the operating system, e.g. password and biometrics.

It shall be noted that this section reflects a preliminary analysis which is based on desk research and not on usability testing/field research and it shall further be expanded and validated with

detailed research/user testing.

The analysed authentication means are being scored-in a scale of 0 to 10-against a set of design- related criteria, aiming to quantify the pros and cons of each mean.

The criteria used for the rating are:

- **Convenience**: The level of intuitiveness of each authentication method
- **Experience**: Overall user experience from a user perspective (i.e. smooth experience)
- **Speed**: Speed of use for the user's authentication process
- **Error Prevention**: Assisting users to minimize potential errors in the authentication process
- **Accessibility**: Adherence to accessibility standards/specificities

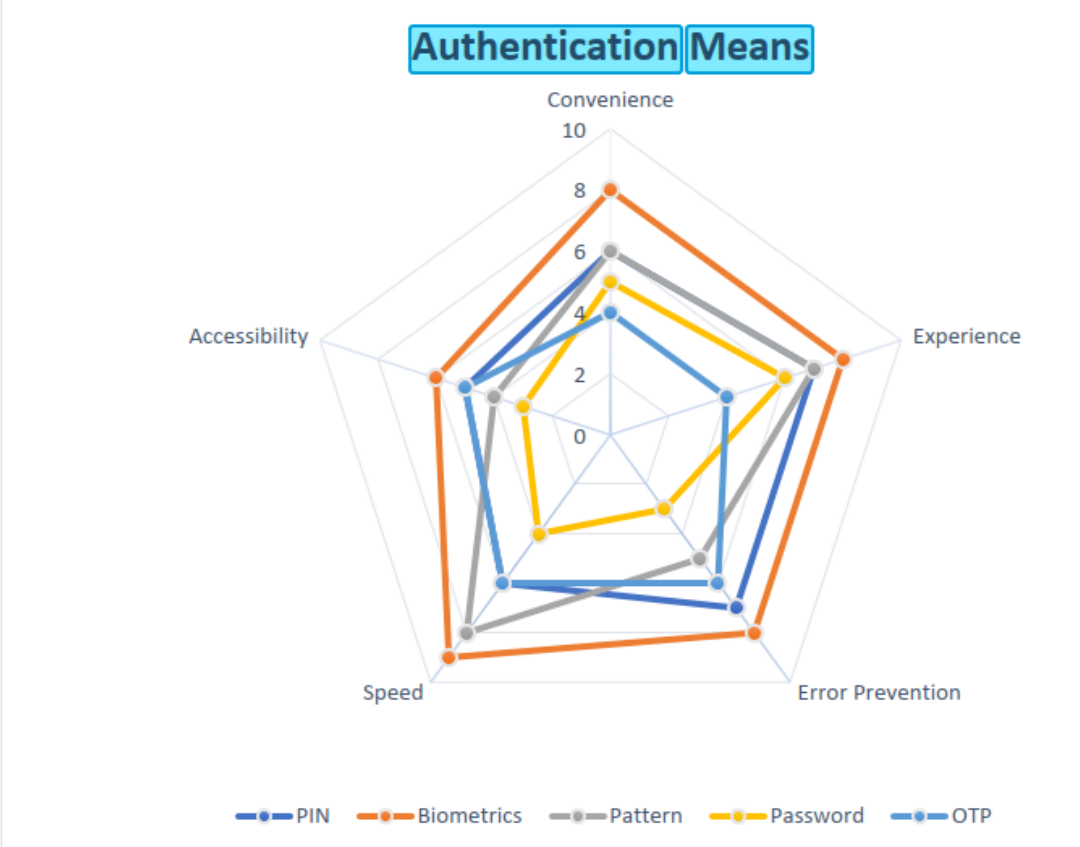


Figure 21: Radar chart comparing different authentication methods across multiple criteria

NOTE: *Ratings have been based on a desk study and not actual first-hand testing.*

Authentication Methods Comparison

Method	Pros	Cons
PIN	Short and easy authentication method Flexibility in PIN requirements	Slower unlocking compared to other authentication methods Requires users to memorize numbers Recovery can be hard if you forget the PIN Often predictable
Pattern	Simple and intuitive to use	Many people choose simple, predictable patterns Input method is visible to those around you Belongs to a third party
Password	More secure than a PIN Flexibility in password requirements	Easy to guess Slower unlocking Password recovery can be as hard as a PIN recovery
Biometrics (fingerprint)	Fast and convenient authentication method	Fingerprints can be replicated Fingerprint distortion can cause failures Belongs to a third party

Method	Pros	Cons
Biometrics (face scan)	Fast unlocking method It doesn't require memorizing codes and passwords	Light effects and facial changes can cause failures Screen orientation and distance from the camera can impact readability The scanner can be fooled by user's photos or sometimes familial similarities Provided by a third party
One Time Password (OTP)	Alleviates the burden associated with memorizing passwords Usually utilized as 2FA on top of PIN/Passwords but may also be used as an alternative to passwords (applicable after first registration to a service) Offers a sense of advanced safety for the user	Associated with higher 'interaction cost' (i.e. users are requested to type a code) May raise confusion if OTP is not received on time - multiple attempts to receive an OTP May require clear and concise OTP text (e.g. SMS or email)

3 Receiving & Configuring Data Request (by the User)

The EUDI Wallet should provide a secure and user-friendly environment by empowering users with granular control over presenting their data, ensuring transparency and clarity, and enabling user control and consent.

- **Selective Disclosure**: The EUDI Wallet should empower users to have granular control over the information they present. The EUDI Wallet should provide clear options for

selective disclosure, allowing users to choose between mandatory and optional information to be presented, intending to emphasize on the data points which are required to be shared by the user. It is recommended that optional data shall be grouped in collapsed sections and be unselected by default. On the other hand, it should be clearly depicted that mandatory data cannot be unselected. The app should show users a concise summary of the requested data, clearly indicating which fields are mandatory and which are optional, as per each Member State (MS) / Relying Party (RP) policy decision. This empowers users to make informed decisions about what information they want to disclose, ensuring their privacy preferences are respected, with the risk of not completing a data request in a later step (more details in section 5 Error Cases).

- **Transparency and Clarity**: Transparency is key in ensuring that users are always aware of what information is being presented. The EUDI Wallet should include clear and concise explanations about the purpose of each data request, the relying party's identity, and how the data will be used, highlighting data storage and 'intent to store' aspects to the user. Utilising plain language and avoiding technical jargon can enhance understanding and minimise user confusion.
- **User Control and Consent**: To promote a sense of trust and control, the EUDI Wallet should prioritise user consent throughout the data-sharing process. The app should provide intuitive controls to enable users to configure their preferences easily. Clear notifications should be presented when changes are made, ensuring users are always aware of their data-sharing settings and can adjust them as needed.
- **Pre-authorisation**: Pre-authorisation is a feature allowing the user to give automatic consent for releasing certain attributes, prior to any interaction. 'Pre-authorisation' as a concept may be implemented in the form of one or multiple 'profiles'. For example, if the user selects an 'age verification' profile, the EUDI Wallet will always release the corresponding attribute (e.g. age_over_NN) when requested by a Relying Party. However, if the user chooses to set a 'law enforcement' profile, the EUDI Wallet will release all attributes with a Relying Party, without giving the User the option of withholding consent during the transaction.

  It shall be highlighted that the 'pre-authorisation' concept may optionally be implemented, under the following conditions:

  - The pre-authorisation mechanism shall give the user the possibility to select which attribute(s) the EUDI Wallet Instance must release with which specific Relying

Parties without asking for user consent during the interaction. User consent shall never apply indiscriminately to all Relying Parties or to all attributes.

- A Relying Party for which pre-consent is given shall have been authenticated by the EUDI Wallet at least once. This is a consequence of the previous point as it is not possible to select a Relying Party if that Relying Party is not unambiguously known to the Wallet Instance. It shall be noted that this requirement holds for both proximity use cases and remote use cases.
- Giving pre-authorisation shall be a 'friction-full' process, meaning that it shall not be too easy and requires a considered user decision. Possibly, giving pre-authorisation should require an additional user authentication step.
- The EUDI Wallet shall be able to present to the user a clear overview of all pre-authorisation given, with the ability to easily change or withdraw one or more of these pre-authorisations.
- It shall be noted that pre-authorisations shall have a validity limit or the user should be regularly prompted to review any set up pre-authorisations.
- If pre-authorisation applies for one or more requested attributes, the EUDI Wallet shall release these attributes without first notifying the user. However, immediately afterwards the EUDI Wallet shall notify the User that one or more attributes were released on the basis of pre-consent. That notification shall include an option to withdraw the applicable user consent, but also highlight 'intent to store' aspects to the user.
- It shall be noted in the case where request also includes additional optional data request, it would be proposed pre-authorisation would prevail the potential request of optional data, since the concept of pre-authorisation would be introduced to simplify the user flow. However, further exploration and user research would be required for such flows.
- Solution providers shall duly consider the associated security/privacy risks associated with the pre-authorisation feature in conjunction with the specific conditions listed above.

- **Relying Party Trustworthiness**: Trust in relying parties is crucial for users to feel confident sharing their personal information. The EUDI Wallet should incorporate clear information and visual indicators or badges e.g. Trust Mark could be utilised to

indicate whether the Relying Party is considered trusted, based on the underpinning trust framework established. Providing users with this data helps them make informed decisions about which parties they trust and are comfortable sharing their data with. Further information must be provided upon clicking on the badge regarding what it means to be a trusted party and how you become one.

The EUDI Wallet aims to promote user confidence and foster a sense of control and privacy, thereby enhancing the overall adoption and utility of the app.

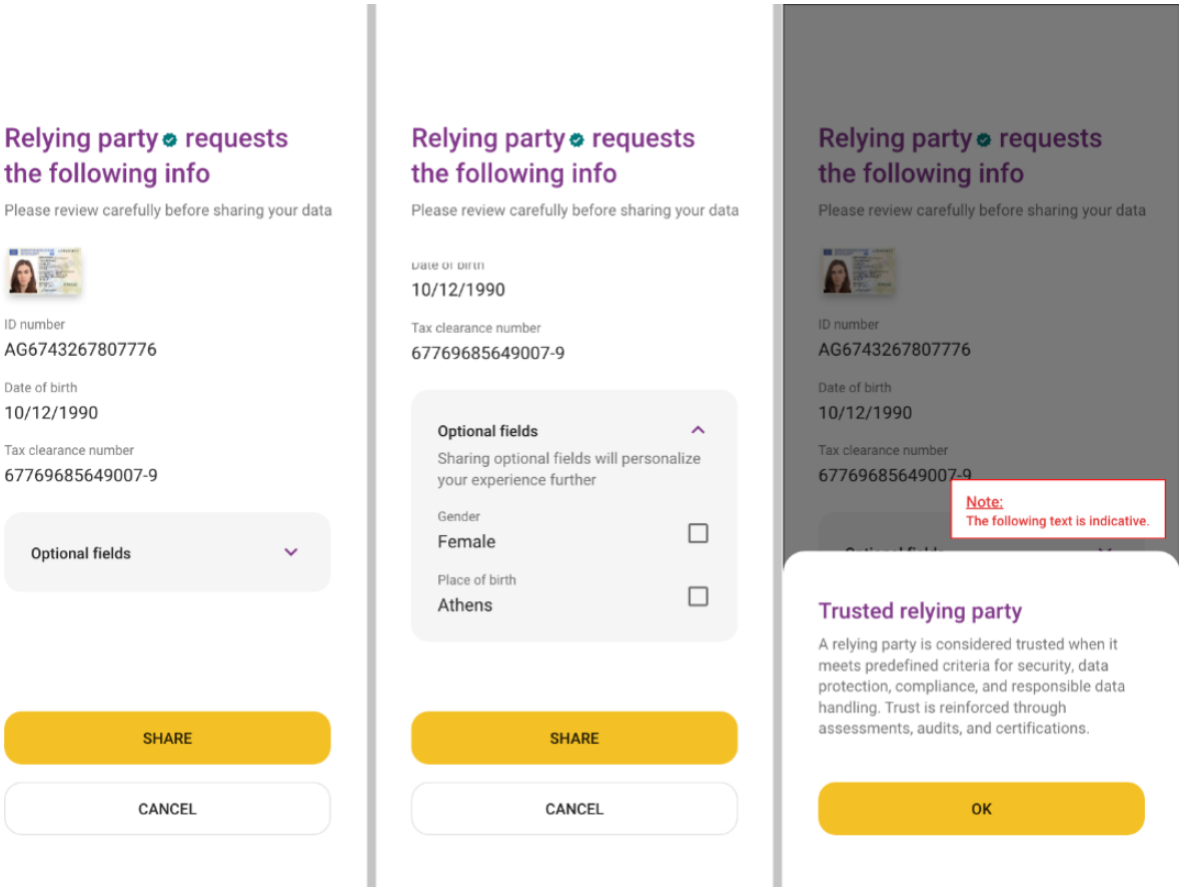


Figure 22: Data sharing screens showing mandatory and optional information requests from Relying Party

4 Authorization

4.1 Remote (Online) Authorization and Authentication

To enable authorization for data sharing during online processes, the following methods can be employed:

4.1.1 Same Device

- **Deep Link**: When sharing data on the same device as the wallet app, users can simply click on a deep link provided by the third-party service, such as “Log in via EUDI Wallet.” This action will instantly launch the EUDI Wallet app and present the authorization screen.

4.1.2 Cross Device

- **QR Code**: When sharing data from a different device, users can scan a QR code generated by the third-party service using their EUDI Wallet. This will seamlessly open the app and display the authorization screen.

4.2 Proximity-Based Authorization

To enable authorization for data sharing during offline processes, the following methods can be employed:

4.2.1 Cross Device (Attended)

- **QR/Bluetooth**: When presenting data to a Relying Party (attended service), users can display a QR code on their EUDI Wallet to be scanned by the Relying Party’s reader device and transmit the information via Bluetooth using their EUDI Wallet.
- **NFC/Bluetooth**: Alternatively, users can use Near Field Communication (NFC) to engage with the Relying Party’s device and Bluetooth to transmit the data to the Relying Party service through their EUDI Wallet.

4.2.2 Cross Device (Unattended)

- **QR/Bluetooth**: When presenting data to a Relying Party (unattended service), users can display a QR code and present the information via Bluetooth through their EUDI Wallet.
- **NFC/Bluetooth**: Similarly, users can utilize NFC and Bluetooth to transmit the data to the Relying Party service through their EUDI Wallet.

During the authorization processes, a comprehensive screen will be presented to the citizen which shall clearly display both mandatory and optional data requested by the third-party service (as presented in 'section 3'). The citizens will have the freedom to choose which optional information they wish to share, providing them with complete control over their personal data. Additionally, a clear indication of the data transfer outcome shall be presented to the users in all scenarios described above, e.g. descriptive message regarding successful data transfer.

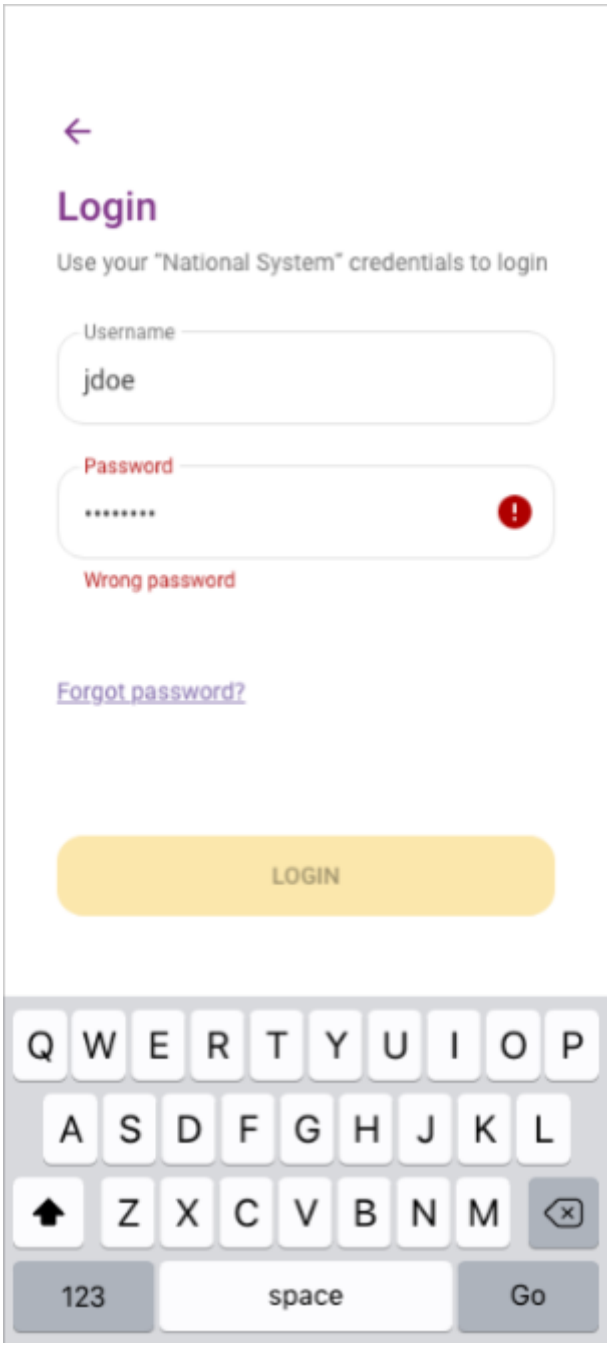
---

5 Error Cases

Handling/Display of error messages in different scenarios. (Principles/guidelines/consequences on how these shall be presented/structured etc.)

- **5.1 Erroneous user credentials**

  When the user attempts to log in to the app, expects to receive feedback indicating the success or failure of their login attempt.



The user gets an error message indicating that his credentials were wrong:

- **5.2 Multiple failed attempts to login or present information**

  When the user is facing multiple failed attempts (e.g., 3) when trying to log in, they get an error message as feedback from the app. The error message typically indicates that the entered credentials are incorrect or that there has been a problem with the

identification process. It can also guide the user in resolving the issue by reviewing the credentials or checking for typos, etc., and prompts the user to try again in 2 minutes or try to recover their password, hence the recovery functionality may be presented as a fallback option for the user in case his/her log-in attempts are not successful. By limiting the number of login attempts, the app reduces the risk of malicious factors attempting to gain unauthorized access by repeatedly guessing passwords or usernames.

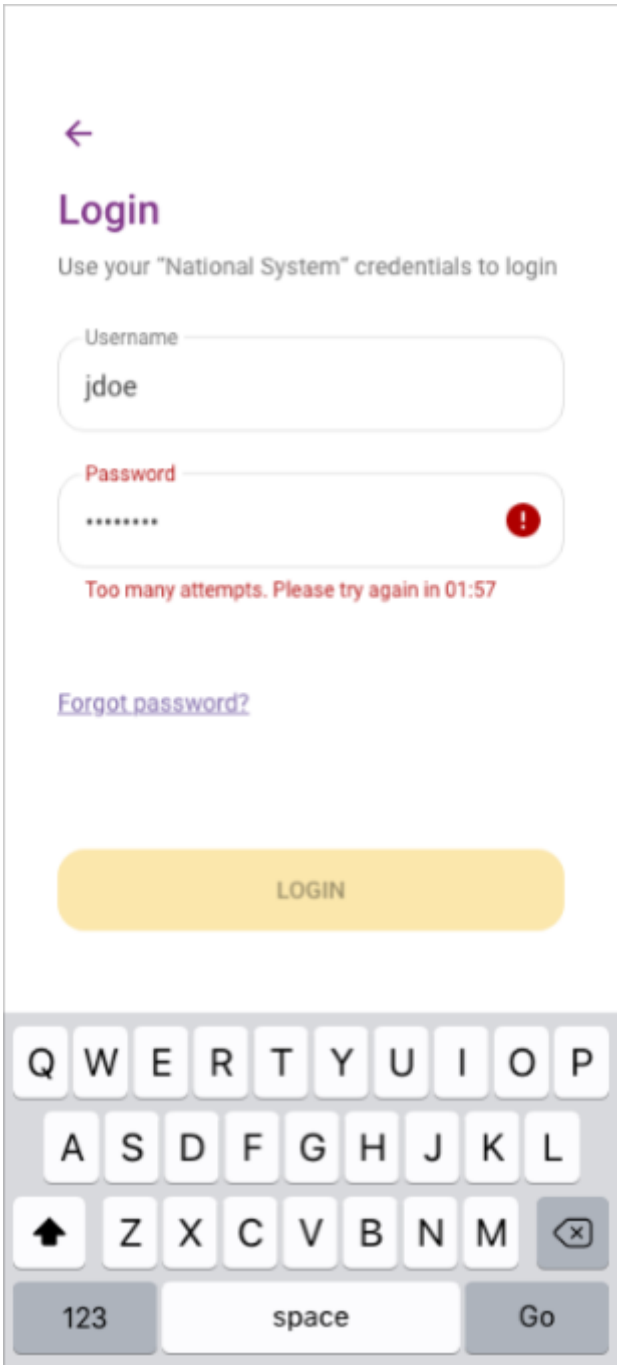


Figure 23: Login screen showing too many attempts error with timer

The user gets an error message indicating that they must try again later:

- **5.3 The document is considered invalid (expired/revoked)**

When the user presents an invalid document through the app, (e.g., a driver's license to a police officer) the app displays an error message on the user's screen, indicating that the document could not be verified because it is expired or revoked.

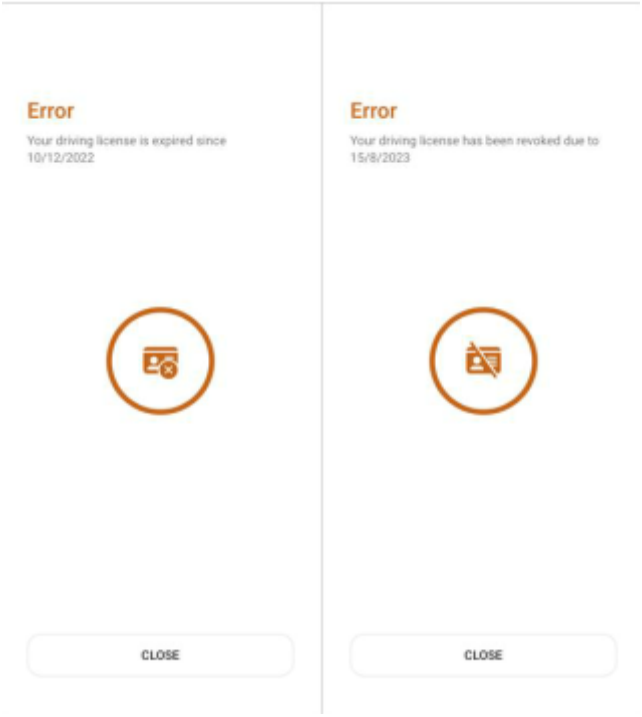


Figure 24: Error message showing additional documents required

The user gets a message indicating the status of the document:

However, the user should be warned if a document they have saved within the app is expired or revoked. The warning could be presented as a notification or prompt within the app, indicating that a saved document is approaching or has already passed its expiration date. The message could include information on how to renew or update the document, directing the user to the appropriate authorities, or providing relevant instructions.

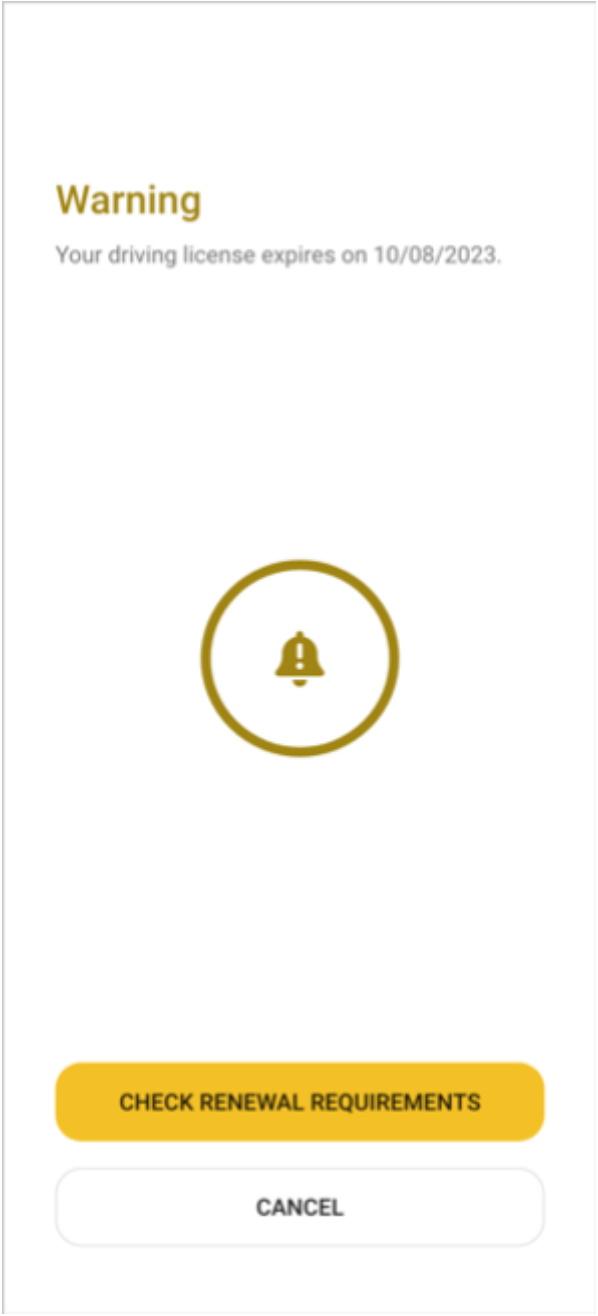


Figure 25: Warning notification about document expiration with renewal option

The user gets a message indicating that the document expires shortly:

By providing proactive reminders about expired documents, the app can contribute to a smoother user experience, help users remain compliant with regulations, and foster trust and confidence in the app's functionality and user support.

- **5.4 The Relying party is not considered trusted. Is not verified or could not be verified (Maybe address safety)**

  When the user attempts to share information through the app with a third party -a physical person or a digital service- and it turns out that the third party is not valid or is a fraud, they must get an alert warning message.

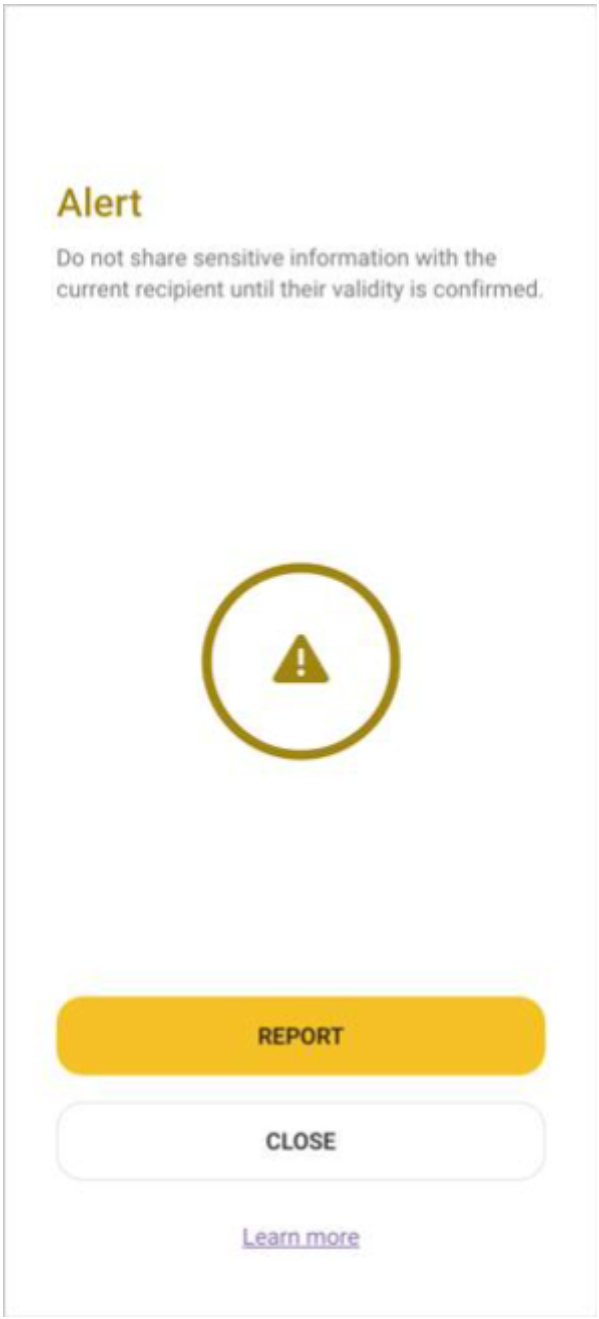


Figure 26: Alert warning about untrusted relying party with security options

The user gets a message indicating that they must not share information with that party. The options are to report it, to close the app, or to search for information about security:

- **5.5 The user fails to present requested document**

When a user scans their QR code using a QR code scanning device, they receive a prompt to provide additional documents, such as an ID. If the required document is not present in the user's app, an error message is displayed, notifying the user that the document is not stored in their app.

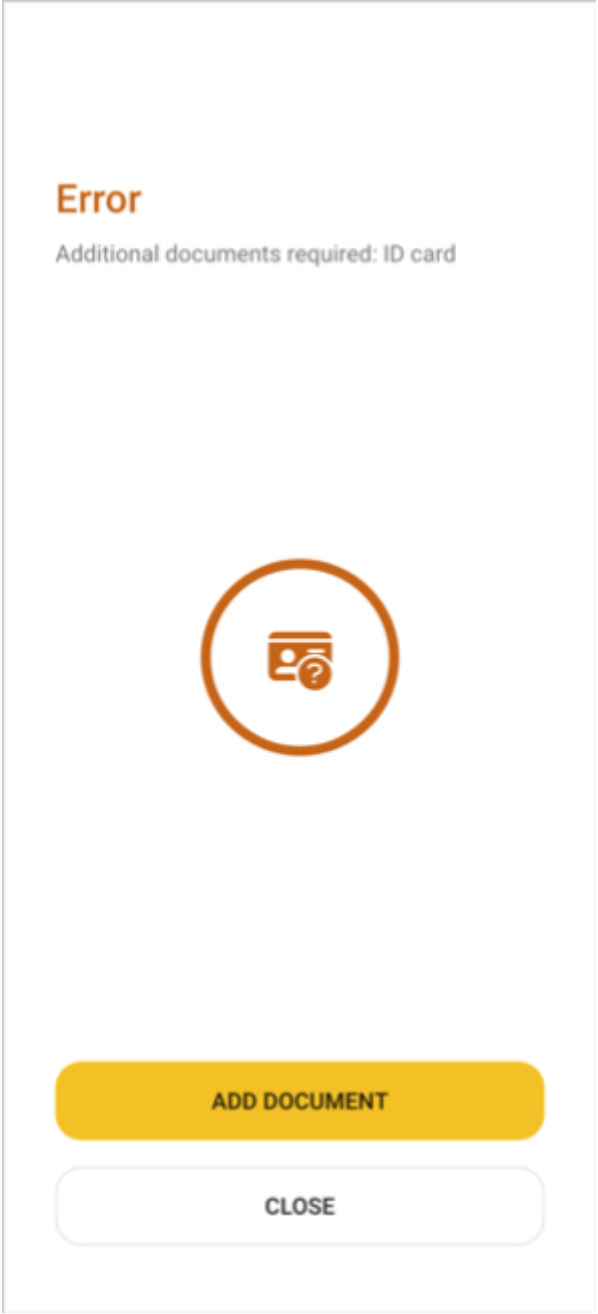


Figure 27: Error message showing missing ID card document with add document option

The error message then suggests adding the document from the available documents list.